Elko County Information Operations Policy Manual

Abstract / Executive Summary

Abstract

The Elko County Information Operations Policy Manual (maintained as the master *Policy_Manual.lyx* file) is the designated Authoritative System of Record for all governance controls, including the departmental security and service management standards defined herein. It establishes the mandatory frameworks required to ensure consistency, accountability, and compliance with applicable laws, regulations, and industry standards across the County's technology landscape.

Executive Summary

The policies contained herein are administratively mandatory and align the Department's strategic objectives with statutory requirements and industry control frameworks.

Compliance Alignment & Order of Precedence

The controls in this manual align with the following frameworks, listed in order of authority:

1. **State Law**: Nevada Revised Statutes (NRS), including Chapter 239 (Public Records), Chapter 205 (Computer Crimes), Chapter 603A (Security of Personal Information), and other applicable provisions.
2. **Administrative Regulation**: Nevada Administrative Code (NAC).
3. **Records Retention**: Nevada Local Government Records Management Program and mandatory retention schedules (Local Records Disposal Authority) under NRS 239.125.
4. **Law Enforcement Compliance**: FBI CJIS Security Policy Version 6.0.
5. **Security Controls**: NIST SP 800-53 Revision 5 (Security and Privacy Controls for Information Systems and Organizations).
6. **Strategic Risk**: NIST Cybersecurity Framework (CSF) 2.0.
7. **Risk Management**: NIST SP 800-37 Revision 2 (Risk Management Framework).
8. **Incident Response**: NIST SP 800-61 Revision 3 (Computer Security Incident Handling Guide).
9. **Governance**: COBIT 2019 (Governance and Management Objectives).
10. **Service Management**: ITIL v4 (Service Value System and Practices).

Additional Frameworks Referenced: NIST SP 800-181 Revision 1 (NICE Workforce Framework for Cybersecurity) and SFIA 9 (Skills Framework for the Information Age) are referenced for workforce role alignment under **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework) and do not participate in the authority resolution hierarchy above.

Authority and Scope

This manual, alongside the procedural library maintained in the System of Engagement, serves as the primary reference for governance, operational decision-making, audit defense, and interdepartmental service level agreements.

Compliance with these policies is mandatory for:

1. All Elko County Information Operations personnel.

2. All County employees, contractors, and vendors who access, administer, or support County information systems, infrastructure, or data governed by the Information Operations Department.

Deviations from these policies shall be managed through the formal exception management framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

Contents

1 Governance and Strategic Framework **1**
1.01 Department Mission and Strategic Objectives . . . 2
1.02 Code of Ethics and Professional Conduct . . . 4
1.03 Standard Operating Ethos . . . 7
1.04 Policy and Documentation Formatting Standards . . . 11
1.05 Policy Review and Update Procedures . . . 23
1.06 IT Governance and Oversight Structure . . . 28
1.07 Workforce Roles, Responsibilities, and Competency Framework . . . 33
1.08 Delegation of Authority and Decision Rights . . . 40
1.09 Risk Management Policy . . . 47
1.10 IT Financial Management and Procurement Policy . . . 54
1.11 Data Governance and Classification Policy . . . 60
1.12 IT Asset Management Policy . . . 68
1.13 Supply Chain Risk Management (SCRM) and Vendor Governance . . . 76
1.14 Stakeholder Engagement and Communications Policy . . . 84

2 Information Security **90**
2.01 Acceptable Use of Information Technology Resources Policy . . . 91
2.02 Personnel Security and Background Screening Policy . . . 96
2.03 Security Awareness and Training Policy . . . 102
2.04 Access Control Policy . . . 106
2.05 Identification and Authentication Policy . . . 114
2.06 Privacy and Data Protection Policy . . . 121
2.07 System and Communications Protection Policy . . . 127
2.08 System Integrity and Malware Protection Policy . . . 133
2.09 Vulnerability and Patch Management Policy . . . 137
2.10 Secure Configuration Baselines and Hardening Policy . . . 145
2.11 Audit Logging and Monitoring Policy . . . 150
2.12 Media Protection and Sanitization Policy . . . 159
2.13 Physical Security and Environmental Controls Policy . . . 165
2.14 Mobile Device and Remote Access Policy . . . 173
2.15 System Development and Secure Software Lifecycle Policy . . . 181

3 Service Management and Operations **188**
3.01 Service Catalog and SLA Policy . . . 189
3.02 Service Level Management and Metrics Reporting . . . 195
3.03 Service Communications Policy . . . 203
3.04 Service Delivery Feedback and Grievance Policy . . . 208
3.05 Service Request Fulfillment Policy . . . 213
3.06 Operational Incident Management Policy . . . 221
3.07 Problem Management Policy . . . 230
3.08 Service Configuration Management (CMDB) Policy . . . 237
3.09 Change Management Policy . . . 243
3.10 Release and Deployment Policy . . . 250
3.11 Capacity and Availability Management Policy . . . 255
3.12 Monitoring and Event Management Policy . . . 259
3.13 Knowledge Management Policy . . . 264
3.14 IT Project Management Policy . . . 269
3.15 Service Continuity and Contingency Planning Policy . . . 277

3.16 Service Improvement and Continual Improvement Plan . . . 284
3.17 System Maintenance and Vendor Repairs . . . 289

4 Incident Response **295**
4.01 Incident Response Policy Overview . . . 296
4.02 Identification and Reporting Procedures . . . 304
4.03 Containment Strategy and Playbooks . . . 313
4.04 Eradication Procedures and Scenario Guides . . . 321
4.05 Recovery Operations and Restoration Prioritization . . . 330
4.06 Communication Protocols and Partner Integration . . . 340
4.07 Postmortem Review and Lessons Learned . . . 353

5 Compliance and Oversight **361**
5.01 Policy Implementation, Enforcement, and Legal Alignment . . . 362
5.02 Internal Audits, Self-Assessment, and Control Testing . . . 373
5.03 Compliance Monitoring and Corrective Action . . . 380
5.04 Performance Metrics and Operational KPIs . . . 386
5.05 Security Control Assessment and Authorization . . . 392
5.06 Vendor Compliance and Third-Party Assurance . . . 396
5.07 Annual Policy Review and Maturity Scoring . . . 405

6 Appendices **412**
6.01 Glossary and Definitions . . . 413
6.02 Policy Matrix . . . 419
6.03 Workforce Roles STAK Matrix . . . 423
6.04 Revision History and Version Control . . . 430

1. Governance and Strategic Framework

1.01 Department Mission and Strategic Objectives

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy defines the mission and strategic objectives of the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel and informs the development, execution, and evaluation of all policies, procedures, and services maintained by the Department. It serves as the strategic anchor point for departmental planning, service delivery, policy enforcement, and cross-departmental coordination.

3. Roles and Responsibilities

- **IT Director**:
  - Shall define, approve, and update the Department mission and strategic objectives to ensure alignment with County goals, in accordance with the review cadence established in **Policy 1.05** (Policy Review and Update Procedures).
  - Shall ensure that all policy development and procedural guidance explicitly maps to the Department's mission.
- **All Information Operations Personnel**:
  - Shall uphold the Department mission and contribute to the realization of strategic objectives through their daily actions, decisions, and participation in governance and risk-management activities.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel.

- **Assessment**: Strategic alignment shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with justification and approved by the IT Director in accordance with the exception management framework defined in **Policy 5.01** and **Policy 1.08** (Delegation of Authority and Decision Rights). Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment

- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NRS 242.171 (Responsibilities of Office/Director)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- NIST CSF 2.0: GV.OC-01 (Organizational Context)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-11 (Mission and Business Process Definition)
- COBIT 2019: EDM01 (Ensure Governance Framework Setting and Maintenance)

6. Policy Statement

6.1 Mission Statement

The mission of the Elko County Information Operations Department is to establish and enforce clear, comprehensive standards for technology and information management, ensuring secure, compliant, and efficient operations across all County departments while actively informing the County's cybersecurity and privacy risk management approach.

6.2 Strategic Objectives

The Department shall achieve and maintain the following strategic objectives:

- **Standardization**: The Department shall establish and maintain clear guidelines for the secure, responsible use of County information systems and technology resources.
- **Enforcement**: The Department shall apply approved standards consistently and impartially, fostering a culture of operational accountability and technical discipline.
- **Risk Management**: The Department shall identify, assess, and mitigate risks across systems, departments, and workflows to reduce systemic vulnerabilities and support the County's cybersecurity risk management strategy.
- **Service Enablement**: The Department shall design and support infrastructure that delivers reliability, continuity, and interoperability across County operations.
- **Decision Support**: The Department shall streamline and automate processes to reduce manual burden and shall provide accurate, current, and well-governed data to County leadership.
- **Policy Leadership**: The Department shall act as the central authority for information governance, security, and service management within Elko County, maintaining a coherent governance framework aligned with applicable laws, regulations, and control frameworks.

1.02 Code of Ethics and Professional Conduct

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes the mandatory standard of professional conduct for all personnel within the Elko County Information Operations Department.

2. Scope

This policy applies to all Elko County Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, interns, and volunteers who access County IT systems or data.

3. Roles and Responsibilities

- **IT Director:**
  - Shall conduct an annual review of this policy and adjudicate ethical conflicts that cannot be resolved at the staff level.
  - Shall approve or deny exceptions to this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **All Information Operations Personnel:**
  - Shall read, acknowledge, and adhere to this policy and the professional standards adopted in Section 6.1.
  - Shall report suspected criminal conduct, Criminal Justice Information (CJI) misuse, or active threats to County systems or data to the IT Director immediately upon discovery.
  - Shall report all other known or suspected violations of this policy to the IT Director within one (1) business day of discovery.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel and all other personnel within the scope defined in Section 2.

- **Assessment**: Adherence to the standards of conduct defined in this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures). All Information Operations Personnel shall acknowledge this policy upon hire and annually thereafter in accordance with the acknowledgment program defined in **Policy 5.01**.
- **Enforcement**: Non-compliance with this policy shall be addressed through the corrective action framework defined in **Policy 5.01**. Violations involving misuse of CJIS data or County assets may result in criminal referral under NRS 205 (Computer Crimes) and applicable federal law.
- **Exceptions**: Exceptions to the standards of conduct defined in this policy shall follow the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205 (Computer Crimes)
- NRS 281A (Ethics in Government)
- ACM: Code of Ethics and Professional Conduct

Framework Alignment:

- CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PS-1 (Personnel Security Policy and Procedures)
- NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions)
- COBIT 2019: APO01.02 (Manage Ethical and Professional Behavior)

6. Policy Statement

Public trust in the administration of government technology requires that all personnel maintain the highest standards of professional conduct and integrity. All directives in this policy apply to all personnel within the scope defined in Section 2. Where a directive applies to a narrower audience, the specific role is identified.

6.1 Adoption of Professional Standards

Elko County Information Operations formally adopts the ACM Code of Ethics and Professional Conduct as the baseline for professional behavior. Personnel shall uphold the principles of contributing to human well-being, avoiding harm, and respecting privacy. Where the ACM Code and County or Department policy conflict, applicable State and Federal law shall take precedence, followed by County and Department policy.

6.2 Professional Conduct and Culture

- **Respect in Communication**: Mocking, belittling, or dismissive comments regarding end-users, colleagues, or other departments—whether verbal, written, or in digital chats—is prohibited. Operational frustration does not justify unprofessional conduct.
- **User-Centered Service**: Personnel shall respond to service requests and inquiries from County staff in a professional and courteous manner. Dismissive or condescending responses to end-user communications are prohibited.
- **Representation**: Personnel shall not express personal opinions as official County positions in any public forum or media channel unless explicitly authorized by the County Manager or IT Director.
- **Compliance with Personnel Policies**: Personnel shall comply with the Elko County Personnel Policies and applicable Collective Bargaining Agreements in addition to this policy.

6.3 Integrity and Conflict of Interest

- **Zero-Gift Policy**: Personnel are strictly prohibited from accepting any gifts, gratuities, meals, entertainment, or favors from current or prospective technology vendors, regardless of monetary value. This includes standard industry courtesies such as vendor-paid business lunches or promotional items.
  - **Rationale**: This standard is intentionally stricter than the minimum requirements of NRS 281A (Ethics in Government) to eliminate ambiguity and protect personnel from even the appearance of impropriety.
- **Vendor Interaction**: When meeting with vendors over a meal, personnel shall pay for their own share or expense it through official County channels if applicable. The vendor is never permitted to pay.
- **Truthfulness**: Personnel shall be honest in all professional reporting. Falsifying logs, obscuring errors, or misrepresenting the status of a project or system is a violation of this policy.

6.4 Stewardship of Information and Assets

- **Confidentiality**: Personnel shall protect sensitive data (PII, PHI, CJIS) in accordance with **Policy 1.11** (Data Governance and Classification Policy). Curiosity is not a valid reason for accessing data; access is permitted only for specific business duties.
- **Zero Tolerance for Misuse**: The use of County IT assets for harassment, illegal activity, or personal financial gain is strictly prohibited.

1.03 Standard Operating Ethos

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy defines the internal culture, operational mindset, and behavioral expectations of the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, and volunteers. It governs the cultural and professional baseline for Department interactions, decision-making, and conflict resolution.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the final authority on matters of operational conduct and Department culture.
  - Shall maintain this policy as the governing standard for Department conduct and professional expectations.
  - Shall define and document operational delegations and escalation paths in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Assistant IT Director:**
  - Shall reinforce the standards defined in this policy through active mentorship and shall model the operational ethos in daily operations.
- **All Information Operations Personnel:**
  - Shall operate in strict alignment with this ethos, modeling professional discipline, initiative, and leadership at every level.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Adherence to this policy shall be evaluated through individual performance reviews, incident post-mortem analysis examining adherence to escalation and documentation standards per **Policy 4.01** (Incident Response Policy Overview), supervisor observations, and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance with this policy may result in corrective actions as defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment), including coaching, supervisory feedback, or formal performance management. Failure to complete required policy acknowledgments under Section 6.5 constitutes non-compliance enforceable under this section.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 281A (Ethics in Government)
- CJIS Security Policy v6.0: Section 5.1.1.4 (Management Control Agreements)

Framework Alignment:

- NIST CSF 2.0: GV.SC-01 (Cybersecurity Supply Chain Risk Management)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- COBIT 2019: APO01.01 (Design the management system for enterprise I&T)
- COBIT 2019: APO07.01 (Maintain adequate and appropriate staffing)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

This policy serves as the unifying ethos that aligns individual conduct with the organizational mission — defining how the Department leads, operates, and serves. The standards established here complement the ethical obligations defined in **Policy 1.02** (Code of Ethics and Professional Conduct) and operationalize the professional discipline required to sustain the Department's governance, security, and service delivery mission.

6.1 Operational Authority and Autonomy

The Information Operations Department shall maintain operational authority over the administration, security, architecture, and configuration of all Elko County information systems, infrastructure, and technology assets placed under the governance of the Information Operations Department as defined in **Policy 1.06** (IT Governance and Oversight Structure).

- **Unified Authority**: To support compliance with the strict connectivity and security requirements of the CJIS Security Policy Section 5.1.1.4 (Management Control Agreements), Elko County has adopted a unified governance structure for shared infrastructure. Under this structure, the IT Director retains final decision-making authority over all technical controls and risk mitigation strategies across the enterprise, subject to the statutory management control authority of Criminal Justice Agencies (CJA) over CJIS data policy.
- **Independence**: While administratively reporting to County Management, the Department's operational decisions shall be driven by technical standards, security mandates, and risk assessments. Political pressure or external influence shall not supersede mandatory security controls, engineering

standards, or the ethical obligations established under NRS 281A. Technical decisions shall be made in accordance with the delegation framework defined in **Policy 1.08**.

6.2 Chain of Command and Escalation

The chain of command is a mechanism for accountability and risk management. All Information Operations Personnel shall utilize the chain of command to ensure decisions are made at the appropriate authority level.

- **Act Decisively**: All Information Operations Personnel shall execute duties with precision within their assigned scope of authority.
- **Escalate with Purpose**: All Information Operations Personnel shall escalate issues to their direct supervisor within one (1) business day when operational risk, legal constraints, or policy ambiguity exceed their defined authority or expertise. During active incidents, personnel shall escalate in accordance with the incident response escalation procedures defined in **Policy 4.01**.
- **Unified Direction**: Once a decision is made by the designated authority, all Information Operations Personnel shall implement that decision promptly. Concerns about implementation shall be raised through the escalation process defined in **Policy 1.08** without impeding execution unless a safety or legal issue is identified.

6.3 Leadership and Crisis Management

Leadership within the Information Operations Department is defined by consistency, clarity, and accountability.

- **Communicate with Precision**: The IT Director and Assistant IT Director shall issue instructions and status reports that are clear, specific, and actionable. All Information Operations Personnel shall confirm understanding of critical directives before execution.
- **Decide Based on Standards**: The IT Director and Assistant IT Director shall base operational decisions on data, policy, and formal risk assessment. Political pressure, personal sentiment, or external influence shall not supersede technical standards or mandatory security controls.
- **Accountability**: The IT Director and Assistant IT Director shall acknowledge errors transparently and shall document lessons learned within five (5) business days of incident closure. The IT Director shall ensure remediation actions are tracked to completion in the Department's system of record.
- **Crisis Discipline**: During major incidents, all Information Operations Personnel shall adhere to the incident response protocols defined in **Policy 4.01**. The IT Director and Assistant IT Director shall provide clear, evidence-based direction to maintain operational discipline and shall participate in formal post-incident reviews to document lessons learned.

6.4 Operational Discipline

Operational discipline is the foundation of the Department's credibility. All Information Operations Personnel shall execute duties according to the following standards:

- **Own the Scope**: All Information Operations Personnel shall fully own tasks within their job role. If a task falls outside their scope, they shall escalate it with clear context and documentation rather than ignoring it.
- **Document as Standard**: All Information Operations Personnel shall document operational actions, changes, and decisions in accordance with the documentation requirements established in **Policy 5.01**.
- **Prioritize Based on Risk**: All Information Operations Personnel shall assess urgency based on impact to County operations and security, not solely on the volume of the request.

- **Resolve or Escalate**: All Information Operations Personnel shall actively move every ticket or work order toward resolution or escalate it to the appropriate tier with sufficient context for action. No ticket or work order shall remain without a documented status update beyond the timeframes established in the applicable service level targets.

6.5 Policy Acknowledgment

All Information Operations Personnel shall acknowledge receipt and understanding of this policy upon hire, upon any substantive revision, and annually thereafter. The IT Director shall ensure acknowledgments are documented and maintained in accordance with **Policy 2.03** (Security Awareness and Training Policy).

1.04 Policy and Documentation Formatting Standards

Effective: April 23, 2026 Version: 1.5

1. Purpose

This policy establishes the mandatory formatting, structural, and stylistic standards governing all policies, procedures, and official documentation maintained by the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel assigned to draft, edit, approve, or maintain any document that is part of the Information Operations Policy Manual or supporting procedural library.

- **In Scope**:
  - Policy documents within the Information Operations Policy Manual.
  - Standard Operating Procedures (SOPs) maintained in the System of Engagement.
  - Playbooks maintained as governed Knowledge Base artifacts in the System of Engagement.
- **Out of Scope**:
  - Informal drafts and internal correspondence.
  - Work order records: **Policy 3.05**.
  - Configuration item records and CMDB entries: **Policy 3.08**.
  - Audit logs and operational telemetry: **Policy 2.11**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall maintain this policy and serve as the final authority on formatting standards, style determinations, and exception approvals.
  - Shall return documents found to be non-compliant to the author for revision prior to publication.
- **All Information Operations Personnel**:
  - Shall apply the structural, grammatical, and stylistic standards defined in this policy when drafting, editing, or maintaining any document within scope.
  - Shall verify cross-reference accuracy and citation completeness prior to submitting a document for review.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel engaged in documentation tasks.

- **Assessment**: Adherence to formatting and style standards shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).

- **Enforcement**: The IT Director shall return documents found to be non-compliant to the author for revision prior to publication. Repeated non-compliance may be escalated under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to formatting standards shall be documented with justification and approved in writing by the IT Director. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix 6.01: Glossary and Definitions
- ECIO Appendix 6.02: Policy Matrix
- NRS 239.010 (Applicability and Public Records)

Framework Alignment:

- COBIT 2019: APO01.01 (Design the management system for enterprise I&T)
- COBIT 2019: APO01.09 (Define and communicate policies and procedures)
- ITIL v4: Knowledge Management Practice

6. Policy Statement

6.1 Source of Truth and Document Authority

The **Elko County Information Operations Policy Manual** (maintained as the master *Policy_Manual.lyx* file) is the designated **Authoritative System of Record** for all governance controls.

- **Master Repository**: The LyX source file constitutes the authoritative source for ECIO policy version control and publication control.
  - **Public Records Status**: Designation of an "authoritative" copy is for version control only and does not alter public records status or disclosure requirements applicable to records in any medium under NRS 239.010.
- **Operational Interface (System of Engagement)**: The Departmental Knowledge Base serves as the accessible operational interface for day-to-day reference.
- **Synchronization**: Content published in the System of Engagement shall be sourced directly from the LyX master. In the event of a discrepancy, the LyX master record (and its compiled PDF) takes precedence.

6.2 Policy Document Structure

All policies within the Information Operations Policy Manual shall adhere to the following six-section structure, presented in this exact order. No sections shall be omitted, reordered, or renamed.

1. **Purpose**: A concise statement defining what the policy governs.
2. **Scope**: Defines who and what the policy applies to, and what it does not.
3. **Roles and Responsibilities**: Identifies specific roles tasked with execution or oversight.
4. **Compliance and Exceptions**: Defines assessment mechanisms, enforcement authority, and the exception process.
5. **References**: Citations of upstream frameworks and internal cross-references that are directly cited in the body of the policy.
6. **Policy Statement**: The core directives, organized into subsections.

Subsections within the Policy Statement shall use decimal notation (e.g., 6.1, 6.2). Nesting beyond two levels (e.g., 6.1.1) is prohibited.

6.3 Purpose Section Template

The Purpose section shall consist of one (1) sentence, or two (2) sentences at maximum. It shall answer a single question: what does this policy govern?

- **Opening Construction**: Every Purpose statement shall open with the construction "This policy [verb]s..." using a direct, present-tense verb (e.g., "This policy establishes...," "This policy defines...," "This policy governs...").
- **Prohibited Constructions**: The preamble "The purpose of this policy is to..." is prohibited. Introductory filler, risk justification, and framework alignment rationale shall not appear in the Purpose section.
- **Rationale Placement**: Context that explains why the policy matters, what risk it addresses, or how it aligns with external frameworks shall be placed in the opening paragraph of Section 6 (Policy Statement) or in the Policy Matrix appendix.

6.4 Scope Section Template

The Scope section shall open with a single universal applicability statement using the construction "This policy applies to [who/what]."

When boundary clarification is required, the Scope section shall use the following labeled subsections, formatted as bolded bullet labels with sub-bullets:

- **In Scope**: Capitalized noun phrases identifying what the policy governs. Each item shall appear as a sub-bullet beneath the label and consist of a standalone noun phrase with a terminal period. No policy pointers are required, as the governed items reside within this policy.
- **Out of Scope**: Capitalized noun phrases identifying what the policy does not govern. Each item shall appear as a sub-bullet beneath the label. When another policy governs the topic, the item shall be followed by a colon and the routing pointer in the format "[Topic]: **Policy [X.XX]**." When no policy governs the topic, the item shall stand alone as a bare noun phrase with a terminal period.

Not every policy requires both In Scope and Out of Scope subsections. Simple policies where the applicability sentence is sufficient may omit them. However, when boundaries are drawn, they shall be drawn with labels and sub-bullets, not with narrative prose.

Cross-references within the Scope section shall use the routing pointer format prescribed above. The first-use parenthetical title convention defined in Section 6.11 applies to prose references in Sections 3, 4, and 6; it does not apply to Scope section routing pointers.

Exclusion: The Scope section shall not contain directives, compliance language, or enforcement statements. Those belong in Section 4.

6.5 Roles and Responsibilities Section Template

The Roles and Responsibilities section shall identify every role with accountability under the policy. Roles shall be listed in descending order of authority (e.g., IT Director, County Manager, Assistant IT Director, then operational roles, then external stakeholders).

Each role shall be formatted as follows:

- The role title shall appear as a bolded bullet item followed by a colon. No text shall follow the colon on the role title line.
- Each distinct obligation shall appear as a sub-bullet beneath the role, opening with the word "Shall" and containing exactly one (1) directive.
- Obligations shall not be chained together in a single comma-separated sentence. Each auditable obligation requires its own sub-bullet.

Role Identity Requirement: Every role listed in Section 3 shall correspond to a defined position in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework), an established County institutional title (e.g., County Manager, Board of County Commissioners), or a defined group with a clear membership boundary (e.g., "All Information Operations Personnel," "All County Personnel," "Department Heads"). Descriptive activity labels (e.g., "Policy Authors," "Approving Authorities," "System Owners") shall not be used as role identifiers in Section 3. If a responsibility applies to any person performing a given activity, it shall be assigned to the defined role or group that performs that activity.

The Roles and Responsibilities section shall focus on ownership of outcomes, not step-by-step procedures. Procedural detail belongs in Section 6.

6.6 Compliance and Exceptions Section Template

The Compliance and Exceptions section shall open with a single sentence establishing the mandatory nature of the policy (e.g., "Compliance with this policy is mandatory for all Information Operations personnel involved in [relevant activity].").

The section shall contain the following three (3) mandatory labeled bullet items, in this order:

- **Assessment**: Identifies how and when compliance with this policy is evaluated.
- **Enforcement**: Identifies the consequences of non-compliance and the authority that enforces the policy.
- **Exceptions**: Defines the process for requesting deviations. Shall state that oral exceptions are not valid.

Additional labeled bullets may be included when the policy warrants them. The following are the governed set of optional labels:

- **Constructive Notice**: For policies where publication constitutes notice.
- **Emergency Deviations**: For policies with time-critical override procedures.
- **Sanctions**: For policies with specific disciplinary consequences beyond the standard enforcement framework.
- **Universal Applicability**: For policies that apply regardless of location or work status.
- **Mandatory Compliance**: For policies that apply without exception to all personnel classes.

No other labels shall be introduced without IT Director approval and incorporation into this governing list. The Compliance and Exceptions section shall not use numbered subsections (e.g., 4.1, 4.2); it shall use the flat bolded-bullet-label structure defined above.

6.7 References Section Template

The References section is the legal and framework audit trail. It shall be formatted as a flat list of citation line items with no narrative prose. The section shall be divided into two (2) labeled subsections: Cited References and Framework Alignment.

Cited References: This subsection contains citations that are directly referenced by number or identifier in the body of the policy (Sections 1 through 4 and Section 6). A policy or framework that is not cited in the body text shall not appear in this subsection. Conversely, any policy or framework cited by number in the body text shall have a corresponding entry in this subsection. Cited References are load-bearing — they support specific directives, cross-references, or compliance statements within the policy.

Framework Alignment: This subsection contains framework mappings that establish where the policy sits in the broader governance landscape, regardless of whether they are explicitly cited in the body text. Framework Alignment entries support traceability, feed the Policy Matrix (Appendix 6.02), and make governance alignment visible at the policy level. A framework reference that is directly cited in the body text shall appear under Cited References, not Framework Alignment.

Default Placement:

- The following categories shall default to Cited References unless they are not cited in the body text:
  - ECIO Policies.
  - ECIO Appendices.
  - NRS.
  - NAC.
  - LRDA.
  - CJIS.
  - NIST CSF.
  - NIST SP.
- The following categories shall default to Framework Alignment unless they are directly cited by identifier in the body text:
  - COBIT 2019.
  - ITIL v4.

A COBIT or ITIL reference that is directly invoked by identifier in the body text shall be promoted to Cited References.

Ordering: Within each subsection, citations shall follow the categorical sequence and sub-ordering rules defined in Section 6.11 of this policy.

Formatting Rules:

- Each citation shall be a distinct, individual line item. Citations shall not be grouped on a single line.
- Reference line items shall not end with a terminal period. They are citations, not sentences.
- Internal ECIO policy and appendix references shall not be bolded in either subsection. All citation line items shall receive uniform formatting to avoid visually privileging internal references over upstream frameworks.

- Internal ECIO policy and appendix references shall use LyX cross-reference insets (CommandInset ref) to maintain link integrity. They shall not be manually typed.

Citation Syntax: Citation formatting for each framework category is defined in Section 6.11 of this policy.

6.8 Policy Statement Section Template

The Policy Statement is the operational core of the policy, containing the auditable controls and directives.

- **Framing Preamble**: When a policy requires contextual framing — risk justification, framework alignment rationale, or dual-audience explanation — that context shall appear as an opening paragraph or paragraphs before Section 6.1 begins, or as the opening content of Section 6.1 itself.
- **Subsection Organization**: Content shall be organized into labeled subsections (6.1, 6.2, etc.) grouped by operational sub-domain.
- **One Directive Per Item**: Each atomic bulleted or numbered item within the Policy Statement shall contain exactly one (1) directive or requirement. Blended items that combine multiple obligations in a single atomic bullet using conjunctions are prohibited.
  - **Clarification**: This rule applies at the atomic item level — each individual Itemize bullet or Enumerate item. A bold-label topic block (defined in Section 6.12) may contain multiple atomic bullets beneath it, each independently satisfying the one-directive rule. Grouping multiple single-directive bullets under a shared parent label is the intended structural pattern, not a violation.

6.9 Compliance Language Standards

To ensure clear enforceability during audits, the following terminology definitions apply to all policy documents within the Information Operations Policy Manual.

- **"Shall" or "Must"**: Indicates a mandatory requirement. Non-compliance is auditable and enforceable.
- **"Should"**: Indicates a recommended best practice. Deviations from "Should" requirements shall be documented in writing and approved by the IT Director or Policy Owner prior to implementation. Justifications shall be retained for audit.
- **"May"**: Indicates a permissible or discretionary action.

Anchoring Requirement: Every directive shall be anchored to a specific, capitalized role. Orphaned directives (e.g., "Logs shall be reviewed weekly" with no identified role) are prohibited. The correct form is "The Systems Administrator shall review logs weekly."

Prohibited Language: The following terms and phrases are prohibited in Section 6 (Policy Statement) of any policy. Authors shall map the intended obligation to "Shall," "Should," or "May" with an explicit role anchor.

- "expected to"
- "responsible for"
- "as needed"
- "where possible"
- "where feasible"
- "is not feasible" / "not feasible" / "technically feasible"
- "as appropriate"
- "in a timely manner / “timely”
- “reasonable”
- "when practical" / "where practical"

- "if necessary"
- "when necessary"
- "attempt to"
- "strive to"
- "best effort"
- "strongly encouraged"

6.10 Universal Style and Grammar Standards

The following style and grammar rules apply to all text within the Information Operations Policy Manual.

- **Voice and Tense**: All policy text shall use present-tense, active voice (e.g., "The IT Director reviews logs" rather than "Logs are reviewed by the IT Director"). Passive constructions are permitted only when the acting role is genuinely irrelevant or unknown.
- **Time and Quantity Syntax**: All deadlines, timeframes, and quantities shall be written as the number in words followed immediately by the numerical digit in parentheses (e.g., "five (5) business days," "twenty-four (24) hours," "ninety (90) calendar days"). Neither the word nor the digit shall appear alone.
- **Institutional Capitalization**: The following shall always be capitalized: proper nouns, official job titles (e.g., "IT Director," "Systems Administrator"), institutional concepts (e.g., "County," "Department," "Information Operations Department"), defined terms from the Glossary (**Appendix 6.01**), and named policy constructs (e.g., "Incident Commander," "Hard Fork," "Operational Handback").
- **Acronym Protocol**: The first instance of a technical term or organizational name within each policy shall be fully spelled out, followed by its abbreviation in parentheses (e.g., "Criminal Justice Information Services (CJIS)"). Subsequent references within the same policy may use the abbreviation alone. Acronym definitions do not carry across policies; each policy shall define its own terms on first use. Standard terms defined in the Glossary (**Appendix 6.01**) are exempt from the first-use requirement only when the policy explicitly states reliance on the Glossary.
- **Oxford Comma**: The Oxford comma is mandatory in all lists (e.g., "systems, services, and infrastructure").
- **Official Systems Terminology**: Software and platforms referenced in policy documents shall be cited by their governance function label only (e.g., "System of Engagement," "Authoritative System of Record," "Endpoint Protection Platform," "Productivity Suite"). Vendor and product names shall not appear in policy text. Product-specific names, configurations, and implementation details belong in operational documentation maintained in the System of Engagement.
- **Policy Numbering**: Policy numbers shall follow a strictly padded two-digit decimal system within each chapter (e.g., Policy 1.01, Policy 2.05, Policy 3.14). Single-digit policy numbers (e.g., Policy 1.1) are prohibited.

6.11 Cross-Reference, Citation, and Bold Standards

Cross-Reference Syntax: Internal references to other policies shall use the following rules:

- Every reference shall use the singular construction "Policy [X.XX]" (e.g., "Policy 2.04"). The word "Policy" shall appear before every number, even when citing multiple policies in sequence (e.g., "Policy 3.03 and Policy 3.04," never "Policies 3.03 and 3.04").
- The first reference to an internal policy within each policy shall include the parenthetical title immediately after the cross-reference (e.g., "Policy 1.08 (Delegation of Authority and Decision Rights)"). The parenthetical title shall not be bolded; bold applies only to the cross-reference itself. All subsequent references within the same policy shall use the short form only (e.g., "Policy 1.08").

- Every in-body cross-reference (Sections 1 through 4 and Section 6) shall be bolded and implemented as a LyX cross-reference inset (CommandInset ref) to maintain link integrity. Manually typed policy numbers are prohibited in the body of any policy.
- Cross-references within Section 5 (References) shall not be bolded, consistent with the uniform citation formatting rule in Section 6.7. They shall still use LyX cross-reference insets.
- Directional phrases such as "see below," "see above," "as described later," and hard-coded page numbers are prohibited. All internal references shall use absolute numerical pointers (e.g., "Policy 2.04" or "Section 6.2").

External Framework First-Use Syntax: The first reference to an external framework citation within each policy shall include the full citation with parenthetical topic (e.g., "NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)"). Subsequent references within the same policy may use the short form (e.g., "NIST SP 800-53 IR-4" or the control identifier alone if context is unambiguous).

Reference Citation Syntax: Citations within Section 5 (References) shall follow the formatting defined below for each framework category. These formats apply uniformly within both the Cited References and Framework Alignment subsections.

- Internal Policies: ECIO Policy [Number]: [Policy Title]
- Internal Appendices: ECIO Appendix [Number]: [Appendix Title]
- NRS: NRS [Chapter].[Section] ([Short Topic Description])
- NAC: NAC [Chapter].[Section] ([Short Topic Description])
- LRDA: LRDA [LRDA Number] ([Record Series Title])
- CJIS: CJIS Security Policy v[Version]: Section [ID] ([Topic])
- NIST CSF: NIST CSF [Version]: [Function].[Category]-[ID] ([Title])
- NIST SP: NIST SP [Number] Rev. [Revision]: [Control ID] ([Control Title])
- COBIT 2019: COBIT 2019: [Process ID] ([Process Name])
- ITIL v4: ITIL v4: [Practice Name]

Reference Sub-Ordering Within Categories: The following ordering rules apply within each subsection (Cited References and Framework Alignment) independently. Citations shall not be interleaved across subsections.

1. **ECIO Policies**: Sorted numerically by Policy Number in ascending order.
2. **ECIO Appendices**: Sorted numerically by Appendix Number in ascending order.
3. **State of Nevada**: Grouped by authority in the sequence NRS, NAC, then LRDA. Within each group, sorted numerically by Chapter, Schedule Number, or LRDA Number.
4. **CJIS**: Sorted alphanumerically by Section or Control Family identifier.
5. **NIST CSF**: Sorted by Core Function sequence (GV, ID, PR, DE, RS, RC), then alphanumerically by Category and Subcategory identifier.
6. **NIST SP**: Sorted numerically by Publication Number (e.g., SP 800-37 precedes SP 800-53), then alphanumerically by Control Identifier.
7. **COBIT 2019**: Sorted alphanumerically by Core Model Objective or Domain identifier.
8. **ITIL v4**: Sorted alphabetically by Practice name.
9. **Other Frameworks**: Sorted alphabetically by issuing authority, then publication title.

This ordering establishes structural consistency and does not alter the legal hierarchy of authority established in the Manual Executive Summary.

Bold Usage: Bold formatting is a navigational and structural tool, not an emphasis tool. Bold shall be reserved for the following uses only:

- **Internal Cross-References**: Bolded on every instance in the policy body (Sections 1 through 4 and Section 6). Not bolded in Section 5 (References).
- **Glossary-Defined Terms**: Bolded on first use within each policy only. Not linked to the Glossary; the bold treatment serves as a visual flag that the term carries a specific defined meaning. The criteria for Glossary inclusion are defined in Section 6.14.
- **Structural Labels**: Role titles in Section 3, compliance labels in Section 4, In Scope and Out of Scope labels in Section 2, and contextual clarifier tags (defined in Section 6.12). Bolded by virtue of their structural position.

Bold shall not be applied to external framework references (CJIS, NIST, COBIT control IDs), numerical values, parenthetical titles accompanying cross-references, or general emphasis within prose.

6.12 List and Structural Formatting Standards

Terminal Periods: Every bulleted and sub-bulleted list item shall end with a terminal period, regardless of whether the item is a full sentence or a fragment.

- **Exception**: Citation line items in Section 5 (References) shall not end with a terminal period.

Bulleted Lists vs. Numbered Lists: Bulleted lists (Itemize) shall be used for unordered collections of items. Numbered lists (Enumerate) shall be used only when the items represent an ordered sequence where position is meaningful (e.g., a workflow, a hierarchy of precedence). Numbered lists shall not be used solely for the purpose of counting items.

Sub-Bullets: Nested list items shall use the LyX begin_deeper environment (rendered as indented sub-bullets). Nesting beyond two levels is prohibited.

Bold Label Formatting: When a bold label is used to identify a bullet item, a paragraph-level directive, or a topic block within a subsection, the label shall always be followed by a colon, never a period. The colon signals that the label identifies the content that follows. Bold labels followed by periods are prohibited.

Contextual Clarifiers: When a directive requires boundary-setting, explanation, or qualification, the clarifying statement shall be separated from the primary directive using a bolded tag followed by a colon, placed on a new line or as a sub-bullet. The following tags constitute the governed vocabulary of permitted contextual clarifiers:

- **Constraint**: Defines a hard limitation or boundary condition on the directive.
- **Rationale**: Provides the justification for a requirement that may not be self-evident.
- **Exception**: Identifies a specific, defined circumstance under which the directive does not apply.
- **Exclusion**: Carves out a specific item, group, or system from the scope of the directive.
- **Clarification**: Resolves a potential ambiguity in the directive's application.

No other contextual clarifier tags shall be introduced without IT Director approval and incorporation into this governed list.

6.13 Visual and Typography Standards

Typography, spacing, and layout are controlled programmatically by the LyX document class (book) and the master preamble to ensure absolute consistency.

- **Manual Overrides**: Authors shall not use manual formatting commands (e.g., forcing font sizes, manual line breaks, or changing margins) within the LyX editor.
- **Images and Diagrams**: Workflow diagrams may be included when required to illustrate complex branching logic, network topologies, or sequence flows. They shall be inserted as standard LyX "Floats" with a caption and created in a format that renders clearly in grayscale (PDF).
- **Term Definitions**: Policies shall not redefine standard terms already defined in the central Glossary (**Appendix 6.01**). If a policy requires a term that does not yet appear in the Glossary and meets the inclusion criteria defined in Section 6.14, the IT Director shall approve the term for addition to **Appendix 6.01** prior to or concurrent with publication of the policy.

6.14 Glossary Governance and Term Criteria

The Glossary (**Appendix 6.01**) is the authoritative repository for defined terms used within the Information Operations Policy Manual. The IT Director shall maintain the Glossary and approve all additions, modifications, and removals.

Inclusion Criteria: A term warrants a Glossary entry if it meets any of the following conditions:

- The term is coined by the ECIO Policy Manual and has no standard external definition (e.g., "Hard Fork," "Operational Handback").
- The term is a standard industry or framework term that the manual uses with a specific institutional meaning that narrows, modifies, or contextualizes the common definition (e.g., "Incident Commander" as scoped by the ECIO framework).
- The term is an acronym or abbreviation whose expansion is not obvious to the intended audience of the manual.

Exclusion Criteria: The following shall not receive Glossary entries:

- Plain-language terms used in their ordinary, commonly understood sense (e.g., "server," "firewall," "email").
- Terms whose meaning is fully self-evident to a competent IT professional without further definition.
- External framework terms (e.g., NIST control names, COBIT process identifiers) that are used in their standard published meaning without institutional modification. These terms are defined by their issuing authority and do not require local redefinition.

Bold Treatment: Terms that appear in the Glossary shall be bolded on first use within each policy, as defined in Section 6.11. Glossary terms shall not be hyperlinked to **Appendix 6.01**; the bold treatment serves as the visual indicator that the term carries a defined meaning.

Maintenance Cadence: The Glossary shall be reviewed as part of each annual policy review cycle defined in **Policy 1.05**. Terms that are no longer referenced by any active policy shall be candidates for removal.

6.15 Procedural and Informational Documentation

Procedural and informational documentation is distinct from policies and is maintained as Knowledge Base artifacts in the System of Engagement. All such documentation shall be classified under one of the two document types defined below. Knowledge Base lifecycle obligations, including category ownership, review cadence, retention, and retirement, are governed by **Policy 3.13** (Knowledge Management Policy).

Document Types: The following two types are the closed set of document classes. A new type shall not be introduced without IT Director approval and incorporation into this list.

- **Procedure**: A document that directs the reader to perform a task. Procedures contain steps, decision points, and an expected end state.

- **Information**: A document that the reader consults for facts or context. Information documents are not performed.

Document Subtypes: Each type has a closed set of subtypes. A new subtype shall not be introduced without IT Director approval and incorporation into this list.

- **Procedure — Troubleshooting**: Resolves a problem or fulfills a defined task. May be linear or branching.
- **Procedure — Playbook**: A scenario-based incident response artifact. Playbook existence, content, and review cadence are governed by **Policy 4.03** (Containment Strategy and Playbooks).
- **Information — Reference**: Catalogs the state of the environment. Takes the form of lists, tables, diagrams, schemas, or inventories.
- **Information — Context**: Prose explanation of policy, process, or governance. Provides background, interpretation, or rationale.

Shared Metadata Header: Every document, regardless of type or subtype, shall carry the following header fields.

- **Subject**: A short, task-oriented title identifying the document.
- **Type**: Procedure or Information.
- **Subtype**: Troubleshooting, Playbook, Reference, or Context.
- **Category**: The operational classification corresponding to the active Knowledge Base taxonomy maintained by the Assistant IT Director in the System of Engagement.
- **Owner**: The role responsible for keeping the document current. The Owner shall be a role, not a named individual.
- **Version**: Begins at 1.0 and increments on revision.
- **Effective Date**: The date the current version takes effect.

Procedure — Troubleshooting Body: A Troubleshooting document shall contain the following body sections.

- **Prerequisites**: Required roles, permissions, tools, or system states. Required.
- **Quick Guide**: A condensed reference for experienced operators. Optional.
- **Step-by-Step**: Numbered steps. Branches shall appear where the procedure contains decision points. Formatting conventions for sequential steps, conditional branches, and expected end states are maintained under **Policy 3.13**. Required.
- **Expected End State**: The condition that defines successful completion. Required.
- **Linked Work Orders**: At least one (1) work order that triggered or used the procedure. Required.

Procedure — Playbook Body: Playbook body content requirements are defined in **Policy 4.03**. This policy does not restate those requirements.

Information — Reference Body: A Reference document shall contain the following body sections.

- **Scope Statement**: A single sentence identifying what the document catalogs. Required.
- **Last Verified Accurate**: The date on which the cataloged content was last confirmed correct. Required.
- **Content**: The cataloged material, presented in whatever form best serves the content (list, table, diagram, schema, or inventory). Required.

- **Update Trigger**: The event or cadence that requires re-verification of the cataloged content. Required.

Information — Context Body: A Context document shall contain the following body sections.

- **Scope Statement**: A single sentence identifying what the document explains and to whom. Required.
- **Authority**: The policy, statute, regulation, or framework the explanation draws from. Required.
- **Body**: The prose explanation. No format mandate beyond readability. Required.
- **Related Procedures**: Links to Procedure documents that implement or operationalize the context. Required when such procedures exist.

This section establishes the mandatory minimum structure for procedural and informational documentation. Field formatting, template layout, and implementation conventions within each required section shall be maintained by the Assistant IT Director under **Policy 3.13** as an operational standard.

1.05 Policy Review and Update Procedures

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy defines the lifecycle, review cadence, and change control mechanisms governing the development, update, resanction, and retirement of policies within the Elko County Information Operations Policy Manual.

2. Scope

This policy applies to all Information Operations personnel engaged in the development, review, approval, or maintenance of policies within the Information Operations Policy Manual.

- **In Scope**:
  - Policy documents within the Information Operations Policy Manual.
  - Review cadence, lifecycle management, and change control for policy documents.
  - Emergency temporary policy amendments (Technical Directives).
- **Out of Scope**:
  - Informal working documents, drafts in progress, and operational guidance not intended for publication in the Policy Manual.
  - Formatting and structural standards for policy documents: **Policy 1.04**.
  - Policy enforcement, exception management, and sanctions: **Policy 5.01**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall conduct or coordinate the annual internal review of each policy as defined in Section 6.1.
  - Shall coordinate biennial resanction of the Policy Manual with the County Manager and, where required, the Board of County Commissioners.
  - Shall approve technical and operational policy revisions that do not alter governance structures or budget authority.
  - Shall issue Technical Directives in accordance with Section 6.3.
  - Shall ensure that review and update records are maintained in the System of Engagement and available for audit.
- **County Manager:**
  - Shall grant final approval for policy changes that affect governance constructs, decision rights, or risk appetite.
  - Shall escalate to the Board of County Commissioners when a policy change requires legal ratification or additional appropriation.
- **Board of County Commissioners:**

  - Shall approve policies requiring legal ratification, funding appropriation, or significant changes to County governance structure.
- **All Information Operations Personnel:**
  - Shall complete documented acknowledgments of policy changes within the timeframes defined in Section 6.2.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel engaged in the development, review, approval, or maintenance of policies within the Information Operations Policy Manual.

- **Assessment**: Completion and timeliness of required policy reviews and resanctions shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to conduct required reviews, resanctions, or record updates in accordance with this policy shall be treated as non-compliance and escalated under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Emergency Deviations**: The IT Director shall document deviations from scheduled review timelines defined in Section 6.1, including justification and a revised review date, in the System of Engagement within five (5) business days of the missed deadline.
  - **Clarification**: This label governs timeline deviations from the review cadence in Section 6.1. It does not govern the Technical Directives mechanism defined in Section 6.3, which is a distinct emergency authority.
- **Exceptions**: Exceptions to this policy shall be processed through the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: Exceptions that materially affect the annual review cadence, biennial resanction schedule, approval hierarchy, or acknowledgment obligations defined in this policy shall require County Manager approval, regardless of the IT Director's general delegated authority under **Policy 5.01**.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- ECIO Appendix 6.04: Revision History and Version Control
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Adoption of Records Retention Schedule)
- LRDA 20070057 (Departmental Regulations, Policies and Procedures)

Framework Alignment:

- CJIS Security Policy v6.0: Section 5.1.1.6 (Policy and Procedures)
- NIST CSF 2.0: GV.PO-02 (Policy Review)

- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership)
- COBIT 2019: MEA01 (Monitor, Evaluate and Assess Performance and Conformance)
- COBIT 2019: MEA03 (Monitor, Evaluate and Assess Compliance with External Requirements)

6. Policy Statement

The Information Operations Policy Manual is a living governance instrument that requires structured review, controlled change, and periodic institutional reaffirmation to remain current, enforceable, and aligned with legal, operational, and institutional realities. This policy defines the mechanisms through which the manual is maintained, updated, and reauthorized.

6.1 Review Cadence

To ensure continued relevance and compliance, all policies within the Information Operations Policy Manual shall undergo the following review cycles.

- **Annual Internal Review**: The IT Director shall conduct an annual internal review of each policy to evaluate compliance, technical accuracy, and workforce awareness.
- **Biennial Resanction**: The IT Director shall coordinate biennial resanction of the Policy Manual with the County Manager and, where required, the Board of County Commissioners. Resanction reaffirms institutional support, risk tolerance, and funding alignment for the IT governance framework.
  - **Clarification**: Failure to complete biennial resanction by the scheduled date constitutes non-compliance subject to the enforcement framework in **Policy 5.01**. The Policy Manual remains in force during a lapsed resanction period; policies do not expire for lack of resanction.
- **Ad Hoc Reviews**: The IT Director shall initiate ad hoc reviews when triggered by:
  - Regulatory or legal changes (e.g., CJIS Security Policy updates, HIPAA requirements, or NRS amendments).
  - Internal or external audit findings.
  - Major incidents or critical system events requiring post-mortem policy adjustment.
  - Significant organizational changes (e.g., departmental mergers or new mandates).
  - Significant technology changes (e.g., new platforms, major infrastructure shifts).

6.2 Policy Lifecycle and Change Control

Updates to the Policy Manual shall follow this change control workflow. The approval tiers defined in Step 3 apply to both new policy creation and revision of existing policies.

1. **Identification**: The IT Director shall identify needed revisions based on the review triggers in Section 6.1.
2. **Drafting**: The IT Director shall prepare draft updates in accordance with the formatting standards in **Policy 1.04** (Policy and Documentation Formatting Standards) and the version control requirements in **Appendix 6.04** (Revision History and Version Control).
3. **Approval**:
   - The IT Director shall approve technical and operational changes that do not alter governance structures or budget authority.

- The County Manager shall approve changes that affect governance constructs, decision rights, or risk appetite, and shall escalate to the Board of County Commissioners when legal ratification or additional appropriation is required.

4. **Notification**:
   - The IT Director shall notify all affected personnel of every approved policy change within five (5) business days of approval. The notification shall include an effective date, a summary of changes, and a link to the authoritative policy record.
   - All Information Operations personnel shall complete a documented acknowledgment (electronic or written) within ten (10) business days of notice. Failure to acknowledge does not delay the effective date and constitutes non-compliance.
5. **Publication**:
   - The IT Director shall increment the policy version in accordance with **Appendix 6.04**.
   - The IT Director shall commit the new version to the Authoritative System of Record (LyX/PDF) and synchronize it to the System of Engagement.
   - The IT Director shall mark the previous version "Obsolete" and archive it in accordance with **Appendix 6.04** and LRDA 20070057 (Departmental Regulations, Policies and Procedures).
6. **Retirement**: The IT Director shall formally retire policies determined to be no longer necessary. The retirement process requires the same approval level as the policy's original creation. The IT Director shall remove retired policies from active circulation and retain them in the archive in accordance with **Appendix 6.04** and LRDA 20070057 (Departmental Regulations, Policies and Procedures) for legal defensibility.

6.3 Technical Directives

The IT Director may issue temporary policy amendments ("Technical Directives") when standard policies obstruct legal compliance, operational integrity, or incident response. The underlying policy provision remains in force except to the extent specifically modified by the Technical Directive. Expiration or rescission of a Technical Directive restores the original provision without further action.

- **Permissible Scenarios**:
  - A CJIS, HIPAA, or statutory compliance deadline requiring immediate action.
  - Response to a zero-day vulnerability or active threat.
  - Critical failure affecting escalation, access control, or operational procedures.
- **Documentation Requirements**: The IT Director shall document each Technical Directive in the System of Engagement immediately upon issuance. The documentation shall include justification, scope, and a specific expiration date.
- **Automatic Expiration**: Technical Directives expire ninety (90) calendar days after issuance. Upon expiration, the IT Director shall either (a) incorporate the Technical Directive into a formally approved policy revision following the process in Section 6.2, or (b) explicitly rescind it and document the rescission in the System of Engagement. The IT Director shall not re-issue the same or a substantially similar Technical Directive within twelve (12) months of expiration without formal adoption through the standard approval process.
- **Constraint**: The IT Director shall not use Technical Directives to alter budget authority or core governance roles defined in **Policy 1.06** (IT Governance and Oversight Structure).

6.4 Policy Review Tracker

The IT Director shall record all policy review and update activity in the System of Engagement. The IT Director shall ensure these records are available to support internal audits and the maturity scoring process defined in **Policy 5.07**. The IT Director shall maintain the following metadata for every review or update:

- Policy ID and Title.
- Last Review Date and Next Scheduled Review Date.
- Responsible Reviewer.
- Review Status (Compliant / Revision Needed / Obsolete).
- Associated Work Order or Ticket Reference Link.
- Reference to any applicable audit finding, incident report, or regulatory change.

The IT Director shall retain policy review records, update records, approval records, Technical Directive records, and acknowledgment records in the System of Engagement in accordance with **Policy 1.11** (Data Governance and Classification Policy), NRS 239.125 (Local Government Records Management Program), NAC 239.155 (Adoption of Records Retention Schedule), and LRDA 20070057 (Departmental Regulations, Policies and Procedures).

1.06 IT Governance and Oversight Structure

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy defines the governance structure, decision rights, and oversight authority through which Elko County establishes and maintains Information Technology operations.

2. Scope

This policy applies to all Elko County departments, elected officials, appointed leadership, and employees who interact with, procure, or rely on Information Operations services.

- **Out of Scope**:
  - Delegation mechanics, standing delegations, and separation of duties: **Policy 1.08**.
  - Operational conduct, culture, and behavioral expectations: **Policy 1.03**.
  - Policy lifecycle management, review cadence, and change control: **Policy 1.05**.
  - Policy enforcement, exception management, and sanctions: **Policy 5.01**.

3. Roles and Responsibilities

- **Board of County Commissioners:**
  - Shall provide strategic vision for the County's Information Technology function.
  - Shall ratify County-wide IT governance policy when required under NRS 244.
  - Shall exercise final budgetary authority for IT capital investments.
- **County Manager:**
  - Shall provide operational oversight of County administration, including the Information Operations Department.
  - Shall approve administrative policies affecting governance structure or budget authority.
  - Shall arbitrate conflicts between the Information Operations Department and other County entities in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **IT Director:**
  - Shall serve as the primary governance authority for technical standards, security controls, and infrastructure operations.
  - Shall exercise decision rights consistent with the delegation framework defined in **Policy 1.08**.
- **Department Heads:**
  - Shall define business requirements for technology services consumed by their departments.
  - Shall participate in governance processes when requested by the IT Director or County Manager.
  - Shall comply with established IT standards and procedures.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Elko County departments, officials, and personnel who interact with, procure, or rely on Information Operations services.

- **Assessment**: Adherence to the governance structure and decision rights defined in this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: Non-compliance with this policy — including circumvention of IT governance through unauthorized procurement, unauthorized system changes, or deployment of unauthorized technology ("Shadow IT") — shall be addressed through the corrective action framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be processed through the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: Exceptions that alter decision rights, governance structure, or the delegation framework shall require County Manager approval, regardless of the IT Director's general delegated authority under **Policy 1.08**.

5. References

Cited References:

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 244 (Counties: Government)
- CJIS Security Policy v6.0: Section 5.1.1.4 (Management Control Agreements)
- NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership)

Framework Alignment:

- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- NIST CSF 2.0: GV.OC-02 (Stakeholder Expectations)
- NIST CSF 2.0: GV.RR-01 (Leadership Accountability)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-3 (Information System Resources)
- COBIT 2019: EDM01 (Ensure Governance Framework Setting and Maintenance)

6. Policy Statement

Elko County requires a governance structure that connects strategic direction from County leadership to the technical execution of Information Operations. This policy establishes the formal authority designations, interdepartmental boundaries, and escalation constructs that ensure IT decisions are made at the appropriate level, funded through proper channels, and overseen with accountability. This policy defines the governance structure within which the delegation framework established in **Policy 1.08** operates; it does not create or modify delegation records, stand-in authority, or exception approval mechanisms.

6.1 Delegated Governance Framework

Elko County hereby establishes a delegated governance model for IT oversight. Strategic direction and budget appropriation are established by the Board of County Commissioners under NRS 244. The execution of technical strategy is delegated to the Information Operations Department in accordance with the decision rights defined in **Policy 1.08**.

- **Program Leadership**: The IT Director shall serve as the designated senior official with responsibility and authority to coordinate, develop, implement, and maintain the County's information security program, consistent with NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership).
- **Central Authority**: The Information Operations Department is designated as the sole authoritative source for all IT-related governance policy, technical standards, and architecture coordination across County departments.
- **Operational Independence**: The Information Operations Department shall operate with the autonomy required to enforce compliance standards, as defined in **Policy 1.03** (Standard Operating Ethos).

6.2 Policy and Enforcement Authority

The IT Director holds the delegated authority to develop IT policy, enforce technical standards, and manage operational decisions.

- **Binding Nature**: The Information Operations Department shall enforce all formally adopted IT policies and technical standards across all Elko County departments, systems, and personnel.
- **CJIS Management Control**: Consistent with CJIS Security Policy v6.0: Section 5.1.1.4 (Management Control Agreements) and applicable Management Control Agreements, the Criminal Justice Agency (CJA) retains management control over criminal justice functions and Criminal Justice Information (CJI). Within that framework, the IT Director (as LASO), acting as the CJA's technical agent, shall exercise exclusive administrative control over the configuration, security, and management of hardware, software, and firmware that transmit or store CJI on County-managed infrastructure, regardless of the user department.

6.3 Access and Change Governance

The IT Director shall reserve the following decision rights exclusively for Information Operations leadership to maintain the integrity of the County network.

- **Access Control**: The IT Director shall retain operational authority over the granting, modification, and revocation of logical access privileges to County information systems and physical access to IT-controlled facilities (e.g., data centers, server rooms, network closets), implemented in accordance with **Policy 2.04** (Access Control Policy) and **Policy 2.02** (Personnel Security and Background Screening Policy).
  - **Constraint**: For systems processing CJI, the IT Director shall ensure that access decisions comply with the CJIS Security Policy and applicable Management Control Agreements.

- **Change Control**: The IT Director shall review and approve changes affecting cross-departmental services, core infrastructure, or security baselines. All such changes shall be processed in accordance with **Policy 3.09** (Change Management Policy).
  - **Constraint**: The IT Director shall notify or obtain approval from the County Manager for significant changes affecting County-wide operations, in accordance with **Policy 1.08**.

6.4 Interdepartmental Dependencies and Obligations

Effective governance requires structured coordination between the Information Operations Department and specific County control functions. The following dependencies are mandatory.

- **Human Resources (HR)**: HR serves as the authoritative source for personnel status. HR shall provide onboarding, offboarding, and role change notifications to the Information Operations Department in accordance with the notification timelines and procedures defined in **Policy 1.08**.
- **Fiscal Affairs**: Fiscal Affairs governs financial processing for technology purchases. Fiscal Affairs shall collaborate with the Information Operations Department to ensure all technology procurement aligns with the governance standards defined in **Policy 1.10** (IT Financial Management and Procurement Policy) and supply chain risk criteria in **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance). Fiscal Affairs shall reject non-compliant requisitions.

6.5 Governance Violations

The following actions constitute governance violations under this policy. The IT Director shall document confirmed instances in the Risk Register maintained under **Policy 1.09** (Risk Management Policy) and shall initiate corrective action through the enforcement framework defined in **Policy 5.01**.

- **Shadow IT**: Deployment of hardware, software, or cloud services on the County network or using County data without Information Operations Department authorization.
- **Unauthorized Procurement**: Purchase or acquisition of technology products, services, or subscriptions without Information Operations Department review and approval as required by **Policy 1.10**.
- **Unauthorized System Changes**: Configuration changes, installations, or modifications to County information systems performed outside the change management process defined in **Policy 3.09**.

6.6 Board Engagement and Governance Escalation

The County Manager shall determine when governance matters require Board of County Commissioners engagement. The following trigger criteria shall inform that determination.

- **Mandatory Board Engagement**: The County Manager shall present the following matters to the Board of County Commissioners for approval or ratification.
  - Policy changes that require legal ratification under NRS 244.
  - IT capital investments or budget appropriations that require Board of County Commissioners approval under applicable County purchasing authority or NRS 244.
  - Material changes to the County's IT governance structure that alter the reporting relationship or authority designation of the Information Operations Department.
- **Discretionary Board Engagement**: The County Manager may present the following matters to the Board of County Commissioners when the County Manager determines that Board awareness or direction is warranted.
  - The Annual Policy Review Report produced under **Policy 5.07**, when findings indicate material governance risk, sustained maturity regression, or resource constraints that require Board-level resolution.

- Conflict resolution matters escalated under **Policy 1.08** that the County Manager determines exceed the County Manager's mediation authority.
- Risk acceptance decisions that the County Manager determines carry County-wide liability implications, as evaluated under **Policy 1.09**.

The IT Director shall provide the County Manager with the information and analysis necessary to support Board engagement determinations.

1.07 Workforce Roles, Responsibilities, and Competency Framework

Effective: April 29, 2026 Version: 1.4

1. Purpose

This policy defines the organizational structure, role definitions, authority tiers, and competency requirements for all personnel within the Elko County Information Operations Department.

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, trainees, contractors, and temporary workers.

- **In Scope**:
  - Internal role design and authority tiers.
  - Role definitions and operational duties.
  - Competency and advancement requirements.
  - Professional development expectations.
- **Out of Scope**:
  - Delegation of authority and acting capacity: **Policy 1.08**.
  - Personnel security screening and background checks: **Policy 2.02**.
  - Security awareness and training program administration: **Policy 2.03**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the department head and senior technical authority for the Information Operations Department.
  - Shall exercise final adjudication authority over competency mastery determinations, role assignments, and advancement decisions.
  - Shall ensure that formal County position descriptions incorporate the competencies defined in **Appendix 6.03** (Workforce Roles STAK Matrix).
- **County Manager:**
  - Shall exercise vacancy governance authority for the IT Director position, including initiation of permanent backfill or role restructuring as defined in Section 6.5.
- **Assistant IT Director:**
  - Shall manage day-to-day service delivery and workforce development.
  - Shall validate competency mastery against the standards defined in **Appendix 6.03**.
  - Shall conduct performance evaluations against the role definitions and competency standards defined in this policy.
- **All Information Operations Personnel:**

  - Shall act strictly within the scope of their assigned role and authority tier.
  - Shall not perform duties reserved for higher tiers without documented delegation in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall maintain the competencies defined for their assigned role in **Appendix 6.03**.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel.

- **Assessment**: Role alignment, competency mastery, certification currency, and training completion shall be verified at least annually through a documented competency assessment. For personnel subject to formal performance reviews, the competency assessment may be conducted as part of the performance review process. The IT Director shall confirm that each individual maintains the current certifications and training completions required by the assigned tier in **Appendix 6.03**. For the IT Director, the annual verification of certification currency, training completion, and assigned-tier competency requirements shall be performed or approved by the County Manager. Lapses shall trigger the access-eligibility consequences defined in Section 6.1 and any account actions required under **Policy 2.03** (Security Awareness and Training Policy) and **Policy 2.04** (Access Control Policy).
- **Enforcement**: Failure to adhere to assigned role boundaries, tier restrictions, or competency requirements shall constitute non-compliance and shall be escalated under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to the role structure or minimum competency requirements for subordinate personnel shall be approved in writing by the IT Director. Exceptions concerning the IT Director's own role, tier, or competency requirements shall require County Manager approval in accordance with **Policy 1.08**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Appendix 6.03: Workforce Roles STAK Matrix
- NRS 242.171 (Responsibilities of Office/Director)
- CJIS Security Policy v6.0: Section PS-3 (Personnel Screening)

Framework Alignment:

- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: AT-1 (Awareness and Training Policy and Procedures)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: PM-13 (Security and Privacy Workforce)

- NIST SP 800-53 Rev. 5: PS-1 (Personnel Security Policy and Procedures)
- NIST SP 800-53 Rev. 5: PS-4 (Personnel Termination)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- NIST SP 800-53 Rev. 5: PS-9 (Position Descriptions)
- NIST SP 800-181 Rev. 1 (NICE Workforce Framework for Cybersecurity)
- COBIT 2019: APO07 (Manage Human Resources)
- ITIL v4: Workforce and Talent Management Practice
- SFIA 9 (Skills Framework for the Information Age)

6. Policy Statement

The Information Operations Department maintains a structured workforce framework to ensure operational continuity, clear authority boundaries, and defensible competency standards across all service delivery and governance functions. This framework aligns role definitions with industry workforce standards and maps competency requirements to the **Skills, Tasks, Abilities, and Knowledge (STAK)** matrix maintained in **Appendix 6.03**.

6.1 Role Tier Structure and Access Eligibility

The Information Operations Department is organized into hierarchical role tiers to ensure operational clarity, escalation discipline, and professional development. Role tiers L0 through L5 correspond directly to the roles defined in **Appendix 6.03**.

- **Security Screening Requirements**: The IT Director shall not assign any individual, including contractors and temporary personnel, to a role above Trainee (Tier L0) until the individual has successfully completed the background screening required for the applicable access classification as defined in **Policy 2.02** (Personnel Security and Background Screening Policy).
  - **Rescreening**: Personnel with access to Criminal Justice Information (CJI) shall undergo rescreening at least once every five (5) years in accordance with CJIS Security Policy v6.0: Section PS-3 (Personnel Screening).
  - **Advancement**: The IT Director shall verify that an individual's background screening adjudication remains current and appropriate for the target tier's access classification before approving advancement between tiers.
  - **Clarification**: Assignment to Tier L0 (Trainee) does not exempt personnel from screening requirements applicable to the access they will receive. No individual shall be granted logical or physical access beyond what the individual's adjudicated access classification permits under **Policy 2.02**.
- **Competency Maintenance**: Assignment to Tier L3 (Administrator) and above shall be contingent upon maintaining all requirements designated as mandatory in **Appendix 6.03**, including required certifications and renewals where specified.
  - **Lapse**: The IT Director shall immediately suspend the affected individual's administrative privileges and remove the individual from unsupervised Tier L3+ duties upon discovery of a lapse in any mandatory requirement (e.g., expiration, revocation, or failure to maintain renewal status).
  - **Reassignment**: The IT Director shall temporarily reassign the affected individual to Tier L2 (Support Specialist) duties or lower until the requirement is reinstated or a written exception is approved under **Policy 1.08**.

  - **Documentation**: The IT Director shall document all privilege suspensions, exceptions, and reinstatements in the Department's system of record and shall manage non-compliance under **Policy 5.01**.

- **Tier Definitions**:
  - **Director Level (Tier L5)**: Provides strategic leadership, governance, and oversight. Focus is on Strategy and Risk.
  - **Assistant Director Level (Tier L4)**: Manages operations and workforce development. Focus is on Operations and Governance.
  - **Administrator Level (Tier L3)**: Manages critical infrastructure, security controls, and engineering. Focus is on Stability and Security.
  - **Support Specialist Level (Tier L2)**: Provides front-line support and resolution. Focus is on Service and Resolution.
  - **Administrative Assistant Level (Tier L1)**: Provides triage and logistics. Focus is on Process and Logistics.
  - **IT Trainee Level (Tier L0)**: Focus is on Learning and Assimilation.

6.2 Role Definitions and Duties

The following roles define the operational and governance structure of the Information Operations Department. The IT Director shall ensure that formal County position descriptions align with these definitions and with the competencies defined in **Appendix 6.03**.

- **IT Director**: The IT Director is the senior technology authority, reporting to the County Manager, with statutory responsibilities established under NRS 242.171. The IT Director shall:
  - **Strategic Planning**: Develop and drive IT strategy aligned with Elko County's statutory duties and public service objectives.
  - **Governance**: Establish and maintain the Information Operations Policy Manual, ensuring compliance with Federal, State, and Local mandates.
  - **Security Leadership**: Serve as the designated Chief Information Security Officer (CISO) function, holding ultimate accountability for the County's cybersecurity posture.
  - **Financial Management**: Manage the departmental budget, capital improvement plans (CIP), and procurement contracts.
- **Assistant IT Director**: The Assistant IT Director serves as the operational executive and deputizes for the IT Director. The Assistant IT Director shall:
  - **Operations Management**: Oversee daily IT service delivery, ensuring adherence to Service Level Agreements (SLAs).
  - **Workforce Development**: Manage staffing, performance evaluations, and the execution of role-based technical training and exercises assigned under **Policy 2.03**.
  - **Project Governance**: Lead the IT project portfolio to ensure initiatives are delivered on time, within scope, and on budget.
  - **Deputization**: Assume decision-making authority in the IT Director's absence only to the extent formally delegated under **Policy 1.08**.
- **Systems Administrator**: The Systems Administrator manages server infrastructure, identity, and data integrity. The Systems Administrator shall:
  - **Server Management**: Provision, harden, and maintain physical and virtual server infrastructure.

  - **Identity Management**: Manage the County's directory services, group policy, and role-based access control (RBAC) in accordance with **Policy 2.04**.
  - **Data Integrity**: Manage backups, disaster recovery replication, and database platform security to ensure data availability and confidentiality.
  - **Patch Management**: Execute the vulnerability management program for server endpoints.
- **Network Administrator**: The Network Administrator manages connectivity, boundary defenses, and transport infrastructure. The Network Administrator shall:
  - **Network Architecture**: Design and maintain LAN/WAN/Wireless topologies to ensure high availability and fault tolerance.
  - **Boundary Defense**: Configure firewalls, VPNs, and intrusion detection systems (IDS/IPS) to protect the network perimeter.
  - **Traffic Analysis**: Monitor network flow and performance metrics to identify anomalies or capacity bottlenecks.
  - **Physical Infrastructure**: Manage structured cabling, switching infrastructure, and environmental controls in network closets.
- **Support Specialist**: Support Specialists serve as the primary interface for end-user assistance and resolution. Support Specialists shall:
  - **Incident Resolution**: Diagnose and resolve front-line hardware and software issues for end-users via the service desk.
  - **Deployment**: Configure and install new endpoints, peripherals, and software in accordance with standard baselines.
  - **User Guidance**: Educate users on approved software configurations and best practices.
  - **Escalation**: Accurately document and escalate unresolved issues to Administrators with complete diagnostic data.
- **Administrative Assistant**: The Administrative Assistant manages departmental front-end operations and logistics. The Administrative Assistant shall:
  - **Access Triage**: Validate visitor credentials, issue visitor badges, and manage physical access logs in compliance with physical security policies.
  - **Credential Support**: Perform verified password resets (non-privileged accounts only) and initial ticket intake and classification under documented procedures.
  - **Coordination**: Manage departmental procurement receiving, phone routing, and scheduling logistics.
  - **Documentation Support**: Assist with formatting and distributing IT communications in accordance with **Policy 1.04** (Policy and Documentation Formatting Standards).
- **IT Trainee**: Trainees operate under a structured development program. Trainees shall:
  - **Mentorship Rotation**: Participate in mandatory rotations across Support and Infrastructure domains.
  - **Certification**: Obtain the mandatory certifications designated for Tier L0 in **Appendix 6.03** (or IT Director-approved equivalents) within twelve (12) months of hire date.
  - **Operational Discipline**: Adhere to the standards of conduct and professional communication requirements defined in **Policy 1.02** (Code of Ethics and Professional Conduct).

  - **CJIS Restriction**: Trainees shall not be assigned duties involving access to Criminal Justice Information (CJI) or CJIS-connected systems until all required CJIS personnel security screening defined in **Policy 2.02** has been successfully adjudicated.

6.3 Advancement Pathways

The IT Director shall evaluate advancement candidates based on demonstrated competency mastery, certification acquisition, and adherence to the standards defined in this policy. Tenure alone shall not constitute grounds for promotion.

- **Criteria**: The IT Director shall base advancement decisions on technical competency as measured against **Appendix 6.03** and the individual's security compliance history (e.g., adherence to policies, absence of unresolved disciplinary actions).
- **Competency Verification**: The Assistant IT Director shall verify that the candidate meets all mandatory STAK requirements for the target tier prior to the IT Director's advancement decision.

6.4 Competency and Skills Framework (STAK)

To ensure objective evaluation of personnel, the Department utilizes the STAK framework.

- **Definition**: Specific STAK requirements for each role are defined in **Appendix 6.03**.
- **Alignment**: Competencies are mapped to the NICE Workforce Framework for Cybersecurity (NIST SP 800-181) and SFIA 9. Framework-to-role alignment detail is maintained in **Appendix 6.03**.
- **Evaluation**: The Assistant IT Director shall explicitly reference the STAK matrix during performance reviews to identify skill gaps and assign remedial training.
- **Training**: The IT Director shall ensure that personnel with security-relevant duties complete role-based cybersecurity training at onboarding and at least annually thereafter, consistent with the competencies defined in **Appendix 6.03** and **Policy 2.03**.

6.5 Role Vacancy and Continuity

To ensure continuity of critical information operations, the following requirements govern role vacancy management.

- **Succession Designation**: The IT Director shall designate at least one (1) individual capable of providing interim coverage for each Tier L3 and above role.
  - **Documentation**: The IT Director shall document succession designations in the Department's system of record.
  - **Annual Review**: The IT Director shall review succession designations at least annually.
- **Immediate Coverage**: Upon an unplanned vacancy in any Tier L3+ role, the IT Director shall activate interim delegation under **Policy 1.08** within one (1) business day.
- **IT Director Vacancy — Interim Authority**: In the event of an IT Director vacancy, the Assistant IT Director shall assume interim operational authority under the standing delegation framework established in **Policy 1.08**.
  - **Notification**: The Assistant IT Director shall formally notify the County Manager of the vacancy within one (1) business day.
  - **Backfill**: The County Manager shall initiate permanent backfill or role restructuring within thirty (30) calendar days of notification.
- **Extended Vacancy**: If a Tier L3+ vacancy (other than IT Director) exceeds sixty (60) calendar days without permanent backfill or a documented restructuring decision, the IT Director shall prepare a risk assessment identifying competency gaps, coverage limitations, and compensating controls.

  - **Submission**: The IT Director shall submit the risk assessment to the County Manager.

6.6 Policy Acknowledgment

All Information Operations Personnel shall acknowledge receipt and understanding of this policy and their assigned role definition upon the following events:

- Initial hire or onboarding into the Department.
- Any change in assigned role or tier.
- Annually thereafter.

The IT Director shall retain acknowledgment records in the Department's system of record.

1.08 Delegation of Authority and Decision Rights

Effective: April 29, 2026 Version: 1.6

1. Purpose

This policy defines the structure, scope, and limitations of decision-making authority within the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel and to any County official, department, or entity interacting with the Information Operations Department in a managerial, technical, or support capacity.

3. Roles and Responsibilities

- **IT Director:**
  - Shall hold primary operational and decision-making authority over technical services, cybersecurity, and infrastructure.
  - Shall delegate administrative and operational authority as defined in Section 6 of this policy.
  - Shall maintain the Separation of Duties Matrix and review it at least annually.
- **County Manager:**
  - Shall hold administrative oversight of the IT Director, including performance evaluation and policy ratification.
  - Shall not exercise operational authority over security controls.
  - Shall serve as the mediation authority for conflicts between administrative and operational authority as defined in Section 6.4.
- **Assistant IT Director:**
  - Shall hold standing delegated operational authority as defined in Section 6.2.
  - Shall serve as the primary operational decision-maker in the IT Director's absence, within the bounds of the standing written Delegation of Authority Order.
- **Human Resources (HR):**
  - Shall provide official onboarding and offboarding notifications as defined in Section 6.5.
  - Shall not direct or influence technical decisions or access control timelines.
- **Fiscal Affairs:**
  - Shall oversee budgetary and procurement processes.
  - Shall not prescribe technical standards or override IT design decisions.
- **All Information Operations Personnel:**
  - Shall operate strictly within their designated role and authority as defined by department policy.
  - Shall not assume authority beyond their assigned role without formal, written delegation.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel and County officials exercising authority over or within the Information Operations Department.

- **Assessment**: Compliance with delegation requirements shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and through the annual review of delegation records and the Separation of Duties Matrix required under Section 6 of this policy.
- **Enforcement**: The IT Director shall treat unauthorized assumption of authority, failure to document delegations, or exercise of authority beyond a delegation's defined scope as non-compliance and may initiate corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with written justification, approved in accordance with **Policy 5.01**, and processed as follows. Oral exceptions are not valid.
  - **Operational Exceptions**: Exceptions to operational delegation shall be approved in writing by the IT Director.
  - **Governance Exceptions**: Exceptions regarding decision rights or chain of command shall be approved by the County Manager in consultation with the IT Director. Governance exceptions shall not grant operational authority, alter security baselines, or authorize deviation from mandatory security controls. Governance exceptions shall not modify incident declaration authority, Incident Commander designation criteria, or operational decision rights during incident response as defined in **Policy 4.01** (Incident Response Policy Overview).
  - **Stand-in Restriction**: During the IT Director's absence, exceptions that would expand the authority of an acting administrative stand-in shall be deferred until the IT Director's return or escalated to the Board of County Commissioners.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: Section AC-6(7) (Least Privilege — Review of User Privileges)
- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: AC-6 (Least Privilege)

Framework Alignment:

- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: AC-1 (Access Control Policy and Procedures)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)

- COBIT 2019: APO01.04 (Define roles, responsibilities, and authorities)
- COBIT 2019: APO01.05 (Define target capability)
- COBIT 2019: DSS06.03 (Manage roles, responsibilities, access privileges, and levels of authority)

6. Policy Statement

This policy formalizes how decision-making power — both operational and administrative — is assigned, delegated, and exercised within the Information Operations Department. The separation of administrative and operational authority is designed to preserve continuity, accountability, and appropriate oversight across the Information Technology function while ensuring that mandatory security controls are never subordinated to administrative convenience.

6.1 Authority Classification

Authority within the Information Operations Department is classified into two distinct categories to satisfy NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties):

- **Administrative Authority**: Managerial oversight functions including personnel management, timekeeping, budget approval, and policy ratification.
- **Operational Authority**: Technical decision-making functions including infrastructure management, cybersecurity configuration, technical standards, and service design.
- **Constraint**: Dual authority (the ability to exercise both administrative and operational functions) resides inherently with the IT Director and may only be granted to others through explicit, written delegation (including the standing delegation defined in Section 6.2).
- **Clarification**: Mandatory security controls — defined as all requirements stipulated by the CJIS Security Policy, Nevada Revised Statutes, and County-adopted security baselines — shall not be subject to override by administrative stand-ins. The IT Director shall ensure that mandatory security controls are maintained regardless of personnel changes or delegations.
- **CJIS Management Control**: For systems processing, storing, or transmitting Criminal Justice Information (CJI), decision rights are subject to the applicable CJIS Management Control Agreement and shall not be overridden by administrative stand-ins.

6.2 Delegation Rules and Limitations

- **Formal Documentation**: The IT Director shall delegate operational authority only to technically qualified personnel (Tier L3 or higher per **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework)) and shall document each delegation in writing. The IT Director shall define the scope, conditions, and duration in the delegation record.
- **Annual Review**: The IT Director shall review delegated authority and privileged access assignments at least annually to validate continued business need, consistent with CJIS Security Policy v6.0: Section AC-6(7) (Least Privilege — Review of User Privileges).
- **Retention**: The IT Director shall retain delegation records in the Department's designated system of record in accordance with NRS 239.125 and the Nevada Local Government Records Management Program.
- **Standing Delegation**: The Assistant IT Director holds standing delegated operational authority and is authorized to exercise administrative functions in the IT Director's absence only within the bounds of a standing written Delegation of Authority Order, reviewed annually. The Assistant IT Director shall exercise only those administrative functions explicitly delegated in writing by the IT Director. Authority not expressly granted is reserved to the IT Director.

  - **Scope of Administrative Authority**: Authority is limited to routine operational administration (e.g., timecard approvals, workflow coordination, internal purchasing). It does not include authority for HR disciplinary actions, terminations, or ratification of the Countywide IT budget.
  - **Lapse**: Failure to complete the annual review of the standing Delegation of Authority Order shall not automatically revoke the standing delegation, but shall constitute non-compliance subject to remediation under **Policy 5.01**. The IT Director shall complete the overdue review within ten (10) business days of discovery, and the delegation record shall be flagged as review-past-due in the Department's system of record until remediation is complete.

- **Directed Deputization**: The IT Director may designate any Tier L3+ Information Operations Department personnel to exercise specific operational authority on the IT Director's behalf for a defined scope and duration. Directed Deputization is limited to operational functions — including work order management, priority retasking, and representation in meetings — and shall not include administrative authority as defined in Section 6.1. The IT Director shall document the designation in writing, specifying the scope of authority granted, the duration, and any constraints. Directed Deputization does not displace the Assistant IT Director from their current role, modify their standing delegation, or alter the chain of delegation established in this policy. The IT Director retains authority to rescind any Directed Deputization at any time. Directed Deputization shall not include the following functions:
  - Policy exception approval.
  - Formal risk acceptance.
  - Incident declaration authority, unless separately authorized under **Policy 4.01**.
  - Access approval for the delegate's own account.
  - NRS 603A.220 breach determination authority.
  - Law enforcement referral authority.
  - Media and public communication authority during cybersecurity incidents.
  - Privacy Impact Assessment (PIA) approval.
  - LASO accountability for CJIS Security Policy incident reporting obligations. **Clarification**: Execution of CJIS notifications may be delegated under Section 6.2; accountability for the obligation is non-delegable.
  - Any function prohibited by the Separation of Duties Matrix maintained under Section 6.6.

- **Emergency Operational Authority**: During declared cybersecurity incidents (per **Policy 4.01**), all operational authority transfers immediately and exclusively to the designated Incident Commander.
  - **Declaration Authority**: Authority to declare a cybersecurity incident resides with the IT Director, Assistant IT Director, or designated technical lead as defined in **Policy 4.01**.
  - **Incident Commander Qualification — Designated Appointment**: The IT Director may designate any Information Operations Department personnel as Incident Commander for a specific incident. Designation shall be made at the time it becomes effective and documented in the incident record. No tier-level prerequisite applies to a designated appointment. The IT Director retains authority to rescind any designation and resume the Incident Commander role at any time.
  - **Incident Commander Qualification — Emergency Declaration Authority**: When both the IT Director and the Assistant IT Director are genuinely unavailable, authority to declare a cybersecurity incident and serve as Incident Commander shall be limited to Tier L3+ Information Operations Department personnel identified in writing by the IT Director. The IT Director shall maintain this list and review it at least annually. In all cases, the Incident Commander shall be Information Operations Department personnel. Personnel serving in a non-technical administrative or acting capacity are not eligible to serve as Incident Commander under either path.

  - **Non-Interference**: Administrative stand-ins shall not intervene in, delay, or countermand operational directives issued by the Incident Commander.
  - **Emergency Procurement**: Emergency operational actions and procurement necessary to maintain or restore mandated security controls shall not be delayed for administrative convenience; unresolved funding disputes shall be escalated to the Board of County Commissioners without pausing required containment actions. The Incident Commander is authorized to initiate emergency procurement using County emergency procedures with after-the-fact ratification.
  - **Fiscal Duty**: Fiscal Affairs and Purchasing shall process Incident Commander emergency procurement requests using applicable emergency procedures without delaying required containment or mandated control restoration. Fiscal Affairs and Purchasing shall document all actions and approvals in the incident record.
  - **Constraint**: Administrative funding authority shall not be exercised to delay, suspend, or condition execution of incident containment actions or mandated security control implementation.
- **Administrative Stand-ins**: Non-technical leadership (e.g., County Manager) acting as a stand-in during leadership absence may fulfill administrative duties (e.g., communications coordination, staffing logistics, budget routing) but shall not:
  - Issue operational directives, service restoration sequencing instructions, or countermand technical decisions.
  - Authorize changes to security baselines, firewall rules, or access configurations.
  - Approve risk acceptance for mandatory security controls.
  - Modify patch deployment schedules or vulnerability remediation priorities.

6.3 Interdepartmental Boundaries

To preserve operational integrity and separation of duties, the following boundaries shall apply:

- **Human Resources (HR)**:
  - HR may enforce administrative actions (e.g., terminations) and shall provide official notifications per Section 6.5.
  - HR shall not influence how access revocation is performed, dictate tools, or establish technical response timelines without IT Director approval.
- **Fiscal Affairs**: Fiscal Affairs may control budgetary limits but shall not mandate hardware standards or compel the reduction of mandatory security controls due to cost without a formal risk acceptance documented in the Risk Register maintained under **Policy 1.09** (Risk Management Policy) and signed by the IT Director.
- **System Access Restrictions**: To enforce separation of duties (AC-5), non-IT personnel serving as administrative stand-ins shall not be granted administrative access to Information Operations systems (e.g., Active Directory, firewalls), including "break-glass" accounts, or physical access to secure server environments without IT escort.
  - **Facilities Access**: Facilities and custodial access provisioning for server rooms/network closets shall be controlled by Information Operations access lists; emergency entry by non-IT personnel shall require IT escort or the Incident Commander's written authorization.

6.4 Revocation and Escalation

- **Revocability**: The IT Director may revoke any delegated authority at any time.
- **Conflict Resolution**: The IT Director or the party identifying the conflict shall formally escalate disputes between administrative and operational authority to the County Manager for mediation.

- **Mediation Constraints**: Mediation shall occur on an expedited basis and begin within one (1) business day of escalation. Mediation may address priorities and resources but shall not authorize deviation from mandatory security controls or security baselines. The IT Director or Incident Commander shall ensure that operational containment and mandated control implementation continue during mediation.
- **Impartiality**: If the County Manager is serving as the administrative stand-in and is a party to the conflict, the IT Director shall escalate the matter to the Board of County Commissioners to ensure impartial review.

6.5 Delegated Notification Authority

The Information Operations Department designates Human Resources as the authoritative originator of official onboarding and offboarding notifications. This delegation is procedural — HR is authorized to initiate the process — but does not convey control over access implementation, technical execution timing, or operational response, which remain with the IT Director and designated IT personnel. When HR is unavailable and an urgent separation requires immediate action, the County Manager or other legally authorized official may initiate the notification directly to the Information Operations Department. The IT Director shall treat such notifications as valid and shall document the source and circumstances in the Department's system of record.

- **Timelines**: HR shall provide:
  - **Onboarding notifications**: At least three (3) business days prior to the start date.
  - **Offboarding notifications**: Immediately upon determination of separation (no later than close of business on the decision date).
- **Accountability**: The IT Director shall document notification delays that result in access control violations and report them to the County Manager. The delaying party bears accountability for the resulting compliance gap.

6.6 Separation of Specific Duties

The IT Director shall enforce the following separation of duties requirements to satisfy NIST SP 800-53 AC-5 (Separation of Duties):

- **Access Approval vs. Access Provisioning**: Personnel authorized to approve access requests shall not be the same personnel who implement the access in the directory service, except where automated provisioning systems enforced by policy are utilized. Automated systems must enforce approval workflows and maintain immutable audit trails.
- **Security Administration vs. Audit Logging**: Personnel with administrative control over security baselines (e.g., firewall rules) shall not have the ability to modify or delete audit logs that record their actions. Security logs must be forwarded to a repository where security administrators hold read-only or append-only privileges.
- **Development vs. Production**: Personnel shall not have unmonitored administrative access to both development and production environments for the same system.
- **Change Approval vs. Change Implementation**: Personnel authorized to approve significant changes to security baselines (e.g., firewall policy, Group Policy, endpoint protection) shall not be the same personnel who implement those changes, except where emergency procedures are invoked and subsequently reviewed.
- **Separation Matrix**: The IT Director shall maintain a documented Separation of Duties Matrix identifying specific incompatible duties, including but not limited to: (a) system administration vs. audit log review; (b) access provisioning vs. access approval. The IT Director shall review this matrix annually.

- **Delegation Constraint**: Delegation shall not permit any individual to both request and approve access, approve access for themselves, or combine access approval with access provisioning, in accordance with separation of duties (AC-5) and least privilege (AC-6).

The IT Director shall document separation-of-duties role assignments and corresponding privileged access authorizations in the Department's access control matrix and shall enforce them through role-based access control (RBAC). The IT Director shall review the access control matrix at least annually and upon significant role or staffing changes. When the IT Director determines that staffing constraints require a single individual to perform otherwise incompatible duties, the IT Director shall implement compensating controls (e.g., independent after-the-fact review within one (1) business day, immutable logging, or secondary approval via workflow) and shall document the exception.

1.09 Risk Management Policy

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy establishes the governance structure, methodology, and responsibilities for managing information technology risk within Elko County.

2. Scope

This policy applies to all information systems, infrastructure, data, personnel, and third-party vendors managed by or on behalf of the Elko County Information Operations Department (ECIO).

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the designated **Authorizing Official (AO)** for Elko County, with authority to issue risk-based authorization decisions for all County information systems.
  - Shall serve as the **Chief Information Security Officer (CISO)** for the County.
  - Shall define the County's risk tolerance by reviewing and approving the **Risk Management Strategy** at least annually.
  - Shall approve all **Risk Acceptance Memos** in accordance with the governance requirements defined in Section 6.8.
  - Shall review and formally approve System Security Categorizations.
- **Assistant IT Director:**
  - Shall serve as the **Risk Program Owner** and coordinate Risk Management Framework (RMF) evidence across systems.
  - Shall ensure the accuracy and currency of the centralized **Risk Register**.
  - Shall develop and maintain a documented Risk Management Strategy that defines risk appetite and tolerance, prioritization criteria, management decision rules for selecting risk responses, scoring methodology, reporting thresholds, and review cadence (NIST SP 800-53 Rev. 5: PM-9 (Risk Management Strategy)).
  - Shall oversee the execution of risk assessments and vulnerability scans.
  - Shall validate that risk mitigation strategies and **Corrective Action Plans** tracked under **Policy 5.03** (Compliance Monitoring and Corrective Action) are effective and updated.
- **Systems Administrators and Network Administrators:**
  - Shall conduct technical risk assessments and vulnerability scans within their operational domain.
  - Shall implement required risk mitigation controls and remediate vulnerabilities within mandated timelines.
  - Shall populate and update technical risk entries in the Risk Register — including Common Vulnerabilities and Exposures (CVE) data, scan results, vulnerability status, and treatment progress — for controls within their operational domain.

  - Shall report changes in system architecture that may alter the risk profile to the Assistant IT Director within one (1) business day.
- **All Information Operations Personnel:**
  - Shall submit identified vulnerabilities, control gaps, or potential threats to the Assistant IT Director for inclusion in the Risk Register.
  - Shall report active threats, anomalous system behavior, or suspected breaches immediately via the channels defined in **Policy 4.02** (Identification and Reporting Procedures).
  - Shall adhere to risk mitigation procedures and security controls defined in this manual.
- **Department Heads and Elected Officials:**
  - Shall support the categorization of information systems within their purview and participate in risk assessments when requested by the IT Director or Assistant IT Director.
  - Shall concur with Risk Acceptance Memos for systems within their purview, acknowledging the operational risk being accepted, in accordance with Section 6.8.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel and County officials involved in risk management activities.

- **Assessment**: Adherence to risk management requirements shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: Failure to identify, report, or remediate risks in accordance with this policy shall be treated as non-compliance. The IT Director may initiate corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.
  - **Clarification**: Formal risk acceptance under Section 6.8 is not an exception to this policy. Risk acceptance is a governed risk response strategy within the framework established by this policy. Requests to deviate from the risk acceptance governance framework itself — including decision rights or the chain of approval — are governance exceptions governed by **Policy 1.08** (Delegation of Authority and Decision Rights).

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.05: Security Control Assessment and Authorization

- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- CJIS Security Policy v6.0: Section RA-3 (Risk Assessment)
- CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning)
- NIST CSF 2.0: ID.RA-02 (Cyber Threat Intelligence)
- NIST SP 800-53 Rev. 5: PM-9 (Risk Management Strategy)
- NIST SP 800-53 Rev. 5: RA-2 (Security Categorization)
- NIST SP 800-53 Rev. 5: RA-3 (Risk Assessment)
- NIST SP 800-53 Rev. 5: RA-5 (Vulnerability Monitoring and Scanning)
- NIST SP 800-53 Rev. 5: RA-7 (Risk Response)
- NIST SP 800-53 Rev. 5: RA-9 (Criticality Analysis)

Framework Alignment:

- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section RA-1 (Risk Assessment Policy and Procedures)
- CJIS Security Policy v6.0: Section RA-2 (Security Categorization)
- CJIS Security Policy v6.0: Section RA-7 (Risk Response)
- CJIS Security Policy v6.0: Section RA-9 (Supply Chain Risk Assessment)
- NIST CSF 2.0: GV.RM-01 (Risk Management Objectives)
- NIST CSF 2.0: GV.RM-02 (Risk Appetite and Tolerance)
- NIST CSF 2.0: GV.RM-04 (Risk Response Direction)
- NIST CSF 2.0: GV.RM-06 (Risk Calculation and Prioritization)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST CSF 2.0: ID.RA-03 (Threat Identification)
- NIST CSF 2.0: ID.RA-04 (Threat Impact and Likelihood)
- NIST CSF 2.0: ID.RA-05 (Risk Response Prioritization)
- NIST CSF 2.0: ID.RA-06 (Risk Responses)
- NIST SP 800-30 Rev. 1: (Guide for Conducting Risk Assessments)
- NIST SP 800-37 Rev. 2: (Risk Management Framework for Information Systems and Organizations)
- NIST SP 800-53 Rev. 5: RA-1 (Risk Assessment Policy and Procedures)
- NIST SP 800-137: (Information Security Continuous Monitoring)
- COBIT 2019: APO12 (Manage Risk)
- COBIT 2019: EDM03 (Ensure Risk Optimization)
- ITIL v4: Risk Management Practice

6. Policy Statement

This policy mandates a lifecycle approach to identifying, assessing, responding to, and monitoring risks that threaten the confidentiality, integrity, and availability of County information systems. It serves as the authority for risk-based decision-making, resource prioritization, and the formal acceptance of operational risk. The Authorize step of the RMF lifecycle is operationalized through **Policy 5.05** (Security Control Assessment and Authorization), which consumes the risk ratings, security categorizations, and Corrective Action Plan status produced under this policy to render formal authorization decisions.

6.1 Risk Management Framework (RMF) Adoption

The Information Operations Department adopts the NIST Risk Management Framework (RMF) as the strategic methodology for managing system lifecycles. The Assistant IT Director shall ensure that all County information systems move through the RMF stages: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor.

- **Risk Management Strategy**: The Assistant IT Director shall maintain a documented Risk Management Strategy that defines risk appetite and tolerance, prioritization criteria, management decision rules for selecting risk responses, scoring methodology, reporting thresholds, and review cadence. The IT Director shall approve the Risk Management Strategy at least annually (NIST SP 800-53 Rev. 5: PM-9 (Risk Management Strategy)).
- **Continuous Monitoring**: The Assistant IT Director shall align operational risk management with the NIST Cybersecurity Framework (CSF) 2.0 functions and shall integrate risk monitoring into the Department's Continuous Monitoring program. The Assistant IT Director shall record outputs as evidence in the Risk Register and control assessment records. The program shall explicitly track:
  - **Effectiveness**: Monitoring ensuring security controls are operating as intended.
  - **Compliance**: Monitoring ensuring adherence to CJIS, HIPAA, PCI, and County policy.
  - **Change**: Monitoring identifying changes to systems or environments that alter the risk profile.

6.2 Security Categorization

The Assistant IT Director shall categorize all County information systems based on the potential impact of a loss of confidentiality, integrity, or availability.

- **Authorizing Official Approval**: The IT Director (AO) shall review and formally approve the security categorization of all information systems (NIST SP 800-53 Rev. 5: RA-2 (Security Categorization)).
- **Documentation**: The Assistant IT Director shall document security categorization results and rationale in the System Security Plan (SSP) or equivalent system security documentation.
- **Criminal Justice Information (CJI)**: All systems processing, storing, or transmitting CJI shall be categorized, at a minimum, as Moderate Impact and shall implement CJIS-required controls and County controls commensurate with that impact level.
- **Categorization Review**: The Assistant IT Director shall review security categorizations annually or following any significant system change.

6.3 Risk Assessment Methodology

The Assistant IT Director shall ensure that risk assessments identify threats, vulnerabilities, likelihood, and impact specific to the system environment. Assessments shall utilize the standardized scoring criteria defined in the Risk Management Strategy. Assessments shall explicitly consider supply chain risks in accordance with **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance).

- **Assessment Cadence**:

  - **Quarterly Review**: The Assistant IT Director shall review all risk assessments at least quarterly. Review consists of Risk Register reconciliation, status validation, and treatment progress confirmation.
  - **Annual Update**: The Assistant IT Director shall perform formal risk assessment updates — including re-scoring and threat refresh — at least annually for non-critical systems.
  - **CJI and Critical Systems Update**: The Assistant IT Director shall perform formal risk assessment updates at least quarterly for CJI and Critical systems (CJIS Security Policy v6.0: Section RA-3 (Risk Assessment)).
- **Event-Driven Reviews**: The Assistant IT Director shall initiate a risk assessment update within five (5) business days following any security incident, material system change, significant control failure, or confirmed vulnerability affecting County systems (NIST SP 800-53 Rev. 5: RA-3 (Risk Assessment)).
- **Policy Review**: This policy shall be reviewed at least annually in accordance with **Policy 1.05** and updated when changes to the risk environment, regulatory requirements, or organizational structure warrant revision.
- **Threat Intelligence**: The Assistant IT Director shall incorporate cyber threat intelligence received from external information-sharing forums (e.g., MS-ISAC, FBI InfraGard) into the risk assessment process (NIST CSF 2.0: ID.RA-02 (Cyber Threat Intelligence)).

6.4 Vulnerability Monitoring and Remediation Standards

The Department shall employ automated tools to scan for vulnerabilities in information systems and hosted applications. Operational patching procedures, specific tool configurations, and authoritative remediation timelines are maintained in **Policy 2.09** (Vulnerability and Patch Management Policy).

- **Scope**: The Systems Administrators and Network Administrators shall scan internal assets, external perimeter assets, and web applications. Privileged vulnerability scans shall require explicit authorization from the IT Director or Assistant IT Director.
- **Scanning Frequency**: The responsible Administrators shall perform vulnerability scans at least monthly (County Baseline) and whenever new vulnerabilities potentially affecting the system are identified and reported, including following major configuration changes and critical exploit advisories (CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning)).
- **Remediation**: The responsible Administrators shall remediate vulnerabilities within the timelines defined in **Policy 2.09**. Severity ratings shall be based on the County-approved scoring standard (e.g., CVSS base score or vendor severity, whichever is higher), as defined in **Policy 2.09**.
- **Enforcement**: When remediation will exceed the timelines defined in **Policy 2.09**, the responsible Administrator shall submit a Risk Acceptance Memo in accordance with Section 6.8 before the remediation deadline expires. The memo shall include compensating controls to mitigate risk during the exposure window and a defined expiration date.

6.5 Risk Response Strategies

Upon identification of a risk, the Assistant IT Director shall select one of the following response strategies (NIST SP 800-53 Rev. 5: RA-7 (Risk Response)):

- **Mitigate**: The responsible Administrator shall apply controls (patches, configuration changes, and physical barriers) to reduce risk to an acceptable level. When the mitigation response requires tracked remediation with milestones, the Assistant IT Director shall route it to **Policy 5.03** for Corrective Action Plan development.
- **Accept**: Formally acknowledge the risk in accordance with the Risk Acceptance Governance requirements defined in Section 6.8.

- **Transfer**: Shift liability to a third party (e.g., cyber insurance, managed service contracts). The Assistant IT Director shall manage vendor risk transfer in accordance with **Policy 1.13**.
- **Avoid**: The IT Director shall authorize discontinuation of the activity, system, or vendor relationship causing the risk.

6.6 Criticality Analysis

The Assistant IT Director shall identify critical system components and functions by performing a criticality analysis at the planning, design, and implementation stages (NIST SP 800-53 Rev. 5: RA-9 (Criticality Analysis)).

- **High Value Assets (HVAs)**: The IT Director shall designate systems as Critical or High Value in the Disaster Recovery Plan or System Security Plan (SSP). The Assistant IT Director shall prioritize designated systems for advanced protection measures and continuity planning.

6.7 Risk Register and Reporting

The Assistant IT Director shall maintain a centralized Risk Register tracking all identified risks.

- **System of Record**: The Risk Register shall be maintained in the Department's designated **System of Engagement** with strict role-based access controls.
- **Sensitive Security Information**: The Risk Register and supporting evidence shall be treated as sensitive security documentation. The Assistant IT Director shall restrict access to authorized personnel on a need-to-know basis and shall manage disclosures in accordance with County policy and CJIS requirements.
- **Minimum Data Fields**: The Risk Register shall contain, at a minimum: Risk ID, Date Identified, System/Asset, System Owner, CJI Indicator (Y/N), Risk Category, CVE/CVSS (if applicable), Inherent/Residual Score, Control Mapping, Treatment Strategy, CAP Linkage (when applicable), Status, Due Date, and Acceptance Authority.
- **CAP Updates**: Corrective Action Plans for unremediated risks shall follow the tracking and update cadence defined in **Policy 5.03**. The Assistant IT Director shall update the corresponding Risk Register entry when a CAP achieves closure or when a CAP milestone changes the residual risk posture.
- **Reporting**: The IT Director shall report a summary of the County's risk posture — including all accepted High and Critical risks — to the County Manager annually. Risk posture data shall also be provided as an input to the annual policy review and maturity scoring process under **Policy 5.07**.

6.8 Risk Acceptance Governance

Risk acceptance is a formal risk response strategy that requires documented justification, dual concurrence, and IT Director approval. This section defines the governance framework for risk acceptance decisions.

- **Risk Acceptance Memo**: The Assistant IT Director shall document each risk acceptance in a Risk Acceptance Memo. Each memo shall include, at a minimum: scope of the accepted risk, business justification, compensating controls, expiration or review date, residual risk statement, and the concurrence of the Department Head or Elected Official responsible for the affected system.
- **Decision Rights**: Department Head or Elected Official concurrence constitutes acknowledgment of operational and business impact and acceptance of residual operational risk. IT Director (AO) approval constitutes the authorization decision and acceptance of residual security risk on behalf of the County.
- **Approval Authority**: The IT Director shall approve all Risk Acceptance Memos. Risk acceptance is non-delegable. No other role may approve risk acceptance on the IT Director's behalf, consistent with the non-delegable functions defined in **Policy 1.08**.

- **Automatic Expiration**: All risk acceptances shall automatically expire on the stated expiration date. The Assistant IT Director shall treat expired acceptances as unauthorized deviations until renewed in writing.
- **Ongoing Monitoring**: The Assistant IT Director shall monitor accepted risks for changes in likelihood, impact, or exposure until the risk is closed or the acceptance expires. Accepted risks shall remain documented in the Risk Register.
- **Prohibition**: Risk acceptance shall not authorize non-compliance with CJIS Security Policy requirements, statutory requirements, or other mandatory security controls.
- **Authorization Package**: Risk Acceptance Memos shall become part of the system's authorization package alongside the System Security Plan, Security Assessment Report, and any open Corrective Action Plans.
- **Record Retention**: The Assistant IT Director shall retain Risk Acceptance Memos, risk assessment reports, and supporting evidence in accordance with NRS 239.125 and the applicable Nevada Local Government Records Retention Schedule under NAC 239.155, including records classified under the IT Security Evaluations, IT Security Plans, and IT Security Reviews, Reports and Logs series.

1.10 IT Financial Management and Procurement Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes mandatory internal controls over the financial stewardship and procurement of County technology resources.

2. Scope

This policy applies to all technology-related financial transactions conducted by any Elko County entity, department, or elected office, regardless of funding source or purchasing mechanism.

- **In Scope**:
  - Technology hardware, software, and infrastructure procurement.
  - Cloud services (Software-as-a-Service (SaaS), Infrastructure-as-a-Service (IaaS), Platform-as-a-Service (PaaS)), subscriptions, renewals, and auto-renewals.
  - Consulting, support, and managed service contracts.
  - Technology purchases made via departmental Purchase Cards (P-Cards), regardless of funding source.
  - Grant-funded technology acquisitions and renewals.
- **Out of Scope**:
  - Technical review of system design and implementation changes: **Policy 3.09** and **Policy 2.15**.
  - Post-award vendor compliance monitoring: **Policy 5.06**.
  - Asset lifecycle controls after receipt: **Policy 1.12**.
  - Supply chain risk due diligence and vendor onboarding review: **Policy 1.13**.
  - Non-technology procurement conducted by County departments.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the Technical Authority for all County technology procurement.
  - Shall approve technical specifications, security requirements, and lifecycle and architectural impact for all technology procurement prior to the obligation of funds, the execution of purchasing actions, or the acceptance of contract terms.
  - Shall own County IT vendor technical standards, security requirements, and technical dispute escalation.
  - Shall designate technical approvers only through **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall document each technical-approver designation.
- **Assistant IT Director:**

  - Shall maintain procurement tracking artifacts required for audit and reconciliation, including the linkage of purchases to requisitions, receiving records, work orders, project codes, inventory entries, and Configuration Management Database (CMDB) entries maintained under **Policy 3.08** (Service Configuration Management (CMDB) Policy).
  - Shall provide oversight of procurement workflow execution.
  - Shall resolve workflow exceptions that exceed Administrative Assistant authority.
- **Administrative Assistant:**
  - Shall execute day-to-day procurement workflow tasks — including requisition preparation, purchase order tracking, and receiving coordination — as directed by the Assistant IT Director.
- **Office of Fiscal Affairs:**
  - Shall verify budget availability for all technology procurement prior to commitment of funds.
  - Shall execute purchasing and payment activities in accordance with applicable County procurement rules and NRS 332.
  - Shall not process technology invoices, reimbursements, or payment requests that lack documented Technical Approval from the IT Director or a formally delegated technical approver.
- **Department Heads:**
  - Shall define business requirements for departmental technology needs.
  - Shall coordinate with the Information Operations Department to validate technology requirements prior to initiating procurement.
  - Shall not negotiate technology vendor agreements without Information Operations Department review and documented Technical Approval.
  - Shall not authorize technology procurement without Information Operations Department review and documented Technical Approval.
  - Shall not accept or execute technology contract terms — including click-through terms, End User License Agreements (EULAs), Master Service Agreements (MSAs), Statements of Work (SOWs), renewals, and auto-renewals — without Information Operations Department review and documented Technical Approval.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all County personnel engaged in technology procurement or technology-related financial activity.

- **Assessment**: Compliance shall be assessed through procurement review activities, audit support activities, and the annual policy review process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Emergency Deviations**: When immediate technology procurement is necessary to protect life, safety, or critical infrastructure and delay would materially increase harm, the IT Director or the Assistant IT Director may authorize Emergency Technical Approval. A technical approver formally delegated under **Policy 1.08** may issue Emergency Technical Approval only within the scope of that written delegation. Emergency Technical Approval does not constitute purchasing authority, contract execution authority, or payment authorization; these remain subject to the Office of Fiscal Affairs and applicable emergency-contract requirements under NRS 332.112. Emergency Technical Approval shall satisfy the following constraints:

  - The invoking authority shall document a written emergency basis establishing the threat to life, safety, or critical infrastructure and the time constraints that preclude the standard Technical Approval process.
  - The invoking authority shall notify the Office of Fiscal Affairs within twenty-four (24) hours of authorization.
  - When Emergency Technical Approval is issued by a technical approver delegated under **Policy 1.08**, the delegated approver shall notify the IT Director within twenty-four (24) hours of authorization.
  - The invoking authority shall submit complete post-incident documentation — including the written emergency basis, the Emergency Technical Approval record, inventory capture, and asset or CMDB entry — within ten (10) business days of the emergency action.
  - Emergency Technical Approval authority does not extend beyond the specific transaction required to address the immediate harm; subsequent related procurements shall follow the standard Technical-Fiscal Handshake.
  - The IT Director shall review all Emergency Technical Approval authorizations on a quarterly basis.
  - The IT Director shall report the inventory of emergency invocations, their written bases, and their post-incident documentation status as part of the annual policy review under **Policy 5.07**.
- **Exceptions**: Standing exceptions to this policy shall be documented with justification and approved in writing in accordance with **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.15: System Development and Secure Software Lifecycle Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 332.063 (Procurement thresholds: Contracts over $50,000 but not more than $100,000)
- NRS 332.065 (Procurement thresholds: Contracts over $100,000 — advertising and award)
- NRS 332.112 (Emergency contracts)
- NAC 239.155 (Adoption of Records Retention Schedule)
- LRDA 20070074 (Requisitions and Purchase Orders)
- LRDA 20071310 (Procurement and Credit Card Records)

- CJIS Security Policy v6.0: SA-9 (External System Services — Security Addendum requirements for private contractors)
- CJIS Security Policy v6.0: Appendix H (CJIS Security Addendum and Certification)

Framework Alignment:

- NIST CSF 2.0: GV.RR-03 (Resource Allocation)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)
- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: PM-3 (Information Security and Privacy Resources)
- NIST SP 800-53 Rev. 5: SA-2 (Allocation of Resources)
- NIST SP 800-53 Rev. 5: SA-4 (Acquisition Process)
- NIST SP 800-53 Rev. 5: SR-3 (Supply Chain Controls and Processes)
- COBIT 2019: APO06 (Managed Budget and Costs)
- COBIT 2019: APO10 (Managed Vendors)
- ITIL v4: Service Financial Management
- ITIL v4: Supplier Management

6. Policy Statement

Elko County shall separate **Technical Authority** (validation of technology need, compatibility, lifecycle and architectural impact, inventory integration, and security) from **Financial Authority** (budget verification and lawful purchasing execution). This separation exists to prevent unauthorized technology acquisition, ensure value realization, and maintain auditability of public funds consistent with Nevada Revised Statutes.

6.1 The Technical-Fiscal Handshake

All technology spending shall pass through a mandatory two-step validation:

- **Technical Approval**: The IT Director shall record Technical Approval as a distinct approval status on the procurement work order in the System of Engagement, including approver identity and timestamp. Email correspondence and verbal assent shall not constitute Technical Approval.
- **Financial Approval**:
  - The Office of Fiscal Affairs shall validate budget availability prior to authorizing payment.
  - The Office of Fiscal Affairs shall verify that purchasing actions comply with applicable procurement requirements, including competitive bidding thresholds and required documentation under NRS 332.
- **Handshake Restrictions**:
  - The Office of Fiscal Affairs shall not treat a budget line item as authorization to procure; Technical Approval is required.
  - The Office of Fiscal Affairs shall not process payment without documented Technical Approval.
  - The Information Operations Department shall not integrate, support, or onboard technology resources acquired without documented Technical Approval.

6.2 Procurement Controls and Shadow IT Prohibition

- **Centralized Procurement**: All County personnel shall route County software, hardware, and cloud subscription procurement through the Information Operations Department to ensure security review, asset tagging, license compliance, and CMDB and inventory integration.
- **P-Card Restrictions**: County personnel shall not use departmental P-Cards for technology hardware, software, or subscriptions without written pre-authorization by the IT Director or a formally delegated technical approver. The Office of Fiscal Affairs shall flag suspected technology P-Card transactions for review and audit.
- **Grant-Funded Technology**: Grant-funded technology shall be subject to the same standards as County-funded assets, including security requirements, inventory and CMDB entry, supportability, and lifecycle cost planning. Department Heads shall engage the Information Operations Department during grant application development to validate technical feasibility and total cost of ownership.
- **Auto-Renewal Controls**: The IT Director shall disable auto-renewal on technology subscriptions when vendor contract terms permit. When auto-renewal cannot be disabled due to vendor contract terms, the Assistant IT Director shall initiate renewal review not less than sixty (60) calendar days before each renewal date to prevent unmanaged commitments.
- **Bid Splitting**: County personnel shall not split a single technology procurement requirement into multiple smaller transactions to evade competitive bidding thresholds established by NRS 332.063 and NRS 332.065.

6.3 Budgeting and Security Resource Allocation

- **Security Resourcing**: The IT Director shall plan, request, and maintain discrete funding necessary to implement required security controls and compliance obligations.
- **Lifecycle Forecasting**: The IT Director shall include Total Cost of Ownership (TCO) considerations in technology budget submissions, including licensing, maintenance, support, required security controls, power and cooling (as applicable), and end-of-life disposal.

6.4 Asset Intake Handshake

The Office of Fiscal Affairs shall not approve payment for technology hardware, software, or Software-as-a-Service invoices without the asset intake confirmations required under **Policy 1.12** (IT Asset Management Policy). Receiving, inspection, tagging, and inventory or CMDB entry shall follow the Hardware Receiving Gatekeeping and Software and SaaS Gatekeeping requirements established in that policy.

6.5 Vendor Integrity and Contract Security Requirements

- **Conflict of Interest and Gifts**: All County personnel participating in technology procurement decisions shall comply with the Zero-Gift Policy and Vendor Interaction requirements established under **Policy 1.02** (Code of Ethics and Professional Conduct). Personnel shall disclose any actual or potential conflict of interest in writing to the IT Director prior to participating in a procurement decision.
- **Contract Security Requirements**: The IT Director shall ensure that contracts involving County data exchange, hosting, or access to County systems incorporate the security and data protection terms established under **Policy 5.06** (Vendor Compliance and Third-Party Assurance Policy). Department Heads shall not execute technology contracts that omit these required terms.
- **CJIS Contractor Requirements**: When a vendor or contractor may have logical or physical access to Criminal Justice Information (CJI):
  - The IT Director (as LASO) shall require incorporation of the CJIS Security Addendum into the contract consistent with CJIS Security Policy v6.0 SA-9 (External System Services) and Appendix H.

- The IT Director (as LASO) shall ensure that each contractor employee with CJI access is provided a copy of the CJIS Security Addendum and the CJIS Security Policy, and that an executed Security Addendum Certification is obtained acknowledging receipt and agreement to comply.
- The Assistant IT Director shall retain executed certifications and acknowledgments in the department's records retention system.
- The Assistant IT Director shall ensure that executed certifications and acknowledgments remain available for audit.

6.6 Records Retention

The Assistant IT Director shall retain Information Operations procurement artifacts and tracking records — including Technical Approval records, procurement work order linkages, receiving confirmations, and inventory and CMDB reconciliation data — in accordance with LRDA 20070074 (Requisitions and Purchase Orders), LRDA 20071310 (Procurement and Credit Card Records), NRS 239.125 (Local Government Records Management Program), and NAC 239.155 (Adoption of Records Retention Schedule). Official purchasing and payment records — including purchase orders, invoices, and payment vouchers — shall be retained by the Office of Fiscal Affairs or the authoritative County custodian under the applicable retention schedule.

1.11 Data Governance and Classification Policy

Effective: April 29, 2026 Version: 2.5

1. Purpose

This policy establishes the mandatory governance framework for classifying and protecting Elko County data assets. This policy mandates data stewardship, classification assignment, and security attribute association while preserving statutory transparency obligations under Nevada law.

2. Scope

This policy applies to all data created, received, maintained, processed, stored, or transmitted by Elko County, regardless of format (digital, physical, or audiovisual) or location (on-premises, cloud-hosted, mobile, or third-party managed).

- **In Scope**:
  - Production data, records, databases, and application files supporting County operations.
  - Operational and security data, including system logs, audit trails, configuration data, and network telemetry.
  - Physical media, including printed documents, tapes, portable media, and removable storage devices.
  - Criminal Justice Information (CJI) stored or processed within County-controlled systems.
- **Out of Scope**:
  - Privacy-specific obligations and individual data subject rights: **Policy 2.06**.
  - Media sanitization and physical destruction procedures: **Policy 2.12**.
  - Access control enforcement mechanisms and identity management: **Policy 2.04** and **Policy 2.05**.
  - Vendor and third-party compliance assurance: **Policy 1.13**.

3. Roles and Responsibilities

- **Board of County Commissioners:**
  - Shall delegate authority to the IT Director to administer retention and disposition procedures for Information Operations records and IT-managed data assets in accordance with Nevada retention schedules, County directives, and applicable legal holds.
    - **Constraint**: This delegation applies to Information Operations records and IT-managed data assets and shall not be interpreted as superseding statutory duties assigned to other County offices.
- **IT Director:**
  - Shall serve as the primary governance authority for data classification and data security.
  - Shall define and enforce the County Data Classification Schema and mandatory safeguards.
  - Shall hold the Local Agency Security Officer (LASO) designation, serving as the County's primary information security liaison with the CJIS Systems Agency (CSA).

  - Shall represent the County in all CJIS information security matters.
  - Shall maintain CJIS security documentation, including system configuration data.
  - Shall support CJIS compliance audits of hardware and procedures.
  - Shall disseminate CJIS information security alerts and related material to County stakeholders with CJI access.
  - Shall keep the CSA informed of information security needs and incidents.
  - Shall authorize or deny requests to reclassify Restricted CJI downward, subject to any additional CJIS governing authority required by applicable agreements.
  - Shall serve as the Information Operations Records Custodian under Board delegation for Information Operations records and IT-managed data assets, including retention and disposition procedures.
  - Shall ensure required technical controls, handling standards, and exception decisions are implemented and enforced County-wide for County-managed systems.
- **Department Heads:**
  - Shall classify departmental data at creation or intake in accordance with the Data Classification Schema defined in Section 6.
  - Shall ensure access to departmental data is limited to authorized personnel based on business need-to-know.
  - Shall ensure departmental processes comply with the handling requirements defined in this policy.
- **All Information Operations Personnel:**
  - Shall implement and operate the technical controls required to protect data according to its assigned classification, including access enforcement, encryption, segmentation, and logging.
- **All County Personnel:**
  - Shall handle, transmit, and store data in accordance with this policy and the assigned classification.
  - Shall report suspected misclassification, mishandling, or unauthorized disclosure promptly through established reporting channels to the IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all County departments and personnel who create, access, store, or transmit County data.

- **Assessment**: Adherence to data classification and handling requirements shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: The IT Director shall enforce this policy. Unauthorized disclosure or mishandling of Confidential or Restricted information constitutes a violation subject to the enforcement framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be governed by the exception management framework defined in **Policy 5.01**, within delegated authority under **Policy 1.08**. Oral exceptions are not valid.
  - **Clarification**: Exceptions involving Restricted CJI are subject to the CJI-specific requirements in **Policy 5.01**.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205 (Crimes Against Property)
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records)
- NRS 603A (Security of Personal Information)
- NAC 239.165 (Destruction of Confidential Records)
- LRDA 20071728 (IT Access Control Reviews and Audit Trails)
- CJIS Security Policy v6.0: Section 4 (Criminal Justice Information and Personally Identifiable Information)

Framework Alignment:

- CJIS Security Policy v6.0: Section 3.2 (Roles and Responsibilities for Agencies and Parties)
- CJIS Security Policy v6.0: Section AU (Audit and Accountability)
- CJIS Security Policy v6.0: Appendix G.3 (Cloud Computing)
- CJIS Security Policy v6.0: Section MP (Media Protection)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- NIST CSF 2.0: ID.AM-05 (Asset Prioritization)
- NIST CSF 2.0: ID.AM-07 (Data Inventories and Metadata)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST SP 800-53 Rev. 5: AC-3 (Access Enforcement)
- NIST SP 800-53 Rev. 5: AC-16 (Security and Privacy Attributes)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: MP-3 (Media Marking)

- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-53 Rev. 5: RA-2 (Security Categorization)
- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: APO13 (Manage Security)
- COBIT 2019: APO14 (Manage Data)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: DSS05 (Manage Security Services)

6. Policy Statement

The County shall assign value and sensitivity to information so that security controls are applied consistently and proportionally to the risk of unauthorized access, disclosure, modification, destruction, or loss of availability. All data residing on County infrastructure or processed on behalf of the County is County property. In any conflict between requirements established in this policy and upstream authorities, the order of precedence established in the Manual Executive Summary governs.

6.1 Data Classification Schema

The IT Director shall maintain the County Data Classification Schema. The County shall classify all data into one (1) of four (4) levels based on the potential impact of unauthorized disclosure, modification, destruction, or loss of availability. Classification shall drive mandatory safeguards, handling restrictions, and access enforcement.

- **Default Classification**: All County Personnel shall handle data not yet classified as Restricted until the responsible Department Head formally evaluates and assigns a classification level.
- **Prohibited Storage**: All County Personnel shall store and process County data only in repositories and systems approved by the IT Director. The use of personal cloud storage, personal email accounts, unsanctioned collaboration tools, or other unauthorized systems to store or process County data is prohibited.

6.2 Level 1 — Public

Public information is data explicitly approved for unrestricted distribution. Unauthorized disclosure presents no identified risk of harm to the County.

- **Examples**: Published press releases, public meeting agendas, job postings, public website content.
- **Minimum Safeguards**: The IT Director shall ensure integrity controls sufficient to prevent unauthorized modification or defacement.

6.3 Level 2 — Internal Use

Internal Use information is operational data intended for internal County business use. Disclosure may cause operational confusion, reputational harm, or unnecessary disruption but is not inherently sensitive.

- **Examples**: Internal memos, internal directories, standard procedures, non-sensitive drafts.
- **Minimum Safeguards**: All Information Operations Personnel shall enforce standard access controls (unique user authentication), standard backup, and retention per approved schedules.

6.4 Level 3 — Confidential

Confidential information is sensitive data that, if compromised, could negatively impact individual privacy, County finances, legal posture, or operational security. Department Heads shall limit access to personnel with a validated business need-to-know.

- **Examples**: Personally Identifiable Information (PII) as defined in NRS 603A, personnel records, vendor contracts containing non-public financial terms, draft budgets, privileged legal communications.
- **Minimum Safeguards**:
  - **Access**: All Information Operations Personnel shall enforce role-based access control (RBAC) and least privilege in accordance with **Policy 2.04** (Access Control Policy).
  - **Encryption**: All Information Operations Personnel shall apply County-approved encryption at rest for mobile devices, portable storage, and systems storing Confidential data outside a County-controlled physically secure location.
  - **Logging**: All Information Operations Personnel shall ensure systems storing Confidential information generate audit logs and that privileged access to such systems is logged in accordance with **Policy 2.11** (Audit Logging and Monitoring Policy).
  - **Privacy**: Department Heads shall ensure Confidential data containing PII is handled in accordance with **Policy 2.06** (Privacy and Data Protection Policy).

6.5 Level 4 — Restricted

Restricted information is highly sensitive data protected by strict federal or state requirements. Unauthorized disclosure or modification could result in severe legal penalties, loss of program access, loss of funding, or public safety impacts.

- **Examples**: Criminal Justice Information (CJI) as governed by CJIS Security Policy v6.0 Section 4, Protected Health Information (PHI) where applicable, active investigative data, administrative credentials, cryptographic keys.
- **Minimum Safeguards**:
  - **Encryption**: All Information Operations Personnel shall protect Restricted data using cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP) for data at rest and in transit, consistent with CJIS requirements.
  - **Access**: All Information Operations Personnel shall enforce multi-factor authentication (MFA) for access to Restricted data systems, Restricted data repositories, and administrative functions, in accordance with **Policy 2.05** (Identification and Authentication Policy).
  - **Exposure Controls**: The IT Director shall ensure Restricted data systems are not directly exposed to the public Internet without County-approved boundary protection and network segmentation consistent with CJIS requirements.
  - **Auditing**: All Information Operations Personnel shall capture and retain audit records for access, modification, and deletion events in accordance with **Policy 2.11**, CJIS requirements for CJI, and the retention requirements defined in Section 6.9.

6.6 Data Handling and Stewardship

- **Classification Assignment and Security Attributes**:
  - Department Heads shall assign the appropriate classification at creation or intake.
  - The IT Director shall ensure classification is associated as a security attribute on systems that support attribute-based access enforcement to support handling rules and auditability.

- **Labeling and Marking**:
  - The IT Director shall ensure that systems storing Confidential or Restricted data support classification labeling.
  - All Information Operations Personnel shall apply classification labels to digital documents and physical media containing Confidential or Restricted information (e.g., headers/footers, watermarking, media labels) to ensure personnel are aware of required handling and disclosure constraints.
  - **Exception**: Systems or media formats that do not support labeling shall be documented by the IT Director, and the IT Director shall apply compensating controls.
- **Access Control and Need-to-Know**:
  - Department Heads shall ensure Confidential and Restricted data is accessible only to authorized users with a validated business need-to-know.
  - All Information Operations Personnel shall enforce access through approved identity and access management controls consistent with **Policy 2.04** and **Policy 2.05**.
  - The IT Director shall ensure access is reviewed and adjusted when personnel roles change or upon termination of employment or contract.
- **Transmission Security**: All County Personnel shall not transmit Confidential or Restricted data over unprotected channels.
  - **Restricted Data**: All County Personnel shall transmit Restricted data only using County-approved secure methods that enforce strong encryption in transit (e.g., approved VPN, TLS 1.2 or higher, or other approved secure protocols consistent with CJIS requirements).
  - **Email Restrictions**: All County Personnel shall not use standard unencrypted email to transmit Restricted data. If transmission is explicitly authorized by the IT Director for business necessity, the IT Director shall designate an approved encryption method or secure delivery mechanism. Restricted CJI shall only be transmitted in accordance with the CJIS Security Policy.
- **Authorized Storage Locations and Cloud Security Assurance**: The IT Director shall approve all repositories and systems authorized for County data storage.
  - **Cloud Security Assurance**: The IT Director shall ensure vendors or cloud service providers hosting Confidential or Restricted County data are evaluated and governed through the vendor governance process defined in **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance). Third-party authorizations (e.g., FedRAMP, StateRAMP, SOC 2) may support due diligence but shall not be represented as automatically meeting CJIS Security Policy requirements or substituting for required CJIS agreements and addenda.
  - **CJI Cloud Requirements**: The IT Director shall ensure systems storing or processing CJI in cloud environments meet all CJIS Security Policy requirements for encryption, access control, auditing, personnel security, and agreement and oversight obligations applicable to the service model.
  - **CJI Data Sovereignty**: As an Elko County standard for CJIS risk control and audit defensibility, the IT Director shall ensure CJI is stored and processed only within the physical boundaries of an APB-member country and under the legal authority of an APB-member agency, unless permitted by the CSA/CSO and approved in writing by the IT Director (as LASO), with all required CJIS governing approvals documented.
  - **Non-CJI Restricted Data Residency**: All Information Operations Personnel shall store Restricted data that is not CJI within the physical borders of the United States.
  - **Confidential Data Residency**: All Information Operations Personnel should store Confidential data within the physical borders of the United States.

    - **Exception**: When storage of Confidential data outside U.S. borders is proposed, the IT Director shall document the justification, the compensating controls, and the residual risk accepted, and shall review such authorizations annually.
  - **Internal and Public Data Residency**: Internal and Public data have no residency requirement under this policy.
- **Storage, Media Control, and Disposal**:
  - All Information Operations Personnel shall protect Confidential and Restricted data through secure storage controls.
  - All Information Operations Personnel shall ensure data is destroyed or sanitized when no longer required, consistent with the retention requirements defined in Section 6.9 and the sanitization procedures defined in **Policy 2.12** (Media Protection and Sanitization Policy), in a manner that renders the data unrecoverable prior to disposal, transfer, or reuse of the media.

6.7 Reclassification

Data classification is not static. Department Heads shall review classifications annually, at minimum, and shall update classification when sensitivity, disclosure status, legal posture, or operational context changes.

- **CJI Reclassification**:
  - **Constraint**: The IT Director (as LASO) shall not authorize downward reclassification of Restricted CJI without written authorization from any additional CJIS authority required by governing agreements.
  - The IT Director (as LASO) shall retain written authorization with the classification decision record.

6.8 Data Inventory

The IT Director, in coordination with Department Heads, shall maintain a County Data Inventory that identifies:

- Data categories and assigned classification levels.
- The responsible Department Head for each category.
- Logical and physical storage locations, including approved cloud services.
- Applicable retention requirements based on mandatory Nevada retention schedules and County directives.

The IT Director shall review and update the Data Inventory annually and following significant changes to systems, services, or regulatory obligations. The Data Inventory shall support the System Inventory maintained under **Policy 1.12** (IT Asset Management Policy) and the Risk Register maintained under **Policy 1.09** (Risk Management Policy).

6.9 Records Retention and Disposition

The IT Director shall ensure retention periods are applied in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule.

- **IT Access Control Reviews and Audit Trails**: The IT Director shall retain IT security logs, including access control and audit logs, for a minimum of three (3) calendar years from the end of the calendar year in which the review or audit was concluded, per the applicable Nevada Local Government Records Retention Schedule for IT Access Control Reviews and Audit Trails (currently LRDA 20071728).
- **CJIS Audit Records**: For CJIS audit records, the IT Director shall apply the greater of the CJIS minimum retention period or the applicable Nevada retention requirement.

- **Destruction Standards**: The IT Director shall ensure destruction of confidential records complies with NAC 239.165.
- **Legal Holds**: The IT Director shall suspend retention and disposition actions for Information Operations records during litigation holds, public records preservation requirements, audits, or other legal hold events.

6.10 Public Records and Disclosure Obligations

The IT Director shall ensure security classification is not treated as an automatic exemption from disclosure. The IT Director shall ensure public records requests under NRS 239 are handled through the County's established legal review process. When classification controls appear to conflict with a public records obligation, the District Attorney's Office shall provide binding guidance.

6.11 LASO Designation and Authority

The IT Director shall hold the Local Agency Security Officer (LASO) designation by policy mandate. The LASO designation shall be registered with the CJIS Systems Agency (currently Nevada Department of Public Safety).

- The IT Director shall update the LASO registration with the CSA upon appointment of a new IT Director.
- **Clarification**: LASO accountability for CJIS Security Policy obligations is non-delegable under **Policy 1.08**. Execution of specific CJIS tasks (e.g., notifications) may be delegated under **Policy 1.08**.

1.12 IT Asset Management Policy

Effective: April 29, 2026 Version: 2.7

1. Purpose

This policy establishes the governance framework for the lifecycle management of Information Technology (IT) assets owned, leased, or operated by Elko County.

2. Scope

This policy applies to all IT assets acquired, leased, managed, deployed, connected, or supported by Elko County, regardless of funding source.

- **In Scope**:
  - **End-User Computing**: Laptops, desktops, workstations, tablets, and thin clients.
  - **Mobile Computing**: Smartphones, cellular hotspots, and portable storage media.
  - **Infrastructure**: Physical and virtual servers, storage arrays, switches, routers, firewalls, wireless access points, and uninterruptible power supply (UPS) units.
  - **Peripherals**: Network-connected printers and multifunction devices, scanners, and specialized interface devices.
  - **Communications**: Voice over Internet Protocol (VoIP) endpoints and conferencing hardware.
  - **Physical Security Systems**: Internet Protocol (IP) cameras, Network Video Recorders (NVRs), and access control panels.
  - **Software and Subscriptions**: Licensed software, operating systems, subscriptions, and Software as a Service (SaaS) entitlements.
- **Out of Scope**:
  - **Media Sanitization and Handling Procedures**: **Policy 2.12** (Media Protection and Sanitization Policy).

3. Roles and Responsibilities

- **IT Director:**
  - Shall maintain IT asset property and equipment records and inventory controls pursuant to NRS 354.625.
  - Shall serve as the final approving authority for lifecycle standards, replacement determinations, and decommissioning actions.
  - Shall approve all retire, transfer, and disposition decisions for County IT assets.
  - Shall ensure that asset records in the System of Engagement are maintained current and complete.
  - Shall provide an annual asset reconciliation report to the Office of Fiscal Affairs.
- **Assistant IT Director:**
  - Shall maintain the At-Risk asset list as a continuously updated view in the System of Engagement.

  - Shall conduct the annual physical inventory audit and reconciliation cycle defined in Section 6.7.
- **All Information Operations Personnel:**
  - Shall execute asset receiving, tagging, asset record creation, and deployment tasks in accordance with this policy.
  - Shall process all asset transfers, relocations, and reassignments through the work order system.
  - Shall execute secure decommissioning and sanitization actions under Section 6.10.
  - Shall deny network connectivity and technical support to any asset that lacks a valid County IT asset tag or that is not recorded in the System of Engagement.
- **Department Heads:**
  - Shall ensure that department personnel do not remove, transfer, relocate, or dispose of any County IT asset without processing the action through the Information Operations Department.
  - Shall report loss, theft, damage, or suspected compromise of assigned IT assets to the Information Operations Department immediately upon discovery, and in no event later than one (1) hour following discovery.
- **All County Personnel:**
  - Shall protect assigned County IT assets from theft, damage, and unauthorized access.
  - Shall report loss, theft, or suspected compromise of any assigned IT asset to the Information Operations Department immediately upon discovery, and in no event later than one (1) hour following discovery.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Personnel, Department Heads, and All County Personnel in the handling of County IT assets.

- **Assessment**: Asset inventory accuracy and lifecycle compliance shall be assessed through the annual physical inventory audit defined in Section 6.7 and the annual maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance with this policy may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 2.14: Mobile Device and Remote Access Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy

- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 354.625 (Records Relating to Property and Equipment; Control of Inventory)
- LRDA 20070440 (Fixed Assets and Inventories)
- CJIS Security Policy v6.0: Section 5.9.1 (Physically Secure Location)
- NIST CSF 2.0: ID.AM-02 (Software, Services, and Systems Inventories)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: MP-6 (Media Sanitization)
- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-88 Rev. 1 (Guidelines for Media Sanitization)

Framework Alignment:

- NIST CSF 2.0: ID.AM-01 (Hardware Inventories)
- NIST CSF 2.0: ID.AM-05 (Asset Prioritization)
- NIST CSF 2.0: ID.AM-08 (Asset Lifecycle Management)
- COBIT 2019: BAI09 (Managed Assets)
- COBIT 2019: BAI10 (Managed Configuration)

6. Policy Statement

6.1 Asset Stewardship and Acquisition

Elko County shall manage IT assets under centralized technical authority to ensure security, interoperability, and fiscal accountability. All technology assets and services placed under County custody or connected to the County network are subject to the lifecycle controls defined in this policy, regardless of funding source.

- **Centralized Technical Approval**: All technology assets and services shall be procured through the Information Operations Department or with documented Technical Approval as defined in **Policy 1.10**.
- **Unauthorized Acquisition**: Technology acquired without documented Technical Approval shall be treated as unauthorized and may be denied integration, support, and network connectivity by the Information Operations Department.
- **Hardware Receiving Gatekeeping**: Hardware invoices shall not be approved for payment by the Office of Fiscal Affairs until the assets are received, inspected, tagged under Section 6.3, and entered into the asset inventory under Section 6.5.
- **Software and SaaS Gatekeeping**: Software and SaaS invoices shall not be approved for payment until the license or subscription is recorded in the designated software inventory and any vendor review required under **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance) is complete.

- **County Property**: Technology assets owned by Elko County — regardless of funding source (General Fund, Enterprise Funds, Grants, Donations, or Asset Forfeiture) — are County property and are subject to all controls defined in this manual.
- **County Custody and Network Governance**: Leased, hosted, or vendor-owned technology assets placed under County custody or connected to County network infrastructure are subject to the operational, support, and security controls defined in this manual, regardless of ownership.
- **Tracking Threshold**: Consumables (including toner, cables, paper, and similar low-value supplies) are below the individual asset-tracking threshold of this policy and are not assigned asset records. The IT Director may designate specific passive peripheral classes for individual tracking under Section 6.3.

6.2 Asset Support Classification

All IT assets and systems operating within or connected to the Elko County network shall carry one of three support classifications. This classification determines support ownership and escalation routing for each asset. The IT Director shall approve the support classification for each asset and shall ensure the classification is recorded on the asset record in the System of Engagement and updated when contractual or operational conditions change.

Interaction with Lifecycle Status: Support classification under this policy and asset lifecycle status classification under **Policy 3.01** (Service Catalog and SLA Policy) are independent dimensions. Support classification determines ownership and escalation routing; lifecycle status classification determines the level of support commitment the Information Operations Department provides. Each asset carries one value from each dimension simultaneously.

- **IT-Managed**: Assets and systems wholly procured, configured, maintained, and supported by the Information Operations Department for the duration of the operational lifespan.
  - The Information Operations Department shall retain exclusive authority over all technical work performed on IT-Managed assets.
  - No vendor, contractor, or department personnel shall perform technical work on IT-Managed assets without prior written authorization from the IT Director.
  - All service activity on IT-Managed assets shall be documented in the work order system governed by **Policy 3.05** (Service Request Fulfillment Policy).
- **IT-Supported**: Assets and systems supported under a vendor contract or lease agreement for which the Information Operations Department provides first-line support and escalates to the vendor when issues exceed local resolution capability or when the contract directs vendor involvement.
  - The Information Operations Department shall be the first point of contact for service requests on IT-Supported assets.
  - Direct contact with the vendor is permissible when the contract explicitly provides for it or when the issue is outside the Information Operations Department's scope of support.
  - All service activity, whether performed locally or escalated to the vendor, shall be documented in the work order system.
- **Vendor-Managed**: Assets and systems for which the vendor retains exclusive support responsibility and over which the Information Operations Department exercises no technical authority.
  - Information Operations Personnel shall not perform technical work on Vendor-Managed assets beyond the minimum required to provide vendor access, such as assigning network addresses or granting physical facility access.
  - All service requests for Vendor-Managed assets shall be referred directly to the vendor.
  - The Information Operations Department shall document coordination activity on Vendor-Managed assets in the work order system for tracking purposes.

6.3 Asset Identification and Tagging

The Information Operations Department shall apply a visual tagging system to provide immediate visibility into asset ownership and funding source. Tags are applied at the point of deployment and shall be recorded on the asset record in the System of Engagement.

- **GREEN Tags (IT-Managed)**: Applied to assets procured (purchased or leased), configured, and supported by the Information Operations Department. GREEN-tagged assets represent the standard authorized computing environment.
- **YELLOW Tags (Grant-Funded)**: Applied to assets purchased with grant funds. The YELLOW tag is informational, identifying the grant source on the asset record for reporting purposes; it does not alter the IT Director's authority over retire, transfer, or disposition decisions.
- **BLUE Tags (Fiscal Inventory)**: Applied to assets meeting the Office of Fiscal Affairs capitalization threshold and carrying a County fiscal inventory tag. The Information Operations Department shall track BLUE-tagged assets for reconciliation against Fiscal Affairs records.

Passive Peripherals: Keyboards, pointing devices, standard cables, and other passive peripherals are not individually tagged or tracked unless the IT Director designates a specific class for tracking based on a formal risk assessment conducted under **Policy 1.09**. The IT Director shall document any such designation and the supporting risk assessment in the System of Engagement.

6.4 Lifecycle Standards

The Information Operations Department shall maintain lifecycle standards to reduce outage risk and ensure supportability. The IT Director shall publish standard replacement cycles in the System of Engagement and shall apply them as the default planning horizon for each asset class, subject to budget appropriation.

- **Standard Replacement Lifecycle**: The following timelines represent the standard useful life for County assets:
  - **Mobile Devices (Smartphones)**: three (3) years.
  - **End-User Computing (Laptops, Desktops, Tablets)**: four (4) years.
  - **Printers and Multifunction Devices**: four (4) years.
  - **UPS Batteries**: three (3) to five (5) years. The IT Director shall apply the manufacturer-specified replacement interval when it falls within this range. Manufacturer-specified intervals outside this range shall be documented on the asset record and approved by the IT Director.
  - **Servers and Storage**: six (6) years.
  - **Peripherals (Monitors, Scanners)**: eight (8) years.
  - **Infrastructure (Switches, Cabling, Cameras)**: ten (10) years.
- **At-Risk Designation**: Any asset remaining in production beyond its standard replacement cycle shall be designated **At Risk** on the asset record in the System of Engagement.
  - The Assistant IT Director shall maintain the At-Risk list as a continuously updated view in the System of Engagement.
  - The IT Director shall use the At-Risk list as standing input to procurement planning and replacement prioritization.
  - **Clarification**: The At-Risk designation applies to individual physical assets and is distinct from the lifecycle status classifications (Supported, Deprecated, Unsupported) maintained in the IT Asset Catalog under **Policy 3.01**.
  - **Unfunded Replacement**: Assets operating beyond their standard replacement cycle shall be referred to the risk management framework under **Policy 1.09** (Risk Management Policy) for

formal risk acceptance if replacement cannot be funded within the current or subsequent budget cycle.

6.5 Inventory and Tracking

The Information Operations Department shall maintain a System Inventory consistent with the statutory property and equipment records requirement in NRS 354.625 and the system component inventory control **NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)**.

- **System of Record**: The asset record, maintained in the System of Engagement, shall serve as the authoritative record for IT asset inventory under this policy. Asset records and Configuration Item records governed by **Policy 3.08** are distinct instruments that serve different governance purposes; each deployed physical asset shall carry both records, cross-referenced via the Related Issues field in the System of Engagement.
- **Ownership Indication**: Every asset record shall indicate the legal ownership status of the asset (County-owned, leased, hosted, or vendor-owned) in accordance with NRS 354.625(2).
- **Unauthorized Presence**: Unauthorized technology shall not be connected to, installed on, or operated within the County IT environment.
  - **Hardware Authorization**: Hardware is authorized when it has been acquired through the Information Operations Department, recorded as an asset record in the System of Engagement, and tagged under Section 6.3.
  - **Software and SaaS Authorization**: Software and SaaS entitlements are authorized when they have been acquired through the Information Operations Department, enumerated in the IT Asset Catalog maintained under **Policy 3.01**, and recorded in the software inventory under Section 6.6 of this policy.
  - **Enforcement**: All Information Operations Personnel shall deny network connectivity and technical support to any asset lacking the required authorization markers and shall remove unauthorized hardware, software, or SaaS from the County IT environment upon discovery.
- **Required Record Elements**: Each asset record shall, at a minimum, contain the following fields:
  - **Unique Asset Identifier** (Tag ID).
  - **Make, Model, and Serial Number**.
  - **Support Classification** (IT-Managed, IT-Supported, or Vendor-Managed per Section 6.2).
  - **Operational State** (Stored, Deployed, or Decommissioned).
  - **Physical Location**.
  - **Assigned Custodian**.
  - **Network Identity** (hostname, Media Access Control (MAC) address, and Internet Protocol (IP) address, as applicable).
  - **Component Type** (hardware category; for example, laptop, server, switch, firewall).
  - **Date Received** (date the asset was received by the Information Operations Department and placed into inventory).
  - **Supplier Information** (vendor or reseller from which the asset was acquired).
  - **Procurement Identifiers** (Purchase Order number or lease/contract identifier, invoice number where applicable, and original cost, to support **Policy 1.10** auditability).
  - **Data Classification Relevance** (applicable classification level per **Policy 1.11** (Data Governance and Classification Policy) where the asset stores or accesses Confidential or Restricted data).

6.6 Software and License Management

The Information Operations Department shall manage software assets to ensure license compliance and security.

- **Software Inventory**: Software, subscriptions, and SaaS entitlements shall be inventoried consistent with **NIST CSF 2.0: ID.AM-02 (Software, Services, and Systems Inventories)**.
- **Required Software Inventory Elements**: Each software inventory record shall, at a minimum, contain the following fields:
  - **Software Name**.
  - **Publisher** (software vendor or manufacturer).
  - **Version** (installed or subscribed version).
  - **License Type** (for example, perpetual, subscription, concurrent-user, or site license).
  - **License Count** (number of seats, installations, or entitlements authorized).
  - **Software Owner** (County role or department accountable for the software's authorized use).
  - **Assigned Deployments** (users, devices, or systems on which the software is installed or for which access is provisioned).
  - **Renewal or Expiration Date** (for subscriptions, SaaS entitlements, and term-limited licenses).
- **License Compliance**: The IT Director shall reconcile license allocation annually to prevent over-deployment and under-utilization.
- **Unapproved Software**: Installation of software or cloud services not recorded in the inventory is prohibited. All Information Operations Personnel shall remove unapproved software upon discovery and document the removal in the work order system.

6.7 Inventory Auditing and Reconciliation

The Information Operations Department shall conduct inventory audits to validate record accuracy.

- **Annual Audit**: The Assistant IT Director shall complete a physical and logical inventory validation at least annually.
- **Reconciliation**: The Assistant IT Director shall investigate and reconcile discrepancies between the physical audit and the asset records in the System of Engagement within thirty (30) calendar days of discovery.
- **Fiscal Reporting**: The IT Director shall provide an annual IT asset reconciliation report to the Office of Fiscal Affairs to support County financial reporting and the Office of Fiscal Affairs' statutory property and equipment reporting obligations under NRS 354.625.
- **Records Retention**: Reconciliation records and supporting inventory documentation shall be retained in accordance with **LRDA 20070440 (Fixed Assets and Inventories)**.

6.8 Movement and Transfer

To preserve inventory integrity, County IT assets shall not be transferred between users, relocated between facilities, or reassigned without an approved work order under **Policy 3.05** and a corresponding asset record update. Information Operations Personnel shall update the asset record to reflect the new assignment or location before closing the work order. Unauthorized relocation of County IT assets by custodians is prohibited.

6.9 Secure Storage and Loss Reporting

Custodians shall ensure County IT assets are stored securely to prevent theft, damage, or unauthorized access.

- **Physical Security**: Storage practices for assets capable of accessing or storing Criminal Justice Information (CJI) shall align with the physically secure location requirements of **CJIS Security Policy v6.0 Section 5.9.1**.
- **Immediate Reporting**: All County Personnel shall report loss, theft, or suspected compromise of any County IT asset to the Information Operations Department immediately upon discovery, and in no event later than one (1) hour following discovery.
- **Chapter 4 Intake**: Information Operations Personnel shall create a Safety and Security category work order upon receipt of any device loss or theft report. This discharges the Chapter 4 intake obligation under **Policy 4.02** (Identification and Reporting Procedures).
- **CJIS Notification**: Where the lost or stolen asset contains or has access to CJI, the Criminal Justice Information Services (CJIS) determination and the CJIS Security Policy Section IR-6 Part (a) internal one-hour reporting clock are governed by **Policy 4.02**. CJIS Security Policy Section IR-6 Part (b) external notification execution is governed by **Policy 4.06** (Communication Protocols and Partner Integration). This policy owns the asset-loss reporting intake; incident declaration and CJIS notification execution are not within the scope of this policy.

6.10 Secure Disposal and Decommissioning

The Information Operations Department shall control decommissioning to prevent data exposure and ensure auditable disposal.

- **Sanitization Standard**: All Information Operations Personnel shall sanitize digital media prior to disposal, release, or reuse using methods (Clear, Purge, or Destroy) consistent with **NIST SP 800-88 Rev. 1** and **Policy 2.12**.
- **Method Selection**: The IT Director shall approve the sanitization method based on the classification of data stored on the device under **Policy 1.11**.
- **Documentation**: All Information Operations Personnel shall document each sanitization and disposal action, recording the date, method used, and the personnel performing the validation.
- **CI Record Retirement**: All Information Operations Personnel shall retire the associated Configuration Item record in accordance with **Policy 3.08** as a required step of the decommissioning workflow.
- **E-Waste**: The IT Director shall transfer electronic waste only through approved recycling vendors that provide certificates of destruction or recycling.

6.11 Offsite and Home Use

County IT assets are intended for County business use.

- **Authorized Offsite Use**: Only portable devices (laptops, tablets, smartphones) issued to a specific user are authorized for offsite use.
- **Prohibited Removal**: Infrastructure, desktop computers, printers, and monitors shall not be removed from County premises for offsite or home use. Exceptions to this provision shall be processed under **Policy 5.01** and shall require the express written approval of the IT Director prior to asset removal.
- **Governing Obligations**: County IT assets used offsite are subject to the acceptable use controls in **Policy 2.01** and the mobile and remote access controls in **Policy 2.14** (Mobile Device and Remote Access Policy).

1.13 Supply Chain Risk Management (SCRM) and Vendor Governance

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy governs third-party vendor engagements. It establishes Supply Chain Risk Management (SCRM) controls for the acquisition of technology products and services.

2. Scope

This policy applies to all third-party entities — including vendors, contractors, consultants, and managed service providers (MSPs) — that interact with Elko County information systems, data, or secure facilities. This policy does not govern commodity off-the-shelf consumables (e.g., toner, cables) where the vendor has no access to County systems, data, or secure facilities.

- **In Scope**:
  - Third parties granted physical or logical access to County Information Technology (IT) assets, facilities, or systems.
  - Third parties providing hardware, software, or cloud-based solutions integrated with County operations.
  - Third parties requiring network connectivity through on-premise, Virtual Private Network (VPN), or cloud integration.
  - Third parties that store, process, transmit, or administer Elko County data.
- **Out of Scope**:
  - Technology procurement, contract execution, and payment authorization: **Policy 1.10**.
  - Asset lifecycle governance after receipt: **Policy 1.12**.
  - Ongoing vendor compliance monitoring and Vendor Compliance Record maintenance: **Policy 5.06**.
  - Ongoing vendor repair operations on production systems: **Policy 3.17**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the Technical Authority for third-party vendor engagements.
  - Shall approve vendor engagements, architectural fit, and security boundaries.
  - Shall reject vendors that fail to meet minimum security requirements or refuse required security addendums.
  - Shall hold the Local Agency Security Officer (LASO) designation per **Policy 1.11** and shall execute all Criminal Justice Information Services (CJIS) liaison obligations arising from vendor engagements.
- **Assistant IT Director:**

  - Shall manage day-to-day vendor governance activities including vendor risk assessment execution, onboarding coordination, and offboarding coordination.
  - Shall prepare vendor risk assessment findings for IT Director review and approval.
  - Shall coordinate vendor access provisioning and revocation with the relevant Information Operations Personnel.
- **Department Heads:**
  - Shall serve as the Business Owner for vendor engagements originating in their department.
  - Shall define business requirements and manage vendor deliverables and timelines.
  - Shall ensure vendor adherence to County operational requirements.
  - Shall not delegate contract ownership or business-logic decisions to Information Operations Personnel.
- **Office of Fiscal Affairs:**
  - Shall ensure contracts include County-required indemnification and procurement clauses.
  - Shall not finalize procurement processing for vendor engagements involving Criminal Justice Information (CJI) until the IT Director (as LASO) provides written confirmation that required CJIS contract language has been incorporated.
- **Human Resources:**
  - Shall maintain personnel tracking for individual contractors requiring County system access.
  - Shall coordinate background screening processes for contractors in accordance with applicable County hiring standards.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Personnel and for all County personnel involved in third-party vendor engagements.

- **Assessment**: Compliance shall be assessed through vendor onboarding review, internal audit activities defined in **Policy 5.02**, and the annual policy review process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance may result in corrective actions defined under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment). Unauthorized provisioning of access or assets to a third party is a security violation subject to corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing in accordance with **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy

- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 2.14: Mobile Device and Remote Access Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.17: System Maintenance and Vendor Repairs
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance Policy
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Adoption of Records Retention Schedule)
- LRDA 20070378 (Vendor Files)
- LRDA 20070474 (Contracts and Agreements)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section PS-3 (Personnel Screening)
- CJIS Security Policy v6.0: Section SA-9 (External System Services)
- CJIS Security Policy v6.0: Appendix H (CJIS Security Addendum and Certification)
- 2 CFR §200.216 (Prohibition on certain telecommunications and video surveillance equipment or services)
- 47 CFR §1.50002 (FCC Covered List)
- NDAA FY2019 §889 (Covered telecommunications equipment and services prohibition)

Framework Alignment:

- NIST CSF 2.0: GV.SC-01 (SCRM Program Establishment)
- NIST CSF 2.0: GV.SC-04 (Supplier Prioritization)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SR-1 (Policy and Procedures)
- NIST SP 800-53 Rev. 5: SR-3 (Supply Chain Controls and Processes)
- COBIT 2019: APO10 (Manage Vendors)

6. Policy Statement

Third-party vendor engagements expose the County to risks that no internal control alone can contain: supply-chain compromise, unauthorized access through contractor systems, and data exposure through service providers. This policy establishes the operational controls that make vendor engagement defensible — clear authority boundaries, documented risk assessment, binding contractual security terms, and auditable offboarding.

6.1 Operational Boundaries

- **Business Ownership**: The Department Head of the Requesting Department shall serve as Project Lead.
  - The Department Head of the Requesting Department shall manage scope, timelines, acceptance, and invoicing.
- **Technical Enablement**: The Information Operations Department shall provide security validation, network connectivity, and infrastructure provisioning necessary to support approved engagements.
- **Prohibition**: Information Operations Personnel shall not serve as Project Manager for third-party engagements initiated by other departments.

6.2 Supply Chain Risk Management

- **Vendor Risk Assessment**: The Assistant IT Director shall conduct a risk assessment for each new technology vendor prior to contract execution using the methodology defined in **Policy 1.09** (Risk Management Policy), commensurate with service criticality and data classification.
- **Assessment Approval**: The IT Director shall approve or reject each vendor risk assessment prior to contract execution.
- **Federal Covered-Technology Prohibition**:
  - The IT Director shall not procure, renew, or expand deployment of equipment or services identified as covered under applicable federal restrictions, including items appearing on the Federal Communications Commission (FCC) Covered List, to preserve eligibility for federal funding and reduce supply chain exposure.
  - The IT Director shall document discovered covered equipment within five (5) business days of discovery.
  - The IT Director shall ensure network-level segregation of documented covered equipment within ten (10) business days of documentation.
  - The IT Director shall file a replacement plan for documented covered equipment within thirty (30) calendar days of documentation, based on risk and lifecycle constraints.
- **Enhanced Due Diligence**: For vendors with logical access to Confidential or Restricted data (per **Policy 1.11**) or to CJI, the IT Director shall require at least one independent assurance artifact prior to contract execution, such as a Service Organization Control (SOC) 2 Type II report, an ISO/IEC 27001 certification, an independent security assessment report, a qualified third-party penetration-test summary, or equivalent independent third-party attestation. Vendor-authored questionnaires may supplement but shall not substitute for independent assurance. For other vendors, the IT Director may require such evidence based on risk.

6.3 Contracting and Pre-Engagement Controls

- **No Contract, No Access**: The IT Director shall not grant third-party logical access, and shall not authorize vendor hardware installation or connection, until a contract or formal agreement is fully executed.

- **Data Protection Addendum**: The IT Director shall ensure contracts involving Confidential or Restricted data (per **Policy 1.11**) incorporate County-required security and data protection terms.
- **CJIS Security Addendum**: The IT Director (as LASO) shall require incorporation of the CJIS Security Addendum into any vendor contract involving potential logical access to CJI, or unescorted access to physically secure locations where CJI is processed, consistent with CJIS Security Policy v6.0 SA-9 (External System Services) and Appendix H.
- **CJIS Contractor Certifications**: The IT Director (as LASO) shall ensure that each contractor employee with CJI access is provided a copy of the CJIS Security Addendum and the CJIS Security Policy, executes the CJIS Security Addendum Certification, and that executed certifications are retained and available for audit.
- **Information Exchange Agreement**: The IT Director (as LASO) shall ensure that any vendor arrangement enabling external access to, transmission of, or exchange of CJI is supported by a written Information Exchange Agreement (IEA) or equivalent contract language in accordance with **Policy 1.14**.
- **CJIS External Provider Oversight**: The IT Director (as LASO) shall ensure that vendor agreements for external system services with access to CJI authorize the CJIS Systems Agency (CSA), the CJIS Systems Officer (CSO), their designated auditors, and authorized County representatives to conduct audits at minimum triennially, conduct unannounced security inspections, and require evidence of control compliance.
- **Fingerprint-Based Record Check**: The IT Director (as LASO) shall ensure that, prior to any grant of logical access or unescorted physical access to CJI, all vendor personnel undergo a state of residency and national fingerprint-based record check adjudicated by the CSA or the State Identification Bureau (SIB) in accordance with CJIS Security Policy v6.0 PS-3 (Personnel Screening).
- **Vendor Personnel Notification**: The IT Director shall ensure vendor agreements require vendor notification to the IT Director or designee within one (1) business day of any transfer or termination of vendor personnel holding County credentials, badges, or system privileges, and prior to separation where planned.
- **Subcontractor Flow-Down**: The IT Director shall ensure vendor agreements prohibit the vendor from engaging subcontractors or sub-processors with access to County data, network connectivity, or CJI exposure without prior affirmative written approval from the IT Director. Absence of an affirmative written response from the IT Director shall not constitute approval. Vendor agreements shall require contractual flow-down of all applicable County obligations — including security controls, incident notification, audit rights, personnel screening, data handling, and destruction requirements — to any approved subcontractor. The prime vendor shall remain fully liable for subcontractor compliance.
- **Vendor Incident Notification**: The IT Director shall ensure vendor agreements require vendor notification to the Information Operations Department of any suspected or confirmed incident affecting County systems or County data. Contract terms shall establish the following windows:
  - **CJI Branch**: If CJI may be impacted, vendor notification shall occur no later than one (1) hour after discovery, consistent with CJIS Security Policy v6.0 IR-6 (Incident Reporting).
  - **Non-CJI Branch**: For all other incidents affecting County systems or data, vendor notification shall occur no later than twenty-four (24) calendar hours after discovery.
- **Monitoring and Service Oversight**: The IT Director shall ensure vendor contracts provide County monitoring and review access to security operational information through one or more of the following: automated access to vendor audit logs, annual third-party assurance reports (e.g., SOC 2 Type II), or integration with County-designated security monitoring infrastructure. For vendors handling CJI, contracts shall also incorporate CJIS monitoring requirements consistent with CJIS Security Policy v6.0 SA-9 (External System Services).

6.4 Asset Integration

Vendor-provided, vendor-installed, and vendor-leased technology placed on County networks or under Information Operations configuration control shall be classified, tagged, and governed in accordance with **Policy 1.12** (IT Asset Management Policy). The asset support classification (IT-Managed, IT-Supported, or Vendor-Managed) and the GREEN-tag governance that follows are defined by **Policy 1.12**, and apply regardless of contractual ownership or lease status when Information Operations exercises configuration control or lifecycle governance.

- **Configuration Item Recording**: The Assistant IT Director shall ensure leased or vendor-provided devices under Information Operations configuration control are recorded in the Configuration Management Database (CMDB) per **Policy 3.08** (Service Configuration Management (CMDB) Policy) as distinct configuration items, referencing the lease or contract identifier to support lifecycle control and decommission verification.
- **Return Sanitization**: Prior to return to the vendor, devices shall undergo data sanitization appropriate to stored data and media in accordance with **Policy 2.12** (Media Protection and Sanitization Policy).

6.5 Contractor Equipment and Support Model

- **Default Requirement**: Contractors shall provide their own equipment unless an exception is approved in writing by the IT Director in accordance with **Policy 5.01**.
- **Contractor-Owned Device Support**: Information Operations Personnel shall not troubleshoot, configure, or install software on contractor-owned devices.
  - **Clarification**: The Information Operations Department may provide County-approved secure access software (e.g., VPN clients, MFA agents) as artifacts to the contractor, may provide written configuration guidance, and shall configure County-side network routing and infrastructure necessary to enable authorized connections. Hands-on work on the contractor-owned device remains prohibited.
- **Network Admission Enforcement**: The IT Director shall deny network connectivity to contractor devices that do not meet County security requirements. Exceptions to this prohibition shall be documented and approved in accordance with **Policy 5.01**.

6.6 System and Network Access Control

- **Least Privilege**: Third-party access shall be explicitly authorized, limited to the least privilege required, and time-bounded with a defined termination date specified at the time of authorization.
- **Named Accounts Only**: Generic or shared vendor accounts are prohibited. Each vendor user shall be provisioned a unique named account in accordance with **Policy 2.05** (Identification and Authentication Policy).
- **Remote Access**: Vendors shall use County-approved secure remote access in accordance with **Policy 2.14** (Mobile Device and Remote Access Policy), which at minimum includes VPN with multi-factor authentication (MFA).
- **Persistent Tunnels Prohibited**: Persistent, unmonitored vendor remote-access tunnels are prohibited. Exceptions shall be documented and approved in accordance with **Policy 5.01**.
- **Access Provisioning**: Vendor access shall be provisioned in accordance with **Policy 2.04** (Access Control Policy).
- **Logging and Monitoring**: The IT Director shall ensure vendor activity is logged and monitored in accordance with **Policy 2.11** (Audit Logging and Monitoring Policy).

6.7 Data Sovereignty and Protection

- **Non-CJI Data Residency**: County data (excluding CJI) stored or processed by third-party cloud providers shall reside within the continental United States unless an exception is approved per **Policy 5.01**.
- **CJI Sovereignty**: CJI shall be handled in accordance with the CJI data sovereignty provisions in **Policy 1.11**.
- **Data Ownership**: County data remains the property of Elko County. Vendors acquire no rights to County data beyond contractually authorized use.

6.8 Termination and Offboarding

- **Revocation Notification**: The Department Head of the Requesting Department shall notify the Information Operations Department of contract termination or project completion within twenty-four (24) hours of the event.
- **Revocation Execution**: Upon notification, the IT Director or designee shall disable vendor logical access in accordance with **Policy 2.04**.
- **Asset Reclamation**: The Department Head of the Requesting Department shall ensure County-issued assets are returned within three (3) business days of termination or completion.
- **Data Return and Destruction**: The IT Director shall ensure vendor contracts include a clause requiring certified return or secure destruction of County data in accordance with **Policy 2.12** (Media Protection and Sanitization Policy).

6.9 Unauthorized Commitments

Technology or vendor engagements initiated without documented Technical Approval from the IT Director, or from a technical approver formally delegated under **Policy 1.08** (Delegation of Authority and Decision Rights), constitute unauthorized commitments and shall be governed as follows.

- **Integration Refusal**: The Information Operations Department shall not integrate, onboard, or support technology or vendor services acquired without documented Technical Approval per **Policy 1.10** (IT Financial Management and Procurement Policy).
- **Payment Refusal**: The Office of Fiscal Affairs shall not process payment for technology purchases or subscriptions without documented Technical Approval per **Policy 1.10**.
- **Remediation Funding**: The Requesting Department shall fund remediation, replacement, and incident-response costs resulting from unauthorized technology or vendor commitments.

6.10 Vendor Records Retention

The IT Director shall ensure vendor records are retained in the County-designated contract repository, with a corresponding entry in the System of Engagement linking each record to the applicable vendor engagement.

- **Contract-Class Records**: Executed vendor contracts, CJIS Security Addenda, CJIS Security Addendum Certifications, and Information Exchange Agreements shall be retained for six (6) fiscal years from termination or completion of the contract in accordance with NRS 239.125, NAC 239.155, and LRDA 20070474 (Contracts and Agreements).
- **Vendor-File-Class Records**: Vendor risk assessments, security questionnaires, independent attestations, fingerprint-based record check documentation, and vendor performance evidence shall be retained for three (3) fiscal years from the fiscal year to which they pertain in accordance with NRS 239.125, NAC 239.155, and LRDA 20070378 (Vendor Files).

- **Retrievability**: The IT Director shall ensure that executed contracts, addenda, and Information Exchange Agreements are retrievable within one (1) business day of request, consistent with the retrieval standard in **Policy 1.14**.
- **Legal Hold**: Retention schedules shall be suspended on any record subject to a legal hold. Records shall not be destroyed while a legal hold is in effect.

1.14 Stakeholder Engagement and Communications Policy

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy governs internal and external communications conducted by the Elko County Information Operations Department, including formal and informal communication boundaries, stakeholder engagement, and incident-adjacent reporting obligations.

2. Scope

This policy applies to all Information Operations personnel, including full-time employees, part-time staff, contractors, vendors, and volunteers, and governs communications with County leadership, elected and appointed officials, department heads, third-party vendors and contractors, regulatory bodies, and the public.

- **Out of Scope**:
  - Day-to-day service request, fulfillment, and end-user communication standards: **Policy 3.03**.
  - Active cybersecurity incident communications, CJIS Security Policy Section IR-6 Part (b) execution, NRS 603A.220 breach notification mechanics, legal review routing during incidents, and the Incident Response Contact Directory: **Policy 4.06**.
  - CJIS Security Policy Section IR-6 Part (a) one (1) hour internal reporting clock and incident declaration: **Policy 4.02**.
  - Critical Incident stakeholder reporting: **Policy 3.06**.
  - Root cause investigation and Problem Management: **Policy 3.07**.
  - Data classification, handling, and transmission requirements: **Policy 1.11**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the primary strategic spokesperson for the Information Operations Department.
  - Shall retain final approval authority for communications that establish County commitments, risk posture, or policy direction.
  - Shall provide the Monthly Executive Report and Monthly Briefing to the County Manager in accordance with Section 6.2.
  - Shall approve exceptions to this policy in accordance with the exception framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment), within delegated authority under **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall retain LASO accountability for CJIS Security Policy Section IR-6 Part (b) external notification obligations, as designated under **Policy 1.11** (Data Governance and Classification Policy) and executed through **Policy 4.06** (Communication Protocols and Partner Integration).
  - Shall, in LASO capacity, approve in writing any exception to a communication or transmission requirement that affects Criminal Justice Information (CJI), in coordination with the CJIS Systems Agency (CSA), CJIS Systems Officer (CSO), or other governing authority required by applicable CJIS agreements.

- **County Manager:**
  - Shall receive the Monthly Executive Report and Monthly Briefing from the IT Director in accordance with Section 6.2.
- **Assistant IT Director:**
  - Shall manage operational communication standards across the Department.
  - Shall issue scheduled maintenance notifications and unplanned outage notifications in accordance with Section 6.3.
- **All Information Operations Personnel:**
  - Shall adhere to the formal versus informal communication boundaries established in Section 6.1.
  - Shall document material stakeholder communications in accordance with the documentation standard established in **Policy 5.01**.
  - Shall comply with the One Voice Rule established in Section 6.4 during cybersecurity incidents and infrastructure crises.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in internal or external stakeholder communications.

- **Assessment**: Adherence to communication documentation, channel compliance, and notification requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to document material communications, failure to use required channels, failure to comply with the Written Confirmation Rule, or failure to meet emergency or stakeholder notification timelines, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception framework established in **Policy 5.01**, within the delegation constraints of **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. No exception shall suspend or modify CJIS Security Policy Section IR-6 reporting obligations, NRS 603A.220 breach notification obligations, or mandatory security controls. Governance exceptions affecting decision rights, chain of command, or County commitments shall be processed in accordance with **Policy 1.08** §4. Exceptions affecting the handling, transmission, or access of Criminal Justice Information (CJI) shall additionally require the IT Director, in LASO capacity, to evaluate CJIS compliance implications and coordinate with the CJIS Systems Agency (CSA), CJIS Systems Officer (CSO), or other governing authority as required by applicable CJIS agreements and **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 3.03: Service Communications Policy

- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- NAC 239.155 (Adoption of Records Retention Schedule)
- CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: CA-3 (Information Exchange)

Framework Alignment:

- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: PM-15 (Contacts with Security Groups)
- COBIT 2019: APO08 (Manage Relationships)
- COBIT 2019: EDM05 (Ensure Stakeholder Engagement)
- ITIL v4: Relationship Management Practice

6. Policy Statement

This policy is the governance-level root for all Information Operations communications. It establishes the formal versus informal communication boundary, the strategic reporting cadence to County leadership, the operational notification standards for service availability, the One Voice Rule that governs incident communications, and the Information Exchange Agreement framework that operationalizes CJIS Security Policy Section 5.1 (Information Exchange Agreements) and NIST SP 800-53 Rev. 5: CA-3 (Information Exchange). Day-to-day service communications are governed by **Policy 3.03** (Service Communications Policy); active cybersecurity incident communications are governed by **Policy 4.06** (Communication Protocols and Partner Integration). Both policies incorporate the governance framework established in this policy.

6.1 Formal vs. Informal Communications

To ensure accountability, Information Operations shall distinguish strictly between binding and non-binding communications.

- **Formal Communications (Binding)**: Written or recorded communications that create an official record, authorize work, direct action, commit funds, establish scope, or signify a decision. Examples include emails, memoranda, work orders, approved meeting minutes, status reports, and presentations.

- **Informal Communications (Non-Binding)**: Verbal conversations, hallway discussions, non-recorded phone calls, text messages (SMS), and transient instant-messaging exchanges (including chat platforms, direct messages, and ephemeral channels). Informal communications shall not authorize work, financial commitments, security-impacting changes, or policy deviations. Directives received through text messages or instant-messaging channels shall be treated as verbal communications for purposes of the Written Confirmation Rule and shall be subject to the same written confirmation, presumption, escalation, and liability provisions established in this section.
- **Lawful Supervisory Direction**: All Information Operations Personnel shall comply with lawful verbal direction from their chain of command and shall pursue written confirmation under the Written Confirmation Rule.
- **Written Confirmation Rule**: Verbal communications involving directives, financial commitments, procurement direction, scope changes, or architectural decisions shall be reduced to writing by the end of the business day on which the verbal communication occurred. When the verbal communication occurs within the final two (2) hours of the business day, written confirmation shall be completed no later than 10:00 AM on the following business day. All other verbal communications requiring a record shall be reduced to writing within one (1) business day.
- **Presumption**: Verbal directives not reduced to writing within the applicable Written Confirmation Rule window are presumptively void, and the underlying communication shall be treated as non-binding.
- **Escalation**: When the issuing authority fails to provide written confirmation within the applicable window, the receiving personnel shall escalate the matter through the chain of command in accordance with **Policy 1.08**.
- **Liability**: All Information Operations Personnel shall not execute financial, procurement, or scope-changing directives that have not been reduced to writing within the applicable Written Confirmation Rule window. Action taken outside this control shall constitute non-compliance and may result in corrective action under **Policy 5.01**.

6.2 Strategic Reporting Cadence

The IT Director shall maintain a predictable reporting rhythm to ensure leadership visibility and alignment with County Management.

- **Monthly Executive Report**: The IT Director shall provide a formal written report to the County Manager each month covering project status, service performance, budget variance, and emerging risks.
- **Monthly Briefing**: The IT Director shall conduct a live status briefing with the County Manager each month to review the Monthly Executive Report and align priorities.

6.3 Operational Communication Standards

Information Operations shall maintain a "No Surprise" standard regarding service availability.

- **Scheduled Maintenance**: The Assistant IT Director shall issue scheduled maintenance notifications no less than forty-eight (48) hours in advance of the maintenance window. When forty-eight (48) hours advance notice is not operationally achievable, the Assistant IT Director shall issue notice immediately upon scheduling and shall document the justification in the work order.
- **Unplanned Outages**: The Assistant IT Director or designated Information Operations Personnel shall issue an initial stakeholder notification within fifteen (15) minutes of confirming a widespread outage. For purposes of this section, a widespread outage is a service interruption that meets any of the following criteria: affects two (2) or more County departments; impairs a core enterprise service (including email, telephony, network connectivity, directory services, or financial and enterprise resource planning systems); or affects a life-safety or public-safety system.

6.4 Incident, Media, and Public Communications

This policy establishes the One Voice Rule for incident communications. The execution of incident communications during active cybersecurity incident response is governed by **Policy 4.06**, which incorporates the One Voice Rule established here and operationalizes CJIS Security Policy Section IR-6 Part (b) external notifications, NRS 603A.220 breach notification mechanics, and legal review routing.

- **One Voice Rule**: The IT Director, or the designated Incident Commander, shall serve as the sole authoritative source for strategic and public-facing messaging during a cybersecurity incident or infrastructure crisis. No Information Operations Personnel shall speculate in writing or verbally on incident cause, attribution, or scope until authorized by the IT Director or the Incident Commander.
- **Technical Coordination Carve-Out**: The One Voice Rule shall not prohibit technical staff from communicating operational details to vendors, service providers, or partners when necessary to resolve an incident, provided that such communications are limited to technical scope and comply with the data handling requirements established in **Policy 1.11**. The operational guardrails for technical coordination during active incident response are defined in **Policy 4.06**.
- **Media and Public Authorization (All Contexts)**: Communications with the public or with media outlets shall occur only when expressly authorized by the IT Director, the County Manager, or another designated County authority. During active cybersecurity incident response, **Policy 4.06** governs the execution of media and public communications and supersedes this bullet. Responses to public records requests made under NRS 239 shall be routed through the County's legal review and records process.
- **Emergency Communications**: Emergency communications necessary to protect life, safety, or critical infrastructure may occur outside standard protocols. The originating personnel shall document the emergency communication in the designated System of Engagement within twenty-four (24) hours of the communication.

6.5 Information Exchange Agreements

Information Exchange Agreements (IEAs) are the governance instruments through which the County authorizes, documents, and constrains the exchange of Criminal Justice Information (CJI) and other restricted data with external parties. This policy establishes the County standard for IEA content, custody, and retrievability, consistent with CJIS Security Policy v6.0: Section 5.1 (Information Exchange Agreements) and NIST SP 800-53 Rev. 5: CA-3 (Information Exchange).

- **Requirement**: Any arrangement that enables external access to, transmission of, or exchange of CJI shall be supported by a written Information Exchange Agreement or equivalent contract language.
- **Required Agreement Content**: Information exchange documentation shall define each of the following:
  - Interface characteristics.
  - Security controls implemented at each connection point.
  - Authorized data elements.
  - Restrictions on connections.
  - Terms and termination conditions.
- **Custody and Retrieval**: The IT Director shall ensure that executed Information Exchange Agreements are stored in the County's designated contract repository with version control, and that any executed Information Exchange Agreement is retrievable within one (1) business day upon request.

6.6 Public Records Awareness

All Information Operations Personnel shall compose formal communications with the awareness that such records may be subject to disclosure under NRS 239 (Public Records), unless protected by a specific statutory exemption or confidentiality requirement. The Department's documentation discipline, governed by **Policy 5.01**, shall be exercised with this awareness in mind.

Records generated under this policy shall be classified, retained, and disposed of in accordance with **Policy 1.11**, NRS 239.125 (Local Government Records Management Program), NAC 239.155 (Adoption of Records Retention Schedule), and the applicable Nevada Local Government Records Retention Schedule series. Retention and disposition shall be suspended during litigation holds, audit holds, and public records preservation requirements.

6.7 Contractor and Vendor Communication Obligations

Contractors and vendors are subject to communication and documentation obligations established by this policy as a condition of access to County information systems. Contractors and vendors are not County employees, and the obligations imposed under this policy do not modify their independent contractor status.

- **Acknowledgment**: Contractors and vendors shall acknowledge the applicable provisions of this policy as a condition of access provisioning, in coordination with the acceptable use acknowledgment process established in **Policy 2.01** (Acceptable Use of Information Technology Resources Policy).
- **Communication Discipline**: Contractors and vendors shall comply with the formal versus informal communication boundaries established in Section 6.1 and shall not act on verbal directives without written confirmation under the Written Confirmation Rule.
- **Boundary**: The IT Director shall coordinate contractor and vendor communication obligations through the contract administrator and shall not direct or supervise contractor personnel as County employees.

2. Information Security

2.01 Acceptable Use of Information Technology Resources Policy

Effective: April 29, 2026 Version: 2.6

1. Purpose

This policy establishes mandatory rules of behavior governing the acceptable use of Elko County Information Technology (IT) resources.

2. Scope

This policy applies to all users granted access to County IT resources, including employees, elected officials, contractors, vendors, interns, and volunteers. County IT resources include County-owned, County-managed, and County-provisioned systems and services, including endpoints, networks, applications, cloud services, accounts, and County data.

- **In Scope**:
  - User rules of behavior governing the use of County IT resources.
  - User-facing prohibitions on unauthorized activity.
  - User acknowledgment requirements as a prerequisite to access.
  - User reporting obligations for security incidents and lost or stolen County IT resources.
- **Out of Scope**:
  - Access provisioning, authorization, and system use notification banner content: **Policy 2.04**.
  - Security awareness training delivery and workforce training obligations: **Policy 2.03**.
  - Privacy controls, Personally Identifiable Information (PII) handling, and data subject rights: **Policy 2.06**.
  - Mobile device and remote access specific controls: **Policy 2.14**.
  - Incident response procedures following intake: **Policy 4.02**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the final authority on acceptable-use determinations under this policy.
  - Shall, as Local Agency Security Officer (LASO) per **Policy 1.11** (Data Governance and Classification Policy), execute CJIS-specific notification obligations that attach to acceptable-use violations involving Criminal Justice Information (CJI).
  - Shall suspend privileged access upon discovery of any lapse in the prerequisites defined in Section 6.7 of this policy, consistent with **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
- **Assistant IT Director:**
  - Shall approve operational exceptions to this policy within the criteria and notification requirements defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
  - Shall coordinate the annual acknowledgment refresh cycle defined in Section 6.6 of this policy.

  - Shall serve as the authoritative custodian of executed acknowledgments, retaining them in accordance with LRDA 20071725 (IT Employee Access Control and Security Awareness Files) for a minimum of three (3) calendar years from the end of the calendar year in which the acknowledgment was modified or the user's access rights were terminated.
  - Shall maintain system-level evidence of acknowledgment completion sufficient for access-control determinations and audit.
  - Shall execute disposition of acknowledgment records upon expiration of the applicable retention period in accordance with the disposition instructions established in the referenced schedule.
  - Shall maintain the text of the Acceptable Use Policy Acknowledgment in the System of Engagement in alignment with this policy.
- **Human Resources:**
  - Shall verify that users have executed the Acceptable Use Policy Acknowledgment prior to access provisioning as part of the onboarding process.
  - Shall notify Information Operations of user separations and status changes that affect acknowledgment retention obligations or trigger access revocation.
- **Department Heads:**
  - Shall ensure all personnel under their supervision execute the required acknowledgment prior to being granted access to County IT resources.
  - Shall notify Information Operations immediately upon becoming aware of lost, stolen, or compromised County IT resources assigned to personnel under their supervision.
- **All Information Operations Personnel:**
  - Shall intake user-reported incidents and lost asset reports under this policy through the mechanisms defined in **Policy 4.02** (Identification and Reporting Procedures).
- **All Users of County IT Resources:**
  - Shall comply with this policy as a condition of access to County IT resources.
  - Shall protect County IT resources from unauthorized access, loss, or misuse.
  - Shall execute the Acceptable Use Policy Acknowledgment prior to initial access and upon each annual refresh.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all users of County IT resources.

- **Assessment**: Adherence to this policy shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and the acknowledgment-completion tracking maintained by Human Resources and Information Operations.
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Universal Applicability**: The standards defined in this policy apply to the use of County IT resources at all times and in all locations, including County facilities, remote work locations, and during official travel.
- **Exceptions**: Exceptions to this policy shall be requested, documented, approved, and retained in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.14: Mobile Device and Remote Access Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- LRDA 20071725 (IT Employee Access Control and Security Awareness Files)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: AC-8 (System Use Notification)

Framework Alignment:

- CJIS Security Policy v6.0: Section CM-11 (User-Installed Software)
- CJIS Security Policy v6.0: Section PL-4 (Rules of Behavior)
- CJIS Security Policy v6.0: Section PS-6 (Access Agreements)
- NIST CSF 2.0: GV.PO-01 (Policy for managing cybersecurity risks is established, communicated, and enforced)
- NIST CSF 2.0: GV.RR-04 (Cybersecurity is included in human resources practices)
- NIST SP 800-53 Rev. 5: CM-11 (User-Installed Software)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PS-6 (Access Agreements)
- COBIT 2019: APO01.02 (Manage ethical and professional behavior)

6. Policy Statement

6.1 Ownership and Consent to Monitoring

- **County Property**: All County IT resources, including hardware, software, and data created, stored, or transmitted upon them, are the sole property of Elko County regardless of physical location or funding source, as defined and classified under **Policy 1.12** (IT Asset Management Policy).
- **No Expectation of Privacy**: Users shall have no expectation of privacy in County IT resources.
- **Consent to Monitoring**: Use of County IT resources constitutes consent to monitoring, logging, and disclosure for operational, security, legal, and investigative purposes.
- **System Use Notification**: The system use notification banner implementing NIST SP 800-53 Rev. 5 AC-8 shall be displayed on County systems as specified in **Policy 2.04** (Access Control Policy) to provide continuous notice of monitoring and consent.

6.2 Identity and Credentials

- **Credential Protection**: Users shall not share passwords, tokens, or access badges.
- **Account Sharing**: Users shall not use another user's account or allow another person to use their account.
- **Workstation Security**: Users shall lock their workstation or device whenever it is left unattended.

6.3 Acceptable Use Standards

- **Official Use**: County IT resources are provided to support the official business of Elko County.
- **Incidental Personal Use**: Users may engage in limited personal use of County IT resources only during break and lunch periods, provided such use complies with the prohibitions defined in Section 6.4 of this policy, incurs no cost to the County, and does not delay or prevent the completion of assigned tasks.

6.4 Prohibited Activities

- **Unauthorized Software**: Users shall not install unauthorized software on County IT resources.
- **Security Control Bypass**: Users shall not disable, circumvent, or tamper with security controls, including but not limited to endpoint protection software, firewalls, and logging mechanisms.
- **Network Filter Evasion**: Users shall not use anonymization tools, proxies, or any other mechanism to bypass County network filters or monitoring.
- **External AI Data Exposure**: Users shall not input Confidential or Restricted County data, as classified under **Policy 1.11** (Data Governance and Classification Policy), into any Generative Artificial Intelligence (GenAI) system or Large Language Model (LLM) that is not a County-managed service.
- **Political and Commercial Use**: Users shall not use County IT resources for political campaigning, lobbying, or personal commercial ventures.
- **Prohibited Content**: Users shall not access, store, or distribute harassing, discriminatory, or sexually explicit content using County IT resources.

6.5 Reporting Requirements

- **Security Incidents**: Users shall report suspected security incidents to Information Operations immediately upon discovery, and no later than one (1) hour after discovery. Intake handling is governed by **Policy 4.02**.
- **Lost or Stolen CJI-Capable Devices**: Users shall report any device capable of accessing Criminal Justice Information (CJI) that is lost, stolen, or otherwise unaccounted for to Information Operations no later than one (1) hour after discovery. This window supports the CJIS Security Policy v6.0 Section IR-6 Part (a) internal reporting clock operationalized in **Policy 4.02**.
- **Lost or Stolen General Assets**: Users shall report all other lost or stolen County IT resources to Information Operations no later than the end of the next business day after discovery. Losses of resources known or suspected to contain Confidential or Restricted County data shall be reported under the Security Incidents provision above.
- **Exclusion**: Routine violations of this policy that do not involve a suspected security incident or Indicator of Compromise as defined in **Policy 4.02** shall be handled through the enforcement pathway established in Section 4 of this policy, and shall not be routed as Chapter 4 incidents solely on the basis of policy non-compliance.

6.6 Acknowledgment Requirement

- **Prerequisite**: Users shall execute the Acceptable Use Policy Acknowledgment, maintained in the System of Engagement, prior to being granted access to County IT resources.
- **Annual Refresh**: Users shall re-execute the acknowledgment within three hundred sixty-five (365) calendar days of the previous execution and upon any revision to this policy that alters user obligations under Section 6.
- **Refusal**: Upon refusal by a user to execute the acknowledgment, Information Operations shall immediately deny or revoke the user's access to all County IT resources.
- **Retention**: Executed acknowledgments shall be retained by Information Operations in accordance with LRDA 20071725 (IT Employee Access Control and Security Awareness Files).

6.7 Additional Requirements for Privileged Users

- **Privileged Account Use**: Users assigned to Tier L3 (Administrator) or above, as defined in **Policy 1.07**, shall use privileged accounts only for tasks requiring elevated access.
- **Standard Account Use**: Privileged users shall perform routine activities using standard (non-privileged) accounts.
- **Prerequisites**: Privileged users shall maintain the background screening and role-based training requirements specified in **Policy 1.07** and **Policy 2.03** (Security Awareness and Training Policy).
- **Suspension on Lapse**: The IT Director shall suspend privileged access upon discovery of any lapse in the prerequisites defined in this section, consistent with **Policy 1.07**.

2.02 Personnel Security and Background Screening Policy

Effective: April 29, 2026 Version: 2.8

1. Purpose

This policy establishes mandatory personnel security and background screening requirements for individuals granted logical or physical access to Elko County information systems, facilities containing IT assets, or County data.

2. Scope

This policy applies to all employees, elected officials, contractors, vendors, interns, and volunteers requiring logical or physical access to County IT resources.

- **In Scope**:
  - Personnel screening and background investigation requirements.
  - Criminal Justice Information (CJI) adjudication standards.
  - Access gating and provisioning prerequisites.
  - Continued access review upon self-reported arrest, charge, or restraining order.
  - Access revocation and modification timelines upon personnel action.
  - Exit requirements and asset recovery coordination.
- **Out of Scope**:
  - Access provisioning mechanics and identity lifecycle: **Policy 2.04** (Access Control Policy).
  - CJI classification and handling: **Policy 1.11** (Data Governance and Classification Policy).
  - Vendor and contractor onboarding and governance: **Policy 1.13** (Supply Chain Risk Management and Vendor Governance).
  - IT asset recovery at separation: **Policy 1.12** (IT Asset Management Policy).
  - Facility access credentials (badges, keys, entry fobs): **Policy 2.13** (Physical Security and Environmental Controls Policy).

3. Roles and Responsibilities

- **County Manager:**
  - Shall approve formal exceptions to this policy that exceed the IT Director's delegated authority under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **IT Director:**
  - Shall define the positions within Information Operations that require Privileged or CJI Access screening.
  - Shall serve as the final gatekeeper for access provisioning.
  - Shall not authorize access to County IT resources until Human Resources confirms screening adjudication status is "Cleared" for the applicable classification.

  - Shall coordinate, acting as Local Agency Security Officer (LASO), CJI adjudication activities with the CJIS Systems Agency (CSA) and CJIS Systems Officer (CSO) in accordance with **Policy 1.11** (Data Governance and Classification Policy) and Criminal Justice Information Services (CJIS) Security Policy v6.0: PS-3 (Personnel Screening).
  - Shall notify the CSO, acting as LASO, of any suspected violation of CJIS Security Policy and any denial of CJI access, consistent with the LASO duties established in **Policy 1.11**.
- **Assistant IT Director:**
  - Shall document and maintain records of day-to-day access-gating decisions, screening status verifications, and exit processing workflows between Human Resources and Information Operations.
- **Department Heads:**
  - Shall identify positions within their departments that require enhanced or CJI Access screening prior to recruitment.
  - Shall not permit third-party personnel to begin work until screening adjudication is complete per **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance) and CJIS Security Policy v6.0 PS-7 (External Personnel Security), and access is formally approved by the IT Director.
- **Human Resources:**
  - Shall serve as the authoritative originator of personnel status actions (hire, transfer, termination).
  - Shall notify Information Operations of personnel changes in accordance with the timelines defined in **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall coordinate the submission of state-of-residency and national fingerprint-based record checks through an FBI-approved authority for personnel requiring CJI Access, consistent with CJIS Security Policy v6.0 PS-3.
  - Shall handle Criminal History Record Information (CHRI) returned from screening checks in accordance with NRS 179A (Records of Criminal History).
  - Shall retain personnel screening documentation for County employees and appointed personnel in the Master Personnel File for a minimum of ten (10) calendar years from the end of the calendar year in which the individual separated from service, per NRS 239.125, NAC 239.155, and LRDA 20070321.
  - Shall notify the IT Director of any court or law-enforcement action reported under Section 3 that may affect an individual's fitness for continued access to County IT resources or involvement in CJI Access.
- **All County Personnel:**
  - Shall truthfully disclose legal history during screening.
  - Shall report to Human Resources any court or law-enforcement action that may affect their fitness for continued access to County IT resources, workplace safety, or continued status as a trusted representative of the County, within twenty-four (24) hours of the action.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals granted logical or physical access to County information systems, facilities containing IT assets, or County data.

- **Assessment**: Compliance with screening, adjudication, and access-gating requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the security control assessment process defined in **Policy 5.05** (Security

Control Assessment and Authorization). CJI screening and adjudication records shall additionally be assessed as part of the CJIS triennial audit conducted by the CSA.

- **Enforcement**: The IT Director shall enforce this policy. Provisioning actions that bypass screening or adjudication requirements constitute violations subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: Exceptions to CJI Access screening and adjudication requirements are prohibited under CJIS Security Policy v6.0 PS-3 and shall not be approved.
- **Universal Applicability**: These standards apply to all access to County IT resources regardless of location or work arrangement, including remote work and official travel.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.05: Security Control Assessment and Authorization
- NRS 179A (Records of Criminal History)
- NRS 239.125 (Local Government Records Management Program)
- NRS 239B (Disclosure of Personal Information)
- NAC 239.155 (Adoption of Records Retention Schedule)
- LRDA 20070321 (Master Personnel File)
- CJIS Security Policy v6.0: Section AC-2(13) (Disable Accounts for High-Risk Individuals)
- CJIS Security Policy v6.0: Section PS-3 (Personnel Screening)
- CJIS Security Policy v6.0: Section PS-4 (Personnel Termination)
- CJIS Security Policy v6.0: Section PS-5 (Personnel Transfer)
- CJIS Security Policy v6.0: Section PS-7 (External Personnel Security)

Framework Alignment:

- NIST CSF 2.0: GV.RR-04 (Cybersecurity Included in Human Resources Practices)
- NIST CSF 2.0: PR.AA-01 (Identities and Credentials Management)
- NIST CSF 2.0: PR.AA-05 (Access Permissions, Entitlements, and Authorizations)
- NIST SP 800-53 Rev. 5: AC-2 (Account Management)

- NIST SP 800-53 Rev. 5: PS-2 (Position Risk Designation)
- NIST SP 800-53 Rev. 5: PS-3 (Personnel Screening)
- NIST SP 800-53 Rev. 5: PS-4 (Personnel Termination)
- NIST SP 800-53 Rev. 5: PS-5 (Personnel Transfer)
- NIST SP 800-53 Rev. 5: PS-7 (External Personnel Security)
- COBIT 2019: APO07.01 (Maintain Adequate and Appropriate Staffing)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

Personnel security is the County's first defensive layer against insider risk and unauthorized disclosure of sensitive information. This policy implements federal personnel security requirements for Criminal Justice Information (CJI) access while establishing County-wide screening standards for all access to County IT resources. Per **Policy 1.11**, the IT Director holds the Local Agency Security Officer (LASO) designation by policy mandate. This policy cites the IT Director (as LASO) when the CJIS liaison function is specifically invoked.

6.1 Position Risk and Access Classification

- The IT Director shall assign each position an access classification (General, Privileged, or CJI).
- **Access Classification Definitions**:
  - **General**: Standard user access to County IT resources that are not designated as CJI.
  - **Privileged**: Elevated permissions capable of altering system configurations or security controls, corresponding to Role Tiers L3 through L5 as defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
  - **CJI**: Any position with potential unescorted access to unencrypted CJI.

6.2 Screening Requirements

- **No Clearance, No Access**: The IT Director shall not provision access until screening and adjudication are complete for the applicable classification.
- **General Access**: Human Resources shall complete County-required identity verification and background screening prior to the IT Director provisioning access.
- **CJI Access**: Human Resources shall coordinate the submission of state-of-residency and national fingerprint-based record checks through an FBI-approved authority prior to the IT Director provisioning access. Final adjudication of CJI Access eligibility shall follow CJIS Security Policy v6.0 PS-3 as applied in Section 6.3.
  - **Constraint**: "Pending" or temporary access to CJI environments is prohibited.

6.3 CJI Adjudication Standards

- **Felony Convictions**: If a felony conviction of any kind exists, the IT Director shall deny CJI access. The requesting agency may request a review by the CSO in extenuating circumstances where the severity of the offense and the time that has passed would support a possible variance, per CJIS Security Policy v6.0 PS-3(a)(3)(a).
- **Misdemeanors**: Where the CSO has formally delegated misdemeanor adjudication authority to the IT Director per CJIS Security Policy v6.0 PS-3(a)(3)(b), the IT Director may grant CJI access if the

offense does not meet the disqualification criteria established by the CSO. Absent formal written delegation, the IT Director shall refer the matter to the CSO for determination.

- **Fugitive Status or Unresolved Arrest**: The IT Director shall deny CJI access to any individual with an active warrant. For individuals with an arrest history without conviction, where the CSO has formally delegated review authority to the IT Director per CJIS Security Policy v6.0 PS-3(a)(4), the IT Director may grant or continue access based on the review outcome. Absent formal written delegation, the IT Director shall refer the matter to the CSO for determination.
- **Authorized CJI Access List**:
  - The IT Director shall maintain a current record of all personnel authorized for unescorted access to unencrypted CJI, per CJIS Security Policy v6.0 PS-3(a)(7).
  - The IT Director shall provide the record to the CSO or the CSO's designee upon request.
- **CSO Notification**: The IT Director (as LASO) shall notify the CSO in writing of any denial of CJI access, any suspected violation of CJIS Security Policy, and any continued-access determination arising under Section 6.4.

6.4 Continued Access Review

- **Notification Trigger**: Upon receipt from Human Resources of a notification of a court or law-enforcement action that may affect an individual's fitness for continued CJI access, the IT Director shall review continued CJI access in accordance with CJIS Security Policy v6.0 PS-3(a)(5).
- **Self-Reporting Non-Compliance**: The IT Director shall suspend access within thirty (30) minutes of determining that an individual failed to self-report a court or law-enforcement action within the twenty-four (24) hour window established in Section 3. For CJI Access, final access determination shall follow the adjudication process defined in Section 6.3.

6.5 Transfers and Termination

Upon receipt of personnel-change notification — from Human Resources per **Policy 1.08** for County personnel, or from vendors per **Policy 1.13** for contractor and vendor personnel holding County credentials — the IT Director shall revoke or adjust access in accordance with the following timelines.

- **High-Risk Individuals**: The IT Director shall disable accounts within thirty (30) minutes of notification, consistent with CJIS Security Policy v6.0 AC-2(13) (Disable Accounts for High-Risk Individuals).
- **Involuntary Termination**: The IT Director shall disable accounts within thirty (30) minutes of notification.
- **Standard Termination**: The IT Director shall disable accounts within twenty-four (24) hours of notification, consistent with CJIS Security Policy v6.0 PS-4 (Personnel Termination).
- **Transfers**: The IT Director shall modify access authorizations within twenty-four (24) hours of notification to conform with the Least Privilege and Need-to-Know principles defined in **Policy 2.04**, consistent with CJIS Security Policy v6.0 PS-5 (Personnel Transfer).

6.6 Exit Requirements

- **Exit Interview — County Employees and Appointed Personnel**: Human Resources shall conduct an exit interview covering non-disclosure obligations for Criminal Justice Information (CJI) and Personally Identifiable Information (PII) under NRS 239B for every separating County employee or appointed official who held logical or physical access to County IT resources.
  - **Exception**: Where the separating individual is unavailable (e.g., job abandonment, sudden incapacitation, or refusal to participate), Human Resources shall execute alternate separation han-

dling consisting of documented reason for the missed interview and a written non-disclosure reminder delivered to the individual's last known address.

  - **Constraint**: Credential recovery and asset recovery obligations under this section shall remain in force regardless of whether an exit interview is conducted.

- **Separation Processing — Contractors and Vendors**: Separation processing for contractors and vendors who held County IT access shall follow the vendor offboarding requirements in **Policy 1.13**.
- **Separation Processing — Interns, Volunteers, and Elected Officials**: The sponsoring department or appointing authority shall conduct equivalent separation processing, including non-disclosure reminder for CJI and PII where applicable, for separating interns, volunteers, and outgoing elected officials who held logical or physical access to County IT resources.
- **IT Asset Recovery**: Information Operations shall recover County-issued IT assets (tokens, endpoint devices, mobile equipment) prior to final departure per **Policy 1.12**.
- **Facility Asset Recovery**: Facility access credentials (badges, keys, entry fobs) shall be recovered by the issuing department in accordance with **Policy 2.13**.

6.7 High-Risk Individual Definition

The following conditions qualify an individual as a High-Risk Individual for purposes of Section 6.5:

- The individual has been involuntarily or hostilely terminated from County employment or service.
- The individual has been identified by Human Resources, the IT Director, the County Manager, or the District Attorney's Office as posing a credible threat of misuse or retaliation.
- The individual has received formal written notice of investigation from law enforcement, the District Attorney's Office, or a federal agency.
- The individual has been identified by the IT Director (as LASO) or the CSO as a direct threat to CJI confidentiality or integrity.

2.03 Security Awareness and Training Policy

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy establishes the mandatory security awareness and role-based training requirements for all personnel granted access to Elko County information technology resources.

2. Scope

This policy applies to all County personnel and authorized non-employees, including employees, elected officials, appointed officials, contractors, vendors, interns, volunteers, and service providers, who are granted logical access to County information technology resources, who process or handle County data, or who possess unescorted physical access to areas designated as physically secure locations.

- **In Scope**:
  - Initial security awareness training prior to receipt of access.
  - Annual refresher training for all personnel with continuing access.
  - Role-based training for privileged users, privacy-data handlers, and physical security personnel.
  - Practical security exercises, including spear-phishing simulations.
  - Retention of training-completion records.
- **Out of Scope**:
  - Personnel screening and background investigation: **Policy 2.02**.
  - Access provisioning and account lifecycle mechanics: **Policy 2.04**.
  - Privacy program administration: **Policy 2.06**.
  - Acceptable use acknowledgment custody: **Policy 2.01**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall approve the security awareness and role-based training curriculum design.
  - Shall review the training curriculum at a minimum cadence of one (1) calendar year and update content to maintain alignment with applicable federal, state, and Manual requirements.
  - Shall maintain this policy and its implementing procedures consistent with CJIS Security Policy v6.0: Section AT-1 (Policy and Procedures).
- **Assistant IT Director:**
  - Shall develop and deliver the technical and role-based training content.
  - Shall disseminate emerging threat advisories and security alerts to affected personnel within one (1) business day of identifying a threat materially affecting County users, systems, or data.
- **Human Resources:**
  - Shall schedule and track completion of the general security awareness curriculum for all County personnel.

  - Shall collect training-completion documentation and transmit it to Information Operations for authoritative retention.
  - Shall verify completion of initial security awareness training prior to authorizing onboarding or credentialing of any individual.
  - Shall enforce administrative actions for personnel who fail to meet the annual refresher cadence required by this policy.
- **Department Heads:**
  - Shall ensure that one hundred percent (100%) of personnel and authorized non-employees under their operational authority complete initial and annual training within the cadence required by this policy.
  - Shall notify Information Operations and Human Resources of any subordinate who has not completed required training by the applicable deadline.
- **All County Personnel:**
  - Shall complete all assigned training modules and practical exercises by the deadlines established under this policy.
  - Shall apply training concepts to daily operations and report suspected security anomalies in accordance with **Policy 4.02** (Identification and Reporting Procedures).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all County personnel and authorized non-employees who are granted logical access to County information technology resources, who process or handle County data, or who possess unescorted physical access to areas designated as physically secure locations.

- **Assessment**: Adherence to this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and through the training-completion verification performed during access provisioning and periodic access recertification under **Policy 2.04** (Access Control Policy).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: Initial security awareness training prior to receipt of access to systems that process, store, or transmit Criminal Justice Information (CJI) is non-waivable per CJIS Security Policy v6.0: Section AT-2 (Literacy Training and Awareness). No exception under **Policy 5.01** may waive this requirement.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy

- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- LRDA 20071725 (IT Employee Access Control and Security Awareness Files)
- CJIS Security Policy v6.0: Section AT-1 (Policy and Procedures)
- CJIS Security Policy v6.0: Section AT-2 (Literacy Training and Awareness)
- CJIS Security Policy v6.0: Section AT-3 (Role-Based Training)
- CJIS Security Policy v6.0: Section AT-4 (Training Records)

Framework Alignment:

- NIST CSF 2.0: PR.AT-01 (Awareness and Training)
- NIST CSF 2.0: PR.AT-02 (Role-Based Training)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: AT-4 (Training Records)
- COBIT 2019: APO07.03 (Maintain Skills and Competencies)
- ITIL v4: Workforce and Talent Management Practice

6. Policy Statement

6.1 Program Design and Authority

The IT Director shall design the security awareness and role-based training curriculum. Human Resources shall administer the general security awareness program for County personnel. The Assistant IT Director shall develop and deliver the technical and role-based training content. The training program implements the workforce-competency requirements established in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework) and the data-handling obligations established in **Policy 1.11** (Data Governance and Classification Policy).

6.2 Training Cadence

- **Initial Training**: All County Personnel shall complete initial security awareness training prior to receipt of access. Initial training is paired with the user acknowledgment required under **Policy 2.01** (Acceptable Use of Information Technology Resources Policy). The IT Director shall not authorize provisioning of access under **Policy 2.04** (Access Control Policy) until both initial training completion and acceptable use acknowledgment execution are verified.
- **Annual Refresher**: All County Personnel shall complete annual refresher training at a maximum cadence of twelve (12) calendar months from the date of the most recent completion.
- **Security Event Retraining**: Personnel involved in a security event shall complete remedial training within thirty (30) calendar days of the event, consistent with CJIS Security Policy v6.0: Section AT-2.
- **Account Suspension Trigger**: The Assistant IT Director shall suspend the account of any user who fails to complete the annual refresher within the prescribed cadence, or who fails to complete assigned remedial training within thirty (30) calendar days, in accordance with **Policy 2.04**.

6.3 Literacy Content

The general security awareness curriculum shall address, at minimum, the following topics:

- **Insider Threat**: Recognition of indicators of malicious or accidental insider threat.
- **Social Engineering**: Identification of phishing, vishing, and related deception techniques.
- **Data Handling**: Protection of Criminal Justice Information (CJI), Personally Identifiable Information (PII), and other classified data in accordance with **Policy 1.11**.

6.4 Role-Based Training

Personnel in roles with elevated privileges or specialized data-handling obligations shall complete role-based training in addition to the general literacy program, consistent with CJIS Security Policy v6.0: Section AT-3 (Role-Based Training).

- **Privileged Users**: Personnel holding privileged accounts (Tier L3 and above as defined in **Policy 1.07**) shall complete role-based training addressing administrative responsibilities, privileged credential handling, and audit accountability.
- **Privacy-Data Handlers**: Personnel handling Criminal Justice Information (CJI), Personally Identifiable Information (PII), or Protected Health Information (PHI) shall complete role-based privacy training addressing the obligations defined in **Policy 2.06** (Privacy and Data Protection Policy) and the data classification handling requirements defined in **Policy 1.11**.
- **Physical Access Holders**: Personnel with unescorted access to physically secure locations as defined in **Policy 2.13** (Physical Security and Environmental Controls Policy) shall complete role-based training addressing visitor management, tailgating prevention, physical incident reporting, and protection of Criminal Justice Information (CJI) from unauthorized observation or access.

6.5 Practical Exercises

The Assistant IT Director shall conduct not fewer than two (2) spear-phishing simulations annually. The Assistant IT Director shall assign remedial training within thirty (30) calendar days to personnel who fail a simulation.

6.6 Records Retention

Information Operations shall retain training-completion records and signed acknowledgments in accordance with LRDA 20071725 (IT Employee Access Control and Security Awareness Files) and CJIS Security Policy v6.0: Section AT-4 (Training Records) for a minimum of three (3) calendar years from the end of the calendar year in which the record was modified or the employee's access rights were terminated. Each training record shall identify, at minimum, the individual, the assigned role or access classification, the training title, the completion date, the delivery method, the result, the remediation status where applicable, and the record custodian.

2.04 Access Control Policy

Effective: April 29, 2026 Version: 2.8

1. Purpose

This policy establishes mandatory requirements for managing logical access to Elko County information systems, networks, and data.

2. Scope

This policy applies to all individuals with logical access to Elko County information systems, networks, or data, including employees, elected officials, appointed officials, interns, volunteers, contractors, and third-party vendors.

- **In Scope**:
  - Logical account lifecycle management, including creation, modification, disablement, and removal.
  - Access authorization and enforcement for County information systems.
  - Least privilege and separation of duties enforcement.
  - Remote and wireless access authorization.
  - Session management, device lock, and unsuccessful-logon handling.
  - Periodic access recertification.
- **Out of Scope**:
  - Physical access controls: **Policy 2.13**.
  - Identifier and authenticator mechanics, including password complexity and multi-factor authenticator lifecycle: **Policy 2.05**.
  - Network, boundary, and communications protection: **Policy 2.07**.
  - Secure configuration of systems providing access control: **Policy 2.10**.
  - Audit logging and monitoring of access events: **Policy 2.11**.
  - Personnel screening and background adjudication governing access eligibility: **Policy 2.02**.
  - Mobile device management and teleworking operations: **Policy 2.14**.
  - Exception management: **Policy 5.01**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall hold final authority for logical access decisions affecting County information systems.
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for access decisions involving Criminal Justice Information (CJI).
  - Shall authorize each type of remote access and wireless access prior to permitting connections.

  - Shall approve shared, group, and emergency accounts based on documented operational necessity.
  - Shall review shared, group, and emergency account approvals at least annually.
  - Shall adjudicate access decisions for High-Risk Individuals as defined in **Policy 2.02**.
- **County Manager:**
  - Shall approve access control policy exceptions that exceed the IT Director's delegated authority per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall maintain the account-type registry and the access control matrix required under this policy.
  - Shall operate the periodic access recertification program defined in Section 6.9.
  - Shall ensure that information systems implement the technical access controls required by this policy, including account disablement automation, device lock, session termination, and unsuccessful-logon handling.
  - May approve operational access exceptions within the Operational Exception Tier defined in **Policy 5.01**.
- **Department Heads:**
  - Shall validate the specific need-to-know for personnel under their authority.
  - Shall ensure access requests are commensurate with assigned job duties.
  - Shall complete periodic access recertification reviews for systems under their data ownership within the cadence defined in Section 6.9.
  - Shall notify the IT Director within one (1) business day of identifying access that is no longer justified.
- **Human Resources:**
  - Shall serve as the Authoritative Source for personnel status changes affecting logical access.
  - Shall notify the IT Director of terminations, transfers, and High-Risk Individual determinations in accordance with **Policy 2.02**.
- **All County Personnel:**
  - Shall not share credentials, authentication tokens, or access devices with any other person.
  - Shall not elevate privileges beyond those authorized for their assigned role by any means, direct or indirect.
  - Shall not bypass, disable, or circumvent access control mechanisms.
  - Shall report known or suspected credential compromise to the IT Director within one (1) hour of discovery, consistent with CJIS Security Policy v6.0: Section IR-6(a) (Incident Reporting).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals with logical access to Elko County information systems.

- **Assessment**: Adherence to this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and through the periodic access recertification reviews defined in Section 6.9.

- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: Exceptions affecting access to systems that process, store, or transmit CJI shall route through the CJI Exceptions provisions of **Policy 5.01**, which require written approval of the IT Director (as LASO) and, where applicable, written approval by the CJIS Systems Agency (CSA) or CJIS Systems Officer (CSO).
- **Universal Applicability**: These standards apply to all access to County information systems regardless of location or work arrangement, including remote work and official travel.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.07: System and Communications Protection Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 2.14: Mobile Device and Remote Access Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- CJIS Security Policy v6.0: Section AC-2 (Account Management)
- CJIS Security Policy v6.0: Section AC-2(3) (Disable Accounts)
- CJIS Security Policy v6.0: Section AC-2(13) (Disable Accounts for High-Risk Individuals)
- CJIS Security Policy v6.0: Section AC-3 (Access Enforcement)
- CJIS Security Policy v6.0: Section AC-6 (Least Privilege)
- CJIS Security Policy v6.0: Section AC-6(7) (Review of User Privileges)
- CJIS Security Policy v6.0: Section AC-7 (Unsuccessful Logon Attempts)
- CJIS Security Policy v6.0: Section AC-8 (System Use Notification)
- CJIS Security Policy v6.0: Section AC-11 (Device Lock)
- CJIS Security Policy v6.0: Section AC-12 (Session Termination)
- CJIS Security Policy v6.0: Section AC-17 (Remote Access)
- CJIS Security Policy v6.0: Section AC-18 (Wireless Access)
- CJIS Security Policy v6.0: Section IA-2(1) (Multi-Factor Authentication to Privileged Accounts)

- CJIS Security Policy v6.0: Section IA-2(2) (Multi-Factor Authentication to Non-Privileged Accounts)
- CJIS Security Policy v6.0: Section IA-4 (Identifier Management)
- CJIS Security Policy v6.0: Section IA-11 (Re-Authentication)
- CJIS Security Policy v6.0: Section IR-6(a) (Incident Reporting)
- CJIS Security Policy v6.0: Section PS-4 (Personnel Termination)
- CJIS Security Policy v6.0: Section PS-5 (Personnel Transfer)
- NIST SP 800-53 Rev. 5: AC-2 (Account Management)

Framework Alignment:

- CJIS Security Policy v6.0: Section AC-5 (Separation of Duties)
- NIST CSF 2.0: PR.AA-01 (Identities and Credentials Managed)
- NIST CSF 2.0: PR.AA-03 (Authentication)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST SP 800-53 Rev. 5: AC-1 (Policy and Procedures)
- NIST SP 800-53 Rev. 5: AC-3 (Access Enforcement)
- NIST SP 800-53 Rev. 5: AC-5 (Separation of Duties)
- NIST SP 800-53 Rev. 5: AC-6 (Least Privilege)
- NIST SP 800-53 Rev. 5: AC-6(7) (Review of User Privileges)
- NIST SP 800-53 Rev. 5: AC-7 (Unsuccessful Logon Attempts)
- NIST SP 800-53 Rev. 5: AC-8 (System Use Notification)
- NIST SP 800-53 Rev. 5: AC-11 (Device Lock)
- NIST SP 800-53 Rev. 5: AC-12 (Session Termination)
- NIST SP 800-53 Rev. 5: AC-17 (Remote Access)
- NIST SP 800-53 Rev. 5: AC-18 (Wireless Access)
- NIST SP 800-53 Rev. 5: IA-2 (Identification and Authentication)
- NIST SP 800-53 Rev. 5: IA-4 (Identifier Management)
- NIST SP 800-53 Rev. 5: IA-11 (Re-Authentication)
- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Access Management Practice

6. Policy Statement

This policy implements the principles of least privilege and need-to-know to protect the confidentiality, integrity, and availability of County information. Access control is the primary technical boundary between authorized use and unauthorized disclosure; the directives in this section define the auditable controls that sustain that boundary. This policy is the foundational access-control layer of the Information Operations Policy Manual: identifier and authenticator mechanics build on it under **Policy 2.05**, and mobile and teleworking implementations build on it under **Policy 2.14**.

6.1 Account Management

- The Assistant IT Director shall maintain a registry of account types authorized for use on County information systems. The registry shall include at minimum the following types:
  - Individual.
  - Privileged.
  - Shared or group (restricted).
  - Service.
  - System.
  - Guest (restricted).
  - Temporary.
  - Emergency.
- The Assistant IT Director shall ensure that information systems disable accounts within the following maximum timeframes upon notification of a qualifying trigger, consistent with CJIS Security Policy v6.0: Section AC-2 (Account Management) and Section AC-2(3) (Disable Accounts):
  - **Involuntary Termination**: Within thirty (30) minutes of notification from Human Resources per **Policy 2.02**.
  - **Standard Termination**: Within twenty-four (24) hours of notification from Human Resources per **Policy 2.02**, consistent with CJIS Security Policy v6.0: Section PS-4 (Personnel Termination).
  - **High-Risk Individuals**: Within thirty (30) minutes of notification from Human Resources per **Policy 2.02** for individuals meeting the High-Risk Individual definition in **Policy 2.02**, or within thirty (30) minutes of independent discovery by the IT Director (as LASO), consistent with CJIS Security Policy v6.0: Section AC-2(13) (Disable Accounts for High-Risk Individuals).
  - **Expired or Unauthorized Accounts**: Within seven (7) calendar days of account expiration or discovery that an account is no longer associated with an active user.
  - **Inactivity**: After thirty (30) calendar days of inactivity.
    - **Rationale**: This threshold exceeds the CJIS Security Policy v6.0 Section AC-2(3) minimum of ninety (90) days and is adopted as a stricter Elko County internal control.
- Upon notification of a personnel transfer, the Assistant IT Director shall modify access authorizations within twenty-four (24) hours to conform with the least privilege and need-to-know principles defined in Section 6.3 and the recertification obligations defined in Section 6.9, consistent with **Policy 2.02** and CJIS Security Policy v6.0: Section PS-5 (Personnel Transfer).
  - **Clarification**: Transfer shall not trigger automatic account disablement. The control objective is to align authorizations with the new role, not to terminate the identity.
- The Assistant IT Director shall manage user identifiers such that identifiers are not reused for a minimum of one (1) year following disablement or removal of the previous account, consistent with CJIS Security Policy v6.0: Section IA-4 (Identifier Management).
- All County Personnel shall not use shared or group accounts except where the IT Director has approved a documented operational necessity in writing.
  - The Assistant IT Director shall ensure that the associated authenticator is changed within twenty-four (24) hours whenever shared or group account membership changes.
- The Assistant IT Director shall ensure that temporary and emergency accounts are automatically removed or disabled within seventy-two (72) hours of creation unless a longer duration is approved as an exception under **Policy 5.01**.

6.2 Separation of Duties

Separation of duties requirements applicable to access control are governed under **Policy 1.08** (Delegation of Authority and Decision Rights), including the separation of access approval from access provisioning, the separation of security administration from audit logging, the Separation of Duties Matrix, and the compensating controls pattern for situations where staffing constraints prevent technical separation. This policy does not restate those requirements.

6.3 Least Privilege

- The Assistant IT Director shall ensure that access is restricted to the minimum privileges required for assigned job duties, consistent with CJIS Security Policy v6.0: Section AC-6 (Least Privilege).
- All County Personnel holding privileged accounts shall use such accounts strictly for administrative functions and shall not use them for routine activities such as email or general web browsing.
- The Assistant IT Director shall ensure that information systems prevent non-privileged users from executing privileged functions, including the disablement or circumvention of security safeguards, consistent with CJIS Security Policy v6.0: Section AC-3 (Access Enforcement).

6.4 Unsuccessful Logon Attempts

- The Assistant IT Director shall ensure that information systems enforce a limit of five (5) consecutive invalid logon attempts within a fifteen (15)-minute period, consistent with CJIS Security Policy v6.0: Section AC-7 (Unsuccessful Logon Attempts).
- The Assistant IT Director shall ensure that accounts on systems processing CJI remain locked until released by the IT Director (as LASO) or by administrative personnel acting under the IT Director's direction.
- The Assistant IT Director shall ensure that CJI systems do not perform automatic unlock except where the CJIS Systems Officer (CSO) has approved a documented operational mission need in writing.
- The IT Director (as LASO) shall retain any CSO-approved automatic-unlock authorization for audit.

6.5 System Use Notification

- The Assistant IT Director shall ensure that information systems display a notification banner before granting access, consistent with CJIS Security Policy v6.0: Section AC-8 (System Use Notification). The banner shall state each of the following:
  - Users are accessing a restricted Elko County / FBI CJIS information system.
  - System usage may be monitored, recorded, and subject to audit.
  - Unauthorized use is prohibited and subject to criminal and civil penalties.
  - Use of the system indicates consent to monitoring and recording, and users shall have no expectation of privacy.
- The banner shall remain on screen until the user takes an explicit action to acknowledge the notice.

6.6 Device Lock and Session Management

- The Assistant IT Director shall ensure that information systems automatically initiate a device lock after fifteen (15) minutes of inactivity, consistent with CJIS Security Policy v6.0: Section AC-11 (Device Lock).
  - **Rationale**: This threshold exceeds the CJIS Security Policy v6.0 Section AC-11 (Device Lock) maximum of thirty (30) minutes and is adopted as a stricter Elko County internal control.

- The Assistant IT Director shall ensure that the device lock conceals previously visible information with a pattern-hiding display.
- The Assistant IT Director shall ensure that the device lock remains engaged until the user re-authenticates.
- The Assistant IT Director shall ensure that information systems automatically terminate remote access sessions authenticating via password, or require re-authentication, after twelve (12) hours of duration or fifteen (15) minutes of inactivity, consistent with CJIS Security Policy v6.0: Section AC-12 (Session Termination) and Section IA-11 (Re-Authentication).

6.7 Remote Access

- The IT Director shall authorize each type of remote access to County information systems prior to allowing such connections, consistent with CJIS Security Policy v6.0: Section AC-17 (Remote Access).
- The Assistant IT Director shall ensure that all remote access is routed through a County-managed access control point.
- The Assistant IT Director shall monitor all remote access connections.
- The IT Director (as LASO) shall require Multi-Factor Authentication (MFA) for all remote access and all privileged access, consistent with CJIS Security Policy v6.0: Section IA-2(1) (Multi-Factor Authentication to Privileged Accounts) and Section IA-2(2) (Multi-Factor Authentication to Non-Privileged Accounts). Authenticator mechanics are governed under **Policy 2.05**.
- The Assistant IT Director shall ensure that remote access communications are protected using cryptographic modules meeting the validation requirements defined in **Policy 1.11**.

6.8 Wireless Access

- The IT Director shall authorize each type of wireless access prior to allowing such connections, consistent with CJIS Security Policy v6.0: Section AC-18 (Wireless Access).
- The Assistant IT Director shall ensure that authorized wireless access to the internal network uses WPA2 or WPA3 Enterprise authentication and encryption.
- The Assistant IT Director shall ensure that guest wireless networks are logically or physically separated from any environment processing CJI or any other data classified as Confidential or Restricted under **Policy 1.11**.

6.9 Periodic Access Recertification

To ensure access privileges remain commensurate with assigned duties and current business need, the Assistant IT Director shall operate a periodic access recertification program. Department Heads shall validate that personnel under their authority retain a legitimate need-to-know for the access granted. The Assistant IT Director shall disable or modify accounts where the Department Head cannot confirm continued business need.

- **Restricted Systems (Level 4)**: Access to systems processing, storing, or transmitting Criminal Justice Information (CJI) or other Restricted data as defined in **Policy 1.11** shall be recertified at least quarterly. This cadence aligns with the quarterly risk assessment review cycle for CJI and Critical systems defined in **Policy 1.09** (Risk Management Policy).
- **Confidential Systems (Level 3)**: Access to systems storing or processing Confidential data as defined in **Policy 1.11** shall be recertified at least semi-annually.
- **Internal Use and Public Systems (Levels 1–2)**: Access to systems classified at Internal Use or Public under **Policy 1.11** and shall be recertified at least annually, consistent with CJIS Security Policy v6.0: Section AC-6(7) (Review of User Privileges).

- **Privileged Accounts**: All privileged access (Tier L3 and above) shall be recertified at least semi-annually, regardless of system classification, to validate continued operational need and compliance with the competency maintenance requirements defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
- **Recertification Triggers**: In addition to the scheduled cadence, the Assistant IT Director shall initiate a recertification review within five (5) business days following a significant organizational change, including departmental reorganization, system migration, or material change to a Department Head's scope, consistent with NIST SP 800-53 Rev. 5: AC-2 (Account Management) and CJIS Security Policy v6.0: Section AC-2 (Account Management).
- **Documentation**: The Assistant IT Director shall maintain the documentation of access recertification results as follows.
  - The Assistant IT Director shall document recertification results in the Department's system of record.
  - The Assistant IT Director shall suspend accounts not recertified within the required timeframe until the review is completed.
  - The Assistant IT Director shall retain recertification records in accordance with **Policy 1.11**.

2.05 Identification and Authentication Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes mandatory requirements for uniquely identifying and authenticating all users, devices, and services prior to granting access to Elko County information systems and data.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, County employees, elected officials, contractors, vendors, and any other individuals or services accessing County information systems.

- **In Scope**:
  - Authenticators, including passwords, cryptographic tokens, smart cards, biometrics, device certificates, and service credentials.
  - Authentication for local, network, remote, and application/API access.
  - Identifier management and lifecycle controls for user, device, and service identities.
- **Out of Scope**:
  - Logical access decisions and account lifecycle: **Policy 2.04**.
  - Personnel security and adjudication: **Policy 2.02**.
  - Data classification: **Policy 1.11**.
  - Vendor access governance: **Policy 1.13**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall hold final authority for County authentication architecture decisions.
  - Shall hold final authority for enterprise multi-factor authentication (MFA) technology selections.
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for authentication decisions involving Criminal Justice Information (CJI).
  - Shall approve any exception to authentication requirements in writing per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **County Manager:**
  - Shall approve authentication policy exceptions that exceed the IT Director's delegated authority per **Policy 5.01**.
- **Assistant IT Director:**
  - Shall maintain the Identity and Access Management (IAM) infrastructure required under this policy.
  - Shall implement compensating controls for approved authentication exceptions.

  - Shall ensure information systems implement the technical authentication controls required by this policy.
- **Systems Administrator:**
  - Shall configure authentication mechanisms in accordance with the requirements established in Section 6.
  - Shall bind authenticators to verified identities.
  - Shall execute credential revocation within the timeframes defined in Section 6.3.
- **Department Heads:**
  - Shall identify the classification level of data under their ownership per **Policy 1.11**, which determines the authentication strength applied under this policy.
  - Shall request authentication policy exceptions for systems under their data ownership per **Policy 5.01**.
- **Human Resources:**
  - Shall serve as the Authoritative Source for workforce identity proofing.
  - Shall manage the lifecycle of physical County identity credentials.
- **All County Personnel:**
  - Shall protect County-issued authenticators from unauthorized use.
  - Shall report suspected compromise, loss, or theft within the timelines defined in Section 6.3.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals authenticating to County information systems.

- **Assessment**: Compliance with authentication and identifier management requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the security control assessment process defined in **Policy 5.05** (Security Control Assessment and Authorization).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.
- **Universal Applicability**: These standards apply to all authentication to County information systems regardless of location or work arrangement, including remote work and official travel.

5. References

Cited References:

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management and Vendor Governance
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment

- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.05: Security Control Assessment and Authorization
- CJIS Security Policy v6.0: Section 5.20.7.2 (Advanced Authentication)
- CJIS Security Policy v6.0: Section 5.20.7.2.1 (Compensating Controls)
- CJIS Security Policy v6.0: Section 5.20.7.3 (Device Certificates)
- CJIS Security Policy v6.0: Section IA-2 (Identification and Authentication (Organizational Users))
- CJIS Security Policy v6.0: Section IA-2(8) (Replay Resistant)
- CJIS Security Policy v6.0: Section IA-3 (Device Identification and Authentication)
- CJIS Security Policy v6.0: Section IA-4 (Identifier Management)
- CJIS Security Policy v6.0: Section IA-5 (Authenticator Management)
- CJIS Security Policy v6.0: Section IA-5(1) (Authenticator Management | Authenticator Types)
- CJIS Security Policy v6.0: Section IA-5(2) (Authenticator Management | Public Key-Based Authentication)
- CJIS Security Policy v6.0: Section IA-6 (Authentication Feedback)
- CJIS Security Policy v6.0: Section IA-7 (Cryptographic Module Authentication)
- CJIS Security Policy v6.0: Section IA-8 (Identification and Authentication (Non-Organizational Users))
- CJIS Security Policy v6.0: Section IA-12 (Identity Proofing)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)

Framework Alignment:

- NIST CSF 2.0: PR.AA-01 (Identities and Credentials)
- NIST CSF 2.0: PR.AA-02 (Identity Proofing)
- NIST CSF 2.0: PR.AA-03 (Authentication)
- NIST CSF 2.0: PR.AA-04 (Identity Assertions Protected, Conveyed, and Verified)
- NIST SP 800-53 Rev. 5: IA-2 (Identification and Authentication (Organizational Users))
- NIST SP 800-53 Rev. 5: IA-3 (Device Identification and Authentication)
- NIST SP 800-53 Rev. 5: IA-4 (Identifier Management)
- NIST SP 800-53 Rev. 5: IA-5 (Authenticator Management)
- NIST SP 800-53 Rev. 5: IA-5(1) (Password-Based Authentication)
- NIST SP 800-53 Rev. 5: IA-5(2) (Public Key-Based Authentication)
- NIST SP 800-53 Rev. 5: IA-6 (Authentication Feedback)
- NIST SP 800-53 Rev. 5: IA-8 (Identification and Authentication (Non-Organizational Users))
- NIST SP 800-53 Rev. 5: IA-12 (Identity Proofing)
- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Access Management Practice

6. Policy Statement

6.1 Unique Identification and Identifier Reuse

- **Unique Identification**:
  - The Systems Administrator shall configure County systems to uniquely identify each user.
  - The Systems Administrator shall not assign a single identifier to multiple individuals.
- **Shared/Generic Accounts**: The Systems Administrator shall not provision shared, generic, or group accounts except where the IT Director has approved a documented operational necessity in writing.
- **Identifier Reuse Floor**: The Systems Administrator shall not reuse identifiers (e.g., usernames) for a minimum of one (1) year following account deactivation, consistent with CJIS Security Policy v6.0: Section IA-4 (Identifier Management).

6.2 MFA Baselines and Authentication Strength

- **MFA Required for Restricted (Level 4)**: The Systems Administrator shall require multi-factor authentication (MFA) for access to Restricted (Level 4) data systems (CJI, PHI), Restricted repositories, and administrative functions, consistent with **Policy 1.11** and CJIS Security Policy v6.0: Section IA-2 (Identification and Authentication (Organizational Users)).
- **MFA Required for Remote and Privileged Access**: The Systems Administrator shall require MFA for all remote access and for privileged accounts consistent with **Policy 2.04** (Access Control Policy) access control baselines.
- **Replay-Resistant Requirement (CJI)**: The Systems Administrator shall implement at least one (1) replay-resistant factor for access to CJI and workflows requiring replay resistance, consistent with CJIS Security Policy v6.0: Section IA-2(8) (Replay Resistant).

6.3 Authenticator Lifecycle and Revocation

- **Identity Proofing**: Human Resources shall conduct in-person identity verification prior to issuance of County credentials, consistent with CJIS Security Policy v6.0: Section IA-12 (Identity Proofing).
- **Revocation Timeframes**:
  - For standard termination, the Systems Administrator shall disable accounts within twenty-four (24) hours, consistent with **Policy 2.02** (Personnel Security and Background Screening Policy).
  - For High-Risk Individuals as defined in **Policy 2.02**, the Systems Administrator shall disable accounts within thirty (30) minutes.
- **Compromise/Loss Reporting**:
  - All County Personnel shall report suspected authenticator compromise, loss, or theft immediately.
  - For authenticators or devices providing access to CJI, All County Personnel shall report within one (1) hour of discovery.
- **Temporary Authenticators**: The Systems Administrator shall require an immediate change to a user-defined secret upon first use of any temporary authenticator (e.g., initial passwords), consistent with CJIS Security Policy v6.0: Section IA-5 (Authenticator Management).

6.4 Rate Limiting and Unsuccessful Authentication

- **Unsuccessful Logon Attempts**: The Systems Administrator shall enforce unsuccessful logon attempt limits consistent with **Policy 2.04** requirements: five (5) invalid attempts within fifteen (15) minutes, resulting in a lockout until released by an administrator for CJI-connected systems.

6.5 Memorized Secret (Password) Standards

- **Minimum Length**: The Systems Administrator shall require a minimum of twelve (12) characters for standard accounts and a minimum of fourteen (14) characters for privileged accounts (Tier L3 and above), consistent with CJIS Security Policy v6.0: Section IA-5(1) (Authenticator Management | Authenticator Types).
- **Password History**: The Systems Administrator shall prevent reuse of the last ten (10) passwords.
- **Blocklist Screening**:
  - The Systems Administrator shall implement screening against an IT Director-approved reference list of commonly-used, expected, or compromised passwords.
  - The Systems Administrator shall update the password screening reference data at least quarterly.
  - The Systems Administrator shall compare current memorized-secret authenticators against the approved reference list at least quarterly and upon suspected compromise.
- **Compromise-Triggered Change**:
  - The Systems Administrator shall require a password change upon evidence of compromise.
  - The Systems Administrator shall not mandate periodic password changes as a primary control.
- **Account Recovery**: The Systems Administrator shall require immediate selection of a new memorized secret upon account recovery.
- **No Truncation**: The Systems Administrator shall not configure verifiers to truncate memorized secrets during authentication or storage.
- **Hint Prohibition**: The Systems Administrator shall not configure systems to permit storage of memorized-secret hints accessible to unauthenticated claimants.
- **Knowledge-Based Authentication Prohibition**: The Systems Administrator shall not prompt users to use knowledge-based information (e.g., security questions) when selecting memorized secrets, either during initial selection or account recovery.

6.6 Service Accounts and API Credentials

- **Interactive Logon Prohibited**: The Systems Administrator shall not permit personnel to use service accounts for administrative work or interactive logon.
- **Legacy Service-Account Controls**: Where an application requires interactive use of a service account:
  - Department Heads shall request an exception per **Policy 5.01**.
  - The IT Director shall approve the exception in writing.
  - The Assistant IT Director shall enable interactive use only during scheduled maintenance windows.
  - The Assistant IT Director shall require MFA for any interactive service-account session.
  - The Assistant IT Director shall configure full event logging for any interactive service-account session, consistent with **Policy 2.11** (Audit Logging and Monitoring Policy).
- **Secrets Management**:
  - The Systems Administrator shall store service credentials and API keys in an ECIO-approved secrets management solution.
  - The Systems Administrator shall rotate service credentials and API keys upon events that may compromise authenticator integrity, including but not limited to: suspected compromise, owner

departure, privilege change, vendor contract termination, administrator role change, application ownership transfer, and system decommissioning.

6.7 Non-Organizational Users and Device Authentication

- **Non-Organizational Users**:
  - The Systems Administrator shall uniquely identify and authenticate contractors and vendors, consistent with **Policy 1.13** (Supply Chain Risk Management and Vendor Governance) and CJIS Security Policy v6.0: Section IA-8 (Identification and Authentication (Non-Organizational Users)).
  - The Assistant IT Director shall ensure non-organizational user access is time-bounded with a defined termination date specified at the time of authorization.
  - The Assistant IT Director shall re-verify non-organizational user access at least annually.
- **Device Identification**:
  - The Systems Administrator shall uniquely identify County-managed devices prior to network connection, consistent with CJIS Security Policy v6.0: Section IA-3 (Device Identification and Authentication).
  - The Systems Administrator shall not substitute device authentication for user authentication or user MFA requirements.

6.8 Authentication Feedback

- **Obscuration**: The Systems Administrator shall mask characters during entry to protect against shoulder surfing, consistent with CJIS Security Policy v6.0: Section IA-6 (Authentication Feedback).
- **Generic Error Messages**:
  - The Systems Administrator shall configure authentication error messages to be generic.
  - The Systems Administrator shall not configure error messages that disclose which element of the credentials (username or password) was incorrect.

6.9 Mobile Device Advanced Authentication

- **Requirement**: The Systems Administrator shall require advanced authentication (MFA) for mobile devices accessing CJI, consistent with CJIS Security Policy v6.0: Section 5.20.7.2 (Advanced Authentication).
- **Eligible Device Class**:
  - The IT Director shall approve advanced-authentication compensating-control exceptions only for agency-issued smartphones and tablets with limited-feature operating systems, consistent with CJIS Security Policy v6.0: Section 5.20.7.2.1 (Compensating Controls).
  - The IT Director shall not approve advanced-authentication compensating-control exceptions for unmanaged, personally owned, or full-featured operating system endpoints.
- **Compensating Control Procedure**: Where a mobile device requires an exception to the advanced authentication requirement:
  - Department Heads shall request the exception per **Policy 5.01**.
  - The IT Director shall approve the exception in writing.
  - The Assistant IT Director shall enroll the device in the County mobile device management (MDM) platform prior to CJIS Systems Officer (CSO) consideration, consistent with CJIS Security Policy v6.0: Section 5.20.7.2.1 (Compensating Controls).

  - The IT Director shall not allow the exception to take effect until written approval is obtained from the CSO.
- **Compensating Control Criteria**:
  - The Assistant IT Director shall ensure compensating controls meet the intent of the CJIS advanced-authentication requirement.
  - The Assistant IT Director shall ensure compensating controls provide a similar level of protection as the original advanced-authentication requirement.
  - The Assistant IT Director shall ensure compensating controls do not rely upon the existing advanced-authentication requirement as the compensating control.
  - The Assistant IT Director shall ensure compensating controls expire on the CSO-approved date or upon implementation of a compliant advanced-authentication solution.
- **Mandatory Compensating Controls**:
  - The Assistant IT Director shall implement possession and registration of an agency-issued smartphone or tablet as proof of authorized user.
  - The Assistant IT Director shall implement device certificates consistent with CJIS Security Policy v6.0: Section 5.20.7.3 (Device Certificates).
  - The Assistant IT Director shall implement CJIS-compliant standard authenticator protection on the secure storage location where CJI resides.

6.10 Public Key-Based Authentication (Smart Cards/Tokens)

- **Private Key Protection**: The Systems Administrator shall enforce protection of the private key in systems implementing public key-based authentication and shall prevent unauthorized use.
- **Identity Mapping**: The Systems Administrator shall map the authenticated identity to the unique individual account in the County's authoritative identity repository.
- **Certificate Validation and Revocation**:
  - The Systems Administrator shall validate certificates to a trusted root.
  - The Systems Administrator shall maintain revocation information (e.g., CRL/OCSP) to support validation during network unavailability, consistent with CJIS Security Policy v6.0: Section IA-5(2) (Authenticator Management | Public Key-Based Authentication).

6.11 Cryptographic Protection (FIPS)

- **FIPS Validation**: The Systems Administrator shall use cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP) to protect Restricted data, consistent with CJIS Security Policy v6.0: Section IA-7 (Cryptographic Module Authentication) and Section SC-13 (Cryptographic Protection).
- **Validation Evidence**: The Systems Administrator shall retain the CMVP validation certificate number, validated module name, validated module version, and implementation context for each cryptographic module relied upon to satisfy this policy.

2.06 Privacy and Data Protection Policy

Effective: April 29, 2026 Version: 2.8

1. Purpose

This policy establishes mandatory requirements for the protection of Criminal Justice Information (CJI), Personally Identifiable Information (PII), and Protected Health Information (PHI, where applicable) processed, stored, or transmitted by or on behalf of Elko County.

2. Scope

This policy applies to all County Personnel — including employees, elected officials, contractors, vendors, interns, and volunteers — who access, use, collect, store, process, or transmit CJI, PII, or PHI. This policy applies regardless of location, medium, or funding source, and regardless of whether the data is held in County-owned, County-managed, or County-provisioned systems and services.

- **In Scope**:
  - Privacy Impact Assessments (PIAs) for defined trigger events.
  - Data minimization at collection.
  - Privacy-specific handling obligations for CJI, PII, and PHI.
  - Privacy incident reporting triggers and breach determination.
  - Privacy training obligations for personnel handling CJI, PII, or PHI.
- **Out of Scope**:
  - Data classification schema, labeling, storage authorization, residency, retention, and reclassification: **Policy 1.11**.
  - Access control mechanics, recertification cadence, and revocation timelines: **Policy 2.04**.
  - General security awareness and training delivery: **Policy 2.03**.
  - Media sanitization and physical destruction standards: **Policy 2.12**.
  - Incident intake, triage, declaration, and CJIS notification execution: **Policy 4.02**.
  - External breach notification under NRS 603A.220: **Policy 4.06**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the final authority on privacy and data protection determinations under this policy.
  - Shall approve Privacy Impact Assessments (PIAs) under Section 6.1 of this policy.
  - Shall, as Local Agency Security Officer (LASO) per **Policy 1.11** (Data Governance and Classification Policy), execute CJIS Security Policy obligations that attach to privacy incidents involving CJI.
  - Shall render the NRS 603A.220 breach determination as governed by **Policy 4.06** (Communication Protocols and Partner Integration).

  - Shall maintain a register of applicable federal and state privacy laws in the System of Engagement.
- **Assistant IT Director:**
  - Shall approve operational exceptions to this policy within the criteria and notification requirements defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
  - Shall prepare each Privacy Impact Assessment (PIA) required under Section 6.1 of this policy, in consultation with the applicable Department Head.
  - Shall ensure each PIA addresses the content requirements of Section 6.1 of this policy.
  - Shall serve as the authoritative custodian of PIA records and supporting artifacts.
  - Shall coordinate privacy-specific training content with **Policy 2.03** (Security Awareness and Training Policy).
- **Human Resources:**
  - Shall notify Information Operations of personnel separations and role changes affecting access to CJI, PII, or PHI.
- **Department Heads:**
  - Shall determine the necessity of data collection under Section 6.2 of this policy.
  - Shall ensure personnel under their supervision comply with the privacy handling obligations of this policy and the classification handling rules of **Policy 1.11**.
  - Shall notify the Assistant IT Director upon becoming aware of any event meeting a Privacy Impact Assessment (PIA) trigger defined in Section 6.1 that arises within their department.
  - Shall provide departmental information required for PIA preparation, including business purpose, data categories handled, operational context, and access population.
  - Shall acknowledge in writing the residual risk disposition documented in each approved PIA covering data under their department's purview.
- **All Information Operations Personnel:**
  - Shall implement the technical controls required to enforce the privacy handling obligations of this policy, including encryption, access enforcement, logging, and sanitization handoffs.
  - Shall support PIA preparation by providing system architecture, data flow, and technical control information required by the Assistant IT Director.
- **All County Personnel:**
  - Shall comply with the privacy handling obligations of this policy for CJI, PII, or PHI they access, use, collect, store, process, or transmit.
  - Shall complete required privacy training in accordance with Section 6.7 of this policy.
  - Shall report suspected or confirmed privacy incidents and data breaches in accordance with Section 6.8 of this policy.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all County Personnel who access, use, collect, store, process, or transmit CJI, PII, or PHI.

- **Assessment**: Adherence to this policy shall be assessed through the audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).

- **Enforcement**: The IT Director shall enforce this policy. Non-compliance shall be addressed under the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be requested, documented, approved, and retained in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- NRS 603A (Security and Privacy of Personal Information)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: Section 4 (Criminal Justice Information and Personally Identifiable Information)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)

Framework Alignment:

- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- CJIS Security Policy v6.0: Section SC-28 (Protection of Information at Rest)
- NIST CSF 2.0: GV.PO-01 (Organizational Cybersecurity Policy)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST SP 800-53 Rev. 5: AT-2 (Literacy Training and Awareness)
- NIST SP 800-53 Rev. 5: AT-3 (Role-Based Training)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: PM-18 (Privacy Program Plan)
- NIST SP 800-53 Rev. 5: PM-19 (Privacy Program Leadership Role)
- NIST SP 800-53 Rev. 5: PT-1 (Policy and Procedures)
- NIST SP 800-53 Rev. 5: PT-3 (Personally Identifiable Information Processing Purposes)
- NIST SP 800-53 Rev. 5: RA-8 (Privacy Impact Assessments)

- NIST SP 800-53 Rev. 5: SA-8 (Security and Privacy Engineering Principles)
- NIST SP 800-53 Rev. 5: SC-13 (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: APO14 (Manage Data)
- COBIT 2019: DSS05 (Manage Security Services)
- ITIL v4: Information Security Management Practice

6. Policy Statement

This policy governs the County's privacy-specific controls and the Privacy Impact Assessment (PIA) process. General data classification, storage, retention, access mechanics, media sanitization, and incident execution remain governed by their respective policies cross-referenced throughout this policy.

6.1 Privacy Impact Assessments

The Privacy Impact Assessment (PIA) is the County's authoritative instrument for identifying and disposing of privacy risk before data is collected, processed, or shared. A PIA is not exclusive to formally designated projects; it applies to any change in the County's privacy posture that meets the trigger conditions below.

- **Trigger Events**: The IT Director shall approve a PIA before any of the following events proceed:
  - A new system that will process, store, or transmit CJI, PII, or PHI.
  - A modification to an existing system processing CJI, PII, or PHI that introduces a new data category, a new storage location, an expanded access population, or a new data recipient.
  - A new data collection that introduces a category of personal information the County did not previously collect.
  - A new data-sharing arrangement under which CJI, PII, or PHI is shared with an external party.
  - Reclassification of data upward under **Policy 1.11** when the new classification is Confidential or Restricted.
  - A change in processing purpose for personal information already collected that exceeds or contradicts the legal authority under which the data was originally collected, expands data use into a category not previously authorized, or is inconsistent with any public notice of collection provided to data subjects.
- **PIA Content**: The Assistant IT Director shall ensure each PIA addresses the following items at minimum:
  - Data categories involved (CJI, PII, PHI), approximate record count or estimated data volume, and sources.
  - Legal authority for collection, processing, use, or disclosure, including the specific statute, regulation, ordinance, court order, agreement, grant condition, or documented County business function under which the data is authorized.
  - Processing purpose and consistency with the purpose of original collection.
  - Data flow, storage locations, and transmission paths.
  - Access control posture and role eligibility.
  - Retention disposition aligned with **Policy 1.11**.
  - Sharing arrangements and recipient controls.
  - Privacy risks identified, compensating controls applied, and residual risk accepted.

- **Approval Authority**: The IT Director shall approve all PIAs. PIA approval authority is not subject to Directed Deputization under **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Invoking Policies**: **Policy 3.14** (IT Project Management Policy) invokes PIA as a charter-approval package requirement when the project data-handling trigger fires.
- **Retention**: The Assistant IT Director shall retain approved PIAs and supporting artifacts as the authoritative custodian, in accordance with **Policy 1.11**.
- **Re-Review**: The Assistant IT Director shall prepare a fresh PIA when a subsequent trigger event fires against the same data, system, or processing purpose. PIAs are not reviewed on a fixed calendar cadence.

6.2 Data Collection and Minimization

Department Heads shall ensure that only data necessary for defined County business functions is collected. Department Heads shall not authorize collection of CJI, PII, or PHI beyond the data elements required to execute the specific legal authority under which the data is collected (statute, regulation, ordinance, court order, agreement, grant condition, or documented County business function authorized by law).

6.3 Access Control

All Information Operations Personnel shall enforce access to CJI, PII, and PHI on a need-to-know and least-privilege basis, in accordance with **Policy 2.04** (Access Control Policy) and the data classification rules of **Policy 1.11**.

6.4 Encryption

- **Data at Rest**: All Information Operations Personnel shall encrypt CJI, PII, and PHI at rest in accordance with the Confidential and Restricted data requirements defined in **Policy 1.11**.
- **Data in Transit**: All Information Operations Personnel shall encrypt CJI, PII, and PHI in transit in accordance with the Confidential and Restricted data requirements defined in **Policy 1.11**.

6.5 Regulatory Alignment

The IT Director shall maintain a register of applicable federal and state privacy laws in the System of Engagement, including at minimum NRS 603A (Security and Privacy of Personal Information) and CJIS Security Policy v6.0 Section 4 (Criminal Justice Information and Personally Identifiable Information). The IT Director shall initiate updates to this policy triggered by new or amended law through the ad hoc review process defined in **Policy 1.05** (Policy Review and Update Procedures).

6.6 Data Classification, Retention, and Residency

- **Classification and Handling**: All Information Operations Personnel shall apply **Policy 1.11** (Data Governance and Classification Policy) to classification assignment, labeling, reclassification, authorized storage locations, data residency, retention, and disposition of CJI, PII, and PHI.
- **Media Destruction**: All Information Operations Personnel shall apply **Policy 2.12** (Media Protection and Sanitization Policy) to destruction of digital media containing CJI, PII, or PHI.

6.7 Privacy Training

- **Initial and Annual Training**: All County Personnel shall complete initial and annual privacy training as part of the training program defined in **Policy 2.03** (Security Awareness and Training Policy).
- **Role-Based Training**: Personnel handling CJI, PII, or PHI shall complete role-based privacy training addressing the specific obligations of this policy applicable to their role.

- **Remedial Training**: All County Personnel shall complete remedial privacy training within thirty (30) calendar days of any privacy incident or policy violation attributable to them.

6.8 Incident and Breach Reporting

- **Internal Reporting**: All County Personnel shall report suspected or confirmed privacy incidents and data breaches in accordance with **Policy 4.02** (Identification and Reporting Procedures).
- **Reporting Mechanics**: The one (1) hour internal reporting clock and associated CJIS IR-6 mechanics are defined in **Policy 4.02**.
- **Breach Determination**: The IT Director shall render the NRS 603A.220 breach determination.
- **External Notification**: The IT Director shall execute external breach notification in accordance with **Policy 4.06**.

2.07 System and Communications Protection Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes mandatory technical and procedural controls for protecting Elko County information systems and data during transmission and storage.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, County employees, elected officials, contractors, vendors, and any other individuals or services accessing County information systems.

- **In Scope**:
  - Boundary protection components, including firewalls, routers, switches, and gateways.
  - Cryptographic components, including encryption keys, certificates, and validated cryptographic modules.
  - Communication channels, including Voice over Internet Protocol (VoIP), Virtual Private Networks (VPNs), and wireless networks.
  - Domain Name System (DNS) infrastructure and name-resolution services.
  - Collaborative computing devices, including cameras and microphones, attached to or integrated with County information systems.
  - Protected data, including Criminal Justice Information (CJI), Personally Identifiable Information (PII), and Restricted County records.
- **Out of Scope**:
  - Identification and authentication of users, devices, and services: **Policy 2.05**.
  - Access control authorization and account management: **Policy 2.04**.
  - Audit logging and monitoring: **Policy 2.11**.
  - Physical security of facilities and infrastructure: **Policy 2.13**.
  - Mobile device endpoints and remote access devices: **Policy 2.14**.
  - Security incident identification and response: **Policy 4.02**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall hold final authority for ingress and egress traffic policy deviations from the Deny-by-Default standard.
  - Shall authorize all connections to external information systems via formal Interconnection Security Agreements.
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for system and communications protection decisions involving Criminal Justice Information (CJI).

  - Shall approve any exception to this policy in writing per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **County Manager:**
  - Shall approve exceptions to this policy that exceed the IT Director's delegated authority per **Policy 5.01**.
- **Assistant IT Director:**
  - Shall ensure information systems implement the technical boundary protection, transmission, at-rest, cryptographic key management, and name-resolution controls required by this policy.
  - Shall maintain the cryptographic infrastructure required to satisfy this policy.
  - Shall implement compensating controls for approved exceptions to this policy.
- **Network Administrator:**
  - Shall configure boundary protection devices to enforce the Deny-by-Default traffic policy.
  - Shall maintain boundary protection devices in conformance with the Deny-by-Default traffic policy.
  - Shall implement network segregation between public, internal, and CJI-dedicated network segments.
  - Shall verify the integrity of network segregation through periodic configuration review.
  - Shall review firewall rule sets monthly to ensure no unauthorized access points exist.
- **Systems Administrator:**
  - Shall configure encryption for data in transit using cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP).
  - Shall configure encryption for data at rest using cryptographic modules validated under the CMVP.
  - Shall manage the cryptographic key lifecycle in accordance with Section 6.4.
  - Shall configure remote access mechanisms to disable split tunneling.
- **All County Personnel:**
  - Shall use only County-authorized methods for remote access and data transmission.
  - Shall physically cover or logically disable collaborative computing devices when accessing CJI and the device is not required for the immediate task.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals using or operating Elko County information systems.

- **Assessment**: Compliance with system and communications protection requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the security control assessment process defined in **Policy 5.05** (Security Control Assessment and Authorization).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.

- **Universal Applicability**: These standards apply to all use of County information systems regardless of location or work arrangement, including remote work and official travel.

5. References

Cited References:

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 2.14: Mobile Device and Remote Access Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.05: Security Control Assessment and Authorization
- CJIS Security Policy v6.0: Section SC-5 (Denial-of-Service Protection)
- CJIS Security Policy v6.0: Section SC-7 (Boundary Protection)
- CJIS Security Policy v6.0: Section SC-7(24) (Boundary Protection — Personally Identifiable Information)
- CJIS Security Policy v6.0: Section SC-8 (Transmission Confidentiality and Integrity)
- CJIS Security Policy v6.0: Section SC-10 (Network Disconnect)
- CJIS Security Policy v6.0: Section SC-12 (Cryptographic Key Establishment and Management)
- CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection)
- CJIS Security Policy v6.0: Section SC-15 (Collaborative Computing Devices and Applications)
- CJIS Security Policy v6.0: Section SC-20 (Secure Name/Address Resolution Service (Authoritative Source))
- CJIS Security Policy v6.0: Section SC-21 (Secure Name/Address Resolution Service (Recursive or Caching Resolver))
- CJIS Security Policy v6.0: Section SC-22 (Architecture and Provisioning for Name/Address Resolution Service)
- CJIS Security Policy v6.0: Section SC-28 (Protection of Information at Rest)

Framework Alignment:

- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: PR.IR-01 (Network Protection)
- NIST SP 800-53 Rev. 5: SC-5 (Denial-of-Service Protection)
- NIST SP 800-53 Rev. 5: SC-7 (Boundary Protection)
- NIST SP 800-53 Rev. 5: SC-7(24) (Boundary Protection — Personally Identifiable Information)

- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)
- NIST SP 800-53 Rev. 5: SC-10 (Network Disconnect)
- NIST SP 800-53 Rev. 5: SC-12 (Cryptographic Key Establishment and Management)
- NIST SP 800-53 Rev. 5: SC-13 (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: SC-15 (Collaborative Computing Devices and Applications)
- NIST SP 800-53 Rev. 5: SC-20 (Secure Name/Address Resolution Service (Authoritative Source))
- NIST SP 800-53 Rev. 5: SC-21 (Secure Name/Address Resolution Service (Recursive or Caching Resolver))
- NIST SP 800-53 Rev. 5: SC-22 (Architecture and Provisioning for Name/Address Resolution Service)
- NIST SP 800-53 Rev. 5: SC-28 (Protection of Information at Rest)
- COBIT 2019: DSS05 (Manage Security Services)
- ITIL v4: Architecture Management Practice
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Boundary Protection and Architecture

The Network Administrator shall monitor and control communications at the external managed interfaces and at key internal managed interfaces of County information systems, consistent with CJIS Security Policy v6.0: Section SC-7 (Boundary Protection).

- **Managed Interfaces**: The Network Administrator shall route connections to external networks (Internet) or external information systems only through managed interfaces such as firewalls, proxies, and gateways arranged in accordance with the County security architecture.
- **Deny-by-Default**: The Network Administrator shall configure boundary protection devices to deny all inbound and outbound traffic by default, allowing only those services and ports explicitly authorized by the IT Director (as LASO) for documented business need.
- **Split Tunneling Prohibition**: The Systems Administrator shall configure remote access mechanisms to disable split tunneling such that all network traffic from the remote device routes through the County's managed boundary protection devices for inspection.
- **Demilitarized Zone Implementation**: The Network Administrator shall locate publicly accessible system components such as web servers in a Demilitarized Zone (DMZ), physically or logically separated from internal organizational networks.
- **Denial of Service**: The Network Administrator shall configure boundary devices to detect and mitigate denial-of-service attacks through rate limiting and traffic filtering, consistent with CJIS Security Policy v6.0: Section SC-5 (Denial-of-Service Protection).
- **PII Boundary Monitoring**: The Network Administrator shall monitor for permitted processing of Personally Identifiable Information (PII) at external managed interfaces and at key internal boundaries, consistent with CJIS Security Policy v6.0: Section SC-7(24) (Boundary Protection — Personally Identifiable Information).

6.2 Transmission Confidentiality and Integrity

The Systems Administrator shall protect the confidentiality and integrity of transmitted information, consistent with CJIS Security Policy v6.0: Section SC-8 (Transmission Confidentiality and Integrity).

- **Encryption In-Transit**: The Systems Administrator shall encrypt CJI and Personally Identifiable Information (PII) transmitted outside a physically secure location as defined in **Policy 2.13** (Physical Security and Environmental Controls Policy).
- **Wireless CJI**: The Systems Administrator shall prohibit wireless transmission of CJI unless protected by a CMVP-validated cryptographic module.
- **Cryptographic Standards**: The Systems Administrator shall use cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP) to protect data in transit, with a symmetric cipher key strength of at least one hundred twenty-eight (128) bits, consistent with CJIS Security Policy v6.0: Section SC-13 (Cryptographic Protection).
- **Session Authenticity**: The Systems Administrator shall protect the authenticity of communications sessions through Transport Layer Security (TLS) version 1.2 or higher to prevent man-in-the-middle attacks and session hijacking.
- **Network Disconnect**: The Network Administrator shall configure VPN and remote access gateway termination at the network layer in accordance with the inactivity thresholds and Criminal Justice Conveyance exemption defined in **Policy 2.04** (Access Control Policy), consistent with CJIS Security Policy v6.0: Section SC-10 (Network Disconnect).

6.3 Protection of Information at Rest

The Systems Administrator shall protect the confidentiality and integrity of information at rest, consistent with CJIS Security Policy v6.0: Section SC-28 (Protection of Information at Rest).

- **CJI Encryption**: The Systems Administrator shall encrypt CJI stored on digital media, including servers, workstations, mobile devices, and external drives, outside a physically secure location using cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP), with a minimum key strength of one hundred twenty-eight (128) bits.

6.4 Cryptographic Key Management

The Systems Administrator shall manage cryptographic keys to secure the key lifecycle, consistent with CJIS Security Policy v6.0: Section SC-12 (Cryptographic Key Establishment and Management).

- **Generation**: The Systems Administrator shall generate cryptographic keys using random number generators contained within CMVP-validated cryptographic modules.
- **Distribution**: The Systems Administrator shall distribute cryptographic keys via secure methods that prevent unauthorized disclosure, including encrypted channels.
- **Storage**: The Systems Administrator shall not store unencrypted cryptographic keys on the same system or media as the encrypted data they protect.
- **Destruction**: The Systems Administrator shall destroy or zeroize cryptographic keys immediately when they are no longer needed or when the association with the authorized user or entity is terminated.
- **Validation Records**: The Systems Administrator shall retain the CMVP validation certificate number, validated module name, validated module version, and implementation context for each cryptographic module relied upon to satisfy this policy.

6.5 Collaborative Computing Devices

To prevent unauthorized remote surveillance, the Systems Administrator shall configure systems to prohibit the remote activation of collaborative computing devices, including cameras and microphones, consistent with CJIS Security Policy v6.0: Section SC-15 (Collaborative Computing Devices and Applications).

- **Indication of Use**: The Systems Administrator shall deploy only collaborative computing devices that provide a physical or on-screen indication of activation.
- **Disablement**: All County Personnel accessing CJI via a workstation with a built-in camera or microphone shall physically cover or logically disable the device when the device is not required for the immediate task.

6.6 Secure Name and Address Resolution

The Network Administrator shall ensure the integrity of the Domain Name System (DNS) infrastructure supporting County information systems.

- **Authoritative DNS**: The Network Administrator shall configure County-operated authoritative DNS servers to publish DNS Security Extensions (DNSSEC) origin authentication and integrity verification artifacts for County-managed zones, consistent with CJIS Security Policy v6.0: Section SC-20 (Secure Name/Address Resolution Service (Authoritative Source)).
- **Forgery Protection**: The Network Administrator shall configure recursive resolvers to request and validate DNSSEC signatures to verify the authenticity of DNS responses, consistent with CJIS Security Policy v6.0: Section SC-21 (Secure Name/Address Resolution Service (Recursive or Caching Resolver)).
- **Fault Tolerance**: The Network Administrator shall maintain at least two (2) geographically separated DNS servers, or use a redundant cloud DNS provider, to ensure availability, consistent with CJIS Security Policy v6.0: Section SC-22 (Architecture and Provisioning for Name/Address Resolution Service).

2.08 System Integrity and Malware Protection Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy establishes mandatory controls for maintaining the integrity of Elko County information systems and for protecting those systems from malicious code, exploitation, and unauthorized changes.

2. Scope

This policy applies to all Elko County Information Operations (ECIO) personnel, County employees, elected officials, contractors, vendors, and any other individuals or services accessing County information systems. Technical implementation requirements apply to all information systems, networks, endpoints, and supporting infrastructure owned, leased, managed, or operated by Elko County, including all systems that process, store, or transmit Criminal Justice Information (CJI).

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall approve the selection of malicious code protection and system monitoring capabilities deployed on County information systems.
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for system integrity decisions involving Criminal Justice Information (CJI).
  - Shall approve any exception to this policy in writing per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall oversee the operational execution of the system integrity program.
  - Shall ensure information systems are monitored to detect attacks and indicators of potential attacks.
  - Shall ensure all Information Operations Personnel performing system integrity duties under this policy receive role-based training under **Policy 2.03** (Security Awareness and Training Policy).
  - Shall ensure all Information Operations Personnel performing system integrity duties under this policy are provisioned with access to approved protection tools.
- **Systems Administrator:**
  - Shall provision, harden, and maintain malicious code protection on workstations and servers.
  - Shall configure malicious code protection mechanisms to update signatures and scanning engines automatically.
  - Shall execute integrity verification on County information systems.
  - Shall remediate information system flaws in accordance with **Policy 2.09** (Vulnerability and Patch Management Policy).
- **Network Administrator:**

  - Shall configure boundary protection devices to detect and block malicious traffic at system entry and exit points.
  - Shall monitor boundary protection devices for indications of detected or attempted malicious activity.
  - Shall monitor network flow to identify anomalies or traffic patterns indicative of malware command-and-control activity.
- **Support Specialist:**
  - Shall verify the presence and current configuration of malicious code protection on endpoints during deployment and during work order activity.
  - Shall immediately report confirmed or suspected malware infections to the Systems Administrator and the Assistant IT Director.
  - Shall escalate confirmed malware events via the operational incident management process under **Policy 3.06** (Operational Incident Management Policy).
- **All County Personnel:**
  - Shall comply with **Policy 2.01** (Acceptable Use Policy).
  - Shall not disable or circumvent malicious code protection or system monitoring controls.
  - Shall report suspected security anomalies to the Service Desk immediately upon discovery.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals using or operating Elko County information systems.

- **Assessment**: Compliance with system integrity and malicious code protection requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.01: Acceptable Use Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 2.15: System Development and Secure Software Lifecycle
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- CJIS Security Policy v6.0: Section SI-3 (Malicious Code Protection)
- CJIS Security Policy v6.0: Section SI-4 (System Monitoring)

- CJIS Security Policy v6.0: Section SI-7 (Software, Firmware, and Information Integrity)
- CJIS Security Policy v6.0: Section SI-8 (Spam Protection)
- CJIS Security Policy v6.0: Section SI-10 (Information Input Validation)
- CJIS Security Policy v6.0: Section SI-16 (Memory Protection)

Framework Alignment:

- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: PR.PS-05 (Installation and Execution of Unauthorized Software Are Prevented)
- NIST CSF 2.0: DE.AE-02 (Adverse Event Analysis)
- NIST CSF 2.0: DE.CM-01 (Network Monitoring)
- NIST SP 800-53 Rev. 5: SI-2 (Flaw Remediation)
- NIST SP 800-53 Rev. 5: SI-3 (Malicious Code Protection)
- NIST SP 800-53 Rev. 5: SI-4 (System Monitoring)
- NIST SP 800-53 Rev. 5: SI-7 (Software, Firmware, and Information Integrity)
- NIST SP 800-53 Rev. 5: SI-8 (Spam Protection)
- NIST SP 800-53 Rev. 5: SI-10 (Information Input Validation)
- NIST SP 800-53 Rev. 5: SI-16 (Memory Protection)
- COBIT 2019: DSS05.01 (Protect Against Malware)
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Malicious Code Protection

The Systems Administrator shall implement malicious code protection mechanisms at system entry and exit points and on all workstations, servers, and mobile devices to detect and eradicate malicious code.

- **Automatic Updates**: The Systems Administrator shall configure malicious code protection mechanisms to perform automatic updates of virus definitions and scanning engines every twenty-four (24) hours.
  - **Exception**: Where a system does not support automatic updates, the Systems Administrator shall perform manual updates every twenty-four (24) hours.
- **Real-Time Scanning**: The Systems Administrator shall configure malicious code protection mechanisms to perform real-time scanning of files from external sources as files are downloaded, opened, or executed.
- **Periodic Scanning**: The Systems Administrator shall configure malicious code protection mechanisms to perform full system scans every twenty-four (24) hours.
- **Response Actions**:
  - The Systems Administrator shall configure malicious code protection mechanisms to automatically block or quarantine detected malicious code.
  - The Systems Administrator shall configure malicious code protection mechanisms to automatically alert the Systems Administrator and the Assistant IT Director upon detection of malicious code.

  - The Systems Administrator shall review false positives generated by malicious code protection mechanisms prior to releasing quarantined files.

6.2 System Monitoring

- **Monitoring Tools**: The Network Administrator shall employ automated monitoring tools (e.g., IDS/IPS, SIEM) to monitor inbound and outbound communications traffic for unusual or unauthorized activity.
- **Perimeter Monitoring**: The Network Administrator shall configure monitoring to check for indicators of attacks and unauthorized connections at external boundaries and at key internal boundaries.
- **Command-and-Control Detection**: The Network Administrator shall use system monitoring tools to inspect network flow and Domain Name System (DNS) logs for traffic patterns indicative of malware command-and-control (C2) activity.
- **Alerting**: The Systems Administrator and Network Administrator shall analyze and respond to system-generated security alerts.
- **Incident Escalation**: The Systems Administrator and Network Administrator shall escalate alerts assessed as potential incidents through the operational incident management process under **Policy 3.06**.

6.3 Information Integrity and Input Validation

- **Integrity Checks**: The Systems Administrator shall employ integrity verification tools (e.g., File Integrity Monitoring) to detect unauthorized changes to software, firmware, and information.
- **CJI Integrity Verification**: For systems processing CJI, the Systems Administrator shall perform integrity checks every seven (7) calendar days.
- **Input Validation**: The Systems Administrator shall verify that information systems acquired or operated by the Department implement input validation controls (e.g., character set, length, numerical range, format) sufficient to prevent injection attacks and data corruption.
  - **Exception**: For vendor-managed systems where input validation is implemented by the software vendor, the Systems Administrator shall confirm the control during procurement review under **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance Policy) and during secure software lifecycle review under **Policy 2.15** (System Development and Secure Software Lifecycle Policy).
- **Spam Protection**: The Systems Administrator shall employ spam protection mechanisms at information system entry and exit points.
- **Spam Protection Updates**: The Systems Administrator shall configure spam protection signatures to update automatically every twenty-four (24) hours.

6.4 Flaw Remediation

The Systems Administrator shall remediate information system flaws in accordance with **Policy 2.09**.

6.5 Memory Protection

The Systems Administrator shall configure operating systems and applications to utilize memory protection controls (e.g., Data Execution Prevention, Address Space Layout Randomization) to prevent the execution of unauthorized code.

2.09 Vulnerability and Patch Management Policy

Effective: July 01, 2026 Version: 2.0

1. Purpose

This policy establishes the requirements for identifying, scoring, remediating, and verifying technical vulnerabilities in Elko County information systems.

2. Scope

This policy applies to all Elko County information systems, networks, endpoints, applications, and supporting infrastructure owned, leased, operated, or managed by Elko County, including all systems that process, store, or transmit Criminal Justice Information (CJI).

- **In Scope**:
  - Vulnerability scanning, scoring, and prioritization.
  - Patch deployment for County-managed systems and endpoints.
  - Verification scanning following remediation.
  - Receipt, dissemination, and implementation of vendor and federal security advisories.
  - End-of-life and end-of-support software identification and migration.
  - External vulnerability reports received through the public reporting channel.
- **Out of Scope**:
  - Asset and software inventory: **Policy 1.12**.
  - Configuration baselines and hardening: **Policy 2.10**.
  - Change authorization for patch deployment: **Policy 3.09**.
  - Risk acceptance for unremediated vulnerabilities: **Policy 1.09**.
  - Incident response when vulnerabilities are exploited: **Policy 4.02**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall approve the vulnerability and patch management program for Elko County Information Operations.
  - Shall approve all Risk Acceptance Memos for vulnerabilities that cannot be remediated within the timelines defined in this policy, in accordance with **Policy 1.09** (Risk Management Policy).
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for vulnerability management decisions involving CJI.
  - Shall approve any exception to this policy in writing per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall oversee the operational execution of the vulnerability and patch management lifecycle.

  - Shall subscribe to and review external security alerts, advisories, and directives from authoritative sources on an ongoing basis.
  - Shall maintain the publicly available channel for the receipt of external vulnerability reports concerning County information systems.
  - Shall compile the Monthly Vulnerability Compliance Report from the domain-specific inputs prepared by the Systems Administrator and the Network Administrator.
  - Shall submit the compiled Monthly Vulnerability Compliance Report to the IT Director.
  - Shall validate the operability of vulnerability scanning tools and the timeliness of scan execution.
  - Shall coordinate vendor patching and vulnerability management obligations with the supply chain governance program defined in **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance).
- **Systems Administrator:**
  - Shall configure and maintain authenticated vulnerability scanning across servers, workstations, and applications.
  - Shall analyze vulnerability scan results.
  - Shall test patches on a non-production subset of representative systems prior to County-wide deployment.
  - Shall deploy remediation actions for server and endpoint systems within the timelines defined in this policy.
  - Shall maintain vulnerability-management metadata associated with the software inventory, including Common Vulnerabilities and Exposures (CVE) cross-references, current patch state, and last-scan timestamps.
  - Shall prepare domain-specific monthly inputs to the Vulnerability Compliance Report covering open vulnerabilities by severity, Mean Time to Remediate (MTTR), patch compliance percentage, and the list of overdue assets within the server and endpoint domain.
- **Network Administrator:**
  - Shall manage vulnerabilities on network infrastructure components, including routers, switches, firewalls, and wireless access points.
  - Shall test firmware and configuration updates on a non-production subset of representative network components prior to County-wide deployment.
  - Shall deploy firmware and configuration updates within the timelines defined in this policy.
  - Shall prepare domain-specific monthly inputs to the Vulnerability Compliance Report covering open vulnerabilities by severity, Mean Time to Remediate (MTTR), patch compliance percentage, and the list of overdue assets within the network infrastructure domain.
- **Support Specialist:**
  - Shall verify endpoint patch state during deployment and during work order activity.
  - Shall verify that automated update agents and endpoint protection mechanisms are functional during support engagements.
- **Department Heads and Elected Officials:**
  - Shall coordinate with Information Operations to schedule maintenance windows for the deployment of patches affecting business-critical applications under their purview.
- **All County Personnel:**

  - Shall comply with reboot and update notifications issued by Information Operations within the timeframe specified in the notification.
  - Shall not disable, defer indefinitely, or circumvent automated update mechanisms or endpoint protection agents.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all individuals using or operating Elko County information systems.

- **Assessment**: Compliance with vulnerability and patch management requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Risk acceptance for unremediated vulnerabilities shall additionally follow the Risk Acceptance Memo procedure defined in **Policy 1.09**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning)
- CJIS Security Policy v6.0: Section RA-5(2) (Update Vulnerabilities to Be Scanned)
- CJIS Security Policy v6.0: Section RA-5(5) (Privileged Access)
- CJIS Security Policy v6.0: Section RA-5(11) (Public Disclosure Program)
- CJIS Security Policy v6.0: Section SI-2 (Flaw Remediation)
- CJIS Security Policy v6.0: Section SI-5 (Security Alerts, Advisories, and Directives)

Framework Alignment:

- NIST CSF 2.0: ID.RA-01 (Vulnerabilities in Assets Are Identified, Validated, and Recorded)
- NIST SP 800-53 Rev. 5: RA-5 (Vulnerability Monitoring and Scanning)
- NIST SP 800-53 Rev. 5: SI-2 (Flaw Remediation)
- NIST SP 800-53 Rev. 5: SI-5 (Security Alerts, Advisories, and Directives)

- COBIT 2019: BAI03 (Manage Solutions Identification and Build)
- COBIT 2019: DSS05 (Manage Security Services)
- ITIL v4: Change Enablement Practice
- ITIL v4: Information Security Management Practice
- ITIL v4: Release Management Practice

6. Policy Statement

6.1 Inventory Inputs

- **Hardware Inventory Source**: The Systems Administrator and the Network Administrator shall scope vulnerability scanning to the asset inventory maintained under **Policy 1.12** (IT Asset Management Policy).
- **Software Inventory Source**: The Systems Administrator shall scope patch targeting and vulnerability identification to the software inventory and the field set defined in **Policy 1.12**.
- **Vulnerability Management Augmentation**: The Systems Administrator shall maintain vulnerability management metadata linked to each software inventory record. At a minimum, the augmentation set shall include the following:
  - **CVE Cross-Reference**: The Common Vulnerabilities and Exposures (CVE) identifiers known to affect the recorded software version.
  - **Current Patch State**: The patch level installed on each instance, expressed as the vendor-defined version, build, or update identifier.
  - **Last-Scan Timestamp**: The date and time of the most recent vulnerability scan that evaluated the recorded instance.

6.2 Security Advisories and Directives

- **Intake**: The Assistant IT Director shall subscribe to and review security alerts, advisories, and directives from authoritative external sources, including the Multi-State Information Sharing and Analysis Center (MS-ISAC), the Cybersecurity and Infrastructure Security Agency (CISA), the United States Computer Emergency Readiness Team (US-CERT), federal and state advisories, and vendor security feeds for products in the asset inventory.
- **Dissemination**: The Assistant IT Director shall route applicable advisories to the Systems Administrator and the Network Administrator within one (1) business day of receipt for review and applicability determination.
- **Implementation**: The Systems Administrator and the Network Administrator shall implement remediation actions identified in advisories or directives within the timelines established for the corresponding severity in this policy, consistent with CJIS Security Policy v6.0: Section SI-5 (Security Alerts, Advisories, and Directives).
- **Internal Generation**: The Assistant IT Director shall generate internal advisories where threat conditions affecting County assets warrant action beyond the scope of an external advisory.
- **Public Vulnerability Reporting Channel**:
  - The Assistant IT Director shall maintain a publicly available email address for the receipt of vulnerability reports concerning County information systems from external sources, consistent with CJIS Security Policy v6.0: Section RA-5(11) (Public Disclosure Program).
  - The Assistant IT Director shall triage reports received through the public reporting channel under this policy.

  - The Assistant IT Director shall escalate confirmed or suspected exploitation arising from a public vulnerability report under **Policy 4.02** (Identification and Reporting Procedures).

- **Noncompliance Notification**: Where a directive cannot be implemented within the established timeframe, the Assistant IT Director shall notify the issuing organization of the degree of noncompliance and shall document the deviation in accordance with **Policy 5.01**.

6.3 Vulnerability Scanning and Identification

- **Automated Scanning**: The Systems Administrator and the Network Administrator shall employ automated tools to perform vulnerability scans on all active assets within the scope of this policy.
- **External-Facing Systems**: For purposes of this policy, external-facing systems are systems, services, interfaces, gateways, web applications, application programming interfaces (APIs), mail gateways, and cloud services reachable from the public Internet or from networks not owned or operated by Elko County.
- **Scanning Frequency**:
  - The Systems Administrator and the Network Administrator shall scan internal systems no less frequently than monthly.
  - The Network Administrator shall scan external-facing systems no less frequently than weekly.
  - The Systems Administrator and the Network Administrator shall scan systems that process, store, or transmit CJI at the stricter of the monthly internal-systems baseline or the cadence required by CJIS Security Policy v6.0: Section RA-5 (Vulnerability Monitoring and Scanning).
  - The Systems Administrator or the Network Administrator shall initiate an ad-hoc scan within seventy-two (72) hours of the publication of a Critical severity vendor security advisory affecting County assets.
- **Scan Content Currency**: The Systems Administrator shall update vulnerability scanning tool content within twenty-four (24) hours prior to each scheduled scan and upon receipt of notification of new vulnerabilities affecting County assets, consistent with CJIS Security Policy v6.0: Section RA-5(2) (Update Vulnerabilities to Be Scanned).
- **Authenticated Scanning**:
  - The Systems Administrator and the Network Administrator shall perform vulnerability scans using privileged credentials.
  - The Systems Administrator and the Network Administrator shall perform authenticated scans on all systems that process, store, or transmit CJI, consistent with CJIS Security Policy v6.0: Section RA-5(5) (Privileged Access).
  - The Systems Administrator or the Network Administrator shall submit an exception under **Policy 5.01** for any asset whose architecture does not support privileged-credential scanning.
- **Asset Discovery**: The Systems Administrator and the Network Administrator shall configure scanning tools to identify devices connected to County networks and to flag devices that are not present in the asset inventory.
- **Unauthorized Device Routing**: The Systems Administrator or the Network Administrator who identifies through asset discovery a device that is not present in the asset inventory shall report the device as an Indicator of Compromise in accordance with **Policy 4.02**.

6.4 Vulnerability Scoring and Prioritization

- **Scoring Standard**: The Systems Administrator and the Network Administrator shall assess vulnerabilities using the Common Vulnerability Scoring System (CVSS) version 3.1 or a successor version adopted by the IT Director.

- **Severity Categories**:
  - **Critical**: CVSS base score of 9.0 through 10.0.
  - **High**: CVSS base score of 7.0 through 8.9.
  - **Medium**: CVSS base score of 4.0 through 6.9.
  - **Low**: CVSS base score of 0.1 through 3.9.
- **Prioritization**: The Systems Administrator and the Network Administrator shall prioritize remediation by combining the CVSS base score with the asset criticality classification defined in **Policy 1.11** and the asset support classification defined in **Policy 1.12**.

6.5 Patch Management and Remediation Timelines

- **Remediation Mandate**: The Systems Administrator and the Network Administrator shall test and deploy security patches, firmware updates, or compensating controls within the following timelines, measured from the date of vendor release or vulnerability discovery, whichever is earlier, consistent with CJIS Security Policy v6.0: Section SI-2 (Flaw Remediation):
  - **Critical Severity**: Within fifteen (15) calendar days.
  - **High Severity**: Within thirty (30) calendar days.
  - **Medium Severity**: Within sixty (60) calendar days.
  - **Low Severity**: Within ninety (90) calendar days.
- **Patch Testing**: The Systems Administrator and the Network Administrator shall test patches on a non-production subset of representative systems prior to County-wide deployment to identify operational impact.
- **Emergency Patch Testing**:
  - **Exception**: The IT Director may authorize expedited patch deployment without full non-production testing where active exploitation of a Critical severity vulnerability creates immediate operational risk.
  - The Systems Administrator or the Network Administrator shall document compensating monitoring and rollback steps within the Emergency Change record under **Policy 3.09** (Change Management Policy).
- **Automated Updates**:
  - The Systems Administrator shall configure workstations and endpoints to install security-relevant updates automatically.
  - The Systems Administrator shall obtain a Risk Acceptance Memo approved under **Policy 1.09** for any deviation from automatic installation.
- **Change Authorization**:
  - The Systems Administrator and the Network Administrator shall authorize patch deployments in accordance with **Policy 3.09**.
  - The Systems Administrator and the Network Administrator may implement patches as Standard Changes when a documented procedure exists in the Knowledge Base.
  - The Systems Administrator and the Network Administrator shall follow the Emergency Change procedure for patching that cannot await standard authorization.
- **Isolation of Unremediated Critical Vulnerabilities**: The Network Administrator shall logically isolate from production networks any system with Critical severity vulnerabilities that remain unremediated past the timeline defined in this section, where no Risk Acceptance Memo has been approved under

Policy 1.09. The Network Administrator shall maintain logical isolation until remediation is complete or a Risk Acceptance Memo is in place.

6.6 Unsupported Software (End-of-Life)

- **Prohibition**: The Systems Administrator and the Network Administrator shall not deploy or maintain software, firmware, or operating systems that have reached End-of-Life or End-of-Support status as declared by the vendor on County networks.
- **Migration Plan**:
  - The Assistant IT Director shall present a migration plan to the IT Director for any asset approaching End-of-Life, not later than ninety (90) calendar days prior to the vendor's declared End-of-Life date.
  - The IT Director shall approve the migration plan.
- **Continued-Use Compensating Controls**: Where End-of-Life software remains in use to support a critical business function, the IT Director shall require all of the following before authorizing continued use:
  - The Assistant IT Director shall obtain a Risk Acceptance Memo approved under **Policy 1.09**.
  - The Network Administrator shall enforce network isolation by air-gap or strict firewall segregation from the general County network and from external networks.
  - The Systems Administrator and the Network Administrator shall not permit CJI processing, storage, or transmission on the affected asset.

6.7 Verification and Rescanning

- **Validation**: The Systems Administrator and the Network Administrator shall verify remediation actions through a follow-up vulnerability scan or by manual verification within seven (7) calendar days of patch deployment.
- **False-Positive Disposition**:
  - The Systems Administrator or the Network Administrator who marks a vulnerability as a false positive shall validate the determination.
  - The Systems Administrator or the Network Administrator shall document supporting evidence for the false-positive determination.
  - The Systems Administrator or the Network Administrator shall record the false-positive disposition in the scanning tool.
  - The Assistant IT Director shall review false-positive designations no less frequently than annually for continued accuracy.

6.8 Reporting

- **Domain-Specific Inputs**: The Systems Administrator and the Network Administrator shall each prepare monthly inputs covering open vulnerabilities by severity, Mean Time to Remediate (MTTR), patch compliance percentage, and the list of overdue assets within their respective domains.
- **Compilation**:
  - The Assistant IT Director shall compile the domain-specific inputs into a Monthly Vulnerability Compliance Report.
  - The Assistant IT Director shall perform cross-domain analysis prior to submission.

- **Submission**: The Assistant IT Director shall submit the Monthly Vulnerability Compliance Report to the IT Director not later than the tenth (10th) calendar day of the following month.

6.9 Cloud and Third-Party Systems

- **Shared Responsibility**: For cloud-based systems, including Software-as-a-Service (SaaS), Infrastructure-as-a-Service (IaaS), and Platform-as-a-Service (PaaS) deployments, the Assistant IT Director shall ensure that the contract or Service Level Agreement specifies the vendor's responsibility for vulnerability scanning and patch deployment.
- **Vendor Vulnerability Assurance**:
  - The Assistant IT Director shall evaluate vendor vulnerability management practices, including scan cadence, remediation timelines, and incident notification commitments, in coordination with the supply chain governance program defined in **Policy 1.13**.
  - The Assistant IT Director shall evaluate vendor security attestations, including Service Organization Control (SOC) 2 Type II reports and ISO/IEC 27001 certifications, specifically for vulnerability management adequacy.
  - The Assistant IT Director shall evaluate FedRAMP authorization status for federal-tier cloud services in the asset inventory.

2.10 Secure Configuration Baselines and Hardening Policy

Effective: July 01, 2026 Version: 2.3

1. Purpose

This policy establishes the secure configuration baselines, hardening requirements, and configuration compliance monitoring obligations for all Elko County information systems.

2. Scope

This policy applies to all Elko County information systems, networks, endpoints, applications, and supporting infrastructure owned, leased, operated, or managed by Elko County, and to all County Personnel, contractors, and third-party vendors interacting with these systems.

- **In Scope**:
  - Establishment and maintenance of secure configuration baselines from DISA Security Technical Implementation Guides (STIGs) and CIS Benchmarks.
  - Application of approved baselines to assigned server, endpoint, and network assets prior to production deployment and throughout the asset lifecycle.
  - Default account, credential, and least-functionality hardening.
  - Configuration change control through the Configuration Control Authority (CCA).
  - Continuous monitoring of baseline compliance and drift detection.
  - Identification and routing of unauthorized systems and remediation of baseline drift on registered systems.
  - Network topological documentation under configuration control.
- **Out of Scope**:
  - Configuration item record governance and the CMDB minimum field set: **Policy 3.08**.
  - Change authorization mechanics and the Request for Change (RFC) lifecycle: **Policy 3.09**.
  - Vulnerability scanning and patch management: **Policy 2.09**.
  - Operational incident triage of unregistered or anomalous systems detected on the County network: **Policy 3.06**.
  - Indicator of Compromise (IoC) evaluation and Chapter 4 lifecycle handling: **Policy 4.02**.
  - Risk Acceptance Memo procedure for unremediated baseline deviations: **Policy 1.09**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall serve as the final approval authority for all enterprise baseline configuration standards.
  - Shall exercise the Local Agency Security Officer (LASO) designation under **Policy 1.11** (Data Governance and Classification Policy) for configuration decisions affecting CJI systems.
  - Shall approve risk acceptance for unremediated baseline deviations per **Policy 1.09** (Risk Management Policy).

  - Shall approve any exception to this policy in writing per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Assistant IT Director:**
  - Shall define secure configuration benchmarks based on the frameworks identified in Section 6.1 of this policy.
  - Shall audit baseline compliance across all operational domains.
  - Shall mandate remediation for non-compliant assets within the timelines defined in Section 6.6 of this policy.
  - Shall maintain the registry of approved baseline standards in coordination with **Policy 3.08** (Service Configuration Management (CMDB) Policy).
- **Systems Administrator:**
  - Shall engineer, apply, and maintain approved configuration baselines on all assigned server and endpoint computing assets prior to production deployment.
  - Shall maintain compliance with approved baselines throughout the asset lifecycle.
- **Network Administrator:**
  - Shall engineer, apply, and maintain approved configuration baselines on all assigned network infrastructure, boundary protection, and communication assets prior to production deployment.
  - Shall maintain compliance with approved baselines throughout the asset lifecycle.
- **All Information Operations Personnel:**
  - Shall modify established configuration baselines only through the formal Change Management process defined in **Policy 3.09** (Change Management Policy).
  - Shall route systems detected on the County network without an approved baseline to operational triage under **Policy 3.06** (Operational Incident Management Policy).
- **All County Personnel:**
  - Shall not connect unauthorized devices to the County network.
  - Shall not modify, disable, or circumvent approved configuration baselines on assigned County devices.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all personnel involved in the configuration, deployment, or maintenance of Elko County information systems.

- **Assessment**: Compliance with secure configuration baseline requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Risk acceptance for unremediated baseline deviations shall additionally follow the Risk Acceptance Memo procedure defined in **Policy 1.09**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- CJIS Security Policy v6.0: Section CM-2 (Baseline Configuration)
- CJIS Security Policy v6.0: Section CM-2(2) (Automation Support for Accuracy and Currency)
- CJIS Security Policy v6.0: Section CM-2(3) (Retention of Previous Configurations)
- CJIS Security Policy v6.0: Section CM-5 (Access Restrictions for Change)
- CJIS Security Policy v6.0: Section CM-7 (Least Functionality)
- CJIS Security Policy v6.0: Section CM-7(1) (Periodic Review)
- Center for Internet Security (CIS): CIS Benchmarks
- Defense Information Systems Agency (DISA): Security Technical Implementation Guides (STIGs)

Framework Alignment:

- CJIS Security Policy v6.0: Section CM-1 (Configuration Management Policy and Procedures)
- CJIS Security Policy v6.0: Section CM-6 (Configuration Settings)
- CJIS Security Policy v6.0: Section CM-8 (System Component Inventory)
- CJIS Security Policy v6.0: Section CM-9 (Configuration Management Plan)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)
- NIST SP 800-53 Rev. 5: CM-1 (Configuration Management Policy and Procedures)
- NIST SP 800-53 Rev. 5: CM-2 (Baseline Configuration)
- NIST SP 800-53 Rev. 5: CM-2(2) (Automation Support for Accuracy and Currency)
- NIST SP 800-53 Rev. 5: CM-2(3) (Retention of Previous Configurations)
- NIST SP 800-53 Rev. 5: CM-5 (Access Restrictions for Change)
- NIST SP 800-53 Rev. 5: CM-6 (Configuration Settings)
- NIST SP 800-53 Rev. 5: CM-7 (Least Functionality)
- NIST SP 800-53 Rev. 5: CM-7(1) (Periodic Review)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)

- NIST SP 800-53 Rev. 5: CM-9 (Configuration Management Plan)
- COBIT 2019: BAI10.01 (Establish and maintain a configuration model)
- COBIT 2019: BAI10.02 (Establish and maintain a configuration repository and baseline)
- COBIT 2019: BAI10.03 (Maintain and control configuration items)
- ITIL v4: Service Configuration Management Practice
- ITIL v4: Change Enablement Practice

6. Policy Statement

Secure configuration of information systems is the foundation of system integrity and the principle of least functionality. By establishing, enforcing, and continuously monitoring approved baselines, ECIO minimizes the organizational attack surface and protects the confidentiality, integrity, and availability of County systems, with specific emphasis on environments processing Criminal Justice Information (CJI).

6.1 Baseline Configuration Establishment

The Assistant IT Director shall establish, document, and maintain secure configuration baselines for all Elko County information systems, consistent with CJIS Security Policy v6.0: Section CM-2 (Baseline Configuration). The Assistant IT Director shall derive baselines from Defense Information Systems Agency (DISA) Security Technical Implementation Guides (STIGs). Where an applicable DISA STIG does not exist for a specific system class, the Assistant IT Director shall use the Center for Internet Security (CIS) Benchmark at Level 2 or higher as the mandatory fallback baseline standard. The Assistant IT Director shall document the absence of an applicable STIG and the use of the CIS fallback in the System Security Plan (SSP). The Assistant IT Director shall review and update these baselines at least annually, or upon the introduction of a new system architecture, to maintain alignment with the current approved release of the applicable STIG or CIS Benchmark.

The Assistant IT Director shall retain at least one (1) prior approved version of the baseline configuration for each system to support rollback capability, consistent with CJIS Security Policy v6.0: Section CM-2(3) (Retention of Previous Configurations).

6.2 Network Topological Drawing

The Network Administrator shall develop, document, and maintain under configuration control a current and complete topological drawing depicting the interconnectivity of the County network to criminal justice information systems and services. The Network Administrator shall review and update this drawing at least annually, upon security-relevant system changes, and when network components are installed or upgraded.

6.3 Principle of Least Functionality and System Hardening

The Systems Administrator and the Network Administrator shall configure each information system to provide only essential capabilities, consistent with CJIS Security Policy v6.0: Section CM-7 (Least Functionality). Prior to production deployment, the Systems Administrator and the Network Administrator shall enable only those services, daemons, ports, protocols, and applications that are both explicitly justified in the approved System Security Plan (SSP) and authorized by the approved baseline.

The Assistant IT Director shall ensure that systems in production at the effective date of this policy are assessed against the applicable baseline within ninety (90) days of the effective date. The responsible Systems Administrator or Network Administrator shall remediate non-compliant systems, or formally except them under Section 4 of this policy, within one hundred eighty (180) days.

The Assistant IT Director shall conduct a least-functionality review of County information systems at least annually, upon security-relevant system changes, and when incidents identify unnecessary functions, ports,

protocols, software, or services, consistent with CJIS Security Policy v6.0: Section CM-7(1) (Periodic Review). The Systems Administrator and the Network Administrator shall remediate or formally except findings from each review under Section 4 of this policy.

6.4 Default Account and Credential Hardening

The Systems Administrator and the Network Administrator shall disable, rename, or strictly restrict all default, guest, and built-in vendor accounts before an asset is joined to the production network. The Systems Administrator and the Network Administrator shall change all default authentication credentials to meet current enterprise cryptographic and complexity standards prior to deployment.

6.5 Configuration Change Control

Information Operations Personnel shall not modify established configuration baselines except through the formal Change Management process defined in **Policy 3.09**. The Systems Administrator and the Network Administrator shall submit a Request for Change (RFC) and receive Configuration Control Authority (CCA) approval prior to altering configuration settings on production systems, consistent with CJIS Security Policy v6.0: Section CM-5 (Access Restrictions for Change). Information Operations Personnel executing emergency changes shall follow the emergency change procedure and complete catch-up documentation and CCA review in accordance with the timelines established in **Policy 3.09**.

6.6 Continuous Monitoring and Enforcement

The Assistant IT Director shall deploy automated mechanisms to monitor systems for deviations from their approved DISA STIG or CIS baselines, scoped to the asset inventory maintained under **Policy 1.12** (IT Asset Management Policy), consistent with CJIS Security Policy v6.0: Section CM-2(2) (Automation Support for Accuracy and Currency). The Assistant IT Director shall configure automated monitoring to generate a work order upon detection of a deviation. The responsible Systems Administrator or Network Administrator shall classify the deviation work order at the severity produced by the standard priority calculation, and shall remediate the deviation within the response and resolution timeframes defined in **Policy 3.01** (Service Catalog and SLA Policy). Where a Critical severity baseline deviation cannot be remediated within the resolution timeframe defined in **Policy 3.01**, the responsible administrator shall logically isolate the affected asset from the production network until remediation is complete. The responsible Systems Administrator or Network Administrator shall escalate any deviation not remediated within the assigned SLA to the IT Director and document it as an open exception in accordance with Section 4 of this policy.

6.7 Unauthorized System Detection and Routing

The Assistant IT Director, the Systems Administrator, or the Network Administrator who detects a system on the County network that is not registered in the System of Engagement and lacks an approved configuration baseline shall report the system as an operational incident under **Policy 3.06** for triage.

The responsible Systems Administrator or Network Administrator shall remediate any registered County system found operating without the applicable approved baseline (e.g., baseline drift, missed initial application, or post-rebuild configuration gap) through the Configuration Change Control process defined in Section 6.5 of this policy and **Policy 3.09**. Information Operations Personnel shall not route such cases through the incident response lifecycle.

2.11 Audit Logging and Monitoring Policy

Effective: April 29, 2026 Version: 2.5

1. Purpose

This policy establishes the requirements for the generation, protection, review, and retention of security audit logs across all Elko County information systems.

2. Scope

This policy applies to all County information systems, network infrastructure, endpoints, and cloud services that process, store, or transmit County data, and to all Information Operations personnel and County Personnel who generate, configure, review, or interact with audit records produced by those systems.

- **In Scope**:
  - Security audit record generation by County information systems.
  - Centralized log management infrastructure, including aggregation, storage, and tamper protection.
  - Audit review, analysis, and alerting processes.
  - Records retention and disposition of security audit logs.
  - Routing of audit findings to downstream response, problem management, and compliance monitoring processes.
- **Out of Scope**:
  - Operational performance logging, including resource utilization and service health metrics: **Policy 3.12**.
  - Physical security logs, including facility access records and video surveillance: **Policy 2.13**.
  - Evidentiary collection during active operational incident response: **Policy 3.06**.
  - Evidentiary collection and chain-of-custody during active cybersecurity incident response: **Policy 4.03**.
  - Internal audit working papers and audit engagement records: **Policy 5.02**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall serve as the final authority on audit logging requirements under this policy.
  - Shall ensure configurations for systems processing Criminal Justice Information (CJI) meet the audit and accountability mandates of the FBI Criminal Justice Information Services (CJIS) Security Policy.
  - Shall retain non-delegable accountability for Local Agency Security Officer (LASO) obligations to the CJIS Systems Agency in accordance with **Policy 1.11** (Data Governance and Classification Policy).
  - Shall approve exceptions to this policy in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

  - Shall suspend automated and manual log disposition actions during active legal holds in accordance with **Policy 1.11**.
  - Shall review the meta-log of centralized log repository access on a quarterly basis to identify anomalous access patterns by authorized personnel.
- **County Manager:**
  - Shall approve policy exceptions that exceed the IT Director's delegated authority in accordance with **Policy 5.01**.
  - Shall serve as the escalation authority for enforcement disputes that cannot be resolved at the IT Director level.
- **Assistant IT Director:**
  - Shall oversee the centralized log management architecture.
  - Shall allocate audit record storage capacity sufficient to prevent logs from being overwritten or dropped prior to scheduled archival.
  - Shall ensure automated audit review mechanisms are configured to alert on anomalous activities in accordance with Section 6.5.
  - Shall ensure designated Tier L3 personnel conduct formal review of aggregated security audit logs no less than weekly, evidenced by a documented review record in the System of Engagement.
  - Shall initiate Problem record intake when weekly audit review identifies a pattern satisfying the Recurring Incident spawn trigger defined in **Policy 3.07** (Problem Management Policy).
  - Shall coordinate response activities triggered by audit findings in accordance with **Policy 4.01** (Incident Response Policy Overview) and **Policy 4.02** (Identification and Reporting Procedures).
- **System and Network Administrators:**
  - Shall configure information systems to generate required audit records in accordance with Section 6.1.
  - Shall forward audit records to the centralized log repository in accordance with Section 6.3.
  - Shall review automated security alerts within the service levels defined in Section 6.5.
  - Shall protect log facilities from unauthorized access in accordance with Section 6.4.
  - **Constraint**: Personnel administering security access controls shall not modify or delete audit logs that record their own actions, nor serve as the sole reviewers of their own administrative logs, in accordance with the Separation of Duties Matrix maintained under **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Department Heads:**
  - Shall identify business or regulatory logging requirements applicable to their departmental data.
  - Shall coordinate implementation of those requirements with the Information Operations Department.
- **All County Personnel:**
  - Shall not disable, bypass, or tamper with system auditing functions.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel and all County Personnel interacting with systems subject to this policy.

- **Assessment**: Adherence to this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: The IT Director shall enforce compliance with this policy. Repeated non-compliance may be escalated under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification, compensating controls, and proposed duration, and shall be approved in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: No exception approved under this policy shall authorize the destruction or modification of audit records outside the retention and disposition framework of **Policy 1.11**, nor the suspension of legal hold preservation obligations defined in Section 6.8 or Section 6.9.
- **Sanctions**: The following acts constitute severe security violations of this policy. Upon confirmed occurrence of any such act, the consequences defined in this bullet apply.
  - **Prohibited Act — Tampering**: Disabling, bypassing, or tampering with audit logging mechanisms.
  - **Prohibited Act — Record Destruction**: Unauthorized modification, deletion, or export of audit records.
  - **Prohibited Act — Legal Hold Violation**: Failure to preserve audit records during an active legal hold, public records preservation requirement, audit, or incident investigation.
  - **Prohibited Act — Self-Review**: Serving as the sole reviewer of one's own administrative logs in violation of the Separation of Duties Constraint established in Section 3.
  - **Immediate Access Revocation**: The IT Director shall direct the immediate revocation of the violating account's access in accordance with the Involuntary Termination procedure defined in **Policy 2.04** (Access Control Policy).
  - **Disciplinary Execution**: Disciplinary action shall be executed through the enforcement framework established in **Policy 5.01**.
  - Conduct meeting the elements of NRS 205.4765 (Unlawful acts regarding computers) shall be referred for criminal prosecution through the County's legal process.
- **Universal Applicability**: This policy applies to all County information systems regardless of physical location, operational schedule, or delegation status.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy

- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205.4765 (Unlawful acts regarding computers)
- CJIS Security Policy v6.0: Section AU-2 (Event Logging)
- CJIS Security Policy v6.0: Section AU-3 (Content of Audit Records)
- CJIS Security Policy v6.0: Section AU-4 (Audit Log Storage Capacity)
- CJIS Security Policy v6.0: Section AU-5 (Response to Audit Logging Process Failures)
- CJIS Security Policy v6.0: Section AU-6 (Audit Record Review, Analysis, and Reporting)
- CJIS Security Policy v6.0: Section AU-7 (Audit Record Reduction and Report Generation)
- CJIS Security Policy v6.0: Section AU-8 (Time Stamps)
- CJIS Security Policy v6.0: Section AU-9 (Protection of Audit Information)
- CJIS Security Policy v6.0: Section AU-11 (Audit Record Retention)
- CJIS Security Policy v6.0: Section AU-12 (Audit Record Generation)
- NIST SP 800-53 Rev. 5: AU-2 (Event Logging)
- NIST SP 800-53 Rev. 5: AU-3 (Content of Audit Records)
- NIST SP 800-53 Rev. 5: AU-4 (Audit Log Storage Capacity)
- NIST SP 800-53 Rev. 5: AU-5 (Response to Audit Logging Process Failures)
- NIST SP 800-53 Rev. 5: AU-6 (Audit Record Review, Analysis, and Reporting)
- NIST SP 800-53 Rev. 5: AU-7 (Audit Record Reduction and Report Generation)
- NIST SP 800-53 Rev. 5: AU-8 (Time Stamps)
- NIST SP 800-53 Rev. 5: AU-9 (Protection of Audit Information)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: AU-12 (Audit Record Generation)

Framework Alignment:

- NIST CSF 2.0: DE.AE-02 (Potentially adverse events are analyzed to better understand associated activities)
- NIST CSF 2.0: DE.AE-03 (Information is correlated from multiple sources)

- NIST CSF 2.0: DE.AE-06 (Information on adverse events is provided to authorized staff and tools)
- NIST CSF 2.0: DE.AE-08 (Incidents are declared when adverse events meet the defined incident criteria)
- NIST CSF 2.0: DE.CM-03 (Personnel activity and technology usage are monitored to find potentially adverse events)
- NIST CSF 2.0: DE.CM-09 (Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events)
- COBIT 2019: DSS05.07 (Monitor the infrastructure for security-related events)

6. Policy Statement

The accurate recording of system activity is essential to detecting unauthorized access, supporting forensic investigations, maintaining individual accountability, and satisfying the audit and accountability mandates of the CJIS Security Policy and Nevada Revised Statutes. This policy defines the requirements that govern the generation, protection, review, and retention of security audit logs, and establishes the routing by which audit findings enter the incident response, problem management, and compliance monitoring processes of the Information Operations Policy Manual.

6.1 Auditable Events

The Assistant IT Director shall ensure County information systems, network infrastructure, and cloud environments are configured to generate audit records for security-relevant events. At a minimum, the following events shall be logged:

- **Authentication and Access**: All successful and unsuccessful logon attempts, session disconnections, and access to systems processing Criminal Justice Information (CJI) or Restricted data classified under **Policy 1.11**. Account-state transitions governed by **Policy 2.04** — including involuntary termination, standard termination, session timeout, and device lock — shall be captured with sufficient detail to verify compliance with the threshold requirements of **Policy 2.04**.
- **Privileged Operations**: All actions executed under elevated or administrative privileges, including "break-glass" emergency access. Privileged operations executed by personnel at Tier L3 (Administrator) or above under **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework) shall be captured with sufficient detail to identify the specific commands or administrative actions executed, the parameters supplied, and the resultant system or account state changes.
- **Account Management**: The creation, modification, enablement, disablement, and deletion of any system or user account.
- **Data Manipulation**: The creation, modification, and deletion of Restricted data (including CJI) and Confidential data classified under **Policy 1.11**.
- **Security Control Modifications**: Any modification to security baselines, firewall rules, group policies, or audit logging configurations. Configuration change events governed by **Policy 3.09** (Change Management Policy) shall be captured.
- **System Integrity**: System restarts, shutdowns, and alerts generated by malicious code protection or file integrity monitoring (FIM) mechanisms.

6.2 Content of Audit Records

To ensure forensic viability and individual accountability, every generated audit record shall contain the following mandatory data elements:

- **Timestamp**: The exact date and time the event occurred.

- **Identity**: The unique identifier (e.g., username, service account ID) of the individual or process causing the event.
- **Event Type**: A clear categorization of the action attempted or executed.
- **Outcome**: An indicator of success or failure.
- **Originating Source**: The logical or physical origin of the request (e.g., source IP address, MAC address, terminal identifier).
- **Target Asset**: The name, identifier, or file path of the system, application, or data record impacted by the event.
- **Clarification**: Audit records capturing personally identifiable information — including usernames, network addresses, and data manipulation records — inherit the privacy controls defined in **Policy 2.06** (Privacy and Data Protection Policy). Standing up a new centralized log aggregation system or extending an existing system to process a new personal information category may qualify as a Privacy Impact Assessment trigger under **Policy 2.06**.

6.3 Log Centralization, Capacity, and Tamper Protection

To satisfy separation of duties and protect audit integrity, the Information Operations Department shall configure audit logs to be protected from unauthorized modification, deletion, and spoofing.

- **Storage Capacity**: The Assistant IT Director shall allocate audit record storage capacity sufficient to prevent logs from being overwritten or dropped prior to scheduled archival.
- **Centralized Repository**: The System and Network Administrators shall configure information systems to forward audit records continuously to a centralized, logically isolated log management repository. Batch forwarding intervals shall not exceed fifteen (15) minutes.
- **Append-Only Enforcement**: The Assistant IT Director shall enforce append-only or read-only privileges for all System and Network Administrators on the centralized repository. Personnel with administrative control over security baselines or system configurations shall not possess the capability to modify or delete audit logs that record their actions, in accordance with the Separation of Duties Matrix maintained under **Policy 1.08**.
- **Tamper Detection**: The Assistant IT Director shall ensure the centralized log repository employs cryptographic mechanisms — including file hashing — and access control monitoring to detect unauthorized modifications to archived log files.

6.4 Log Repository Access Controls

The Information Operations Department shall control and monitor access to the centralized log repository to preserve audit record integrity and confidentiality.

- **Access Authorization**: The IT Director shall approve all accounts granted read access to the centralized log repository. Base access control under **Policy 2.04** applies; this section establishes additional audit-specific controls.
- **Read-Only by Default**: The Assistant IT Director shall configure the default access level for authorized personnel as read-only. Write access to the repository shall be restricted to designated administrative service accounts.
- **Administrator Separation**: Personnel whose routine duties include administering systems that generate audit records shall not serve as the sole reviewer of their own administrative logs, in accordance with **Policy 1.08**.
- **Meta-Logging**: The Assistant IT Director shall ensure all access to the centralized log repository — including read, query, and export operations — is itself logged in the repository.

- **Export Controls**: The Assistant IT Director shall restrict log extraction to named administrators authorized for forensic support, compliance reporting, or legal hold response. Exported audit records shall inherit the classification of the source data and shall be handled in accordance with **Policy 1.11**.
- **Audit-of-the-Auditor Review**: The IT Director shall review the meta-log of repository access no less than quarterly to identify anomalous access patterns by authorized personnel.

6.5 Audit Review, Analysis, Alerting, and Finding Routing

The Information Operations Department shall proactively analyze audit records to detect anomalous activity, unauthorized access attempts, and potential security incidents, and shall route findings to appropriate downstream response and compliance processes.

- **Review Frequency**: The Assistant IT Director shall ensure designated Tier L3 personnel conduct formal review of aggregated security audit logs no less than weekly, evidenced by a documented review record in the System of Engagement.
- **Automated Alerting**: The Assistant IT Director shall ensure automated tools are configured to generate real-time alerts for critical security events, including multiple failed authentication attempts, unauthorized access to CJI repositories, and detection of malicious code.
- **Alert Routing**: System-generated security alerts shall be transmitted in real-time to the Assistant IT Director and designated Tier L3 System Administrators.
- **Alert Review Service Levels**: Designated Tier L3 Administrators shall acknowledge and review alerts within the following time windows, measured from alert generation:
  - **Critical**: Acknowledgment and triage initiation within fifteen (15) minutes, twenty-four (24) hours per day, seven (7) days per week. Full review shall complete within the High tier window. Applies to confirmed Indicator of Compromise (IoC) conditions, unauthorized access to CJI, and confirmed malicious code execution.
  - **High**: Full review within one (1) hour, twenty-four (24) hours per day, seven (7) days per week. Applies to multiple failed authentication events, privileged operation anomalies, and unauthorized configuration changes.
  - **Medium and Routine**: By the end of the next business day. Applies to informational security events and single-threshold failed authentication events.
  - **Tier Assignment**: The Assistant IT Director shall establish alert tier assignments in the alerting configuration. Tier assignments shall be reviewable during scheduled audit.
- **Finding Routing**: Designated Tier L3 Administrators shall route audit findings to the appropriate downstream process:
  - Findings matching the IoC categories defined in **Policy 4.02** shall be routed to **Policy 4.02** intake via a Safety and Security category work order.
  - Confirmed operational security events not matching IoC criteria shall be routed to **Policy 3.06**.
  - Findings satisfying the Recurring Incident spawn trigger — five (5) or more same-category events within a rolling thirty (30) day window — shall prompt Problem record intake under **Policy 3.07**, initiated by the Assistant IT Director.
  - Findings identifying acceptable use violations without a security nexus shall be routed to **Policy 2.01** (Acceptable Use of Information Technology Resources Policy).
  - Findings requiring independent compliance evaluation shall be routed to **Policy 5.02** for internal audit scope consideration.

6.6 Response to Audit Logging Process Failures

The Information Operations Department shall detect audit logging process failures and route them to the appropriate response process within defined time windows.

- **Failure Alerting**: The Assistant IT Director shall configure the logging system to alert the Assistant IT Director and designated administrators within one (1) hour of an audit logging process failure, including software or hardware errors, network disruption, and storage threshold breaches.
- **Restoration and Routing**: Designated Tier L3 Administrators shall, within one (1) hour of receiving the failure alert, either:
  - Confirm a benign operational cause — including disk capacity exhaustion, service crash, or network segment outage — and proceed with restoration under **Policy 3.06**.
  - Create a Safety and Security category work order under **Policy 4.02** for Indicator of Compromise evaluation when the cause cannot be confirmed benign within the one (1) hour window or the failure pattern matches IoC Category A (Unauthorized Access or Access Anomaly), Category B (Malicious Code Activity), or Category F (Improper Use with Security Nexus) as defined in **Policy 4.02**.
- **Logical Isolation**: Decisions to logically isolate the affected system shall follow from **Policy 4.03** (Containment Strategy and Playbooks) when the failure routes to **Policy 4.02**, or from **Policy 3.06** when the failure proceeds as an operational incident.
- **Restart and Verification**: Upon remediation of the underlying cause, the Assistant IT Director shall restart all affected audit logging processes and verify end-to-end ingestion of audit records by the centralized log repository before closing the failure event. If end-to-end verification cannot be confirmed within the one (1) hour window established under Restoration and Routing, the failure shall be routed to **Policy 4.02** regardless of the apparent cause.
- **Outage Documentation**: The Assistant IT Director shall ensure each audit logging process failure is documented in the System of Engagement with the failure start time, end time, affected systems, apparent cause, actions taken, and end-to-end verification results.

6.7 Time Synchronization

To ensure accurate correlation of audit records across distinct systems, the System and Network Administrators shall synchronize all County information systems and network devices to an authoritative, County-approved Network Time Protocol (NTP) source.

- **Stratum-1 Source**: Primary internal NTP servers shall synchronize to Coordinated Universal Time (UTC) using a trusted, stratum-1 external time source.
- **UTC Recording**: All County information systems shall record audit record timestamps in Coordinated Universal Time (UTC) to ensure cross-system and cross-jurisdictional forensic correlation.
- **Timestamp Precision**: Audit record timestamps shall be recorded to hundredths-of-a-second precision, expressed in the format hh:mm:ss.ss.
- **Failure Handling**: Time synchronization failures shall be treated as audit logging process failures under Section 6.6.

6.8 Records Retention and Legal Hold

Audit logs constitute official County records. Retention and disposition of audit logs are governed by the retention authority chain established in **Policy 1.11**.

- **Records Custodian**: The IT Director, serving as the Information Operations Records Custodian under **Policy 1.11**, shall ensure audit logs generated under this policy are classified to the applicable Nevada Local Government Records Retention Schedule record series and retained accordingly.

- **Legal Hold Suspension**: The IT Director shall immediately suspend all automated and manual log disposition actions upon notification of any active legal hold, public records preservation requirement, audit, or incident investigation, in accordance with **Policy 1.11**.

6.9 Decommissioned-System Log Handling

When a County information system is scheduled for decommissioning under **Policy 1.12** (IT Asset Management Policy), retained audit logs generated by that system shall be preserved through the centralized log repository prior to media sanitization.

- **Custody Transfer**: The System and Network Administrator executing the decommissioning workflow shall verify that audit logs retained under Section 6.8 have been successfully transferred to the centralized log repository before initiating media sanitization under **Policy 2.12**.
- **Verification**: The Assistant IT Director shall confirm successful log transfer and record the confirmation in the decommissioning work order prior to sanitization approval.
- **Legal Hold**:
  - **Exception**: Assets subject to an active legal hold, public records preservation requirement, audit, or incident investigation shall not proceed to decommissioning. Such assets shall remain in documented chain of custody under tamper-evident seal until the hold is formally released or the asset is transferred to law enforcement or a County-approved third-party forensic examiner designated by the IT Director, in accordance with **Policy 1.12**. Imaging, extraction, or other surrogate preservation shall not substitute for physical custody of the asset during an active hold.

2.12 Media Protection and Sanitization Policy

Effective: April 29, 2026 Version: 2.5

1. Purpose

This policy governs the protection, access, transport, and verifiable sanitization of all physical and digital media storing Elko County information.

2. Scope

This policy applies to all Elko County Information Operations personnel, County employees, contractors, and third-party vendors who access, transport, store, or sanitize County media.

- **In Scope**:
  - Portable Storage Devices.
  - Optical Media.
  - Magnetic Tapes.
  - Solid-State Drives and Internal Hard Drives.
  - Networking Equipment Non-Volatile Memory.
  - Internal Storage Media within Multifunction Printers and Copiers.
  - Physical and Printed Media containing County Data.
- **Out of Scope**:
  - Logical Access Controls Governing Access to Media Contents: **Policy 2.04**.
  - Data Classification Level Assignment: **Policy 1.11**.
  - Asset Procurement and Lifecycle Governance: **Policy 1.12**.
  - Configuration Management Database Record Maintenance: **Policy 3.08**.
  - Incident Reporting Intake and CJIS Notification Mechanics: **Policy 4.02**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the Local Agency Security Officer (LASO) for CJIS media protection matters.
  - Shall direct the data disposition at vendor contract termination in accordance with Section 6.10.
- **Systems Administrators and Network Administrators:**
  - Shall execute media sanitization prior to disposal, release, external transfer, lease return, or internal reuse.
  - Shall perform post-sanitization verification as a secondary, independent reviewer for media that stores or has stored Criminal Justice Information (CJI).
  - Shall document each sanitization action in the Configuration Management Database (CMDB) in accordance with **Policy 3.08** (Service Configuration Management (CMDB) Policy).
- **Department Heads:**

  - Shall enforce destruction of physical documents generated within their departments in accordance with the classification level assigned under **Policy 1.11** (Data Governance and Classification Policy).
- **All County Personnel:**
  - Shall physically protect County media in their custody from unauthorized access, loss, or theft.
  - Shall report the loss, theft, or suspected compromise of County media in accordance with **Policy 4.02** (Identification and Reporting Procedures).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel and all County Personnel handling County media.

- **Assessment**: Adherence to this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: The IT Director shall enforce compliance with this policy. Repeated non-compliance may be escalated under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification, compensating controls, and proposed duration, and shall be approved in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.
- **Sanctions**: The following acts constitute severe security violations of this policy. Upon confirmed occurrence of any such act, the consequences defined in this bullet apply.
  - **Prohibited Act — Unauthorized Disposal**: Disposal, release, transfer, or reuse of County media without executing the sanitization procedures defined in Section 6.
  - **Prohibited Act — Unsanctioned Removable Media**: Use of personally owned removable media or other unsanctioned portable storage devices on Elko County information systems.
  - **Immediate Asset Confiscation**: The IT Director shall direct the immediate confiscation of implicated media and any system containing unsanctioned removable media.
  - **Immediate Access Revocation**: The IT Director shall direct the immediate revocation of the violating account's access in accordance with **Policy 2.04** (Access Control Policy).
  - **Disciplinary Execution**: Disciplinary action shall be executed through the enforcement framework established in **Policy 5.01**.
- **Universal Applicability**: This policy applies to all County media regardless of physical location, operational schedule, or lease ownership status.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management and Vendor Governance
- ECIO Policy 2.04: Access Control Policy

- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.210 (Security Measures for Personal Information)
- LRDA 20070440 (Fixed Assets and Inventories)
- NIST SP 800-53 Rev. 5: MP-6(7) (Dual Authorization)
- NIST SP 800-88 Rev. 1 (Guidelines for Media Sanitization)

Framework Alignment:

- CJIS Security Policy v6.0: Section MP-1 (Media Protection Policy and Procedures)
- CJIS Security Policy v6.0: Section MP-2 (Media Access)
- CJIS Security Policy v6.0: Section MP-3 (Media Marking)
- CJIS Security Policy v6.0: Section MP-4 (Media Storage)
- CJIS Security Policy v6.0: Section MP-5 (Media Transport)
- CJIS Security Policy v6.0: Section MP-6 (Media Sanitization)
- CJIS Security Policy v6.0: Section MP-7 (Media Use)
- NIST CSF 2.0: PR.DS-01 (Data-at-Rest Protection)
- NIST SP 800-53 Rev. 5: MP-1 (Media Protection Policy and Procedures)
- NIST SP 800-53 Rev. 5: MP-2 (Media Access)
- NIST SP 800-53 Rev. 5: MP-3 (Media Marking)
- NIST SP 800-53 Rev. 5: MP-4 (Media Storage)
- NIST SP 800-53 Rev. 5: MP-5 (Media Transport)
- NIST SP 800-53 Rev. 5: MP-6 (Media Sanitization)
- NIST SP 800-53 Rev. 5: MP-7 (Media Use)
- COBIT 2019: DSS05.06 (Manage Sensitive Documents and Output Devices)

6. Policy Statement

This policy prevents the unauthorized disclosure of Confidential and Restricted data, including Criminal Justice Information (CJI), by enforcing strict lifecycle constraints from media provisioning through destruction, consistent with FBI CJIS Security Policy v6.0 and NIST SP 800-88 Rev. 1.

6.1 Media Access and Storage

All County Personnel shall store physical and digital media containing Confidential or Restricted information (including CJI) within physically secure locations or locked containers when not in active use. Media shall only be accessible to authorized personnel with a validated business need-to-know. Removable digital media shall be encrypted using cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP) prior to storing any Level 3 (Confidential) or Level 4 (Restricted) data.

6.2 Media Marking and Labeling

All County Personnel shall mark or label physical media and removable digital media containing Confidential or Restricted data with the assigned classification level. Labels shall omit system-specific or operational details that could increase the risk of targeted theft.

- **Exception**: Media that cannot physically accept a label (e.g., micro-form factor storage, firmware-embedded media) shall be marked via the associated container or inventory record.

6.3 Media Transport

All County Personnel shall transport media containing Confidential or Restricted data using continuous chain-of-custody controls. Digital media in transit shall employ cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP). If physical media containing Restricted data (e.g., printed CJI) must be transported outside of a physically secure location, the media shall remain under the direct, continuous physical control of authorized personnel or be shipped via a tracked courier service utilizing signature verification upon delivery.

6.4 Digital Media Sanitization

Elko County retains drives at the end of their operational use rather than releasing them to external parties. Digital media removed from systems shall be retained for internal reuse subject to the classification constraints defined in this section, or physically destroyed. External release of digital media is prohibited except under the narrow fallback defined in this section.

Prior to sanitization of media from systems scheduled for decommissioning, Systems Administrators and Network Administrators shall confirm that audit log custody transfer under **Policy 2.11** (Audit Logging and Monitoring Policy) has been completed.

- **CJI Media — Destruction Only**: Media that stores or has stored Criminal Justice Information (CJI) shall be physically destroyed. CJI media shall not enter the internal reuse pool and shall not be released to external parties under any circumstance.
- **Internal Reuse — Clear**: Systems Administrators and Network Administrators may execute Clear on media that solely stored Level 1 (Public) or Level 2 (Internal Use) data when the media will be reused at the same or lower classification level.
- **Internal Reuse — Purge**: Systems Administrators and Network Administrators shall execute Purge on media that previously stored Level 3 (Confidential) or Level 4 (Restricted) non-CJI data prior to internal reuse. The Purge method shall be appropriate to the media architecture per NIST SP 800-88 Rev. 1 (e.g., Cryptographic Erase or firmware Block Erase for solid-state media; manufacturer-specified overwrite for magnetic media). Cryptographic Erase constitutes an acceptable Purge method only where the storage device natively supports it and employs cryptographic modules validated under the NIST Cryptographic Module Validation Program (CMVP).
- **Destroy**: Mandatory for End-of-Life (EOL) digital media and for any media that cannot be successfully purged. Destruction shall render the data permanently irretrievable and the media physically unusable.
- **Fallback — External Release Without Drive Retention**: Where operational circumstances preclude drive retention (e.g., pre-existing vendor leases lacking a "Keep Your Drive" provision under Section 6.8), Systems Administrators and Network Administrators shall execute Purge on-site using a vendor-provided factory overwrite utility or equivalent method appropriate to the media architecture per NIST SP 800-88 Rev. 1 before the drive leaves County custody. This fallback shall not apply to CJI media; CJI drives shall be removed and destroyed prior to asset return regardless of any contractual provision.
- **Networking Equipment**: Network Administrators shall sanitize networking equipment non-volatile memory using vendor-approved factory-reset commands or physical destruction.

- **Equipment Testing**: Systems Administrators and Network Administrators shall test sanitization equipment and procedures annually to verify that the intended sanitization is achieved.
- **Legal Hold**:
  - **Exception**: Assets subject to an active legal hold, public records preservation requirement, audit, or incident investigation shall not proceed to sanitization until the hold is formally released, consistent with **Policy 2.11**.

6.5 Physical Media Sanitization and Destruction

All County Personnel shall destroy physical media (e.g., paper documents) containing Confidential or Restricted data when no longer required, executing a method that renders the information unrecoverable (e.g., cross-cut shredding or incineration). The destruction of physical media containing Personally Identifiable Information (PII) shall comply with the destruction standards mandated by NRS 603A.210. All County Personnel shall not place intact physical media containing sensitive data into standard waste or recycling receptacles.

6.6 Records of Sanitization, Disposal, and Verification

Systems Administrators and Network Administrators shall comprehensively document and verify all sanitization and disposal actions for IT-managed assets. Required documentation shall include the date of sanitization, the unique Asset Identifier (Tag ID), the specific sanitization method utilized, the final disposition of the media, the identity of the personnel executing the sanitization, and the identity of the personnel performing the post-sanitization verification.

For media that stores or has stored Criminal Justice Information (CJI), the post-sanitization verification shall be performed by a secondary, independent Systems Administrator or Network Administrator who did not execute the initial sanitization, consistent with NIST SP 800-53 Rev. 5: MP-6(7) (Dual Authorization). Verification shall consist of a documented test read or visual inspection to confirm the sanitization was effective.

Electronic waste (E-Waste) transferred to approved third-party recycling vendors shall be accompanied by a vendor-issued Certificate of Destruction.

- **Retention**: Information Operations shall retain Certificates of Destruction and sanitization logs in accordance with LRDA 20070440 (Fixed Assets and Inventories).

6.7 Prohibited Media Types

All County Personnel shall not connect or operate personally owned removable media (e.g., personal USB flash drives, external hard drives) on Elko County information systems. All County Personnel shall use only County-procured, encrypted portable storage devices that are cataloged as Configuration Items under **Policy 3.08** (Service Configuration Management (CMDB) Policy).

6.8 Multifunction Printers (MFPs) and Copier Handling

Elko County utilizes MFPs with internal storage drives capable of caching Confidential and Restricted data. The terminal disposition of these assets is subject to chain-of-custody and sanitization controls. Systems Administrators shall document MFP models and their configuration limitations in the Configuration Management Database (CMDB) per **Policy 3.08** and in supporting Standard Operating Procedures (SOPs).

- **Automated Data Removal Limitations**: Systems Administrators shall configure MFPs to execute automated job data removal no less than weekly and shall implement automated alerting for job data removal failures. In the event of an automated job data removal failure, Systems Administrators shall execute a manual clearing within twenty-four (24) hours of the alert. Automated job data removal operates solely as a defense-in-depth risk mitigation and does not constitute terminal sanitization for CJI media.

- **Contractual "Keep Your Drive" Requirement**: The IT Director shall require a "Keep Your Drive" provision in all MFP lease or purchase agreements executed after the effective date of this policy. At lease expiration or hardware replacement, Systems Administrators shall remove and retain the internal storage media for destruction in accordance with the Destroy method defined in Section 6.4.
- **On-Site Vendor Sanitization**: For pre-existing lease agreements executed prior to the effective date of this policy that lack a "Keep Your Drive" provision, Systems Administrators shall execute the External Release Without Drive Retention fallback defined in Section 6.4 on-site before removing the asset from Elko County facilities. Systems Administrators shall visually verify the sanitization action and obtain a Certificate of Sanitization prior to the hardware's departure. Where the MFP stored or may have stored CJI, Systems Administrators shall remove and destroy the drive per Section 6.4 regardless of the lease terms, and the asset shall be returned to the vendor without the drive.
- **Inoperable Media (Break/Fix)**: Systems Administrators shall not release inoperable MFP drives that cannot be logically overwritten to vendor technicians. Elko County shall classify these drives as physical media for destruction and shall retain them regardless of warranty or lease return requirements. The IT Director shall notify vendors of this requirement in writing prior to any service event to ensure compliance at the time of a break/fix call.

6.9 Media Loss Reporting

All County Personnel shall report the loss, theft, or suspected compromise of County media immediately upon discovery. Reports shall be initiated through the incident identification and reporting channels established in **Policy 4.02** (Identification and Reporting Procedures), which governs the internal reporting clock and CJIS notification mechanics for media-involved incidents.

- **CJI Media**: The loss, theft, or suspected compromise of any County media containing Criminal Justice Information (CJI) shall be reported no later than one (1) hour after discovery, consistent with CJIS Security Policy v6.0 IR-6 Part (a) and **Policy 4.02**.

6.10 Vendor Data Return

At vendor contract termination or project completion initiated under **Policy 1.13** (Supply Chain Risk Management and Vendor Governance), the IT Director shall direct one of the following dispositions for County data held by the vendor.

- **Certified Return**: The vendor shall return all County data to the Information Operations Department on County-approved media, accompanied by written certification that no copies have been retained.
- **Secure Destruction**: The vendor shall destroy all County data using methods consistent with Section 6.4 and shall provide a written Certificate of Destruction identifying the data destroyed, the method used, the date of destruction, and the responsible individual.
- **Verification**: The IT Director shall verify receipt of the returned media or the Certificate of Destruction and shall record the verification in the vendor contract file.

2.13 Physical Security and Environmental Controls Policy

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy establishes physical and environmental safeguards for Elko County facilities, information systems, and Criminal Justice Information (CJI).

2. Scope

This policy applies to all Elko County physical facilities, data centers, network closets, and terminal areas where County information systems reside or where Criminal Justice Information (CJI) is accessed, processed, transmitted, or stored, and to all Information Operations personnel, Buildings and Grounds personnel, and all County Personnel who access or work within those locations.

- **In Scope**:
  - Physically secure locations housing County information systems or Criminal Justice Information (CJI).
  - Perimeter physical access controls, signage, and structural separation of secure locations from non-secure locations.
  - Physical access authorization, visitor escort, and visitor record-keeping.
  - Physical access audit logs and security camera surveillance systems protecting County information assets.
  - Environmental controls including fire protection, temperature and humidity regulation, and water damage protection.
  - Power equipment, emergency shutoff, emergency lighting, and uninterruptible power supply (UPS) serving critical information technology infrastructure.
- **Out of Scope**:
  - Logical access to information systems: **Policy 2.04**.
  - Security audit record generation, aggregation, and retention for system-level events: **Policy 2.11**.
  - Protection and sanitization of digital and physical media: **Policy 2.12**.
  - Personnel screening, credential issuance, and separation processing: **Policy 2.02**.
  - Incident response procedures following a physical security event: **Policy 4.01**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall serve as the final approving authority for physical access control lists for County information technology facilities.
  - Shall approve environmental control baselines for critical information technology facilities.
  - Shall approve exceptions to this policy in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

  - Shall retain non-delegable accountability for Local Agency Security Officer (LASO) obligations to the CJIS Systems Agency in accordance with **Policy 1.11** (Data Governance and Classification Policy) for physical security matters affecting Criminal Justice Information (CJI).
  - Shall direct changes to combinations, keys, and access cards in accordance with Section 6.1.
- **Assistant IT Director:**
  - Shall oversee maintenance of physical access audit logs and security camera recordings for County information technology facilities.
  - Shall review visitor access records no less than quarterly, evidenced by a documented review record in the System of Engagement.
  - Shall review physical access logs no less than quarterly, and following any physical, environmental, or security-related incident involving Criminal Justice Information (CJI) or systems used to process, store, or transmit CJI.
  - Shall coordinate physical security findings and investigation outcomes with the incident response capability in accordance with **Policy 4.01** (Incident Response Policy Overview) and **Policy 4.02** (Identification and Reporting Procedures).
  - Shall export camera footage segments capturing incidents, breaches, or legal events in accordance with Section 6.3.
- **System and Network Administrators:**
  - Shall configure security cameras in server rooms and network closets in accordance with Section 6.3.
  - Shall maintain physical access audit logs for all physically secure information technology locations in accordance with Section 6.1.
  - Shall respond to physical access motion alerts and generate work orders in accordance with Section 6.3.
  - Shall maintain uninterruptible power supply (UPS) units serving County information technology infrastructure in accordance with **Policy 1.12** (IT Asset Management Policy) lifecycle standards.
  - Shall deactivate and reissue physical access credentials in accordance with Section 6.1 and the personnel separation and transfer timelines established in **Policy 2.02** (Personnel Security and Background Screening Policy).
- **Buildings and Grounds:**
  - Shall install physical access control hardware (locks, card readers, and equivalent mechanisms) at physically secure locations.
  - Shall ensure perimeter signage is posted at the entry points of physically secure locations.
  - Shall install security cameras at locations designated by the Information Operations Department.
  - Shall maintain fire suppression and fire detection systems serving facilities containing critical information technology infrastructure.
  - Shall ensure fire suppression and fire detection systems are inspected no less than annually.
  - Shall maintain automated temperature and humidity controls for primary server rooms.
  - Shall maintain master shutoff valves, emergency power shutoff devices, and emergency lighting serving facilities containing critical information technology infrastructure.
- **Department Heads:**

  - Shall coordinate visitor access requests for their personnel with the Information Operations Department.
  - Shall ensure separating personnel return physical access credentials at separation in accordance with **Policy 2.02**.
- **All County Personnel:**
  - Shall escort unauthenticated visitors at all times within physically secure locations.
  - Shall challenge any unescorted or unbadged individual encountered within a physically secure location.
  - Shall report suspected physical security anomalies, tampering, or unauthorized access attempts to the Information Operations Department.
  - Shall not duplicate, share, or transfer physical access credentials issued to them.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel, Buildings and Grounds personnel, and all County Personnel who access or work within physically secure County facilities.

- **Assessment**: Adherence to this policy shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures). Quarterly visitor record reviews, quarterly physical access log reviews, and annual fire system inspections provide ongoing compliance evidence.
- **Enforcement**: The IT Director shall enforce compliance with this policy. Repeated non-compliance may be escalated under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with business justification, compensating controls, and proposed duration, and shall be approved in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.
  - **Constraint**: No exception approved under this policy shall authorize the destruction or modification of physical access audit logs, visitor control logs, or security camera recordings outside the retention framework established in **Policy 1.11**, nor the suspension of legal hold preservation obligations.
- **Sanctions**: Violations of this policy, including tailgating into physically secure locations, unauthorized duplication or sharing of physical access credentials, and disabling of environmental or physical security controls, may result in disciplinary action up to and including termination through the enforcement framework established in **Policy 5.01**.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.02: Personnel Security and Background Screening Policy
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy

- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- LRDA 20071749 (Property Management: Security Records)
- LRDA 20200003 (Property Management: Security Camera Recordings)
- CJIS Security Policy v6.0: Section MA-5 (Maintenance Personnel)
- CJIS Security Policy v6.0: Section PE-2 (Physical Access Authorizations)
- CJIS Security Policy v6.0: Section PE-3 (Physical Access Control)
- CJIS Security Policy v6.0: Section PE-6 (Monitoring Physical Access)
- CJIS Security Policy v6.0: Section PE-6(1) (Intrusion Alarms and Surveillance Equipment)
- CJIS Security Policy v6.0: Section PE-8 (Visitor Access Records)
- CJIS Security Policy v6.0: Section PE-9 (Power Equipment and Cabling)
- CJIS Security Policy v6.0: Section PE-10 (Emergency Shutoff)
- CJIS Security Policy v6.0: Section PE-11 (Emergency Power)
- CJIS Security Policy v6.0: Section PE-12 (Emergency Lighting)
- CJIS Security Policy v6.0: Section PE-13 (Fire Protection)
- CJIS Security Policy v6.0: Section PE-13(1) (Detection Systems — Automatic Activation and Notification)
- CJIS Security Policy v6.0: Section PE-14 (Environmental Controls)
- CJIS Security Policy v6.0: Section PE-15 (Water Damage Protection)
- NIST SP 800-53 Rev. 5: PE-2 (Physical Access Authorizations)
- NIST SP 800-53 Rev. 5: PE-3 (Physical Access Control)
- NIST SP 800-53 Rev. 5: PE-6 (Monitoring Physical Access)
- NIST SP 800-53 Rev. 5: PE-6(1) (Intrusion Alarms and Surveillance Equipment)
- NIST SP 800-53 Rev. 5: PE-8 (Visitor Access Records)
- NIST SP 800-53 Rev. 5: PE-9 (Power Equipment and Cabling)
- NIST SP 800-53 Rev. 5: PE-10 (Emergency Shutoff)
- NIST SP 800-53 Rev. 5: PE-11 (Emergency Power)
- NIST SP 800-53 Rev. 5: PE-12 (Emergency Lighting)
- NIST SP 800-53 Rev. 5: PE-13 (Fire Protection)
- NIST SP 800-53 Rev. 5: PE-13(1) (Detection Systems — Automatic Activation and Notification)
- NIST SP 800-53 Rev. 5: PE-14 (Environmental Controls)
- NIST SP 800-53 Rev. 5: PE-15 (Water Damage Protection)

Framework Alignment:

- NIST CSF 2.0: PR.AA-06 (Physical access to assets is managed, monitored, and enforced)

- NIST CSF 2.0: PR.IR-02 (The organization's technology assets are protected from environmental threats)
- COBIT 2019: DSS01 (Manage Operations)

6. Policy Statement

Physical and environmental controls prevent unauthorized physical access, environmental damage, and interruption of operations for County information systems and the Criminal Justice Information (CJI) they process. This policy defines the requirements governing perimeter, monitoring, environmental, and power infrastructure safeguards required to satisfy the physical security mandates of the FBI CJIS Security Policy, and establishes the routing by which physical security findings enter the incident response and compliance monitoring processes of the Information Operations Policy Manual.

6.1 Physically Secure Locations and Perimeter Controls

- Buildings and Grounds shall ensure the perimeter of any physically secure location housing critical information technology infrastructure or processing Criminal Justice Information (CJI) is structurally separated from non-secure locations by physical controls (locked doors, card readers, or equivalent) and is clearly signed at entry points to designate restricted access.
- System and Network Administrators shall position information system devices to prevent unauthorized individuals from accessing or visually observing Criminal Justice Information (CJI) or sensitive administrative sessions.
- **Access Control Procedures**:
  - System and Network Administrators shall maintain physical access audit logs for all physically secure information technology locations.
  - System and Network Administrators shall ensure physical access audit logs record all access events.
  - System and Network Administrators shall retain physical access audit logs in accordance with Nevada LRDA 20071749 (Property Management: Security Records).
  - All County Personnel issued physical access credentials shall not leave keys, key fobs, access cards, or combination codes unattended in locations accessible to unauthorized individuals.
  - All County Personnel issued physical access credentials shall not share keys, key fobs, access cards, or combination codes among personnel.
  - The IT Director shall direct that combinations and keys are changed, and access cards deactivated and reissued, whenever:
    - (a) a key is lost or a combination is believed to have been compromised.
    - (b) an individual possessing a key, combination, or unescorted access credential is transferred to a role not requiring access or is separated from the County.

6.2 Physical Access Authorizations and Visitor Control

- The IT Director shall approve the access list of individuals authorized to enter physically secure information technology locations.
- System and Network Administrators shall maintain the access list in the System of Engagement.
- The Assistant IT Director shall review and update the access list no less than annually.
- System and Network Administrators shall execute physical access credential issuance, modification, and revocation for all secure information technology facilities in accordance with the personnel onboarding and offboarding framework established in **Policy 2.02**.

- Upon notification of personnel separation or role change, System and Network Administrators shall revoke physical access credentials (keycards, key fobs, and combination codes) on the Involuntary Termination and Standard Termination timelines established in **Policy 2.02**.
- System and Network Administrators shall maintain a visitor control log recording the names, organizations, dates, entry and exit times, and forms of identification used to authenticate every visitor accessing a physically secure location.
- All County Personnel shall escort visitors at all times within secure areas.
  - **Constraint**: When the escort involves vendor or contractor personnel performing maintenance on systems that process, store, or transmit Criminal Justice Information (CJI), the Information Operations Department shall designate an escort who meets the personnel security clearance requirements for Criminal Justice Information (CJI) access established in **Policy 2.02** and who is technically qualified to supervise the specific maintenance activity being performed.
- The Assistant IT Director shall conduct a review of visitor access records no less than quarterly to assess whether access authorizations remain current for County operational needs.
- The Assistant IT Director shall report anomalies identified during visitor access record reviews — including unauthorized access patterns, missing records, or entries outside authorized access periods — to the IT Director, and, for anomalies involving facilities processing Criminal Justice Information (CJI), to the IT Director (as LASO) for CJIS Systems Agency notification assessment.
- **Retention Mandate**: System and Network Administrators shall retain the visitor control log for a minimum period of three (3) calendar years from the end of the calendar year to which the log pertains, in accordance with Nevada LRDA 20071749 (Property Management: Security Records).

6.3 Monitoring Physical Access and Camera Surveillance

- The Assistant IT Director shall ensure physical access to facilities where information systems reside is monitored to detect and respond to physical security incidents.
- **Motion Detection Configuration**: System and Network Administrators shall configure security cameras in server rooms and network closets with motion detection.
- **Alert Routing**: System and Network Administrators shall configure the monitoring system to notify the Information Operations Department via email on motion detection.
- **Out-of-Hours Follow-Up**: System and Network Administrators shall configure the monitoring system to generate a work order on any motion event occurring outside Information Operations Department hours of operation, to be actioned by end of the next business day.
  - **Rationale**: Camera-based motion alerting satisfies the physical intrusion alarm requirement under CJIS Security Policy v6.0 Section PE-6(1).
- The Assistant IT Director shall review physical access logs no less than quarterly, and following any physical, environmental, or security-related incident involving Criminal Justice Information (CJI) or systems used to process, store, or transmit CJI.
- The Assistant IT Director shall coordinate the results of physical access log reviews and any physical security investigations with the County's incident response capability in accordance with **Policy 4.01**.
- **Retention Mandate**:
  - System and Network Administrators shall retain security camera recordings that monitor physical access for a minimum of seven (7) calendar days or for the period needed to review the recordings, whichever is longer, in accordance with Nevada LRDA 20200003 (Property Management: Security Camera Recordings).
  - The Assistant IT Director shall determine any extension beyond seven (7) calendar days required to complete review.

- When camera footage captures an incident, breach, or legal event, the Assistant IT Director shall export the relevant segment of footage within twenty-four (24) hours of discovery.
- The Assistant IT Director shall report the event in accordance with **Policy 4.02**.
- The Assistant IT Director shall reclassify the exported footage segment as an incident record.
- The Assistant IT Director shall retain the reclassified incident record in accordance with the evidence artifact retention framework established in **Policy 4.02**.

6.4 Environmental Controls

- **Fire Protection**:
  - Buildings and Grounds shall ensure facilities containing critical information technology infrastructure employ automatic fire suppression and fire detection systems.
  - Buildings and Grounds shall ensure fire suppression and fire detection systems are inspected no less than annually.
  - Buildings and Grounds shall configure fire detection systems to activate automatically upon detection of fire conditions and to simultaneously notify organizational incident response personnel and local emergency responders without requiring manual intervention.
- **Temperature and Humidity Controls**: Buildings and Grounds shall maintain automated temperature and humidity controls for primary server rooms to prevent environmental degradation of information systems.
- **Water Damage Protection**:
  - Buildings and Grounds shall ensure master shutoff valves are identified and accessible.
  - The Information Operations Department shall position or elevate information technology equipment to minimize risk from water damage.

6.5 Power Equipment, Emergency Infrastructure, and Continuity

- **Power Equipment and Cabling**:
  - Buildings and Grounds shall protect power equipment and power cabling serving critical information technology infrastructure from physical damage and destruction.
  - Buildings and Grounds shall ensure cabling paths are identified, documented, and physically secured within locked conduits or restricted-access routing pathways.
- **Emergency Shutoff**:
  - Buildings and Grounds shall ensure facilities housing critical information technology infrastructure provide the capability to shut off power to all information systems in emergency situations.
  - Buildings and Grounds shall place emergency shutoff switches or devices in locations readily accessible to authorized personnel.
  - Buildings and Grounds shall protect emergency shutoff capability from unauthorized or accidental activation.
- **Emergency Power**:
  - System and Network Administrators shall ensure critical information technology facilities are equipped with an uninterruptible power supply (UPS) providing near-instantaneous protection from power interruptions and facilitating orderly system shutdown or transition to an alternate power source upon loss of primary power.

  - System and Network Administrators shall maintain UPS units in accordance with **Policy 1.12** lifecycle standards.
- **Emergency Lighting**:
  - Buildings and Grounds shall maintain automatic emergency lighting that activates upon power outage or disruption.
  - Buildings and Grounds shall ensure emergency lighting covers emergency exits and evacuation routes within the facility.

2.14 Mobile Device and Remote Access Policy

Effective: July 01, 2026 Version: 2.0

1. Purpose

This policy establishes mandatory security controls for mobile devices and remote access technologies connecting to Elko County information systems, including those processing, storing, or transmitting Criminal Justice Information (CJI).

2. Scope

This policy applies to all Elko County information systems, mobile devices, wireless infrastructure, and remote access connections, and to all County Personnel, contractors, and third-party vendors interacting with these resources.

- **In Scope**:
  - County-owned mobile devices, including smartphones, tablets, and laptops authorized to process, store, or transmit County data.
  - Wireless access points, wireless clients, and wireless infrastructure owned, leased, or operated by Elko County.
  - Remote access connections originating from outside the County's internal trusted network, including Virtual Private Network (VPN) sessions, remote desktop sessions, and managed gateway traffic.
  - Personally owned devices used to access County information assets.
  - Vendor remote access to County information systems.
- **Out of Scope**:
  - Contractor-owned device support and the contractor equipment model: **Policy 1.13**.
  - Identification and authentication mechanics, including multi-factor authentication baselines and mobile device advanced authentication: **Policy 2.05**.
  - Cryptographic standards, transmission protections, and key management: **Policy 2.07**.
  - Device lock thresholds and remote access session termination: **Policy 2.04**.
  - Vulnerability management and patch deployment timelines: **Policy 2.09**.
  - Audit logging cadence and centralized log review: **Policy 2.11**.

3. Roles and Responsibilities

- **IT Director (as LASO):**
  - Shall authorize each remote access connection type prior to deployment.
  - Shall authorize each wireless access type prior to deployment.
  - Shall approve the enterprise mobile device management (MDM) platform.
  - Shall designate compelling operational needs for privileged remote access.
  - Shall approve compensating controls for advanced authentication exceptions per **Policy 2.05**.

  - Shall authorize the transport of CJI-authorized devices outside the United States in writing prior to departure.
  - Shall approve risk acceptance for deviations from this policy per **Policy 1.09**.
  - Shall approve any exception to this policy in writing per **Policy 5.01**.
- **Assistant IT Director:**
  - Shall perform a pre-departure inspection on each CJI-authorized device approved for international travel.
  - Shall perform a post-return inspection on each CJI-authorized device upon its return to County custody from international travel.
  - Shall receive immediate reports of lost, stolen, or suspected-compromise mobile devices from County Personnel.
- **Systems Administrator:**
  - Shall configure and maintain the enterprise mobile device management (MDM) platform per the requirements in Section 6.3.
  - Shall apply security patches to mobile operating systems per **Policy 2.09**.
  - Shall initiate remote lock and remote wipe procedures via the MDM platform upon notification of mobile device loss, theft, or compromise.
  - Shall configure cryptographic key extraction protections and remote-wipe-on-failure controls on CJI-authorized mobile devices.
- **Network Administrator:**
  - Shall configure and maintain the County's Virtual Private Network (VPN) and remote access gateway infrastructure.
  - Shall route remote access traffic through authorized and managed network access control points.
  - Shall perform validation testing for rogue wireless access points no less frequently than quarterly.
  - Shall maintain the inventory of all County wireless access points.
  - Shall configure wireless infrastructure per the requirements in Section 6.2.
  - Shall change administrative credentials on wireless access points consistent with the configuration baselines defined in **Policy 2.10**.
- **All County Personnel:**
  - Shall physically protect County mobile devices in their custody.
  - Shall report the loss, theft, or suspected compromise of any County mobile device to the Assistant IT Director immediately upon discovery and no later than two (2) hours after discovery.
  - Shall report the loss, theft, or suspected compromise of any CJI-authorized mobile device to the IT Director (as LASO) immediately and no later than one (1) hour after discovery.
  - Shall initiate session locks before leaving County devices unattended.
  - Shall not connect personally owned devices to the County's internal trusted network or use personally owned devices to access CJI.
  - Shall not transport CJI-authorized devices outside the United States without prior written authorization from the IT Director (as LASO).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all personnel and entities defined in Section 2.

- **Assessment**: Compliance with mobile device and remote access controls shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Risk acceptance for deviations shall additionally follow the Risk Acceptance Memo procedure defined in **Policy 1.09**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.04: Access Control Policy
- ECIO Policy 2.05: Identification and Authentication Policy
- ECIO Policy 2.07: System and Communications Protection Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- CJIS Security Policy v6.0: Section AC-17 (Remote Access)
- CJIS Security Policy v6.0: Section AC-17(4) (Privileged Commands and Access)
- CJIS Security Policy v6.0: Section AC-18 (Wireless Access)
- CJIS Security Policy v6.0: Section AC-18(1) (Authentication and Encryption)
- CJIS Security Policy v6.0: Section AC-19 (Access Control for Mobile Devices)
- CJIS Security Policy v6.0: Section AC-19(5) (Full Device or Container-Based Encryption)
- CJIS Security Policy v6.0: Section AC-20 (Use of External Systems)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Appendix G.4 (Mobile Device Guidance — Cellular Service Abroad)

Framework Alignment:

- CJIS Security Policy v6.0: Section AC-11 (Device Lock)
- CJIS Security Policy v6.0: Section IA-2(1) (Multi-Factor Authentication to Privileged Accounts)
- CJIS Security Policy v6.0: Section IA-2(2) (Multi-Factor Authentication to Non-Privileged Accounts)

- CJIS Security Policy v6.0: Section IR-4(1) (Automated Incident Handling Processes)
- CJIS Security Policy v6.0: Section SC-8(1) (Cryptographic Protection)
- NIST CSF 2.0: PR.AA-05 (Access Permissions and Authorizations)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)
- NIST SP 800-53 Rev. 5: AC-17 (Remote Access)
- NIST SP 800-53 Rev. 5: AC-17(4) (Privileged Commands)
- NIST SP 800-53 Rev. 5: AC-18 (Wireless Access)
- NIST SP 800-53 Rev. 5: AC-19 (Access Control for Mobile Devices)
- NIST SP 800-53 Rev. 5: AC-20 (Use of External Systems)
- NIST SP 800-53 Rev. 5: IA-3 (Device Identification and Authentication)
- NIST SP 800-53 Rev. 5: SC-7 (Boundary Protection)
- NIST SP 800-53 Rev. 5: SC-8 (Transmission Confidentiality and Integrity)
- COBIT 2019: DSS05.01 (Protect against malware)
- COBIT 2019: DSS05.03 (Manage endpoint security)
- COBIT 2019: DSS05.04 (Manage User Identity and Logical Access)
- ITIL v4: Information Security Management Practice

6. Policy Statement

6.1 Remote Access Management

- **Authorization**: The IT Director (as LASO) shall authorize each remote access connection type prior to use, consistent with CJIS Security Policy v6.0: Section AC-17 (Remote Access).
- **Managed Access Points**: The Network Administrator shall route all remote access traffic through authorized and managed network access control points, including VPN gateways.
- **Privileged Remote Access**: The Systems Administrator and the Network Administrator shall not execute privileged commands via remote access except where the IT Director (as LASO) has documented a compelling operational need, consistent with CJIS Security Policy v6.0: Section AC-17(4) (Privileged Commands and Access). The Assistant IT Director shall ensure information systems generate assessable evidence of all privileged remote access sessions.
- **Cryptographic Protection of Remote Sessions**: The Network Administrator shall protect remote access sessions in transit consistent with **Policy 2.07**.
- **Session Termination and Re-Authentication**: The Network Administrator shall configure remote access session termination and re-authentication consistent with **Policy 2.04**.

6.2 Wireless Networking Security

- **Wireless Access Authorization**: The IT Director (as LASO) shall authorize each type of wireless access to County information systems prior to allowing such connections, consistent with CJIS Security Policy v6.0: Section AC-18 (Wireless Access).
- **Validation and Inventory**:
  - The Network Administrator shall perform validation testing for rogue wireless access points no less frequently than quarterly.

  - The Network Administrator shall maintain a complete inventory of all County wireless access points.
  - The Network Administrator shall test access point range boundaries to determine the extent of wireless coverage.
  - The Network Administrator shall design wireless coverage areas to remain within approved operational boundaries.
- **Physical and Logical Security**:
  - The Network Administrator shall place wireless access points in secured areas to prevent unauthorized physical access and user manipulation.
  - The Network Administrator shall logically separate the wireless network from the wired operational infrastructure using boundary protection mechanisms, including Virtual Local Area Networks (VLANs) and Access Control Lists (ACLs).
  - The Network Administrator shall limit access between wireless and wired networks to operational needs only.
- **Required Authentication and Encryption**: The Network Administrator shall configure wireless access to County internal networks to use Wi-Fi Protected Access 2 (WPA2) or Wi-Fi Protected Access 3 (WPA3) Enterprise authentication and encryption, with cryptographic protections governed by **Policy 2.07**, consistent with CJIS Security Policy v6.0: Section AC-18(1) (Authentication and Encryption).
- **Prohibited Protocols**: The Network Administrator shall not deploy Wired Equivalent Privacy (WEP) or original Wi-Fi Protected Access (WPA) on County wireless infrastructure.
- **Configuration Baselines**:
  - The Network Administrator shall change default Service Set Identifiers (SSIDs) prior to deployment.
  - The Network Administrator shall disable ad-hoc mode on County wireless infrastructure.
  - The Network Administrator shall disable nonessential management protocols on County wireless infrastructure.
  - The Network Administrator shall use management protocols whose cryptographic protections are consistent with **Policy 2.07**.
- **Access Point Reset Procedures**:
  - The Network Administrator shall invoke access point reset functions only to resolve a documented operational fault or to apply an approved configuration change.
  - The Network Administrator shall restore the access point to the latest approved configuration baseline defined in **Policy 2.10** immediately following any reset.
  - The Network Administrator shall not retain factory default configurations on County wireless infrastructure.
- **Access Point Logging**:
  - The Network Administrator shall enable logging on all wireless access points.
  - The Network Administrator shall not deploy access points incapable of logging without an exception approved per **Policy 5.01**.
  - The Network Administrator shall forward wireless access point logs to the centralized log repository consistent with **Policy 2.11**.

- **Mobile Hotspots**: The Systems Administrator shall configure County mobile devices authorized to access CJI such that any Wi-Fi hotspot function employs encryption, a non-default pre-shared key, port filtering, and connection restrictions to agency-controlled devices only. All County Personnel shall not transmit CJI over a mobile hotspot connection absent application-layer encryption that satisfies CJIS Security Policy requirements.

6.3 Mobile Device Management (MDM)

- **Enrollment Requirement**: The Systems Administrator shall manage all County-owned mobile devices accessing CJI or County data through the centralized enterprise mobile device management (MDM) platform, consistent with CJIS Security Policy v6.0: Section AC-19 (Access Control for Mobile Devices).
- **Mandatory Controls**: The Systems Administrator shall configure the MDM to enforce all of the following:
  - Remote locking of County mobile devices on demand.
  - Remote wiping of County mobile devices on demand.
  - Detection of jailbroken or rooted devices, with automatic access blocking upon detection.
  - Full-device or container-based encryption on managed devices, consistent with CJIS Security Policy v6.0: Section AC-19(5) (Full Device or Container-Based Encryption).
  - Automatic device wipe after a maximum of ten (10) consecutive failed access attempts.
- **Mobile Operating System Patching**: The Systems Administrator shall apply mobile operating system patches consistent with **Policy 2.09**.
- **Mobile Device Encryption**: The Systems Administrator shall encrypt CJI processed, stored, or transmitted on County mobile devices consistent with **Policy 2.07**.
- **Bluetooth**:
  - The Systems Administrator shall configure the MDM to disable Bluetooth on CJI-authorized devices except where explicitly required for an approved operational purpose.
  - Where Bluetooth is approved, the Systems Administrator shall restrict associations to known agency-approved accessories only.
  - Where Bluetooth is approved, the Systems Administrator shall prevent users from creating unapproved Bluetooth associations on CJI-capable devices.
- **Prohibited Transmission Methods**: All County Personnel shall not transmit CJI using Short Message Service (SMS), Multimedia Messaging Service (MMS), or consumer voice or chat applications, including FaceTime and standard SMS. The Systems Administrator shall configure approved application-based communication tools used for CJI transmission to employ authentication and encryption mechanisms compliant with CJIS Security Policy requirements, independent of the device unlock authenticator.
- **Cryptographic Key Extraction Protections**:
  - The Systems Administrator shall configure mobile devices to prevent extraction of stored certificates and cryptographic keys from the device hardware.
  - The Systems Administrator shall configure certificates and cryptographic keys that grant special access or unique device identification for remote wipe on demand.
  - The Systems Administrator shall configure certificates and cryptographic keys that grant special access or unique device identification for self-deletion upon a defined number of unsuccessful access attempts.

  - The Systems Administrator shall manage cryptographic key generation, distribution, storage, destruction, and validation records for mobile devices consistent with **Policy 2.07**.

6.4 Identification and Authentication

- **By Reference**: The Systems Administrator and the Network Administrator shall configure identification and authentication for mobile and remote access consistent with **Policy 2.05**, including multi-factor authentication baselines and mobile device advanced authentication with compensating-control exceptions.

6.5 Personally Owned Devices

- **CJI Prohibition**: All County Personnel shall not use personally owned devices to access, process, store, or transmit Criminal Justice Information, consistent with CJIS Security Policy v6.0: Section AC-20 (Use of External Systems).
- **Internal Network Prohibition**: The Network Administrator shall deny personally owned devices connectivity to the County's internal trusted network.
- **Limited External-Service Access**:
  - All County Personnel may access County non-CJI cloud services from personally owned devices, including productivity suite web access, only where such access does not require enrollment of the personally owned device in the County mobile device management (MDM) platform.
  - All County Personnel shall not locally synchronize, download, cache, or persistently store Restricted or Confidential County data on personally owned devices.
  - All County Personnel shall handle County data on personally owned devices consistent with the data classification and handling requirements in **Policy 1.11**.
- **Exceptions**: Exceptions to the prohibitions in this section shall be processed per **Policy 5.01**.

6.6 Vendor Remote Access

- **Compliance with This Policy**: Vendor remote access to County information systems shall comply with the requirements of this policy, including authorization, managed gateway routing, cryptographic protection, and session termination.
- **Additional Vendor Obligations**: The IT Director (as LASO) shall require vendor compliance with the additional vendor-specific obligations defined in **Policy 1.13**, including least privilege, named-account-only provisioning, time-bounded authorization, persistent-tunnel prohibition, and vendor activity logging.

6.7 Mobile Device Incident Response

Cybersecurity incident response activities triggered by mobile device events shall be conducted within the program established under **Policy 4.01**. The following mobile-specific procedures supplement the Chapter 4 lifecycle.

- **Initial Reporting**: All County Personnel shall report the loss, theft, or suspected compromise of any County mobile device to the Assistant IT Director immediately upon discovery and no later than two (2) hours after discovery.
- **CJI Device Reporting Threshold**: All County Personnel shall report the loss, theft, or suspected compromise of any CJI-authorized mobile device to the IT Director (as LASO) immediately and no later than one (1) hour after discovery, consistent with CJIS Security Policy v6.0: Section IR-6 (Incident Reporting).

- **Remote Lock and Wipe**: Upon notification of mobile device loss, theft, or suspected compromise, the Systems Administrator shall initiate remote lock and remote wipe procedures via the MDM platform within fifteen (15) minutes of notification.
- **Tiered Response Scenarios**: The Incident Commander designated under **Policy 4.01** shall ensure response procedures address, at minimum, the following physical-control-loss scenarios:
  - Device known to be locked, loss of physical control for less than fifteen (15) minutes.
  - Device known to be locked, loss of physical control for fifteen (15) minutes or greater.
  - Device lock state unknown, loss of physical control for less than fifteen (15) minutes.
  - Device lock state unknown, loss of physical control for fifteen (15) minutes or greater.
  - Device known to be unlocked, any loss of physical control exceeding five (5) minutes.
  - Total loss of device.
  - Device compromise or suspected compromise.
  - Device loss or compromise outside the United States.

6.8 International Travel

- **Authorization**: All County Personnel shall not transport CJI-authorized devices outside the United States without prior written authorization from the IT Director (as LASO), consistent with CJIS Security Policy v6.0: Appendix G.4 (Mobile Device Guidance — Cellular Service Abroad).
- **Pre-Departure Inspection**: The Assistant IT Director shall perform a pre-departure inspection of each authorized device to verify Mobile Device Management enrollment, configuration baseline compliance, cryptographic protection, and managed-gateway connectivity, evidenced by a documented inspection record in the System of Engagement.
- **Post-Return Inspection**: The Assistant IT Director shall perform a post-return inspection of each authorized device within twenty-four (24) hours of its return to County custody, evidenced by a documented inspection record in the System of Engagement.
- **Foreign Network Exposure**: Any CJI-authorized device transported outside the United States shall be subject to a security assessment under **Policy 4.01** prior to being returned to operational use, regardless of known foreign network connectivity.

2.15 System Development and Secure Software Lifecycle Policy

Effective: July 01, 2026 Version: 2.0

1. Purpose

This policy establishes mandatory System Development Life Cycle (SDLC) and secure software engineering requirements for Elko County information systems, including those processing, storing, or transmitting Criminal Justice Information (CJI).

2. Scope

This policy applies to all Elko County information systems, software, and system components, and to all County Personnel, contractors, and External Service Providers involved in the specification, design, development, acquisition, testing, implementation, or modification of those systems.

- **In Scope**:
  - Acquisition of information systems, software, and system components.
  - Internal development, scripting, and configuration work performed by Information Operations Personnel.
  - Pre-production environments, including development, test, and integration environments.
  - Secure design and engineering principles applied during system specification, development, and modification.
  - Developer testing and evaluation prior to system acceptance.
  - Flaw remediation gating to production promotion.
  - Acquisition-time prohibition on unsupported system components.
  - Intellectual property and source code ownership terms for County-developed and contracted work.
- **Out of Scope**:
  - Procurement workflow and Technical Approval mechanics: **Policy 1.10**.
  - Vendor risk assessment, contract obligations, and Assessment Approval: **Policy 1.13**.
  - Data classification and pre-production data handling standards: **Policy 1.11**.
  - Production change authorization: **Policy 3.09**.
  - Release packaging and deployment mechanics: **Policy 3.10**.
  - Vulnerability scanning, patch deployment timelines, and operational end-of-life governance: **Policy 2.09**.
  - Configuration baseline standards for production systems: **Policy 2.10**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall approve external development engagements and major system acquisitions prior to contract execution.

  - Shall approve intellectual property deviations per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment) and **Policy 1.09** (Risk Management Policy).
  - Shall approve risk acceptance for unsupported component retention per **Policy 5.01** and **Policy 1.09**.
- **Assistant IT Director:**
  - Shall define security and privacy roles within SDLC phases prior to project initiation.
  - Shall integrate the organizational risk management process into SDLC activities prior to system authorization.
  - Shall ensure third-party contracts obligate External Service Providers to execute secure development processes consistent with NIST SP 800-53 Rev. 5: SA-8 (Security and Privacy Engineering Principles).
  - Shall ensure third-party contracts identify functions, ports, protocols, and services consistent with CJIS Security Policy v6.0: Section SA-9(2) (Identification of Functions, Ports, Protocols, and Services).
  - Shall validate External Service Provider testing evidence prior to system acceptance.
  - Shall review development tools, processes, and methodologies no less frequently than annually.
  - Shall conduct and document a market survey within the preceding ninety (90) calendar days prior to any request to retain an unsupported component.
- **Systems Administrator:**
  - Shall maintain version control over all internal development artifacts, including source code, scripts, and configuration files.
  - Shall conduct security-focused testing on internally developed software prior to production promotion.
  - Shall document and provide test results as verifiable evidence of execution prior to system acceptance.
- **All Information Operations Personnel:**
  - Shall apply County-documented security and privacy engineering principles in the specification, design, development, implementation, and modification of all systems and system components.
  - Shall apply the privacy principle of minimization, using only the Personally Identifiable Information (PII) strictly necessary to perform system engineering and development tasks.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all personnel and entities defined in Section 2.

- **Assessment**: Compliance with SDLC and secure software engineering requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: The IT Director shall enforce this policy. Violations constitute non-compliance subject to the enforcement framework defined in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be processed in accordance with the exception management framework defined in **Policy 5.01**. Risk acceptance for deviations shall additionally follow the Risk Acceptance Memo procedure defined in **Policy 1.09**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- CJIS Security Policy v6.0: Section SA-3 (System Development Life Cycle)
- CJIS Security Policy v6.0: Section SA-4 (Acquisition Process)
- CJIS Security Policy v6.0: Section SA-8 (Security and Privacy Engineering Principles)
- CJIS Security Policy v6.0: Section SA-8(33) (Minimization)
- CJIS Security Policy v6.0: Section SA-9 (External System Services)
- CJIS Security Policy v6.0: Section SA-9(2) (Identification of Functions, Ports, Protocols, and Services)
- CJIS Security Policy v6.0: Section SA-10 (Developer Configuration Management)
- CJIS Security Policy v6.0: Section SA-11 (Developer Testing and Evaluation)
- CJIS Security Policy v6.0: Section SA-15 (Development Process, Standards, and Tools)
- CJIS Security Policy v6.0: Section SA-22 (Unsupported System Components)
- NIST SP 800-53 Rev. 5: SA-3(1) (Manage Preproduction Environment)
- NIST SP 800-53 Rev. 5: SA-8 (Security and Privacy Engineering Principles)

Framework Alignment:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- NRS 205 (Computer Crimes)
- NRS 603A (Security of Personal Information)
- CJIS Security Policy v6.0: Section SA-4(1) (Functional Properties of Controls)
- CJIS Security Policy v6.0: Section SA-4(2) (Design and Implementation Information for Controls)
- CJIS Security Policy v6.0: Section SA-4(9) (Functions, Ports, Protocols, and Services In Use)
- CJIS Security Policy v6.0: Section SA-15(1) (Criticality Analysis)
- NIST CSF 2.0: GV.SC-06 (Supply Chain Due Diligence)
- NIST CSF 2.0: ID.RA-01 (Vulnerability Identification)
- NIST CSF 2.0: PR.DS-02 (Data-in-Transit Protection)
- NIST CSF 2.0: PR.PS-01 (Configuration Management)

- NIST SP 800-53 Rev. 5: SA-3 (System Development Life Cycle)
- NIST SP 800-53 Rev. 5: SA-4 (Acquisition Process)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SA-10 (Developer Configuration Management)
- NIST SP 800-53 Rev. 5: SA-11 (Developer Testing and Evaluation)
- NIST SP 800-53 Rev. 5: SA-15 (Development Process, Standards, and Tools)
- NIST SP 800-53 Rev. 5: SA-22 (Unsupported System Components)
- COBIT 2019: BAI02 (Manage Requirements Definition)
- COBIT 2019: BAI03 (Manage Solutions Identification and Build)
- ITIL v4: Software Development and Management Practice

6. Policy Statement

6.1 System Development Life Cycle Baseline

- The Assistant IT Director shall manage Elko County information systems using a formally defined System Development Life Cycle (SDLC) that incorporates information security and privacy considerations at every phase, from initiation through disposal, consistent with CJIS Security Policy v6.0: Section SA-3 (System Development Life Cycle).
- The Systems Administrator shall protect pre-production environments, including development, test, and integration environments, commensurate with risk throughout the system development life cycle, consistent with NIST SP 800-53 Rev. 5: SA-3(1) (Manage Preproduction Environment).

6.2 Acquisition Process and Contracting

The Assistant IT Director shall not initiate engagements involving third-party systems or External Service Providers absent Assessment Approval per **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance) and Technical Approval per **Policy 1.10** (IT Financial Management and Procurement Policy).

- The Assistant IT Director shall ensure third-party contracts obligate External Service Providers to execute secure development processes consistent with NIST SP 800-53 Rev. 5: SA-8 and CJIS Security Policy v6.0: Section SA-8.
- The Assistant IT Director shall ensure third-party contracts explicitly identify the functions, ports, protocols, and services employed, consistent with CJIS Security Policy v6.0: Section SA-9(2).
- For all system, system component, or system service acquisitions, the Assistant IT Director shall ensure the following requirements are included explicitly or by reference in the acquisition contract, consistent with CJIS Security Policy v6.0: Section SA-4 (Acquisition Process):
  - (a) Security and privacy functional requirements;
  - (b) Strength of mechanism requirements;
  - (c) Security and privacy assurance requirements;
  - (d) Controls needed to satisfy the security and privacy requirements;
  - (e) Security and privacy documentation requirements;
  - (f) Requirements for protecting security and privacy documentation;
  - (g) Description of the system development environment and the environment in which the system is intended to operate;

  - (h) Allocation of accountability for information security, privacy, and supply chain risk management; and
  - (i) Acceptance criteria.

6.3 Security and Privacy Engineering Principles

All Information Operations Personnel shall apply County-documented security and privacy engineering principles in the specification, design, development, implementation, and modification of all systems and system components, consistent with CJIS Security Policy v6.0: Section SA-8.

- All Information Operations Personnel shall implement the privacy principle of minimization, using only the Personally Identifiable Information (PII) strictly necessary to perform system engineering and development tasks, consistent with CJIS Security Policy v6.0: Section SA-8(33).
- The Systems Administrator shall not permit pre-production environments to contain Criminal Justice Information or Restricted data unless the environment is authorized and controlled to the same baseline required for production handling of that data classification per **Policy 1.11** (Data Governance and Classification Policy).
- The Systems Administrator shall not permit pre-production environments to contain unmasked Confidential data without IT Director authorization, consistent with **Policy 1.11**.

6.4 Developer Configuration Management, Testing, and Standards

- **Applicability**: The developer testing, evaluation, and assessment-plan requirements in this section shall apply to:
  - Software, scripts, or system components developed or acquired for execution on production systems;
  - Software, scripts, or system components that process, store, or transmit Criminal Justice Information, Restricted data, or Confidential data;
  - Software, scripts, or system components that perform authentication, authorization, access control, or audit logging functions;
  - All deliverables developed by External Service Providers; and
  - Software intended for shared use, scheduled execution, or deployment beyond the authoring individual.
  - Ad-hoc administrative tooling executed interactively by authorized personnel against their own work product is not subject to this section.
- **Version Control and Configuration Integrity**: The Systems Administrator shall maintain version control over all internal development artifacts, including source code, scripts, and configuration files. Changes to development tools and processes shall be documented and managed to facilitate supply chain risk assessment, consistent with CJIS Security Policy v6.0: Section SA-10 (Developer Configuration Management).
- **Developer Testing and Evaluation**: The Assistant IT Director shall require, for all software meeting the criteria in the Applicability bullet above, a documented security and privacy assessment plan executed during development. Required testing shall include, at minimum, functional testing, integration testing, regression testing, and information security testing, with rigor proportionate to the criticality of the software's function and the sensitivity of the data it handles, consistent with CJIS Security Policy v6.0: Section SA-15(1) (Criticality Analysis). The assessment plan and test results shall be documented and provided to the Assistant IT Director as verifiable evidence of execution prior to system acceptance, consistent with CJIS Security Policy v6.0: Section SA-11 (Developer Testing and Evaluation).

- **Development Process Standards**: The Assistant IT Director shall review development tools, standards, and methodologies no less frequently than annually to confirm they satisfy security and privacy requirements throughout the development life cycle, consistent with CJIS Security Policy v6.0: Section SA-15 (Development Process, Standards, and Tools).

6.5 Flaw Remediation

The Assistant IT Director shall require all internal developers and External Service Providers to implement a verifiable flaw remediation process consistent with CJIS Security Policy v6.0: Section SA-11.

- The Systems Administrator shall remediate all flaws identified during development, testing, or post-deployment operation according to the severity-based schedule established in **Policy 2.09** (Vulnerability and Patch Management Policy).
- The Systems Administrator shall not promote into production any system containing an unmitigated Critical or High severity flaw.

6.6 Production Promotion Gate

The Systems Administrator shall promote SDLC outputs to production environments only following documented change authorization issued under the change authorization framework defined in **Policy 3.09** (Change Management Policy).

6.7 End of Life and Unsupported System Components

Acquisition-time controls in this policy prohibit County entry into engagements that depend on unsupported system components. Operational governance of components that become unsupported during their service life is governed by **Policy 2.09**.

- The IT Director shall not approve acquisition of any system or system component for which the developer, vendor, or manufacturer has ceased to provide analytical support, software updates, or security patches, consistent with CJIS Security Policy v6.0: Section SA-22 (Unsupported System Components).
- The IT Director shall not approve retention of an unsupported component beyond the vendor's declared end-of-support date except under a Risk Acceptance Memo issued per **Policy 1.09**.
- The Assistant IT Director shall conduct and document a market survey within the preceding ninety (90) calendar days prior to any request for retention authorization, confirming that no vendor-supported replacement product or approved support alternative is commercially available that meets the functional requirements.

6.8 Intellectual Property and Source Code Ownership

The IT Director shall enforce the following ownership terms to ensure the continuous security, maintainability, and auditability of Elko County systems:

- The IT Director shall ensure that all software, source code, scripts, configurations, and related intellectual property engineered or developed by Elko County employees remains the exclusive and sole property of Elko County.
- The IT Director shall ensure that all software and related intellectual property developed by External Service Providers, contractors, or vendors utilizing Elko County systems, funding, or data becomes the exclusive property of Elko County upon creation.
- Any deviation from this ownership model — including commercial-off-the-shelf software licensing, shared-rights agreements, or vendor retention of underlying intellectual property — shall be documented in a legally binding contract and processed in accordance with the exception management framework defined in **Policy 5.01** and the Risk Acceptance Memo procedure defined in **Policy 1.09**.

The IT Director shall not authorize commencement of development or deployment without documented exception approval.

3. Service Management and Operations

3.01 Service Catalog and SLA Policy

Effective: April 29, 2026 Version: 2.5

1. Purpose

This policy establishes the IT Asset Catalog, asset lifecycle status classifications, work order triage and severity classification framework, and service level commitments for the Elko County Information Operations Department.

2. Scope

This policy applies to all hardware models, software titles, and services within the operational purview of the Information Operations Department, to all work orders submitted to the Department, and to all Information Operations personnel involved in triage, service delivery, escalation, or vendor coordination.

- **In Scope**:
  - IT Asset Catalog and asset lifecycle status classifications.
  - Work order triage and severity classification framework.
  - Service level commitments for response and resolution.
  - After-hours emergency response criteria.
  - Vendor SLA requirements for IT-Supported and Vendor-Managed assets.
- **Out of Scope**:
  - Work order lifecycle, documentation, and closure standards: **Policy 3.05**.
  - Operational incident management: **Policy 3.06**.
  - Performance monitoring and metrics reporting: **Policy 3.02**.
  - Asset inventory, procurement, and disposal lifecycle: **Policy 1.12**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the sole approving authority for the IT Asset Catalog and all lifecycle status classifications and reclassifications.
  - Shall maintain the authoritative list of mission-critical systems eligible for after-hours on-call activation.
  - Shall authorize extensions to Deprecated asset replacement deadlines in writing.
  - Shall authorize continued remediation beyond the standard labor ceiling by written notation in the work order, in accordance with **Policy 3.05** (Service Request Fulfillment Policy).
  - Shall approve vendor SLA terms at contract execution.
- **Assistant IT Director:**
  - Shall ensure the IT Asset Catalog is maintained current in the System of Engagement.
  - Shall conduct lifecycle status classification reviews and prepare reclassification proposals for IT Director approval.

  - Shall ensure that the assigned technician or queue reviewer completes triage within the required timeframes defined in this policy.
  - Shall ensure that service level commitments are met across all active work orders.
  - Shall monitor vendor SLA performance in accordance with **Policy 3.02** (Service Level Management and Metrics Reporting).
  - Shall approve changes to the on-call rotation schedule and after-hours contact procedures maintained by the Administrative Assistant.
  - Shall identify and document vendor SLA gaps in existing contracts.
  - Shall present identified vendor SLA gaps to the IT Director no later than ninety (90) days prior to each applicable renewal opportunity.
- **All Information Operations Personnel:**
  - Shall perform triage on assigned work orders within the required window, confirming or reclassifying severity based on verified operational impact.
  - Shall document all reclassifications, remediation attempts, escalation rationale, and closure decisions in the work order.
  - Shall adhere to response and resolution commitments as defined in this policy.
  - Shall refer work orders for Unsupported assets to the IT Director for disposition without performing remediation.
- **Administrative Assistant:**
  - Shall maintain after-hours contact procedures and on-call rotation schedules in the System of Engagement under Assistant IT Director direction.
  - Shall update contact procedures and rotation schedules within one (1) business day of any personnel change affecting on-call assignments.
- **County Personnel and Department Heads:**
  - Shall submit service requests through the designated work order system.
  - Shall provide sufficient information at the time of submission to enable triage.
  - Shall respond to pending information requests from IT staff within five (5) consecutive business days to prevent work order closure.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in service delivery, triage, escalation, or vendor coordination.

- **Assessment**: Compliance with service level commitments, triage timeliness, and catalog maintenance obligations shall be assessed through the service level reporting process defined in **Policy 3.02** and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to meet triage, response, or resolution commitments without documented escalation or rationale shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment). Vendor non-compliance with contracted SLA terms shall be addressed through the vendor compliance framework established in **Policy 5.06** (Vendor Compliance and Third-Party Assurance).

- **Exceptions**: Exceptions to the service level commitments defined in this policy shall be documented with written justification and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NIST CSF 2.0: GV.SC-06 (Cybersecurity Supply Chain Risk Management)
- NIST CSF 2.0: ID.AM-01 (Inventories of hardware managed by the organization)
- NIST CSF 2.0: ID.AM-02 (Inventories of software, services, and systems managed by the organization)
- NIST SP 800-53 Rev. 5: PM-5 (System Inventory)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- COBIT 2019: APO09 (Manage Service Agreements)
- COBIT 2019: APO10 (Manage Vendors)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Service Catalogue Management Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 IT Asset Catalog

The Assistant IT Director shall maintain a current IT Asset Catalog in the System of Engagement. The catalog shall enumerate all hardware models, software titles, and services that fall within the operational purview of the Information Operations Department, regardless of asset support tier as defined in **Policy 1.12** (IT Asset Management Policy). The IT Asset Catalog is an internal operational reference document maintained for IT Department use and shall not be published to general County staff. The IT Asset Catalog is a service-support governance register that maps support posture to each hardware model, software title, and service within the Department's operational purview. The IT Asset Catalog shall not be construed as a substitute for the asset inventory maintained under **Policy 1.12** or the Configuration Item record maintained under **Policy 3.08** (Service Configuration Management (CMDB) Policy). The IT Director holds sole authority to establish and approve the catalog and its contents. The Assistant IT Director shall present the catalog for IT Director review and approval no less than annually and following any significant change to the County's technology environment, contract portfolio, or vendor relationships.

The IT Asset Catalog is the authoritative software authorization register for the Elko County IT environment. Software titles and SaaS entitlements not enumerated in the IT Asset Catalog are subject to the Unauthorized Presence enforcement defined in **Policy 1.12**.

6.2 Asset Lifecycle Status Classifications

Every hardware model, software title, and service enumerated in the IT Asset Catalog shall carry one of the following three lifecycle status classifications. These classifications govern the IT Department's support commitment for each item and inform service level obligations as defined in Section 6.4 of this policy. Support classification under **Policy 1.12** determines ownership and escalation routing for each asset; lifecycle status classification under this policy determines the level of support commitment the Department provides.

- **Supported**: Designates hardware, software, or services that are fully endorsed and actively supported by the Information Operations Department. Supported assets represent the standard authorized technology environment for Elko County. The IT Department shall fulfill its full service level commitments for Supported assets as defined in this policy.
- **Deprecated**: Designates hardware, software, or services that remain operational but have been formally identified for replacement. At the time of Deprecated classification, the IT Director shall establish and document a mandatory replacement deadline in the IT Asset Catalog. Deprecated assets are no longer authorized for new deployments or expanded use. The IT Department shall provide support for Deprecated assets within the labor ceiling framework defined in **Policy 3.05**, for the duration of the replacement window. Upon reaching the replacement deadline, the Assistant IT Director shall transition the asset to Unsupported status unless the IT Director has formally authorized an extension in writing, documented in the IT Asset Catalog with a new deadline and supporting rationale. No open-ended extensions shall be granted. The IT Director may authorize continued remediation beyond the standard labor ceiling by written notation in the work order, in accordance with the disposition review process defined in **Policy 3.05**.
- **Unsupported**: Designates hardware, software, or services that the Information Operations Department does not support and will not remediate. Unsupported assets represent an active operational and security risk and shall be prioritized for immediate replacement or decommissioning under **Policy 1.12**. The assigned technician or queue reviewer shall close work orders submitted for Unsupported assets with a documented replacement referral. The IT Department's obligation for Unsupported assets is limited to documenting the referral and initiating the replacement process.

The IT Director shall approve all lifecycle status classifications and reclassifications. The Assistant IT Director shall ensure that classification reviews are conducted no less than annually and whenever a vendor announces end-of-life, a contract expires, a security risk materially changes, or a replacement technology is formally adopted. The Assistant IT Director shall prepare reclassification proposals, document the proposed effective date and supporting rationale, and submit them to the IT Director for approval prior to implementation in the IT Asset Catalog.

6.3 Triage and Severity Classification Authority

All work orders submitted to the Information Operations Department shall undergo IT-side triage prior to the commencement of active work. User-submitted severity levels represent the requester's assessment and shall be treated as an input to triage, not as a binding operational classification. The assigned technician or queue reviewer shall confirm or reclassify the severity level based on verified operational impact assessment prior to committing to a service level response. The assigned technician or queue reviewer shall document any reclassification in the work order with a brief rationale. The operative severity, as confirmed or reclassified by the assigned technician or queue reviewer, governs all service level commitments defined in this policy.

The Assistant IT Director shall ensure that the assigned technician or queue reviewer completes triage within one (1) business hour of work order submission. Triage is complete when the assigned technician or queue reviewer has assessed the work order, confirmed or reclassified the severity, and initiated or queued

the appropriate response. Where a submitted work order lacks sufficient information to complete triage, the assigned technician or queue reviewer shall document the attempt, specify the information required, and notify the requester that more information is required. Service level clocks shall be paused for the duration of pending information status and shall resume upon receipt of the required information from the requester. The assigned technician or queue reviewer shall close work orders that remain in pending information status without requester response for five (5) consecutive business days, with closure rationale documented in the work order.

6.4 Service Level Commitments

Service level commitments consist of two sequential obligations: a response commitment and a resolution or escalation commitment. All timeframes are measured in business hours or business days from the completion of triage unless otherwise specified. Business hours are defined as Monday through Friday, 8:00 AM to 5:00 PM, excluding Elko County observed holidays. The Assistant IT Director shall ensure that service level commitments are met and shall monitor adherence in accordance with **Policy 3.02**.

Response and resolution commitments by severity level are as follows:

- **Critical severity**:
  - Response within one (1) business hour of triage completion.
  - Resolution or formal escalation within one (1) business day of triage completion.
- **Urgent severity**:
  - Response within two (2) business hours of triage completion.
  - Resolution or formal escalation within three (3) business days of triage completion.
- **High severity**:
  - Response within four (4) business hours of triage completion.
  - Resolution or formal escalation within five (5) business days of triage completion.
- **Normal severity**:
  - Response within one (1) business day of triage completion.
  - Resolution or formal escalation within ten (10) business days of triage completion.
- **Low severity**:
  - Response within two (2) business days of triage completion.
  - Resolution or formal escalation within twenty (20) business days of triage completion.
  - Where a Low severity work order carries a specified due date at the time of submission, that due date governs resolution in lieu of the default twenty (20) business day window.

Resolution commitments apply in full to IT-Managed assets as defined in **Policy 1.12**. For IT-Supported assets, the resolution commitment represents IT's obligation to initiate vendor escalation within the defined window, not to guarantee vendor resolution within that timeframe. Vendor resolution timelines for IT-Supported assets are governed by the applicable contract or service agreement. For Vendor-Managed assets, IT's commitment is limited to referral — the Information Operations Department shall route the request to the appropriate vendor contact within the response window defined above, and the vendor shall handle resolution execution entirely.

The Hard Fork jurisdictional transfer defined in **Policy 3.06** (Operational Incident Management Policy), is the sole mechanism under which the SLA obligations defined in this section are suspended for a work order. No other SLA suspension mechanism exists within the operational framework governed by this policy.

6.5 After-Hours and Emergency Response

The Information Operations Department maintains an on-call capability for after-hours emergencies. Severity level alone does not constitute sufficient basis for after-hours on-call activation. The IT Director or the on-call designee shall activate after-hours on-call response only when a mission-critical system supporting public safety operations, law enforcement functions, or a time-bound legal or financial obligation is completely non-functional and no operational workaround exists. Low and Normal severity work orders are explicitly excluded from after-hours on-call activation by definition.

Upon after-hours on-call activation, the designated on-call technician shall acknowledge the activation within thirty (30) minutes and shall commence active troubleshooting within one (1) hour. All after-hours timeframes are measured in continuous calendar hours from the time of activation. The on-call technician shall create a work order in the System of Engagement in accordance with **Policy 3.05**, and shall document all actions taken during the after-hours response in the work order.

The IT Director shall maintain and annually review the authoritative list of systems qualifying as mission-critical for purposes of after-hours on-call activation in the System of Engagement. The Administrative Assistant shall maintain after-hours contact procedures and on-call rotation schedules in the System of Engagement under Assistant IT Director direction. The Assistant IT Director shall approve changes to the rotation schedule before publication. These operational details are not enumerated in this policy.

6.6 Vendor SLA Requirements

The IT Director shall ensure that any contract or service agreement governing an IT-Supported or Vendor-Managed asset entered into or renewed following the effective date of this policy includes defined vendor response and resolution commitments as a condition of the engagement. The Assistant IT Director shall ensure that vendor SLA terms are documented at the time of contract execution and recorded in the IT Asset Catalog entry for the applicable system, subject to IT Director approval. The Assistant IT Director shall monitor vendor SLA performance in accordance with **Policy 3.02**. The Assistant IT Director shall evaluate vendor SLA performance under the vendor compliance framework established in **Policy 5.06**. Where an existing contract does not include defined service level terms, the Assistant IT Director shall identify the gap, document it in the IT Asset Catalog, and present it to the IT Director no later than ninety (90) days prior to the next available renewal opportunity so that incorporation of vendor SLA terms may be pursued at renewal.

3.02 Service Level Management and Metrics Reporting

Effective: April 29, 2026 Version: 2.6

1. Purpose

This policy governs the operational monitoring, measurement, and reporting of service level performance for the Elko County Information Operations Department.

2. Scope

This policy applies to all Information Operations personnel involved in service delivery, triage, escalation, vendor coordination, or performance reporting. County Department Heads hold limited review and feedback obligations as defined in Section 3.

- **In Scope**:
  - Service level performance data collection and monitoring.
  - SLA adherence tracking, deviation thresholds, and corrective action protocols.
  - Service level reporting at weekly, monthly, and quarterly cadences.
  - Vendor SLA performance monitoring and breach recording.
  - Recurring Ticket identification and analysis.
- **Out of Scope**:
  - SLA target definitions, severity classification, and asset lifecycle status: **Policy 3.01**.
  - Work order lifecycle, documentation, and closure standards: **Policy 3.05**.
  - Operational incident management: **Policy 3.06**.
  - System audit log collection and security event monitoring: **Policy 2.11**.
  - KPI taxonomy and quarterly governance review: **Policy 5.04**.
  - Internal audit and self-assessment: **Policy 5.02**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for all formal service level performance reports produced under Section 6.4.
  - Shall approve corrective action plans initiated under the Threshold 3 sustained non-compliance process defined in Section 6.3.
  - Shall review and acknowledge each Monthly Performance Summary Report within five (5) business days of receipt.
  - Shall authorize any formal deviation from reporting cadences or data collection standards established in this policy.
  - Shall ensure that performance data generated under this policy is integrated with the quarterly KPI review process defined in **Policy 5.04** (Performance Metrics and Operational KPIs).
- **Assistant IT Director:**

  - Shall serve as the primary operational owner of the service level management and reporting function.
  - Shall ensure that performance data is collected continuously and accurately from the work order system and any supporting monitoring tools.
  - Shall monitor SLA adherence in accordance with the intervals and procedures defined in Sections 6.1 and 6.2.
  - Shall compile, analyze, and submit the reports defined in Section 6.4 from inputs provided by the Systems Administrator, Network Administrator, and Support Specialists.
  - Shall identify deviations meeting the thresholds defined in Section 6.3.
  - Shall document identified deviations in the work order system.
  - Shall initiate the prescribed escalation or corrective action response for each deviation in accordance with Section 6.3.
  - Shall ensure that vendor SLA performance is tracked and reported in accordance with Section 6.5.
  - Shall prepare the quarterly performance data summary submitted to the IT Director for integration with **Policy 5.04** reporting.
- **Systems Administrator:**
  - Shall prepare server, endpoint, and infrastructure domain data inputs to the Monthly Performance Summary Report defined in Section 6.4.
  - Shall submit the prepared inputs to the Assistant IT Director no later than the third (3rd) business day of the following month.
- **Network Administrator:**
  - Shall prepare network availability, vendor escalation, and connectivity domain data inputs to the Monthly Performance Summary Report defined in Section 6.4.
  - Shall submit the prepared inputs to the Assistant IT Director no later than the third (3rd) business day of the following month.
- **Support Specialists:**
  - Shall prepare front-line work order data inputs to the Monthly Performance Summary Report defined in Section 6.4, including tickets opened and closed by severity, triage timeliness, and first-contact resolution data.
  - Shall submit the prepared inputs to the Assistant IT Director no later than the third (3rd) business day of the following month.
- **All Information Operations Personnel:**
  - Shall document all triage decisions, reclassifications, remediation milestones, escalation actions, and closure decisions in the work order system in sufficient detail to support accurate SLA adherence measurement.
  - Shall notify the Assistant IT Director within one (1) business hour when a work order is at risk of missing a response or resolution commitment.
  - Shall execute data collection and reporting tasks assigned by the Assistant IT Director under this policy.
- **County Department Heads:**

  - Shall review service level performance summaries for services used by their departments when distributed by the Assistant IT Director.
  - Shall communicate service delivery concerns to the Assistant IT Director through the work order system or direct written correspondence.

4. Compliance and Exceptions

Adherence to the data collection, monitoring, escalation, and reporting obligations defined in this policy is mandatory for all Information Operations personnel within scope. County Department Heads shall comply with the review and feedback obligations assigned in Section 3.

- **Assessment**: Compliance with this policy shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to collect required performance data, report deviations within the required windows, or produce reports on the cadences established in Section 6.4 shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

Cited References:

- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071558 (Activity Reports)

Framework Alignment:

- NIST CSF 2.0: GV.OV-03 (Performance Evaluated and Reviewed)

- NIST CSF 2.0: ID.IM-01 (Improvements Identified from Evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements Identified from Operational Processes)
- NIST SP 800-53 Rev. 5: PM-6 (Information Security Measures of Performance)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- ITIL v4: Measurement and Reporting Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Performance Data Collection

Business hours, as defined in **Policy 3.01** (Service Catalog and SLA Policy), govern all timeframe calculations in this policy. Work order creation, documentation, and closure standards governing the data elements consumed by this policy are defined in **Policy 3.05** (Service Request Fulfillment Policy).

The Assistant IT Director shall ensure that performance data collection is systematic, automated where the designated work order system provides reporting or alerting capability, and sufficient to support the SLA adherence measurements, deviation analyses, and reports defined in this policy.

- **Work Order System as System of Record**: The designated work order system is the authoritative source for all service level performance data. All Information Operations Personnel shall ensure that all triage completions, response actions, escalation events, and closure decisions are recorded in the work order system with timestamps accurate to the minute. The Assistant IT Director shall ensure that no performance measurement activity relies on data sources that are not traceable to the work order system or a formally designated supplementary monitoring tool approved by the IT Director.
- **Data Collection Intervals**: The Assistant IT Director shall verify adherence status at intervals sufficient to detect risk against the applicable SLA windows established in **Policy 3.01**. The following minimum monitoring frequencies apply:
  - **Critical severity**: The Assistant IT Director shall monitor adherence continuously through system alerting where the designated work order system provides alerting capability, and shall verify adherence status manually no less than every thirty (30) minutes from triage completion until the response action is logged.
  - **Urgent severity**: The Assistant IT Director shall verify adherence status manually no less than every one (1) business hour from triage completion.
  - **High severity**: The Assistant IT Director shall verify adherence status no less than every four (4) business hours from triage completion.
  - **Normal and Low severity**: The Assistant IT Director shall review adherence in aggregate no less than weekly.

These intervals represent minimum monitoring frequency. Where the designated work order system provides continuous automated alerting, the Assistant IT Director shall configure and maintain it to supplement the manual review obligations defined above.

- **Required Data Elements**: For each closed work order, the assigned technician shall capture and retain the following elements to support SLA adherence measurement:
  - Work order identifier and submission timestamp.
  - Assigned severity level at triage completion and triage completion timestamp.
  - Response action timestamp and responding technician.
  - Resolution or escalation timestamp and disposition.

  - Any reclassifications with documented rationale.
  - Asset support classification (IT-Managed, IT-Supported, or Vendor-Managed) as defined in **Policy 1.12** (IT Asset Management Policy).
  - Escalation chain and vendor contact timestamps where applicable.

- **Domain Data Preparation**: The Systems Administrator, Network Administrator, and Support Specialists shall extract their respective domain inputs prepared under Section 3 from the work order system or from supplementary monitoring tools formally designated by the IT Director under this section.
- **Domain Input Verification**: The Assistant IT Director shall verify completeness of all required domain inputs no later than the fourth (4th) business day of the following month.
- **Domain Input Escalation**: The Assistant IT Director shall escalate any missing or incomplete domain inputs to the IT Director as a Section 3 compliance failure attributable to the responsible role.
- **Automated Monitoring Tools**: Where automated monitoring tools are deployed to support service delivery, the Assistant IT Director shall ensure that tool outputs are integrated with the work order system or formally reconciled against it at minimum weekly. The Assistant IT Director shall review tool configurations and data collection parameters no less than annually and shall submit proposed changes to the IT Director for approval.

6.2 SLA Adherence Monitoring

The Assistant IT Director shall maintain ongoing visibility into SLA adherence across all active work orders, using the performance data defined in Section 6.1 and the service level commitments established in **Policy 3.01**.

- **Adherence Tracking**: The Assistant IT Director shall maintain a current adherence view of all open work orders that are within or approaching their response or resolution windows. The Assistant IT Director shall update this view continuously from the work order system and shall make it accessible to Information Operations Personnel for self-monitoring.
- **At-Risk Identification**: The Assistant IT Director shall classify a work order as At-Risk when seventy-five percent (75%) or more of its applicable response or resolution window has elapsed without the required action being completed. At the time of At-Risk classification, the Assistant IT Director shall notify the assigned technician and flag the work order status in the system. The assigned technician shall acknowledge the At-Risk flag and provide a written status update within one (1) business hour of notification. If the assigned technician does not acknowledge the At-Risk flag within the one (1) business hour window, the Assistant IT Director shall escalate the work order directly and document the escalation in the work order record.
- **Breach Detection**: The Assistant IT Director shall record a work order as an SLA Breach when the applicable response or resolution commitment has not been met by the deadline established in **Policy 3.01**. The Assistant IT Director shall record all SLA Breaches in the work order system with a Breach designation, the breach timestamp, and the technician of record at time of breach.

  Clarification: SLA Breaches are distinct from formal escalations. A work order may breach a commitment and remain under active remediation.
- **Trend Monitoring**: The Assistant IT Director shall review SLA adherence trends no less than monthly, examining breach rates by severity level, by technician, by asset support classification, and by service category. The Assistant IT Director shall incorporate trend data into the Monthly Performance Summary Report defined in Section 6.4.

6.3 Deviation Thresholds and Corrective Action Protocol

Not all SLA deviations require the same response. This section establishes the thresholds at which a deviation escalates from a work order management issue to a documented operational deficiency requiring

formal action, and defines the required response at each threshold.

- **Threshold 1 — Individual Breach (Operational Response)**: A single SLA Breach shall trigger a breach review by the Assistant IT Director within one (1) business hour of breach detection. The Assistant IT Director shall document the cause in the work order record and determine whether the breach resulted from (a) resource or workload conditions, (b) a process or triage failure, (c) a vendor response gap, or (d) an approved exception. No formal corrective action plan is required for an isolated breach, but the Assistant IT Director shall retain the cause documentation and count it toward threshold calculations below.
- **Threshold 2 — Severity-Weighted Breach Rate (Formal Review)**: When the SLA breach rate for any individual severity level exceeds ten percent (10%) of all work orders at that severity level within any rolling thirty (30) calendar day period, the Assistant IT Director shall initiate a formal review. The Assistant IT Director shall document the formal review in writing, complete it within five (5) business days of threshold detection, and submit it to the IT Director. The review shall identify systemic causes, affected services or personnel, and recommended remediation. The IT Director shall approve or direct modifications to the recommended remediation within five (5) business days of receipt.
- **Threshold 3 — Sustained Non-Compliance (Corrective Action Plan)**: When a formal review under Threshold 2 identifies the same root cause for the second consecutive thirty (30) calendar day period, or when the breach rate for any severity level exceeds twenty percent (20%) in any single thirty (30) calendar day period, the Assistant IT Director shall initiate a formal Corrective Action Plan (CAP) under **Policy 5.03** (Compliance Monitoring and Corrective Action). The Assistant IT Director shall assign the CAP, submit it to the IT Director for approval, and track it to closure. The Assistant IT Director shall report open CAPs in the Monthly Performance Summary Report defined in Section 6.4.
- **Vendor-Specific Deviation**: When a vendor governing an IT-Supported asset fails to meet contracted SLA terms and the failure results in an IT breach of the referral or escalation commitment defined in **Policy 3.01**, the Assistant IT Director shall document the vendor failure separately from the IT breach record. The Assistant IT Director shall maintain vendor performance data as defined in Section 6.5. The Assistant IT Director shall escalate sustained vendor SLA failures to the vendor compliance framework under **Policy 5.06** (Vendor Compliance and Third-Party Assurance).

The Assistant IT Director shall route deviations identified under Thresholds 1 and 2 that do not meet the criteria for a Corrective Action Plan but indicate a systemic improvement opportunity to the Service Improvement Register maintained under **Policy 3.16** (Service Improvement and Continual Improvement Plan). The Assistant IT Director shall route deviations between **Policy 3.16** and **Policy 5.03** using the criteria defined in **Policy 5.04**.

6.4 Service Level Reporting

The Information Operations Department shall produce and distribute service level performance reports on the following cadences, with the defined content and distribution.

- **Weekly At-Risk and Open Ticket Summary**: The Assistant IT Director shall produce a brief internal summary each week identifying all open work orders classified as At-Risk, all open SLA Breaches in active remediation, and any Threshold 2 formal reviews in progress. Distribution is internal to Information Operations Personnel. The Assistant IT Director shall retain this report for a minimum of two (2) calendar years from the year created, in accordance with LRDA 20071558.
- **Monthly Performance Summary Report**: The Assistant IT Director shall compile and submit a formal Monthly Performance Summary Report to the IT Director no later than the seventh (7th) business day of the following month, incorporating the domain inputs provided by the Systems Administrator, Network Administrator, and Support Specialists under Section 3. This report shall include, at minimum:
  - Total work orders opened and closed by severity level.

  - SLA compliance rate by severity level, expressed as a percentage of work orders meeting both response and resolution commitments.
  - Breach count and breach rate by severity level.
  - Open Corrective Action Plans and their current status.
  - Vendor SLA performance summary as defined in Section 6.5.
  - Recurring Ticket analysis as defined in Section 6.6.
  - Any trends or anomalies identified during the reporting period that are not captured by the preceding data elements.
- **Quarterly Contribution to KPI Framework**: No later than ten (10) business days following the close of each calendar quarter, the Assistant IT Director shall prepare and submit to the IT Director a Quarterly Service Level Performance Summary for integration with the departmental KPI review process defined in **Policy 5.04** (Performance Metrics and Operational KPIs). This summary shall aggregate the three (3) preceding monthly reports and provide trend analysis across the quarter for all service level KPIs identified in **Policy 5.04** that are sourced from service level management data. The IT Director shall include this summary in the quarterly KPI review.
- **On-Request Reporting**: The IT Director may request performance reports outside the standard cadences for any purpose, including audit preparation, vendor negotiations, budget planning, or executive presentation. The Assistant IT Director shall produce requested reports within the timeframe specified by the IT Director, not to exceed five (5) business days. The IT Director may authorize an extended timeline for requests requiring complex data extraction or cross-system reconciliation by documented approval specifying the revised deadline.
- **Report Format and Retention**: The Assistant IT Director shall store all formal reports produced under this section in the System of Engagement and shall retain them in accordance with NRS 239.125 and LRDA 20071558 (Activity Reports) for a minimum of three (3) years from the date of production. Where a longer retention period is required by another applicable authority, the longest applicable period shall govern. The Assistant IT Director shall review report formats annually for accuracy and utility and shall submit proposed format changes to the IT Director for approval.

6.5 Vendor SLA Performance Monitoring

For all IT-Supported and Vendor-Managed assets governed by a vendor contract that includes defined service level terms, as required by **Policy 3.01**, the Information Operations Department shall maintain active monitoring of vendor adherence to those terms.

- **Vendor Performance Tracking**: The Assistant IT Director shall maintain a vendor SLA performance record for each IT-Supported and Vendor-Managed asset with contractual service level terms, recorded in the asset's entry in the IT Asset Catalog maintained under **Policy 3.01**. This record shall capture:
  - Contracted response and resolution commitments.
  - Each vendor escalation event, including the timestamp IT initiated contact, the timestamp vendor acknowledged, and the timestamp vendor resolved or reported status.
  - A running compliance calculation for each vendor across the current contract period.
- **Vendor Breach Recording**: The Assistant IT Director shall record a vendor SLA breach when a vendor fails to meet a contracted response or resolution commitment. Vendor breaches are separate from IT SLA breaches; the Assistant IT Director shall include them in the Monthly Performance Summary Report required by Section 6.4. The Assistant IT Director shall preserve vendor breach records in accordance with the vendor compliance retention framework established in **Policy 5.06**, and shall make them available to the IT Director and, where applicable, to the vendor compliance review process under **Policy 5.06**.

- **Contract Renewal Input**: No later than ninety (90) calendar days prior to any contract renewal, the Assistant IT Director shall prepare a vendor SLA performance summary for IT Director review. This summary shall inform vendor compliance evaluation under **Policy 5.06** and shall be retained as part of the contract renewal documentation.
- **Contracts Without Defined SLA Terms**: For existing contracts that do not include defined service level terms, as identified under **Policy 3.01**, the Assistant IT Director shall document vendor response and resolution performance by extracting and analyzing all available vendor communication timestamps, ticket histories, and resolution logs currently held within the work order system. The Assistant IT Director shall use this documentation to support SLA negotiation at renewal.

6.6 Recurring Ticket Analysis and Upward Reporting Integration

- **Recurring Ticket Identification**: As defined in this section, a work order shall be flagged as a Recurring Ticket when the same user submits a work order in the same work order category as a prior closed work order within any rolling ninety (90) calendar day window, and the prior work order was closed as resolved. The Assistant IT Director shall review the work order system monthly to identify Recurring Ticket patterns and shall ensure that all Recurring Tickets are flagged in the system.

  Clarification: The Recurring Ticket construct defined in this section is distinct from the Recurring Incident Trigger defined in **Policy 3.06** (Operational Incident Management Policy). The Recurring Ticket identifies user-centric recurrence patterns within a ninety (90) calendar day window for reporting purposes. The Recurring Incident Trigger identifies asset-centric failure patterns within a thirty (30) calendar day window for Problem investigation under **Policy 3.07**. Both constructs may identify the same work orders; they serve different governance functions and both shall be evaluated independently.
- **Root Cause Assignment**: Each Recurring Ticket flag shall trigger assignment of a root cause determination by the Assistant IT Director or delegated technician. The Assistant IT Director or delegated technician shall document root cause determinations in the work order record within five (5) business days of the Recurring Ticket flag and shall classify the cause as one of the following: (a) user training or documentation gap, (b) unresolved underlying technical issue, (c) process failure, or (d) environmental or infrastructure condition. The Assistant IT Director shall report root cause classifications in the Monthly Performance Summary Report.
- **Upward Reporting to Policy 5.04**: The monthly and quarterly reports produced under Section 6.4 of this policy constitute the primary data feed from this policy into the organizational performance management function governed by **Policy 5.04**. The following service level KPIs identified in **Policy 5.04** are sourced from this policy's data collection and reporting activities: SLA compliance rate, Recurring Ticket Ratio, Mean Time to Repair/Recovery (MTTR), and first contact resolution rate. The Assistant IT Director shall ensure these values are accurately derived from the work order system and accurately reported in the quarterly contribution required by Section 6.4. All Information Operations Personnel shall not establish separate data collection processes for these KPIs outside this policy; **Policy 5.04** reporting shall draw from the authoritative values produced here.

3.03 Service Communications Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy establishes mandatory standards for all service-related operational communications conducted by Elko County Information Operations (ECIO) Department personnel with end users, internal stakeholders, vendors, and external partners.

2. Scope

This policy applies to all Information Operations Department personnel and governs verbal, written, and electronic communications conducted in connection with request intake, troubleshooting, service fulfillment, coordination, escalation, vendor interaction, and service closure.

- **Out of Scope**:
  - Cybersecurity incident communications during active incident response: **Policy 4.06**.
  - Governance-level stakeholder engagement, strategic reporting, and crisis communications: **Policy 1.14**.
  - Procurement negotiations and vendor contract terms: **Policy 1.13**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the final authority on communication standards and style determinations.
  - Shall conduct or authorize spot audits of communication quality and traceability as part of quarterly reviews, postmortems, or compliance assessments.
  - Shall approve all exceptions to this policy in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall ensure vendor and external partner communication expectations are codified in applicable contracts and service agreements in coordination with **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance).
- **Assistant IT Director:**
  - Shall ensure that all Information Operations personnel are trained on and consistently applying the communication standards defined in this policy.
  - Shall review communication quality through periodic audits and shall flag systemic communication deficiencies to the IT Director.
  - Shall maintain documentation templates and work order notation standards in the System of Engagement.
- **All Information Operations Personnel:**
  - Shall follow the communication protocols defined in this policy for all service interactions, including documentation, clarification, escalation, and closure.
  - Shall ensure that verbal and informal communications are summarized in the relevant work order within one (1) business day.

  - Shall apply the communication standards defined in this policy in all written and verbal interactions conducted on behalf of the Department.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel.

- **Assessment**: Communication quality, channel compliance, and documentation traceability shall be assessed as part of quarterly service reviews, postmortem processes, and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Repeated failure to document communications, use required channels, or adhere to the communication and conduct standards defined in this policy shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. Oral exceptions are not valid. Exception documentation procedures are defined in Section 6.1.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- CJIS Security Policy v6.0: Section SI-12 (Information Management and Retention)

Framework Alignment:

- LRDA 20071280 (Correspondence: Transitory)
- LRDA 20071715 (Work Orders)
- LRDA 20141919 (Correspondence: Routine Business)
- NIST SP 800-53 Rev. 5: AU-3 (Content of Audit Records)
- NIST SP 800-53 Rev. 5: AU-6 (Audit Record Review, Analysis, and Reporting)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- COBIT 2019: APO09 (Manage Service Agreements)

- COBIT 2019: APO10 (Manage Vendors)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Service Desk Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

Professional and documented communication is foundational to service accountability, operational continuity, and public trust. The standards defined in this section ensure that all service-related interactions conducted by Information Operations personnel — regardless of channel or audience — are traceable, appropriately scoped, and consistent with the Department's governance obligations.

6.1 Required Communication Channels

The designated work order system is the authoritative channel for all service requests, technical communications, and service lifecycle documentation. Work order records are subject to the retention obligations established in NRS 239.125 (Local Government Records Management Program) and NAC 239.155 (Retention and Disposition of Local Government Records).

- **Channel Mandate**: Unless the designated work order system is inaccessible due to a documented system outage, All Information Operations Personnel shall initiate, track, and close all service requests and IT responses within the designated work order system. Channel exceptions require justification documented in the relevant work order.
- **Out-of-Band Summarization**: All Information Operations Personnel shall summarize verbal or informal communications — including hallway conversations, phone calls, and instant messages — and enter the summary into the relevant work order within one (1) business day of the interaction, or prior to ticket closure, whichever occurs first.
- **Private Notes Use**: All Information Operations Personnel shall default to standard, user-visible notes for all ticket documentation and shall use Private Notes only for the following authorized purposes:
  - Documenting internal security vulnerabilities or unpatched exploit data.
  - Redacting or handling accidental spillage of PII, PHI, or CJI.
  - Documenting personnel-sensitive actions such as HR-directed account lockouts.
  - Internal technical diagnostics that would not be meaningful for the end user.

  Clarification: Private Notes remain subject to applicable retention obligations and public records law.
- **Vendor and External Partner Communications**: All Information Operations Personnel shall summarize communications with vendors or external partners in the relevant work order or project record within one (1) business day. Where such communications occur outside the designated work order system, the summary shall document the substance of those communications.
- **Documentation Substitution**: When an approved exception to this policy precludes full documentation, the authorized Information Operations Personnel shall summarize the exception using Private Notes in accordance with the constraints defined above and within one (1) business day. Where the sensitive nature of an exception precludes narrative documentation, the authorized Information Operations Personnel shall generate a placeholder record in the designated work order system referencing the authorized exception without disclosing the sensitive content.

6.2 Written Communication as Default

Written communication is the departmental standard. All Information Operations Personnel shall default to written communication for all service interactions to reduce ambiguity, support auditability, and ensure

continuity of service knowledge across staff. Intake routing for verbal and informal requests is governed by **Policy 3.05** (Service Request Fulfillment Policy).

6.3 E-Prime Communication Guidance

The following guidance is advisory and supports the clarity objectives of this policy.

Information Operations Personnel may apply English Prime (E-Prime) principles in written communications — specifically, avoiding forms of the verb "to be" when greater precision or flexibility would benefit the communication. This practice reduces false certainty in service communications and naturally invites end-user confirmation.

For example: "This appears to be resolved" or "This should be working now — please verify" invites the user to confirm, whereas "This is fixed" places the user in a position of either agreement or conflict. The goal is not to introduce ambiguity, but to invite collaborative confirmation and reduce premature closure of unresolved issues.

6.4 Disambiguation and Clarity

All Information Operations Personnel shall communicate in plain language accessible to non-technical County staff.

- All Information Operations Personnel shall define acronyms and technical jargon before using them in end-user communications.
- When multiple questions are required, All Information Operations Personnel shall number them individually. Example: "1. When did the issue begin? 2. What error message appears? 3. Can you reproduce the issue consistently?" This format reduces missed answers and vague responses.
- All Information Operations Personnel shall avoid compound or binary questions that allow for ambiguous single-word answers. Example: "Can I come before or after lunch?" invites the response "Yes." The clearer form is "Can I come before lunch? If not, what time after lunch works for you?" The goal is not to talk down to users, but to provide prompts precise enough that their responses are actionable.

6.5 Vendor and External Partner Communications

When communicating with vendors or external partners on behalf of the Department, All Information Operations Personnel shall maintain the same documentation and clarity standards as for end-user communications. All Information Operations Personnel shall confirm commitments made to vendors — including agreed timelines, approved scopes, or escalation acknowledgments — in writing and shall document them in the relevant work order or contract record. All Information Operations Personnel shall not communicate acceptance of deliverables, changes to contracted scope, or authorization of additional costs without IT Director approval in accordance with **Policy 1.08** and **Policy 1.13**.

6.6 Accountability in Language

All Information Operations Personnel shall use precise language of personal and departmental accountability in service communications.

- All Information Operations Personnel shall use "I" when taking personal responsibility for a specific action or commitment. Example: "I will follow up with you by 3:00 PM today."
- All Information Operations Personnel shall use "We" when speaking on behalf of the Department as a whole. Example: "We received your request and are currently reviewing it."
- All Information Operations Personnel shall not imply action, approval, or authority beyond the scope of their assigned role. Commitments that exceed role authority shall be escalated to the designated authority as defined in **Policy 1.08** before being communicated to the user or vendor.

6.7 Information Spillage Prevention

All Information Operations Personnel shall not instruct or permit end users to transmit passwords, Criminal Justice Information (CJI), or unprotected Personally Identifiable Information (PII) through standard work order notes or unencrypted email. If a user transmits such data into a work order, the receiving Information Operations Personnel shall immediately move the data to a Private Note, sanitize the user-facing record, and initiate the data spillage protocols required by **Policy 4.02** (Identification and Reporting Procedures), consistent with CJIS Security Policy v6.0: SI-12 (Information Management and Retention).

6.8 Communication During Service Incidents

During active service incidents or outages, the communication standards defined in this policy remain in effect for documentation and channel requirements. Operational service incidents remain governed by **Policy 3.06** (Operational Incident Management Policy) and the communication standards of this policy remain in effect unless a Chapter 4 incident is declared.

- **Operational Outage Notifications**: The IT Director and designated Information Operations Personnel shall follow the stakeholder notification standards defined in **Policy 1.14** (Stakeholder Engagement and Communications Policy) for scheduled maintenance, unplanned outages, and root cause analyses.
- **Cybersecurity Incident Communications**: All communications governed by Chapter 4 authority during active cybersecurity incident response — including notification timelines, external reporting obligations, and the One Voice Rule — are defined in **Policy 4.06** (Communication Protocols and Partner Integration). During active cybersecurity incident response, **Policy 4.06** supersedes this policy for all incident-related communications.
- **Authorization Requirement**: All Information Operations Personnel shall not communicate incident scope, affected systems, or estimated recovery timelines to external parties, media, or non-IT County staff without IT Director authorization.

3.04 Service Delivery Feedback and Grievance Policy

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy governs the receipt, routing, and disposition of service-related feedback and grievances directed at or concerning the Elko County Information Operations Department (ECIO). It defines service quality under the Department's compliance-enforcement mandate, establishes authorized feedback channels and formal grievance pathways, and decouples staff performance evaluation from end-user satisfaction with compliance outcomes.

2. Scope

This policy applies to all Information Operations Department personnel.

- **In Scope**:
  - Service-related feedback, complaints, and grievances concerning service delivery, technical decisions, and compliance-enforcement activities conducted by Information Operations Department personnel.
- **Out of Scope**:
  - Personnel and employment complaints: County Human Resources processes and applicable collective bargaining agreements.
  - Professional conduct standards: **Policy 1.02** and **Policy 1.03**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the primary authority for receiving, evaluating, and dispositioning service-related grievances brought by department heads or end users.
  - Shall solicit feedback from the County Manager at each regularly scheduled monthly meeting as a minimum cadence, and may bring matters to the County Manager outside that cadence when circumstances warrant.
  - Shall receive and evaluate upward feedback from IT staff through the chain of command.
  - Shall evaluate grievances against IT personnel by reference to the compliance record, the communication standards in **Policy 3.03** (End-User Communication Standards), and the conduct standards in **Policy 1.02** (Code of Ethics and Professional Conduct) and **Policy 1.03** (Standard Operating Ethos).
  - Shall document grievance dispositions in the documentation system designated by the IT Director.
  - Shall not be subject to lateral pressure from department heads on technical or compliance decisions.
- **County Manager:**
  - Shall serve as the escalation authority for department heads unsatisfied with the IT Director's disposition of a service grievance.

  - Shall serve as the direct authority for complaints about the IT Director.
- **Assistant IT Director:**
  - Shall receive and route service-related feedback and complaints directed to the Department.
  - Shall ensure that Information Operations personnel are aware of and consistently apply the grievance pathways defined in this policy.
  - Shall surface staff-sourced operational feedback to the IT Director through the established chain of command.
- **All Information Operations Personnel:**
  - Shall document service-related feedback received through informal channels in the relevant work order in accordance with the documentation and channel requirements of **Policy 3.03**.
  - Shall escalate complaints or expressions of dissatisfaction that exceed their authority to the Assistant IT Director or IT Director within the same business day the complaint is received.
  - Shall not commit to operational or compliance-related changes in response to end-user or departmental pressure without authorization from the appropriate authority as defined in **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Department Heads:**
  - Shall direct service-related grievances to the IT Director in writing.
  - Shall not use informal channels, lateral communication, or HR processes as substitutes for the grievance pathways defined in this policy.
  - Shall direct requests to relax or waive compliance standards through the risk management process defined in **Policy 1.09** (Risk Management Policy), not through the grievance pathways in this policy.

4. Compliance and Exceptions

Adherence to the routing and documentation requirements of this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with grievance routing and documentation requirements shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to route, document, or disposition service-related feedback in accordance with this policy may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved by the IT Director in accordance with **Policy 1.08**, except where the exception concerns a complaint about the IT Director, in which case County Manager approval is required. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.02: Code of Ethics and Professional Conduct
- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.06: IT Governance and Oversight Structure
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 3.03: End-User Communication Standards
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NRS 244 (Counties: Government)
- NRS 281A (Ethics in Government)
- NIST CSF 2.0: GV.OC-02 (Stakeholder Expectations)
- NIST CSF 2.0: GV.RR-01 (Leadership Accountability)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-2 (Information Security Program Leadership)
- COBIT 2019: APO09 (Manage Service Agreements)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- ITIL v4: Relationship Management Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

6.1 Definition of Service Quality

The Information Operations Department operates as a compliance-enforcement and technology governance function within Elko County. The Department's mandate is to establish, maintain, and enforce compliance with information and technology standards, and to bring non-compliant systems and practices into alignment with those standards. It does not operate as a hospitality or satisfaction-driven service organization, and end-user satisfaction with the outcome of a compliance decision does not constitute a measure of service quality under this mandate.

Service quality is defined by accuracy, auditability, and adherence to policy. A technician who brings a non-compliant system into compliance clearly, professionally, and in accordance with the communication standards defined in **Policy 3.03** has delivered service of the highest quality, regardless of whether the end user found the outcome convenient or welcome.

The IT Director is accountable to the County Manager for the performance and conduct of the Department. Department heads and end users are not the Department's managerial authority, and their dissatisfaction with a technically correct and professionally executed compliance action does not constitute grounds for corrective action against IT personnel.

6.2 Authorized Feedback Channels

The Department does not operate passive feedback collection mechanisms such as satisfaction surveys, open feedback forms, or suggestion systems. End-user satisfaction with compliance outcomes is not an operational input to technical standards or service delivery decisions, and passive feedback mechanisms of this type do not produce actionable intelligence sufficient to justify the administrative overhead or the implied premise that survey sentiment governs operational direction.

The Department accepts feedback through the following authorized channels:

- **County Manager**: The IT Director shall solicit feedback from the County Manager at each regularly scheduled monthly meeting as a minimum cadence. This does not limit communication — the County Manager may raise concerns, complaints, commendations, or observations at any time through any channel, and the IT Director may likewise bring matters to the County Manager outside the scheduled meeting when circumstances warrant. The monthly meeting establishes the routine checkpoint; it does not constrain the relationship to that interval. The IT Director shall document the substance of any actionable feedback received through this channel in the documentation system designated by the IT Director and shall initiate a response or corrective action as warranted.
- **Work Order System and Written Correspondence**: End users and department heads may provide service-related feedback through the designated work order system or in direct written correspondence addressed to the IT Director. IT personnel shall document feedback received informally — including verbal complaints and hallway conversations — in the relevant work order in accordance with **Policy 3.03**. The IT Director or Assistant IT Director shall acknowledge feedback submitted through the work order system or written correspondence within five (5) business days of receipt.
- **IT Staff (Upward Feedback)**: IT personnel shall surface operational feedback, service delivery concerns, and process improvement observations to their direct supervisor or the IT Director through the established chain of command. Staff observations have direct operational value as the Department's primary ground-level intelligence on service delivery effectiveness and shall be actively solicited and considered by Department leadership. This upward feedback channel is the Department's principal mechanism for identifying process improvements and service delivery gaps.

6.3 Grievance Pathways

Service-related grievances — defined as formal expressions of dissatisfaction with IT service delivery, technical decisions, or compliance-enforcement actions — shall be routed exclusively through the pathways defined in this section. These pathways are the only legitimate channels for service grievances. Informal or lateral communications that attempt to circumvent these pathways — including direct appeals to County leadership outside the defined chain, back-channel pressure on IT staff, or misrouting of service disputes into HR processes — are not recognized as valid grievance submissions under this policy. The IT Director or Assistant IT Director shall redirect misdirected grievances received by the Department to the appropriate pathway defined in this section and shall document the redirection in the documentation system designated by the IT Director.

- **Grievance against an IT technician or staff member**: The complainant shall submit the grievance in writing to the IT Director. The IT Director shall evaluate the grievance against the compliance record, the communication standards in **Policy 3.03**, and the conduct standards in **Policy 1.02** and **Policy 1.03**. Where the grievance concerns a technically correct and professionally executed compliance action, the IT Director shall document the finding, close the matter, and provide written notification of the disposition to the complainant. Where the grievance identifies a legitimate conduct or process deficiency, the IT Director shall initiate appropriate corrective action through the Department's internal performance management process. The IT Director shall document grievance dispositions in the documentation system designated by the IT Director.
- **Grievance against the IT Director**: The complainant shall direct the grievance to the County Manager. The County Manager serves as the IT Director's administrative authority under the governance structure established in **Policy 1.06** (IT Governance and Oversight Structure) and the delegation framework in **Policy 1.08**, and is the appropriate party to evaluate complaints about the IT Director's decisions or conduct. This pathway shall not be used as a mechanism to compel changes to compliance policy or technical standards; such requests remain subject to the risk management process in **Policy 1.09** regardless of the channel through which they are raised.
- **Department head escalation**: Where a department head is unsatisfied with the IT Director's written disposition of a service grievance, the department head may escalate the matter to the County

Manager. This pathway represents the final internal escalation available for service-related disputes.

- **Compliance relaxation requests**: A request by any party to relax, waive, or deviate from a technical standard or compliance control is not a service grievance and shall not be processed through the pathways defined in this section. The IT Director shall route such requests through the formal risk acceptance process defined in **Policy 1.09**. This determination applies regardless of how the request is framed.

6.4 Staff Protection and Performance Evaluation

IT personnel shall not be subject to negative performance evaluations, formal corrective action, or adverse informal treatment on the basis of end-user or departmental dissatisfaction with a compliance outcome, provided the personnel member acted in accordance with the technical standards of this manual, the communication standards of **Policy 3.03**, and the conduct standards of **Policy 1.02** and **Policy 1.03**.

This protection is precise in its scope. It shields IT personnel from lateral political pressure to violate or circumvent compliance standards. It does not shield personnel from accountability for:

- Genuine conduct deficiencies, including rudeness, unprofessional behavior, or violations of **Policy 1.02** or **Policy 1.03**.
- Errors in technical execution or professional judgment.
- Failure to document actions in accordance with the requirements of **Policy 1.03** and **Policy 3.03**.
- Failure to escalate appropriately within the chain of command as defined in **Policy 1.03** and **Policy 1.08**.

The IT Director or Assistant IT Director shall conduct performance evaluations for IT personnel in accordance with **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework). External pressure from department heads or end users shall not substitute for, or override, the Department's internal performance evaluation process.

6.5 Boundary with HR and Personnel Processes

This policy governs service-related feedback and grievances only. Complaints alleging employee misconduct, harassment, discrimination, ethics violations, or other employment-related matters are not service grievances and are not governed by this policy. IT personnel who receive such complaints shall direct them to the County's Human Resources function for handling in accordance with County HR policies and applicable collective bargaining agreements, regardless of whether the subject of the complaint is an IT staff member.

The distinction between a service grievance and a personnel complaint shall be determined by the substance of the allegation, not its framing or channel of submission. A complaint that characterizes a technically correct and professionally executed compliance action as hostile, inappropriate, or otherwise objectionable — when submitted to HR rather than through the grievance pathways in Section 6.3 — remains a service grievance and shall be evaluated as such. When the IT Director redirects a complaint from the HR channel to the service grievance process, the IT Director shall notify HR of the routing decision and its rationale in writing.

Conversely, a genuine allegation of misconduct — including an alleged violation of the Code of Ethics under **Policy 1.02** — that arises in the context of a service interaction shall not be processed under this policy. The IT Director shall route such allegations to HR immediately upon identification. Where the allegation is directed against the IT Director, the County Manager shall be notified directly and HR shall be engaged by the County Manager.

3.05 Service Request Fulfillment Policy

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy governs the lifecycle of work order management within the Elko County Information Operations Department, from intake through authorized closure, and establishes the Deprecated Asset labor ceiling framework.

2. Scope

This policy applies to all Information Operations Department personnel and governs all work performed by the Department, whether reactive or proactive.

- **In Scope**:
  - User-submitted service requests and reactive work orders.
  - IT-initiated work orders, including infrastructure maintenance, compliance remediations, and internal projects.
  - Work order triage, authorization, execution, documentation, and closure standards.
  - Deprecated Asset labor ceiling framework and disposition review process.
  - Emergency exception procedures for work order creation.
- **Out of Scope**:
  - Service level commitments, asset lifecycle classifications, and triage severity framework: **Policy 3.01**.
  - Performance monitoring and metrics reporting: **Policy 3.02**.
  - Service communication standards and documentation channel requirements: **Policy 3.03**.
  - Feedback and grievance framework: **Policy 3.04**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for IT-initiated work orders requiring Director-level authorization as defined in Section 6.3.
  - Shall issue written disposition decisions for Deprecated assets escalated by the Assistant IT Director under the labor ceiling framework defined in Section 6.5, within the timeframes specified therein.
  - Shall authorize continued remediation beyond the standard labor ceiling by written notation in the work order, in accordance with **Policy 3.01** (Service Catalog and SLA Policy).
  - Shall review emergency exception work orders in aggregate no less than quarterly in accordance with Section 6.8.
- **Assistant IT Director:**

  - Shall ensure that work order intake, triage, and documentation standards are consistently applied by all Information Operations personnel in accordance with this policy and work order operational standards maintained in the System of Engagement.
  - Shall monitor the work order queue for compliance with triage timeliness obligations defined in **Policy 3.01**.
  - Shall conduct disposition reviews for Deprecated assets flagged under the labor ceiling framework and shall escalate to the IT Director where required, within the timeframes defined in Section 6.5.
  - Shall ensure that emergency exception work orders are created and acknowledged within the timeframes defined in Section 6.8.
  - Shall conduct monthly audits of work order closure quality and report findings to the IT Director.
- **All Information Operations Personnel:**
  - Shall create a work order for every actionable task, without exception, regardless of task origin or channel of identification.
  - Shall adhere to the intake, triage, documentation, and closure standards defined in this policy and work order operational standards maintained in the System of Engagement.
  - Shall flag Deprecated assets meeting objective trigger thresholds, or submit written technical assessments through the Technician Judgment Pathway, as defined in Section 6.5.
  - Shall document emergency actions and create catch-up work orders within the timeframes defined in Section 6.8.
- **County Personnel and Department Heads:**
  - Shall utilize the designated work order system as the primary and initial method for submitting all service requests.
  - Shall route walk-in and telephone requests to the work order system in accordance with Section 6.2 when directed to do so by Information Operations Personnel.
  - Shall respond to Information Operations requests for additional information within five (5) consecutive business days to prevent work order closure under the provisions of Section 6.4.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with work order creation, documentation, triage, and closure obligations shall be assessed through the service level reporting process defined in **Policy 3.02** (Service Level Management and Metrics Reporting) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to create required work orders, document actions within work orders, or meet closure standards without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.03: Service Communications Policy
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Local Government Records)
- LRDA 20071715 (Work Orders)
- CJIS Security Policy v6.0: Section SI-12 (Information Management and Retention)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: ID.AM-01 (Hardware Inventories)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: MA-2 (Controlled Maintenance)
- NIST SP 800-53 Rev. 5: SA-22 (Unsupported System Components)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Service Request Management Practice

6. Policy Statement

The work order is the non-negotiable unit of accountability for all work performed by the Information Operations Department. This policy establishes the work order as the authoritative record of why a task was undertaken, who authorized it, what was done, and how it was resolved. Work order operational standards maintained in the System of Engagement govern the technical anatomy of work orders — field definitions, status workflows, category taxonomy, and the terminal closure state — and are incorporated by reference throughout this policy. Where this policy establishes procedural mandates, work order operational standards provide the operational detail for executing them.

6.1 Work Order as Universal Requirement

All Information Operations Personnel shall create a work order for every actionable task, without exception. This obligation applies regardless of whether the work is reactive or proactive, regardless of the channel through which the work was identified or requested, and regardless of the estimated duration or complexity of the task.

No Information Operations Personnel shall perform IT work, or make a commitment to perform IT work, without an associated work order. The absence of a work order for completed work constitutes a documentation failure regardless of the operational outcome.

The creation of a work order indicates that a request has been submitted to the Information Operations Department for evaluation. It does not guarantee acceptance or execution. The assigned technician or queue

reviewer shall disposition work orders that fall outside the scope of Information Operations responsibilities, that are submitted for Unsupported assets, or that cannot be resourced within current operational capacity in accordance with work order operational standards maintained in the System of Engagement and this policy.

6.2 Intake and Channel Routing

The designated work order system is the authoritative intake channel for all service requests. All Information Operations Personnel shall route requests received through any other channel to the work order system immediately, and in all cases no later than one (1) business hour following the receipt of the request or the initiation of the task, whichever occurs first.

- **Walk-in requests**: When a County employee presents a request in person, the receiving Information Operations Personnel shall direct the requester to submit the request through the work order system. Where the requester is unable to do so, the receiving Information Operations Personnel shall create the work order on the requester's behalf, ensuring that the Requested By field accurately identifies the actual requester in accordance with work order operational standards maintained in the System of Engagement.
- **Telephone requests**: The receiving Information Operations Personnel shall handle requests received by telephone in the same manner as walk-in requests. The receiving Information Operations Personnel shall create a work order concurrent with or immediately following the call and shall document the substance of the conversation in the work order notes in accordance with the out-of-band summarization requirements of **Policy 3.03** (Service Communications Policy).
- **Email and informal digital communications**: The receiving Information Operations Personnel shall route requests received by email or other informal digital channels to the work order system. The receiving Information Operations Personnel shall summarize the communication in the work order notes in accordance with **Policy 3.03**.

In all cases, the work order is the record of the request. Channel acknowledgment to the requester — including verbal or informal confirmation — does not substitute for work order creation. Information Operations Personnel shall not begin work on a request prior to work order creation except as provided under the emergency exception in Section 6.8.

6.3 IT-Initiated Work Orders

The Information Operations Department regularly initiates work that is not triggered by a user request. This includes infrastructure maintenance, proactive upgrades, compliance remediations, internal projects, and any other IT-driven activity that constitutes actionable work. All Information Operations Personnel shall create a work order for all IT-initiated work, and all IT-initiated work orders shall be designated using the Internal Project checkbox as defined in the System of Engagement. The Internal Project designation is mandatory for all IT-initiated work without exception.

Authorization requirements for IT-initiated work orders are as follows:

- **Routine IT-initiated tasks**: The assigned technician may authorize routine IT-initiated tasks — including scheduled maintenance, standard configuration updates, and minor proactive remediations — in accordance with their defined role authority under **Policy 1.08** (Delegation of Authority and Decision Rights). The assigned technician shall document the basis for authorization in the work order at the time of creation.
- **Non-routine or significant IT-initiated tasks**: The Assistant IT Director or IT Director shall authorize non-routine or significant IT-initiated tasks — including infrastructure changes, new deployments, system decommissions, or any task that materially alters the County's operational technology environment — prior to work commencement. The authorizing official's name and the basis for authorization shall be documented in the work order before work begins.

- **Project-level IT-initiated work**: IT-initiated work that meets project-level thresholds — as determined by scope, resource requirements, or duration — shall additionally be subject to the project management requirements of **Policy 3.14** (IT Project Management Policy).

6.4 Triage and Authorization

The assigned technician or queue reviewer shall triage all work orders prior to the commencement of active work, in accordance with **Policy 3.01**. Triage confirms or reclassifies the severity level, validates scope, identifies the applicable asset support classification, and initiates or queues the appropriate response. Information Operations Personnel shall not begin work on a work order until triage is complete.

Where a submitted work order lacks sufficient information to complete triage, the assigned technician or queue reviewer shall document the triage attempt, specify the information required, and notify the requester that more information is needed. The work order shall remain in Queued status for the duration of this pending information period. The assigned technician or queue reviewer shall pause service level clocks for the duration of the pending information period and shall resume them upon receipt of the required information from the requester. The assigned technician or queue reviewer shall close work orders that remain without requester response for five (5) consecutive business days, with closure rationale documented in the work order.

The Waiting for User status, as defined in the System of Engagement, applies during the active execution phase of a work order when an IT-side action cannot proceed due to a user-side dependency — not during triage. The assigned technician shall apply Waiting for User status in accordance with work order operational standards maintained in the System of Engagement when that condition is encountered after triage and work commencement.

The assigned technician or queue reviewer shall close work orders triaged for Unsupported assets immediately with a documented replacement referral, in accordance with **Policy 3.01**. No remediation shall be performed on Unsupported assets. The assigned technician or queue reviewer shall confirm the lifecycle status of Deprecated assets during triage and shall initiate the labor ceiling monitoring obligations defined in Section 6.5.

6.5 Deprecated Asset Labor Ceiling

The Information Operations Department operates on the principle that unreliable tools are replaced rather than indefinitely maintained. For Deprecated assets — those already formally identified for replacement — this principle governs remediation decisions. The Department's obligation is to keep the user functional for the duration of the replacement window, not to restore a failing asset to full health. Where an asset demonstrates a pattern of failure that undermines that reliability, the appropriate response is to accelerate replacement, not to continue investing remediation labor.

This framework operates through one (1) objective trigger and a Technician Judgment Pathway. Either activates the disposition review process.

- **Objective Trigger — Incident Frequency**: A Deprecated asset shall be flagged for disposition review when it generates five (5) or more reactive work orders within the same category within any rolling ninety (90) calendar day window.
  - The same-category requirement is essential. Five or more reactive tickets across different categories may indicate a heavily utilized asset. Five or more within the same category indicates a specific, repeating failure pattern in that functional dimension.
  - Tickets in different categories do not aggregate toward this trigger, even if the total exceeds five (5).
  - For purposes of this trigger, reactive work orders are those submitted in response to asset failures or degradation, as distinct from IT-initiated maintenance or proactive work orders.

  - **Monitoring Accountability**: The Assistant IT Director shall maintain a monitoring mechanism — whether automated reporting, periodic query, or scheduled review — sufficient to identify Deprecated assets approaching or crossing the objective trigger threshold. The monitoring method shall be documented in work order operational standards maintained in the System of Engagement.

- **Technician Judgment Pathway**: The assigned technician may initiate a disposition review for any Deprecated asset at any time, independent of whether the objective trigger has been crossed.
  - The assigned technician shall enter a written technical assessment in the work order record identifying the specific observations, failure patterns, or reliability concerns supporting the recommendation. Qualitative characterizations without supporting observations do not satisfy this requirement.
  - **Rationale**: This pathway is the primary mechanism of this framework. Reliability failure does not always express itself in countable tickets — it expresses itself in whether the asset can be depended upon. That judgment, when documented, is sufficient basis for a disposition review.
- **Disposition Review Process**: When a Deprecated asset is flagged under either mechanism, the following review process shall apply.
  - **Notification**: The technician or queue reviewer who identifies the trigger condition shall notify the Assistant IT Director within one (1) business day, with a summary of the trigger conditions or technician assessment and the relevant work order history.
  - **Assistant IT Director Review**: The Assistant IT Director shall review the flagged asset within three (3) business days of notification and shall determine whether the existing replacement timeline remains appropriate or whether escalation to the IT Director is warranted.
  - **Disposition Authority**: The Assistant IT Director may authorize the following disposition without IT Director escalation: confirm that the existing replacement timeline remains appropriate and direct that remediation continue within existing parameters. The following dispositions require IT Director approval: (a) authorize replacement acceleration; or (b) authorize continued remediation beyond the standard labor ceiling in accordance with **Policy 3.01**.
  - **IT Director Escalation**: Where the Assistant IT Director determines that replacement acceleration or continued remediation beyond the standard labor ceiling is warranted, the Assistant IT Director shall escalate to the IT Director with a written recommendation within one (1) business day of completing the review. The IT Director shall issue a written disposition decision within five (5) business days of escalation.
  - **Documentation**: The official who renders the disposition decision shall document the decision in the relevant work order and in the IT Asset Catalog entry for the asset.
- **Proximity-to-Deadline Standard**: The assigned technician shall apply a restricted remediation standard to Deprecated assets with an established replacement deadline within thirty (30) calendar days of the date of triage.
  - The assigned technician shall limit remediation to maintaining basic operational capability sufficient for the user to perform their assigned job function.
  - Full objective trigger framework analysis is not required for assets already imminently scheduled for replacement.
  - **Clarification**: This exemption applies to the objective trigger analysis only. The Technician Judgment Pathway remains available at all times regardless of replacement timeline proximity.
  - The assigned technician shall inform the user of the replacement timeline and advise of any available interim workarounds.

- **Exclusions from Disposition Decisions**: The following factors are explicitly excluded from consideration in any disposition decision made under this framework.
  - **Sunk cost**: Prior investment in consumables, supplies, parts, or remediation labor is not a factor. The IT Director or Assistant IT Director shall evaluate disposition on the basis of forward-looking operational analysis only.
  - **End-user workflow disruption and preference**: If the user can perform their assigned job function, the operational standard is met. User preferences regarding specific equipment shall not influence disposition decisions.

6.6 Execution and Documentation

Once a work order has been triaged, authorized, and assigned, the assigned technician shall execute the work in accordance with the scope defined in the work order and the service level commitments defined in **Policy 3.01**. The assigned technician shall document all actions taken during the lifecycle of a work order in the Notes section in accordance with work order operational standards maintained in the System of Engagement, and shall enter documentation within the timeframe established in **Policy 5.01**.

The assigned technician shall ensure that documentation is specific and sufficient to reconstruct the work performed by a subsequent reviewer who was not present.

Rationale: This standard is the minimum required to support resolution audits, continuity across technicians, SLA adherence measurement under **Policy 3.02** (Service Level Management and Metrics Reporting), and the broader reporting obligations of the Department.

Required documentation elements include, at minimum:

- Troubleshooting steps taken and their outcomes.
- Configuration changes made, with before and after states where applicable.
- User communications summarized in accordance with **Policy 3.03**.
- Any escalations, their rationale, and their outcomes.
- The basis for any reclassification of severity or scope.
- Where a user has transmitted Criminal Justice Information (CJI), Personally Identifiable Information (PII), or credentials into a work order, the assigned technician shall immediately execute the information spillage protocols defined in **Policy 3.03**.

The assigned technician shall comply with the Private Note constraints defined in **Policy 3.03**, and work order operational standards maintained in the System of Engagement. Private Notes are not a substitute for standard documentation and shall not be used to conceal routine work activity from the record. The assigned technician shall maintain subtasks, related issues, asset linkages, and checklist items in accordance with work order operational standards maintained in the System of Engagement throughout the work order lifecycle.

6.7 Closure Standards

The assigned technician shall not close a work order until the work is complete, the resolution is documented, and the appropriate closure status has been applied in accordance with work order operational standards maintained in the System of Engagement. The terminal closure state for confirmed, properly completed work is Resolution Confirmed, as defined in the System of Engagement. Resolution Confirmed seals the work order record. Any future work on the same asset or issue requires a new work order.

Prior to applying any closed status, the assigned technician shall ensure that:

- All actions taken are documented in the Notes section.
- The resolution or disposition is stated clearly and completely.

- Applicable assets are linked via the Related Issues field.
- The user has been notified of the closure or disposition in accordance with **Policy 3.03**.
- Where user confirmation is required, the Reached for Confirmation checkbox has been applied and the user's response documented.

Closure status selection is not discretionary — it is a data element used in performance reporting under **Policy 3.02** and shall accurately characterize the terminal outcome of the work. The available closure statuses and their definitions are established in work order operational standards maintained in the System of Engagement. The assigned technician shall document the five (5) business day notification requirement prior to closing work orders due to requester non-response, consistent with **Policy 3.01**, and Section 6.4 of this policy.

6.8 Emergency Exception

When an operational emergency requires immediate IT action before a work order can be created, the responding Information Operations Personnel may proceed with emergency action prior to work order creation. This exception is narrow. It applies only when the time required to create a work order before acting would materially extend the duration or severity of the impact. It does not represent a general relaxation of the work order requirement.

The emergency exception suspends the sequence; it does not eliminate the requirement. The responding Information Operations Personnel shall create a work order as soon as operationally practicable and in all cases no later than one (1) business hour following the initiation of emergency action or the conclusion of the immediate emergency phase, whichever is earlier.

The responding Information Operations Personnel shall document the following in work orders created under this exception:

- The nature of the emergency and the specific conditions that justified bypassing standard work order creation.
- All actions taken prior to work order creation, with the most precise timestamps recoverable.
- A notation in the work order that the emergency exception was invoked.

The Assistant IT Director shall acknowledge the emergency exception work order within one (1) business day of its creation by entering an acknowledgment notation in the work order.

The assigned technician shall apply the On-Call checkbox defined in the System of Engagement to all work orders created in connection with after-hours emergency response for statistical tracking purposes.

The IT Director shall review emergency exception work orders in aggregate no less than quarterly. The quarterly review shall examine the frequency of emergency exception invocations, the consistency of catch-up work order creation with the one (1) business hour requirement, the adequacy of documented justifications, and whether patterns indicate systemic conditions warranting process improvement rather than continued exception use. The IT Director shall document review findings and any resulting corrective actions in the System of Engagement. Patterns of emergency exception usage inconsistent with the narrow criteria defined above shall be addressed as a compliance matter under **Policy 5.01**.

3.06 Operational Incident Management Policy

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy governs the detection, intake, triage, resolution, and closure of operational incidents within the Elko County Information Operations Department (ECIO), and establishes the mandatory jurisdictional transfer procedure when an Indicator of Compromise (IoC) is discovered during an operational response.

2. Scope

This policy applies to all Information Operations Department personnel and governs all operational incidents involving County IT assets and services, regardless of the channel through which the incident was identified or reported.

- **In Scope**:
  - Operational incident detection, intake, triage, resolution, and closure.
  - Incident Commander authority and designation for operational incidents.
  - Hard Fork jurisdictional transfer to Chapter 4 upon IoC discovery.
  - SLA obligations during operational incidents, including Hard Fork suspension.
  - Parent-Child linkage and incident suppression during active Problem investigations.
  - Problem Record spawn triggers at incident closure.
  - Critical Incident Stakeholder Report deliverables for Critical severity operational incidents.
- **Out of Scope**:
  - Cybersecurity incidents and Indicator of Compromise definitions: **Policy 4.02**.
  - Cybersecurity incident postmortem review: **Policy 4.07**.
  - Service level commitments and severity classification framework: **Policy 3.01**.
  - Performance monitoring and metrics reporting: **Policy 3.02**.
  - Work order lifecycle and documentation standards: **Policy 3.05**.
  - Root cause investigation and Problem Management: **Policy 3.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the Incident Commander by default for all operational incidents governed by this policy.
  - May designate any Information Operations staff member as Incident Commander for a specific incident, in accordance with the delegation authority established in **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall exercise final decision authority on incident prioritization, escalation, and resource allocation for any incident under active management.

  - Shall review Problem records spawned under the triggers defined in Section 6.6 and shall fulfill the authorization obligations defined in **Policy 3.07** (Problem Management Policy).
  - Shall fulfill stakeholder report review, authorship, and distribution obligations for Critical severity incidents as defined in Section 6.8.
- **Assistant IT Director:**
  - Shall ensure that work order intake, triage, documentation, and closure standards are consistently applied by all Information Operations personnel in accordance with this policy, **Policy 3.05** (Service Request Fulfillment Policy), and work order operational standards maintained in the System of Engagement.
  - Shall monitor the work order queue for compliance with SLA obligations defined in **Policy 3.01** (Service Catalog and SLA Policy) and for recurring incident patterns that trigger Problem record requirements under Section 6.6.
  - Shall notify the IT Director when an incident is classified as Critical severity and shall support Incident Commander functions as directed.
  - Shall notify the relevant technician when a recurring incident threshold under Section 6.6 has been crossed without a corresponding Problem record having been opened.
  - Shall author stakeholder reports for Critical severity incidents when the IT Director served as Incident Commander, in accordance with Section 6.8.
- **All Information Operations Personnel:**
  - Shall create a work order for every operational incident, without exception, in accordance with **Policy 3.05**.
  - Shall search the Knowledge Base maintained under **Policy 3.13** (Knowledge Management Policy) for documented workarounds before escalating any incident, as required by Section 6.3 of this policy.
  - Shall document all troubleshooting steps, configuration changes, communications, and outcomes in the work order notes in accordance with **Policy 1.03** (Standard Operating Ethos).
  - Shall recognize and respond to Indicators of Compromise in accordance with the Hard Fork procedure defined in Section 6.2.
  - Shall apply the Parent-Child linkage mechanic defined in Section 6.5 when receiving incidents that match an active Parent Problem investigation.
  - Shall evaluate and act upon Problem record spawn triggers at incident closure, as defined in Section 6.6.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with incident intake, triage, workaround search, documentation, Hard Fork recognition, Parent-Child linkage, Problem spawn trigger, stakeholder reporting, and closure obligations shall be assessed through the service level reporting process defined in **Policy 3.02** (Service Level Management and Metrics Reporting) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to create required work orders, failure to initiate the Hard Fork procedure upon IoC discovery, failure to document actions within required timeframes, failure to open mandated Problem records at incident closure, or failure to complete stakeholder reporting obligations for Critical severity incidents, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- NIST CSF 2.0: RS.MA-01 (Incident Triage)
- NIST CSF 2.0: RS.MA-02 (Incident Escalation)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Incident Management Practice
- ITIL v4: Monitoring and Event Management Practice
- ITIL v4: Service Desk Practice

6. Policy Statement

The Information Operations Department responds to two fundamentally different categories of adverse IT events, governed by two different policy regimes with two different objectives. **Policy 3.06** governs operational incidents — unplanned technical failures whose cause is non-malicious and whose resolution requires restoring service. The governing objective is speed: identify the failure, locate a workaround or fix, and return County operations to normal. **Policy 3.06** does not care why something broke. Its job is to restore service as quickly as possible. Root cause analysis is the exclusive domain of **Policy 3.07** and does not begin until the **Policy 3.06** incident is closed.

Chapter 4 governs cybersecurity incidents — events involving malicious activity, unauthorized access, data compromise, or any Indicator of Compromise as defined in **Policy 4.02** (Identification and Reporting Procedures). The governing objective for Chapter 4 is containment and forensic integrity. A Chapter 4 response

may deliberately extend an outage in order to stop the bleed, preserve evidence, or prevent further compromise. Speed of restoration is subordinate to that objective.

These two regimes are not interchangeable, and a technician shall not substitute one for the other. If an event involves or is suspected to involve an Indicator of Compromise, Chapter 4 shall control, and **Policy 3.06** shall automatically subordinate. The procedure for that transfer is defined in Section 6.2.

6.1 Incident Commander

The IT Director shall serve as the Incident Commander for all operational incidents governed by this policy by default. The IT Director may designate any Information Operations staff member as Incident Commander for a specific incident. The IT Director shall document designations in the relevant work order at the time they are made, specifying the scope and duration of the designation. Designation authority and decision rights for this role align with **Policy 1.08**.

The title Incident Commander is singular. No parallel title — Major Incident Manager or equivalent — exists within the ECIO framework. This role applies uniformly to both **Policy 3.06** operational incidents and Chapter 4 cybersecurity incidents. There is no disambiguation of title between the two contexts.

The Incident Commander shall:

- Exercise full command authority over the operational response for the duration of the designated incident, including technician assignments, escalation decisions, and communication with external vendors.
- Direct the Hard Fork transfer to Chapter 4 jurisdiction upon confirmation of an IoC under Section 6.2, and coordinate with Chapter 4 protocols as the incident record transitions.
- Determine when to return jurisdiction from Chapter 4 to **Policy 3.06** operational recovery where applicable.
- Document all command-level decisions in the incident work order.

6.2 Hard Fork — Indicator of Compromise Discovery and Jurisdictional Transfer

If a technician working a **Policy 3.06** operational incident discovers, at any point during the response, any event or condition that constitutes an Indicator of Compromise (IoC) as defined in **Policy 4.02**, **Policy 3.06** immediately and automatically subordinates to Chapter 4. This transition is not discretionary. It shall not require supervisor approval. The technician's obligation upon IoC discovery is to act immediately.

Upon discovering an IoC, the technician shall:

1. Cease all troubleshooting immediately. No further diagnostic, remediation, or configuration activity shall be performed on the affected system or systems without express direction from the Incident Commander.
2. Preserve the system's current state. The technician shall not power off, reboot, disconnect, or otherwise alter the affected system's physical or logical state, except to prevent immediate harm to persons or to prevent active data loss that cannot be addressed by other means — and only then with immediate notification to the Incident Commander of the action taken.
3. Document the IoC observation in the work order notes immediately. The notation shall describe specifically what was observed, when, and on which system. This entry constitutes the initial forensic record.
4. Notify the Incident Commander immediately via the most direct communication channel available.
5. Await direction from the Incident Commander before taking any further action on the affected system or the incident work order.

The work order shall not be abandoned upon Hard Fork. It shall transfer jurisdiction. The **Policy 3.01** SLA obligations associated with the work order are formally suspended as of the date and time the IoC observation is documented in the work order notes, pending Chapter 4 disposition. The suspension and its effective date shall be noted in the work order. When Chapter 4 activity concludes and the operational recovery phase begins, **Policy 3.06** obligations shall resume if applicable, as directed by the Incident Commander.

The canonical list of Indicators of Compromise that trigger the Hard Fork is maintained in **Policy 4.02** and is incorporated into this policy by reference. Technicians shall be familiar with that list. Where a technician is uncertain whether an observed condition constitutes an IoC, the technician shall treat it as one and initiate the Hard Fork procedure. A false positive that triggers an unnecessary Chapter 4 review is a recoverable error. A missed IoC that allows a malicious event to proceed unchecked is not.

6.3 Incident Lifecycle

1. **Detection and Intake:**
   - Every operational incident shall be documented in a work order in the System of Engagement.
   - All channel routing requirements of **Policy 3.05,** apply: incidents identified through any channel — user report, helpdesk contact, direct technician observation, or automated monitoring alert from **Policy 3.12** (Monitoring and Event Management Policy) — shall be recorded in a work order no later than one (1) business hour following detection or the initiation of any response activity, whichever occurs first.
   - No response activity shall proceed without an associated work order.
2. **Triage:**
   - All incident work orders shall undergo IT-side triage prior to the commencement of active response work, in accordance with **Policy 3.01**.
   - The assigned technician or queue reviewer shall confirm or reclassify the severity level, validate the asset support classification, and assign the incident to the appropriate technician or escalation path.
   - The assigned technician or queue reviewer shall complete triage within the timeliness obligations defined in **Policy 3.01** for the assigned severity level.
3. **Workaround Search (Mandatory Before Escalation):**
   - Before escalating any incident to a higher support tier or requesting external vendor support, the assigned technician shall search the Knowledge Base maintained under **Policy 3.13** for documented workarounds applicable to the reported condition.
   - This obligation applies regardless of the technician's familiarity with the system.
   - The Knowledge Base represents the Department's accumulated resolution intelligence and shall be the first resource consulted, not a fallback after independent troubleshooting has been exhausted.
   - If an applicable documented workaround exists, the assigned technician shall attempt it and document the attempt and outcome in the work order notes.
   - The assigned technician may proceed to escalation when: (a) no applicable workaround exists in the Knowledge Base; (b) an applicable workaround was attempted and did not resolve the condition; or (c) an applicable workaround partially restored service but did not meet the required service level.
   - In all cases, the assigned technician shall document the reason for escalation in the work order before escalation occurs.
4. **Active Resolution:**

- The assigned technician or Incident Commander shall pursue the fastest path to service restoration.
- The assigned technician shall document all troubleshooting steps, configuration changes, and outcomes in the work order notes in accordance with **Policy 1.03**.
- The assigned technician shall enter all actions into the work order system within twenty-four (24) hours of each action taken.
- The assigned technician shall remain alert throughout the resolution process for any condition that may constitute an Indicator of Compromise.
- If any such condition is discovered, the assigned technician shall immediately invoke the Hard Fork procedure defined in Section 6.2.

5. **Closure:**
   - Upon service restoration, the assigned technician shall confirm resolution with the affected user or users.
   - If the user is unavailable to confirm resolution, the assigned technician shall document the unresponsiveness in the work order notes before proceeding to closure.
   - The assigned technician shall update the work order status to the appropriate terminal status in accordance with work order operational standards maintained in the System of Engagement and shall document the resolution state in the work order notes.
   - The assigned technician shall then evaluate whether the incident meets either Problem record spawn trigger defined in Section 6.6 and shall act accordingly before the work order is sealed.

6.4 SLA Obligations During Incidents

Full **Policy 3.01** service level commitments shall remain in effect during operational incidents. No special SLA suspension mechanism exists within this policy for routine operational incidents.

Incidents classified as Critical severity under **Policy 3.01** shall be subject to the response and resolution timeframes defined in **Policy 3.01** for Critical severity work orders. For extended outages that cannot be resolved within the Critical resolution window, the formal escalation pathway within the Critical SLA is the appropriate mechanism. The SLA clock shall be satisfied when formal escalation is documented in the work order — not when service is restored. No additional carve-out or SLA pause is required for extended outages that are actively managed and escalated.

The only condition under which **Policy 3.01** SLA obligations are suspended for a work order originated under this policy is when the Hard Fork fires under Section 6.2, transferring jurisdiction to Chapter 4. In that event, the SLA suspension and its effective date shall be documented in the work order at the time the suspension takes effect.

6.5 Parent-Child Linkage and Incident Suppression During Active Problem Investigations

When a formal Problem record has been opened under **Policy 3.07** for an active failure condition, that Problem record becomes the Parent record for that condition. Duplicate troubleshooting of the same underlying failure by independent technicians wastes remediation resources and risks contaminating the Problem investigation. The following mechanic governs incidents received while a relevant Parent Problem investigation is active.

If a technician receives a new incident work order whose symptoms match those of an active Parent Problem record, the technician shall:

1. Set the work order status to In Progress in accordance with work order operational standards maintained in the System of Engagement.

2. Link the work order to the Parent Problem record via the Related Issues field in the System of Engagement.
3. Document in the work order notes that the incident has been identified as related to an active Problem investigation, identifying the Parent record by its work order number in the System of Engagement and providing a brief notation of the matching symptoms.
4. Not attempt independent troubleshooting on the underlying failure condition while the Parent Problem investigation is active.

The Related Issues link to the Parent Problem record is the required audit trail for why the child work order remains In Progress without independent resolution activity. This link shall be established before or concurrent with the In Progress status assignment. An In Progress work order with no Related Issues link to a Parent Problem record is not compliant with this section.

At the time the Parent Problem record is resolved, the assigned technician shall revisit each linked child work order and close it with the appropriate terminal status in accordance with work order operational standards maintained in the System of Engagement:

- **Duplicate:** If the Parent Problem resolution fully addressed the child work order's reported condition and no additional end-system work was required on the child work order's asset or user environment.
- **Resolved:** If end-system work was required on the child work order's asset or user environment following or concurrent with the Problem resolution — for example, reinstalling software, restoring a user configuration, re-imaging a device, or performing any other technician action specific to the child work order's asset or user.

The assigned technician shall document the closure rationale in each child work order's notes at the time of closure.

6.6 Problem Record Spawn Triggers

Two objective conditions automatically mandate that a formal Problem record be opened under **Policy 3.07**. The technician closing the qualifying incident work order shall evaluate whether either trigger has been met and shall open the Problem record if so. This obligation is not discretionary and is not satisfied by referencing the trigger threshold in the work order notes without opening the record.

- **Major Incident Trigger:**

  Every incident classified as Critical severity under **Policy 3.01**, without exception, shall generate a formal Problem record upon closure. The Problem record shall be opened no later than end of business (EOB) on the calendar day the incident work order is resolved. If the incident is resolved on a non-business day, or within two (2) hours of EOB on a business day, the deadline extends to 10:00 AM on the next consecutive business day. This requirement is non-negotiable. Critical severity incidents represent the most significant service failures within the Department's operational environment. The causes of those failures shall be formally investigated regardless of whether a technician believes the cause to be self-evident.

- **Recurring Incident Trigger:**

  Five (5) or more incidents against the same asset or service, within the same work order category, within any rolling thirty (30) calendar day window, shall automatically generate a formal Problem record. The technician closing the fifth qualifying incident shall open the Problem record at the time of that closure.

  For purposes of this trigger:

  - The same-category requirement is essential. Five or more incidents across different categories on the same asset may indicate a heavily utilized or aging asset; five or more within the same category indicates a specific, repeating failure pattern in that functional dimension. Tickets in different categories do not aggregate toward this trigger, even if the total exceeds five (5).

  - The thirty (30) calendar day window is a rolling calculation, not a fixed calendar period. Any thirty-day span ending on the date of the most recent incident is the applicable window.
  - The Assistant IT Director shall monitor queue data to identify recurring incident patterns and shall notify the relevant technician if the threshold has been crossed without a corresponding Problem record.

- **Relationship to** Policy 3.05 **Deprecated Asset Trigger:**

  The Recurring Incident Trigger above shall not be conflated with the Deprecated Asset labor ceiling trigger defined in **Policy 3.05**. These are related but distinct mechanisms. The **Policy 3.05** trigger uses a ninety (90) calendar day window to ask whether a Deprecated asset is failing with sufficient frequency to warrant accelerated replacement. The **Policy 3.07** trigger uses a thirty (30) calendar day window to ask whether something is actively wrong with an asset or service right now — a tighter window that reflects the need to investigate while evidence is fresh.

  Both triggers may fire simultaneously on the same asset. When they do, the Problem investigation asks why the asset is failing while the disposition review asks whether it is worth fixing. These are complementary obligations, not conflicting ones, and both shall be executed.

6.7 Handoff to Policy 3.07 at Closure

Policy 3.06 jurisdiction ends at service restoration. A **Policy 3.06** technician's job is complete when the County is back to work. This policy does not perform root cause analysis, and technicians shall not delay incident closure pending root cause identification. Holding an incident work order open to investigate the cause is the wrong tool — that work belongs to **Policy 3.07**.

For Critical severity incidents, the IT Director shall additionally ensure that the stakeholder reporting obligation defined in Section 6.8 is fulfilled. The stakeholder report is an accountability deliverable for affected Department leadership; it does not constitute root cause analysis and does not alter the **Policy 3.07** Problem investigation obligation.

Where a Problem record spawn trigger has been met under Section 6.6, the responsible technician shall open the Problem record under **Policy 3.07** before or concurrently with closing the incident work order. The Problem record shall reference the originating incident work order via the Related Issues field in the System of Engagement. From that point forward, root cause analysis, permanent remediation authorization, and Known Error management are the exclusive domain of **Policy 3.07**. The closed **Policy 3.06** work order is the evidentiary foundation for the investigation — it shall not be modified or extended once sealed.

6.8 Critical Incident Stakeholder Report

This section establishes the formal stakeholder reporting obligation for operational incidents classified as Critical severity under **Policy 3.01**. This obligation is distinct from the routine work order documentation required for all incidents under Section 6.3, from the Problem investigation governed by **Policy 3.07**, and from the cybersecurity incident postmortem process governed exclusively by **Policy 4.07** (Postmortem Review and Lessons Learned). The stakeholder report is an accountability deliverable summarizing what happened and how it was resolved. It does not replace or subsume the **Policy 3.07** Problem investigation, which remains the authoritative root cause analysis instrument for operational incidents.

- **Trigger:** Every operational incident classified as Critical severity under **Policy 3.01** shall receive a formal written stakeholder report upon closure. There are no deferral provisions.
- **Separation of Duties:** The person who commanded the incident response shall not author the stakeholder report for that incident. This separation ensures that the report is prepared with independence from the operational decisions under examination.
  - **When the IT Director served as Incident Commander:** The Assistant IT Director shall author the report. The IT Director shall review and approve the completed report prior to distribution. The IT Director retains final approval authority but shall not suppress factual findings.

  - **When a designated Incident Commander other than the IT Director served:** The IT Director shall author the report.
- **Timeline:** The report author shall complete the written stakeholder report within five (5) business days of incident closure.
- **Content:** The stakeholder report shall include, at minimum:
  - Incident summary, including severity classification, affected services, duration, and resolution.
  - Chronology of the incident from detection through service restoration.
  - Preliminary cause assessment, if available at the time of report preparation. Where root cause has not yet been determined, the report shall reference the spawned **Policy 3.07** Problem record as the instrument governing formal root cause investigation.
  - Corrective actions taken and any recommendations for preventive measures.
- **Constraint:** The stakeholder report is informational and managerial in purpose. The report shall not declare root cause, authorize permanent remediation, or close corrective actions. Root-cause determination, Known Error declaration, and permanent corrective measures are governed exclusively by **Policy 3.07**, and cybersecurity lessons-learned reviews are governed exclusively by **Policy 4.07**.
- **Distribution:** The IT Director shall distribute the completed stakeholder report to affected Department Heads and the County Manager within two (2) business days of report completion.
- **Documentation:** The completed stakeholder report shall be attached to the originating incident work order in the System of Engagement.
- **Retention:** The stakeholder report shall be retained for the duration of the originating work order's retention period as governed by work order operational standards maintained in the System of Engagement and applicable records retention schedules.

3.07 Problem Management Policy

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy governs the formal investigation of root causes of IT service failures and the authorization of permanent remediations within the Elko County Information Operations Department.

2. Scope

This policy applies to all Information Operations Department personnel and governs all formal Problem investigations involving County IT assets and services.

- **Out of Scope**:
  - Service restoration during active operational incidents: **Policy 3.06** (Operational Incident Management Policy).
  - Cybersecurity incident postmortems: **Policy 4.07** (Postmortem Review and Lessons Learned).

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the final authorizing authority for all permanent remediations proposed through the Problem management process, in accordance with Section 6.4.
  - Shall authorize the opening of discretionary Problem records outside the objective spawn triggers defined in **Policy 3.06**.
  - Shall review and sign off on Problem record closure in accordance with Section 6.6.
  - Shall determine investigation priority when an active Problem investigation conflicts with other operational demands, in accordance with Section 6.3.
  - Shall review Known Error declarations and confirm publication authorization to the Knowledge Base under **Policy 3.13** (Knowledge Management Policy) where required by Section 6.5 of this policy.
- **Assistant IT Director:**
  - Shall ensure that Problem records are opened in accordance with the spawn triggers defined in **Policy 3.06**, and shall notify the IT Director when a Problem record is opened.
  - Shall review proposed remediations prior to IT Director authorization and shall provide a documented recommendation to the IT Director as part of the authorization workflow defined in Section 6.4.
  - Shall ensure that Known Error workarounds are published to the Knowledge Base under **Policy 3.13** within the timeframes defined in Section 6.5.
  - Shall verify Problem record closure quality and confirm that all required documentation elements are present before the IT Director's closure sign-off is sought.
  - Shall monitor open Problem records for compliance with the investigation activity obligations defined in Section 6.3 and shall escalate stalled investigations to the IT Director in accordance with Section 6.3.

- **All Information Operations Personnel:**
  - Shall conduct all analysis activities defined in Section 6.3 when assigned as Investigator on a Problem record.
  - Shall document all investigative steps, findings, and intermediate conclusions in the Problem record in accordance with **Policy 1.03** (Standard Operating Ethos), within twenty-four (24) hours of each investigative action taken.
  - Shall not implement any permanent system change or deploy any Known Error workaround independently when serving as Investigator.
  - Shall submit all proposed remediations for authorization in accordance with Section 6.4 before implementation.
  - Shall notify the Assistant IT Director when root cause has been identified and a remediation proposal is ready for authorization review.
  - Shall notify the Assistant IT Director when a Known Error condition exists and a workaround is available for publication, in accordance with Section 6.5.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with Problem record opening obligations, investigation documentation standards, Known Error publication timelines, remediation authorization requirements, and closure sign-off obligations shall be assessed through the service level reporting process defined in **Policy 3.02** (Service Level Management and Metrics Reporting) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to open a required Problem record following a spawn trigger, failure to document investigation activity within required timeframes, implementation of a permanent remediation without required authorization, or closure of a Problem record without required sign-off shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented and approved in accordance with **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.03: Standard Operating Ethos
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NIST CSF 2.0: ID.IM-03 (Improvements are identified from the execution of operational processes, procedures, and activities)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: DSS03 (Manage Problems)
- ITIL v4: Knowledge Management Practice
- ITIL v4: Problem Management Practice

6. Policy Statement

Problem management is the Department's structured response to evidence that a failure condition is systemic or significant. Where **Policy 3.06** governs the restoration of service, this policy governs the identification and permanent elimination of the conditions that caused the service to fail. The objective is durable resolution — finding why something broke and ensuring it does not break the same way again. The Problem record is the continuation of accountability after service has been restored, not a parallel track to restoration. Problem investigation is not a general-purpose research activity; it is the Department's deliberate response to evidence that a failure condition warrants formal root cause analysis.

The Department's operating philosophy on Problem investigation is that investigative capability shall not be gatekept by job title. Any Information Operations staff member at any tier may be assigned as Investigator on a Problem record. The IT Director or Assistant IT Director shall ensure the assigned Investigator receives the system access and data visibility required to perform the investigative activities defined in Section 6.3. The quality of the investigation is measured by the rigor of the documentation and the validity of the findings, not by the seniority of the Investigator.

6.1 Problem Record Intake

A Problem record shall be opened through one of the following three mechanisms. No other mechanism authorizes the creation of a Problem record.

- **Objective Trigger — Major Incident**: Every incident classified as Critical severity under **Policy 3.01** (Service Catalog and SLA Policy) shall generate a formal Problem record upon closure of the originating incident work order, in accordance with the spawn trigger requirements defined in **Policy 3.06**. The spawn trigger criteria and deadline are defined in **Policy 3.06**, and shall not be restated here.
- **Objective Trigger — Recurring Incident**: A qualifying recurring incident pattern against the same asset or service shall generate a formal Problem record in accordance with the spawn trigger requirements defined in **Policy 3.06**. The pattern threshold, category matching rules, and rolling window are defined in **Policy 3.06**, and shall not be restated here.
- **IT Director Discretion**: The IT Director may authorize the opening of a Problem record for any failure condition that, in the IT Director's judgment, warrants formal root cause investigation outside the objective triggers above. The IT Director's authorization shall be documented in the Problem record at the time of creation. Upon IT Director authorization, the Assistant IT Director (or a staff member explicitly designated by the IT Director in the authorization) shall open the Problem record within one (1) business day.

Upon opening, all Problem records shall include, at minimum: the originating trigger or authorization, a description of the symptoms and affected asset or service, links to all associated incident work orders via the Related Issues field in the System of Engagement, and the name of the assigned Investigator.

- **Investigator Assignment**: The IT Director or Assistant IT Director shall assign the Investigator at the time the Problem record is created, or no later than one (1) business day after creation. Assignment as Investigator shall not require a specific seniority level.
- **Notification**: The Assistant IT Director shall be notified of all Problem record openings no later than end of business on the day the record is created.

6.2 Relationship to Policy 3.05 Deprecated Asset Trigger

The Recurring Incident spawn trigger defined in **Policy 3.06**, and the Deprecated Asset labor ceiling trigger defined in **Policy 3.05** (Service Request Fulfillment Policy), are related but distinct mechanisms. The spawn trigger asks whether something is actively wrong with an asset or service. The Deprecated Asset trigger asks whether a Deprecated asset is failing with sufficient frequency to warrant accelerated replacement.

Both triggers may fire simultaneously on the same asset. When they do, the Problem investigation and the disposition review shall proceed in parallel. The Investigator shall ask why the asset is failing. The IT Director disposition review shall ask whether the asset is worth fixing. The findings of the Problem investigation shall be made available to the IT Director as an input to the disposition decision, but the two processes shall not be merged or held pending the other's conclusion.

6.3 Investigation Conduct and Priority

- **Investigator Authority**: The assigned Investigator shall be authorized to pursue root cause through any analytical method relevant to the failure condition. This includes, without limitation: log analysis, network trace and routing review, configuration comparison, vendor documentation review, testing in non-production environments, and consultation with subject matter experts within or outside the Department. The Investigator's analytical authority shall be unrestricted. The Investigator's remediation authority shall be strictly limited in accordance with Section 6.4.
- **Investigation Documentation**: The Investigator shall document all investigative steps, analytical findings, and intermediate conclusions in the Problem record within twenty-four (24) hours of each action taken, in accordance with **Policy 1.03**. Documentation shall be specific and sufficient to reconstruct the investigation by a subsequent reviewer who was not present. At minimum, the Problem record shall contain:
  - A description of each investigative action taken and the system or data source examined.
  - The findings or output of each investigative action.
  - Any hypotheses considered and the basis on which they were confirmed or eliminated.
  - The identified root cause, stated with sufficient specificity to inform a permanent remediation proposal.
  - The proposed remediation, including scope, affected systems, and estimated implementation effort.
- **Investigation Priority**: Active **Policy 3.06** incidents classified as Critical or Urgent severity against the same asset or service as an open Problem investigation shall automatically take priority over the Problem investigation for the duration of the active incident. The Investigator shall pause investigation activity on the affected asset and shall support incident resolution under **Policy 3.06** as directed by the Incident Commander. Investigation activity shall resume upon closure of the preempting incident.

Below the Critical and Urgent threshold, the IT Director shall determine priority between active Problem investigations and other operational demands on a case-by-case basis. The IT Director's priority determination shall be documented in the Problem record.

- **RCA Methodology**: This policy shall not prescribe a specific root cause analysis methodology. The Investigator shall select and apply the analytical approach best suited to the failure condition under

investigation. The obligation is that root cause analysis is conducted rigorously, documented completely, and produces a finding that is specific enough to support a permanent remediation proposal. The methodology used shall be noted in the Problem record.

- **Stalled Investigation Threshold**: A Problem record with no documented investigative activity within ten (10) business days shall be considered stalled. The Assistant IT Director shall escalate stalled Problem records to the IT Director within one (1) business day of identifying the stalled condition. The IT Director shall determine whether to reassign the investigation, reprioritize it, or close the Problem record as a Known Error in accordance with Section 6.5.

6.4 Separation of Investigative and Remediation Authority

The Problem management process is divided into two distinct phases with different authority structures: Execution and Authorization. This separation ensures that investigative capability is distributed across all staff tiers while permanent system changes remain subject to appropriate oversight.

- **Execution — The Investigation**: The assigned Investigator, at any staff tier, shall be fully authorized to conduct all investigative activities described in Section 6.3 without restriction or additional approval. The Investigator shall not require supervisory sign-off to analyze logs, review configurations, trace network paths, or pursue any other analytical activity in furtherance of root cause identification.
- **Authorization — The Fix**: The Investigator shall not implement any permanent system change, configuration modification, patch deployment, architectural adjustment, or other remediation action independently. Once the Investigator has identified root cause and developed a remediation proposal, the following authorization process applies before any remediation action is taken:
  1. The Investigator shall document the proposed remediation in full in the Problem record, including: the root cause finding, the proposed corrective action, the systems affected, the implementation plan, and any risks or dependencies associated with the remediation.
  2. The Investigator shall notify the Assistant IT Director that a remediation proposal is ready for review.
  3. The Assistant IT Director shall review the proposal and shall provide a documented recommendation to the IT Director within three (3) business days of notification.
  4. The IT Director shall review the proposal and the Assistant IT Director's recommendation and shall issue a written authorization or denial within five (5) business days of the Assistant IT Director's recommendation.
  5. Remediation shall not commence until the IT Director's written authorization is documented in the Problem record.
  6. Upon IT Director authorization, the Investigator (or an implementer assigned by the Assistant IT Director) shall initiate the remediation through the change management process defined in **Policy 3.09** (Change Management Policy). The Problem management authorization under this section confirms that the remediation addresses the identified root cause. The change management authorization under **Policy 3.09** confirms that the change can be safely implemented in the production environment. Both authorizations are required before implementation.

The total authorization cycle from Investigator notification to IT Director decision shall not exceed eight (8) business days. Delays beyond eight (8) business days shall require a documented IT Director extension in the Problem record, including the reason for the delay and the revised target date.

If the IT Director denies the proposed remediation, the denial shall be documented with rationale in the Problem record. The Investigator may develop an alternative remediation proposal, which shall follow the same authorization process.

The Problem record shall not be closed without IT Director sign-off, regardless of whether a remediation has been implemented. A Problem record that reaches closure without a viable permanent remediation

shall be closed as a Known Error in accordance with Section 6.5.

6.5 Known Error Management and Knowledge Base Publication

A Known Error is a Problem for which root cause has been identified but for which a permanent remediation has not yet been implemented, whether because the remediation is pending authorization, pending resources, pending a vendor fix, or has been determined not to be cost-effective relative to an available workaround.

- **Known Error Declaration**: When the Investigator identifies root cause and determines that a permanent remediation will not be immediately implemented — for any reason — the Investigator shall notify the Assistant IT Director and shall declare a Known Error condition in the Problem record. The Known Error declaration shall include:
  - The identified root cause.
  - The reason a permanent remediation is not immediately forthcoming.
  - A documented workaround sufficient to restore or maintain service for affected users in the interim.
- **Knowledge Base Publication**: Upon Known Error declaration, the Assistant IT Director shall ensure that the documented workaround is published to the Knowledge Base maintained under **Policy 3.13** within two (2) business days of the declaration. The published entry shall include the symptoms that identify the Known Error condition, the workaround procedure, and the Problem record number for traceability. Publication to the Knowledge Base shall not be deferred pending Problem closure.
  - **Rationale**: This publication feeds the mandatory workaround search under **Policy 3.06**. Unpublished workarounds are inaccessible to technicians during incident response.
- **Known Error Lifecycle**: A Known Error entry in the Knowledge Base shall remain active until the underlying Problem record is formally closed with a permanent remediation implemented and verified. Upon permanent remediation, the Assistant IT Director shall ensure that the corresponding Knowledge Base entry is updated to reflect the resolution and marked inactive within two (2) business days of Problem closure.

6.6 Problem Closure and the Formal Closure Declaration

- **Problem Record Resolution Conditions**: A Problem record shall not be considered resolved by informal agreement or by the cessation of investigation activity. Closure requires a formal declaration that satisfies all of the following conditions:
  1. **Root cause has been identified** and is documented in the Problem record with sufficient specificity to distinguish the underlying cause from its symptoms.
  2. **A permanent remediation has been implemented and verified**, or the Problem has been formally reclassified as a Known Error in accordance with Section 6.5 with a workaround published to the Knowledge Base.
  3. **All required authorization documentation** under Section 6.4 is present in the Problem record, including the IT Director's written authorization for any remediation implemented.
  4. **The Assistant IT Director has reviewed the record** and confirmed that all required documentation elements are complete.
  5. **The IT Director has reviewed and signed off** on the closure.
- **Formal Closure Declaration**: Upon satisfaction of all conditions above, the IT Director shall issue the Formal Closure Declaration by updating the Problem record status to the appropriate closed status in work order operational standards maintained in the System of Engagement and documenting the closure rationale. The IT Director's status update constitutes the authoritative declaration that the

Problem is resolved. The IT Director shall issue the Formal Closure Declaration within five (5) business days of the Assistant IT Director's confirmation that all resolution conditions are satisfied.

- **Trigger for** Policy 3.06 **Child Work Order Mass-Closure**: The Formal Closure Declaration is the event that triggers the mass-closure of child work orders linked to the Problem record under **Policy 3.06**. Upon the IT Director's closure of the Problem record, the Assistant IT Director shall notify all technicians with linked child work orders that the Parent Problem record has been closed and that child work orders are to be dispositioned in accordance with **Policy 3.06**, — as either Duplicate or Resolved depending on whether end-system work was required. This notification shall occur no later than end of business on the day the Formal Closure Declaration is issued. Child work order dispositions shall be completed within two (2) business days of notification.
- **Trigger for Significant Incident Report Intake**: Where the permanent remediation identifies a systemic improvement opportunity beyond the immediate fix, the Assistant IT Director shall route the matter to **Policy 3.16** (Service Improvement and Continual Improvement Plan) for SIR intake under that policy's Section 6.2.

6.7 Relationship to Policy 3.06 — Jurisdictional Boundary

Policy 3.07 is the downstream continuation of **Policy 3.06**. The jurisdictional boundary between them is the closure of the originating incident work order. The full handoff protocol is defined in **Policy 3.06**.

- A technician shall not hold a **Policy 3.06** incident work order open on the grounds that root cause has not yet been identified. When service is restored, the **Policy 3.06** work order closes and the **Policy 3.07** Problem record begins — not before.
- The Problem record inherits the evidentiary record of the originating incident work order. The closed **Policy 3.06** work order shall not be modified after sealing. All subsequent findings, analysis, and remediation documentation belong to the Problem record.
- **Clarification**: Where a Chapter 4 cybersecurity event also generates operational findings that warrant a Problem investigation under this policy, the IT Director shall determine whether a **Policy 3.07** Problem record is appropriate and shall authorize its opening. This determination is an IT Director governance decision and is not a mechanical output of the **Policy 4.07** postmortem process.

3.08 Service Configuration Management (CMDB) Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy governs the creation, maintenance, verification, and retirement of Configuration Item (CI) records for all deployed IT assets within the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations Department personnel and governs the CI record lifecycle for all assets with Deployed status in the designated system of record.

- **In Scope**:
  - Hardware assets deployed into the operational environment.
  - Software and application instances deployed into the operational environment.
  - Network infrastructure components deployed into the operational environment.
  - Virtual infrastructure components deployed into the operational environment.
- **Out of Scope**:
  - Consumables and passive peripherals excluded from asset tracking: **Policy 1.12**.
  - Assets not yet deployed (asset records awaiting CI creation at deployment): **Policy 1.12**.
  - Active endpoint configuration state, including OS version, patch level, and software inventory: **Endpoint Protection Platform** as defined in Section 6.2.
  - Security baseline definitions and hardening requirements: **Policy 2.10**.
  - Financial controls governing asset acquisition and payment: **Policy 1.10** and **Policy 1.12**.
  - Change authorization: **Policy 3.09**.

Exclusion: This policy enforces the CI record update obligation that is the downstream consequence of every authorized change. It shall not govern change authorization itself.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for any modification to the CI minimum field set defined in Section 6.3.
  - Shall ensure that the annual physical asset audit conducted under **Policy 1.12** (IT Asset Management Policy) incorporates the CI verification obligation defined in Section 6.5 of this policy.
  - Shall review and approve exceptions to CI record requirements in accordance with the exception management framework defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall ensure that CI record creation, maintenance, and verification obligations are consistently applied by all Information Operations personnel in accordance with this policy.

  - Shall conduct a quarterly review of CI record currency, identifying deployed assets whose CI records have not been verified within the preceding twelve (12) months and whose CI records contain unresolved record deficits, and shall document quarterly review findings in the System of Engagement and ensure remediation obligations are tracked to completion.
  - Shall coordinate with the IT Director to ensure that supply chain review status under **Policy 1.13** (Supply Chain Risk Management and Vendor Governance) is confirmed before CI record creation is initiated for any new asset.
- **All Information Operations Personnel:**
  - Shall create a CI record in the System of Engagement for every asset at the time of deployment, following confirmation that supply chain review under **Policy 1.13** is complete.
  - Shall verify that all required CI fields defined in Section 6.3 are populated accurately as a condition of work order closure for any work order in which the asset is the primary subject of active work, in accordance with Section 6.4.
  - Shall remediate any CI record deficit discovered during a work order before closing that work order, in accordance with Section 6.4.
  - Shall update the CI record in the System of Engagement to reflect the post-change configuration state before or concurrent with closing any change record under **Policy 3.09** (Change Management Policy), in accordance with Section 6.6.
  - Shall update CI records associated with emergency changes within twenty-four (24) hours of the emergency change, in accordance with Section 6.6.
- **All County Personnel:**
  - Shall not modify, relocate, or alter any deployed IT asset in a manner that would affect its CI record without initiating a work order through the Information Operations Department.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel within scope.

- **Assessment**: CI record accuracy, work order closure quality, annual verification currency, and change record coupling shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to create required CI records at deployment, failure to remediate CI record deficits before work order closure, failure to update CI records following authorized changes, or failure to meet the annual verification obligations defined in this policy shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with the exception management framework defined in **Policy 5.01**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance

- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- CJIS Security Policy v6.0: Section CM-1 (Configuration Management Policy and Procedures)
- CJIS Security Policy v6.0: Section CM-2 (Baseline Configuration)
- CJIS Security Policy v6.0: Section CM-8 (System Component Inventory)
- NIST CSF 2.0: ID.AM-01 (Inventories of hardware managed by the organization)
- NIST CSF 2.0: ID.AM-02 (Inventories of software, services, and systems managed by the organization)
- NIST SP 800-53 Rev. 5: CM-1 (Configuration Management Policy and Procedures)
- NIST SP 800-53 Rev. 5: CM-2 (Baseline Configuration)
- NIST SP 800-53 Rev. 5: CM-8 (System Component Inventory)
- NIST SP 800-53 Rev. 5: CM-8(1) (Updates During Installation and Removal)
- COBIT 2019: BAI09 (Manage Assets)
- COBIT 2019: BAI10 (Manage Configuration)
- ITIL v4: Service Configuration Management Practice

6. Policy Statement

A CI record is distinct from an asset record. A **Policy 1.12** asset record answers whether a physical asset exists, who owns it, where it is, and what its operational state is. A Policy 3.08 CI record answers what that asset's current configuration identity is, what its operational relationships are, and whether its record is complete and current. Both records co-exist in the System of Engagement and cross-reference each other via the Related Issues field, but they serve different governance purposes and neither substitutes for the other. An asset enters inventory under **Policy 1.12**. It becomes a CI under this policy at the time of deployment into the operational environment.

The Department treats CI record accuracy as an operational obligation, not an administrative one. A deployed asset with an incomplete or inaccurate CI record is not fully serviceable. This policy establishes the mechanisms by which that standard is maintained continuously.

6.1 Configuration Item Definition and Lifecycle

A Configuration Item (CI) is any deployed IT asset whose configuration identity, operational relationships, and work order history require tracking to support service delivery, incident response, problem investigation, and change management. All Information Operations Personnel shall create a CI record in the System of Engagement at the time an asset is deployed into the operational environment. CI record creation shall not precede completion of supply chain review under **Policy 1.13**. The assigned Information Operations

Personnel shall ensure that the CI record cross-references the **Policy 1.12** asset record for the same physical asset via the Related Issues field in the System of Engagement. The assigned Information Operations Personnel shall retire the CI record when the asset is decommissioned under **Policy 1.12**.

6.2 System of Record Architecture

The Information Operations Department operates a two-layer configuration management architecture. Both layers are authoritative within their respective domains.

- **System of Engagement (CI Identity and Inventory)**: The System of Engagement is the designated system of record for CI identity and inventory. It holds configuration identity, physical location, operational state, funding source, assigned user, network identifiers, work order linkage, and annual verification date. The System of Engagement is the authoritative record of what a deployed asset is and where it belongs within the County's operational environment.
- **Endpoint Protection Platform (Active Configuration State)**: The Endpoint Protection Platform is the designated system of record for active endpoint configuration management. It holds OS version, patch level, software inventory, and endpoint compliance state. The Endpoint Protection Platform is the authoritative source for what a deployed asset is running. Reporting and compliance obligations for endpoint configuration state shall be satisfied by reference to Endpoint Protection Platform output. CI records in the System of Engagement shall not attempt to replicate Endpoint Protection Platform data, and population of CI fields shall not be used as a substitute for Endpoint Protection Platform compliance reporting.

Active configuration compliance — including OS patch level and endpoint hardening state — is enforced through the Endpoint Protection Platform. **Policy 2.10** defines the security baseline requirements that the Endpoint Protection Platform enforces. This policy does not restate those requirements and does not own baseline enforcement.

6.3 CI Minimum Field Set

The following fields constitute a complete CI record in the System of Engagement and shall all be populated for any deployed asset. The obligation this policy establishes is population discipline — ensuring that these fields are populated accurately and kept current — not the creation of new fields beyond those defined here.

- Subject (Device Name / Asset Tag).
- Status.
- Location and Room Number.
- Date Received.
- Equipment Type.
- Manufacturer and Model.
- Serial Number.
- Assigned User (where applicable).
- Device Name.
- IP Address (Ethernet and/or Wireless, where applicable).
- MAC Address (Ethernet and/or Wireless, where applicable).
- Funding Source.
- Cost.
- Expected Expiration Date.
- Verified (annual audit date).

- Related Issues (work order linkage).

All Information Operations Personnel shall populate network identity fields (IP Address and MAC Address) for all deployed networked assets. A deployed asset with Deployed status and empty network identity fields constitutes a record deficit requiring remediation. The IT Director shall approve any modification to the CI minimum field set.

6.4 CI Record Accuracy — Governing Principle and Work Order Closure Condition

The Department treats CI record deficits as operationally equivalent to functional deficits. A deployed asset with an incomplete or inaccurate CI record is not fully serviceable. A work order in which that asset is the primary subject of active work shall not be closed until the record deficit is remediated.

The CI verification and remediation obligation applies when the asset is the primary subject of active work in the work order — the asset being repaired, configured, deployed, or serviced. This obligation shall be restricted to the primary CI; it shall not extend to assets mentioned incidentally in a work order where active work is being performed on a different asset. The annual physical audit defined in Section 6.5 is the systematic mechanism for identifying and remediating record deficits on assets not recently touched by a work order.

The following mechanics govern CI record accuracy enforcement:

- The assigned technician shall verify that all required CI fields defined in Section 6.3 are populated as a condition of work order closure for any work order in which an asset is the primary subject.
- If the assigned technician discovers a record deficit during a work order, the assigned technician shall remediate the CI record before closing the work order.
- If remediation requires information the assigned technician cannot obtain independently, the work order shall remain open until the information is obtained and the CI record is updated. The assigned technician shall not close a work order with a known CI deficit documented and deferred.
- The assigned technician shall treat discovery of a CI record deficit during any work order as a defect requiring correction, not an observation to be deferred.

This obligation operates as a supplemental closure condition alongside the base work order closure standard defined in **Policy 3.05** (Service Request Fulfillment Policy). It does not create a standalone SLA or separate monitoring mechanism.

6.5 Annual CI Verification

The IT Director shall ensure that CI records are actively verified against the deployed asset on an annual basis, tied to the physical asset audit conducted under **Policy 1.12**. All Information Operations Personnel performing the annual audit shall update the Verified field in the System of Engagement to reflect the date of verification at the time of each annual audit. A deployed asset whose Verified date is more than twelve (12) months prior to the current date shall be treated as pending verification for audit purposes.

The annual physical audit is the systematic sweep for CI record accuracy across the full deployed asset population. Work order closure enforcement under Section 6.4 is the continuous mechanism between audits. Both mechanisms are complementary and shall operate in parallel.

6.6 CI Record Updates and Change Management Coupling

The coupling between this policy and **Policy 3.09** is bidirectional and mandatory.

Policy 3.08 → Policy 3.09 direction: No CI record in the System of Engagement shall be modified to reflect a configuration change without a corresponding authorized change record under **Policy 3.09**. A CI update reflecting a configuration change without a corresponding change record constitutes a compliance failure under this policy.

Policy 3.09 → Policy 3.08 direction: No change record under **Policy 3.09** shall be closed without a corresponding CI record update confirming that the System of Engagement record reflects the post-change configuration state. A closed change record with an un-updated CI record constitutes a compliance failure under **Policy 3.09**.

Emergency changes: Emergency changes executed under **Policy 3.09** emergency protocols may precede the formal change record. In those cases, the CI record update obligation is deferred, not waived. The assigned Information Operations Personnel shall update the CI record within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later, concurrent with the catch-up documentation obligation under **Policy 3.09**. Both timelines are governed by **Policy 3.09**.

6.7 Relationship to Downstream Policies

CI record accuracy directly supports the operational effectiveness of the following policies. The obligations defined in each relationship are stated here for clarity and shall not be construed as restatements of those policies' requirements.

- **Policy 3.06 (Operational Incident Management Policy)**: Incident work orders reference CI records to identify affected assets and their configuration identity. An incomplete CI record at the time of an incident is an operational liability that degrades incident response speed and accuracy.
- **Policy 3.07 (Problem Management Policy)**: Problem investigations use CI records and work order history to trace failure patterns and support root cause analysis. CI record accuracy and work order linkage directly support investigation quality. An incomplete or inaccurate CI record may impair the ability to establish a reliable configuration baseline for comparison.
- **Policy 1.13 (Supply Chain Risk Management and Vendor Governance)**: The assigned Information Operations Personnel shall not initiate CI record creation for any new asset until supply chain review under **Policy 1.13** is complete. CI creation is a post-clearance event.

3.09 Change Management Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy governs all changes to production systems, infrastructure, configurations, and software within the Elko County Information Operations Department (ECIO), including the classification, authorization, documentation, and closure requirements for Standard, Significant, and Emergency changes.

2. Scope

This policy applies to all Information Operations Department personnel and governs all changes to production systems, infrastructure, configurations, and software within the County technology environment administered by the Information Operations Department.

- **In Scope**:
  - Standard, Significant, and Emergency changes to production systems, infrastructure, configurations, and software.
  - Configuration Control Authority (CCA) authorization and Request for Change (RFC) record governance.
  - Rollback obligations, Post-Implementation Review (PIR) requirements, and change record closure.
- **Out of Scope**:
  - Security baseline definitions and hardening requirements: **Policy 2.10**.
  - CI record governance and minimum field set: **Policy 3.08**.
  - Release and deployment mechanics: **Policy 3.10**.
  - Incident response actions taken under Chapter 4: **Policy 4.01**.

Clarification: The CI record update obligation and catch-up RFC documentation obligation apply following any Emergency change, regardless of whether the change originated from an incident response context, per **Policy 3.08** and Section 6.7 of this policy.

3. Roles and Responsibilities

- **IT Director:**
  - Shall hold CCA authority for all Significant changes.
  - Shall delegate CCA authority for specific Significant changes to the Assistant IT Director only by explicit written authorization documented at the time of delegation, or through the standing delegation mechanism defined in Section 6.2.
  - Shall serve as the catch-up CCA reviewer for all Emergency changes.
  - Shall complete the catch-up CCA review of each Emergency change within twenty-four (24) hours, or by noon on the next business day, whichever is later.
  - May countermand any Emergency change designation; the countermand shall be documented in the change record at the time it is issued.

  - Shall authorize any alternative resolution path adopted in lieu of rollback for a failed Significant change; that authorization shall be documented in the change record at the time it is issued, with rationale.
  - Shall consult with the County Manager prior to implementation of any Significant change meeting the triggers defined in Section 6.6.
  - Shall approve exceptions to this policy through the exception process defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **County Manager:**
  - Shall be consulted by the IT Director prior to implementation of Significant changes meeting the triggers defined in Section 6.6.
  - Shall be notified no later than four (4) hours following the initiation of implementation when Emergency changes meet the consultation triggers defined in Section 6.6.
- **Assistant IT Director:**
  - Shall hold CCA authority for all Standard changes, by reference to standing authority under **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall hold CCA authority for Significant changes only where explicitly delegated in writing by the IT Director, or where the standing delegation defined in Section 6.2 applies.
  - Shall ensure that all Information Operations Personnel comply with the change categorization, RFC documentation, rollback, PIR, and CI update obligations established in this policy.
  - Shall ensure that catch-up RFC documentation and CCA review for Emergency changes are completed within twenty-four (24) hours, or by noon on the next business day, whichever is later.
  - Shall ensure that no change record is closed without a corresponding CI record update per Section 6.7.
  - May designate a change as Emergency in accordance with Section 6.2.
- **All Information Operations Personnel:**
  - Shall classify all changes using the categories defined in Section 6.1 prior to initiating any change activity.
  - Shall document Standard change authorization within the associated work order, including the basis for Standard classification and a reference to the qualifying Knowledge Base procedure under **Policy 3.13** (Knowledge Management Policy).
  - Shall submit a standalone RFC record in the System of Engagement prior to implementation of any Significant change.
  - Shall structure Significant changes as discrete, incremental steps, each with a defined rollback point, as required by Section 6.4.
  - Shall complete PIR documentation within the change record for all Significant and Emergency changes within five (5) business days of implementation, per Section 6.5.
  - Shall update the CI record in the designated system of record to reflect the post-change configuration state before or concurrent with closing any change record, per Section 6.7 and **Policy 3.08** (Service Configuration Management (CMDB) Policy).
  - Shall create catch-up RFC documentation for Emergency changes within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- **Incident Commander:**

  - May designate a change as Emergency when operating under an active incident response action, in accordance with Section 6.2.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel engaged in change management activities.

- **Assessment**: Adherence to change management requirements shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: The conditions that constitute compliance failures under this policy are defined in Section 6.8. Repeated or willful non-compliance may be escalated under **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be requested and approved through the exception process defined in **Policy 5.01**. Exceptions require IT Director approval in accordance with **Policy 1.08** and shall be documented prior to implementation. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- CJIS Security Policy v6.0: Section CM-3 (Configuration Change Control)
- CJIS Security Policy v6.0: Section CM-5 (Access Restrictions for Change)
- NIST CSF 2.0: ID.RA-07 (Changes and exceptions are managed, assessed for risk impact, recorded, and tracked)
- NIST CSF 2.0: PR.PS-01 (Configuration management practices are established and applied)
- NIST SP 800-53 Rev. 5: CM-3 (Configuration Change Control)
- NIST SP 800-53 Rev. 5: CM-4 (Impact Analyses)
- NIST SP 800-53 Rev. 5: CM-5 (Access Restrictions for Change)
- COBIT 2019: BAI06 (Manage IT Changes)
- COBIT 2019: BAI10 (Manage Configuration)

- ITIL v4: Change Enablement Practice

6. Policy Statement

This policy establishes the Configuration Control Authority (CCA) function, the Request for Change (RFC) record structure, rollback obligations, Post-Implementation Review (PIR) requirements, and the conditions under which County Manager consultation is mandatory before a change may proceed. Standard change authorization is captured within the work order per **Policy 3.05** (Service Request Fulfillment Policy) mechanics. Significant and Emergency change records are standalone RFC records that exist alongside, but separately from, any associated work order.

6.1 Change Categories

All changes to production systems, infrastructure, configurations, and software within the Information Operations Department's technology environment shall be classified into one of three categories prior to initiation: Standard, Significant, or Emergency. All Information Operations Personnel shall determine the classification before initiating any change activity. Changes entering the change management process from any source — including remediations authorized under **Policy 3.07** (Problem Management Policy) — shall be classified and authorized under this policy. The Problem management authorization confirms that the remediation addresses the identified root cause; the change management authorization under this policy confirms that the change can be safely implemented in the production environment. Both authorizations are required before implementation.

- **Standard Change**: A Standard change is a low-risk, pre-approved change type for which a documented procedure exists in the Knowledge Base under **Policy 3.13**. A change type qualifies as Standard only if a pre-approved procedure for that change type is documented in the Knowledge Base; if no qualifying procedure exists, the change shall be classified as Significant until such a procedure is established and documented. Standard changes shall not require a per-instance standalone RFC record; authorization shall be captured within the associated work order per Section 6.2. Standard change examples include routine patching, password resets, and network printer additions.
- **Significant Change**: A Significant change is any change that materially alters the County's operational technology environment and does not qualify as Standard or Emergency. Significant changes align with the "non-routine or significant IT-initiated tasks" category established in **Policy 3.05**. A standalone RFC record in the System of Engagement shall be submitted and CCA authorization shall be obtained prior to implementation.
- **Emergency Change**: An Emergency change is an unplanned change that shall be implemented immediately to restore service or address a critical security threat, where the time required to complete standard RFC and CCA review before acting would materially extend the duration or severity of the impact. Emergency changes shall be designated in accordance with Section 6.2. Implementation may precede the formal RFC record; catch-up documentation obligations are defined in Section 6.3.

6.2 Change Authorization and CCA

CCA is a function, not a title or organizational body. It is fulfilled as follows.

For **Standard** changes, the Assistant IT Director holds CCA authority by reference to standing authority under **Policy 1.08**.

For **Significant** changes, the IT Director holds CCA authority. The IT Director may delegate CCA authority for Significant changes to the Assistant IT Director through either of two mechanisms:

- **Per-instance delegation**: The IT Director issues explicit written delegation for a specific change or class of changes, documented at the time it is issued and specifying the scope to which it applies.
- **Standing delegation**: The IT Director may establish standing CCA delegation to the Assistant IT Director for Significant changes that satisfy all of the following criteria:

  - The change affects only internal IT infrastructure with no cross-departmental service impact.
  - The change has no Criminal Justice Information (CJI) nexus.
  - The change does not meet any County Manager consultation trigger defined in Section 6.6.
  - The change does not involve decommission or replacement of a system designated as operationally critical infrastructure by the IT Director.

The standing delegation shall be documented in the standing Delegation of Authority Order reviewed annually under **Policy 1.08**. The IT Director retains personal CCA authority for all changes involving CJI systems, cross-departmental impact, County Manager consultation triggers, critical infrastructure decommission, and any change the IT Director elects to review. The IT Director may revoke or modify the standing delegation at any time.

Implementation of a Significant change without prior CCA authorization constitutes a compliance failure under Section 6.8.

For **Emergency** changes, the IT Director, the Assistant IT Director, or the active Incident Commander may designate a change as Emergency. Emergency designation serves as a trigger for expedited change review and implementation; it does not itself constitute CCA authorization. The IT Director or Assistant IT Director shall hold provisional CCA authority to authorize immediate implementation of the designated Emergency change. Provisional CCA authority authorizes immediate implementation pending the catch-up CCA review defined below; if the catch-up review countermands the change, remediation obligations attach. Where the IT Director is the designating authority, that designation constitutes provisional CCA authorization. The IT Director may countermand any Emergency change designation; the countermand shall be documented in the change record at the time it is issued. Catch-up CCA review shall be completed by the IT Director within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later.

The County Manager consultation obligations defined in Section 6.6 shall be satisfied prior to CCA authorization for Significant changes. For Emergency changes meeting Section 6.6 triggers, County Manager notification shall occur no later than four (4) hours following the initiation of implementation.

6.3 RFC Structure and Requirements

- **Standard Changes**: No standalone RFC record shall be required. Authorization shall be documented within the associated work order and shall include: the basis for Standard classification, and a reference to the Knowledge Base procedure under **Policy 3.13** that qualifies this change type as Standard.
- **Significant Changes**: A standalone RFC record shall be created in the System of Engagement prior to implementation. The RFC shall include at minimum: a description and scope of the change; a risk assessment; discrete, incremental implementation steps each with a defined rollback point; a rollback plan; anticipated impact and affected systems; the CCA authorization record; and County Manager consultation status where applicable under Section 6.6.
- **Emergency Changes**: Implementation may precede the RFC record. A standalone RFC record shall be created in the System of Engagement within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later. This is the same clock as the CI record update obligation under **Policy 3.08** and the catch-up CCA review obligation; all three obligations run concurrently on the same clock. The catch-up RFC shall document: all actions taken prior to record creation with the most precise timestamps recoverable; the conditions that justified Emergency designation; the CCA review outcome; and CI update confirmation per **Policy 3.08**. Failure to complete catch-up RFC documentation or CCA review within this window constitutes a compliance failure under Section 6.8.

6.4 Rollback and Failed Change Protocol

Significant changes shall be structured as discrete, incremental steps, each with a defined rollback point. A single monolithic implementation is not permitted. The incremental step structure required in the RFC is

the mechanism that makes rollback to a stable state operationally feasible; it is a design requirement of the change, not a documentation preference.

A Significant change that fails mid-implementation shall be rolled back to the last stable incremental state immediately. Rollback shall not require additional authorization; it is the default response to implementation failure.

The IT Director may authorize an alternative resolution path in lieu of rollback. That authorization shall be documented in the change record at the time it is issued, with rationale.

The assigned technician shall evaluate a failed Significant change that required rollback against the Problem record spawn triggers defined in **Policy 3.07**. If the failure condition meets those triggers, a Problem record shall be created independently of the change management process. The change management process and the problem management process are complementary and shall not be merged or held pending the other's conclusion.

6.5 Post-Implementation Review (PIR)

The assigned technician shall complete a PIR for all Significant and Emergency changes. The PIR shall be documented within the change record itself; no standalone record is required.

The PIR shall address at minimum: whether the change achieved its intended outcome; whether any unintended impacts occurred; whether the rollback plan was invoked and, if so, why; and any follow-on actions required.

The assigned technician shall complete and document the PIR within five (5) business days of implementation.

6.6 County Manager Consultation

The following conditions require mandatory County Manager consultation prior to implementation of a Significant change:

- Changes to systems whose failure, compromise, or misconfiguration could directly affect the conduct, security, or publicly reported outcome of an election — such as voter registration systems, election night reporting systems, or network infrastructure dedicated to election administration.
  - **Exclusion**: Routine support work for the Clerk's office, including workstation support, peripherals, and streaming setup, shall not qualify.
- Changes that will cause planned downtime or degraded service visible to the public or to other County departments for more than one (1) business day.
- Changes involving decommission or replacement of a system designated as operationally critical infrastructure by the IT Director.
- Any change not meeting the above criteria that the IT Director determines carries political or notable operational implications.

County Manager consultation shall be documented in the RFC record prior to CCA authorization. Emergency changes meeting any of the above criteria shall notify the County Manager no later than four (4) hours following the initiation of implementation.

6.7 Change Record Closure and CI Record Coupling

The coupling between this policy and **Policy 3.08** is bidirectional and mandatory.

- **Policy 3.09 → Policy 3.08 direction**: No change record under this policy shall be closed without a corresponding CI record update confirming that the CI record in the designated system of record reflects the post-change configuration state. Closure of a change record with an un-updated CI record constitutes a compliance failure under Section 6.8.

- **Policy 3.08 → Policy 3.09 direction**: No CI record shall be modified to reflect a configuration change without a corresponding authorized change record under this policy. This obligation is established in **Policy 3.08**; this policy carries the reciprocal.
- **Emergency exception**: The CI record update obligation for Emergency changes is deferred, not waived. The assigned technician shall update the CI record within twenty-four (24) hours of the emergency change, or by noon on the next business day, whichever is later, concurrent with the catch-up RFC documentation obligation under Section 6.3. Both obligations run on the same clock.

6.8 Compliance Failure Definitions

The following conditions each constitute a compliance failure under this policy and shall be subject to corrective action under **Policy 5.01**:

- Implementation of a Significant change without prior CCA authorization (Section 6.2).
- Failure to complete catch-up RFC documentation or CCA review of an Emergency change within twenty-four (24) hours, or by noon on the next business day, whichever is later (Section 6.3).
- Closure of a change record without a corresponding CI record update per Section 6.7.

3.10 Release and Deployment Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy governs the packaging, testing, and deployment of applications, drivers, firmware, and associated documentation to production environments within the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations Department personnel involved in deployment activities across all change categories defined in **Policy 3.09** (Change Management Policy).

- **In Scope**:
  - Standard, Significant, and Emergency deployments to production environments.
  - Firmware deployments to network devices, switches, and infrastructure.
  - Software Repository eligibility and governance.
- **Out of Scope**:
  - Change authorization and RFC governance: **Policy 3.09**.
  - CI record governance following deployment: **Policy 3.08**.
  - Vendor deployments in cloud environments not directly controlled by ECIO: **Policy 5.06**.
  - Device-specific deployment procedures: **Policy 3.13**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall ensure this policy is implemented and enforced across all deployment activity within the Information Operations Department.
  - Shall ensure the Software Repository is maintained as the exclusive authorized deployment source.
  - Shall ensure the Department's test environment is established and operational.
  - Shall approve all Supported lifecycle status classifications under **Policy 3.01** (Service Catalog and SLA Policy) that serve as the intake authorization gate for Software Repository eligibility.
- **Assistant IT Director:**
  - Shall ensure deployment activities comply with this policy across all change categories.
  - Shall verify that the pre-deployment checklist for Emergency deployments is completed and documented before any Emergency deployment proceeds.
  - Shall confirm that post-deployment verification is complete and documented in the RFC record before the **Policy 3.09** PIR is opened for Significant and Emergency deployments.
  - Shall confirm that CI update obligations under **Policy 3.08** (Service Configuration Management (CMDB) Policy) are fulfilled within the applicable timelines.

  - Shall prepare proposals for adding items to the IT Asset Catalog under **Policy 3.01** and submit them to the IT Director for Supported classification approval.
  - Shall ensure that Knowledge Base entries for test environment applicability criteria and pilot group selection are current under **Policy 3.13** (Knowledge Management Policy).
- **All Information Operations Personnel:**
  - Shall deploy exclusively from the Software Repository under all change categories.
  - Shall document deployment activities in accordance with this policy and the applicable change record requirements under **Policy 3.09**.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel engaged in deployment activities.

- **Assessment**: Adherence to deployment requirements shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and in accordance with the review schedule defined in **Policy 1.05** (Policy Review and Update Procedures).
- **Enforcement**: Non-compliance with mandatory requirements shall be subject to corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment). The Software Repository requirement (Section 6.3) is non-waivable. No exception mechanism under this policy, **Policy 3.09**, or **Policy 5.01** shall authorize deployment from any source other than the Software Repository.
- **Exceptions**: Exceptions to this policy, other than the non-waivable Software Repository requirement, shall be requested and approved through the exception process defined in **Policy 5.01**. Exceptions require IT Director approval in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights) and shall be documented prior to implementation. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- CJIS Security Policy v6.0: Section CM-3 (Configuration Change Control)
- CJIS Security Policy v6.0: Section SA-10 (Developer Configuration Management)
- NIST CSF 2.0: PR.PS-01 (Configuration management practices are established and applied)

- NIST CSF 2.0: PR.PS-02 (Software is maintained, replaced, and removed commensurate with risk)
- NIST SP 800-53 Rev. 5: CM-3 (Configuration Change Control)
- NIST SP 800-53 Rev. 5: CM-7 (Least Functionality)
- NIST SP 800-53 Rev. 5: SA-10 (Developer Configuration Management)
- COBIT 2019: BAI06 (Manage IT Changes)
- COBIT 2019: BAI07 (Manage IT Change Acceptance and Transitioning)
- ITIL v4: Deployment Management Practice
- ITIL v4: Release Management Practice

6. Policy Statement

This policy is the downstream operational partner of **Policy 3.09**. **Policy 3.09** governs the authorization decision — whether a change may proceed and on what terms. This policy governs what happens after that authorization is granted: packaging, testing, and deploying the change to production. The Software Repository defined in Section 6.1 is the exclusive deployment source for all change categories. Category-specific deployment requirements are defined in Sections 6.4 through 6.6.

6.1 Software Repository

The Software Repository is the IT-controlled repository designated as the authoritative and exclusive source for all deployment packages within the scope of this policy.

The IT Director shall ensure the Software Repository is read-only for all personnel except Information Operations Personnel with authorized write access. The IT Director shall establish and maintain the write-access authorization process.

All Information Operations Personnel shall refer to the Software Repository by its governance function label in all policy instruments. Server paths and share names shall not appear in policy text to preserve policy validity if the repository is relocated.

6.2 Repository Eligibility

Only applications, drivers, firmware, and associated documentation corresponding to items with a current Supported lifecycle status classification in the IT Asset Catalog maintained under **Policy 3.01** shall be present in the Software Repository and eligible for deployment.

Presence in the repository without a corresponding Supported classification under **Policy 3.01** constitutes a policy violation. The Assistant IT Director shall remediate any such condition upon discovery.

The IT Director's approval of a Supported lifecycle status classification under **Policy 3.01** is the intake authorization gate for repository eligibility. The Assistant IT Director shall prepare classification proposals and submit them to the IT Director for approval. No separate intake approval process is required under this policy.

6.3 Repository Requirement — No Exceptions

All Information Operations Personnel shall deploy exclusively from the Software Repository under all change categories, including Emergency. This requirement applies regardless of urgency, authorization status, or the identity of the personnel directing the deployment.

The Emergency category in **Policy 3.09** authorizes expedited change authorization. It does not alter, waive, or supersede the deployment source requirement or the Supported classification eligibility requirement established in this policy. An Incident Commander's Emergency designation under **Policy 3.09** does not constitute authorization to deploy from an uncontrolled source.

6.4 Standard Deployments

The deploying technician shall deploy Standard changes from the Software Repository per the pre-approved Knowledge Base procedure maintained under **Policy 3.13**. The Knowledge Base procedure is the deployment control for Standard changes; no staging or pilot group is required.

The deploying technician shall document the deployment within the associated work order in accordance with **Policy 3.05** (Service Request Fulfillment Policy). The CI update obligation under **Policy 3.08** applies upon completion of the deployment.

Post-deployment verification for Standard deployments is implicit in work order closure under **Policy 3.05**.

6.5 Significant Deployments

The deploying technician shall deploy Significant changes from the Software Repository. Before implementation, the deploying technician shall prepare and document a deployment package within the RFC record under **Policy 3.09**.

The deploying technician shall complete staging or pilot group testing prior to full production deployment, in accordance with the testing requirements defined in Section 6.7. For Significant deployments affecting end-user systems, a phased rollout — pilot group before full production — shall be the default approach. Where a phased rollout is not applicable due to deployment scope or infrastructure constraints, the deploying technician shall document the basis for that determination in the RFC record before proceeding to full production deployment.

The deploying technician shall verify that the rollback procedure is operational before the deployment proceeds to production. The deploying technician shall document all deployment steps in the RFC record.

Post-deployment verification is required before the **Policy 3.09** PIR may be initiated. The Assistant IT Director shall confirm that post-deployment verification is complete and documented in the RFC record before the PIR is opened. The CI update obligation under **Policy 3.08** applies upon completion of the deployment.

6.6 Emergency Deployments

The deploying technician shall deploy Emergency changes from the Software Repository. No exception to this requirement applies under Emergency conditions.

Before any Emergency deployment proceeds, the deploying technician shall complete a pre-deployment checklist and document it in the catch-up RFC record. The checklist shall confirm each of the following: the deployment source is the Software Repository; the package has a corresponding Supported classification under **Policy 3.01**; and the deploying technician has confirmed the target systems. The Assistant IT Director shall verify that the completed checklist is documented in the catch-up RFC record under **Policy 3.09**.

Staging is waived for Emergency deployments. Post-deployment verification is required before the catch-up RFC record under **Policy 3.09** may be closed. The **Policy 3.09** PIR serves as the post-deployment review for Emergency deployments; no separate deployment review record is required.

The CI update obligation under **Policy 3.08** applies under the Emergency timeline established in **Policy 3.09**.

6.7 Staging and Testing

The IT Director shall ensure that a dedicated test environment is maintained for pre-production validation of Significant deployments. The test environment shall consist of one (1) or more virtual machines representative of production system configurations.

Where the dedicated test environment is not applicable to a specific deployment type — for example, infrastructure changes that cannot be meaningfully replicated in a virtual machine environment — the deploying

technician shall use a defined pilot group as the validation mechanism and shall document the basis for test environment non-applicability in the RFC record.

The Assistant IT Director shall ensure that the criteria for test environment applicability and pilot group selection are documented in the Knowledge Base under **Policy 3.13** and that the relevant entries are current.

6.8 Post-Deployment Verification and PIR Sequencing

Post-deployment verification is a prerequisite to initiating the **Policy 3.09** PIR for Significant and Emergency deployments. The deploying technician shall not request PIR initiation until post-deployment verification confirms that the deployment completed successfully and that no immediate unintended impacts are present. The **Policy 3.09** PIR is sufficient for both change review and deployment review purposes; no separate deployment post-implementation record is required.

For Standard deployments, post-deployment verification is implicit in work order closure under **Policy 3.05**.

6.9 Vendor Cloud Deployments

Where a vendor deployment in a cloud environment that ECIO does not directly control affects County-managed systems, the Information Operations Personnel who discovers the change shall notify the IT Director or Assistant IT Director upon discovery. The Assistant IT Director shall document the notification and assess the impact within one (1) business day of receipt. A CI update obligation under **Policy 3.08** is triggered upon such notification. Vendor deployment obligations are governed by **Policy 5.06** (Vendor Compliance and Third-Party Assurance) and are not restated here.

3.11 Capacity and Availability Management Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy governs the baselining, forecasting, and threshold management of capacity and availability for all IT services and infrastructure administered by the Elko County Information Operations Department.

2. Scope

This policy applies to all Information Operations personnel involved in the baselining, forecasting, and planning of capacity and availability for IT services, infrastructure, and applications administered by the Department.

- **In Scope**:
  - Capacity baseline establishment and maintenance across storage, compute, network bandwidth, and application performance.
  - Availability measurement for all services with active SLA commitments.
  - Capacity and availability threshold definition.
  - Forward-looking capacity and availability forecasting and planning.
  - Quarterly capacity and availability briefing.
- **Out of Scope**:
  - SLA target definitions, severity classification, and service catalog governance: **Policy 3.01**.
  - Real-time monitoring, alerting, and event response: **Policy 3.12**.
  - Service level performance reporting to stakeholders: **Policy 3.02**.
  - Service continuity and recovery planning for major disruptions: **Policy 3.15**.
  - Change authorization for capacity-driven infrastructure changes: **Policy 3.09**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall receive and review the quarterly capacity and availability briefing prepared by the Assistant IT Director.
  - Shall approve remediation plans that carry budget implications or require infrastructure change.
  - Shall authorize deviations from the planning cadences or threshold documentation requirements established in this policy.
- **Assistant IT Director:**
  - Shall serve as the operational owner of capacity baselining, availability measurement, threshold management, forecasting, and planning under Section 6.
  - Shall prepare and present the quarterly capacity and availability briefing to the IT Director.
  - Shall ensure that capacity and availability data is provided to the reporting processes governed by **Policy 3.02** (Service Level Management and Metrics Reporting).

- **Systems Administrator:**
  - Shall collect and update storage and compute utilization data for capacity baseline maintenance.
  - Shall provide domain-specific availability data for systems within their domain to the Assistant IT Director.
- **Network Administrator:**
  - Shall collect and update network bandwidth utilization data for capacity baseline maintenance.
  - Shall provide domain-specific availability data for network infrastructure to the Assistant IT Director.
- **All Information Operations Personnel:**
  - Shall support capacity and availability data collection as directed by the Assistant IT Director.
  - Shall document relevant performance observations in the work order system in accordance with **Policy 3.05** (Service Request Fulfillment Policy).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in capacity and availability management activities.

- **Assessment**: Compliance with baseline maintenance, threshold documentation, planning cadence, and briefing obligations shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain required baselines, document threshold values, conduct planning on the required cadence, or deliver required briefings without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period.

5. References

Cited References:

- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- COBIT 2019: BAI04 (Manage Availability and Capacity)
- ITIL v4: Availability Management Practice
- ITIL v4: Capacity and Performance Management Practice

6. Policy Statement

This policy governs capacity and availability planning: establishing baselines, defining thresholds, identifying trends, and driving remediation before gaps become service failures. The threshold values defined under this policy are provided to **Policy 3.12** (Monitoring and Event Management Policy) for implementation in automated monitoring configurations; real-time monitoring and alerting against those thresholds is governed by **Policy 3.12**, not this policy. The services under management are those with active SLA commitments under **Policy 3.01** (Service Catalog and SLA Policy).

6.1 Capacity Baseline

The Assistant IT Director shall maintain a current capacity baseline across all in-scope resource categories: storage, compute, network bandwidth, and application performance. The Assistant IT Director shall establish the baseline from measured actuals, shall update the baseline no less than quarterly, and shall document the baseline in the System of Engagement.

- **Data Collection**: The Systems Administrator shall collect and update storage and compute utilization data. The Network Administrator shall collect and update network bandwidth utilization data. The Systems Administrator and Network Administrator shall each submit updated utilization data to the Assistant IT Director no later than the fifth (5th) business day of each quarter.
- **Quarterly Validation**: The Assistant IT Director shall validate the accuracy of the capacity baseline no less than quarterly by reconciling domain inputs against the documented baseline and correcting any discrepancies.
- **Knowledge Base Maintenance**: The Assistant IT Director shall ensure that Knowledge Base entries maintained under **Policy 3.13** (Knowledge Management Policy) that document capacity baselines, availability thresholds, or planning procedures are reviewed and updated following each quarterly baseline validation.

6.2 Availability Measurement

The Assistant IT Director shall measure availability for all services with active SLA commitments under **Policy 3.01**. The Assistant IT Director shall distinguish planned downtime from unplanned downtime in all availability measurements. The Assistant IT Director shall measure availability actuals against **Policy 3.01** SLA targets no less than monthly and shall update availability records to reflect current actuals in advance of each quarterly briefing.

The Systems Administrator shall provide domain-specific availability data for systems within their domain. The Network Administrator shall provide domain-specific availability data for network infrastructure. The Systems Administrator and Network Administrator shall each submit availability data to the Assistant IT Director no later than the fifth (5th) business day of the following month.

The Assistant IT Director shall ensure that availability data is provided to the **Policy 3.02** reporting processes for inclusion in service level performance reports.

6.3 Threshold Definition

The Assistant IT Director shall define capacity and availability thresholds that, when breached, indicate risk to service level commitments. Each threshold entry shall include the resource category, the metric being measured, the threshold value, and the associated service or configuration item. The Assistant IT Director

shall document threshold values in the System of Engagement and shall provide them to the **Policy 3.12** monitoring function for implementation in automated monitoring configurations.

The Assistant IT Director shall review threshold values no less than annually or whenever a Significant or Emergency change, as defined in **Policy 3.09** (Change Management Policy), is executed against the service catalog or infrastructure.

6.4 Forecasting and Planning

The Assistant IT Director shall conduct forward-looking capacity and availability planning no less than annually. The Assistant IT Director shall time planning to inform the County budget cycle and shall account for known service changes, projected growth, and aging infrastructure.

Where forecasting identifies a gap between projected capacity and committed service levels, the Assistant IT Director shall develop a remediation plan within thirty (30) calendar days of gap identification. The Assistant IT Director shall present any remediation plan requiring budget allocation or infrastructure change to the IT Director for approval before submission to the **Policy 3.09** change process.

The Assistant IT Director shall route emergency capacity issues requiring immediate infrastructure change through the **Policy 3.09** Emergency change category.

6.5 Issue Response

When monitoring under **Policy 3.12** identifies a threshold breach, the Assistant IT Director shall investigate and determine whether the breach represents a transient condition or a structural capacity or availability gap.

- **Transient Conditions**: The Assistant IT Director shall document transient conditions, including duration and impact, in the System of Engagement prior to closing the associated record.
- **Structural Gaps**: The Assistant IT Director shall document structural gaps in the System of Engagement. The Assistant IT Director shall escalate gaps that pose imminent risk to service level commitments to the remediation planning process defined in Section 6.4 immediately. The Assistant IT Director shall incorporate gaps that do not pose imminent risk into the next annual planning cycle under Section 6.4.

6.6 Quarterly Briefing

The Assistant IT Director shall prepare and present a quarterly capacity and availability briefing to the IT Director. The briefing shall include, at minimum:

- Current baseline status across all in-scope resource categories.
- Availability actuals against **Policy 3.01** SLA targets, distinguishing planned and unplanned downtime.
- Threshold breaches recorded during the quarter and any threshold risk trends identified through monitoring under **Policy 3.12**.
- Identified trends or emerging gaps.
- Status of any active remediation plans.

The Assistant IT Director shall schedule the quarterly briefing cycle to support County budget planning milestones.

3.12 Monitoring and Event Management Policy

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy governs the real-time monitoring, event classification, and automated work order generation for all IT services, infrastructure, endpoints, and applications administered by the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel and governs the real-time monitoring of all IT services, infrastructure, endpoints, and applications administered by the Department.

- **In Scope**:
  - Availability and ping checks.
  - Performance metrics (CPU utilization, memory utilization, disk utilization, and application response times).
  - Flow data (NetFlow and sFlow).
  - Syslog and event logs from network equipment and servers.
  - SNMP polling.
- **Out of Scope**:
  - Configuration drift detection: **Policy 2.10**.
  - Physical security and environmental monitoring: **Policy 2.13**.
  - Security audit logging and SIEM operations: **Policy 2.11**.
  - Threshold definition and capacity planning: **Policy 3.11**.
  - Incident response once a work order is opened: **Policy 3.06**.
  - Service continuity and recovery: **Policy 3.15**.
  - Monitoring tool names, tool configurations, and tool-specific procedures: Knowledge Base under **Policy 3.13**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the **Incident Commander** by default for all operational incidents that generate work orders under this policy, consistent with the designation established in **Policy 3.06** (Operational Incident Management Policy).
  - Shall serve as the external communications spokesperson for operational incidents triggered by monitoring events under this policy.
  - Shall escalate to the County Manager, the Board of County Commissioners, or Department Heads as warranted by the nature and scope of the event.

  - Shall authorize any formal deviation from the monitoring cadences, configuration review requirements, or threshold implementation obligations established in this policy.
- **Assistant IT Director:**
  - Shall serve as the primary operational owner of the monitoring and event management function.
  - Shall ensure that all in-scope monitoring functions are operational and producing current data.
  - Shall review events and ensure that work orders are generated for Alert and Major events in accordance with this policy.
  - Shall ensure that threshold values received from **Policy 3.11** (Capacity and Availability Management Policy) are implemented in monitoring configurations.
  - Shall ensure that Knowledge Base entries for monitoring configurations under **Policy 3.13** (Knowledge Management Policy) remain current.
- **Network Administrator:**
  - Shall configure all network equipment within scope to forward syslog and event data to the designated collection infrastructure.
  - Shall maintain network equipment SNMP configurations to support polling.
  - Shall ensure that NetFlow and sFlow export configurations on network devices capable of NetFlow or sFlow export are current and functioning.
  - Shall document relevant network monitoring configurations in the Knowledge Base under **Policy 3.13**.
- **Systems Administrator:**
  - Shall maintain the monitoring collection infrastructure, including servers and collection platforms.
  - Shall configure server-side monitoring agents and ensure that performance and availability data is collected from all in-scope systems.
  - Shall ensure that server syslog forwarding to the collection infrastructure is current and functioning.
  - Shall document relevant server monitoring configurations in the Knowledge Base under **Policy 3.13**.
- **All Information Operations Personnel:**
  - Shall respond to work orders generated by automated monitoring events in accordance with **Policy 3.06** and **Policy 3.05** (Service Request Fulfillment Policy).
  - Shall document all actions taken in the work order system.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel within scope.

- **Assessment**: Compliance with monitoring configuration currency, event classification, work order generation, threshold implementation, and retention obligations shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain required monitoring configurations, classify and route events in accordance with the taxonomy established in this policy, generate required work orders, or retain

monitoring records for the required period without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception management framework defined in **Policy 5.01**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- LRDA 20071728 (IT Access Control Reviews and Audit Trails)

Framework Alignment:

- NIST CSF 2.0: DE.CM (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: SI-4 (System Monitoring)
- COBIT 2019: BAI04 (Manage Availability and Capacity)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: Monitoring and Event Management Practice

6. Policy Statement

This policy governs real-time detection and operational response: collecting monitoring data, classifying events, generating work orders for actionable conditions, and routing threshold breaches to the capacity and availability investigation process defined in **Policy 3.11**. The threshold values that this policy implements are defined in **Policy 3.11**,; proactive planning, baselining, and threshold definition are governed there. This

policy governs operational performance monitoring and is distinct from the security event logging governed by **Policy 2.11** (Audit Logging and Monitoring Policy); these are separate data streams, and the boundary between them is maintained intentionally.

6.1 Monitoring Scope and Configuration Ownership

The Department shall maintain real-time monitoring coverage across all IT services, infrastructure, endpoints, and applications within the scope defined in Section 2. In-scope data collection includes availability and ping checks, performance metrics, flow data, syslog and event logs, and SNMP polling.

The Network Administrator shall maintain monitoring configurations for all network equipment within scope. The Systems Administrator shall maintain the monitoring collection infrastructure and all server-side monitoring configurations. The Assistant IT Director shall verify that both configuration sets are current, functional, and producing data sufficient to support event classification under this policy.

Tool configurations, procedures, and monitoring runbooks shall be maintained in the Knowledge Base under **Policy 3.13**.

Monitoring data collected under this policy shall be provided to the **Policy 3.02** (Service Level Management and Metrics Reporting) reporting process as an input to monthly performance summary reports.

6.2 Event Taxonomy

The Assistant IT Director shall ensure that all events generated by the monitoring function are classified under the following four-tier taxonomy, regardless of monitoring stream. A single taxonomy governs all in-scope monitoring data types. Severity levels referenced below correspond to the severity classification framework defined in **Policy 3.01** (Service Catalog and SLA Policy).

- **Informational**: System behavior is within normal parameters. No action is required. Events at this tier shall be logged for baseline and trending purposes. No work order is generated.
- **Warning**: System behavior is approaching a defined threshold. No action is required. Events at this tier shall be logged. The Assistant IT Director shall maintain awareness of Warning-tier events as part of the threshold review obligations established in **Policy 3.11**. No work order is generated.
- **Alert**: A defined threshold has been breached and action is required. A work order shall be generated in the **System of Engagement** at Urgent or High severity, determined by the scope of impact at the time of the event. Alert-tier events initiate the **Policy 3.06** incident intake process and are subject to all intake, triage, and response obligations defined there.
- **Major**: Service impact is confirmed or imminent. A work order shall be generated in the System of Engagement at Critical severity. The IT Director shall be notified immediately. Major-tier events initiate the **Policy 3.06** incident intake process and are subject to all intake, triage, and response obligations defined there.

6.3 Security Handoff

Any event at any tier that meets the **Indicator of Compromise** (IoC) definition in **Policy 4.02** (Identification and Reporting Procedures) shall route immediately to Chapter 4, regardless of its tier classification at the time. The event tier governs operational response; **Policy 4.02** governs jurisdictional transfer. This handoff is consistent with the **Hard Fork** procedure established in **Policy 3.06**. Tier classification does not delay or qualify the security handoff obligation.

Events routed to Chapter 4 under this section enter intake on the continuous calendar-hour clock established in **Policy 4.02**,; the business-hour work order creation deadline in Section 6.4 does not apply to such events.

6.4 Automated Event Intake and Work Order Generation

The monitoring system is a valid intake channel under **Policy 3.06**. Work orders generated by Alert and Major events shall be created in the System of Engagement within the intake deadline established in **Policy 3.06**. The monitoring system may generate work orders automatically; automated creation satisfies the intake obligation. Work orders shall be created following the same submission standards as any other intake channel. Once created, the work order is triaged and worked under standard **Policy 3.06** mechanics.

No response activity shall proceed on an Alert or Major event without an associated work order.

Work orders generated by persistent threshold breach patterns accumulate in the work order queue and are subject to the **Policy 3.06**, spawn triggers and the **Policy 3.07** (Problem Management Policy) intake process. No separate spawn mechanism is required under this policy.

6.5 Threshold Implementation and Review

The Assistant IT Director shall receive threshold values from the **Policy 3.11** process defined in Section 6.3 of that policy and shall implement them in monitoring configurations. The Assistant IT Director shall review threshold implementation in monitoring configurations on the cadence established in **Policy 3.11**.

When monitoring under this policy identifies a threshold breach, the Assistant IT Director shall conduct the investigation defined in **Policy 3.11**, to determine whether the breach represents a transient condition or a structural capacity or availability gap.

6.6 Retention

The Assistant IT Director shall ensure that monitoring event records, alert records, and telemetry data are retained for a minimum of three (3) calendar years from the end of the calendar year in which the record was generated, in accordance with **Policy 1.11** (Data Governance and Classification Policy) and the Nevada Local Government Records Retention Schedule: LRDA 20071728 (IT Access Control Reviews and Audit Trails). Work orders generated from monitoring events shall be retained under the closure and retention obligations of **Policy 3.06**.

3.13 Knowledge Management Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy governs the creation, maintenance, review, and retirement of all knowledge artifacts within the Departmental Knowledge Base, including the authorization function that qualifies change types as Standard under **Policy 3.09** (Change Management Policy).

2. Scope

This policy applies to all Information Operations Personnel and governs all knowledge artifacts created, maintained, or retired by the Department.

- **In Scope**:
  - Operational procedures.
  - Workaround and resolution documentation.
  - Known Error entries.
  - Standard change pre-authorization procedures.
  - Standard deployment procedures.
  - System and tool configurations.
  - Monitoring runbooks.
  - Escalation paths and service delivery workflows.
  - Reference documentation.
- **Out of Scope**:
  - Policy documents: **Policy 1.04** and **Policy 1.05**.
  - Work order records: **Policy 3.05**.
  - Configuration Management Database (CMDB) records: **Policy 3.08**.
  - Security audit logs and SIEM data: **Policy 2.11**.
  - Incident and Problem records: **Policy 3.06** and **Policy 3.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for the formal retirement of any KB article.
  - Shall approve KB procedures that carry Standard change authorization weight, consistent with the change authorization framework in **Policy 3.09**.
  - Shall authorize any external distribution of KB content in writing.
  - Shall authorize any formal deviation from the documentation, review, or retention obligations established in this policy.
- **Assistant IT Director:**

  - Shall serve as the primary operational owner of the Knowledge Base as a system, including platform accessibility, organizational structure, and category integrity, in support of the mandatory pre-escalation search obligation established in **Policy 3.06** (Operational Incident Management Policy).
  - Shall ensure Known Error entries are published and marked inactive within the timeframes established in **Policy 3.07** (Problem Management Policy).
  - Shall conduct or coordinate the annual KB review cycle and shall verify that all domain-level reviews are completed.
  - Shall coordinate review of all KB entries associated with any modified system, service, or configuration following Significant or Emergency changes, consistent with the obligations established in **Policy 3.09** and **Policy 3.12** (Monitoring and Event Management Policy).
  - Shall establish and maintain the operational standard governing KB procedure formatting conventions, templates, and acceptable secondary accessible media.
- **Network Administrator:**
  - Shall author and maintain all KB entries governing network equipment monitoring configurations, SNMP configurations, and NetFlow/sFlow export configurations, as required by **Policy 3.12**.
  - Shall author and maintain all Reference Documentation entries within the network domain, including network schemas, addressing plans, VLAN tables, and topology diagrams.
  - Shall review assigned KB entries for accuracy no less than annually.
  - Shall approve new technical entries authored by Support Specialists within the network domain before publication.
  - Shall author Standard change pre-authorization procedures within the network domain and submit them for IT Director approval.
- **Systems Administrator:**
  - Shall author and maintain all KB entries governing server-side monitoring configurations, collection infrastructure, and server syslog forwarding, as required by **Policy 3.12**.
  - Shall author and maintain all Reference Documentation entries within the server and systems domain, including system architecture overviews and similar informational artifacts.
  - Shall review assigned KB entries for accuracy no less than annually.
  - Shall approve new technical entries authored by Support Specialists within the systems domain before publication.
  - Shall author Standard change pre-authorization procedures within the systems domain and submit them for IT Director approval.
- **Support Specialist:**
  - Shall author and revise KB entries under Administrator guidance.
  - Shall document new procedures prior to closing any work order for a task that lacked prior documentation.
  - Shall reference applicable KB entries in all work orders.
- **All Information Operations Personnel:**
  - Shall search the KB before escalating any incident, as required by **Policy 3.06**.
  - Shall flag outdated, inaccurate, or missing KB content to the responsible Administrator or the Assistant IT Director.

  - Shall reference applicable KB entries in work order documentation.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Personnel.

- **Assessment**: Compliance with KB currency, Known Error publication timelines, Standard change procedure approval, annual review cadence, and documentation-before-closure obligations shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain required KB entries, publish Known Error entries within established timeframes, obtain required approvals for Standard change procedures, or document new procedures prior to work order closure shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception framework defined in **Policy 5.01**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20070057 (Departmental Regulations, Policies and Procedures)

Framework Alignment:

- COBIT 2019: BAI08 (Manage Knowledge)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: Knowledge Management Practice

6. Policy Statement

The Knowledge Base serves as both the authoritative repository for operational knowledge and the authorization mechanism that qualifies change types as Standard under **Policy 3.09**. This policy governs the KB content lifecycle; upstream policies govern the triggers that mandate specific KB actions.

6.1 Knowledge Base as Authoritative Repository

The Knowledge Base maintained in the System of Engagement is the authoritative repository for all operational knowledge artifacts governed by this policy.

- The Assistant IT Director shall ensure that all KB articles are stored in the System of Engagement as the primary repository.
- The Assistant IT Director shall maintain at least one secondary accessible medium, synchronized no less than monthly, in accordance with the operational standard the Assistant IT Director establishes under Section 3.

6.2 KB Content Categories

All knowledge artifacts shall be classified under the following categories:

- **Workaround Procedures**: Resolution procedures for known conditions; mandatory pre-escalation reference per **Policy 3.06**.
- **Known Error Entries**: Documented Known Errors with symptom description, workaround procedure, and Problem record reference.
- **Standard Change Procedures**: Pre-approved procedures that authorize Standard change classification under **Policy 3.09**.
- **Standard Deployment Procedures**: Pre-approved deployment steps for Standard changes, maintained as the deployment control per **Policy 3.10** (Release and Deployment Policy).
- **Tool Configurations and Runbooks**: Monitoring tool configurations, collection parameters, and operational runbooks maintained by role per **Policy 3.12**.
- **Incident Response Playbooks**: Scenario-based containment and response artifacts governed by **Policy 4.03** (Containment Strategy and Playbooks) and formatted per **Policy 1.04**.
- **Operational Procedures**: Recurring procedures, system workflows, and escalation paths not covered by the categories above.
- **Reference Documentation**: Static informational artifacts that document the state of the environment and support operational decision-making, including network schemas, addressing plans, VLAN tables, topology diagrams, and system architecture overviews. Reference Documentation entries do not prescribe action steps and are not subject to the structured procedure format requirement in Section 6.3.

Ownership and review obligations for each category shall follow the roles defined in Section 3.

6.3 Structured Procedure Format

All KB procedures shall document tasks as discrete, sequentially numbered steps. KB procedures shall address known error conditions and their corresponding recovery actions as conditional branches within the step sequence. KB procedures shall specify the expected end state upon successful completion. The Assistant IT Director shall establish and maintain the formatting conventions and templates implementing these requirements as an operational standard.

6.4 Standard Change Authorization Function

A KB procedure qualifies a change type as Standard only when the procedure carries explicit IT Director approval. If no qualifying KB procedure exists for a given change type, the change type shall default to Significant classification under **Policy 3.09**. The IT Director shall approve retirement or material modification of any Standard change procedure through the same approval path as creation.

6.5 Known Error Entry Lifecycle

Known Error entries are a distinct KB record type. The Known Error declaration and closure triggers, including publication and inactivation timeframes, are governed by **Policy 3.07**; this policy governs the KB mechanics of the entry lifecycle.

- Upon Known Error declaration, the Assistant IT Director shall ensure publication within the timeframe established in **Policy 3.07**, including symptoms, workaround procedure, and Problem record reference.
- Upon permanent remediation and Problem closure, the Assistant IT Director shall ensure the corresponding entry is marked inactive within the timeframe established in **Policy 3.07**.

6.6 Documentation-Before-Closure Obligation

The assigned technician shall create or revise a KB article for any task executed without a corresponding KB entry prior to closing the associated work order.

- **Clarification**: Updating an existing KB article to cover a new variant of a documented procedure satisfies this obligation; a separate article is not required for every unique task instance.

6.7 Review, Retirement, and Retention

The following review, retirement, and retention obligations govern the lifecycle of all KB entries.

- **Review**: The content owner (Network Administrator or Systems Administrator as applicable) shall review each KB entry within their domain no less than annually or following any Significant or Emergency change affecting the documented procedure or reference artifact.
- **Retirement**: Only the IT Director shall authorize the formal retirement of any KB article. The Assistant IT Director shall mark retired articles as inactive upon IT Director authorization.
- **Retention**: The Assistant IT Director shall ensure that retired articles are retained in an inactive state for a minimum of six (6) calendar years after supersession or official abandonment, in accordance with NRS 239.125 and Nevada Local Government Records Retention Schedule LRDA 20070057. The IT Director shall not authorize disposition of any KB article subject to an active litigation hold, audit hold, or public records preservation requirement, regardless of the retention period.
- **Confidentiality**: All KB content shall be treated as operationally confidential. No Information Operations Personnel shall distribute KB content externally without written IT Director authorization.
  - **Clarification**: This operational designation does not alter public records status or disclosure requirements under applicable law.

3.14 IT Project Management Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes the framework for the designation, governance, execution, and closure of IT projects within the Elko County Information Operations Department, governing the full project lifecycle from charter through post-mortem. This policy ensures that project work is formally authorized, documented, and governed in alignment with the Department's governance obligations and service commitments.

2. Scope

This policy applies to all Information Operations Department personnel and all County stakeholders participating in formally designated IT projects.

- **In Scope**:
  - Initiatives formally designated as IT projects by the IT Director or Assistant IT Director.
  - Internal projects originated by the Information Operations Department to fulfill its own operational, infrastructure, or governance objectives.
  - External projects where the Department participates as technical authority and service partner.
- **Out of Scope**:
  - Routine and standard operational work: **Policy 3.05**.
  - Standard and Significant changes below the project designation threshold: **Policy 3.09**.
  - Unauthorized technology procurement or implementation: **Policy 1.10**.
  - Vendor governance and supply chain risk review: **Policy 1.13**.
  - SDLC and secure development requirements for system acquisitions: **Policy 2.15**.
  - Cybersecurity incident post-mortems: **Policy 4.07**.
  - External budget appropriation and funding timelines outside the Department's direct control.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for all project charters.
  - Shall serve as the approving authority for any change to the active project priority order.
  - Shall serve as the approving authority for all annual project re-authorizations.
  - Shall receive project status as part of the Monthly Executive Report obligation established in **Policy 1.14** (Stakeholder Engagement and Communications Policy).
  - Shall authorize emergency project designations and emergency waivers of project process components with documented rationale. Normal procedures shall resume no later than completion of catch-up documentation required under Section 6.1.
  - Shall serve as joint authority with the Assistant IT Director for formal IT withdrawal from external projects.

  - Shall provide final sign-off for project closure on all complex projects and on any project involving a Significant or Emergency change.
- **County Manager:**
  - Shall receive project status via the IT Director's Monthly Executive Report per **Policy 1.14**.
  - Shall receive written notification prior to any IT withdrawal from an external project.
  - May serve as a neutral arbitrator between the sponsoring agency and the Information Operations Department prior to withdrawal being finalized, consistent with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Assistant IT Director:**
  - Shall serve as the primary owner of the project portfolio per **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
  - Shall maintain the active project priority order in the System of Engagement.
  - Shall ensure project documentation compliance across all active projects.
  - Shall coordinate with the IT Director on charter approval, re-authorization, and closure.
  - Shall confirm go-live stability as the trigger for complex project post-mortems.
  - Shall verify that all Knowledge Base, CMDB, CI update, and service catalog obligations are satisfied at project closure.
  - Shall serve as joint authority with the IT Director for formal IT withdrawal from external projects.
  - Shall provide sign-off for routine project closure, with IT Director countersign.
- **Project Owner:**
  - Shall coordinate stakeholders, own the project timeline and task assignments, and ensure that all required documentation is attached to the project record throughout the lifecycle.
  - Shall escalate risks and scope changes to the Assistant IT Director within one (1) business day of identification.
  - Shall conduct or coordinate the post-mortem.
  - Shall serve as the primary notification recipient if IT withdrawal is invoked on an external project.
- **All Information Operations Personnel:**
  - Shall execute assigned project tasks documented in child work orders.
  - Shall document execution details, configuration changes, and risk observations in the work order system per **Policy 3.05** (Service Request Fulfillment Policy).
  - Shall raise risks to the Project Owner within one (1) business day of identification.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel and all stakeholders participating in formally designated IT projects.

- **Assessment**: Project management compliance shall be assessed as part of the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring) and through internal audit procedures defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).
- **Enforcement**: Non-compliance may result in corrective actions as defined in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Exceptions**: Exceptions to this policy shall be authorized in writing by the IT Director. Emergency waivers of specific process components are permitted per Section 6.1 of this policy. All exceptions shall be documented in the project record and retained with the master work order. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 2.06: Privacy and Data Protection Policy
- ECIO Policy 2.15: System Development and Secure Software Lifecycle Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.10: Release and Deployment Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- COBIT 2019: BAI02 (Manage Requirements Definition)

Framework Alignment:

- COBIT 2019: BAI01 (Manage Programs)
- ITIL v4: Project Management Practice

6. Policy Statement

6.1 Project Designation

An initiative qualifies for formal project designation when it (a) requires three (3) or more discrete work orders to complete, and (b) requires advance resource planning, stakeholder coordination, or sequenced task dependencies that cannot be captured within a single work order record. Both conditions shall be satisfied for threshold-based designation.

The Assistant IT Director or IT Director may designate any initiative as a formal project regardless of whether it meets the threshold criteria. No initiative may self-designate as a project below the threshold without authorization from the Assistant IT Director or IT Director.

- **Emergency Designation**: An initiative may be formally designated as a project after work has already begun when urgency precludes advance charter preparation — for example, a county-mandated security remediation requiring an immediate multi-work-order response. Emergency designation requires IT Director authorization. Catch-up documentation, including the project charter, risk log, stakeholder map, and all other required project record elements defined in Section 6.10, shall be completed and attached to the master work order within five (5) business days of emergency designation.
  - **Constraint**: Emergency designation waives the advance charter approval requirement only. It does not waive the documentation requirements enumerated in Section 6.10, the change classification obligations under **Policy 3.09** (Change Management Policy), or the CMDB and Knowledge Base closure gates.

The IT Director shall review emergency project designations in aggregate no less than annually as part of the maturity scoring process defined in **Policy 5.07**.

6.2 Project Record Structure

Each formally designated project shall be represented in the System of Engagement as a master work order, which serves as the project record and coordination hub. The master work order shall have the Internal Project checkbox set per **Policy 3.05** and work order operational standards maintained in the System of Engagement. Individual task units shall be created as child work orders and linked to the master via the Related Issues field.

A **Policy 3.09** Post-Implementation Review (PIR) fires on any Significant or Emergency change within a child work order per the timelines and mechanics established in **Policy 3.09**. This is a change-level obligation that runs independently of this policy. A separate project post-mortem under Section 6.7 fires when the master work order closes, covering the initiative as a whole. These two (2) obligations are parallel and distinct.

6.3 Phase 1 — Initiation and Charter

The IT Director shall designate a Project Owner at charter for every formally designated project. Project Owner is a functional designation assigned per-project to an existing role holder — IT Director, Assistant IT Director, Information Operations Systems Administrator, or Information Operations Network Administrator. For vendor-led external projects, the assigned Information Operations Systems Administrator or Information Operations Network Administrator shall serve as Project Owner.

The Project Owner shall define the project scope, objectives, impacted stakeholders, resource requirements, success criteria, and target completion date. The charter shall designate stakeholders and testers from the sponsoring department where applicable and shall specify their participation obligations for requirements definition, testing, acceptance, and post-mortem review. The charter shall explicitly document:

- Whether the project is net-new-service-bearing, for purposes of the service catalog closure gate in Section 6.6.
- Whether the project involves vendor engagement, which triggers the **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance) gate before contracts are executed.
- Whether the project involves systems that process, store, or transmit County data, which flags the data classification obligation in Section 6.4.
- Whether the project will process, store, or transmit CJI, PII, or PHI, which requires a Privacy Impact Assessment (PIA) approved by the IT Director as part of the charter approval package under **Policy 2.06** (Privacy and Data Protection Policy).

The IT Director shall approve the charter before any project work begins. The master work order shall be created in the System of Engagement upon charter approval.

For emergency project designations, IT Director authorization substitutes for advance charter approval. Catch-up documentation shall be completed within five (5) business days of emergency designation per Section 6.1.

6.4 Phase 2 — Planning

The Project Owner shall complete the following activities during the planning phase, before execution begins:

- Stakeholder and tester identification.
- Solution evaluation and selection, including vendor demonstrations where applicable. Solution evaluation shall follow the requirements definition standards in COBIT 2019: BAI02 (Manage Requirements Definition). Planning-phase activities shall not absorb SDLC or secure development obligations governed by **Policy 2.15** (System Development and Secure Software Lifecycle Policy).
- For projects involving systems that process, store, or transmit County data: data classification under **Policy 1.11** (Data Governance and Classification Policy) shall be completed during this phase before execution begins.
- Timeline and milestone definition, with task ownership assigned per work order.
- Risk log creation. Risk scoring shall apply the criteria established in **Policy 1.09** (Risk Management Policy).
- Communication plan development.
- Child work orders shall be created for each discrete task unit and linked to the master work order via the Related Issues field.

6.5 Phase 3 — Execution and Ongoing Oversight

All task execution shall be documented in child work orders per **Policy 3.05**. All production changes shall be classified and authorized per **Policy 3.09**; Significant and Emergency changes trigger **Policy 3.09** PIR obligations on the relevant child work orders independently of this policy. All deployments shall be executed from the Software Repository per **Policy 3.10** (Release and Deployment Policy). The Project Owner shall monitor KPIs against defined success criteria and shall escalate identified risks to the Assistant IT Director within one (1) business day of identification.

Scheduled Status Reviews: The Project Owner shall conduct status reviews at intervals not exceeding twenty-five (25) percent of the chartered project duration, measured by elapsed calendar days from project initiation to the chartered target completion date. For projects with no defined end date, or where the calculated interval would exceed ninety (90) calendar days, status reviews shall occur at ninety (90) calendar day intervals instead. Each review shall confirm that scope, budget, and timeline remain on track and shall be documented in the project record.

Any status review that identifies scope expansion beyond the approved charter, budget variance exceeding five (5) percent of the approved charter amount, or resource reassignment shall escalate to IT Director re-authorization regardless of where it falls on the annual re-authorization clock.

- **Clarification**: The budget variance trigger applies only where a project budget is formally defined in the charter. For external projects with sponsor-owned funding, the charter shall state whether the Department controls a defined budget component subject to this threshold.

Annual Re-Authorization: For projects exceeding twelve (12) months in duration, the IT Director shall provide annual re-authorization confirming that the project continues under its current charter. Re-authorization shall be documented in the project record.

6.6 Phase 4 — Closure Gates

The Assistant IT Director shall verify that the following gates are satisfied before the master work order may be closed:

- All child work orders resolved or formally dispositioned.
- CI records updated per **Policy 3.08** (Service Configuration Management (CMDB) Policy).
- Knowledge Base documentation completed per **Policy 3.13** (Knowledge Management Policy).
- All **Policy 3.09** PIRs completed for any Significant or Emergency changes, within the timelines established in **Policy 3.09**.
- **For net-new-service-bearing projects**: the service shall be registered in the service catalog under **Policy 3.01** (Service Catalog and SLA Policy), and SLA targets shall be established under **Policy 3.02** (Service Level Management and Metrics Reporting), before closure.
- **Formal acceptance**: the Assistant IT Director and IT Director shall jointly confirm that acceptance criteria have been met and shall authorize transition to steady-state operations. For external projects, the Project Owner shall countersign acceptance.

6.7 Phase 5 — Post-Mortem

The Project Owner shall conduct a post-mortem for every formally designated project upon master work order closure. Post-mortem timing is tiered by project complexity:

- **Routine projects** — those completing within ninety (90) calendar days with no Significant or Emergency changes — shall complete the post-mortem within fourteen (14) calendar days of master work order closure.
- **Complex projects** — those exceeding ninety (90) calendar days in duration, involving Significant or Emergency changes, or involving vendor delivery — shall initiate the post-mortem upon Assistant IT Director confirmation of go-live stability, with a hard outer bound of thirty (30) calendar days from master work order closure regardless of stability status.

The Project Owner shall ensure the post-mortem addresses:

- Whether the project achieved its defined success criteria.
- Scope, budget, and timeline variance.
- Risks that materialized and the means by which they were resolved.
- Stakeholder and communication plan effectiveness.
- Actionable takeaways for future projects.

The post-mortem summary shall be documented in the project record and retained with the master work order. Stakeholders designated in the project charter shall participate in the post-mortem review as specified in the charter.

The Project Owner shall document training requirements identified during a project in the project charter and shall communicate them to the relevant department for that department's own planning purposes. End-user training delivery carries no project closure gate obligation under this policy.

6.8 Project Portfolio Management

Any change to the active project priority order requires IT Director approval, documented in the project record at the time the change is made.

In external projects, the sponsoring department or entity provides direction on business objectives and outcomes. The Information Operations Department retains full authority over technical design, security

compliance, architecture decisions, and all IT governance obligations established in this manual. External project sponsors hold no supervisory or directive authority over Information Operations Personnel or IT technical determinations.

When a vendor leads project delivery, an Information Operations Systems Administrator or Information Operations Network Administrator shall serve as the internal Project Owner and shall carry all oversight obligations defined in this policy. **Policy 1.13** governs the vendor governance obligations; this policy governs the internal accountability structure.

Project KPI performance data shall feed into the broader performance management framework defined in **Policy 5.04** (Performance Metrics and Operational KPIs).

6.9 Project Cancellation, Suspension, and IT Withdrawal

Internal Projects: Formal cancellation or suspension of an internal project requires IT Director authorization. The Project Owner shall close or suspend all in-flight child work orders with their current state documented. The Project Owner shall update CMDB and Knowledge Base entries to reflect completed work. No obligation exists to revert partially-configured systems to their pre-project baseline.

External Projects — Agreed Closure: The IT Director may formally close IT's role in an external project when all project sponsors concur that IT's role is complete. IT's role may be formally closed while the project continues under the sponsor's direction. Upon formal closure of IT's involvement, the Information Operations Department carries no further obligation for the project's outcomes.

External Projects — IT Withdrawal Over Objection: The IT Director and Assistant IT Director may jointly declare a formal IT withdrawal from an external project when continued involvement is technically, financially, or operationally untenable — for example, when scope changes imposed by external parties conflict with the Department's security, architecture, or resource obligations, or when the project direction creates unacceptable risk to County systems or ongoing service commitments. Neither the IT Director nor the Assistant IT Director may invoke withdrawal unilaterally.

Prior to withdrawal, the County Manager shall be notified in writing of the basis for the Department's position. The County Manager may serve as a neutral arbitrator between the sponsoring agency and the Information Operations Department to ensure good-faith resolution before withdrawal is finalized, consistent with **Policy 1.08**. If the County Manager's arbitration does not resolve the impasse, the IT Director and Assistant IT Director may proceed with withdrawal.

Upon withdrawal, the Project Owner and County Manager shall receive written notice documenting the basis for withdrawal and the current state of all IT work. The Project Owner shall close or suspend all in-flight IT work orders with their current state documented. The Project Owner shall update CMDB and Knowledge Base entries to reflect completed work. No obligation exists to revert partially-configured systems to their pre-project baseline. The project may continue under the sponsor's direction; the Information Operations Department carries no further obligation for its outcomes.

The IT Director shall report all IT withdrawals from external projects in the next Monthly Executive Report under **Policy 1.14**.

6.10 Documentation Requirements

The Project Owner shall ensure that all project records include the following elements, maintained in the System of Engagement, attached to or linked from the master work order:

- Project Charter (IT Director approved; or catch-up charter for emergency designations, completed within five (5) business days of emergency designation).
- Stakeholder Map.
- Risk Log.
- Timeline and Task Assignments.

- Communication Plan.
- KPI Results.
- Post-Mortem Summary.
- Status review records (at each review interval defined in Section 6.5).
- Annual re-authorization record (for projects exceeding twelve (12) months in duration).

Project records shall be retained under the work order retention obligations applicable per **Policy 3.05**.

3.15 Service Continuity and Contingency Planning Policy

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy establishes the framework for planning, preparing for, and recovering from disruptions to IT services managed by the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all IT systems, services, and infrastructure operated or managed by the Information Operations Department.

- **In Scope**:
  - Business Impact Analysis (BIA) development and maintenance.
  - Asset criticality classification.
  - Recovery Time Objective (RTO) and Recovery Point Objective (RPO) definition.
  - Continuity Plan development and maintenance.
  - Backup governance framework requirements.
  - Continuity plan activation.
  - Operational recovery sequencing following plan activation or Operational Handback from Chapter 4.
- **Out of Scope**:
  - Steady-state capacity and availability management: **Policy 3.11**.
  - Real-time monitoring, alerting, and event detection: **Policy 3.12**.
  - Operational incident response execution: **Policy 3.06**.
  - Cybersecurity incident response and security-phase recovery operations: **Policy 4.05**.
  - Physical security and environmental controls: **Policy 2.13**.
  - Risk scoring and Risk Register maintenance: **Policy 1.09**.
  - Backup operational procedures: **Policy 3.13**.
  - SLA target-setting for normal operations: **Policy 3.01**.
  - Change authorization for infrastructure changes: **Policy 3.09**.

3. Roles and Responsibilities

All roles identified in this section correspond to positions defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).

- **IT Director:**
  - Shall serve as the Incident Commander by default for all continuity plan activations, consistent with the designation established in **Policy 3.06** (Operational Incident Management Policy).

  - Shall serve as the approving authority for the Business Impact Analysis, including all criticality classification assignments, RTOs, RPOs, and backup minimums.
  - Shall serve as the approving authority for the Continuity Plan and all material amendments to it.
  - Shall authorize continuity plan activation under the Incident Commander judgment pathway defined in Section 6.3.
  - Shall authorize any formal exception to the testing cadence established in Section 6.5.
  - Shall receive the annual tabletop exercise findings report.
- **Assistant IT Director:**
  - Shall own the Business Impact Analysis as a planning artifact and shall maintain it on the cadence defined in Section 6.2.
  - Shall develop and maintain the Continuity Plan in the System of Engagement.
  - Shall design tabletop exercise scenarios, facilitate the exercise, document findings, and present the findings report to the IT Director.
  - Shall ensure that Knowledge Base documentation under **Policy 3.13** (Knowledge Management Policy) for backup procedures and test procedures remains current and consistent with the backup minimums approved in the BIA.
  - Shall ensure that CI records and CMDB entries under **Policy 3.08** (Service Configuration Management (CMDB) Policy) reflect recovery configuration requirements for in-scope systems.
- **Systems Administrator:**
  - Shall execute backup operations in accordance with the procedures maintained in the Knowledge Base under **Policy 3.13**.
  - Shall implement and maintain cryptographic mechanisms to protect the confidentiality and integrity of all backups at rest and in transit.
  - Shall conduct quarterly backup restoration verification, document results in a restoration verification record, and retain the four (4) most recent records with the Continuity Plan.
  - Shall escalate backup failures or integrity verification failures to the Assistant IT Director within one (1) business day of identification.
  - Shall participate in annual tabletop exercises.
- **Network Administrator:**
  - Shall maintain awareness of network infrastructure dependencies documented in the BIA.
  - Shall participate in annual tabletop exercises.
  - Shall support recovery operations as directed by the Incident Commander upon plan activation.
- **Administrative Assistant:**
  - Shall coordinate tabletop exercise logistics, including scheduling, invitations, attendance tracking, and room booking.
- **All Information Operations Personnel:**
  - Shall execute assigned recovery tasks as directed by the Incident Commander upon plan activation.
  - Shall participate in annual tabletop exercises as designated by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in continuity planning, backup governance, or recovery operations.

- **Assessment**: Compliance with BIA maintenance, continuity plan currency, backup governance obligations, and testing cadence shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain the BIA, produce or maintain the Continuity Plan, execute required backups, conduct required testing, or document required activation and handback decisions without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing and processed through the exception management framework established in **Policy 5.01**. No exception shall be granted on an open-ended basis. Each approved exception shall specify its duration, business justification, and any compensating controls in effect during the exception period. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Retention and Disposition of Records of Local Governmental Entities)
- NIST CSF 2.0: ID.RA-04 (Risk Impacts)
- NIST CSF 2.0: PR.DS-11 (Backups of Data)
- NIST CSF 2.0: RC.CO-03 (Recovery Communications)

- NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution)
- NIST CSF 2.0: RC.RP-02 (Recovery Actions Selection and Execution)
- NIST CSF 2.0: RC.RP-03 (Backup and Restoration Asset Integrity)
- NIST CSF 2.0: RC.RP-04 (Post-Incident Operational Norms)
- NIST CSF 2.0: RC.RP-05 (Restoration Verification)
- NIST CSF 2.0: RC.RP-06 (Recovery Closure and Documentation)
- NIST SP 800-53 Rev. 5: CP-1 (Contingency Planning Policy and Procedures)
- NIST SP 800-53 Rev. 5: CP-2 (Contingency Plan)
- NIST SP 800-53 Rev. 5: CP-4 (Contingency Plan Testing)
- NIST SP 800-53 Rev. 5: CP-9 (System Backup)
- NIST SP 800-53 Rev. 5: CP-9(8) (Cryptographic Protection)
- NIST SP 800-53 Rev. 5: CP-10 (System Recovery and Reconstitution)
- COBIT 2019: DSS04 (Manage Continuity)
- ITIL v4: IT Service Continuity Management Practice

6. Policy Statement

6.1 Purpose and Governing Principle

The Department shall maintain a documented, tested, and IT Director-approved Continuity Plan that enables the restoration of IT services following any disruption affecting systems within the scope of this policy. Recovery planning under this policy governs failure scenarios; Service Level Agreement targets for normal operations are governed by **Policy 3.01** (Service Catalog and SLA Policy). The two (2) frameworks are complementary and distinct — neither supersedes the other.

6.2 Business Impact Analysis

The Business Impact Analysis (BIA) is a formal planning artifact owned by the Assistant IT Director and approved by the IT Director. The BIA is distinct from the Risk Register governed by **Policy 1.09** (Risk Management Policy). The Risk Register produces risk scores; the BIA produces recovery planning outputs. **Policy 1.09**'s Criticality Analysis informs BIA inputs; the BIA produces the criticality classifications, RTOs, RPOs, backup minimums, and recovery sequence priority order that continuity execution depends upon.

The BIA shall document, at minimum: a criticality classification assignment for each in-scope system and service using the taxonomy defined in Section 6.4; the approved RTO for each criticality classification; the approved RPO for each criticality classification; the minimum backup frequency, retention period, and offsite storage requirement for each criticality classification; and the recovery sequence priority order across all in-scope systems.

The BIA shall be reviewed and updated no less than annually and following any Significant or Emergency change as defined in **Policy 3.09** (Change Management Policy) that materially alters the service catalog or infrastructure. The IT Director shall approve each updated version before it takes effect.

6.3 Continuity Plan

The Continuity Plan is a governed document maintained in the System of Engagement by the Assistant IT Director. The Assistant IT Director shall protect the Continuity Plan from unauthorized disclosure and modification. The Continuity Plan shall contain, at minimum:

- **Criticality Classification Register**: All in-scope systems and services assigned to one (1) of the classifications defined in Section 6.4, with BIA-derived RTO, RPO, and backup minimums for each classification documented alongside.
- **Recovery Sequence Priority Order**: The order in which systems are restored by classification. Where multiple systems exist within the same wave, the priority order within that wave shall be explicitly documented. Security Infrastructure sequencing shall follow the three (3)-state rule defined in Section 6.4.
- **Backup Procedures Reference**: A pointer to the Knowledge Base procedures under **Policy 3.13** governing the operational execution of backups to achieve the BIA-approved schedules, retention cadences, and offsite storage requirements.
- **Activation Criteria and Authority**: A summary of the two (2)-pathway activation model defined below and the documented authority for each pathway.
- **Operational Handback Protocol**: The receiving mechanics upon Operational Handback from Chapter 4, including documentation requirements and a cross-reference to **Policy 4.05** (Recovery Operations and Restoration Prioritization) for handback initiation mechanics.
- **Recovery Procedures Reference**: Pointers to system-specific recovery procedures maintained in the Knowledge Base under **Policy 3.13**.
- **Testing Records**: The most recent annual tabletop exercise record and the four (4) most recent quarterly backup restoration verification records.

Continuity plan activation may occur through either of two (2) pathways. Both pathways require the activation decision to be documented in the incident work order at the time it is made.

Objective Trigger: When the projected or elapsed restoration time for a disrupted system exceeds the RTO established for that system's criticality classification in the BIA, the Incident Commander shall declare continuity plan activation and initiate recovery procedures under this policy.

Incident Commander Judgment Pathway: The Incident Commander may declare continuity plan activation at any time, independent of whether the objective RTO threshold has been crossed, based on a documented professional assessment of operational conditions — for example, where the nature of the failure, resource availability, or cascading impact makes continued repair inadvisable before the RTO is breached. Qualitative assessments without supporting observations do not satisfy this requirement. The basis for the judgment shall be documented in the incident work order at the time of activation.

6.4 Asset Criticality Classification

The Department operates three (3) operational tiers and one (1) cross-cutting security classification for continuity and backup governance purposes. Specific RTO, RPO, and backup minimums for each classification are established in the BIA and approved by the IT Director.

- **Tier 1 — Mission Critical**: Systems whose failure immediately impairs the Department's ability to deliver mandated services or maintain operations across the County.
- **Tier 2 — Operationally Important**: Systems that support individual department functions. Their failure degrades service for specific departments but does not immediately impair County-wide operations.
- **Tier 3 — Administrative / Deferrable**: Systems that provide operational convenience or supplementary capability. County operations continue normally without these systems.
- **Security Infrastructure**: Systems that support the Department's security monitoring, logging, and vulnerability management functions. Recovery priority is driven by security posture rather than operational impact; sequencing follows the three (3)-state rule below.

Recovery sequencing for Security Infrastructure is determined by the Incident Commander's declared event classification, documented in the incident work order:

- **Known non-security disruption:** Hardware failure, utility outage, natural disaster, or other event with no security nexus, as declared by the Incident Commander. Security Infrastructure recovers at Tier 2 priority, in the second wave alongside Tier 2 operational systems.
- **Known or suspected security event:** Operational Handback received from Chapter 4, or security nexus not yet ruled out. Security Infrastructure recovers concurrently with Tier 1. Log visibility shall be confirmed before broader restoration proceeds, to ensure no residual threat is present before systems are returned to the environment.
- **Unknown or unclassified disruption:** Treated as a suspected security event until the Incident Commander explicitly declares otherwise. Security Infrastructure recovers concurrently with Tier 1 by default. This principle is consistent with **Policy 3.06**, under which uncertainty is resolved in favor of caution.

6.5 Testing

The Assistant IT Director shall coordinate an annual tabletop exercise covering the full Continuity Plan. The exercise shall produce a written record documenting participants, scenarios tested, and findings, which the IT Director shall receive. Findings warranting tracked improvement shall be routed to **Policy 3.16** (Service Improvement and Continual Improvement Plan) for SIR intake under that policy's Section 6.2.

Information Operations personnel designated for contingency roles shall receive contingency training within thirty (30) days of assuming those responsibilities and following any IT Director-approved revision to the Continuity Plan or the BIA that alters recovery procedures, criticality classifications, or role assignments. Annual participation in the tabletop exercise satisfies the recurring training obligation; no additional training artifact is required. Training records generated under this section shall be maintained in accordance with **Policy 2.03** (Security Awareness and Training Policy).

The Systems Administrator shall conduct quarterly backup restoration verification by restoring from backup to a non-production environment and confirming data integrity. Results shall be documented in a restoration verification record. Backup failures or integrity verification failures shall be escalated to the Assistant IT Director within one (1) business day of identification. Specific test procedures are maintained in the Knowledge Base under **Policy 3.13**.

The most recent annual tabletop exercise record and the four (4) most recent quarterly backup restoration verification records shall be retained with the Continuity Plan. Retention periods shall comply with the applicable Nevada Local Government Records Retention Schedule series; where the retention schedule requires a longer period than the minimums stated in this section, the retention schedule governs. Exceptions to the testing cadence require written IT Director approval and shall be documented in the Continuity Plan.

6.6 Backup Governance

All in-scope systems shall have backups maintained in accordance with the parameters established in this section. The BIA shall define minimum backup frequency, retention period, and offsite storage requirements by asset classification, subject to IT Director approval. Operational procedures to execute, verify, and store backups in compliance with the BIA-approved parameters shall be maintained in the Knowledge Base under **Policy 3.13**. All backups shall be encrypted at rest and in transit regardless of the classification of the system being backed up.

6.7 Operational Handback

Operational Handback is the mechanism by which operational recovery authority passes from Chapter 4 back to this policy following a cybersecurity incident. **Policy 4.05** governs Operational Handback initiation — the conditions under which the Incident Commander declares the Chapter 4 security response phase

complete, the declaration procedure, and the documentation requirements on the Chapter 4 side. This policy governs the receiving obligations that attach upon Operational Handback.

Chapter 4 authority holds until the Incident Commander explicitly declares Operational Handback. Ambiguity or assumption of handback is not permitted. Upon Operational Handback, the BIA-driven recovery priority order established in this policy governs operational restoration sequencing, subject to the Security Infrastructure sequencing rules in Section 6.4.

For hybrid events where a cybersecurity incident has also caused infrastructure failure, Chapter 4 holds full authority through the security response phase. This policy receives authority for operational restoration only after explicit Operational Handback is declared. The Incident Commander's declaration shall be documented in the incident work order at the time it is made. Upon receiving Operational Handback, the Assistant IT Director shall confirm that the Continuity Plan's Operational Handback Protocol section has been consulted and that recovery sequencing is proceeding in accordance with the BIA priority order.

6.8 Relationship to Change Management

Infrastructure changes identified during continuity planning or recovery operations require change authorization under **Policy 3.09**. This policy does not modify or supersede change authorization requirements.

6.9 Relationship to Capacity and Availability Management

Policy 3.11 (Capacity and Availability Management Policy) governs steady-state capacity and availability management and explicitly designates failure-scenario recovery planning as the domain of this policy. The two (2) policies are complementary; findings from capacity or availability trend analysis conducted under **Policy 3.11** may inform BIA inputs.

6.10 Relationship to Monitoring and Event Management

Policy 3.12 (Monitoring and Event Management Policy) governs real-time monitoring, alerting, and event detection and explicitly states that service continuity and recovery are governed by this policy. Events escalated under **Policy 3.12** that result in continuity plan activation are subject to the activation mechanics defined in Section 6.3.

3.16 Service Improvement and Continual Improvement Plan

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy governs the identification, logging, triage, and routing of IT service improvement opportunities for the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel involved in the identification, logging, triage, routing, or governance tracking of service improvement initiatives.

- **In Scope**:
  - Service Improvement Register maintenance.
  - Service Improvement Plan preparation.
  - Intake from mandatory trigger sources.
  - Triage decisions and execution routing.
  - Annual improvement summary production.
- **Out of Scope**:
  - Work order lifecycle management: **Policy 3.05**.
  - Operational incident response: **Policy 3.06**.
  - Root cause analysis and Problem investigation: **Policy 3.07**.
  - Technical execution of changes required to implement improvements: **Policy 3.09**.
  - Project execution lifecycle: **Policy 3.14**.
  - Service continuity planning: **Policy 3.15**.
  - Annual governance and framework maturity scoring: **Policy 5.07**.
  - SLA target definition: **Policy 3.01**.
  - KPI taxonomy and baseline definition: **Policy 5.04**.
  - Performance data collection and SLA adherence measurement: **Policy 3.02**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for all Service Improvement Plans.
  - Shall approve Service Improvement Plans as charter approval under **Policy 3.14** (IT Project Management Policy).
  - Shall authorize cancellation of any Service Improvement Register entry that cannot be resolved through normal progression, with cancellation rationale documented in the register entry.
  - Shall receive the annual improvement summary as part of the **Policy 5.07** (Annual Policy Review and Maturity Scoring) review cycle.

- **Assistant IT Director:**
  - Shall own and maintain the Service Improvement Register in the System of Engagement.
  - Shall log a Service Improvement Register entry upon identification of any mandatory intake trigger defined in Section 6.2.
  - Shall complete the triage decision for each Service Improvement Register entry and route it to the appropriate execution path in accordance with Section 6.3.
  - Shall prepare Service Improvement Plans for IT Director approval for all entries meeting the project route threshold defined in Section 6.3.
  - Shall record the linked work order or project record number in each Service Improvement Register entry at the time of routing.
  - Shall confirm closure of each Service Improvement Register entry when its linked work order or project record closes, within two (2) business days of that closure.
  - Shall produce the annual improvement summary for submission to the IT Director in accordance with the **Policy 5.07** review cycle.
- **All Information Operations Personnel:**
  - Shall surface operational observations, service delivery concerns, and process improvement candidates to the Assistant IT Director or IT Director through the channels established in **Policy 3.04** (Service Delivery Feedback and Grievance Policy).
  - Shall execute improvement tasks as assigned through the standard work order system.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations Department personnel.

- **Assessment**: Compliance with Service Improvement Register maintenance, triage obligations, and annual summary production shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to log required Service Improvement Register entries, complete required triage decisions, or produce the annual improvement summary without documented justification shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with the exception management framework defined in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy

- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.11: Capacity and Availability Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071558 (Activity Reports)

Framework Alignment:

- NIST CSF 2.0: ID.IM-01 (Improvements are identified from evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements are identified from execution of operational processes, procedures, and activities)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-6 (Information Security Measures of Performance)
- COBIT 2019: APO11 (Manage Quality)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Service Level Management Practice

6. Policy Statement

This policy governs the intake funnel and the triage decision for service improvement initiatives. Once a triage decision is made and the improvement is routed, execution is governed entirely by the receiving policy. Work order lifecycle, escalation, and closure are governed by **Policy 3.05** (Service Request Fulfillment Policy). Project execution is governed by **Policy 3.14**. Change authorization is governed by **Policy 3.09** (Change Management Policy). This policy defines the Service Improvement Register as the authoritative record of improvement intake and triage activity, and the Service Improvement Plan as the initiation document for improvement initiatives that qualify for formal project designation under **Policy 3.14**.

6.1 Service Improvement Register

The Service Improvement Register (SIR) is the authoritative record of the Department's improvement intake and triage activity. The Assistant IT Director shall maintain the SIR in the System of Engagement. Each SIR entry shall record, at minimum: the improvement identified, the intake source, the date logged, the triage decision, the linked work order or project record number, and closure confirmation.

The SIR is a log. Once a SIR entry is routed and a work order or project record is linked, execution is governed entirely by the receiving policy. SIR entries shall remain linked to an active work order or project record from the time of routing through closure. Where a linked work order or project is cancelled, the Assistant IT Director shall formally close the SIR entry with a cancellation notation and IT Director authorization documented in the entry.

SIR records shall be retained for a minimum of two (2) calendar years from the end of the calendar year in which the entry was created, in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule: LRDA 20071558 (Activity Reports).

6.2 Mandatory Intake Triggers

The Assistant IT Director shall log a SIR entry upon identification of any of the following:

- An SLA deviation routed to the Service Improvement Register by the Assistant IT Director under **Policy 3.02** (Service Level Management and Metrics Reporting).
- A KPI underperformance pattern identified under **Policy 5.04** (Performance Metrics and Operational KPIs).
- Closure of a Problem record under **Policy 3.07** (Problem Management Policy) where the permanent remediation identifies a systemic improvement opportunity beyond the immediate fix.
- A capacity or availability remediation plan produced under **Policy 3.11** (Capacity and Availability Management Policy) that does not immediately require a change record under **Policy 3.09**.
- A threshold breach pattern identified under **Policy 3.12** (Monitoring and Event Management Policy) that does not resolve through a single work order.
- Findings from the annual tabletop exercise conducted under **Policy 3.15** (Service Continuity and Contingency Planning Policy).
- Upward staff feedback surfaced through **Policy 3.04** that the Assistant IT Director or IT Director determines warrants a tracked improvement.
- IT Director or Assistant IT Director discretionary entry — any operational observation that warrants tracked improvement, regardless of source.

6.3 Triage and Execution Routing

The Assistant IT Director shall triage every SIR entry. The triage decision determines execution routing.

Work order route: The Assistant IT Director shall route improvements that fall below the project designation threshold defined in **Policy 3.14**, to the standard work order system. The Assistant IT Director shall create a work order under **Policy 3.05**. The Assistant IT Director shall record the work order number in the SIR entry. All work order lifecycle, escalation, and closure obligations are governed by **Policy 3.05**.

Project route: The Assistant IT Director shall route improvements that meet the project designation threshold defined in **Policy 3.14**, to formal project management. The Assistant IT Director shall prepare a Service Improvement Plan and present it to the IT Director for approval. IT Director approval of the Service Improvement Plan constitutes charter approval under **Policy 3.14**, and the Assistant IT Director shall create the master work order in the System of Engagement upon that approval. The Assistant IT Director shall record the project record number in the SIR entry. All project execution obligations are governed by **Policy 3.14**.

The Assistant IT Director or IT Director may designate any improvement as a formal project regardless of whether it meets the threshold criteria, consistent with the discretionary designation authority established in **Policy 3.14**.

Any improvement initiative requiring alteration of a configuration item, software deployment, or infrastructure change shall generate a Request for Change governed by **Policy 3.09**, regardless of whether the improvement routes through the work order or project path. This policy authorizes the business objective; **Policy 3.09** governs the technical risk of implementation.

6.4 Service Improvement Plan

A Service Improvement Plan (SIP) is required for any SIR entry routed through the project path. The SIP serves as the project initiation document submitted to the IT Director for charter approval under **Policy 3.14**. The SIP obligation arises only when the project route threshold is met or a discretionary project designation is made under Section 6.3. The SIP shall include, at minimum, the content elements required for a project charter under **Policy 3.14**.

6.5 SIR Entry Closure

A SIR entry closes when its linked work order or project record closes, or when the IT Director authorizes cancellation. The Assistant IT Director shall confirm closure of the SIR entry within two (2) business days of the closure event or the IT Director's cancellation authorization.

6.6 Annual Improvement Summary

The Assistant IT Director shall produce an annual improvement summary documenting: volume of SIR entries logged, entries routed to work orders, entries routed to projects, entries closed, and entries cancelled. The Assistant IT Director shall submit the summary to the IT Director as part of the **Policy 5.07** annual policy review and maturity scoring cycle. The summary is the evidentiary record that the improvement intake function is operating.

Annual improvement summaries shall be retained permanently in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule: LRDA 20071558 (Activity Reports).

3.17 System Maintenance and Vendor Repairs

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy establishes the requirements for authorized, documented, supervised, and verified maintenance and repair work performed on County IT systems.

2. Scope

This policy applies to all maintenance and repair work performed on County IT systems, including work performed by Information Operations Personnel, contractors, and vendors.

- **In Scope**:
  - Scheduled preventive maintenance.
  - Reactive repairs and component replacements.
  - Warranty service calls.
  - Remote diagnostic and repair sessions.
  - On-site and off-site maintenance activity.
  - All asset support classifications — IT-Managed, IT-Supported, and Vendor-Managed — with differentiated obligations for each classification as defined in **Policy 1.12**.
- **Out of Scope**:
  - Vendor relationship management, contracting, and access provisioning: **Policy 1.13**.
  - Ongoing vendor compliance and third-party assurance: **Policy 5.06**.
  - Change authorization for maintenance-driven configuration changes: **Policy 3.09**.
  - Work order lifecycle management: **Policy 3.05**.
  - CI record updates following maintenance activity: **Policy 3.08**.
  - Media sanitization execution standards: **Policy 2.12**.
  - Physical access control and escort requirements: **Policy 2.13**.
  - Remote session logging and audit trail obligations: **Policy 2.11**.
  - Service continuity and recovery planning: **Policy 3.15**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the approving authority for vendor or contractor technical work performed on IT-Managed assets.
  - Shall authorize the off-site removal of any County IT system component for maintenance, repair, or replacement.

  - Shall approve the authorized maintenance personnel list — identifying both individuals and organizations authorized to perform maintenance — and the authorized maintenance tool list maintained in the Knowledge Base under **Policy 3.13** (Knowledge Management Policy).
- **Assistant IT Director:**
  - Shall serve as the primary operational owner of the maintenance and repair function.
  - Shall authorize vendor involvement in IT-Supported asset maintenance within contracted support scope.
  - Shall ensure that all maintenance activity is documented in the work order system with the required content defined in Section 6.5.
  - Shall ensure that post-maintenance verification is completed and documented before maintenance work orders are closed.
  - Shall ensure that the authorized maintenance personnel list and the authorized maintenance tool list in the Knowledge Base under **Policy 3.13** are current.
  - Shall directly observe, or designate Information Operations Personnel to directly observe, all remote maintenance sessions for the duration of the session.
- **All Information Operations Personnel:**
  - Shall ensure that no maintenance work begins on IT-Managed assets without the required authorization documented in a work order.
  - Shall escort vendor and contractor personnel during on-site maintenance activity on IT-Managed assets in accordance with **Policy 2.13** (Physical Security and Environmental Controls Policy).
  - Shall inspect maintenance tools against the approved list in the Knowledge Base under **Policy 3.13** before allowing use on County systems.
  - Shall conduct post-maintenance verification in accordance with Knowledge Base procedures under **Policy 3.13** and document results in the work order.
  - Shall directly observe remote maintenance sessions when designated by the Assistant IT Director.
  - Shall verify that remote maintenance sessions and all associated network connections are fully terminated upon completion of maintenance activity and shall document termination verification in the work order.
- **Network Administrator:**
  - Shall ensure that remote maintenance sessions are conducted exclusively through County-approved secure remote access mechanisms in accordance with **Policy 1.13** (Supply Chain Risk Management and Vendor Governance).
- **Systems Administrator:**
  - Shall ensure that remote maintenance sessions are conducted exclusively through County-approved secure remote access mechanisms in accordance with **Policy 1.13**.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Personnel and for all contractors and vendors performing maintenance or repair work on County IT systems.

- **Assessment**: Compliance with this policy shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).

- **Enforcement**: Failure to obtain required authorizations before maintenance commences, failure to document maintenance activity in a work order with the required content, or failure to complete post-maintenance verification before closing a work order shall be treated as non-compliance and may result in corrective action under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be requested and processed in accordance with the exception framework defined in **Policy 5.01**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 2.12: Media Protection and Sanitization Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.155 (Disposal of Local Government Records)
- LRDA 20071715 (Work Orders)

Framework Alignment:

- CJIS Security Policy v6.0: Section MA-2 (Controlled Maintenance)
- CJIS Security Policy v6.0: Section MA-3 (Maintenance Tools)
- CJIS Security Policy v6.0: Section MA-4 (Nonlocal Maintenance)
- CJIS Security Policy v6.0: Section MA-5 (Maintenance Personnel)
- CJIS Security Policy v6.0: Section MA-6 (Timely Maintenance)
- NIST CSF 2.0: PR.PS-02 (Software Maintenance)
- NIST CSF 2.0: PR.PS-03 (Hardware Maintenance)
- NIST SP 800-53 Rev. 5: MA-2 (Controlled Maintenance)

- NIST SP 800-53 Rev. 5: MA-3 (Maintenance Tools)
- NIST SP 800-53 Rev. 5: MA-4 (Nonlocal Maintenance)
- NIST SP 800-53 Rev. 5: MA-5 (Maintenance Personnel)
- NIST SP 800-53 Rev. 5: MA-6 (Timely Maintenance)
- COBIT 2019: DSS01 (Manage Operations)
- ITIL v4: IT Asset Management Practice

6. Policy Statement

6.1 Authorization Requirements

Authorization requirements for maintenance and repair activity are differentiated by asset support classification as defined in **Policy 1.12** (IT Asset Management Policy).

- **IT-Managed Assets**:
  - The IT Director shall authorize all vendor, contractor, or non-Information Operations personnel to perform technical work on an IT-Managed asset in writing before work begins.
  - Information Operations Personnel initiating maintenance on IT-Managed assets shall obtain authorization in accordance with the IT-initiated work order requirements of **Policy 3.05** (Service Request Fulfillment Policy),: routine maintenance tasks may be authorized by the assigned technician in accordance with their defined role authority under **Policy 1.08** (Delegation of Authority and Decision Rights); non-routine maintenance tasks or maintenance tasks requiring configuration changes shall be authorized by the Assistant IT Director or IT Director prior to work commencement.
  - When maintenance activity is performed on systems that process, store, or transmit CJI, the designated escort shall be fully cleared and technically qualified to supervise the specific maintenance activity being performed.
  - The Information Operations Personnel assigned to the work order shall verify the identity of vendor or contractor personnel against the authorized maintenance personnel list before granting access to County systems or facilities for maintenance purposes.
- **IT-Supported Assets**:
  - Vendor involvement in maintenance on an IT-Supported asset that falls within the contracted support scope shall be authorized by the Assistant IT Director.
  - Vendor involvement outside the contracted support scope shall require IT Director authorization.
- **Vendor-Managed Assets**:
  - Vendor personnel performing maintenance within their exclusive support domain do not require Information Operations authorization.
  - The Information Operations Department's obligations for Vendor-Managed maintenance events are limited to access facilitation in accordance with **Policy 1.13**, physical escort in accordance with **Policy 2.13**, and work order documentation of coordination activity in accordance with **Policy 1.12**.

All maintenance activity shall be documented in a work order prior to commencement, except as provided under the emergency exception defined in **Policy 3.05**. The authorizing official and the basis for authorization shall be recorded in the work order before work begins.

6.2 Remote Maintenance Session Controls

All remote maintenance sessions involving vendor, contractor, or other third-party personnel on County IT systems shall be directly observed by the Information Operations Personnel assigned to the work order for the duration of the session. No vendor, contractor, or third-party personnel shall initiate or conduct unmonitored remote access — including desktop sharing, screen sharing, or any remote control session — regardless of asset classification.

Exclusion: Internal administrative remote access performed by authorized Information Operations Personnel using County-approved management protocols (e.g., SSH, RDP, remote management consoles) is not subject to the direct observation requirement. Internal administrative access remains subject to the audit logging obligations governed by **Policy 2.11**.

Remote maintenance sessions shall be conducted exclusively through County-approved secure remote access mechanisms in accordance with **Policy 1.13**. Remote session logging and audit trail obligations are governed by **Policy 2.11** (Audit Logging and Monitoring Policy).

Upon completion of remote maintenance, the Information Operations Personnel observing the session shall verify that the session and all associated network connections have been fully terminated before the maintenance work order is closed. The assigned personnel shall document termination verification in the work order.

6.3 Maintenance Tool Controls

Any maintenance tool — hardware, software, or firmware — brought onto County premises or connected remotely for maintenance purposes shall appear on the approved maintenance tool list maintained in the Knowledge Base under **Policy 3.13**. The Information Operations Personnel assigned to the work order shall not permit any maintenance tool to be used on County systems unless it appears on that list.

The Information Operations Personnel assigned to the work order shall inspect media containing diagnostic or test programs for malicious code before use on any County system. Maintenance tools brought by vendors or contractors shall be subject to the same inspection requirement. Tool inspection procedures are maintained in the Knowledge Base under **Policy 3.13**.

Prior to the removal of any vendor-supplied or contractor-supplied maintenance tool or diagnostic equipment from County facilities, the Information Operations Personnel assigned to the work order shall verify that the equipment contains no County data, or shall ensure the equipment is sanitized before departure.

The IT Director shall approve the authorized maintenance tool list. The Assistant IT Director shall ensure the list is current and shall review the list no less than annually and upon any material change in vendor tooling, support model, or threat conditions.

6.4 Post-Maintenance Verification

Upon completion of any maintenance or repair activity on an IT-Managed or IT-Supported asset, the Information Operations Personnel assigned to the work order shall verify that the system and all potentially affected controls are functioning correctly before the maintenance work order is closed. Post-maintenance verification procedures are maintained in the Knowledge Base under **Policy 3.13**.

The assigned personnel shall document verification results in the work order. A work order shall not be closed in the absence of a documented post-maintenance verification result.

6.5 Maintenance Record Content Standard

Maintenance records are work orders governed by **Policy 3.05**. Each work order documenting a maintenance event shall contain, at minimum, the following content:

- The name and serial number of the component serviced.
- The date and time of maintenance.

- A description of the maintenance performed.
- The name of the personnel performing the maintenance.
- The name of the Information Operations escort, where escort was required.
- The post-maintenance verification result.

This content standard supplements the work order documentation requirements established in **Policy 3.05** and work order operational standards maintained in the System of Engagement. Where this standard imposes additional requirements beyond those established in **Policy 3.05**, this standard governs.

6.6 Off-Site Component Removal

No County IT system component shall be removed from County facilities for off-site maintenance, repair, or replacement without explicit written IT Director authorization. The authorization shall be documented in the work order prior to removal.

Prior to removal, the Information Operations Personnel assigned to the work order shall sanitize the component in accordance with **Policy 2.12** (Media Protection and Sanitization Policy) to remove County data from all associated media. If the component cannot be sanitized prior to removal due to a documented technical constraint, the IT Director shall authorize an alternative control, which the assigned personnel shall document in the work order in lieu of the sanitization confirmation.

The work order shall record the authorization, the sanitization confirmation or the authorized alternative control, and the chain of custody for the removed component from departure through return or disposal.

6.7 Maintenance Support Availability for CJI-Processing Systems

The IT Director shall ensure that maintenance support and spare parts for system components that process, store, or transmit Criminal Justice Information (CJI) are obtainable within the recovery time objective (RTO) and recovery point objective (RPO) defined for those systems in **Policy 3.15** (Service Continuity and Contingency Planning Policy). This requirement ties maintenance support availability to the existing continuity planning framework established in **Policy 3.15** and does not create independent planning obligations.

6.8 Retention

Work orders documenting maintenance and repair activity under this policy are work orders governed by **Policy 3.05** and shall be retained in accordance with LRDA 20071715 (Work Orders) under NRS 239.125 and NAC 239.155. Where multiple retention requirements apply to a single record, the longest applicable retention period shall govern. Retention, disposition, and destruction shall be suspended during any litigation hold, audit hold, public records preservation requirement, or other legal hold event.

4. Incident Response

4.01 Incident Response Policy Overview

Effective: April 29, 2026 Version: 2.1

1. Purpose

This policy establishes the authority, structure, and program framework governing the Elko County Information Operations Department's cybersecurity incident response capability.

2. Scope

This policy governs the establishment, authority, structure, and program framework of the ECIO cybersecurity incident response capability. It applies to all IT systems, services, and infrastructure operated or managed by the Information Operations Department, and to all Information Operations personnel.

- **In Scope**:
  - Formal declaration of cybersecurity incidents.
  - Exercise of Incident Commander authority during cybersecurity incidents.
  - The IR lifecycle framework used to organize response activity.
  - Mandatory external reporting obligations acknowledged at the program level.
  - The operational policy roadmap established in Section 6.2.
- **Out of Scope**:
  - Physical security and environmental controls: **Policy 2.13**.
  - Service level commitments and five-tier operational severity classification: **Policy 3.01**.
  - Operational incident response for non-security service disruptions: **Policy 3.06**.
  - Indicator of Compromise definition and incident identification procedures: **Policy 4.02**.
  - Containment strategy selection and playbook execution: **Policy 4.03**.
  - Eradication procedures and scenario-specific guidance: **Policy 4.04**.
  - Recovery operations, restoration prioritization, and data and system classification for recovery: **Policy 4.05**.
  - Incident communication, external partner integration, and IR contact directory governance: **Policy 4.06**.
  - Postmortem review and lessons learned procedures: **Policy 4.07**.
  - Business continuity, RTO/RPO definitions, and contingency planning: **Policy 3.15**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in Section 6.1 of this policy.
  - Shall hold primary authority to declare a cybersecurity incident, subject to the delegation provisions established in Section 6.1 of this policy.

  - Shall exercise final authority over all incident response activity as Incident Commander for the duration of the incident.
  - Shall serve as the sole authoritative source for strategic and public-facing incident communications under the One Voice Rule established in **Policy 4.06**.
  - Shall execute all incident reporting obligations mandated by the CJIS Security Policy in the capacity of the Local Agency Security Officer (LASO).
  - Shall authorize emergency procurement necessary to maintain or restore mandated security controls, using County emergency procedures with after-the-fact ratification, consistent with **Policy 1.08**.
  - Shall authorize formal exceptions to the obligations established in this policy in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall serve as Incident Commander in the IT Director's absence or by IT Director designation.
  - Shall serve as the primary operational coordinator for incident response activities under Incident Commander direction.
  - Shall ensure the IR Roles and Contact Directory maintained under **Policy 4.06** (Communication Protocols and Partner Integration) is current.
  - Shall verify that all Information Operations personnel complete the IR familiarization requirements defined in **Policy 2.03** (Security Awareness and Training Policy) and are current on the IR lifecycle framework established in this policy.
- **Systems Administrator:**
  - Shall provide technical IR support as directed by the Incident Commander.
  - Shall execute containment, eradication, and recovery technical actions under Incident Commander authority in accordance with **Policy 4.03** **Policy 4.04** and **Policy 4.05**
- **Network Administrator:**
  - Shall provide technical IR support as directed by the Incident Commander.
  - Shall execute containment, eradication, and recovery technical actions under Incident Commander authority in accordance with **Policy 4.03** **Policy 4.04** and **Policy 4.05**
- **All Information Operations Personnel:**
  - Shall execute incident response activities as directed by the Incident Commander.
  - Shall initiate the Hard Fork procedure established in **Policy 3.06** (Operational Incident Management Policy), upon discovery of any Indicator of Compromise, without exception.
  - Shall not communicate incident scope, affected systems, attribution, or recovery timelines to external parties, media, or non-IT County personnel without express Incident Commander authorization.
  - Shall maintain familiarity with the IoC list maintained in **Policy 4.02** (Identification and Reporting Procedures) and the chapter roadmap established in Section 6.2 of this policy.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all Information Operations personnel.

- **Assessment**: Compliance with the IR program obligations established in this policy shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy

Review and Maturity Scoring) and the internal audit and self-assessment procedures defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing).

- **Enforcement**: Failure to observe declaration authority requirements, failure to initiate the Hard Fork procedure upon IoC discovery, failure to document Incident Commander designations at the time they are made, or unauthorized external communication of incident information, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**
- **Exceptions**: Exceptions to any requirement of this policy shall be documented with written justification and approved by the IT Director in accordance with the exception framework established in **Policy 5.01 Delegation constraints defined in Policy 1.08** (Delegation of Authority and Decision Rights) apply. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cyber Risk Management

Framework Alignment:

- CJIS Security Policy v6.0: Section IR-1 (Incident Response Policy and Procedures)
- CJIS Security Policy v6.0: Section IR-2 (Incident Response Training)
- CJIS Security Policy v6.0: Section IR-3 (Incident Response Testing)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-8 (Incident Response Plan)
- NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution)
- NIST CSF 2.0: RS.CO-02 (Stakeholder Notification)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-02 (Incident Report Triage and Validation)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST CSF 2.0: RS.MA-04 (Incident Escalation and Elevation)
- NIST SP 800-53 Rev. 5: IR-1 (Incident Response Policy and Procedures)
- NIST SP 800-53 Rev. 5: IR-2 (Incident Response Training)
- NIST SP 800-53 Rev. 5: IR-3 (Incident Response Testing)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- COBIT 2019: DSS04 (Manage Continuity)
- ITIL v4: Incident Management Practice
- ITIL v4: Service Continuity Management Practice

6. Policy Statement

This policy serves two distinct audiences: internal personnel and auditors evaluating it within the full context of the ECIO Policy Manual, and external reviewers — including the Nevada state cyber defense office — who may review it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside elsewhere in the manual, it states the operative substance in plain language. Those statements are incorporative and do not constitute independent definitions; the ECIO Policy Manual's governance framework remains the authoritative source.

Chapter 4 Subordination Principle: Chapter 4 is an explicitly subordinate program framework within the ECIO Policy Manual. No policy in Chapter 4 creates an independent authority structure, modifies role definitions or authorities established elsewhere in the manual, or supersedes any obligation established in Chapters 1 through 3 or Chapter 5. Where Chapter 4 references a role, timeline, classification, or procedure established in another policy, that reference is incorporative — Chapter 4 operates under those established definitions without restating or redefining them. This principle is established here once and governs the entire chapter.

6.1 ECIO Cybersecurity Incident Response Program

Program Establishment: The ECIO shall maintain a formal cybersecurity incident response program to detect, contain, eradicate, and recover from cybersecurity incidents affecting IT systems, services, and infrastructure under the Department's management. The program is established and governed by this policy. It is a subordinate program framework within the ECIO Policy Manual and operates within the governance structure established across Chapters 1 through 3 and Chapter 5. This policy constitutes the Department's formal cybersecurity incident response program statement for submission to the Nevada state cyber defense office.

The ECIO does not maintain a formally designated, standing Incident Response Team. Cybersecurity incident response is executed by Information Operations personnel under Incident Commander authority. The absence of a standing team does not diminish the rigor or authority of the program; it reflects the Department's operating model, in which response authority is vested in defined roles rather than a standing team construct.

Incident Commander: The IT Director shall serve as Incident Commander for all cybersecurity incidents by default. The IT Director may designate any Information Operations Personnel as Incident Commander for a specific incident; designations shall be made at the time they become effective and documented in the incident record. The Incident Commander shall exercise final authority over all incident response activity for the duration of the incident. This title is singular within the ECIO framework — no parallel title exists. The Incident Commander role is established in **Policy 3.06** and incorporated into Chapter 4 by reference without modification.

Declaration Authority: Authority to declare a cybersecurity incident shall reside with the IT Director and the Assistant IT Director. A designated Tier L3+ technical lead may declare a cybersecurity incident only when the IT Director and the Assistant IT Director are both genuinely unavailable and the operational situation requires immediate action. The technical lead(s) authorized to exercise this authority shall be identified in writing by the IT Director in accordance with **Policy 1.08**and reviewed at least annually. Upon declaration, all operational authority shall transfer immediately and exclusively to the Incident Commander. Administrative stand-ins shall not intervene in, delay, or countermand Incident Commander directives. Fiscal Affairs and Purchasing shall process Incident Commander emergency procurement requests without delay.

The declaration authority structure, delegation constraints, and Incident Commander qualification criteria established in this section operate within the delegation framework defined in **Policy 1.08 This section incorporates and applies those provisions to the cybersecurity incident context; it does not establish independent delegation authority.**

Incident Severity Classification: Chapter 4 shall use a three-tier severity classification to categorize cybersecurity incidents. This classification is independent of, and does not interact with, the five-tier operational severity framework (Critical, Urgent, High, Normal, Low) established in **Policy 3.01**for service level management. **Policy 3.01**SLA obligations are suspended for the duration of any active Chapter 4 incident per the Hard Fork mechanics established in **Policy 3.06**.

The three tiers are as follows:

- **High** — Incidents with confirmed or severe impact on operations, Criminal Justice Information (CJI), or public safety systems. Examples include compromise of sensitive or CJI data, widespread malware or ransomware, unauthorized access to critical systems, and denial-of-service attacks affecting enterprise operations.
- **Medium** — Incidents with significant current impact or confirmed potential for severe impact. Examples include small-scale denial-of-service attacks, website compromise, unauthorized access attempts with confirmed breach, and phishing campaigns with confirmed credential capture.
- **Low** — Incidents with minimal current impact but potential for escalation if unaddressed. Examples include network probes or reconnaissance scans, isolated virus infections, acceptable use violations, and unconfirmed anomalies under active investigation.

Severity may be reclassified upward or downward at any point during the response at the Incident Commander's direction. The initial severity classification shall be documented in the incident record at the time of declaration.

IR Lifecycle Framework: The ECIO IR program shall be organized around a six-phase lifecycle: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned. This is ECIO's selected framework, consistent with the incident response lifecycle model recognized in NIST SP 800-61 Rev. 3, which affirms that organizations should use the lifecycle framework that best suits their operating model. Each phase is governed by one or more of the operational policies in Chapter 4, as mapped in Section 6.2 of this policy.

Relationship to Operational Incident Management — Hard Fork: The ECIO distinguishes between two categories of adverse IT events. **Policy 3.06**governs operational incidents — unplanned technical failures whose resolution requires restoring service as quickly as possible. Chapter 4 governs cybersecurity incidents — events involving malicious activity, unauthorized access, data compromise, or any Indicator of Compromise as defined in **Policy 4.02 These two regimes are not interchangeable and one shall not be substituted for the other. A Chapter 4 response may deliberately extend an outage to stop active compromise, preserve forensic evidence, or prevent further damage; speed of restoration is subordinate to containment and forensic integrity.**

When a technician working a **Policy 3.06**operational incident discovers any condition that constitutes an Indicator of Compromise, **Policy 3.06**immediately and automatically subordinates to Chapter 4. This jurisdictional transfer is called the Hard Fork. It is not discretionary and does not require supervisor approval. The canonical IoC list that triggers the Hard Fork is maintained in **Policy 4.02 The mechanics governing the Hard Fork procedure are established in Policy 3.06** and incorporated into this chapter by reference.

CJIS Incident Reporting: The CJIS Security Policy establishes a two-part incident reporting obligation. First, all Information Operations personnel shall report any suspected or confirmed security incident to the Incident Commander immediately, not to exceed one (1) hour after discovery. Second, upon the Incident Commander's confirmation of a reportable incident, the IT Director, acting in the capacity of the Local Agency Security Officer (LASO), shall notify the CJIS Systems Officer (CSO), the State Identification Bureau (SIB) Chief, or the Interface Agency Official as required by CJIS Security Policy Section IR-6. The CJIS Security Policy does not attach a specific timer to this external notification obligation; it is triggered by confirmation, not by the one-hour internal reporting clock. This obligation is acknowledged here at the program level. Its operational execution — including notification mechanics, documentation requirements, and escalation procedures — is governed by **Policy 4.02**and **Policy 4.06**

Breach Notification: Public and stakeholder notification regarding security breaches affecting personal information shall be executed in strict accordance with NRS 603A.220, which requires notification in the most expedient time possible following discovery of a breach. This obligation is acknowledged here at the program level. Its operational execution is governed by **Policy 4.06**

External Partner Relationships: The ECIO maintains active membership in the Multi-State Information Sharing and Analysis Center (MS-ISAC) and the Nevada Information Sharing and Analysis Center (NV-ISAC). These memberships provide access to threat intelligence, incident coordination resources, and analytical support from the broader state and national cybersecurity community. The ECIO also maintains working relationships with the Federal Bureau of Investigation (FBI) and the Nevada Department of Public Safety (DPS) for purposes of incident coordination and law enforcement referral. The operational procedures governing engagement with these and other external partners are established in **Policy 4.06**

Operational Handback: When the security response phase of a cybersecurity incident concludes — that is, when the threat has been contained, eradicated, and the affected environment has been stabilized to a state suitable for operational recovery — the Incident Commander shall issue an explicit Operational Handback declaration. This declaration marks the transfer of recovery authority from Chapter 4 back to the operational continuity framework governed by **Policy 3.15** (Service Continuity and Contingency Planning Policy). Operational Handback shall never be assumed; ambiguity is not permitted. An incident remains under Chapter 4 authority until the Incident Commander explicitly declares otherwise. The full mechanics

governing Operational Handback initiation are established in **Policy 4.05** **Policy 3.15**governs the receiving obligations on the continuity side of the transfer.

Record Retention: Incident records produced under Chapter 4 — including incident work orders, declaration documentation, Incident Commander designation records, evidence preservation logs, communication records, and postmortem reports — shall be retained in accordance with the Nevada Local Government Records Retention Schedule and NRS 239.125. Specific retention obligations for each record type are established in the governing policy for that record type: **Policy 4.02**governs incident reports, **Policy 4.06**governs communication records, and **Policy 4.07**governs postmortem reports.

6.2 Chapter 4 Policy Roadmap

This section provides a navigational overview of the operational policies governing each phase of the ECIO cybersecurity incident response lifecycle. Each policy is summarized below with its lifecycle phase alignment, primary governing subject, and key interfaces with other Chapter 4 policies. This roadmap is provided for the benefit of both Information Operations personnel and external reviewers who may not have access to the full ECIO Policy Manual.

Policy 4.02 — Identification and Reporting Procedures

Lifecycle Phase: Identification

Policy 4.02is the first operational policy activated upon cybersecurity incident declaration. It maintains the canonical list of Indicators of Compromise (IoCs) that govern both the Hard Fork procedure under **Policy 3.06**and the initial identification of cybersecurity incidents under Chapter 4. **Policy 4.02**establishes the intake and triage procedures for newly declared incidents, the documentation requirements for the incident record from the moment of declaration forward, and the CJIS one-hour internal reporting mechanics and notification sequence required under CJIS Security Policy Section IR-6. It also governs incident record retention. **Policy 4.02**feeds directly into **Policy 4.03**(Containment) upon completion of initial identification and triage.

Policy 4.03 — Containment Strategy and Playbooks

Lifecycle Phase: Containment

Policy 4.03governs the selection and execution of containment strategies following incident identification. It establishes the decision framework the Incident Commander uses to select a containment approach — including considerations of operational impact, forensic preservation, and threat scope — and maintains the playbooks for specific incident scenarios that guide technical response personnel through containment execution. **Policy 4.03**operates in direct sequence following **Policy 4.02**and interfaces with **Policy 4.04**(Eradication), as containment decisions affect the scope and sequencing of eradication activity. Technical configuration actions taken under **Policy 4.03**trigger change authorization obligations governed by **Policy 3.09** (Change Management Policy).

Policy 4.04 — Eradication Procedures and Scenario Guides

Lifecycle Phase: Eradication

Policy 4.04governs the removal of threat actors, malicious artifacts, and compromised configurations from the affected environment following containment. It establishes the eradication decision criteria used to confirm that the threat has been fully neutralized before the recovery phase begins, and maintains scenario-specific eradication guides for the incident types most likely to affect ECIO systems. **Policy 4.04**operates in sequence following **Policy 4.03** **It interfaces with Policy 4.05**(Recovery), as the eradication completion determination is the primary criterion for initiating the recovery phase. CI record update obligations triggered by eradication-driven changes are governed by **Policy 3.08** (Service Configuration Management (CMDB) Policy).

Policy 4.05 — Recovery Operations and Restoration Prioritization

Lifecycle Phase: Recovery (operational) and Preparation (classification framework)

Policy 4.05governs two distinct functions under a single policy number. Sections 6.1 through 6.5 and Section 6.7 of that policy govern the operational recovery process — the restoration of IT systems, services, and infrastructure to normal operational status following the completion of eradication. **Policy 4.05**establishes the recovery sequencing framework, the verification criteria required before any system is returned to production status, and the Operational Handback initiation mechanics by which the Incident Commander formally declares the security response phase complete and transfers recovery authority to **Policy 3.15**

Section 6.2 of **Policy 4.05**governs the data and system classification framework for recovery — support infrastructure that is maintained during the Preparation phase and consumed during the Recovery phase. That section maintains a recovery classification register that is a controlled derivative view of the Business Impact Analysis maintained under **Policy 3.15 the BIA is the single authoritative source of truth for classification assignments. Policy 4.05**supplements the BIA with CJI status flags and security dependency mappings specific to the cybersecurity recovery context. **Policy 4.05**interfaces with **Policy 3.15**(continuity receiving mechanics), **Policy 4.04**(eradication-complete determination as recovery precondition), and **Policy 4.06**(recovery communication obligations).

Policy 4.06 — Communication Protocols and Partner Integration

Lifecycle Phase: Support infrastructure — spans all phases

Policy 4.06governs all internal and external communications produced during a cybersecurity incident, the framework for external partner engagement, and the incident response contact directory. It establishes the One Voice Rule — the requirement that all strategic and public-facing communications be authorized by the Incident Commander and issued through a single authoritative channel — and defines the communication cadences, authorized audiences, and approval requirements for each communication type. **Policy 4.06**governs the operational execution of both the CJIS external notification obligation (acknowledged in this policy and initiated in **Policy 4.02and the NRS 603A.220 breach notification obligation. It applies from the moment of incident declaration through the conclusion of post-incident communications following Operational Handback. Policy 4.06**interfaces with every other Chapter 4 policy at the point where that policy triggers a communication obligation.

Policy 4.06also maintains the IR Roles and Contact Directory — the living reference document that identifies current personnel assigned to incident response roles, their contact information, and the escalation sequence to be followed during an active incident. This directory is support infrastructure consumed across all phases of the IR lifecycle. It does not establish role authority or delegation rights; those originate in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework) and **Policy 1.08**and are incorporated by reference. The Incident Commander designation records required under this policy and **Policy 3.06**are maintained separately from the directory in the incident record at the time of designation.

Policy 4.07 — Postmortem Review and Lessons Learned

Lifecycle Phase: Lessons Learned

Policy 4.07governs the postmortem review process conducted following the closure of a cybersecurity incident. It establishes the mandatory postmortem trigger conditions, the postmortem review structure, the timeline for completion, and the documentation requirements for findings and corrective actions. Postmortem findings that identify systemic failures in controls, configurations, or procedures shall be routed to the Risk Register maintained under **Policy 1.09** (Risk Management Policy). **Policy 4.07**is distinct from the Problem Management postmortem process governed by **Policy 3.07** (Problem Management Policy), which applies to operational incidents. Cybersecurity incident postmortems are exclusively governed by **Policy 4.07 Postmortem reports are subject to the retention obligations established in this policy.**

4.02 Identification and Reporting Procedures

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy establishes the identification, intake, triage, classification, notification, and documentation obligations for all cybersecurity incidents within the Elko County Information Operations Department (ECIO).

2. Scope

This policy applies to all Information Operations personnel, contractors, and vendors operating within or interfacing with ECIO systems.

- **In Scope**:
  - Governance and maintenance of the canonical Indicator of Compromise (IoC) list, including its two-layer architecture and amendment procedures.
  - Intake channel normalization for upstream referrals.
  - IoC evaluation, incident declaration, and decline documentation.
  - Incident type and severity classification.
  - CJIS-compliant internal and external reporting mechanics.
  - Incident record structure, mandatory documentation requirements, and the Chapter 4 checklist template.
  - Triage authority, declaration authority, and delegation parameters.
  - Evidence artifact preservation and retention.
  - False positive disposition and indicator review procedures.
- **Out of Scope**:
  - Operational incident response for non-security events: **Policy 3.06**.
  - Hard Fork procedure mechanics: **Policy 3.06**.
  - CI record updates following incident-driven changes: **Policy 3.08**.
  - Catch-up RFC documentation for emergency configuration changes: **Policy 3.09**.
  - Monitoring event classification and work order generation: **Policy 3.12**.
  - Containment strategy selection and execution: **Policy 4.03**.
  - Eradication procedures: **Policy 4.04**.
  - Recovery operations, restoration prioritization, and Operational Handback: **Policy 4.05**.
  - Communication execution, external notification mechanics, IR roles and contact directory, and partner engagement: **Policy 4.06**.
  - Postmortem review and lessons learned: **Policy 4.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as Incident Commander for all cybersecurity incidents by default; the IT Director may designate any Information Operations Personnel member as Incident Commander for a specific incident per **Policy 4.01** (Incident Response Policy Overview). IC designation does not transfer declaration authority, exception approval authority, or incident classification authority.
  - Shall hold primary declaration authority per **Policy 4.01**, and **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall review Safety and Security work orders in the System of Engagement queue and release them to Reviewed status upon declaration, or document the basis for decline in the work order notes.
  - Shall execute CJIS IR-6 Part (b) external notification obligations in the capacity of Local Agency Security Officer (LASO), a designation held by the IT Director under **Policy 1.11** (Data Governance and Classification Policy), within the notification windows established in Section 6.6 of this policy.
  - Shall approve any structural change to Layer 1 IoC categories or definitions.
  - Shall maintain the list of Tier L3+ technical leads authorized to exercise emergency declaration authority when the IT Director and the Assistant IT Director are both genuinely unavailable, per **Policy 1.08** and **Policy 4.01**.
  - Shall authorize formal exceptions to the requirements of this policy per **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall hold declaration authority in the IT Director's absence, per **Policy 4.01**.
  - Shall review Safety and Security work orders and release them to Reviewed status in the IT Director's absence or upon IT Director direction.
  - Shall own and maintain the Layer 2 IoC indicator artifact in the System of Engagement under standing maintenance authority, with IT Director notification upon each update.
  - Shall conduct the thirty (30) day false positive indicator review for each flagged indicator.
  - Shall conduct the quarterly IoC list review.
  - Shall ensure the Chapter 4 checklist template in the Knowledge Base remains current, per **Policy 3.13** (Knowledge Management Policy).
- **Network Administrator:**
  - Shall provide domain-specific technical analysis for network-related incidents as delegated by the Incident Commander.
  - Shall not exercise declaration authority by virtue of delegated analysis responsibility alone; declaration authority remains with the IT Director, the Assistant IT Director, or a Tier L3+ technical lead designated in writing by the IT Director per **Policy 1.08**.
- **Systems Administrator:**
  - Shall provide domain-specific technical analysis for server and endpoint-related incidents as delegated by the Incident Commander.
  - Shall not exercise declaration authority by virtue of delegated analysis responsibility alone; declaration authority remains with the IT Director, the Assistant IT Director, or a Tier L3+ technical lead designated in writing by the IT Director per **Policy 1.08**.

- **All Information Operations Personnel:**
  - Shall create a Safety and Security category work order in the System of Engagement immediately upon discovery of any condition that may constitute an IoC, without exception.
  - Shall create Safety and Security work orders on behalf of external reporters — including vendors, end-users, and members of the public — documenting the reporting party as the source.
  - Shall not perform any response activity on a suspected cybersecurity incident without an associated work order.
  - Shall maintain familiarity with Layer 1 IoC categories and the Layer 2 indicator artifact.
  - Shall treat uncertain conditions as IoCs and initiate intake, consistent with the false-positive-safe principle established in **Policy 3.06** (Operational Incident Management Policy).

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel, contractors, and vendors subject to ECIO governance, in accordance with **Policy 5.01**.

- **Assessment**: Compliance with IoC list governance, intake and triage obligations, classification and documentation requirements, CJIS notification mechanics, and retention obligations shall be assessed through the internal audit and self-assessment procedures defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to create required work orders, failure to perform IoC evaluation before other response activity, failure to document declaration or decline with its basis, failure to execute CJIS notification within the windows established in Section 6.6, or failure to maintain required retention obligations, without documented justification, shall be treated as non-compliance and may result in corrective action under **Policy 5.01**.
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in advance in accordance with the exception framework established in **Policy 5.01**, within the delegation constraints of **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. No exception may suspend or modify the CJIS notification obligations established in Section 6.6, the mandatory work order creation requirement established in Section 6.2, the evidence artifact retention obligations for CJI-involved incidents established in Section 6.7, or the incident record documentation requirements established in Section 6.4. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 2.08: System Integrity and Malware Protection Policy
- ECIO Policy 2.13: Physical Security and Environmental Controls Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.03: Service Communications Policy

- ECIO Policy 3.05: Service Request Fulfillment Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071279 (Property Management: Security Records)
- LRDA 20071728 (IT Access Control Reviews and Audit Trails)
- CJIS Security Policy v6.0: Section AU-11 (Audit Record Retention)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)

Framework Alignment:

- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-8 (Incident Response Plan)
- NIST CSF 2.0: DE.AE-02 (Potentially Adverse Events Analysis)
- NIST CSF 2.0: DE.AE-03 (Multi-Source Information Correlation)
- NIST CSF 2.0: DE.AE-06 (Adverse Event Information Sharing)
- NIST CSF 2.0: DE.AE-08 (Incident Declaration Criteria)
- NIST CSF 2.0: RS.AN-03 (Incident Analysis and Root Cause)
- NIST CSF 2.0: RS.AN-08 (Incident Magnitude Estimation)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-02 (Incident Report Triage and Validation)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST SP 800-53 Rev. 5: AU-11 (Audit Record Retention)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)

- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cyber Risk Management
- COBIT 2019: DSS02 (Manage Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

This policy normalizes seven (7) distinct upstream intake paths into a single, consistent handling framework; maintains the canonical Indicator of Compromise (IoC) list that governs incident declaration throughout the manual; and establishes the CJIS-compliant reporting mechanics and incident record structure required for operational execution and audit accountability. Within the Chapter 4 lifecycle framework established in **Policy 4.01**, this policy governs the Identification phase — the first operational stage following potential incident discovery. This policy is activated immediately upon potential cybersecurity incident discovery and governs all activity through declaration and handoff to the appropriate operational response policies.

6.1 Indicator of Compromise List Architecture

This policy maintains the canonical IoC list that governs cybersecurity incident declaration across the ECIO Policy Manual. The list uses a two-layer architecture separating permanent categorical triggers from current technical indicators.

- **Layer 1 — Categorical Triggers:** Layer 1 consists of six (6) permanent, technology-agnostic categories that constitute an IoC regardless of how they manifest technically. Layer 1 categories reside in this policy text. The IT Director shall not approve changes to Layer 1 categories or definitions unless the fundamental nature of cybersecurity threats changes. The IT Director shall document any change to a Layer 1 category or its definition as a policy amendment.
  - **Category A — Unauthorized Access or Access Anomaly:** Any confirmed or strongly suspected access to systems, data, or accounts by an unauthorized party, or any access by an authorized party outside their defined scope. Includes credential compromise, privilege escalation, lateral movement, and account takeover.
  - **Category B — Malicious Code Activity:** Presence or execution of malware, ransomware, spyware, rootkits, trojans, worms, or any software not authorized under the ECIO software management framework that exhibits destructive, exfiltration, or command-and-control behavior.
  - **Category C — Denial of Service:** Any attack that impairs the availability of County IT systems or services through resource exhaustion, flooding, or disruption, whether targeted at ECIO infrastructure or originating from ECIO infrastructure against external targets.
  - **Category D — Data Compromise or Exfiltration:** Any confirmed or suspected unauthorized access to, disclosure of, modification of, or exfiltration of County data, with particular emphasis on CJI, PII, and systems classified as Tier 1 or Tier 2 under **Policy 4.05** (Recovery Operations and Restoration Prioritization).
  - **Category E — Targeted Reconnaissance:** Systematic probing, scanning, or enumeration of ECIO infrastructure that demonstrates specific targeting of internal systems, knowledge of internal topology or naming conventions not publicly available, or that is combined with any follow-on access attempt, credential probe, or lateral movement indicator. Undifferentiated broad-sweep scanning of external-facing IP space does not constitute an IoC under this category absent one of the preceding qualifying conditions.

  - **Category F — Improper Use with Security Nexus:** Acceptable use violations, insider activity, or policy violations that involve attempted or confirmed unauthorized access to data, systems, or accounts beyond the violator's authorized scope. Routine acceptable use violations without a security nexus remain within the governance of **Policy 3.06**.

- **Layer 2 — Specific Indicators:** Layer 2 consists of current, actionable technical signatures — including file hashes, IP ranges, behavioral patterns, known malware identifiers, and credential stuffing signatures — maintained as a governed artifact in the System of Engagement. Layer 2 reflects the evolving threat landscape and shall be updated as that landscape changes. The Assistant IT Director owns routine Layer 2 maintenance under standing authority. Routine maintenance includes adding new indicators and removing stale ones. The IT Director shall be notified of each update. The Assistant IT Director shall source Layer 2 indicators from recognized threat intelligence sources and internal postmortem findings.
  - **Constraint:** No fixed source list shall be mandated; source selection is at the discretion of the Assistant IT Director.
- **IoC List Review:** The Assistant IT Director shall review the IoC list as a whole no less than quarterly. The quarterly cadence is a floor, not a ceiling.
- **False Positive Disposition:** When a declared incident is determined to be a false positive, the Incident Commander shall flag the triggering indicator in the work order notes at the time of that determination. The indicator shall not be modified at the time of disposition. A standalone thirty (30) day review window shall be initiated at the time of false positive determination. Indicator modification requires a deliberate review cycle conducted within that thirty (30) day window, not an in-the-moment decision at disposition.

6.2 Intake Channel Architecture

- **Mandatory Work Order Requirement:** All Chapter 4 intake shall enter through a Safety and Security category work order in the System of Engagement without exception. All Information Operations Personnel shall not proceed with any cybersecurity incident response activity without an associated work order. This requirement is consistent with the work order discipline established in **Policy 3.05** (Service Request Fulfillment Policy) and **Policy 3.06**. This policy designates the Safety and Security work order category as the mandatory Chapter 4 intake channel, conferring explicit governance authority on that category for all cybersecurity incident intake.
- **Intake States:** All upstream intake paths normalize into one of two (2) functional states at the point of evaluation under this policy. Upstream sources not explicitly mapped below — including referrals from **Policy 1.09** (Risk Management Policy), **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance), **Policy 2.08** (System Integrity and Malware Protection Policy), and **Policy 3.03** (Service Communications Policy) — shall enter through State 2.
  - **State 1 — Work order with existing IoC documentation:** This state applies to Hard Fork referrals from **Policy 3.06** and monitoring handoffs from **Policy 3.12** (Monitoring and Event Management Policy). The work order already exists with the IoC observation documented in the notes, SLA suspension noted, and a forensic timestamp established. This policy receives the work order and proceeds directly to IoC evaluation.
  - **State 2 — Safety and Security intake work order:** This state applies to staff reports, vendor notifications relayed by staff, device loss or theft reports, camera footage referrals from **Policy 2.13** (Physical Security and Environmental Controls Policy), and data spillage events. An Information Operations staff member shall create the Safety and Security work order at the point of intake, documenting the reported condition. IoC evaluation proceeds before any other response activity.
- **Vendor Notification Handling:** ECIO staff receiving a vendor notification of a suspected or confirmed security incident shall create the Safety and Security work order on the vendor's behalf, documenting

the vendor's report as the source. Vendors shall not create work orders directly in the System of Engagement.

- **IoC Evaluation:** The IT Director or the Assistant IT Director shall perform IoC evaluation for every Safety and Security work order before any other response activity proceeds. Evaluation shall be performed against Layer 1 categories and Layer 2 specific indicators. The IT Director or the Assistant IT Director shall document the result — declaration or decline — in the work order at the time of determination. A declined work order shall include the basis for decline.
- **Continuous-Clock Intake:** Any monitoring event under **Policy 3.12** that constitutes a suspected cybersecurity incident shall enter Chapter 4 intake on a continuous calendar-hour clock. The business-hour work order creation windows established in **Policy 3.12** do not apply to events routed to Chapter 4 under this policy. This continuous-clock requirement is consistent with the CJIS IR-6 Part (a) one (1) hour internal reporting obligation, which operates on continuous calendar hours regardless of business-hour status.

6.3 Triage and Declaration Authority

IoC evaluation and declaration authority rests with the IT Director and the Assistant IT Director, consistent with the authority established in **Policy 4.01**, and **Policy 1.08**. The standard System of Engagement triage workflow applies: Safety and Security work orders enter the queue, the IT Director or the Assistant IT Director reviews them, and the reviewing authority releases them to Reviewed status upon declaration.

The IT Director and the Assistant IT Director may delegate incident analysis to domain-appropriate technical leads — the Network Administrator for network-related incidents and the Systems Administrator for server and endpoint-related incidents — to ensure technically qualified personnel execute the analysis. Delegation of analysis responsibility does not transfer declaration authority. Declaration authority remains with the IT Director, the Assistant IT Director, or a Tier L3+ technical lead designated in writing by the IT Director per **Policy 1.08**.

6.4 Incident Record Structure

The incident record for all declared Chapter 4 incidents shall use the existing work order infrastructure within the System of Engagement, supplemented by the mandatory Chapter 4 checklist template.

Work Order Infrastructure: The following existing work order fields constitute the structural foundation of the incident record: Subject, Description, Category (Safety and Security), Assignee, Notes, Files, Related Issues, Watchers, and operational Severity. The IT Director shall not modify these fields for Chapter 4 intake purposes. The system-generated audit trail within the System of Engagement provides the timestamped record for all status changes, field modifications, and note additions. This trail is tamper-evident and constitutes the authoritative chronological record of the incident.

Chapter 4 Checklist Template: The Assistant IT Director shall maintain a Chapter 4 checklist template as a governed Knowledge Base artifact per **Policy 3.13**. This policy mandates the existence of the checklist and the fields it shall contain. **Policy 3.13** governs its maintenance and version control. The IT Director or the Assistant IT Director shall complete the checklist for every declared incident and attach it to the work order. The checklist shall capture, at minimum:

- Chapter 4 jurisdiction flag (a binary notation confirming the work order has entered Chapter 4 governance).
- Declaration authority and the identity of the declaring party.
- Incident Commander designation, including scope and effective time if the Incident Commander is not the IT Director.
- Layer 1 incident type classification (Category A through F; multi-category classification is permissible).
- Chapter 4 severity classification (High, Medium, or Low).

- CJI involvement determination (confirmed, possible, or ruled out with documented basis).
- CJIS notification log, including: the internal one (1) hour clock start; the IT Director notification timestamp; and external notification details to the CSO, SIB Chief, or Interface Agency Official where applicable.
- Evidence preservation log identifying what was preserved, how it was preserved, and by whom.
- False positive disposition notation and thirty (30) day indicator review flag, where applicable.
- Operational Handback declaration, completed at incident conclusion per **Policy 4.05**.

Notes Field — Operational Narrative: The work order Notes field shall serve as the running operational narrative for the incident. The Information Operations personnel assigned to the work order shall enter all IoC observation detail, investigation activity, response decisions and their rationale, and actions taken within four (4) hours after the action is taken or before the conclusion of that staff member's current work shift, whichever occurs first.

Files Field — Evidence Artifacts: The work order Files field shall serve as the repository for all preserved evidence artifacts, including screenshots, exported logs, camera footage segments, and forensic captures attached to the record. If an evidence artifact exceeds the technical file-size upload limit of the System of Engagement, the Information Operations personnel assigned to the work order may store the artifact in a dedicated, access-controlled directory on an ECIO-managed secure file server. When this alternative storage method is utilized, the Information Operations personnel assigned to the work order shall document the exact network file path, file name, and the identity of the personnel depositing the file in the work order Notes field to preserve the chain of custody. Any such external storage location shall be subject to the identical access restrictions and retention schedules as the primary incident record.

6.5 Incident Classification

The Incident Commander shall classify all declared Chapter 4 incidents on two (2) independent dimensions. Both shall be documented in the Chapter 4 checklist.

Incident Type: Incident type is determined by the applicable Layer 1 category or categories (A through F) and answers what kind of incident is being handled. An incident may carry multiple type classifications if it spans multiple categories. The IT Director or the Assistant IT Director shall document incident type at declaration. The Incident Commander may update incident type as investigation unfolds and shall document any update in the work order Notes with the basis for the change.

Incident Severity: Incident severity is determined using the three-tier framework established in **Policy 4.01**, — High, Medium, or Low — and answers how serious the incident is. Chapter 4 severity classification is independent of and non-interacting with the five-tier operational severity framework established in **Policy 3.01** (Service Catalog and SLA Policy). The Incident Commander may reclassify severity at any point and shall document any reclassification in the work order Notes with the basis for the change.

6.6 CJIS Notification

CJIS Security Policy v6.0, Section IR-6 establishes a two-part notification obligation. Both parts apply to all declared incidents and shall be executed and documented in the Chapter 4 checklist CJIS notification log.

Part (a) — Internal Reporting: All Information Operations Personnel shall report any suspected or confirmed security incident to the Incident Commander immediately upon discovery, not to exceed one (1) hour after discovery. Work order creation constitutes the formal internal report satisfying Part (a). The work order creation timestamp in the System of Engagement is the documented record of internal report completion.

Part (b) — External Notification: Upon declaration, the IT Director (as LASO) shall notify the CSO, the SIB Chief, or the Interface Agency Official where CJI involvement is confirmed or cannot be ruled out at triage. **Policy 4.06** (Communication Protocols and Partner Integration) governs the execution of external notification. This policy owns the obligation trigger and the CJIS notification log entry documenting that handoff.

One-Hour Clock: The one (1) hour Part (a) clock starts at the first documented action in the System of Engagement: the work order creation timestamp for State 2 intake events, and the IoC observation notation timestamp for State 1 events. If prior awareness is established through a channel outside of the System of Engagement before the work order is created, that earlier time shall be noted in the work order and becomes the operative clock start for Part (a).

CJI Involvement Determination: CJIS Part (b) external notification attaches only to declared incidents where CJI involvement is confirmed or cannot be ruled out at triage. The IT Director or the Assistant IT Director shall record a CJI involvement determination — confirmed, possible, or ruled out with its basis — in the Chapter 4 checklist for every declared incident, regardless of whether Part (b) is ultimately triggered.

Notification Windows: All notification windows are measured in continuous calendar hours. No business-hours qualification applies, and no after-hours exception applies. For declared incidents with a CJI nexus, the IT Director shall initiate the handoff to **Policy 4.06** for external notification within the following windows measured from the time of declaration:

- **High severity with CJI nexus**: not to exceed one (1) hour from declaration.
- **Medium severity with CJI nexus**: not to exceed four (4) hours from declaration.
- **Low severity with CJI nexus**: not to exceed twenty-four (24) hours from declaration.

6.7 Evidence Artifact Retention

Incident Record Retention: The incident record — comprising the work order, Chapter 4 checklist, Notes, and system-generated audit trail — shall be retained for three (3) calendar years from the end of the calendar year of incident closure, in accordance with LRDA 20071728 (IT Access Control Reviews and Audit Trails). This retention period exceeds the CJIS AU-11 one-year minimum for audit records.

Evidence Artifact Retention: Evidence artifacts — including camera footage segments, exported logs, forensic captures, and file attachments in the work order — constitute security activity records and incident reports under LRDA 20071279 (Property Management: Security Records) and shall be retained for three (3) calendar years from the end of the calendar year to which they pertain, subject to the path-specific conditions below.

- **Path 1 — Confirmed incident, law enforcement involved:** The IT Director shall turn over evidence artifacts to law enforcement. ECIO shall retain documentation of the transfer — identifying what was transferred, to whom, when, and under what authority — for three (3) calendar years from the end of the calendar year of custody transfer. Evidence artifacts are released from ECIO retention upon documented custody transfer.
- **Path 2 — Confirmed incident, no law enforcement involvement:** The IT Director shall ensure evidence artifacts are retained for three (3) calendar years from the end of the calendar year to which the incident pertains, in accordance with LRDA 20071279, or for the duration of any related audit or legal hold, whichever is longer.
- **Path 3 — False positive disposition:** The IT Director shall ensure evidence artifacts are retained for three (3) calendar years from the end of the calendar year of the false positive determination, in accordance with LRDA 20071279, or for the duration of any related audit or legal hold, whichever is longer. The thirty (30) day indicator review window established in Section 6.1 governs modification of the triggering IoC indicator and is independent of this retention obligation.
- **Path 4 — CJI-involved incidents:** Standard tiered retention as described in Paths 1 through 3 applies. The IT Director shall conduct a due-diligence review for any applicable CJIS-specific retention requirement before disposition.

All retention obligations under this section are subject to legal hold requirements, litigation preservation obligations, and NRS 239.125. In the event of a conflict between this section and a legal hold or litigation preservation obligation, the legal hold or litigation preservation obligation governs.

4.03 Containment Strategy and Playbooks

Effective: April 29, 2026 Version: 2.2

1. Purpose

This policy governs the Containment phase of the ECIO incident response lifecycle, establishing the Incident Commander's decision framework for containment strategy selection, the mandatory evaluation criteria for that selection, and the playbooks that guide technical execution for each incident type recognized by the ECIO classification system.

2. Scope

This policy applies to all Information Operations Department personnel participating in incident response operations during the containment phase, including the IT Director, Assistant IT Director, Network Administrator, Systems Administrator, and all technicians operating under Incident Commander authority.

- **In Scope**:
  - Containment strategy selection and execution.
  - Incident Commander decision framework and evaluation criteria.
  - Short-term and long-term containment posture.
  - Emergency Change obligations arising from containment configuration actions.
  - Forensic preservation obligations during containment.
  - Containment documentation requirements.
  - Playbook framework and governance.
  - Containment-complete determination and eradication handoff.
  - False positive containment reversal.
- **Out of Scope**:
  - IoC evaluation and incident declaration: **Policy 4.02**.
  - Hard Fork mechanics: **Policy 3.06**.
  - Eradication procedures: **Policy 4.04**.
  - Recovery operations and Operational Handback: **Policy 4.05**.
  - Stakeholder communication and external notification execution: **Policy 4.06**.
  - Data and system classification for recovery: **Policy 4.05**.
  - Postmortem review and lessons learned: **Policy 4.07**.
  - CI record governance: **Policy 3.08**.
  - Change categorization and RFC governance: **Policy 3.09**.
  - Security baseline definitions: **Policy 2.10**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 4.01** (Incident Response Policy Overview) and governed by the delegation provisions in **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall ensure that when any Information Operations Personnel member is designated as Incident Commander per **Policy 1.08**, the designee exercises the same obligations listed under this role for the duration of the designation.
    - **Constraint**: CCA review authority and exception approval authority shall not transfer to the designee; those obligations remain with the IT Director personally.
  - Shall select the containment mode and document the rationale against the three mandatory evaluation criteria in the work order Notes before execution begins.
  - Shall designate containment configuration actions as Emergency Changes.
  - Shall make the containment-complete determination.
  - Shall designate the primary category for multi-category incidents.
  - Shall complete catch-up Configuration Control Authority (CCA) review for all Emergency Changes within the window established by **Policy 3.09** (Change Management Policy).
  - Shall initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**, when containment requires emergency hardware, vendor engagement, or tooling.
  - Shall authorize formal exceptions to the requirements of this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall serve as Incident Commander in the IT Director's absence or by designation, per **Policy 4.01** and **Policy 1.08**.
  - Shall maintain all category playbooks under standing authority per **Policy 3.13** (Knowledge Management Policy).
  - Shall ensure catch-up RFC documentation and CCA review timelines are met.
  - Shall ensure that affected CI records are flagged at the time of containment action for subsequent update per **Policy 3.08** (Service Configuration Management (CMDB) Policy).
- **Network Administrator:**
  - Shall lead network-related containment actions as directed by the Incident Commander.
  - Shall flag affected CI records at the time of containment action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the window established by **Policy 3.09**.
- **Systems Administrator:**
  - Shall lead server- and endpoint-related containment actions as directed by the Incident Commander.
  - Shall flag affected CI records at the time of containment action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the window established by **Policy 3.09**.

- **All Information Operations Personnel:**
  - Shall execute containment directives under Incident Commander authority.
  - Shall not take any containment action without an associated work order in the System of Engagement and IC authorization.
  - Shall document all actions in work order Notes consistent with the documentation standards established in **Policy 4.02** (Identification and Reporting Procedures).
  - Shall not destroy, overwrite, or cause the disposition of audit logs under any circumstances during the containment phase.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel participating in incident response operations during the containment phase.

- **Assessment**: Compliance with this policy shall be assessed through the ECIO internal audit program governed by **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process governed by **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: The following conditions constitute specific non-compliance with this policy:
  - Failure to document the IC's containment strategy decision — including mode selected and rationale against the three mandatory evaluation criteria — in the work order Notes before execution begins.
  - Execution of containment configuration actions without IC authorization or without an associated work order in the System of Engagement.
  - Failure to create catch-up RFC documentation within the window established by **Policy 3.09**.
  - Any containment action that destroys, overwrites, or causes the disposition of audit logs.
  - Failure to document a containment-complete determination in the work order Notes before initiating eradication activity.

Non-compliance may result in corrective action in accordance with **Policy 5.01**.

- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are permitted. All approved exceptions shall be documented and time-bounded. Oral exceptions are not valid. No exception under this section shall waive the audit log preservation obligation established in Section 6.2, the forensic evidence preservation requirement for CJI-involved systems established in Section 6.2, the CJIS notification obligations established in **Policy 4.02** and **Policy 4.06**, or the containment-complete documentation requirement established in Section 6.4.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy

- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring

Framework Alignment:

- ECIO Policy 1.09: Risk Management Policy
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Security Audit Records)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-5 (Incident Monitoring)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST CSF 2.0: RS.CO-02 (Stakeholder Notification)
- NIST CSF 2.0: RS.MA-01 (Incident Response Plan Execution)
- NIST CSF 2.0: RS.MA-03 (Incident Categorization and Prioritization)
- NIST CSF 2.0: RS.MA-04 (Incident Escalation and Elevation)
- NIST CSF 2.0: RS.MI-01 (Incident Containment)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-5 (Incident Monitoring)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

This policy activates upon handoff from **Policy 4.02**, following incident declaration, incident classification, and initial incident record creation. It governs all activity from that handoff point through containment-complete determination and handoff to **Policy 4.04** (Eradication Procedures and Scenario Guides). Technical configuration actions taken under this policy's authority trigger change authorization obligations governed by **Policy 3.09**.

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone

document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

6.1 Containment Strategy Selection Framework

When this policy activates, the following have been completed by **Policy 4.02** and are not repeated or redefined here:

- IoC evaluation.
- Incident declaration.
- Incident type classification by Layer 1 category.
- Incident severity classification.
- CJI involvement determination.
- Initial forensic record creation.
- External notification clock initiation per **Policy 4.02**.

The Incident Commander is in command. The work order and Chapter 4 checklist are active.

For the benefit of external readers: the Incident Commander is the single accountable authority for all containment decisions. The IT Director holds this role by default; any Information Operations Personnel member may be designated as Incident Commander per **Policy 4.01**. Full IC appointment mechanics are governed by **Policy 4.01** and **Policy 3.06** (Operational Incident Management Policy).

The Layer 1 IoC categories are six permanent categorical triggers governing incident classification:

- **Category A**: Unauthorized Access or Access Anomaly.
- **Category B**: Malicious Code Activity.
- **Category C**: Denial of Service.
- **Category D**: Data Compromise or Exfiltration.
- **Category E**: Targeted Reconnaissance.
- **Category F**: Improper Use with Security Nexus.

Full definitions are governed by **Policy 4.02**.

Incident severity is classified in three tiers — High, Medium, and Low — reflecting the scope, sensitivity, and operational impact of the incident. Severity classification is governed by **Policy 4.01**.

The Incident Commander shall select one of two strategic containment modes:

- **Isolation**: A hard cutoff — network disconnection, account disabling, or system quarantine — that immediately removes the threat's access to affected systems.
- **Active Monitoring**: Deliberate continued observation of threat activity while covert defensive measures are positioned, preserving forensic evidence and allowing threat scope to be confirmed before the isolation boundary is drawn.

Neither mode is a universal default. Both are legitimate IC choices depending on incident-specific evaluation. The IC shall document the mode selected and the rationale in the work order Notes before execution begins.

The Incident Commander shall evaluate all three of the following criteria for every incident before selecting a containment mode:

- **Operational Impact**: What operational capabilities are disrupted, degraded, or lost if the system or segment is isolated? What is the effect on other County departments, public-facing services, or critical infrastructure?
- **Forensic Preservation**: What evidence is gained by observing threat activity before isolation, and what evidence is lost or degraded by immediate isolation? Does the incident present a novel threat pattern that warrants observation to improve future detection?
- **Threat Scope**: How far has the threat spread, or how far could it spread if containment is deferred? Is active lateral movement occurring? Is the affected perimeter bounded or uncertain?

Containment proceeds in two phases. Short-term containment achieves immediate stabilization and bounds the active threat. Short-term actions may be temporary — a firewall block, an account suspension, a network segment quarantine — sufficient to stop the immediate spread while a sustainable long-term posture is designed. Long-term containment establishes a sustained configuration or monitoring state that can be maintained while eradication is prepared under **Policy 4.04**. **Policy 4.04** shall not be initiated until long-term containment is stable.

Two conditions mandate isolation regardless of IC mode discretion, pursuant to **Policy 2.10** (Secure Configuration Baselines and Hardening Policy). Unauthorized systems discovered without an approved configuration baseline (**Policy 2.10** Section 4) trigger incident response isolation protocols automatically. Critical-risk baseline deviations (**Policy 2.10**) shall result in logical isolation within four (4) hours of detection if not remediated. When a mandatory isolation trigger applies, the IC shall document the triggering condition and the isolation action taken in the work order Notes.

For incidents where CJI involvement is confirmed or cannot be ruled out at triage, the IC's mode selection shall account for the forensic preservation constraints in Section 6.2. When CJIS forensic preservation requirements and operational isolation requirements conflict, the IC shall document both considerations and the rationale for the chosen path in the work order Notes before execution begins.

6.2 Hard Fork Transition and Forensic Preservation

For the benefit of external readers: the Hard Fork is the jurisdictional transfer from operational incident management to Chapter 4 incident response, triggered upon IoC discovery by a technician. Full Hard Fork mechanics are governed by **Policy 3.06**.

The system preservation obligation in **Policy 3.06** — which requires a technician who discovers an IoC to cease troubleshooting, preserve current system state, and await direction — governs the technician's actions during the interval before the Incident Commander issues a containment directive. It is a constraint on unilateral technician action, not a constraint on IC authority. Upon receiving the IC's first containment directive, the technician shall execute that directive. The IC's containment direction supersedes the interim preservation hold.

The audit log preservation obligation established in **Policy 2.11** (Audit Logging and Monitoring Policy) is a standing constraint that applies to all personnel, including the Incident Commander, throughout the containment phase. No containment action shall destroy, overwrite, or cause the disposition of audit logs. This obligation is separate from and survives the sequencing resolution above.

Before any destructive containment action — system reimaging, or irreversible configuration change — the Incident Commander shall determine whether the affected system or its artifacts are material to incident scoping, forensic analysis, legal or regulatory obligations, or downstream eradication under **Policy 4.04**. Where the IC determines materiality, evidence shall be preserved before destructive action. For any system that processes, stores, or transmits CJI, preservation is mandatory before destructive action regardless of IC materiality determination. The method of preservation shall be documented in the work order Notes before the destructive action is executed.

When an incident involves audit processing failure as defined in **Policy 2.11**, restoring logging capability is a containment prerequisite. Containment perimeter integrity cannot be confirmed without functioning audit logs. The IC shall direct restoration of audit logging before declaring long-term containment stable.

6.3 Emergency Change Obligations During Containment

Every network isolation, firewall rule modification, account disabling, or system reconfiguration executed under containment authority is an Emergency Change under **Policy 3.09**. Emergency Change obligations attach at the moment of implementation, not after containment is complete.

The Incident Commander is authorized to designate containment configuration actions as Emergency Changes under **Policy 3.09**. This authority requires no prior approval and shall be exercised at the time of action.

Three documentation obligations run concurrently from the moment of each containment configuration action:

- The assigned technician shall create a standalone RFC record in the System of Engagement within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- The IT Director shall complete catch-up CCA review within the same window.
- The assigned technician shall flag affected CI records at the time of action; the CI record update obligation is deferred but not waived, and runs on the same concurrent twenty-four (24) hour clock per **Policy 3.09**.

Documentation obligations do not pause containment execution. They run concurrently with, or immediately following, containment actions. These obligations are not prerequisites to taking network or system action.

The catch-up RFC shall document:

- All actions taken with the most precise timestamps recoverable from system and audit logs.
- The conditions justifying Emergency Change designation.
- The CCA review outcome.
- CI record update confirmation.

The PIR obligation for all Emergency Changes executed under this policy shall follow the requirements and timelines established in **Policy 3.09**.

If a containment action meets any of the County Manager consultation triggers defined in **Policy 3.09**, the IC shall ensure the County Manager is notified no later than four (4) hours after implementation begins.

If containment requires procurement — emergency hardware, vendor engagement, or tooling — the Incident Commander is authorized to initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**. Administrative funding authority shall not be exercised to delay, suspend, or condition containment actions. Fiscal Affairs and Purchasing shall not delay containment for procurement review.

6.4 Containment Completion and Eradication Handoff

Containment is complete when the threat has been demonstrably bounded — further spread is not occurring, and the affected perimeter is defined with sufficient confidence to begin eradication. No phase transition is assumed. The IC shall make an explicit containment-complete determination, documented in the work order Notes, before any eradication activity under **Policy 4.04** begins.

Before initiating eradication activity, the following shall be documented in the work order Notes and Chapter 4 checklist:

- The confirmed containment perimeter with all affected systems identified.
- Systems isolated, accounts disabled, or segments under active monitoring posture.
- Evidence artifacts preserved during containment, including forensic copies, log extracts, and network captures.

- Outstanding catch-up RFC items with assigned owners and due dates.

The external notification clock established in **Policy 4.02** continues running during containment. Containment activities do not pause or satisfy external notification obligations. The notification windows defined in **Policy 4.02** are not affected by the duration of the containment phase. External notification execution is governed by **Policy 4.06** (Communication Protocols and Partner Integration).

If a declared incident resolves as a false positive during containment, the false positive disposition process in **Policy 4.02** governs indicator review. The IC shall direct reversal of all containment actions taken, including rollback of isolated systems to operational status, restoration of disabled accounts, and catch-up RFC documentation for any reversed Emergency Changes. The IC shall document the false positive determination and all reversal actions in the work order Notes. Operational jurisdiction may return to **Policy 3.06** per the IC's direction.

6.5 Playbook Framework

This policy mandates the existence of a governed containment playbook for each of the six Layer 1 IoC categories (A–F). Playbooks are maintained as Knowledge Base artifacts in the System of Engagement per **Policy 3.13** and formatted per **Policy 1.04** (Policy and Documentation Formatting Standards). All six category playbooks shall be in force at v1.0 of this policy.

When an incident receives multi-category classification under **Policy 4.02**, the IC shall designate a primary category at the time of containment strategy selection. The primary category playbook governs containment execution. Supplementary category playbooks inform the response. The IC shall document the primary category designation and rationale in the work order Notes.

Severity tier (High, Medium, or Low per **Policy 4.01**) modulates urgency and escalation thresholds within each category playbook. It does not alter the fundamental playbook structure. Each playbook's structure is consistent across severity tiers; the severity tier determines execution tempo and escalation trigger points.

Each category playbook shall contain, at minimum, the following seven elements:

- **Scenario Description**: A brief characterization of the incident type and its typical manifestations within the ECIO environment.
- **Containment Mode Guidance**: Scenario-specific considerations for isolation vs. active monitoring, informed by the three mandatory evaluation criteria in Section 6.1.
- **Short-Term Containment Actions**: Immediate technical steps to stabilize and bound the threat.
- **Long-Term Containment Posture**: Sustained configuration or monitoring state to maintain while eradication is prepared under **Policy 4.04**.
- **CJIS Considerations**: Specific forensic preservation and notification obligations applicable when CJI involvement is confirmed or cannot be ruled out.
- **Documentation Checkpoints**: What shall be documented in the work order Notes and Chapter 4 checklist at each stage of playbook execution.
- **Eradication Handoff Criteria**: The specific conditions that constitute containment-complete for this incident type, triggering handoff to **Policy 4.04**.

Each playbook shall be reviewed no less than annually, upon closure of any incident that invoked it, and upon any change to the ECIO environment classified as a Significant or Emergency Change under **Policy 3.09** that the Assistant IT Director determines affects the technical assumptions of that playbook. The Assistant IT Director shall maintain all category playbooks under standing authority.

4.04 Eradication Procedures and Scenario Guides

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy governs the eradication of cybersecurity threats from the Elko County Information Operations environment following containment and establishes the eradication-complete determination that gates transition to recovery operations under **Policy 4.05**.

2. Scope

This policy applies to all Information Operations Department personnel participating in incident response operations during the eradication phase, including the IT Director, Assistant IT Director, Network Administrator, Systems Administrator, and all technicians operating under Incident Commander authority.

- **In Scope**:
  - Eradication strategy selection and execution following containment-complete determination.
  - Threat neutralization, including removal of threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities.
  - Pre-execution forensic confirmation for destructive or irreversible eradication actions.
  - Emergency Change obligations arising from eradication configuration actions.
  - Eradication-complete determination and recovery handoff.
  - Eradication procedure framework and governance.
  - Eradication documentation requirements.
- **Out of Scope**:
  - IoC evaluation and incident declaration: **Policy 4.02**.
  - Containment strategy selection and execution: **Policy 4.03**.
  - Recovery operations and Operational Handback: **Policy 4.05**.
  - Data and system classification for recovery: **Policy 4.05**.
  - Stakeholder communication and external notification execution: **Policy 4.06**.
  - Postmortem review and lessons learned: **Policy 4.07**.
  - CI record governance: **Policy 3.08**.
  - Change categorization and RFC governance: **Policy 3.09**.
  - Security baseline definitions: **Policy 2.10**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 4.01** (Incident Response Policy Overview) and governed by the delegation provisions in **Policy 1.08** (Delegation of Authority and Decision Rights).

  - May designate any Information Operations Personnel member as Incident Commander for a specific incident per **Policy 4.01** and **Policy 1.08**; the designee exercises all IC authority defined in this section for the duration of the designation.
  - Shall retain personal responsibility for CCA review, exception approval, and incident classification decisions; these obligations shall not transfer to a designee.
  - Shall approve the eradication strategy, including selection of applicable eradication procedures and authorization of destructive eradication actions.
  - Shall make the eradication-complete determination, documenting the basis in the work order Notes and Chapter 4 checklist before any recovery activity under **Policy 4.05** (Recovery Operations and Restoration Prioritization) begins.
  - Shall confirm that forensic preservation requirements have been satisfied before authorizing any destructive or irreversible eradication action.
  - Shall complete Configuration Control Authority (CCA) review for all eradication-phase Emergency Changes within the twenty-four (24) hour concurrent documentation window established by **Policy 3.09** (Change Management Policy).
  - Shall initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**, when eradication requires emergency tooling, replacement hardware, or vendor engagement.
  - Shall authorize formal exceptions to the requirements of this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall serve as Incident Commander in the IT Director's absence or by IT Director designation, per **Policy 4.01** and **Policy 1.08**.
  - Shall serve as the primary operational coordinator for eradication activities under Incident Commander direction.
  - Shall own maintenance and review of eradication procedures maintained in the Knowledge Base per **Policy 3.13** (Knowledge Management Policy) under standing authority.
- **Network Administrator:**
  - Shall execute network-layer eradication actions as directed by the Incident Commander, including removal of unauthorized firewall rules, rogue DNS entries, compromised routing configurations, and other malicious network artifacts.
  - Shall flag affected CI records at the time of eradication action for subsequent update per **Policy 3.08** (Service Configuration Management (CMDB) Policy).
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Systems Administrator:**
  - Shall execute server- and endpoint-layer eradication actions as directed by the Incident Commander, including malware removal, compromised account remediation, persistence mechanism elimination, and system rebuild when required.
  - Shall flag affected CI records at the time of eradication action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.

- **All Information Operations Personnel:**
  - Shall execute eradication activities as directed by the Incident Commander.
  - Shall not initiate eradication actions independently or deviate from the selected eradication procedures without express IC authorization.
  - Shall document all eradication actions taken in the work order Notes as actions are completed.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel participating in incident response operations during the eradication phase.

- **Assessment**: Compliance with this policy shall be assessed through the ECIO internal audit program governed by **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process governed by **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: The following conditions constitute specific non-compliance with this policy: initiation of eradication activity before the Incident Commander has documented a containment-complete determination under **Policy 4.03**; execution of destructive or irreversible eradication actions without prior IC authorization or without documented confirmation that forensic preservation requirements have been satisfied; execution of eradication actions that deviate from the IC-selected eradication procedures without documented IC authorization; execution of eradication actions without an associated work order in the System of Engagement; failure to create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**; any eradication action that destroys, overwrites, or causes the disposition of audit logs maintained under **Policy 2.11** (Audit Logging and Monitoring Policy) or forensic evidence without documented IC authorization and justification; and failure to document an eradication-complete determination in the work order Notes before initiating recovery activity under **Policy 4.05**. Non-compliance may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are permitted. All approved exceptions shall be documented and time-bounded. No exception shall authorize the destruction, overwriting, or untracked disposition of preserved evidence, required audit records, or mandatory incident-record documentation. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures

- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NIST CSF 2.0: RS.MI-02 (Incident Eradication)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management

Framework Alignment:

- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Security Audit Records)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- ITIL v4: Incident Management Practice

6. Policy Statement

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

Eradication is the phase of the cybersecurity incident response lifecycle in which the threat is neutralized. Threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities are identified and removed from the affected environment. Eradication follows containment and precedes recovery. It is governed by NIST CSF 2.0: RS.MI-02 (Incident Eradication) and aligned with the guidance in NIST SP 800-61 Rev. 3.

6.1 Activation and Handoff State

When **Policy 4.04** activates, the following have been completed by **Policy 4.03** (Containment Strategy and Playbooks) and are not repeated or redefined here:

- Containment strategy selection and execution.
- Short-term and long-term containment posture establishment.
- Containment-complete determination by the Incident Commander (IC).
- All containment-phase documentation and change management obligations.

The IC is in command. The work order and Chapter 4 checklist are active. The following documentation package has been completed under **Policy 4.03** and is available in the work order Notes and Chapter 4 checklist:

- The confirmed containment perimeter with all affected systems identified.
- Systems isolated, accounts disabled, or segments under active monitoring posture.
- Evidence artifacts preserved during containment, including forensic copies, log extracts, and network captures.
- Outstanding catch-up RFC items with assigned owners and due dates.

The external notification clock established in **Policy 4.02** (Identification and Reporting Procedures) continues running during eradication. Eradication activities do not pause or satisfy external notification obligations. External notification execution is governed by **Policy 4.06** (Communication Protocols and Partner Integration).

Eradication shall not be initiated until the IC has documented a containment-complete determination under **Policy 4.03** and long-term containment is stable.

6.2 Eradication Framework

The IC holds authority over all eradication activity. No eradication action shall be initiated without IC authorization. The IC shall select the applicable eradication procedures, assign technical leads, and direct the sequence and timing of eradication actions.

Before eradication execution begins, the IC shall confirm the scope of eradication based on the containment perimeter and the incident classification established in **Policy 4.02**. The IC shall document the eradication scope in the work order Notes before execution begins. The eradication scope shall identify:

- All systems within the containment perimeter requiring remediation.
- The specific threat artifacts and persistence mechanisms to be removed from each system.
- The applicable eradication procedures to be invoked.
- Any systems where the eradication approach requires a destructive action.

Eradication actions fall into three (3) categories, distinguished by reversibility and forensic impact.

- **Non-Destructive Eradication:** Actions that remove threat artifacts without altering the underlying system's ability to be forensically examined after the fact. Examples include deleting malware files, removing unauthorized scheduled tasks or services, closing unauthorized network connections, and revoking compromised authentication tokens.
- **Credential and Access Remediation:** Actions that revoke, rotate, or replace compromised authentication credentials and access authorizations. Examples include password resets, certificate revocation, API key rotation, and disabling compromised accounts. These actions are operationally reversible but may disrupt active authentication sessions for the affected accounts.
- **Destructive Eradication:** Actions that alter or destroy system state in a manner that cannot be reversed and that may eliminate forensic evidence if not preceded by preservation. Examples include reimaging a compromised endpoint, rebuilding a server from clean media, wiping and redeploying a virtual machine, and overwriting compromised storage volumes. Destructive Eradication actions require the Forensic Preservation Gate defined in Section 6.3 to be satisfied before execution.

Eradication owns everything required to neutralize the threat and confirm clean state. Recovery owns everything required to restore operational capability. A system rebuild is eradication when it is performed because the system cannot be confirmed clean. A system rebuild is recovery when the system is confirmed clean and is being rebuilt to restore service. The eradication-complete determination in Section 6.4 marks this boundary.

For incidents where Criminal Justice Information (CJI) involvement is confirmed or has not been ruled out at triage, the IC shall ensure the following:

- No eradication action shall alter, overwrite, or destroy CJI or CJI audit records without documented IC authorization and written justification.
- The assigned technician shall complete forensic copies of CJI-bearing systems and the IC shall verify those copies before any Destructive Eradication action proceeds.
- The assigned technician shall document all eradication actions on CJI-bearing systems with sufficient detail to support post-incident CJIS compliance review.

6.3 Change Management Integration

All eradication configuration actions constitute Emergency Changes under **Policy 3.09**. The concurrent documentation clock established in **Policy 4.03** applies to eradication actions without modification.

Three documentation obligations run concurrently from the moment of each eradication configuration action:

- The assigned technician (Network Administrator or Systems Administrator, depending on the affected system) shall create a standalone RFC record in the System of Engagement within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.
- The IT Director shall complete CCA review within the same window.
- The assigned technician shall flag affected CI records at the time of action per **Policy 3.08**; the CI record update obligation is deferred but not waived and runs on the same concurrent twenty-four (24) hour clock per **Policy 3.09**.

Documentation obligations do not pause eradication execution. They run concurrently with, or immediately following, eradication actions. These obligations are not prerequisites to taking technical action.

The IT Director or designee shall complete Post-Implementation Review (PIR) documentation within five (5) business days of implementation for all Emergency Changes executed under this policy.

Before any Destructive Eradication action is executed, the IC shall confirm and document in the work order Notes that:

- All forensic preservation requirements for the affected system have been satisfied, including any requirements identified during containment under **Policy 4.03**.
- CJI forensic preservation obligations, where applicable, have been completed.
- The evidence record is sufficient to support postmortem review under **Policy 4.07** (Postmortem Review and Lessons Learned) and any external investigation or compliance review.

The Forensic Preservation Gate is a pre-execution confirmation, not a new process. It confirms that preservation actions already completed during containment remain intact and that no additional preservation is required before the system's state is irreversibly altered.

When an eradication action requires simultaneous or coordinated changes across multiple systems — such as domain-wide credential rotation or synchronized malware removal — the IC may authorize a single umbrella RFC documenting the coordinated action. The assigned technician shall document individual systems affected by the coordinated action as line items within the umbrella RFC rather than as separate RFC records. The assigned technician shall apply a CI record flag for each affected system at the time of action per **Policy 3.08**.

When eradication requires action by an external vendor, cloud service provider, or partner organization — such as requesting an ISP-level block or directing a cloud provider to terminate a compromised session — the IC shall document the following in the work order Notes:

- The action requested.

- The party to whom the request was directed.
- The time of request.
- The response received.
- The time of confirmation.

The catch-up RFC obligation does not apply to systems outside ECIO operational control. The documentation obligation survives.

The IC is authorized to initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**. This authority covers emergency tooling, replacement hardware, external incident response vendor engagement, and any other procurement required to sustain or complete eradication. Administrative funding authority shall not be exercised to delay, suspend, or condition eradication actions. Fiscal Affairs and Purchasing shall not delay eradication for procurement review.

If an eradication action meets any County Manager consultation trigger defined in **Policy 3.09**, the IC shall notify the County Manager no later than four (4) hours after the action begins.

6.4 Eradication-Complete Determination

Eradication is complete when the threat has been fully neutralized — all identified threat actors, malicious artifacts, compromised configurations, persistence mechanisms, and exploited vulnerabilities have been removed or remediated across all systems within the containment perimeter. No phase transition is assumed. The IC shall make an explicit eradication-complete determination, documented in the work order Notes and Chapter 4 checklist, before any recovery activity under **Policy 4.05** begins.

The following verification conditions are required for every eradication-complete determination. These conditions are necessary but explicitly not sufficient. The IC shall confirm that all scenario-specific verification criteria identified in the applicable eradication procedures have also been satisfied and shall document the basis for that confirmation in the work order Notes.

- The assigned technician shall verify all systems within the containment perimeter as clean using an authorized detection or validation method defined in the applicable eradication procedure. Where automated scanning is supported, a clean scan result from the Department's authorized scanning tools is required. Where automated scanning is not supported for a given system type, the applicable eradication procedure shall define the alternative validation method.
- The assigned technician shall rotate, revoke, or replace all identified compromised credentials.
- The assigned technician shall remove all identified persistence mechanisms, including unauthorized services, scheduled tasks, registry modifications, startup items, and unauthorized user accounts.
- The assigned technician shall patch all identified exploited vulnerabilities or implement documented compensating controls approved by the IC.
- The assigned technician shall update CI records for all eradication-driven configuration changes per **Policy 3.08**, or confirm that pending CI updates are within the applicable documentation window with assigned owners.
- The assigned technician shall complete all catch-up RFC documentation for eradication-phase Emergency Changes, or confirm that pending RFC items are within the twenty-four (24) hour documentation window with assigned owners.

The IC shall document the eradication-complete determination with explicit reference to each mandatory verification condition and shall identify the eradication procedures that were invoked along with confirmation that their scenario-specific verification criteria were satisfied.

Upon eradication-complete determination, the incident transitions to the recovery phase governed by **Policy 4.05**. The eradication-complete determination is the primary criterion for initiating recovery. The IC remains in command through the recovery phase until Operational Handback is declared under **Policy 4.05**.

6.5 Eradication Procedure Governance

Policy 4.04 mandates the existence of a governed library of eradication procedures. For purposes of this policy, the "scenario guides" referenced in the policy title and in the **Policy 4.01** Chapter 4 roadmap are the governed eradication procedures maintained in the System of Engagement. Eradication procedures are maintained as Knowledge Base artifacts in the System of Engagement per **Policy 3.13** and formatted per **Policy 1.04** (Policy and Documentation Formatting Standards).

The procedure library shall be sufficient to address eradication requirements across all six (6) Layer 1 Indicator of Compromise (IoC) categories (A through F) defined in **Policy 4.02**. The IT Director shall determine what procedures are required and shall authorize the creation of new procedures when operational needs or post-incident findings identify coverage gaps.

The containment playbooks maintained under **Policy 4.03** shall reference the applicable eradication procedures in their Eradication Handoff Criteria element. When a containment playbook identifies eradication procedures for a given incident type, the IC shall invoke those procedures at the time of eradication unless the IC determines and documents that a different procedure set is required based on conditions discovered during containment.

The Assistant IT Director owns eradication procedure maintenance under standing authority. The Assistant IT Director shall review each procedure no less than annually, upon closure of any incident that invoked it, and upon any change to the ECIO environment classified as a Significant or Emergency Change under **Policy 3.09** that is relevant to that procedure's technical scope.

Each eradication procedure shall contain, at minimum, the following seven (7) elements:

- **Scenario Description:** A characterization of the threat type and the circumstances under which this procedure is invoked.
- **Applicability Criteria:** The conditions that determine when this procedure applies, including Layer 1 IoC category mapping and any environmental or system-specific preconditions.
- **Required Tools and Access:** The tools, elevated permissions, and system access required to execute the procedure.
- **Eradication Steps:** Step-by-step technical instructions for threat removal, organized in executable sequence.
- **CJIS Considerations:** Specific forensic preservation and documentation obligations applicable when CJI involvement is confirmed or cannot be ruled out.
- **Verification Criteria:** Scenario-specific criteria that the assigned technician shall satisfy before the IC includes this procedure's scope in the eradication-complete determination. These criteria supplement the mandatory minimum verification conditions established in Section 6.4 of this policy. The Verification Criteria element shall define the authorized detection or validation method for systems within this procedure's scope, including the alternative validation method for system types where automated scanning is not supported.
- **Documentation Checkpoints:** What the assigned technician shall document in the work order Notes and Chapter 4 checklist at each stage of procedure execution.

6.6 False Positive Disposition During Eradication

If a declared incident resolves as a false positive during eradication, the false positive disposition process in **Policy 4.02** governs indicator review. The IC shall direct reversal of all eradication actions taken, unless the action constituted a Destructive Eradication action as defined in Section 6.2, in which case reversal is not possible and restoration shall proceed through the recovery process under **Policy 4.05**. The assigned technician shall reverse Non-Destructive Eradication and Credential and Access Remediation actions, including restoration of disabled accounts, reinstallation of removed software confirmed to be legitimate, and rollback of credential rotations where the original credentials were not compromised. The assigned technician shall

create catch-up RFC documentation for any reversed Emergency Changes per **Policy 3.09**. The IC shall document the false positive determination and all reversal actions in the work order Notes. Operational jurisdiction may return to **Policy 3.06** (Operational Incident Management Policy) per the IC's direction.

For Destructive Eradication actions that have already been executed, the IC shall document a destructive false-positive recovery authorization in the work order Notes. The authorization shall include the false positive determination, the justification for the original Destructive Eradication action, the actions performed, and the affected systems. The affected systems shall be restored through the recovery process under **Policy 4.05**. The IC shall include the authorization in the postmortem under **Policy 4.07**.

4.05 Recovery Operations and Restoration Prioritization

Effective: April 29, 2026 Version: 2.4

1. Purpose

This policy governs the recovery of IT systems, services, and infrastructure following cybersecurity incident eradication, the **Operational Handback** mechanism that transfers recovery authority from Chapter 4 to **Policy 3.15**(Service Continuity and Contingency Planning Policy), and the data and system classification framework that drives recovery prioritization during the security response phase.

2. Scope

This policy applies to all Information Operations Department personnel participating in incident response operations during the recovery phase and to all personnel responsible for maintaining the data and system classification framework for recovery.

- **In Scope**:
  - Recovery operations and system restoration following eradication-complete determination.
  - Security-specific recovery sequencing framework and Incident Commander override authority.
  - System verification criteria and production readiness confirmation.
  - Emergency Change obligations arising from recovery configuration actions.
  - Operational Handback initiation mechanics and documentation requirements.
  - Data and system classification for recovery prioritization.
  - Recovery documentation requirements.
- **Out of Scope**:
  - IoC evaluation and incident declaration: **Policy 4.02**.
  - Containment strategy selection and execution: **Policy 4.03**.
  - Eradication procedures and eradication-complete determination: **Policy 4.04**.
  - Stakeholder communication, external notification execution, IR roles, and contact directory: **Policy 4.06**.
  - Postmortem review and lessons learned: **Policy 4.07**.
  - CI record governance: **Policy 3.08**.
  - Change categorization and RFC governance: **Policy 3.09**.
  - Security baseline definitions: **Policy 2.10**.
  - Business Impact Analysis, RTO/RPO definitions, continuity plan maintenance, and post-Handback operational recovery sequencing: **Policy 3.15**.

3. Roles and Responsibilities

- **IT Director:**

  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 4.01**(Incident Response Policy Overview) and governed by the delegation provisions in **Policy 1.08**(Delegation of Authority and Decision Rights).
  - Shall approve the recovery sequencing plan, including any deviation from the standard BIA-driven recovery priority order established in **Policy 3.15**.
  - Shall make the Operational Handback determination, documenting the basis in the work order Notes and Chapter 4 checklist before recovery authority transfers to **Policy 3.15**.
  - Shall confirm that all system verification requirements have been satisfied before authorizing a system's return to production status.
  - Shall complete Configuration Control Authority (CCA) review for all recovery-phase Emergency Changes within the twenty-four (24) hour concurrent documentation window established by **Policy 3.09**(Change Management Policy).
  - Shall authorize formal exceptions to the requirements of this policy in accordance with the exception management framework established in **Policy 5.01**(Policy Implementation, Enforcement, and Legal Alignment).
  - Shall approve all classification assignments and review outcomes under Section 6.2.
  - Shall initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**, when recovery requires emergency hardware, replacement equipment, or vendor engagement.
  - Shall exercise Incident Commander authority as defined in this policy. The IT Director may designate any Information Operations Personnel as Incident Commander for a specific incident per **Policy 4.01** and **Policy 1.08**; a designated Incident Commander exercises the operational recovery authorities expressly assigned to the Incident Commander under this policy for the duration of the designation.
  - Shall retain personal authority over formal exception approval under **Policy 5.01** and classification register approval under Section 6.2 regardless of IC designation. CCA review authority follows **Policy 3.09** and does not transfer through IC designation.
- **Assistant IT Director:**
  - Shall serve as Incident Commander in the IT Director's absence or by IT Director designation, per **Policy 4.01**and **Policy 1.08**.
  - Shall serve as the primary operational coordinator for recovery activities under Incident Commander direction.
  - Shall own maintenance and review of the Recovery Verification Checklist maintained in the Knowledge Base per **Policy 3.13**(Knowledge Management Policy) under standing authority.
  - Shall own maintenance and review of the recovery classification register, ensuring alignment with the Business Impact Analysis maintained under **Policy 3.15**.
  - Shall ensure that CI records and CMDB entries under **Policy 3.08**(Service Configuration Management (CMDB) Policy) reflect post-recovery configuration states.
- **Network Administrator:**
  - Shall execute network-layer recovery actions as directed by the Incident Commander, including restoration of network configurations, firewall rules, and network services.
  - Shall flag affected CI records at the time of recovery action for subsequent update per **Policy 3.08**.

  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
- **Systems Administrator:**
  - Shall execute server- and endpoint-layer recovery actions as directed by the Incident Commander, including system rebuilds, service restoration, data restoration from backup, and application redeployment.
  - Shall flag affected CI records at the time of recovery action for subsequent update per **Policy 3.08**.
  - Shall create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
  - Shall execute backup restoration operations in accordance with the procedures maintained in the Knowledge Base under **Policy 3.13** consistent with the backup governance requirements established in **Policy 3.15**.
- **All Information Operations Personnel:**
  - Shall execute recovery activities as directed by the Incident Commander.
  - Shall not initiate recovery actions independently or deviate from the IC-approved recovery sequencing plan without express IC authorization.
  - Shall document all recovery actions taken in the work order Notes as actions are completed.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel participating in incident response operations during the recovery phase.

- **Assessment**: Compliance with this policy shall be assessed through the ECIO internal audit program governed by **Policy 5.02**(Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process governed by **Policy 5.07**(Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance may result in corrective action in accordance with **Policy 5.01**. The following conditions constitute specific non-compliance with this policy:
  - Initiation of recovery activity before the Incident Commander has documented either an eradication-complete determination or a destructive false-positive recovery authorization under **Policy 4.04**.
  - Return of a system to production status without documented completion of all applicable verification criteria.
  - Execution of recovery configuration actions without IC authorization or without an associated work order in the System of Engagement.
  - Failure to create catch-up RFC documentation within the twenty-four (24) hour window established by **Policy 3.09**.
  - Declaration of Operational Handback without documented completion of all Handback preconditions established in Section 6.6.
  - Failure to complete Handback close-out documentation within the twenty-four (24) hour window established in Section 6.6.
  - Failure to maintain the classification register review cadence established in Section 6.2.
- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are

permitted. All approved exceptions shall be documented and time-bounded. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 2.09: Vulnerability and Patch Management Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 2.11: Audit Logging and Monitoring Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management

Framework Alignment:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.12: IT Asset Management Policy
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST CSF 2.0: RC.CO-03 (Recovery Activities and Progress Communication)
- NIST CSF 2.0: RC.RP-02 (Recovery Actions Selection and Execution)
- NIST CSF 2.0: RC.RP-03 (Backup and Restoration Asset Integrity)
- NIST CSF 2.0: RC.RP-04 (Post-Incident Operational Norms)
- NIST CSF 2.0: RC.RP-05 (Restoration Verification)

- NIST CSF 2.0: RC.RP-06 (Recovery Closure and Documentation)
- NIST SP 800-53 Rev. 5: CP-2 (Contingency Plan)
- NIST SP 800-53 Rev. 5: CP-9 (System Backup)
- NIST SP 800-53 Rev. 5: CP-10 (System Recovery and Reconstitution)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- COBIT 2019: DSS04 (Manage Continuity)
- ITIL v4: IT Service Continuity Management Practice

6. Policy Statement

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

Recovery is the phase of the cybersecurity incident response lifecycle in which systems, services, and infrastructure are restored to operational status following threat neutralization. Recovery follows eradication and precedes the postmortem review. It is governed by NIST CSF 2.0: RC.RP-01 (Recovery Plan Execution) and aligned with the guidance in NIST SP 800-61 Rev. 3.

This policy governs two distinct functions under a single policy number. Sections 6.1 through 6.5 and Section 6.7 govern the operational recovery process — the phase-specific activities that occur during an active cybersecurity incident. Section 6.2 governs the data and system classification framework for recovery — support infrastructure that is maintained during the Preparation phase and consumed during the Recovery phase. The **Policy 4.01** Chapter 4 roadmap describes both functions and their lifecycle phase alignment.

6.1 Activation and Handoff State

When **Policy 4.05**activates, the following have been completed by **Policy 4.04**(Eradication Procedures and Scenario Guides) and are not repeated or redefined here:

- Eradication strategy selection and execution.
- Forensic Preservation Gate confirmation for all Destructive Eradication actions.
- All mandatory and scenario-specific eradication verification conditions.
- Eradication-complete determination by the Incident Commander (IC).
- All eradication-phase documentation and change management obligations.

The IC is in command. The work order in the System of Engagement and the Chapter 4 checklist are active. The following documentation package has been completed under **Policy 4.04** and is available in the work order Notes and Chapter 4 checklist:

- Eradication-complete determination with explicit reference to each mandatory verification condition.
- Identification of eradication procedures invoked and confirmation that their scenario-specific verification criteria were satisfied.
- All systems within the containment perimeter verified as clean.
- All identified compromised credentials rotated, revoked, or replaced.

- All identified persistence mechanisms removed.
- All identified exploited vulnerabilities patched or subject to documented compensating controls approved by the IC.
- CI record updates completed or within the applicable documentation window with assigned owners.
- Catch-up RFC documentation completed or within the twenty-four (24) hour documentation window with assigned owners.

The external notification clock established in **Policy 4.02**(Identification and Reporting Procedures) continues running during recovery. Recovery activities do not pause or satisfy external notification obligations. External notification execution is governed by **Policy 4.06**(Communication Protocols and Partner Integration).

For cases involving Destructive Eradication actions disposed as false positives, a destructive false-positive recovery authorization issued by the IC under **Policy 4.04** establishes the handoff state in lieu of an eradication-complete determination and associated verification documentation.

The IC shall not initiate recovery activity until the IC has documented either an eradication-complete determination or a destructive false-positive recovery authorization under **Policy 4.04**.

6.2 Data and System Classification for Recovery

This section establishes the classification framework that drives recovery prioritization during a cybersecurity incident. This section is support infrastructure: the classifications are maintained during the Preparation phase so they are current and defensible at the time of an actual incident. References throughout this manual to data and system classification “under **Policy 4.05**" refer to this section.

Policy 3.15(Service Continuity and Contingency Planning Policy) establishes the authoritative asset criticality classification taxonomy used across the ECIO for continuity and recovery planning. That taxonomy defines four classification classes: Tier 1 (Mission Critical), Tier 2 (Operationally Important), Tier 3 (Administrative / Deferrable), and Security Infrastructure. The Business Impact Analysis (BIA) maintained under **Policy 3.15** produces the classification assignments, Recovery Time Objectives (RTOs), Recovery Point Objectives (RPOs), and recovery sequence priority order for each in-scope system. The **Policy 3.15**BIA is the single authoritative source of truth for classification assignments. This policy does not define a separate tier system and does not independently assign systems to tiers.

This policy adopts the **Policy 3.15**classification taxonomy and BIA-driven classification assignments as the foundation for cybersecurity recovery prioritization. The recovery classification register maintained under this section is a controlled derivative view of the **Policy 3.15**BIA. It does not carry independent approval authority over tier assignments. When a discrepancy exists between the recovery classification register and the BIA, the BIA governs.

The recovery classification register supplements the BIA by documenting, for each classified system:

- The system’s **Policy 3.15**tier assignment, mirrored from the BIA.
- Whether the system processes, stores, or transmits Criminal Justice Information (CJI), as determined by the CJI data mapping maintained under **Policy 1.11**(Data Governance and Classification Policy).
- The system’s security dependencies — other systems whose security posture the IC shall confirm before this system can safely return to production (for example, a domain controller that the IC shall verify clean before authorizing restoration of workstations that authenticate against it).

The Assistant IT Director shall maintain the recovery classification register and shall review it no less than annually, concurrent with the BIA review cadence established in **Policy 3.15**, and following any Significant or Emergency Change as defined in **Policy 3.09**that materially alters the service catalog or infrastructure. The IT Director shall approve each updated version before it takes effect.

6.3 Recovery Sequencing and IC Override Authority

The IC shall ensure recovery sequencing during the security response phase follows the BIA-driven recovery sequence priority order established in **Policy 3.15** subject to the IC's security-specific override authority defined in this section.

For the benefit of external readers: the BIA recovery sequence priority order determines which systems are restored first based on their criticality to County operations. Tier 1 (Mission Critical) systems recover first, followed by Tier 2 (Operationally Important), then Tier 3 (Administrative / Deferrable). Security Infrastructure — logging, monitoring, and vulnerability management systems — recovers alongside Tier 1 under security-event conditions. Full classification definitions are established in **Policy 3.15**.

The **Policy 3.15** three-state rule for Security Infrastructure sequencing applies to all Chapter 4 recovery operations. Under Chapter 4 authority, every incident is a known or suspected security event by definition. Security Infrastructure shall therefore recover concurrently with Tier 1 systems. The IC shall confirm log visibility — that audit logging and monitoring systems are operational and producing current data — before authorizing broader restoration of Tier 2 and Tier 3 systems. This constraint ensures that systems are not returned to the environment before the Department has the detection capability to identify any residual threat activity.

Before recovery execution begins, the IC shall establish a recovery sequencing plan documented in the work order Notes. The IC shall identify all systems requiring recovery, their tier assignments, and the planned restoration order in the sequencing plan.

The IC may override the standard BIA-driven recovery sequence when security considerations warrant a deviation. Override authority exists because the BIA recovery order is designed for operational continuity — it does not account for incident-specific security constraints that arise during a cybersecurity response. Two common scenarios illustrate when override is appropriate:

- A Tier 1 system was the point of compromise. Restoring it first, as the BIA sequence would require, risks reintroducing the threat vector before the environment is confirmed clean. The IC may defer its recovery until verification is complete on supporting systems.
- A lower-tier system provides log aggregation or monitoring capability not classified as Security Infrastructure. The IC may elevate its recovery priority to restore detection visibility before higher-tier systems are returned to the environment.

When the IC exercises override authority, the IC shall document the following in the work order Notes before execution begins:

- The specific deviation from the BIA recovery sequence.
- The security justification for the deviation.
- The expected impact on RTOs for affected systems.

Override authority is a security-phase authority exercised during an active incident. It does not modify the BIA or the **Policy 3.15**recovery sequence priority order. Upon Operational Handback, the **Policy 3.15**BIA-driven order governs any remaining restoration activity.

6.4 System Verification and Production Readiness

The IC shall not authorize any system's return to production status following a cybersecurity incident without documented completion of all applicable verification criteria. System verification confirms that the system is not only operationally functional but is in a security posture suitable for production operation.

The Recovery Verification Checklist shall be maintained as a governed Knowledge Base artifact in the System of Engagement per **Policy 3.13**and formatted per **Policy 1.04** (Policy and Documentation Formatting Standards). The Assistant IT Director shall own checklist maintenance under standing authority. The Assistant IT Director shall review the checklist no less than annually, upon closure of any incident that invoked

it, and upon any change to the ECIO environment classified as a Significant or Emergency Change under **Policy 3.09**that is relevant to the checklist's technical scope.

The Recovery Verification Checklist shall address, at minimum, the following verification domains. The assigned technician shall perform each verification action and shall document the results in the work order Notes. The IC shall review the documented results before authorizing the system's return to production.

- **Eradication confirmation**: The assigned technician shall confirm that the eradication-complete determination under **Policy 4.04**covers the system and that the system was verified clean through the applicable eradication verification method.
- **Security baseline verification**: The assigned technician shall verify the system's configuration against the applicable security baseline maintained under **Policy 2.10**(Secure Configuration Baselines and Hardening Policy).
- **Clean media build requirement**: The assigned technician shall build systems rebuilt during eradication or recovery from clean, baselined media in accordance with **Policy 2.10**.
- **Audit log integrity**: The assigned technician shall confirm that audit logging is active and intact on the system, consistent with the requirements of **Policy 2.11**(Audit Logging and Monitoring Policy). The assigned technician shall confirm log continuity from the pre-incident period through recovery or shall document gaps.
- **Post-recovery vulnerability assessment**: The assigned technician shall complete a vulnerability scan of the system in accordance with **Policy 2.09**(Vulnerability and Patch Management Policy). The assigned technician shall remediate Critical or High-severity findings on the recovered system, or the IC shall approve documented compensating controls, before the system is returned to production.
- **Data integrity verification**: Where the Systems Administrator has restored the system from backup, the Systems Administrator shall confirm data integrity consistent with the backup restoration verification standards established in **Policy 3.15**.
- **Security dependency confirmation**: The IC shall confirm that all systems identified as security dependencies in the recovery classification register (Section 6.2) have themselves passed verification before authorizing this system's return to production.

The IC shall authorize each system's return to production status upon receiving documented confirmation from the assigned technician that all applicable verification criteria have been satisfied. The IC shall document the authorization and the verification basis in the work order Notes.

For systems processing, storing, or transmitting CJI, the IC shall confirm and document that all CJIS-required security controls are in force before the system is returned to production. CJI systems shall not be returned to production with compensating controls in lieu of required CJIS controls unless the IT Director (as LASO) has obtained written authorization from the CJIS Systems Agency (CSA), CJIS Systems Officer (CSO), or other CJIS governing authority required by the applicable CJIS Security Addendum or interagency agreement, and the IT Director has documented that authorization in the work order.

6.5 Change Management Integration

All recovery configuration actions constitute Emergency Changes under **Policy 3.09**. Emergency designation by the IC authorizes immediate implementation; it does not itself constitute CCA authorization. Provisional CCA authority for immediate implementation rests with the IT Director or Assistant IT Director per **Policy 3.09**. The concurrent documentation clock established in **Policy 4.03**(Containment Strategy and Playbooks) and carried forward through **Policy 4.04** applies to recovery actions without modification.

Three documentation obligations run concurrently from the moment of each recovery configuration action:

- The assigned technician (Network Administrator or Systems Administrator, depending on the affected system) shall create a standalone RFC record in the System of Engagement within twenty-four (24) hours of implementation, or by noon on the next business day, whichever is later.

- The IT Director shall complete catch-up CCA review within the same window.
- The assigned technician shall flag affected CI records at the time of action per **Policy 3.08**. The CI record update obligation is deferred but not waived and runs on the same concurrent twenty-four (24) hour clock per **Policy 3.09**.

Documentation obligations do not pause recovery execution. They run concurrently with, or immediately following, recovery actions. These obligations are not prerequisites to taking technical action.

The IT Director or designee shall complete Post-Implementation Review (PIR) documentation within five (5) business days of implementation for all Emergency Changes executed under this policy.

When a recovery action requires simultaneous or coordinated changes across multiple systems — such as domain-wide service restoration or synchronized application redeployment — the IC may authorize a single umbrella RFC documenting the coordinated action. The assigned technician shall document individual systems affected by the coordinated action as line items within the umbrella RFC rather than as separate RFC records. The assigned technician shall apply a CI record flag for each affected system at the time of action per **Policy 3.08**.

If a recovery action meets any County Manager consultation trigger defined in **Policy 3.09**, the IC shall notify the County Manager no later than four (4) hours after the action begins.

The IC is authorized to initiate emergency procurement under County emergency procedures with after-the-fact ratification, per **Policy 1.08**. This authority covers replacement hardware, software licensing, external vendor engagement, and any other procurement required to sustain or complete recovery. Administrative funding authority shall not be exercised to delay, suspend, or condition recovery actions. Fiscal Affairs and Purchasing shall not delay recovery for procurement review.

6.6 Operational Handback

Operational Handback is the mechanism by which the Incident Commander formally declares the security response phase complete and transfers operational recovery authority from Chapter 4 to **Policy 3.15**. This section governs the initiation mechanics. **Policy 3.15** governs the receiving obligations.

The IC shall not assume Operational Handback. An incident remains under Chapter 4 authority until the IC explicitly declares Handback. Ambiguity is not permitted.

The IC shall declare Operational Handback when all of the following preconditions are satisfied:

- The IC has confirmed that the eradication-complete determination has been documented under **Policy 4.04**.
- The IC has confirmed that all systems designated for recovery during the security response phase have either been returned to production with documented verification, or the IC has explicitly deferred them to post-Handback restoration under **Policy 3.15**authority with documented justification.
- The IC has made a documented professional judgment that no residual threat remains in the environment. This judgment is an IC determination, not a checklist item. It reflects the totality of the incident — the nature of the threat, the thoroughness of eradication, and the results of recovery verification.
- The IC has confirmed that all evidence preservation obligations have been satisfied or have been transitioned to the retention framework established in **Policy 4.02**.
- The IC has triggered a postmortem review under **Policy 4.07**(Postmortem Review and Lessons Learned).

The IC shall document the Operational Handback declaration in the work order Notes and Chapter 4 checklist at the time it is made. The IC shall reference satisfaction of each precondition in the declaration.

Upon declaring Operational Handback, the IC's emergency authority under Chapter 4 terminates. All subsequent recovery activity for systems deferred to post-Handback restoration is governed by **Policy 3.15**. The BIA-driven recovery sequence priority order governs any remaining restoration sequencing without

IC override authority. Normal operational authority under **Policy 3.06**(Operational Incident Management Policy) and **Policy 3.15**resumes.

A twenty-four (24) hour close-out window begins at the time of Operational Handback declaration. Within this window, the following responsible parties shall complete the following obligations:

- The assigned technician shall complete all outstanding catch-up RFC documentation for recovery-phase Emergency Changes.
- The assigned technician shall complete all outstanding CI record updates for recovery-phase configuration changes.
- The IT Director shall complete CCA review for all recovery-phase Emergency Changes not yet reviewed.
- The Assistant IT Director shall confirm that the Chapter 4 checklist is complete for all mandatory fields through the recovery phase.

The twenty-four (24) hour close-out window governs administrative documentation obligations only. It does not extend IC authority. The IC's emergency authority terminates at the moment of Handback declaration, not at the expiration of the close-out window.

6.7 Re-escalation to Eradication

If, during recovery operations, conditions are discovered that indicate the eradication was incomplete — including but not limited to the reappearance of threat artifacts, the activation of previously unidentified persistence mechanisms, or the observation of new **Indicators of Compromise** as defined in **Policy 4.02**— the IC shall immediately halt recovery on the affected system or systems and shall re-escalate to eradication under **Policy 4.04**.

Re-escalation is not a new incident declaration. The existing incident record, work order, and Chapter 4 checklist remain active. The IC shall document the re-escalation, including the conditions that triggered it, in the work order Notes at the time of the determination. Eradication recommences under **Policy 4.04**authority. The IC shall not resume recovery under this policy until a new eradication-complete determination has been documented under **Policy 4.04**.

When re-escalation occurs after one or more systems have already been returned to production, the IC shall evaluate whether the systems already restored are affected by the newly discovered conditions. If the IC determines that the restored systems may be compromised, the IC shall direct their re-isolation under **Policy 4.03**(Containment Strategy and Playbooks) authority. The IC shall document the re-isolation decision and the basis for it in the work order Notes.

4.06 Communication Protocols and Partner Integration

Effective: April 29, 2026 Version: 2.3

1. Purpose

This policy governs all internal and external communications during cybersecurity incident response, the framework for external partner engagement, and the incident response contact directory.

2. Scope

This policy applies to all Information Operations Department personnel participating in or supporting cybersecurity incident response operations, and to all communications produced under Chapter 4 authority.

- **In Scope**:
  - Communication authority framework and the One Voice Rule during cybersecurity incidents.
  - Communication type taxonomy, approval requirements, and documentation obligations.
  - Internal status update and executive notification requirements.
  - CJIS Security Policy Section IR-6 Part (b) external notification execution.
  - NRS 603A.220 breach notification mechanics, timelines, and legal review routing.
  - External partner engagement framework for threat intelligence, incident coordination, and law enforcement referral.
  - Technical coordination and vendor communication guardrails during active incident response.
  - Legal review routing requirements for incident-related communications.
  - Media and public communication authorization.
  - Post-incident and post-Handback communication requirements.
  - Communication documentation and data protection obligations.
  - Incident response contact directory governance and validation.
  - Communication record retention.
- **Out of Scope**:
  - IoC evaluation, incident declaration, and CJIS IR-6 Part (a) internal one-hour reporting clock: **Policy 4.02**.
  - Containment strategy selection and playbook execution: **Policy 4.03**.
  - Eradication procedures and scenario-specific guidance: **Policy 4.04**.
  - Recovery operations and Operational Handback initiation mechanics: **Policy 4.05**.
  - Postmortem review and lessons learned: **Policy 4.07**.
  - CI record governance: **Policy 3.08**.
  - Change categorization and RFC governance: **Policy 3.09**.
  - Non-incident stakeholder communication and governance-level communication standards: **Policy 1.14**.

- Day-to-day end-user communication standards and channel requirements: **Policy 3.03**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as Incident Commander for all cybersecurity incidents by default, as established in **Policy 4.01** (Incident Response Policy Overview) and governed by the delegation provisions in **Policy 1.08** (Delegation of Authority and Decision Rights).
  - Shall serve as the sole authoritative source for strategic and public-facing incident communications under the One Voice Rule defined in Section 6.1.
  - Shall authorize all external communications issued under this policy, except where the technical coordination carve-out defined in Section 6.7 applies.
  - Shall render the breach determination required to initiate the NRS 603A.220 notification process defined in Section 6.5.
  - Shall authorize all external partner engagement during an active incident in accordance with Section 6.6.
  - Shall authorize all media and public communications in accordance with Section 6.9.
  - Shall make law enforcement referral decisions personally and shall not delegate law enforcement referral authority.
  - Shall, as the designated Local Agency Security Officer (LASO) under **Policy 1.11** (Data Governance and Classification Policy), execute all CJIS Security Policy Section IR-6 Part (b) external notification obligations in accordance with Section 6.4 and the notification windows established in **Policy 4.02** (Identification and Reporting Procedures).
  - Shall, as LASO, execute CJIS denial notifications routed from **Policy 5.05** (Security Control Assessment and Authorization) through the notification mechanics defined in Section 6.4.
  - Shall ensure the incident response contact directory is validated annually in accordance with Section 6.12.
- **Assistant IT Director:**
  - Shall coordinate the preparation of draft communications for IC review and authorization.
  - Shall ensure that all communications issued under this policy are documented in the incident work order in accordance with Section 6.11.
  - Shall prepare communication data for inclusion in the postmortem record under **Policy 4.07** (Postmortem Review and Lessons Learned).
- **Administrative Assistant:**
  - Shall maintain the incident response contact directory as a governed Knowledge Base artifact in accordance with **Policy 3.13** (Knowledge Management Policy) and Section 6.12.
  - Shall update the incident response contact directory within one (1) business day of any personnel change affecting an IR role assignment.
- **Incident Commander (when not the IT Director or Assistant IT Director):**
  - Shall exercise communication authorization authority within the scope of the IC delegation established in **Policy 1.08** and the One Voice Rule defined in Section 6.1.
  - Shall ensure internal status updates are issued in accordance with Section 6.3.
  - Shall ensure all incident-related communications are documented in the incident work order in accordance with Section 6.11.

  - Shall escalate any condition that may constitute a breach of personal information to the IT Director immediately upon identification, in accordance with Section 6.5.
- **All Information Operations Personnel:**
  - Shall comply with the One Voice Rule defined in Section 6.1.
  - Shall not issue external communications regarding a cybersecurity incident without IC authorization, except where the technical coordination carve-out defined in Section 6.7 applies.
  - Shall document all incident-related communications in the incident work order within the timeframes established in Section 6.11.
  - Shall not speculate in writing or verbally on incident cause, attribution, scope, or data compromise to any audience until authorized by the IC.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in or supporting cybersecurity incident response.

- **Assessment**: Adherence to communication authorization requirements, notification timelines, documentation obligations, legal review routing requirements, and contact directory maintenance shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to obtain required authorization before issuing external communications, failure to execute CJIS or breach notifications within the timelines established in this policy, failure to route communications through legal review when required by Section 6.8, failure to document communications as required by Section 6.11, or failure to maintain the contact directory validation cadence established in Section 6.12, without documented justification, shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception framework established in **Policy 5.01**, within the delegation constraints of **Policy 1.08**. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline and any compensating measures in effect during the exception period. No exception may suspend or modify the CJIS notification obligations established in Section 6.4 or the NRS 603A.220 notification obligations established in Section 6.5. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.03: Service Communications Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.15: Service Continuity and Contingency Planning Policy

- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.07: Postmortem Review and Lessons Learned
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.05: Security Control Assessment and Authorization
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239 (Public Records)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- LRDA 20071728 (IT Security Audit Records)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- NIST CSF 2.0: RS.CO-02 (Stakeholder Notification)
- NIST SP 800-53 Rev. 5: IR-6 (Incident Reporting)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cyber Risk Management

Framework Alignment:

- NRS 239.125 (Local Government Records Management Program)
- CJIS Security Policy v6.0: Section IR-1 (Incident Response Policy and Procedures)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- NIST CSF 2.0: RS.CO-03 (Stakeholder Information Sharing)
- NIST CSF 2.0: RC.CO-03 (Recovery Communication)
- NIST SP 800-53 Rev. 5: IR-1 (Incident Response Policy and Procedures)
- NIST SP 800-53 Rev. 5: IR-7 (Incident Response Assistance)
- NIST SP 800-53 Rev. 5: PM-15 (Security and Privacy Groups and Associations)
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- COBIT 2019: MEA03 (Managed Compliance with External Requirements)
- ITIL v4: Incident Management Practice
- ITIL v4: Relationship Management Practice

6. Policy Statement

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers who may read it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

Incident communication is a cross-cutting function that spans the entire cybersecurity incident response lifecycle. Unlike the sequential phase-specific policies in Chapter 4 (**Policy 4.02** through **Policy 4.05**), this policy operates continuously from the moment of incident declaration through the conclusion of post-incident communications following Operational Handback. It operationalizes the CJIS Security Policy Section IR-6 external notification obligation, the NRS 603A.220 breach notification obligation, and the communication governance framework established in **Policy 1.14** (Stakeholder Engagement and Communications Policy). It governs the NIST CSF 2.0: RS.CO-02 (Stakeholder Notification) function and is aligned with the communication guidance in NIST SP 800-61 Rev. 3.

Policy 3.03 (Service Communications Policy) establishes the foundational channel and documentation standards for all IT Department communications. During active cybersecurity incident response, this policy supersedes **Policy 3.03** for all incident-related communications. **Policy 3.03** standards resume upon the conclusion of post-incident communications following Operational Handback. Where this policy does not address a specific communication requirement, **Policy 3.03** remains in effect as the baseline.

6.1 Communication Authority and the One Voice Rule

This policy establishes the One Voice Rule for cybersecurity incident communications. The One Voice Rule requires that all strategic, public-facing, and external incident communications be authorized by the Incident Commander and issued through a single authoritative channel. This rule is consistent with the broader communications governance established in **Policy 1.14** and is restated here in operational terms for personnel and external reviewers who may not have access to the full ECIO Policy Manual.

The IT Director, serving as Incident Commander by default under **Policy 4.01**, shall be the sole authoritative source for strategic and public-facing messaging during a cybersecurity incident. When IC authority has been delegated to a Tier L3+ technical lead in accordance with **Policy 1.08**, the delegate shall exercise communication authorization authority within the scope of that delegation. The IT Director shall retain personal authority over NRS 603A.220 breach notifications, media and public statements, and law enforcement referral communications regardless of IC delegation status.

The IC shall authorize all external communications before issuance. No Information Operations personnel shall issue, publish, or transmit any external communication regarding a cybersecurity incident without prior IC authorization, except where the technical coordination carve-out defined in Section 6.7 applies.

The One Voice Rule shall not prohibit internal communication necessary for incident response coordination. Internal status communications among IT Department personnel do not require individual IC authorization, but shall comply with the documentation requirements in Section 6.11 and the speculation prohibition in Section 3 of this policy.

6.2 Communication Types and Approval Requirements

This policy governs the following communication types. Each type identifies the authorized issuer, the approval authority, and the applicable documentation requirement.

Internal Status Updates: Communications among IT Department personnel regarding incident status, technical findings, and task coordination. Authorized issuer: any Information Operations personnel participating in the response. Approval authority: none required. Documentation: incident work order within four (4) hours.

Executive and County Manager Notifications: Notifications to the County Manager regarding incident declaration, changes in severity classification, CJI involvement determination, breach determination, law enforcement referral, NRS 603A.220 notification initiation, or Operational Handback. Authorized issuer: the IT Director. Approval authority: none required (the IT Director is the authoritative source). Documentation: incident work order at the time of issuance.

CJIS IR-6 Part (b) External Notifications: Notifications to the CJIS Systems Officer (CSO), the State Identification Bureau (SIB) Chief, or the Interface Agency Official. Authorized issuer: the IT Director (as

LASO), or a delegate authorized under **Policy 1.08**. Approval authority: the IT Director. Documentation: CJIS notification log entry in the incident work order and in the Chapter 4 checklist.

NRS 603A.220 Breach Notifications: Notifications to affected individuals and the public regarding a breach of personal information. Authorized issuer: the IT Director. Approval authority: the IT Director following legal review in accordance with Section 6.8. Documentation: breach notification record in the incident work order.

External Partner Engagement Communications: Communications with the MS-ISAC, NV-ISAC, FBI, Nevada DPS, or other external entities for threat intelligence, incident coordination, or law enforcement referral. Authorized issuer: the IT Director, or a delegate authorized under **Policy 1.08** for threat intelligence and incident coordination categories only. Approval authority: the IT Director. Documentation: incident work order within four (4) hours of the communication.

Technical Coordination and Vendor Communications: Operational and technical communications with vendors, service providers, or managed service partners necessary to resolve the incident. Authorized issuer: any Information Operations personnel, subject to the restrictions in Section 6.7. Approval authority: post-hoc IC notification required per Section 6.7; no advance approval required within permitted scope. Documentation: incident work order within four (4) hours.

Media and Public Communications: Any statement, press release, social media post, or response to media inquiry regarding a cybersecurity incident. Authorized issuer: the IT Director exclusively. Approval authority: the IT Director following legal review in accordance with Section 6.8. Documentation: incident work order at the time of issuance.

Post-Incident and Post-Handback Communications: Communications issued after Operational Handback, including incident closure notifications, postmortem distribution, and lessons-learned summaries. Authorized issuer: the IT Director. Approval authority: none required. Documentation: incident work order at the time of issuance.

6.3 Internal and Executive Communications

Internal Status Updates: The IC shall determine the appropriate cadence for internal status updates based on incident severity, operational tempo, and response activity. The IC shall ensure that internal status updates are issued no less frequently than once per twenty-four (24) hour operational period during an active incident. The IC may increase the cadence at any time. The IC shall ensure that all internal status updates are documented in the incident work order in accordance with Section 6.11. The IC shall ensure that status updates include, at minimum, the current incident status, actions completed since the last update, actions planned, and any changes to severity classification or scope.

County Manager Notification: The IT Director shall notify the County Manager of the following events. The IT Director shall issue each notification within four (4) hours of the triggering event.

- Declaration of a cybersecurity incident.
- Any change in severity classification following declaration.
- Confirmation or documented basis to suspect CJI involvement.
- Confirmation or documented basis to suspect a breach involving personal information.
- Initiation of law enforcement referral.
- Initiation of NRS 603A.220 breach notification.
- Declaration of Operational Handback.

The IT Director shall document each County Manager notification in the incident work order at the time of issuance, including the method of delivery and the substance of the notification.

6.4 CJIS IR-6 Part (b) External Notification Execution

The CJIS Security Policy establishes a two-part incident reporting obligation. Part (a) — the one-hour internal reporting clock — is governed by **Policy 4.02**. This section governs the operational execution of Part (b) — the external notification to the CSO, the SIB Chief, or the Interface Agency Official.

Handoff from Policy 4.02: Upon incident declaration where CJI involvement is confirmed or cannot be ruled out at triage, **Policy 4.02** initiates the handoff to this policy for external notification execution. **Policy 4.02** owns the obligation trigger and the CJIS notification log entry documenting that handoff. This policy owns the execution mechanics from the point of handoff forward.

Notification Windows: The notification windows established in **Policy 4.02** govern the maximum time permitted from declaration to external notification execution. Those windows are consumed by this policy without modification. All notification windows are measured in continuous calendar hours. No business-hours qualification applies, and no after-hours exception applies.

Execution: The IT Director (as LASO) shall execute the external notification by contacting the CSO, the SIB Chief, or the Interface Agency Official using the contact information maintained in the incident response contact directory defined in Section 6.12. The IT Director (as LASO) shall include in the notification, at minimum, the date and time of incident declaration, the nature of the incident as classified under **Policy 4.02**, and the current status of CJI involvement.

The IT Director (as LASO) may delegate execution of the notification to a designee authorized under **Policy 1.08**. Delegation of execution does not transfer LASO accountability for the notification obligation.

Documentation: The IT Director (as LASO) or designee shall document the following in the incident work order and the Chapter 4 checklist immediately upon completion of the notification: the date and time of the notification, the individual contacted, the method of contact, the substance of the notification, and the name of the person who executed the notification.

Policy 5.05 CJIS Denial Notifications: When the IT Director determines under **Policy 5.05** that denial or revocation of authorization for a system processing CJI warrants partner notification, the IT Director (as LASO) shall execute the notification through the same CJIS notification mechanics defined in this section. The IT Director (as LASO) shall document the notification in the authorization decision record maintained under **Policy 5.05**.

6.5 NRS 603A.220 Breach Notification

NRS 603A.220 requires notification to affected individuals following discovery of a breach of personal information. The statute directs that disclosure be made "in the most expedient time possible and without unreasonable delay." This section establishes the Department's internal performance standards that operationalize that statutory obligation with measurable timelines.

Breach Determination: The IT Director shall render a formal breach determination within twenty-four (24) hours of the IC confirming that conditions meeting the statutory definition of a breach under NRS 603A.220 have been identified. A formal breach determination is a documented finding, rendered by the IT Director on the basis of the evidence available at the time, that personal information has been acquired by an unauthorized person or that acquisition is supported by one (1) or more of the following indicators:

- Direct evidence of unauthorized access to a system, account, or data store containing personal information, including but not limited to authenticated session records, access logs, or forensic artifacts showing read, copy, or export activity.
- Evidence of exfiltration, including but not limited to outbound network transfers to unauthorized destinations, staged data repositories, or confirmed data transmission to a threat actor.
- Unauthorized acquisition of physical media or devices known to contain personal information.
- Credential compromise combined with authentication records showing successful access to systems containing personal information.

- Threat actor communications, including ransom demands or extortion messages, referencing specific personal information held by the County.

The IT Director shall document in the incident work order and the Chapter 4 checklist: the specific indicators relied upon, the evidence supporting each indicator, the categories of personal information affected, and the basis for the determination. Absence of an indicator on this list does not preclude a breach determination when the totality of evidence supports the finding; the IT Director shall document the alternative basis in that case.

When IC authority has been delegated under **Policy 1.08**, the delegate shall escalate any condition that may constitute a breach to the IT Director immediately upon identification. The IT Director shall retain sole authority over the breach determination regardless of IC delegation status. This constraint operates in addition to the Directed Deputization non-delegable list in **Policy 1.08**.

Notification Preparation: The IT Director shall ensure that a draft breach notification is prepared within forty-eight (48) hours of the breach determination. The Assistant IT Director shall include in the draft, at minimum, the nature of the breach in general terms, the categories of personal information affected, the approximate date of the breach, a description of actions taken by the Department in response, and contact information for affected individuals to obtain further information.

Legal Review: The IT Director shall submit the draft breach notification to the District Attorney's Office for legal review prior to issuance in accordance with the mandatory routing requirements in Section 6.8.

Issuance Timeline: The IT Director shall issue the breach notification to affected individuals within five (5) business days of the breach determination, or upon completion of the District Attorney's Office legal review, whichever is later. Under no circumstance shall the IT Director issue breach notification later than ten (10) business days from the date of the breach determination. These timelines are ECIO internal performance standards and do not override any delay expressly permitted by NRS 603A.220, including a law enforcement determination under NRS 603A.220(3) that notification would impede a criminal investigation. When a law enforcement hold is in effect, the IT Director shall document the hold in the incident work order and shall issue the breach notification after the law enforcement agency determines that notification will not compromise the investigation.

Method of Notification: The IT Director shall deliver notification by written notice sent to the most recent address on file for each affected individual, or by electronic notice if the affected individual has consented to electronic communication, consistent with NRS 603A.220. If the cost of providing individual notice exceeds two hundred fifty thousand dollars ($250,000), or the affected class exceeds five hundred thousand (500,000) persons, or the Department does not have sufficient contact information, the IT Director shall provide substitute notice in accordance with the substitute notice provisions of NRS 603A.220.

Documentation: The IT Director shall document the following in the incident work order: the breach determination and its basis, the date the draft notification was prepared, the date the draft was submitted for legal review, the date legal review was completed, the date notification was issued, the method of notification, the number of individuals notified, and the categories of personal information affected.

6.6 External Partner Engagement Framework

The ECIO maintains relationships with external entities that provide threat intelligence, incident coordination resources, and law enforcement support during cybersecurity incidents. All external partner engagement during an active incident shall require IC authorization and shall be executed within the One Voice Rule and communication authorization framework established in Section 6.1. The IC shall authorize partner engagement based on the functional category of support required.

Threat Intelligence Support: The IC may initiate contact with the Multi-State Information Sharing and Analysis Center (MS-ISAC) or the Nevada Information Sharing and Analysis Center (NV-ISAC) to request threat intelligence, indicator sharing, or analytical support relevant to the incident. The IC may delegate initiation of threat intelligence requests to a designee authorized under **Policy 1.08**. The IC or designee shall limit information shared with threat intelligence partners to the technical indicators and environmental

context necessary to support the request. The IC or designee shall not share organizational identifiers, PII, or CJI with threat intelligence partners without explicit IT Director authorization and compliance with the data handling requirements established in **Policy 1.11**.

Incident Coordination: The IC may request incident coordination support from the MS-ISAC, NV-ISAC, or other entities with relevant capability when the scope or complexity of an incident exceeds internal capacity. The IT Director shall authorize incident coordination engagement. The IT Director shall define the scope of information authorized for sharing with the coordinating entity at the time of engagement.

Law Enforcement Referral: The IT Director shall determine whether an incident warrants law enforcement referral to the Federal Bureau of Investigation (FBI) or the Nevada Department of Public Safety (DPS). The IT Director shall make law enforcement referral decisions personally. The IT Director shall not delegate law enforcement referral authority. The IT Director shall ensure that the communication is routed through the District Attorney's Office in accordance with Section 6.8 prior to initiating law enforcement referral. The IT Director shall document the referral decision, the basis for the decision, and the date and substance of any law enforcement contact in the incident work order.

Documentation: The IC or designee shall document all external partner communications in the incident work order within four (4) hours of the communication. The documentation shall include the date and time, the partner entity contacted, the individual contacted, the method of contact, the substance of the communication, and the scope of information shared.

6.7 Technical Coordination and Vendor Communication

The One Voice Rule shall not prohibit technical staff from communicating operational and technical details to vendors, service providers, or managed service partners when necessary to resolve an active incident. This carve-out is subject to the following guardrails.

Permitted Scope: Technical coordination communications shall be limited to the technical actions required to resolve the immediate condition. Technical staff may describe symptoms, share log data, request vendor support actions, and coordinate remediation steps within the scope of the vendor's service responsibility.

Restricted Topics During Breach: During a confirmed or suspected breach involving personal information or Criminal Justice Information (CJI), Information Operations personnel shall not discuss the following topics with vendors or external parties without explicit IC authorization: the scope or magnitude of the breach, the nature or volume of affected data, PII or CJI involvement or exposure, incident attribution or suspected threat actor identity, and any information that could affect the Department's legal position.

IC Notification: Information Operations personnel who initiate external technical communication during an active incident shall notify the IC within one (1) hour of the initiation of the communication. The notifying personnel shall include in the notification the vendor or partner contacted, the purpose of the communication, and a summary of information shared.

Documentation: Information Operations personnel shall summarize all technical coordination communications in the incident work order within four (4) hours of the communication. The summary shall include the date and time, the vendor or partner contacted, the technical substance discussed, and any actions requested or committed.

Data Handling: All technical coordination communications shall comply with the data classification and handling requirements established in **Policy 1.11**. Information Operations personnel shall not transmit restricted data via unencrypted channels.

6.8 Legal Review Routing

The IT Director shall submit the following categories of incident-related communications to the District Attorney's Office for legal review prior to issuance. Submission to the District Attorney's Office does not transfer communication authority; the IT Director retains authorization authority over all communications under this policy.

Mandatory Legal Review Triggers:

- All NRS 603A.220 breach notifications to affected individuals or the public.
- All media and public communications regarding a cybersecurity incident.
- All communications to regulatory bodies outside the CJIS notification chain, including state agencies, the Attorney General's Office, or other regulatory authorities.
- All communications associated with an incident where law enforcement referral is being considered or has occurred.

CJIS Notification Exclusion: CJIS IR-6 Part (b) notifications to the CSO, SIB Chief, or Interface Agency Official shall not require District Attorney's Office review prior to issuance. These notifications are a compliance obligation with defined notification windows, and inserting additional review steps could jeopardize execution within the notification windows established in **Policy 4.02**.

Submission: The IT Director shall submit the draft communication to the District Attorney's Office with a summary of the incident context, the communication type, and the urgency of issuance. The IT Director shall document the date and time of submission in the incident work order.

Completion: Upon receipt of the District Attorney's Office review, the IT Director shall incorporate any required modifications. The IT Director shall document the completion of legal review in the incident work order, including the date of completion and a summary of any modifications made.

Escalation for Non-Response: If the District Attorney's Office does not respond within three (3) business days of submission for a breach notification review under Section 6.5, the IT Director shall escalate the non-response to the County Manager and shall proceed with issuance of the original draft notification within the ten (10) business day ceiling established in Section 6.5. The IT Director shall document the escalation, the absence of completed legal review, and the basis for proceeding in the incident work order.

6.9 Media and Public Communications

The IT Director shall serve as the sole authorized spokesperson for all media and public communications regarding a cybersecurity incident. The IT Director shall not delegate media or public communication authority.

The IT Director shall not issue any media or public communication without prior legal review in accordance with Section 6.8.

No Information Operations personnel shall respond to media inquiries, issue public statements, post to social media, or otherwise communicate with the public regarding a cybersecurity incident without the IT Director's explicit written authorization.

The IT Director shall ensure that media and public communications do not include speculation regarding incident cause, attribution, scope, or data compromise. The IT Director shall limit such communications to confirmed facts that have been reviewed and authorized for public release.

The IT Director shall coordinate media and public communications with the County Manager prior to issuance. The IT Director shall provide the County Manager, at minimum, advance notice of the communication content and timing.

6.10 Post-Incident and Post-Handback Communications

Upon declaration of Operational Handback under **Policy 4.05** (Recovery Operations and Restoration Prioritization), the IT Director shall issue the following post-incident communications.

Incident Closure Notification: The IT Director shall notify the County Manager and any previously notified stakeholders that the incident has been closed and Operational Handback has been completed.

Postmortem Data Consolidation: The Assistant IT Director shall compile all communication records produced under this policy — including internal status updates, external notifications, partner engagement documentation, legal review records, and media communications — and shall prepare the compiled records for inclusion in the postmortem under **Policy 4.07**. The Assistant IT Director shall include all pertinent communication data, regardless of source, in both the internal and external postmortem reports. The Assistant IT Director shall apply data protection controls appropriate to the classification of the information under **Policy 1.11** to the postmortem record. The Assistant IT Director shall handle PII, CJI, and restricted data in accordance with the applicable data protection requirements, including redaction where necessary to protect affected individuals in externally distributed postmortem materials.

CJIS Closure Notification: If CJIS IR-6 Part (b) external notification was executed during the incident, the IT Director (as LASO) shall notify the CSO, SIB Chief, or Interface Agency Official of incident closure. The IT Director (as LASO) shall include in the closure notification the date of Operational Handback and a summary of the incident outcome.

6.11 Communication Documentation and Data Protection

Documentation Standard: The IC shall ensure that all incident-related communications produced under this policy are documented in the incident work order maintained in the System of Engagement. The documentation timeframe for each communication type is specified in Section 6.2. Where a communication type specifies documentation "at the time of issuance," the responsible personnel shall enter the documentation into the work order before the end of the business day on which the communication was issued, or by 10:00 AM on the following business day if the communication was issued within the final two (2) hours of the business day.

Verbal and Informal Communications: Information Operations personnel shall summarize verbal or informal communications — including phone calls, hallway conversations, and instant messages — that pertain to an active cybersecurity incident and shall enter the summary into the incident work order within four (4) hours of the communication. This four-hour standard supersedes the one (1) business day standard established in **Policy 3.03** for non-incident operations for the duration of active incident response.

Privileged Communications: Communications subject to attorney-client privilege — including the substance of legal review exchanges with the District Attorney's Office — shall not be documented in the System of Engagement work order. The IC shall record only metadata in the work order: the date of submission, the date of completion, and the fact that legal review occurred. The District Attorney's Office shall retain privileged substance under its own direction and in accordance with its own records management obligations. This carve-out does not exempt the IT Director from documenting the outcome of legal review (modifications made, approval to proceed) in the work order; it protects only the privileged substance of the attorney-client exchange itself.

Private Note Usage: The Private Note constraints established in **Policy 3.03** apply to incident work order documentation under this policy. Information Operations personnel shall use Private Notes only for the authorized purposes defined in that section.

Data Classification Compliance: All incident-related communications shall comply with the data classification and handling requirements established in **Policy 1.11**. Information Operations personnel shall not transmit restricted data — including PII, CJI, and security vulnerability details — via unencrypted email, public file shares, or other unprotected channels.

Public Records Awareness: Information Operations personnel shall compose incident-related written communications with the awareness that such records may be subject to disclosure under NRS 239 (Public Records), unless protected by a specific statutory exemption or confidentiality requirement. This awareness requirement is established at the governance level in **Policy 1.14** and is restated here for external readers.

6.12 Incident Response Contact Directory

The IT Director shall ensure that the Department maintains an incident response contact directory — a living reference document that identifies current personnel assigned to incident response roles, their contact

information, and the escalation sequence to be followed during an active incident.

Required Contact Categories: The Administrative Assistant shall ensure that the contact directory includes, at minimum, the following categories:

- IT Department personnel with incident response role assignments, including the IT Director, Assistant IT Director, and all personnel authorized to serve as Incident Commander.
- County Manager and administrative leadership contacts for executive notification.
- District Attorney's Office contact for legal review routing.
- Elko County Emergency Manager contact for coordination during incidents affecting county-wide operations.
- CJIS notification contacts: the CSO, the SIB Chief, and the Interface Agency Official.
- External partner contacts: the MS-ISAC, the NV-ISAC, the FBI field office, and the Nevada DPS point of contact.
- Vendor and managed service provider emergency contacts for Tier 1 Mission Critical services and Security Infrastructure as classified under **Policy 3.15** (Service Continuity and Contingency Planning Policy).
- Media and public affairs contacts, including the County's designated media liaison if applicable.

Operational Maintenance: The Administrative Assistant shall maintain the contact directory as a governed Knowledge Base artifact in the System of Engagement in accordance with **Policy 3.13**. The actual contact details are operational data and shall not appear in this policy.

Physical Copy Distribution: The Administrative Assistant shall maintain current physical copies of the contact directory at distribution points designated by the IT Director, including at minimum the IT Department and locations accessible to the County Manager and County Emergency Manager when the System of Engagement is unavailable. The incident response contact directory is designated for physical distribution to ensure accessibility during an active incident when electronic systems may be compromised or unavailable. This requirement is established by this policy.

Validation Cadence: The Administrative Assistant shall prepare annual validation data for the contact directory, confirming that all listed personnel remain in their assigned roles, that contact information is current, and that the escalation sequence reflects the current organizational structure. The IT Director shall review the validation data and render the annual validation determination.

Immediate Update Obligation: The Administrative Assistant shall update the contact directory within one (1) business day of any personnel change affecting an IR role assignment. Personnel changes include new hires, separations, role transfers, and changes to contact information.

IC Designation Records: Incident Commander designation records created during an active incident shall be maintained separately from the contact directory, in the incident record at the time of designation, in accordance with **Policy 4.01**. The contact directory identifies personnel eligible for IC designation; the incident record documents who was actually designated for a specific incident.

6.13 Communication Record Retention

Communication records produced under this policy — including work order documentation of all communication types defined in Section 6.2, CJIS notification log entries, breach notification records, external partner communication logs, legal review submission and completion records, and media communication records — shall be retained for three (3) calendar years from the end of the calendar year in which the incident was closed. This retention period is consistent with LRDA 20071728 (IT Security Audit Records) and exceeds the CJIS AU-11 one-year minimum for audit records.

Communication records that form part of the incident record maintained under **Policy 4.02** shall be retained in accordance with the retention requirements established in that policy. Where this policy and **Policy 4.02** establish different retention periods for the same record, the longer retention period shall govern.

4.07 Postmortem Review and Lessons Learned

Effective: April 29, 2026 Version: 1.1

1. Purpose

This policy governs the mandatory postmortem review process conducted following every cybersecurity incident declared under Chapter 4 authority.

2. Scope

This policy applies to all Information Operations Department personnel who participated in or supported cybersecurity incident response operations, and to the IT Director and Assistant IT Director in their governance roles over the postmortem review process.

- **In Scope**:
  - Mandatory postmortem trigger and completion timeline.
  - Postmortem leadership assignment and separation of duties.
  - Postmortem meeting requirements.
  - Internal postmortem report content requirements, including the reconstructed incident timeline with Known and Suspected markers.
  - External (redacted) postmortem derivative preparation and distribution.
  - Findings classification and routing to existing remediation and improvement pipelines.
  - Draft findings preservation requirements.
  - Postmortem report retention.
- **Out of Scope**:
  - IoC evaluation and incident declaration: **Policy 4.02**.
  - Containment strategy selection and execution: **Policy 4.03**.
  - Eradication procedures and eradication-complete determination: **Policy 4.04**.
  - Recovery operations and Operational Handback initiation mechanics: **Policy 4.05**.
  - Communication execution and external notification mechanics: **Policy 4.06**.
  - CI record governance: **Policy 3.08**.
  - Change categorization and RFC governance: **Policy 3.09**.
  - Risk Register maintenance and risk assessment methodology: **Policy 1.09**.
  - Corrective Action Plan lifecycle: **Policy 5.03**.
  - Service improvement intake and triage: **Policy 3.16**.
  - Problem Management root cause investigation for operational findings: **Policy 3.07**.
  - Knowledge Base artifact governance: **Policy 3.13**.
  - IT project post-mortems: **Policy 3.14**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall ensure that a postmortem review is initiated for every cybersecurity incident declared under Chapter 4 authority.
  - Shall assign the Postmortem Lead in accordance with the separation of duties requirements defined in Section 6.2.
  - Shall serve as Postmortem Lead when the Incident Commander for the incident was not the IT Director.
  - Shall serve as a mandatory participant in the postmortem meeting when the Assistant IT Director serves as Postmortem Lead.
  - Shall review and approve the completed internal postmortem report.
  - Shall review and approve the external (redacted) postmortem derivative prior to distribution.
  - Shall route postmortem findings to the appropriate remediation and improvement pipelines in accordance with Section 6.6.
  - Shall determine whether operational findings from the postmortem warrant opening a **Policy 3.07** (Problem Management Policy) Problem record, in accordance with the jurisdictional boundary established in Section 6.7.
  - Shall ensure that the Incident Commander for the reviewed incident — the IT Director or designee as designated under **Policy 4.01** (Incident Response Policy Overview) — participates in the postmortem meeting as a mandatory attendee.
  - Shall ensure that the Incident Commander provides the Postmortem Lead with a written summary of key response decisions, rationale, and observations prior to or during the postmortem meeting.
  - Shall retain postmortem report approval, exception authorization under Section 4, and findings routing disposition under Section 6.6 as non-transferable IT Director functions that shall not pass to a designee serving as Incident Commander.
  - Shall authorize formal exceptions to this policy in accordance with the exception management framework established in **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Assistant IT Director:**
  - Shall serve as Postmortem Lead when the Incident Commander for the incident was the IT Director, in accordance with Section 6.2.
  - Shall compile the communication data package prepared under **Policy 4.06** (Communication Protocols and Partner Integration) and shall ensure its inclusion in the internal postmortem report.
  - Shall compile all source documentation from the incident work order, Chapter 4 checklist, and related records in preparation for the postmortem meeting.
  - Shall prepare the external (redacted) postmortem derivative in accordance with Section 6.5.
  - Shall preserve the Postmortem Lead's draft findings as a permanent attachment to the postmortem record in accordance with Section 6.4.
  - Shall maintain postmortem records in the System of Engagement in accordance with Section 6.8.
- **All Information Operations Personnel:**

  - Shall attend the postmortem meeting unless excused by the Postmortem Lead.
  - Shall provide factual input regarding response actions taken, observations made, and difficulties encountered during the incident.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations Department personnel involved in or supporting cybersecurity incident response.

- **Assessment**: Adherence to postmortem initiation, completion timelines, report content requirements, findings routing obligations, and retention requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: The following conditions constitute specific non-compliance with this policy. Non-compliance may result in corrective action in accordance with **Policy 5.01**.
  - Failure to initiate a postmortem review for a declared cybersecurity incident.
  - Failure to complete the internal postmortem report within the timeline established in Section 6.3.
  - Failure to preserve the Postmortem Lead's draft findings as required by Section 6.4.
  - Failure to prepare the external postmortem derivative within the timeline established in Section 6.5.
  - Failure to route actionable findings in accordance with Section 6.6.
  - Failure to maintain postmortem records in accordance with Section 6.8.
- **Exceptions**: Exceptions to this policy require written approval from the IT Director in accordance with the exception management framework established in **Policy 5.01**. No open-ended exceptions are permitted. All approved exceptions shall be documented and time-bounded. Oral exceptions are not valid.
  - **Constraint**: The following obligations constitute a non-waivable floor and shall not be reduced or eliminated by any approved exception: the mandatory postmortem trigger (Section 6.1), the separation of duties requirement (Section 6.2), the draft findings preservation requirement (Section 6.4), and the retention obligations (Section 6.8). No exception may permit the Incident Commander for an incident to serve as Postmortem Lead for that same incident.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.06: Operational Incident Management Policy
- ECIO Policy 3.07: Problem Management Policy
- ECIO Policy 3.08: Service Configuration Management (CMDB) Policy
- ECIO Policy 3.09: Change Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan

- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.03: Containment Strategy and Playbooks
- ECIO Policy 4.04: Eradication Procedures and Scenario Guides
- ECIO Policy 4.05: Recovery Operations and Restoration Prioritization
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071728 (IT Security Audit Records)
- NIST CSF 2.0: ID.IM-01 (Improvements Identified from Evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements Identified from Execution of Operational Processes)
- NIST SP 800-53 Rev. 5: IR-4 (Incident Handling)

Framework Alignment:

- CJIS Security Policy v6.0: Section IR-1 (Incident Response Policy and Procedures)
- CJIS Security Policy v6.0: Section IR-4 (Incident Handling)
- CJIS Security Policy v6.0: Section IR-8 (Incident Response Plan)
- NIST CSF 2.0: RS.AN-03 (Incident Analysis and Root Cause)
- NIST SP 800-53 Rev. 5: IR-1 (Incident Response Policy and Procedures)
- NIST SP 800-53 Rev. 5: IR-8 (Incident Response Plan)
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management
- COBIT 2019: DSS02 (Managed Service Requests and Incidents)
- COBIT 2019: DSS03 (Managed Problems)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Problem Management Practice

6. Policy Statement

This policy is written to serve two audiences simultaneously: ECIO personnel and internal auditors who read it within the full context of the ECIO Policy Manual, and external reviewers — including the Nevada state cyber defense office — who may review it as a standalone document. Where this policy references concepts, roles, or procedures whose authoritative definitions reside in other policies, it states the operative substance in plain language sufficient for an external reader and cites the authoritative source. Those plain-language statements are incorporative and do not constitute independent definitions.

The postmortem review is the Lessons Learned phase of the ECIO cybersecurity incident response lifecycle. Its purpose is to produce a structured, documented assessment of the Department's response to a cybersecurity incident — what happened, what worked, what failed, and what must change. Postmortem findings feed back into the Department's governance, risk, and improvement frameworks to strengthen the Department's posture for the next incident. This feedback loop implements NIST SP 800-53 Rev. 5: IR-4

(Incident Handling), which requires that lessons learned from ongoing incident handling activities be incorporated into incident response procedures, training, and testing, and aligns with NIST CSF 2.0: ID.IM-01 (Improvements Identified from Evaluations) and NIST CSF 2.0: ID.IM-03 (Improvements Identified from Execution of Operational Processes).

This policy is distinct from the Problem Management process governed by **Policy 3.07** (Problem Management Policy), which applies to operational incidents. Cybersecurity incident postmortems are exclusively governed by this policy. The jurisdictional boundary between the two is addressed in Section 6.7.

6.1 Mandatory Postmortem Trigger

Every cybersecurity incident declared under Chapter 4 authority shall receive a postmortem review under this policy. There are no severity-based exclusions and no deferral provisions. An incident that warranted declaration warrants documentation of how the Department responded.

The Incident Commander shall trigger the postmortem review as a precondition of Operational Handback under **Policy 4.05** (Recovery Operations and Restoration Prioritization). The trigger shall be documented in the incident work order Notes and the Chapter 4 checklist at the time it is made.

6.2 Postmortem Leadership and Separation of Duties

The person who commanded the incident response shall not lead the review of that response. This separation ensures that the postmortem review is conducted with independence from the operational decisions under examination.

- **When the Incident Commander was the IT Director**: The Assistant IT Director shall serve as Postmortem Lead. The IT Director shall participate in the postmortem meeting as a mandatory attendee. The IT Director retains final approval authority over the completed internal postmortem report, but shall not direct the investigation, suppress findings, or direct modifications to the Postmortem Lead's factual findings. The IT Director may add a written response or addendum to the final report.
- **When the Incident Commander was not the IT Director**: The IT Director shall serve as Postmortem Lead. The Incident Commander shall participate in the postmortem meeting as a mandatory attendee.

The Postmortem Lead shall schedule the postmortem meeting, conducting the structured review, preparing the internal postmortem report, and presenting findings and recommended routing dispositions to the IT Director for approval.

6.3 Postmortem Meeting and Completion Timeline

- **Postmortem Meeting**: The Postmortem Lead shall convene the postmortem meeting within five (5) business days of the Operational Handback declaration. The meeting is a structured debrief conducted while operational memory is fresh. All Information Operations personnel who participated in the incident response shall attend unless excused by the Postmortem Lead. The Postmortem Lead shall document attendance.
- **Internal Postmortem Report**: The Postmortem Lead shall complete the internal postmortem report within ten (10) business days of the Operational Handback declaration. The IT Director shall review and approve the completed report. IT Director approval constitutes finalization of the internal report.
- **External Postmortem Derivative**: The Assistant IT Director shall prepare the external (redacted) postmortem derivative within five (5) business days of IT Director approval of the internal report. The IT Director shall review and approve the external derivative prior to any distribution.

6.4 Internal Postmortem Report Content

The internal postmortem report is the authoritative record of the Department's review of its response to a cybersecurity incident. The report shall be documented in the System of Engagement and shall include, at minimum, the following content:

- **Incident Summary**: Incident type (Layer 1 category), severity classification, CJI involvement determination, declaration authority and declaring party, Incident Commander designation, and a narrative description of the incident.
- **Reconstructed Incident Timeline**: A chronological reconstruction of the incident from initial detection or report through Operational Handback. Each timeline entry shall be marked as **Known** (confirmed by evidence — system logs, work order timestamps, forensic captures, or other documentary evidence) or **Suspected** (assessed based on professional judgment where contemporaneous technical evidence — system logs, forensic captures, or work order timestamps — is unavailable, incomplete, or inconclusive). The Known/Suspected distinction shall be applied at the entry level, not as a blanket classification for the timeline as a whole.
- **Communication Record**: The communication data package compiled by the Assistant IT Director under **Policy 4.06**, including internal status updates, external notifications, partner engagement records, legal review metadata, and media communications. Data protection controls appropriate to the classification of the information under **Policy 1.11** (Data Governance and Classification Policy) shall be applied to the communication record within the postmortem report.
- **False Positive Documentation**: When a false positive determination was made during the incident under **Policy 4.04** (Eradication Procedures and Scenario Guides), including any documentation of the justification for original eradication actions, the Postmortem Lead shall incorporate that documentation into the report.
- **Root Cause Analysis**: The Postmortem Lead's assessment of the root cause of the incident. Where root cause cannot be determined, the report shall state the basis for the indetermination and identify any investigative avenues that remain open. Root cause analysis in this context addresses why the incident occurred and why it was not prevented or detected sooner. It does not replace the operational root cause investigation function governed by **Policy 3.07** for service failures.
- **Phase-by-Phase Review**: A structured assessment of the Department's performance across each lifecycle phase that was activated during the incident (Identification, Containment, Eradication, Recovery, and Communication). For each phase, the Postmortem Lead shall document what worked effectively, what did not work effectively, and specific observations or recommendations for improvement.
- **Findings and Routing Dispositions**: Each actionable finding shall be documented with a recommended routing disposition in accordance with Section 6.6. The IT Director shall approve the routing disposition for each finding.
- **Postmortem Meeting Attendance Record**: A record of all personnel who attended the postmortem meeting.

Draft Findings Preservation: The Postmortem Lead's draft findings — including draft routing recommendations, working notes, and the draft report — shall be preserved as a permanent attachment to the postmortem record in the System of Engagement. The draft attachment shall not be modified after the IT Director approves the final internal report. This preservation requirement applies regardless of whether the IT Director modifies, supplements, or adds an addendum to the final report. The System of Engagement revision history provides the system-generated, tamper-evident audit trail confirming the sequence of drafts and approvals.

6.5 External (Redacted) Postmortem Derivative

The external postmortem derivative is a controlled derivative of the internal postmortem report, prepared for distribution to audiences outside the Department — including the County Manager, external partners, and oversight bodies when the IT Director determines distribution is warranted. The external derivative is not an independent document; its factual content shall be consistent with the approved internal report.

The Assistant IT Director shall prepare the external derivative by redacting the following categories of information from the internal report:

- Personally Identifiable Information (PII) of affected individuals, in accordance with **Policy 1.11**.
- Criminal Justice Information (CJI), in accordance with the CJIS Security Policy and **Policy 1.11**.
- Privileged legal communications and attorney-client information, consistent with the metadata-only documentation standard established in **Policy 4.06**.
- Architectural details, network topology, security tool configurations, and other technical information whose disclosure could expose the Department's security posture.
- Internal personnel performance observations and disciplinary references.

The IT Director shall review and approve the external derivative prior to any distribution. Distribution of the external derivative shall occur through the communication authority structure established in **Policy 4.06**. When the external derivative contains information related to CJI involvement, breach determination, or other legally sensitive content, the IT Director shall route the derivative through legal review in accordance with **Policy 4.06** prior to distribution. Distribution of the external derivative constitutes a Post-Incident and Post-Handback Communication as defined in **Policy 4.06** and shall be documented in the incident work order.

6.6 Findings Routing

The Postmortem Lead shall classify each actionable finding and recommend a routing disposition. The IT Director shall approve the routing disposition for each finding. This policy does not create parallel remediation trackers, improvement registers, or corrective action mechanisms. All findings route through the existing governance pipelines established in the ECIO Policy Manual.

- **Risk Register (Policy 1.09)**: Control failures, compliance gaps, and risk posture changes identified through the postmortem shall be routed to the Risk Register maintained under **Policy 1.09** (Risk Management Policy). The existing Risk Register-to-Corrective Action Plan pipeline under **Policy 5.03** (Compliance Monitoring and Corrective Action) governs subsequent remediation.
- **Service Improvement Register (Policy 3.16)**: Improvement opportunities that are not control failures or compliance gaps — process refinements, efficiency gains, coordination improvements, and other enhancements that would strengthen future response — shall be routed to the Service Improvement Register under **Policy 3.16** (Service Improvement and Continual Improvement Plan). The existing triage and routing process under **Policy 3.16** governs subsequent execution.
- **IoC List Maintenance (Policy 4.02)**: Indicator updates identified through postmortem analysis — including new indicators observed during the incident that are not yet reflected in the Layer 2 IoC list, and existing indicators whose classification or relevance should be adjusted — shall be routed to the Assistant IT Director for Layer 2 maintenance under **Policy 4.02** (Identification and Reporting Procedures).
- **Knowledge Base (Policy 3.13)**: Playbook updates, procedural corrections, and documentation improvements surfaced by the postmortem shall be routed to the Knowledge Base governance process under **Policy 3.13** (Knowledge Management Policy). The Assistant IT Director shall execute playbook updates under standing maintenance authority established in **Policy 4.03** (Containment Strategy and Playbooks).

A single finding may route to more than one pipeline when the finding has both a remediation component and an improvement component. The IT Director shall approve multi-pipeline routing at the time of disposition.

6.7 Relationship to Policy 3.07 — Jurisdictional Boundary

This policy governs cybersecurity incident postmortems. **Policy 3.07** governs operational incident root cause investigation. These are distinct instruments with distinct purposes, and one shall not be substituted for the other.

Where a Chapter 4 cybersecurity incident also generates operational findings that warrant a formal Problem investigation under **Policy 3.07**, the IT Director shall determine whether a **Policy 3.07** Problem record is appropriate and shall authorize its opening in accordance with **Policy 3.07**. That determination is an IT Director governance decision; it is not a mechanical output of the postmortem process. This policy does not open **Policy 3.07** Problem records.

Policy 3.06 (Operational Incident Management Policy) establishes the Critical Incident Stakeholder Report as the formal reporting instrument for Critical severity operational incidents. That instrument is distinct from this policy's cybersecurity postmortem and the two are not interchangeable. The stakeholder report governs operational accountability reporting; this policy governs cybersecurity incident lessons learned.

6.8 Retention

Internal postmortem reports, external postmortem derivatives, draft findings attachments, postmortem meeting attendance records, and all supporting documentation produced under this policy shall be retained in the System of Engagement for a minimum of three (3) calendar years from the end of the calendar year in which the Operational Handback was declared, in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule: LRDA 20071728 (IT Security Audit Records). Where multiple retention requirements apply, the longest applicable period shall govern. The IT Director shall ensure that postmortem records are not disposed of during any active litigation hold, public records preservation requirement, audit, or other legal hold event.

5. Compliance and Oversight

5.01 Policy Implementation, Enforcement, and Legal Alignment

Effective: April 30, 2026 Version: 2.0

1. Purpose

This policy establishes the enforcement framework, corrective action authority, formal sanctions process, legal and regulatory alignment mechanism, exception governance, and record retention requirements that operationalize the Elko County Information Operations Policy Manual.

2. Scope

This policy applies to all personnel, systems, and entities subject to the ECIO Policy Manual, including Information Operations personnel, non-IT County employees, appointed and elected officials, and contractors and vendors who access, administer, or support County information systems, infrastructure, or data governed by the Information Operations Department.

- **In Scope**:
  - Enforcement authority and IT-administrative corrective actions.
  - Formal sanctions process and Criminal Justice Information Services (CJIS) notification requirements.
  - Policy implementation, dissemination, and acknowledgment tracking.
  - Legal and regulatory alignment.
  - Exception management.
  - Enforcement record retention.
- **Out of Scope**:
  - Policy review cadence and lifecycle management: **Policy 1.05**.
  - Service delivery grievances and dispute resolution for enforcement actions: **Policy 3.04**.
  - Internal audit procedures and control testing: **Policy 5.02**.
  - Vendor compliance and third-party assurance: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the enforcement authority for the ECIO Policy Manual across all population classes defined in Section 6.4.
  - Shall maintain independent authority over the County's information technology infrastructure, including the authority to take immediate system-level action to protect County assets, reduce liability, or manage operational and compliance risk.
  - Shall initiate IT-administrative corrective actions in accordance with Section 6.3.
  - Shall document enforcement decisions in the Department's system of record within twenty-four (24) hours of the action.

  - Shall refer matters to the appropriate personnel authority or legal process when the non-compliance warrants action beyond the IT Director's IT-administrative authority.
  - Shall serve as the Local Agency Security Officer (LASO) for CJIS notification purposes under the formal sanctions process defined in Section 6.5.
  - Shall maintain awareness of legal and regulatory changes affecting the manual and initiate event-driven reviews in accordance with **Policy 1.05** (Policy Review and Update Procedures).
  - Shall approve policy exceptions in accordance with the exception management framework defined in Section 6.6 and within delegated authority under **Policy 1.08** (Delegation of Authority and Decision Rights), except where this policy requires County Manager approval or where the exception exceeds delegated authority.
- **County Manager:**
  - Shall serve as the escalation authority for enforcement disputes that cannot be resolved at the IT Director level.
  - Shall receive written notification from the IT Director when IT-administrative enforcement actions are taken against appointed or elected officials.
  - Shall approve formal policy exceptions that exceed the IT Director's delegated authority in accordance with **Policy 1.08**.
- **Assistant IT Director:**
  - Shall approve operational exceptions within the parameters and notification requirements defined in Section 6.6.
- **Human Resources (HR):**
  - Shall serve as the process owner for personnel-disciplinary actions initiated through the applicable labor agreement, County Personnel Policies, or employment contract.
  - Shall receive referrals from the IT Director when IT-administrative corrective actions escalate to the personnel-disciplinary track.
  - Shall maintain sanctions documentation and personnel records in accordance with applicable retention requirements.
- **District Attorney's Office:**
  - Shall receive referrals from the IT Director when non-compliance involves suspected criminal activity, potential liability to the County, or circumstances requiring immediate legal guidance.
  - Shall determine next steps in coordination with HR when emergency protective actions are taken against appointed officials.
- **Department Heads:**
  - Shall receive written notification from the IT Director when IT-administrative enforcement actions are taken against personnel under their supervision.
  - Shall initiate personnel-disciplinary action through the applicable process when referred by the IT Director.
  - Shall direct disputes regarding IT enforcement actions through the service grievance pathway established in **Policy 3.04** (Service Delivery Feedback and Grievance Policy) or through the risk acceptance process established in **Policy 1.09** (Risk Management Policy) where the dispute concerns a compliance standard.
- **All County Personnel:**
  - Shall comply with the policies, standards, and procedures established in the ECIO Policy Manual.

  - Shall complete required policy acknowledgments within the timeframes defined in Section 6.2.
  - Shall cooperate with IT-administrative enforcement actions and investigations.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all personnel, entities, and systems within the scope of the ECIO Policy Manual.

- **Assessment**: Compliance with the enforcement, acknowledgment, and exception management requirements of this policy shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Non-compliance with the requirements of this policy — including failure to complete required acknowledgments, failure to cooperate with IT-administrative enforcement actions, or failure to document and route enforcement actions as required — shall be addressed through the corrective action framework defined in Section 6.3 of this policy.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the County Manager in accordance with **Policy 1.08**. Oral exceptions are not valid. Exceptions to this policy shall not be approved by the IT Director alone, as the IT Director is both the enforcement authority and a subject of this policy.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 2.01: Acceptable Use of Information Technology Resources Policy
- ECIO Policy 2.03: Security Awareness and Training Policy
- ECIO Policy 2.10: Secure Configuration Baselines and Hardening Policy
- ECIO Policy 3.04: Service Delivery Feedback and Grievance Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.01: Incident Response Policy Overview
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 205 (Computer Crimes)
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records Management Program)

- NRS 242.171 (Responsibilities of Office/Director)
- NRS 244 (Counties: Government)
- NRS 281A (Ethics in Government)
- NRS 603A (Security of Personal Information)
- NAC 239.155 (Adoption of Records Retention Schedule)
- LRDA 20070321 (Master Personnel File)
- LRDA 20071300 (Vendor Performance Case Files)
- LRDA 20121869 (Administrative Hearing Files)
- CJIS Security Policy v6.0: Section AC-7 (Unsuccessful Logon Attempts)
- CJIS Security Policy v6.0: Section IR-6 (Incident Reporting)
- CJIS Security Policy v6.0: Section PS-3 (Personnel Screening)
- CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions)
- NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions)

Framework Alignment:

- NIST CSF 2.0: GV.OC-03 (Legal, Regulatory, and Contractual Requirements)
- NIST CSF 2.0: GV.PO-01 (Policy Establishment)
- NIST CSF 2.0: GV.PO-02 (Policy Review)
- NIST CSF 2.0: GV.RR-02 (Roles, Responsibilities, and Authorities)
- NIST SP 800-53 Rev. 5: PL-1 (Planning Policy and Procedures)
- NIST SP 800-53 Rev. 5: PL-4 (Rules of Behavior)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: SI-12 (Information Management and Retention)
- COBIT 2019: APO01.01 (Design the Management System for Enterprise I&T)
- COBIT 2019: APO01.09 (Define and Communicate Policies and Procedures)
- COBIT 2019: MEA03 (Managed Compliance with External Requirements)
- ITIL v4: Continual Improvement Practice

6. Policy Statement

The ECIO Policy Manual is an enforceable governance instrument, not an aspirational document. Every directive expressed in mandatory compliance language ("shall" or "must") across the manual is an auditable obligation backed by the corrective action framework defined in this policy. This policy provides the operational mechanism through which non-compliance is identified, documented, escalated, and resolved — and through which the manual's alignment with applicable law is maintained.

For purposes of this policy, references to the Department's system of record refer to the designated operational recordkeeping system for enforcement actions, acknowledgments, and exception records. This is distinct from the **Authoritative System of Record** maintained under **Policy 1.04** (Policy and Documentation Formatting Standards), which governs policy text.

6.1 Policy Implementation and Dissemination

The IT Director shall ensure that all policies within the ECIO Policy Manual are operationalized through the following implementation requirements.

- **Publication**: Upon approval of a new or revised policy, the IT Director shall publish the updated policy to the Departmental Knowledge Base in accordance with **Policy 3.13** (Knowledge Management Policy). The LyX master record and its compiled PDF remain the legally authoritative source in accordance with **Policy 1.04**; the Knowledge Base publication constitutes the operational distribution mechanism.
- **Constructive Notice**: Publication of a policy in the Knowledge Base constitutes constructive notice to all Information Operations personnel. The IT Director shall issue a written notification to all Department personnel upon publication of any new or substantively revised policy. For non-IT County personnel, constructive notice is established through the acknowledgment and training mechanisms defined in Section 6.2 and **Policy 2.03** (Security Awareness and Training Policy).
- **Documentation as Standard**: Material operational actions, security-relevant actions, service-affecting changes, enforcement actions, and decisions that establish direction, approval, or disposition shall be documented in the designated System of Engagement within twenty-four (24) hours of completion, except during active incident response where documentation shall occur during incident closure in accordance with **Policy 4.01** (Incident Response Policy Overview). Dependence on memory, verbal direction, or informal communication as a substitute for written documentation is prohibited. Failure to document required actions constitutes non-compliance with this policy.
- **Coordination with Review Lifecycle**: Implementation of policies shall be coordinated with the review lifecycle defined in **Policy 1.05**. Event-driven reviews triggered by enforcement actions, legal changes, or audit findings shall follow the procedures established in that policy.

6.2 Policy Acknowledgment and Awareness

The IT Director shall maintain a policy acknowledgment program to ensure all personnel within scope are aware of their obligations under the ECIO Policy Manual.

- **Information Operations Personnel**: All Information Operations personnel shall acknowledge receipt and understanding of the ECIO Policy Manual upon hire, upon any substantive revision to a policy within their scope of responsibility, and annually thereafter. Acknowledgments shall be documented and retained in the Department's system of record.
- **Non-IT County Personnel**: Acknowledgment requirements for non-IT County personnel are established through the acceptable use acknowledgment process defined in **Policy 2.01** (Acceptable Use of Information Technology Resources Policy) and the security awareness and training program defined in **Policy 2.03**. The IT Director shall coordinate with HR to ensure acknowledgment completion is tracked.
- **Contractors and Vendors**: Contractors and vendors shall acknowledge applicable ECIO policies as a condition of access provisioning in accordance with **Policy 1.14** (Stakeholder Engagement and Communications Policy) and **Policy 2.01**.
- **Lapsed Acknowledgment**: The IT Director shall withhold or suspend system access for any individual whose required policy acknowledgment is overdue by more than thirty (30) calendar days. Access shall be reinstated upon completion of the outstanding acknowledgment. This suspension is an IT-administrative action under Section 6.3, not a personnel-disciplinary action.
- **Completion Tracking**: Acknowledgment completion rates shall be reported as part of the annual policy review and maturity scoring process defined in **Policy 5.07**.

6.3 Enforcement Authority and IT-Administrative Actions

The IT Director maintains independent authority over the County's information technology infrastructure. This authority extends to taking immediate system-level action to protect County assets, reduce liability, or manage operational and compliance risk. This authority exists regardless of the position, department, or employment classification of the affected party.

IT-administrative actions are distinct from personnel-disciplinary actions. IT-administrative actions are imposed by the IT Director under management authority over the technology infrastructure. Personnel-disciplinary actions are governed by the applicable labor agreement, County Personnel Policies, or employment contract and are processed through the appropriate personnel authority. This policy governs IT-administrative actions directly and defines the referral mechanism for personnel-disciplinary actions.

The following IT-administrative actions are available to the IT Director. This list constitutes the governed set of actions; the IT Director may also impose other operationally appropriate restrictions within the IT Director's management authority over the County's information technology infrastructure to protect County assets, reduce liability, or manage operational and compliance risk.

- **System-Level Actions (applicable to all population classes)**:
  - Access suspension (temporary revocation of logical access to one or more County systems).
  - Privilege revocation (removal of elevated or specialized permissions).
  - Network isolation (disconnection of a device, system, or network segment).
  - Asset confiscation (physical removal of County-owned IT assets from the individual's possession).
  - Forced credential reset (mandatory password change or re-authentication).
  - Account lockout (disabling an account pending investigation or remediation).
  - Increased audit frequency (enhanced monitoring of the affected account, system, or network segment).
  - Mandatory retraining as a prerequisite for access reinstatement.
- **Supervisory Actions (applicable only to Information Operations personnel)**:
  - Documented coaching and counseling.
  - Formal written performance deficiency notice.
  - Tier reassignment (temporary or permanent reassignment to a lower operational tier as defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework)).
  - Removal from on-call, standby, or specialized duty rotations.
  - Referral to the HR and/or County Manager process for formal discipline under the applicable labor agreement or County Personnel Policies.

Corrective action may begin at any level depending on the severity of the non-compliance, the frequency of the occurrence, the risk to County assets or operations, and the cumulative effect of prior non-compliance. The IT Director is not required to follow a sequential escalation path.

The IT Director shall document all IT-administrative enforcement actions in the Department's system of record within twenty-four (24) hours of the action. Documentation shall include the nature of the non-compliance, the enforcement action taken, the affected individual or system, and the notification provided to the appropriate parties.

IT-administrative actions shall remain in effect during any dispute resolution process unless the County Manager directs otherwise or a court order requires it. The dispute resolution pathways defined in Section 6.4 determine whether an action was justified; they do not automatically stay the action.

6.4 Enforcement by Population Class

The IT Director's enforcement authority and notification obligations vary based on the affected party's relationship to the County. The following population classes define the enforcement posture, notification chain, and dispute resolution routing for each class.

- **Information Operations Personnel**:
  - **Enforcement Posture**: The IT Director may impose any IT-administrative action defined in Section 6.3, including both system-level and supervisory actions.
  - **Notification**: No external notification is required for IT-administrative actions within the IT Director's supervisory authority. When the IT Director refers a matter to the personnel-disciplinary track, the IT Director shall provide written documentation of the non-compliance and the IT-administrative actions already taken to HR and/or the County Manager.
  - **Personnel-Disciplinary Referral**: Formal discipline beyond the IT Director's supervisory authority shall be initiated through the applicable labor agreement (Article 9, Disciplinary Action) or County Personnel Policies. The IT Director shall provide the written notice, supporting documentation, and evidence required by the applicable process.
  - **Dispute Resolution**: Internal disputes shall follow the Department's chain of command. Represented employees retain all rights under the applicable labor agreement, including grievance and arbitration rights.
- **Non-IT County Employees**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3. The IT Director shall not impose supervisory actions on personnel outside the Information Operations Department.
  - **Notification**: The IT Director shall provide written notification to the affected employee's department head within one (1) business day of any IT-administrative enforcement action. The notification shall identify the non-compliance, the action taken, and the policy basis for the action.
  - **Personnel-Disciplinary Referral**: Where the IT Director determines that the non-compliance warrants personnel-disciplinary action, the IT Director shall refer the matter in writing to the affected employee's department head and/or HR. The department head shall initiate action through the applicable labor agreement or personnel process.
  - **Dispute Resolution**: Department heads who dispute an IT-administrative enforcement action shall direct the dispute through the service grievance pathway established in **Policy 3.04**. Requests to relax or waive the underlying compliance standard shall be directed through the risk acceptance process established in **Policy 1.09**. These pathways are the exclusive channels for resolving enforcement disputes; informal or lateral communications that attempt to circumvent them shall be redirected to the appropriate channel.
- **Appointed and Elected Officials**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3.
  - **Notification**: The IT Director shall provide written notification to the County Manager within one (1) business day of any IT-administrative enforcement action taken against an appointed or elected official.
  - **Emergency Protective Action**: Where the IT Director identifies an immediate threat to County assets, evidence indicating unauthorized activity, misuse, policy violation, or suspected criminal activity, or conditions requiring immediate protective action, the IT Director shall take immediate system-level action and shall notify the County Manager, HR, and the District Attorney's Office

within one (1) hour of the action, providing the basis for the action. The County Manager, in coordination with Human Resources and the District Attorney's Office, shall determine next steps. The IT Director shall document the emergency protective action and the notifications provided in the Department's system of record within twenty-four (24) hours, consistent with the documentation requirement in Section 6.3.

  - **Dispute Resolution**: Appointed and elected officials who dispute an IT-administrative enforcement action shall direct the dispute through the service grievance pathway established in **Policy 3.04**, which provides for escalation to the County Manager. Requests to relax or waive the underlying compliance standard shall be directed through the risk acceptance process established in **Policy 1.09**.

- **Contractors and Vendors**:
  - **Enforcement Posture**: The IT Director may impose system-level IT-administrative actions defined in Section 6.3. Access revocation for contractors and vendors is immediate and does not require prior approval from the contract administrator.
  - **Notification**: The IT Director shall provide written notification to the responsible contract administrator and to the vendor compliance process established in **Policy 5.06** (Vendor Compliance and Third-Party Assurance) within one (1) business day of any IT-administrative enforcement action.
  - **Contract Remedies**: Where non-compliance by a contractor or vendor constitutes a breach of contractual obligations, the IT Director shall refer the matter to the contract administrator and County legal counsel for contract remedies. The IT Director's authority to revoke or restrict system access is independent of the contract remedy process.
  - **Dispute Resolution**: Contractors and vendors shall direct disputes through the contract administrator. The service grievance pathway in **Policy 3.04** is available to the extent the contractor or vendor is a recipient of IT services.

6.5 Formal Sanctions Process and CJIS Notification

The Department shall employ a formal sanctions process for individuals who fail to comply with the policies and procedures established in the ECIO Policy Manual. This process is consistent with applicable County HR policies, labor agreements, and NIST SP 800-53 Rev. 5: PS-8 (Personnel Sanctions).

- **Initiation**: The IT Director initiates the formal sanctions process by documenting the non-compliance, the IT-administrative actions taken, and a recommendation for formal discipline. The IT Director shall refer the documented matter to HR and/or the County Manager for processing through the applicable personnel framework.
- **Process Ownership**: The formal sanctions process is governed by the applicable labor agreement, County Personnel Policies, or employment contract — not by this policy. This policy defines the trigger conditions, the documentation the IT Director provides, and the CJIS notification obligation. It does not define the investigation, notice, response, or appeal procedures, which are established in the applicable personnel framework.
- **CJIS Notification Requirement**: In accordance with CJIS Security Policy v6.0: Section PS-8 (Personnel Sanctions) and NIST SP 800-53 Rev. 5: PS-8, when a formal sanctions process is initiated against any individual with access to Criminal Justice Information (CJI), the IT Director (as LASO) shall notify the appropriate Information Security Officer (ISO), HR representative, System or Network Administrator, and personnel with account management responsibilities within twenty-four (24) hours. The notification shall identify the individual sanctioned and the reason for the sanction, unless County legal counsel determines a different timing is legally required.
- **Legal Referral**: Where non-compliance involves suspected criminal activity — including but not limited to violations of NRS 205 (Computer Crimes) or unauthorized access to CJI — the IT Director shall

refer the matter to the District Attorney's Office and, where applicable, to the appropriate law enforcement authority. Legal referral does not preclude concurrent IT-administrative action; the IT Director shall take immediate system-level protective action as warranted.

6.6 Exception Management

All policies within the ECIO Policy Manual are subject to a uniform exception management framework. Exceptions to any policy requirement shall be governed by the following requirements.

- **Written Documentation**: All exceptions shall be documented in writing prior to implementation. The documentation shall include the specific policy requirement from which the exception is sought, the business justification, the duration of the exception, the remediation timeline, the compensating measures in effect during the exception period or written justification for why none are needed, and the residual risk accepted. Exceptions shall not be granted on an open-ended basis. No exception shall place County systems or Criminal Justice Information out of compliance with applicable CJIS Security Policy obligations.
- **Approval Authority**: Exceptions shall be approved in writing by the IT Director within delegated authority under **Policy 1.08**. Exceptions that exceed the IT Director's delegated authority shall be approved by the County Manager. Oral exceptions are not valid.
- **Operational Tier**: The Assistant IT Director may approve an operational exception without IT Director pre-approval when the exception meets all of the following criteria:
  - The exception duration does not exceed thirty (30) calendar days.
  - The exception does not affect Criminal Justice Information handling, storage, transmission, or access.
  - The exception does not deviate from a security baseline defined in **Policy 2.10** (Secure Configuration Baselines and Hardening Policy).
  - The exception does not deviate from a mandatory CJIS Security Policy requirement.
  - The exception does not alter decision rights, chain of command, or authority structure governed by **Policy 1.08**.
- **Operational Tier Controls**: The Assistant IT Director shall document each approved operational exception in writing and notify the IT Director within one (1) business day of approval. The IT Director may override any operational exception at any time. The Assistant IT Director shall not renew an operational exception; renewal requires IT Director approval. All other requirements in this section apply to operational exceptions without modification.
- **Oversight Mechanism Integrity**: Where a policy establishes an oversight, audit, monitoring, assurance, or review mechanism that applies to other policies in the manual, that mechanism's application to its targets shall not be waived by exception. Operational details of such a mechanism — including cadence, scope, and methodology — remain subject to the standard exception framework established in this section.
- **CJI Exceptions**: Exceptions involving the handling, storage, transmission, or access to Criminal Justice Information shall be approved by the IT Director (as LASO) under the standard exception process established in this section. No separate CJIS Systems Officer (CSO) concurrence is required for the exception itself. CSO concurrence is operationally required only where the CJIS Security Policy or a written CJIS user agreement to which the County is party explicitly requires it — for example, CJIS IR-6 Part (b) external incident notification, CJIS PS-3 adjudication of CJI access, and CJIS AC-7 authorization for automatic account unlock. All approvals shall be retained for audit.
- **Policy-Specific Requirements**: Where a policy's Section 4 establishes exception requirements that are stricter than this general framework, the stricter requirement governs. Exceptions to this policy

(**Policy 5.01**) are subject to the approval requirements in Section 4, which require County Manager approval; the IT Director shall not approve exceptions to this policy acting alone.

- **Risk Recording**: All approved exceptions shall be recorded in the central Risk Register maintained under **Policy 1.09**. The risk entry shall reference the exception documentation and shall be reviewed during the annual policy review cycle defined in **Policy 5.07**.
- **Active Exception Review**: The IT Director shall review all active exceptions during each annual policy review cycle and shall close, renew, or escalate each exception based on current risk conditions.
- **Retroactive Exceptions**: Retroactive exceptions — documenting a deviation after the fact — shall be documented as a non-compliance event under Section 6.3 and evaluated for corrective action. A retroactive exception does not constitute a defense to an enforcement action already initiated.

6.7 Legal and Regulatory Alignment

The ECIO Policy Manual operates within and supports compliance with applicable federal, state, and local law. The IT Director shall maintain awareness of legal and regulatory changes that affect the manual's obligations and shall ensure the manual remains aligned with current requirements.

- **Monitoring Responsibility**: The IT Director shall monitor changes to the Nevada Revised Statutes, the Nevada Administrative Code, the CJIS Security Policy, and applicable federal law and regulation that affect the manual's scope. The IT Director may designate qualified personnel to assist with monitoring but retains accountability for the alignment determination.
- **Event-Driven Review**: When a legal or regulatory change is identified that affects one or more policies in the manual, the IT Director shall initiate an event-driven review in accordance with **Policy 1.05**. The review shall assess the impact of the change, identify the affected policies, and produce the necessary updates.
- **Order of Precedence**: Where a conflict between the ECIO Policy Manual and a legal or regulatory requirement is identified, the legal requirement prevails. The order of authority established in the Compliance Alignment & Order of Precedence section of the Manual Executive Summary governs the resolution hierarchy. The IT Director shall update the affected policy within the next scheduled review cycle, or sooner if the conflict creates immediate compliance risk.
- **Statutory Awareness (Non-Exhaustive)**: The following statutes and regulations are of primary relevance to the manual's enforcement and compliance obligations. This list is maintained for operational awareness and does not constitute a comprehensive legal analysis. NRS 205 (Computer Crimes), NRS 239 (Public Records), NRS 239.125 (Local Government Records Management Program), NRS 242.171 (Responsibilities of Office/Director), NRS 244 (Counties: Government), NRS 281A (Ethics in Government), NRS 603A (Security of Personal Information), and the CJIS Security Policy as published by the FBI Criminal Justice Information Services Division.

6.8 Enforcement Record Retention

The IT Director shall ensure that all records generated under this policy are classified, retained, and disposed of in accordance with **Policy 1.11** (Data Governance and Classification Policy), NRS 239.125 (Local Government Records Management Program), NAC 239.155 (Adoption of Records Retention Schedule), and the applicable series within the Nevada Local Government Records Retention Schedule.

- **IT-Administrative Enforcement Records**: Documentation of IT-administrative enforcement actions, including the nature of the non-compliance, the action taken, notification records, and any remediation completed, shall be retained under the record series applicable to the affected population class: LRDA 20070321 (Master Personnel File) for County employees; LRDA 20121869 (Administrative Hearing Files) for appointed and elected officials; and LRDA 20071300 (Vendor Performance Case Files) for contractors and vendors.

- **Sanctions Documentation**: Records of formal sanctions referrals, including CJIS PS-8 notification records, shall be retained by Human Resources in accordance with LRDA 20070321 (Master Personnel File).
- **Recordkeeping**: Approved exception documentation, risk register entries, and renewal or closure records shall be retained for the duration of the exception plus the applicable retention period.
- **Acknowledgment Records**: Policy acknowledgment records shall be retained in accordance with the applicable Nevada Local Government Records Retention Schedule series, as specified in the originating policy.
- **Legal Referral Records**: Records of referrals to the District Attorney's Office or law enforcement shall be retained in accordance with the applicable retention schedule and in coordination with the receiving authority.
- **Public Records Status**: All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. The classification and handling of enforcement records shall comply with **Policy 1.11**.

5.02 Internal Audits, Self-Assessment, and Control Testing

Effective: April 29, 2026 Version: 2.0

1. Purpose

This policy establishes the internal audit program, self-assessment procedures, and control testing methodology that the Information Operations Department uses to evaluate the implementation, operating effectiveness, and continued adequacy of controls, processes, and obligations defined throughout the ECIO Policy Manual.

2. Scope

This policy applies to all policies, controls, processes, and systems governed by the ECIO Policy Manual.

- **In Scope**:
  - Internal audit planning, scheduling, and execution.
  - Self-assessment procedures and process-owner evaluations.
  - Control testing and validation methodology.
  - Audit and assessment documentation, evidence handling, and record retention.
  - Deficiency identification, classification, and routing.
- **Out of Scope**:
  - Policy lifecycle management and version control: **Policy 1.05**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Corrective action plan development, tracking, and closure: **Policy 5.03**.
  - Security control authorization decisions: **Policy 5.05**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director:**
  - Shall serve as the audit authority for the ECIO Policy Manual.
  - Shall approve the Annual Audit Plan defined in Section 6.1.
  - Shall receive and review all audit summary reports and deficiency notifications produced under this policy.
  - Shall authorize unplanned audits when circumstances require assessment outside the approved schedule.
  - Shall ensure that audit activities maintain sufficient objectivity as defined in Section 6.4.
  - Shall obtain external assessment services or document County Manager-approved compensating oversight when no internal reviewer satisfying the independence test in Section 6.4 can be assigned to controls implementing Criminal Justice Information Services (CJIS) Security Policy

requirements, consistent with CJIS Security Policy v6.0: CA-2(1) (Independent Assessors) and CA-7(1) (Independent Assessment).

- **Assistant IT Director:**
  - Shall develop the draft Annual Audit Plan for IT Director approval.
  - Shall execute or coordinate the execution of all internal audits and control tests scheduled under this policy.
  - Shall coordinate the quarterly self-assessment cycle defined in Section 6.2 and consolidate results from the domain administrators.
  - Shall maintain audit records and evidence in the System of Engagement.
  - Shall ensure that audit-derived evidence is protected against unauthorized modification or deletion in accordance with CJIS Security Policy v6.0: AU-9 (Protection of Audit Information).
  - Shall prepare audit summary reports for IT Director review.
  - Shall classify findings and route deficiencies in accordance with Section 6.5.
  - Shall maintain the Control Testing Register defined in Section 6.3.
- **Systems Administrator:**
  - Shall conduct self-assessments for controls within the systems administration operational area as defined in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework), and document results in the System of Engagement.
- **Network Administrator:**
  - Shall conduct self-assessments for controls within the network administration operational area as defined in **Policy 1.07**, and document results in the System of Engagement.
- **Support Specialist:**
  - Shall conduct self-assessments for controls within the end-user support operational area as defined in **Policy 1.07**, and document results in the System of Engagement.
- **All Information Operations Personnel:**
  - Shall cooperate fully with internal audit and control testing activities, including providing access to systems, records, and documentation within their operational scope.
  - Shall not obstruct, delay, or withhold information from audit or assessment activities.
- **Department Heads (Non-IT County Departments):**
  - Shall cooperate with audit and assessment activities that evaluate controls applicable to their personnel or systems, including access reviews, acceptable use compliance, and training verification.

4. Compliance and Exceptions

Adherence to this policy is mandatory for all personnel within scope, in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).

- **Assessment**: Compliance with this policy shall be assessed through the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Violations of this policy shall be addressed through the enforcement framework established in **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be governed by the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.05: Security Control Assessment and Authorization
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239 (Public Records)
- NRS 239.125 (Local Government Records Management Program)
- NAC 239.165 (Destruction of Confidential Records)
- LRDA 20071256 (Quality Assurance Review Audits and Reports)
- CJIS Security Policy v6.0: AU-9 (Protection of Audit Information)
- CJIS Security Policy v6.0: CA-2(1) (Independent Assessors)
- CJIS Security Policy v6.0: CA-7(1) (Independent Assessment)

Framework Alignment:

- CJIS Security Policy v6.0: CA-1 (Policy and Procedures)
- CJIS Security Policy v6.0: CA-2 (Control Assessments)
- CJIS Security Policy v6.0: CA-7 (Continuous Monitoring)
- NIST CSF 2.0: ID.IM-01 (Improvements are identified from evaluations)
- NIST CSF 2.0: ID.IM-02 (Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties)
- NIST SP 800-53 Rev. 5: CA-2 (Control Assessments)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- COBIT 2019: MEA02 (Managed System of Internal Control)
- ITIL v4: Continual Improvement Practice

6. Policy Statement

6.1 Audit Planning and Annual Schedule

The IT Director shall approve an Annual Audit Plan no later than thirty (30) calendar days after the beginning of each fiscal year. The Assistant IT Director shall prepare the draft plan and submit it to the IT Director for review.

The Annual Audit Plan shall identify, at minimum: the policies, controls, and processes to be assessed during the fiscal year; the assessment method for each item (internal audit, self-assessment, or control test); the planned quarter of execution; and the personnel or role assigned to conduct each assessment.

Audit scope shall be determined on a risk-informed basis. The following factors shall inform prioritization: the results of the previous year's audit and assessment cycle, the risk ratings maintained under **Policy 1.09** (Risk Management Policy), any open deficiencies tracked under **Policy 5.03** (Compliance Monitoring and Corrective Action), changes to the regulatory or threat environment, and the results of any external audits or assessments conducted during the prior period.

Every policy in the ECIO Policy Manual shall be assessed through at least one of the three mechanisms defined in this policy — internal audit, self-assessment, or control test — within each annual cycle. Policies governing controls subject to CJIS Security Policy obligations, or controls associated with risks rated High or Critical in the Risk Register maintained under **Policy 1.09**, shall be assessed no less than annually through internal audit or control testing; self-assessment alone does not satisfy this requirement.

The Annual Audit Plan is a planning instrument; it does not prevent the IT Director from authorizing additional assessments during the fiscal year. The IT Director may initiate unplanned audits in response to cybersecurity incidents, enforcement actions, external audit findings, regulatory changes, or risk conditions identified under **Policy 1.09**. The Assistant IT Director shall document unplanned audits in the System of Engagement with the same rigor as planned audits.

6.2 Self-Assessment Procedures

Self-assessments are process-owner evaluations that determine whether the controls assigned to a given operational area are implemented, are operating as intended, and are producing the expected outcome. Self-assessments supplement — but do not replace — the internal audit and control testing activities defined in Sections 6.1 and 6.3.

The Assistant IT Director shall coordinate the quarterly self-assessment cycle. Self-assessment execution shall be assigned to the domain administrators (Systems Administrator, Network Administrator, and Support Specialist) for controls within their respective operational areas as defined in **Policy 1.07**. Each quarterly self-assessment cycle shall cover the policies and controls designated in the Annual Audit Plan for that quarter. Where the Annual Audit Plan designates a policy for self-assessment rather than internal audit, the quarterly self-assessment constitutes the annual assessment obligation for that policy. Self-assessment shall not serve as the sole annual assessment mechanism for a policy associated with an open Corrective Action Plan under **Policy 5.03** or designated by the IT Director as requiring objective assurance. Restrictions on self-assessment as the sole annual assessment mechanism for CJIS-governed and High or Critical risk-rated controls are established in Section 6.1.

Each self-assessment shall evaluate, at minimum: whether the required controls are documented and current, whether the controls have been executed within the cadences defined in the governing policy, and whether evidence of control execution exists in the System of Engagement or the applicable system of record.

The assigned domain administrator shall document self-assessment results in a work order in the System of Engagement in accordance with **Policy 3.13** (Knowledge Management Policy). Each self-assessment record shall include: the policy or control area assessed, the assessment date, the controls evaluated, the determination for each control (conforming, observation, or deficiency as defined in Section 6.5), and any recommended actions.

The Assistant IT Director shall consolidate self-assessment results across the cycle. Where a self-assessment reveals a condition that requires deeper evaluation, the Assistant IT Director shall escalate the finding to the IT Director with a recommendation to initiate an unplanned internal audit or control test of the affected area.

6.3 Control Testing and Validation

Control testing validates that a specific technical or procedural control produces its intended security or operational outcome when exercised. Control testing goes beyond self-assessment by directly exercising the control mechanism rather than evaluating documentation and evidence of prior execution.

The Assistant IT Director shall maintain a Control Testing Register in the System of Engagement. The register shall list each testable control, the governing policy, the testing method, the testing cadence, the risk rating maintained under **Policy 1.09**, the CJIS applicability of the control, and the date and result of the most recent test. The register is a living instrument; the Assistant IT Director shall update it as policies are added, revised, or retired under **Policy 1.05** (Policy Review and Update Procedures).

The Assistant IT Director shall select testing methods based on the control type, the control objective, and the risk rating maintained under **Policy 1.09**. Testing methods shall include one or more of the following: examination of documentation, records, or configuration artifacts; interview of personnel who operate the control; and direct testing through observation, execution, or simulation of the control mechanism.

Each control test shall document: the control tested and the governing policy reference, the testing method used, the population tested, the sample size and sampling method where sampling was employed, the evidence identifiers, the assessor name or role, the date the test was conducted, the expected outcome, the actual outcome, the pass or fail determination, any anomalies or observations noted during the test, and any systems excluded from the test scope or limitations affecting the test.

Testing cadence shall be risk-informed and shall comply with the following minimum frequencies:

- Controls implementing CJIS Security Policy requirements shall be tested no less than annually.
- Controls associated with risks rated High or Critical in the Risk Register maintained under **Policy 1.09** shall be tested no less than annually.
- All other controls shall be tested no less than once every twenty-four (24) months.

The IT Director may establish more frequent testing cadences for specific controls based on risk conditions, regulatory changes, or prior test failures.

Where a control test results in a failure, the Assistant IT Director shall classify the finding per Section 6.5 and route it accordingly. The Assistant IT Director shall retest a failed control after remediation is complete; the retest result shall be documented in the same work order chain as the original test.

6.4 Audit Execution and Documentation

The Assistant IT Director shall conduct internal audits in accordance with the Annual Audit Plan or under IT Director authorization for unplanned assessments. Each internal audit shall follow a consistent methodology comprising four stages: scoping, evidence collection, analysis, and reporting.

- **Scoping**: The auditor shall define the controls under assessment, the assessment criteria, the evidence to be collected, and the systems or records to be examined. The auditor shall retain the scoping document with the audit record.
- **Evidence Collection**: The auditor shall gather objective evidence to support a determination of control effectiveness. Evidence may include system configurations, log records, work order histories, training records, policy acknowledgment records, and direct observation of operational procedures. Verbal attestation alone shall not constitute objective evidence.

- **Analysis**: The auditor shall evaluate collected evidence against the requirements of the governing policy and applicable framework controls to determine whether each assessed control is conforming, warrants an observation, or constitutes a deficiency.
- **Reporting**: The auditor shall prepare an audit summary that documents the scope, methodology, evidence collected, findings by control, and recommended actions. The auditor shall submit the audit summary to the IT Director within fifteen (15) business days of the completion of evidence collection.

Objectivity is a core requirement of the audit function. Personnel shall not serve as the primary auditor for any control for which they hold administrative access, configuration authority, or operational execution duties. When the Information Operations Department lacks an internal reviewer satisfying the independence test established in this Section, the IT Director shall document the constraint and ensure that audit results receive independent review. For the purposes of this policy, independent review means review by a person who did not participate in the implementation, operation, or assessment of the controls under evaluation.

For controls implementing CJIS Security Policy requirements, when no internal reviewer satisfying the independence test established in this Section can be assigned, the IT Director shall obtain assessment services from qualified external assessors or document compensating oversight approved by the County Manager prior to accepting the assessment as complete. This requirement is consistent with CJIS Security Policy CA-2(1) and CA-7(1).

The Assistant IT Director shall maintain all audit documentation — scoping documents, evidence artifacts, working papers, and audit summaries — in the System of Engagement and shall classify audit records in accordance with **Policy 1.11** (Data Governance and Classification Policy). Audit records may be subject to disclosure under NRS 239 unless protected by a specific statutory exemption; classification and handling shall follow **Policy 1.11**.

6.5 Findings, Classification, and Routing

The Assistant IT Director shall classify audit findings, self-assessment results, and control test outcomes using a three-tier scheme.

- **Conforming**: The assessed control is implemented correctly, is operating as intended, and is producing the desired outcome. Conforming findings shall be recorded in the Control Testing Register and shall contribute to the maturity scoring process under **Policy 5.07**.
- **Observation**: A control deviation, inconsistency, or area for improvement that does not violate a statutory or regulatory obligation, does not violate a CJIS Security Policy requirement, does not permit unauthorized access to County systems or data, does not compromise audit evidence integrity, and does not constitute a failure of the control's primary protective or operational function. The Assistant IT Director shall document and track observations. The Assistant IT Director shall reclassify observations that recur across two (2) or more consecutive assessment cycles as deficiencies.
- **Deficiency**: The control is not implemented, is not operating as intended, or is not producing the desired outcome, and one or more of the following conditions is present: the gap violates a statutory or regulatory obligation, violates a CJIS Security Policy requirement, permits unauthorized access to County systems or data, compromises audit evidence integrity, or constitutes a failure of the control's primary protective or operational function. The Assistant IT Director shall route deficiencies to **Policy 5.03** for corrective action plan development no later than one (1) business day after classification.

When a deficiency affects a control implementing a CJIS Security Policy requirement, the IT Director shall determine whether the deficiency constitutes a reportable condition under the applicable CJIS notification obligations. The IT Director shall document the determination, the basis for the determination, the required notification recipients, the notification deadline, and the completion evidence. Reportable conditions shall be routed through **Policy 4.02** (Identification and Reporting Procedures) and **Policy 4.06** (Communication Protocols and Partner Integration) as applicable.

When an audit or assessment reveals that non-compliance by an individual has occurred, the Assistant IT Director shall route the finding to the IT Director for evaluation under the enforcement framework established

in **Policy 5.01**. The audit function identifies the condition; enforcement authority remains with the IT Director under **Policy 5.01**.

The Assistant IT Director shall prepare a consolidated Annual Audit Summary Report at the conclusion of each annual audit cycle. The report shall document: the total number of assessments conducted by type (internal audit, self-assessment, and control test); the number and distribution of findings by classification tier; the policies and controls with open deficiencies; trend data comparing current-year results to prior-year results; and recommendations for the next annual cycle. The Assistant IT Director shall submit the Annual Audit Summary Report to the IT Director no later than thirty (30) calendar days after the conclusion of each fiscal year and shall make it available as an input to the annual policy review and maturity scoring process under **Policy 5.07**.

6.6 Audit Record Retention

The Assistant IT Director shall retain audit records, self-assessment documentation, control test results, evidence artifacts, and audit summary reports in the System of Engagement. Retention periods shall be applied in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule. Audit records shall be classified in accordance with **Policy 1.11**.

- **Quality Assurance Review Audits and Reports**: The Assistant IT Director shall retain audit records, self-assessment documentation, control test results, evidence artifacts, and audit summary reports produced under this policy for a minimum of three (3) calendar years from the end of the calendar year to which they pertain, in accordance with LRDA 20071256 (Quality Assurance Review Audits and Reports).
- **CJIS Audit Records**: For audit records produced under this policy that document the assessment of controls implementing CJIS Security Policy requirements, the Assistant IT Director shall apply the greater of the CJIS minimum retention period or the applicable Nevada retention requirement.
- **Destruction Standards**: The Assistant IT Director shall ensure destruction of confidential audit records complies with NAC 239.165.
- **Legal Holds**: The Assistant IT Director shall suspend retention and disposition actions for audit records during litigation holds, public records preservation requirements, ongoing audits, CJIS reviews, external investigations, or other legal hold events, in accordance with **Policy 1.11**.
- **Multiple Schedules**: Where multiple retention requirements apply to a single record, the Assistant IT Director shall apply the longest applicable period.

5.03 Compliance Monitoring and Corrective Action

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy governs the development, approval, tracking, and closure of Corrective Action Plans and establishes the compliance monitoring function that verifies the Department's ongoing adherence to its statutory and regulatory notification obligations.

2. Scope

This policy applies to all deficiencies, control failures, and compliance gaps identified through the assessment, audit, and operational monitoring functions of the ECIO Policy Manual that require documented remediation.

- **In Scope**:
  - Corrective Action Plan development, content requirements, and approval.
  - Corrective Action Plan tracking, milestone management, and closure.
  - Verification of remediation effectiveness.
  - Compliance monitoring of incident reporting and breach notification obligations.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Service level target-setting and SLA deviation thresholds: **Policy 3.01** and **Policy 3.02**.
  - Enforcement actions against individuals and formal sanctions: **Policy 5.01**.
  - Audit planning, assessment execution, and deficiency classification: **Policy 5.02**.
  - Vendor compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall approve all Corrective Action Plans prior to execution.
  - Shall approve Corrective Action Plan closures upon receipt of verification evidence.
  - Shall evaluate whether a deficiency affecting a control implementing a Criminal Justice Information Services (CJIS) Security Policy requirement, or any statutory breach notification obligation, triggers external or interagency reporting requirements.
  - Shall ensure that required notifications are executed in accordance with **Policy 4.02** (Identification and Reporting Procedures) and **Policy 4.06** (Communication Protocols and Partner Integration) when reporting is required.
  - Shall authorize exceptions to this policy in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights).
- **Assistant IT Director**:

  - Shall develop the Corrective Action Plan for each deficiency routed to this policy within the timeframes defined in Section 6.2.
  - Shall maintain all open Corrective Action Plans in the System of Engagement (Redmine).
  - Shall review all open Corrective Action Plans no less than monthly and shall update milestone status as material progress occurs.
  - Shall request verification assessments through the mechanisms defined in **Policy 5.02** upon completion of remediation activities.
  - Shall ensure that each Corrective Action Plan is linked to the corresponding entry in the Risk Register maintained under **Policy 1.09**.
  - Shall conduct the compliance monitoring reviews defined in Section 6.5.
  - Shall report open Corrective Action Plans and their current status as part of the reporting cadences defined in **Policy 3.02** and **Policy 5.04** (Performance Metrics and Operational KPIs).
- **All Information Operations Personnel**:
  - Shall execute remediation tasks assigned under an approved Corrective Action Plan within the milestone timelines established in the plan.
  - Shall document remediation actions in the System of Engagement (Redmine) as they are completed.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in deficiency remediation, compliance monitoring, or Corrective Action Plan management.

- **Assessment**: Adherence to Corrective Action Plan development timelines, milestone tracking, verification requirements, and compliance monitoring obligations shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07**.
- **Enforcement**: Failure to develop required Corrective Action Plans within the timelines defined in Section 6.2, failure to maintain milestone tracking, or failure to conduct required compliance monitoring reviews shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01**.
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with **Policy 1.08**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment

- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- NRS 603A.220 (Disclosure of Breach of Security of System Data)
- CJIS Security Policy v6.0: CA-5 (Plan of Action and Milestones)
- CJIS Security Policy v6.0: CA-7 (Continuous Monitoring)
- CJIS Security Policy v6.0: IR-6 (Incident Reporting)
- NIST CSF 2.0: ID.IM-01 (Improvements Are Identified from Evaluations)
- NIST CSF 2.0: ID.IM-03 (Improvements Are Identified from Execution of Operational Processes)
- NIST SP 800-53 Rev. 5: CA-5 (Plan of Action and Milestones)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-4 (Plan of Action and Milestones Process)

Framework Alignment:

- COBIT 2019: MEA01.05 (Ensure the Implementation of Corrective Actions)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Problem Management Practice

6. Policy Statement

6.1 Scope and Intake Sources

This policy governs two functions. First, it defines the lifecycle for Corrective Action Plans (CAPs) — the documented remediation instruments used to correct deficiencies, control failures, and compliance gaps identified across the ECIO Policy Manual. Second, it establishes the compliance monitoring function that verifies the Department's adherence to its incident reporting and breach notification obligations. These functions are connected: gaps identified through compliance monitoring enter the same CAP lifecycle as deficiencies from any other intake source.

Corrective Action Plans constitute the Department's implementation of NIST SP 800-53 Rev. 5: CA-5 (Plan of Action and Milestones) and CJIS Security Policy v6.0: CA-5. All remediation tracking instruments within the ECIO Policy Manual — regardless of the label used in the originating policy — shall follow the lifecycle defined in this policy.

The Assistant IT Director shall initiate CAPs from the following intake sources. This policy does not redefine the triggers or thresholds that generate these inputs; it receives them and governs what happens next.

- **Audit-Derived Deficiencies**: Deficiencies classified under **Policy 5.02** Section 6.5 and routed to this policy for corrective action plan development.
- **Service Level Corrective Action**: Corrective Action Plans triggered by the sustained non-compliance threshold defined in **Policy 3.02** Section 6.3.
- **Risk Response Remediation**: Remediation actions identified through the risk response process defined in **Policy 1.09** that require documented tracking with milestones.
- **Compliance Monitoring Findings**: Gaps identified through the compliance monitoring function defined in Section 6.5 of this policy.

The boundary between this policy and its adjacent policies is as follows. **Policy 5.02** identifies deficiencies through audit, self-assessment, and control testing; this policy develops and manages the remediation. **Policy 5.01** enforces consequences against individuals for non-compliance; this policy remediates the process or control that failed. **Policy 1.09** maintains the Risk Register and defines when a risk response is needed; this policy governs the remediation lifecycle once that response requires tracked corrective action.

6.2 Corrective Action Plan Content and Approval

The Assistant IT Director shall develop a CAP for each deficiency routed to this policy. Development shall be completed within ten (10) business days of receipt from the originating source. When a deficiency is routed from **Policy 5.02**, the ten (10) business day development window begins on the date of classification under **Policy 5.02** Section 6.5.

Each CAP shall be documented in the System of Engagement (Redmine) and shall include, at minimum, the following content:

- **Deficiency Description**: A clear statement of the control failure, compliance gap, or process breakdown, including the originating source and the affected policy or control.
- **Root Cause**: The identified or probable cause of the deficiency. Where the root cause cannot be determined within the development window, the CAP shall state that root cause analysis is ongoing and shall include a milestone for completing it.
- **Remediation Actions**: The specific actions required to correct the deficiency, stated with sufficient precision that completion is objectively verifiable.
- **Milestones**: Each CAP shall include one or more defined milestones with target completion dates. Milestones shall represent measurable interim checkpoints — not a single end-state target. The milestone structure shall be sufficient to enable progress tracking and early detection of delays.
- **Verification Criteria**: The standard by which remediation will be confirmed complete. Verification criteria shall identify the assessment method (control re-test, self-assessment, or audit) and the expected evidence of remediation.
- **Responsible Role**: The role assigned to execute remediation actions. Assignment shall follow the role definitions established in **Policy 1.07** (Workforce Roles, Responsibilities, and Competency Framework).
- **Risk Register Linkage**: The Risk ID of the corresponding entry in the Risk Register maintained under **Policy 1.09**. When a deficiency does not yet have a Risk Register entry, the Assistant IT Director shall create one at the time of CAP development.
- **CJIS Impact Indicator**: A determination of whether the deficiency affects a control implementing a CJIS Security Policy requirement. When the indicator is affirmative, the IT Director shall evaluate whether the deficiency triggers external or interagency reporting requirements and shall ensure that required notifications are executed in accordance with **Policy 4.02** and **Policy 4.06**.

The IT Director shall review and approve each CAP prior to execution. Approval constitutes authorization to begin remediation activities and acceptance of the proposed milestones and timeline. The IT Director may direct modifications to the remediation approach, milestones, or timeline prior to approval.

6.3 Tracking and Update Cadence

The Assistant IT Director shall maintain all open CAPs in the System of Engagement (Redmine). The Assistant IT Director shall review all open CAPs no less than monthly and shall update milestone status upon the completion of any milestone, upon discovery of a delay, or no less than monthly. Each monthly review shall document: milestone completion status, any changes to the remediation approach or timeline, and an assessment of whether the CAP remains on track for closure within its approved timeline.

The Assistant IT Director shall update CAPs whenever new information becomes available from control assessments, independent audits or reviews, or continuous monitoring activities, consistent with CJIS Security Policy v6.0: CA-5, which requires updates at least every six (6) months or when new information is available. The monthly review cadence established in this policy meets and exceeds this minimum.

The Assistant IT Director shall report open CAPs through the existing reporting structures established in the manual. Open CAPs and their current status shall be included in the monthly performance summary defined in **Policy 3.02** Section 6.4. Open CAPs shall be available as an input to the annual policy review and maturity scoring process under **Policy 5.07**. This policy does not establish separate reporting cadences or standalone CAP status reports.

When a CAP milestone target date is missed, the Assistant IT Director shall document the reason for the delay and establish a revised target date. When two (2) or more milestones within a single CAP are missed, the Assistant IT Director shall escalate the CAP to the IT Director for review. The IT Director shall determine whether the CAP requires revision, additional resources, or risk acceptance for the underlying deficiency in accordance with **Policy 1.09**.

6.4 Verification and Closure

The Assistant IT Director shall verify remediation before a CAP is closed. The Assistant IT Director shall request verification through the assessment mechanisms defined in **Policy 5.02** — control re-test, self-assessment, or audit — appropriate to the nature of the original deficiency. This policy does not establish a separate verification methodology; it uses the assessment infrastructure that **Policy 5.02** already provides.

The verification assessment shall confirm that the remediation actions have been implemented, are operating as intended, and are producing the desired outcome — the same standard used for the "Conforming" classification in **Policy 5.02** Section 6.5.

A CAP shall not be closed solely on the basis of task completion. Closure requires documented verification that the remediation achieved the stated control, process, or compliance outcome.

Upon receipt of a conforming verification result, the Assistant IT Director shall prepare the CAP for closure and submit it to the IT Director with the verification evidence. The IT Director shall approve the closure. Upon closure, the Assistant IT Director shall update the corresponding Risk Register entry under **Policy 1.09** to reflect the resolved status.

When verification reveals that remediation was not effective, the Assistant IT Director shall not close the CAP. The Assistant IT Director shall revise the remediation approach, establish new milestones, and resubmit the revised CAP to the IT Director for approval.

6.5 Compliance Monitoring

The Department maintains statutory and regulatory obligations for incident reporting and breach notification that are operationally executed by other policies in the manual. CJIS Security Policy v6.0: IR-6 (Incident Reporting) establishes the incident reporting obligation; its operational execution is governed by **Policy 4.02** and **Policy 4.06**. NRS 603A.220 establishes the breach notification obligation; its operational execution is also governed by **Policy 4.06**. This section establishes the compliance monitoring function that verifies whether those obligations are being met. Gaps identified through this function constitute a CAP intake source under Section 6.1 and enter the same remediation lifecycle as deficiencies from any other source.

The Assistant IT Director shall review, no less than annually, whether the Department's incident reporting and breach notification processes are being executed in accordance with the requirements defined in **Policy 4.02** and **Policy 4.06**. The review shall evaluate, at minimum:

- Whether incidents meeting the CJIS IR-6 reporting criteria were reported within the required timelines.
- Whether breach notifications required by NRS 603A.220 were issued within the timeframes mandated by that statute.
- Whether the documentation requirements established in **Policy 4.02** and **Policy 4.06** were satisfied.

The Assistant IT Director shall treat gaps identified through the compliance monitoring review as deficiencies and shall route them into the CAP lifecycle defined in Sections 6.2 through 6.4 of this policy. When a compliance monitoring review identifies a gap in a CJIS-reportable process, the IT Director shall evaluate whether the gap itself triggers external or interagency reporting requirements and shall ensure that required notifications are executed in accordance with **Policy 4.02** and **Policy 4.06**.

The compliance monitoring review may be conducted as part of the annual audit cycle under **Policy 5.02** or as a standalone review. Regardless of the mechanism, the Assistant IT Director shall document the results and retain them in the System of Engagement (Redmine).

6.6 Record Retention

The Assistant IT Director shall retain all CAP records — including the CAP documentation, milestone tracking updates, verification evidence, and closure approvals — in the System of Engagement (Redmine) in accordance with **Policy 1.11** (Data Governance and Classification Policy) and the applicable Nevada Local Government Records Retention Schedule under NRS 239.125. Where multiple retention requirements apply, the longest applicable period shall govern.

The Assistant IT Director shall retain compliance monitoring review records under the same framework. All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. Classification and handling shall follow **Policy 1.11**.

5.04 Performance Metrics and Operational KPIs

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the governance framework for defining, reviewing, and acting upon departmental performance metrics and operational key performance indicators (KPIs) used by the Elko County Information Operations Department to evaluate service performance, operational resilience, security posture, and organizational sustainability.

2. Scope

This policy applies to all Information Operations personnel involved in KPI definition, data aggregation, performance review, or executive reporting.

- **In Scope**:
  - Departmental KPI taxonomy and domain coverage requirements.
  - KPI definition, approval, and threshold governance.
  - Quarterly KPI review and recordkeeping.
  - Underperformance pattern identification and routing.
  - Annual executive performance reporting.
- **Out of Scope**:
  - Individual personnel performance evaluations: **Policy 1.07**.
  - SLA target definition: **Policy 3.01**.
  - In-flight service level measurement and operational reporting: **Policy 3.02**.
  - Service improvement intake and triage: **Policy 3.16**.
  - Internal audit and control testing mechanics: **Policy 5.02**.
  - Corrective Action Plan lifecycle: **Policy 5.03**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall approve the KPI domain structure, initial KPI selection, and material threshold changes.
  - Shall review the Quarterly KPI Review Summary prepared by the Assistant IT Director and document review acknowledgment.
  - Shall determine whether a single-period deviation is sufficiently severe to require immediate escalation despite the absence of a consecutive miss.
  - Shall approve the annual executive KPI summary prior to issuance.
  - Shall incorporate aggregate service level performance and key operational metrics into the Monthly Executive Report delivered to the County Manager in accordance with **Policy 1.14** (Stakeholder Engagement and Communications Policy).
- **Assistant IT Director**:

  - Shall maintain the live KPI register in the System of Engagement (Redmine) as the authoritative operational catalog of KPI definitions, calculation methods, targets, and current status.
  - Shall validate source data practicality and record integrity for each KPI maintained in the register.
  - Shall coordinate quarterly KPI review preparation, incorporating formal feeder summaries produced under source policies.
  - Shall prepare the Quarterly KPI Review Summary and the annual executive KPI summary.
  - Shall route qualifying underperformance patterns to the Service Improvement Register under **Policy 3.16** (Service Improvement and Continual Improvement Plan) or the Corrective Action Plan lifecycle under **Policy 5.03** (Compliance Monitoring and Corrective Action) as required by Section 6.6.
  - Shall propose KPI additions, removals, or material threshold changes to the IT Director for approval.
- **All Information Operations Personnel**:
  - Shall provide requested source data accurately and within requested timeframes.
  - Shall participate in improvement activity arising from KPI review where assigned.
  - Shall maintain process records required by the source policies that feed the KPI framework.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in KPI governance, data aggregation, performance review, or executive reporting.

- **Assessment**: Adherence to KPI governance obligations, review cadences, and routing requirements shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to maintain required KPI records, conduct required reviews, or route qualifying underperformance issues in accordance with this policy may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment). KPI deviations requiring improvement intake or formal remediation shall be routed through the existing mechanisms defined in **Policy 3.16** and **Policy 5.03**. Parallel improvement logs, corrective-action trackers, or memo-only review processes shall not be created under this policy.
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid.

5. References

Cited References:

- ECIO Policy 1.07: Workforce Roles, Responsibilities, and Competency Framework
- ECIO Policy 1.10: IT Financial Management and Procurement Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.11: Capacity and Availability Management Policy

- ECIO Policy 3.12: Monitoring and Event Management Policy
- ECIO Policy 3.14: IT Project Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.06: Vendor Compliance and Third-Party Assurance
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071558 (Activity Reports)

Framework Alignment:

- NIST CSF 2.0: PR.AT-03 (Information Security Performance Is Measured and Evaluated)
- NIST SP 800-53 Rev. 5: CA-7 (Continuous Monitoring)
- NIST SP 800-53 Rev. 5: PM-6 (Measures of Performance)
- COBIT 2019: MEA01 (Managed Performance and Conformance Monitoring)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Measurement and Reporting Practice

6. Policy Statement

This policy governs the Department's KPI framework at the scorecard and governance level. It defines what qualifies as a KPI, the required domains of KPI coverage, the recordkeeping and review cadence, and the routing rules for performance results that require action. Operational data collection remains governed by the source policies identified in the KPI register; corrective action follows the lifecycle defined in **Policy 5.03**; and improvement intake follows the routing defined in **Policy 3.16**.

6.1 KPI Qualification Criteria

A measure shall qualify as a KPI under this policy only when it meets all of the following conditions:

1. It is reviewed at the IT Director or Assistant IT Director quarterly governance level
2. It reflects departmental outcome, control health, or operational resilience
3. It is stable enough to trend across review periods
4. It is capable of triggering a governance response.

Measures that do not meet this threshold remain supporting metrics owned by their source policies.

6.2 Required KPI Domains

The Department shall maintain KPI coverage across, at minimum, the following domains:

- **Financial Stewardship**: Budget-to-actual performance, cost stewardship, and financially meaningful ratios supporting procurement, budgeting, and sustainability decisions. Source data governed by **Policy 1.10** (IT Financial Management and Procurement Policy) and **Policy 1.12** (IT Asset Management Policy).

- **Service Delivery**: Quarterly service-level KPIs sourced from the service management stack, including SLA compliance rate, Recurring Ticket Ratio, Mean Time to Repair/Recovery, and first contact resolution rate. Source data governed by **Policy 3.02** (Service Level Management and Metrics Reporting).
- **Reliability and Availability**: Measures reflecting core service continuity and operational resilience. Source data governed by **Policy 3.11** (Capacity and Availability Management Policy) and the monitoring function under **Policy 3.12** (Monitoring and Event Management Policy).
- **Security and Control Health**: Measures reflecting security hygiene and control effectiveness. Source data governed by the applicable Chapter 2 policies and **Policy 3.12**.
- **Organizational Health**: Aggregate sustainability indicators addressing workforce readiness, delivery capacity, critical role coverage, or succession fragility. Source data drawn from existing HR and departmental records.
- **Improvement and Remediation**: Measures reflecting whether adverse signals are translating into tracked improvement activity and corrective action. Source data governed by **Policy 3.16** and **Policy 5.03**.
- **Project Delivery**: On-time, on-budget, and on-scope performance for initiatives meeting the project designation threshold defined in **Policy 3.14** (IT Project Management Policy). Source data governed by **Policy 3.14**.
- **Vendor Performance**: Supplier and service-provider measures affecting county service reliability, contractual accountability, or renewal decisions. Source data governed by **Policy 3.02** Section 6.5 and **Policy 5.06** (Vendor Compliance and Third-Party Assurance).

Not every domain must contain the same number of KPIs. The KPI register shall remain deliberately limited and shall prioritize measures that are decision-useful at the departmental governance level.

6.3 KPI Register and Definition Requirements

The Assistant IT Director shall maintain a live KPI register in the System of Engagement (Redmine). The KPI register is the authoritative operational catalog for KPI definitions and current status. The policy manual defines governance requirements; the KPI register carries current formulas, targets, and statuses.

Each KPI record in the register shall include, at minimum:

- KPI title.
- Assigned domain.
- Source policy or source system.
- Calculation method or formula.
- Review cadence.
- Target value.
- Warning threshold, where used.
- Critical threshold, where used.
- Trend direction convention.
- Expected routing action when performance falls outside approved tolerances.

Initial KPI selection and all target or threshold changes shall be proposed by the Assistant IT Director and approved by the IT Director before becoming active. No KPI shall be added to, removed from, or redefined within the register without IT Director approval.

6.4 Data Sourcing

All KPI data shall be sourced exclusively from existing authoritative systems and the data collection processes governed by the source policies identified in the KPI register. Personnel shall not create manual tracking spreadsheets, shadow databases, or parallel data collection pipelines for KPIs where system-generated reporting is technically feasible. The Quarterly Service Level Performance Summary required by **Policy 3.02** Section 6.4, the project performance data feed required by **Policy 3.14** Section 6.8, and other formal feeder summaries produced under source policies shall be incorporated into the KPI review process rather than duplicated.

6.5 Quarterly KPI Review

No later than fifteen (15) business days following the close of each calendar quarter, the Assistant IT Director shall prepare a Quarterly KPI Review Summary for IT Director review. The IT Director shall review the summary and document review acknowledgment. The Quarterly KPI Review Summary shall be maintained in the System of Engagement (Redmine) as the authoritative internal record of quarterly KPI governance review.

The Quarterly KPI Review Summary shall include, at minimum:

- The quarter covered.
- The KPIs reviewed.
- Current status and trend direction for each KPI.
- Any single-period misses requiring monitoring.
- Any underperformance patterns requiring intake under **Policy 3.16**.
- Any deviations requiring Corrective Action Plan development under **Policy 5.03**.
- Approved target or threshold changes.
- Assigned follow-up actions.
- IT Director review acknowledgment.

6.6 Underperformance Thresholds and Routing

- **Single-Period Miss**: A KPI single-period miss exists when a KPI falls below its approved target or outside its approved tolerance during one quarterly review period. A single-period miss shall be documented in the Quarterly KPI Review Summary and monitored during the next review cycle.
- **Underperformance Pattern**: A KPI underperformance pattern exists when either: (a) the same KPI records two consecutive quarterly misses; or (b) the IT Director determines that a single deviation is sufficiently severe, persistent, or strategically significant to require tracked improvement despite the absence of a second consecutive miss.
- **Routing**: Upon identification of a KPI underperformance pattern, the Assistant IT Director shall log a Service Improvement Register entry in accordance with **Policy 3.16** unless the issue instead requires direct routing into the Corrective Action Plan lifecycle under **Policy 5.03**. Where KPI deviation reflects a control deficiency, compliance gap, sustained policy nonconformance, or other condition requiring formal remediation with milestones, the Assistant IT Director shall initiate or update a Corrective Action Plan in accordance with **Policy 5.03**. This policy does not create a separate remediation tracker.
- **Pattern Analysis**: Recurring Ticket Ratio and similar pattern-based KPIs shall be reviewed for evidence of documentation weakness, training need, recurring failure mode, or process design deficiency. Where the analysis identifies a systemic improvement opportunity, the Assistant IT Director shall route the issue through the Service Improvement Register.

6.7 Organizational Health Boundary

Organizational Health KPIs shall be limited to indicators that affect workforce sustainability, delivery capacity, succession fragility, or operational overdependence on specific personnel. Such indicators shall be reviewed primarily in aggregate. This policy shall not be used as an employee ranking or disciplinary scorecard. Individual personnel actions arising from organizational health review shall be handled through normal supervisory and HR processes, not through the KPI governance process defined in this policy.

6.8 Executive Reporting

The IT Director shall extract a targeted subset of the KPI taxonomy to fulfill the Monthly Executive Report obligation established in **Policy 1.14** Section 6.2. The Monthly Executive Report content is the IT Director's executive communication derivative; it draws from, but does not replace, the quarterly governance record.

No later than the end of the first calendar quarter following year-end, the Assistant IT Director shall prepare an annual KPI and operational performance summary for IT Director approval. This summary may be incorporated into the Department's annual reporting or other executive communication issued through County leadership channels.

6.9 Records Retention

The Quarterly KPI Review Summary is the authoritative record of KPI governance review. Annual executive summaries are derivative communication artifacts and do not replace the quarterly record.

Quarterly KPI Review Summaries shall be maintained in the System of Engagement (Redmine) and retained in accordance with the Nevada Local Government Records Retention Schedule under NRS 239.125, for a minimum of three (3) years from the date of production unless a longer period is required by another applicable authority: LRDA 20071558 (Activity Reports).

Where annual executive summaries are issued as formal reports or memoranda, they shall be retained in accordance with the applicable County records-management practice for the record series under which they are filed.

5.05 Security Control Assessment and Authorization

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the authorization decision process by which the IT Director, as the designated Authorizing Official, reviews security control assessment results and renders formal authorization decisions for County information systems and controls governed by the ECIO Policy Manual.

2. Scope

This policy applies to all information systems, controls, and assets governed by the ECIO Policy Manual that require formal authorization to operate within the County production environment.

- **In Scope**:
  - Review of assessment results and audit findings for authorization decisions.
  - Formal authorization, conditional authorization, or denial decisions.
  - Documentation and retention of authorization decision records.
  - Risk-informed conditions attached to conditional authorizations.
  - Reauthorization determinations following changes to system boundary, risk profile, or control posture.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Control testing, self-assessment, and internal audit mechanics: **Policy 5.02**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the Authorizing Official for all County information systems and controls, consistent with the designation established in **Policy 1.09** (Risk Management Policy).
  - Shall review assessment results delivered under **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and render formal authorization decisions.
  - Shall attach risk-based conditions or require compensating controls when granting conditional authorization.
  - Shall ensure that each authorization decision is documented in an authorization decision record and retained in accordance with **Policy 3.13** (Knowledge Management Policy).

  - Shall evaluate whether denial of authorization for a system processing Criminal Justice Information Services (CJIS) data affects active CJIS compliance obligations and, when warranted, shall ensure that appropriate operational, service-restriction, or partner-notification steps are taken through the applicable policies: **Policy 5.03** (Compliance Monitoring and Corrective Action), **Policy 4.02** (Identification and Reporting Procedures), and **Policy 4.06** (Communication Protocols and Partner Integration).

- **Assistant IT Director**:
  - Shall compile the decision inputs for each authorization review by assembling the current **Policy 5.02** assessment results, the **Policy 1.09** risk ratings and security categorization documentation, and the status of any open Corrective Action Plans under **Policy 5.03**.
  - Shall present the compiled decision inputs to the IT Director with a risk summary and a recommendation.
  - Shall document the IT Director's authorization decision in the System of Engagement (Redmine) and maintain the authorization decision record.
  - Shall route deficiencies identified through a denial decision to **Policy 5.03** for Corrective Action Plan development.
  - Shall update the corresponding Risk Register entry under **Policy 1.09** to reflect the authorization status following each decision.
- **All Department Personnel**:
  - Shall provide requested evidence or clarification during the authorization review process when directed by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in authorization decision preparation, review, or documentation.

- **Assessment**: Adherence to authorization decision documentation, retention, and routing requirements shall be assessed through the internal audit process defined in **Policy 5.02** and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Deployment of any information system to the County production network without a valid authorization, or failure to document authorization decisions as required by this policy, may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented with justification and approved in writing by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 4.02: Identification and Reporting Procedures
- ECIO Policy 4.06: Communication Protocols and Partner Integration

- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)

Framework Alignment:

- CJIS Security Policy v6.0: CA-1 (Assessment, Authorization, and Monitoring Policy and Procedures)
- NIST CSF 2.0: ID.RA-06 (Risk Responses)
- NIST SP 800-37 Rev. 2: (Risk Management Framework for Information Systems and Organizations)
- NIST SP 800-53 Rev. 5: CA-6 (Authorization)
- COBIT 2019: MEA02 (Managed System of Internal Control)
- ITIL v4: Risk Management Practice

6. Policy Statement

6.1 Authorization Decision Process

No County information system shall process production data or maintain persistent connectivity to the County production network without a valid authorization decision rendered by the IT Director. This policy implements the Authorize step of the NIST Risk Management Framework lifecycle adopted in **Policy 1.09** Section 6.1.

Authorization decisions shall be made solely on the basis of assessment results and audit findings delivered under **Policy 5.02**, current risk ratings and security categorization documentation maintained under **Policy 1.09**, and the status of any open Corrective Action Plans tracked under **Policy 5.03**. No separate or parallel testing, assessment, or evidence-collection activity shall be performed under this policy. Where the IT Director determines that existing assessment coverage is insufficient to support an authorization decision, the IT Director shall direct the Assistant IT Director to schedule supplemental assessment activity through the mechanisms defined in **Policy 5.02**.

The Assistant IT Director shall compile the decision inputs and present them to the IT Director with a risk summary that identifies: the system or control under review, the security categorization, the assessment results and any open deficiencies, the current risk rating, and a recommendation. The IT Director shall review the compiled inputs and render one of the decision outcomes defined in Section 6.2.

6.2 Decision Outcomes

The IT Director shall render one of the following decisions for each system or control submitted for authorization review.

- **Authorization to Operate**: Issued when **Policy 5.02** assessment results verify that controls are implemented correctly, operating as intended, and producing the desired outcome, and residual risk is within the risk tolerance defined in the Risk Management Strategy maintained under **Policy 1.09**. The system is approved for production operation.
- **Conditional Authorization**: Issued when residual risk exceeds tolerance but can be managed through documented compensating controls or time-bound conditions. The authorization decision record shall identify each condition, the compensating control or remediation action required, and the timeframe for resolution. When a conditional authorization depends on acceptance of residual risk above tolerance, the condition shall be supported by a Risk Acceptance Memo under **Policy 1.09** and documented in the Risk Register. Conditions shall be tracked through the Corrective Action Plan lifecycle under

Policy 5.03 when they require milestone-based remediation. The IT Director may revoke a conditional authorization at any time if conditions are not met within the specified timeframe or if the risk posture deteriorates.

- **Denial of Authorization**: Issued when controls are inadequate and residual risk exceeds tolerance without acceptable compensating controls. A denial prohibits the system from operating in the production environment. The Assistant IT Director shall route the underlying deficiencies to **Policy 5.03** for Corrective Action Plan development. A system that has been denied authorization may be resubmitted for review after remediation is verified through the assessment mechanisms defined in **Policy 5.02**.

6.3 Authorization Decision Record

Each authorization decision shall be documented in the System of Engagement (Redmine) as an authorization decision record. The record shall include, at minimum: the system or control name and identifier, the security categorization, the decision outcome, the assessment results summary relied upon, the risk rationale supporting the decision, any conditions attached to a conditional authorization, and the IT Director's approval. The Assistant IT Director shall maintain authorization decision records in accordance with **Policy 3.13** and the Nevada Local Government Records Retention Schedule under NRS 239.125, for a minimum of three (3) years from the date of the decision unless a longer period is required by another applicable authority.

6.4 Reauthorization and Revocation

Authorization decisions remain valid until a subsequent event requires the IT Director to render a new decision. The following events shall trigger a reauthorization review:

- The annual assessment cycle conducted under **Policy 5.02** produces findings that change the risk posture of an authorized system.
- A change to the system boundary, architecture, data classification, or control posture that alters the system's risk profile occurs.
- The IT Director determines that a change in the threat environment, regulatory landscape, or operational context warrants reauthorization.
- A Corrective Action Plan associated with a conditional authorization fails to achieve closure within the approved timeframe.

The IT Director shall render a new authorization decision following the same process defined in Sections 6.1 and 6.2. The new decision shall supersede the prior authorization decision record. The prior record shall be retained in accordance with Section 6.3.

The IT Director may revoke an existing authorization at any time when the risk posture requires immediate action, without waiting for a reauthorization trigger. A revocation shall be documented as a new authorization decision record with Denial of Authorization as the outcome and shall include the risk rationale for immediate action.

6.5 CJIS-Specific Considerations

For systems processing Criminal Justice Information Services (CJIS) data, authorization decisions shall incorporate the CJIS-specific assessment frequency and independent-assessor requirements already defined in **Policy 5.02**. This policy does not establish separate CJIS assessment mechanics; it consumes the CJIS-relevant assessment results that **Policy 5.02** produces. Denial or revocation of authorization for any system processing CJIS data shall trigger the IT Director's evaluation of whether the system's inability to operate affects active CJIS compliance obligations, and when warranted, the IT Director shall ensure that appropriate operational and notification steps are taken through **Policy 5.03**, **Policy 4.02**, and **Policy 4.06**.

5.06 Vendor Compliance and Third-Party Assurance

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the ongoing compliance monitoring, third-party assurance evaluation, and vendor remediation framework for vendors, contractors, and third-party service providers engaged with Elko County information systems.

2. Scope

This policy applies to all active vendor, contractor, and third-party service provider relationships that fall within the scope of **Policy 1.13** (Supply Chain Risk Management (SCRM) and Vendor Governance).

- **In Scope**:
  - Vendor compliance monitoring and review.
  - Third-party assurance evidence collection and evaluation.
  - Criminal Justice Information Services (CJIS) vendor compliance assessment.
  - Vendor enforcement notification intake from **Policy 5.01**.
  - Vendor remediation and Corrective Action Plan routing.
  - Contract action recommendations based on sustained non-compliance.
  - Vendor compliance data feed to the KPI framework in **Policy 5.04**.
- **Out of Scope**:
  - Risk assessment methodology and Risk Register maintenance: **Policy 1.09**.
  - Vendor onboarding, contracting, and pre-engagement controls: **Policy 1.13**.
  - Vendor SLA performance measurement and operational reporting: **Policy 3.02**.
  - IT-administrative enforcement actions and formal sanctions: **Policy 5.01**.
  - Internal audit mechanics and control testing methodology: **Policy 5.02**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Security control authorization decisions: **Policy 5.05**.
  - Annual policy review and maturity scoring: **Policy 5.07**.

3. Roles and Responsibilities

- **IT Director**:
  - Shall serve as the approving authority for all vendor compliance review outcomes and contract action recommendations produced under this policy.
  - Shall exercise the contractual audit and inspection rights established in **Policy 1.13** Section 6.3, including the authority to initiate triennial audits and unannounced security inspections of vendors with access to Criminal Justice Information (CJI).

  - Shall authorize unscheduled vendor compliance reviews when enforcement notification patterns, assurance evidence deficiencies, or other risk conditions warrant assessment outside the standard cadence.
  - Shall determine whether vendor compliance findings constitute risk-relevant inputs requiring referral to the Risk Register maintained under **Policy 1.09** (Risk Management Policy). This policy identifies and routes risk-relevant findings; **Policy 1.09** governs risk scoring, acceptance, and Risk Register maintenance.
  - Shall approve deviations from the approved assurance evidence types defined in Section 6.4.
- **Assistant IT Director**:
  - Shall maintain the Vendor Compliance Record for each vendor within scope, in the System of Engagement (Redmine), in accordance with **Policy 3.13** (Knowledge Management Policy) and Section 6.1 of this policy.
  - Shall conduct or coordinate all scheduled and unscheduled vendor compliance reviews defined in Section 6.2.
  - Shall prepare pre-renewal compliance evaluations and submit them to the IT Director in accordance with Section 6.3.
  - Shall collect, catalog, and evaluate third-party assurance evidence in accordance with Section 6.4.
  - Shall prepare vendor compliance data for integration with the Vendor Performance KPI domain defined in **Policy 5.04** (Performance Metrics and Operational KPIs).
  - Shall route vendor compliance deficiencies requiring formal remediation to the Corrective Action Plan lifecycle governed by **Policy 5.03** (Compliance Monitoring and Corrective Action) in accordance with Section 6.6.
  - Shall document contract action recommendations for IT Director review in accordance with Section 6.7.
- **Requesting Department Head**:
  - Shall cooperate with vendor compliance reviews by providing business-side performance information, contract deliverable status, and vendor relationship context when requested by the Assistant IT Director.
  - Shall notify the Assistant IT Director of vendor performance concerns, missed deliverables, or contractual disputes that may affect the vendor's compliance posture.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in vendor compliance monitoring, review, or reporting.

- **Assessment**: Adherence to vendor compliance review cadences, Vendor Compliance Record maintenance, assurance evidence collection, and reporting obligations shall be assessed through the internal audit process defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) and the annual policy review and maturity scoring process defined in **Policy 5.07** (Annual Policy Review and Maturity Scoring).
- **Enforcement**: Failure to conduct required vendor compliance reviews, failure to maintain Vendor Compliance Records, failure to collect or evaluate required assurance evidence, or failure to act on enforcement notifications received under **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment) shall be treated as non-compliance and may result in corrective action in accordance with **Policy 5.01**.

- **Exceptions**: Exceptions to any requirement of this policy shall be documented in writing with a business justification and approved by the IT Director in accordance with the exception management framework established in **Policy 5.01**. Exceptions affecting CJIS vendor compliance assessment cadences, CJIS Security Addendum verification requirements, or the exercise of contractual audit rights for vendors with access to CJI shall require County Manager approval in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights). No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline. No exception shall be granted that would place County systems or CJI out of compliance with applicable CJIS Security Policy obligations.

5. References

Cited References:

- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.12: IT Asset Management Policy
- ECIO Policy 1.13: Supply Chain Risk Management (SCRM) and Vendor Governance
- ECIO Policy 3.01: Service Catalog and SLA Policy
- ECIO Policy 3.02: Service Level Management and Metrics Reporting
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.17: System Maintenance and Vendor Repairs
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Policy 5.05: Security Control Assessment and Authorization
- ECIO Policy 5.07: Annual Policy Review and Maturity Scoring
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071300 (Vendor Performance Case Files)
- CJIS Security Policy v6.0: Section CA-2 (Control Assessments)
- CJIS Security Policy v6.0: Section CA-2(1) (Independent Assessors)
- CJIS Security Policy v6.0: Section SA-9 (External System Services)
- CJIS Security Policy v6.0: Section SR-8 (Notification Agreements)
- NIST SP 800-53 Rev. 5: SA-9 (External System Services)
- NIST SP 800-53 Rev. 5: SR-6 (Supplier Assessments and Reviews)

Framework Alignment:

- NIST CSF 2.0: GV.SC-06 (Cybersecurity Supply Chain Risk Management)
- NIST SP 800-37 Rev. 2: (Risk Management Framework for Information Systems and Organizations)
- COBIT 2019: APO10 (Manage Vendors)
- ITIL v4: Supplier Management Practice

6. Policy Statement

Policy 1.13 governs the engagement, onboarding, and contracting of third-party service providers. This policy governs what happens after a vendor is active: the ongoing evaluation of whether vendors continue to meet the security, compliance, and performance standards that justified their engagement. This policy consumes operational data produced by the service management function (**Policy 3.01** and **Policy 3.02**), enforcement data produced by the compliance function (**Policy 5.01**), and assurance evidence provided by the vendors themselves. It produces compliance posture assessments and contract action recommendations that feed back into governance decisions under **Policy 1.09**, enforcement decisions under **Policy 5.01**, corrective action under **Policy 5.03**, and the Vendor Performance KPI domain under **Policy 5.04**.

6.1 Vendor Compliance Record

The Assistant IT Director shall establish and maintain a Vendor Compliance Record for each vendor, contractor, or third-party service provider within scope of this policy. The Vendor Compliance Record shall be maintained in the System of Engagement (Redmine) in accordance with **Policy 3.13** and shall serve as the consolidated, authoritative record of the vendor's compliance posture across all assets, contracts, and service relationships.

- **Record Content**: Each Vendor Compliance Record shall include, at minimum:
  - The vendor name and all associated contracts or service agreements.
  - The asset support classifications (IT-Managed, IT-Supported, or Vendor-Managed) applicable to the vendor's services as defined in **Policy 1.12** (IT Asset Management Policy).
  - The data classification tier of data the vendor accesses or processes as defined in **Policy 1.11** (Data Governance and Classification Policy).
  - Whether the vendor has logical or physical access to Criminal Justice Information (CJI).
  - The current CJIS Security Addendum status, where applicable.
  - The vendor SLA performance data maintained under **Policy 3.02** Section 6.5.
  - All enforcement notifications received from **Policy 5.01**.
  - All third-party assurance evidence received and evaluated under Section 6.4.
  - The outcome of each vendor compliance review conducted under Section 6.2.
  - The status of any active Corrective Action Plan (CAP) associated with the vendor under **Policy 5.03**.
- **Work Order Linkage**: The Vendor Compliance Record shall reference the work orders associated with vendor-related events including SLA breaches recorded under **Policy 3.02** Section 6.5, enforcement actions received under **Policy 5.01** Section 6.4, and maintenance events recorded under **Policy 3.17** (System Maintenance and Vendor Repairs). The work order system is the operational evidence base; the Vendor Compliance Record is the compliance summary layer.
- **Enforcement Notification Intake**: When the IT Director provides written notification to the vendor compliance process under **Policy 5.01** Section 6.4 (Contractors and Vendors), the Assistant IT Director shall log the notification in the applicable Vendor Compliance Record within two (2) business days of receipt. The log entry shall document the date the notification was received to establish the logging deadline.
- **Notification Log Content**: The log entry shall include:
  - The date of the enforcement action
  - The non-compliance identified
  - The IT-administrative action taken

  - The policy basis
  - The affected County systems or services
  - The responsible contract administrator.
- **Review Integration**: Enforcement notifications shall be considered in the next scheduled vendor compliance review.
- **Unscheduled Review Trigger**: Where two (2) or more enforcement notifications are received for the same vendor within any rolling twelve (12) month period, or where a single notification involves a Critical-severity incident or CJI exposure, the Assistant IT Director shall recommend to the IT Director that an unscheduled vendor compliance review be initiated.

6.2 Annual Vendor Compliance Review

The Assistant IT Director shall conduct or coordinate a vendor compliance review for each vendor within scope no less than annually. The annual vendor compliance review establishes the minimum review floor; pre-renewal reviews under Section 6.3 and unscheduled reviews triggered under Section 6.1 or Section 6.5 are additional and do not reset the annual cycle.

- **Review Inputs**: Each vendor compliance review shall evaluate, at minimum:
  - Vendor SLA performance data for the review period, sourced from the Vendor Compliance Record and the vendor SLA performance tracking maintained under **Policy 3.02** Section 6.5.
  - Enforcement notifications received during the review period.
  - The currency and sufficiency of third-party assurance evidence under Section 6.4.
  - CJIS Security Addendum compliance status, where applicable.
  - The status of any open Corrective Action Plan associated with the vendor.
  - Any vendor-related incidents, findings, or risk conditions identified during the review period.
- **Review Output**: The Assistant IT Director shall document each vendor compliance review in the Vendor Compliance Record. The review record shall include the date, the period covered, the data sources evaluated, a compliance determination for each evaluation criterion, an overall vendor compliance posture assessment, and any recommended actions. The compliance posture assessment shall use one of the following determinations: Compliant, Compliant with Observations, Non-Compliant — Remediation Required, or Non-Compliant — Contract Action Recommended.
- **Routing**: A determination of Non-Compliant — Remediation Required shall initiate the vendor remediation and Corrective Action Plan routing defined in Section 6.6. A determination of Non-Compliant — Contract Action Recommended shall initiate the escalation process defined in Section 6.7. Observations identified under a Compliant with Observations determination shall be documented in the Vendor Compliance Record, communicated to the vendor in writing, and evaluated during the next scheduled vendor compliance review. Compliance review outcomes that constitute risk-relevant findings shall be referred to the IT Director for consideration as inputs to the Risk Register under **Policy 1.09**.
- **Unscheduled Reviews**: The IT Director may authorize an unscheduled vendor compliance review at any time based on enforcement notification patterns, assurance evidence deficiencies, security incidents involving vendor systems or personnel, or other risk conditions. Unscheduled reviews shall follow the same input, output, and routing requirements as annual reviews.

6.3 Pre-Renewal Compliance Evaluation

No later than ninety (90) calendar days prior to the expiration or renewal date of any contract with a vendor within scope of this policy, the Assistant IT Director shall prepare a pre-renewal compliance evaluation

and submit it to the IT Director for review. This evaluation aligns with and incorporates the vendor SLA performance summary required by **Policy 3.01** (Service Catalog and SLA Policy) Section 6.5.

- **Evaluation Content**: The pre-renewal compliance evaluation shall include, at minimum:
  - The complete Vendor Compliance Record history for the current contract period.
  - A summary of the vendor's SLA performance across the contract period, sourced from **Policy 3.02** Section 6.5.
  - A summary of enforcement notifications received during the contract period.
  - The status and outcome of all third-party assurance evidence evaluations during the contract period.
  - The status and outcome of any Corrective Action Plans associated with the vendor during the contract period.
  - CJIS compliance status, where applicable.
  - A compliance posture recommendation for the IT Director's consideration in the renewal decision.
- **IT Director Action**: The IT Director shall review the pre-renewal compliance evaluation and document a renewal recommendation. The renewal recommendation shall be one of the following: Renew Without Conditions, Renew With Conditions (specifying the conditions), Do Not Renew, or Escalate to Contract Administrator and Legal Counsel. The documented renewal recommendation shall be provided to the Requesting Department Head identified in **Policy 1.13** Section 3.
- **Contracts Without Defined Renewal Dates**: For evergreen contracts or contracts with automatic renewal provisions, the Assistant IT Director shall conduct the pre-renewal compliance evaluation annually, aligned with the annual vendor compliance review, and shall note the evaluation as serving both the annual review and the pre-renewal function.

6.4 Third-Party Assurance Evidence

For vendors whose services involve access to County data classified as Confidential or Restricted under **Policy 1.11**, or whose services involve access to CJI, the Information Operations Department shall maintain an ongoing program of third-party assurance evidence collection and evaluation.

- **Assurance Evidence Types**: Acceptable assurance evidence shall be restricted to the following approved artifact types:
  - Service Organization Control (SOC) reports (SOC 1, SOC 2 Type I, SOC 2 Type II).
  - Independent security assessments or penetration test summaries.
  - Completed security questionnaires using County-defined or industry-standard formats.
  - Certifications or attestation letters from recognized bodies (e.g., ISO 27001).
  - CJIS Security Addendum Certifications required by **Policy 1.13** Section 6.3.
  - Any deviation from or substitution for these approved artifact types shall require documented IT Director approval.
- **Collection Cadence**: The Assistant IT Director shall request updated assurance evidence from each vendor subject to this section no less than annually, or upon the issuance of new SOC reports or the renewal of relevant certifications. For CJIS vendors, the CJIS Security Addendum Certification and supporting CJIS compliance documentation shall be verified no less than annually and following any change in vendor personnel with CJI access.
- **Evaluation**: The Assistant IT Director shall review each piece of assurance evidence received and document the evaluation in the Vendor Compliance Record. The evaluation shall note whether the evidence is current, whether it covers the services provided to the County, whether it identifies control

deficiencies relevant to County risk, and whether any exceptions, qualifications, or findings in the evidence require County follow-up. Where assurance evidence reveals control deficiencies affecting County data or systems, the Assistant IT Director shall notify the IT Director and recommend whether the deficiency warrants a Corrective Action Plan under **Policy 5.03**, a contract action recommendation under Section 6.7, or an unscheduled vendor compliance review.

- **Failure to Provide**: Where a vendor fails to provide requested assurance evidence within thirty (30) calendar days of the request, the Assistant IT Director shall escalate to the IT Director. The IT Director shall determine whether the failure constitutes a compliance concern warranting further action, including initiation of a Corrective Action Plan under **Policy 5.03** or exercise of contractual audit rights.

6.5 CJIS Vendor Compliance

For vendors with logical access to CJI, or unescorted access to physically secure locations where CJI is processed, the following CJIS-specific compliance obligations apply in addition to the general requirements of this policy. These obligations operationalize the contractual audit and oversight rights established in **Policy 1.13** Section 6.3 and the control assessment requirements of CJIS Security Policy v6.0: Section CA-2 (Control Assessments). This policy governs the County's ongoing monitoring of CJIS vendor compliance after activation; it does not create, modify, or weaken the underlying contractual requirements established in **Policy 1.13** Section 6.3.

- **Triennial Assessment**: The IT Director shall ensure that each CJIS vendor undergoes a compliance assessment no less than once every three (3) years, consistent with CJIS Security Policy v6.0: Section CA-2. The assessment shall evaluate the vendor's implementation and operating effectiveness of controls applicable to CJI protection. The IT Director shall determine whether the assessment is conducted by Information Operations personnel, by an independent assessor, or through a combination of both, considering the objectivity requirements of CJIS Security Policy v6.0: Section CA-2(1) (Independent Assessors) and the assessment resources available. Where internal personnel are utilized, the IT Director shall ensure the selected assessors possess organizational independence from the vendor management activities being assessed, consistent with the objectivity safeguards established in **Policy 5.02** Section 6.4.
- **Unannounced Inspections**: The IT Director retains the authority to conduct unannounced security inspections of CJIS vendor operations, as provided by the contractual terms established under **Policy 1.13** Section 6.3. The IT Director shall exercise this authority when risk conditions, enforcement notification patterns, or assurance evidence deficiencies indicate that a planned assessment may not provide sufficient assurance.
- **Security Addendum Verification**: The Assistant IT Director shall verify, no less than annually, that all CJIS vendor personnel with access to CJI have executed current CJIS Security Addendum Certifications as required by **Policy 1.13** Section 6.3. Any gap in Security Addendum coverage shall be treated as a compliance deficiency and logged in the Vendor Compliance Record.
- **Notification Agreements**: Consistent with CJIS Security Policy v6.0: Section SR-8 (Notification Agreements) and NIST SP 800-53 Rev. 5: SA-9 (External System Services), the IT Director shall verify that each CJIS vendor's contract includes the incident notification and cooperation provisions required by **Policy 1.13** Section 6.3. Where a CJIS vendor fails to meet the notification timelines established in **Policy 1.13**, the failure shall be documented in the Vendor Compliance Record and treated as a compliance deficiency.
- **Findings Routing**: CJIS assessment findings that constitute control deficiencies shall be routed to **Policy 5.03** for Corrective Action Plan development. CJIS assessment findings that affect the authorization posture of a system processing CJI shall be provided to the IT Director for consideration under **Policy 5.05** (Security Control Assessment and Authorization). CJIS assessment results shall be documented in the Vendor Compliance Record.

6.6 Vendor Remediation and Corrective Action Routing

When a vendor compliance review under Section 6.2 produces a determination of Non-Compliant — Remediation Required, or when the IT Director determines that a vendor's cumulative compliance posture warrants formal remediation, the identified deficiencies shall be routed to the Corrective Action Plan (CAP) lifecycle governed by **Policy 5.03**. This policy defines the vendor-specific triggers and referral content; **Policy 5.03** governs CAP development, tracking, and closure.

- **CAP Referral Content**: The Assistant IT Director shall prepare the CAP referral and submit it to the IT Director for approval. The referral shall include:
  - The vendor name and applicable contracts.
  - The specific compliance deficiencies or performance failures that triggered the referral.
  - The affected County systems or services.
  - The contract administrator responsible for the vendor relationship.
  - Any interim risk mitigation measures in effect.
- **Vendor Notification**: Upon IT Director approval of the CAP referral, the Assistant IT Director shall provide written notification to the vendor and to the Requesting Department Head. The notification shall identify the deficiencies, the required remediation outcomes, and the CAP timeline established under **Policy 5.03**. Vendor notification is an operational communication; it does not require vendor agreement or acceptance to take effect.
- **Monitoring**: The Assistant IT Director shall update the Vendor Compliance Record with the CAP reference and shall monitor vendor-related CAP progress as part of each subsequent scheduled vendor compliance review.
- **Closure or Escalation**: Where the vendor achieves the required remediation outcomes within the CAP timeline, the Assistant IT Director shall document the resolution in the Vendor Compliance Record. Where a vendor-related CAP fails to achieve closure within the approved timeline, or where the vendor's compliance posture deteriorates during the CAP period, the Assistant IT Director shall recommend escalation to contract action under Section 6.7.
- **Clarification**: Observations that do not meet the threshold for formal CAP development shall be documented in the Vendor Compliance Record and communicated to the vendor in writing. The observations shall be evaluated during the next scheduled vendor compliance review.

6.7 Escalation and Contract Action Recommendations

When a vendor compliance review under Section 6.2 produces a determination of Non-Compliant — Contract Action Recommended, or when a vendor-related Corrective Action Plan under Section 6.6 fails to achieve closure, the Assistant IT Director shall prepare a formal contract action recommendation for IT Director review.

- **Recommendation Content**: The contract action recommendation shall include, at minimum:
  - A summary of the vendor's compliance history from the Vendor Compliance Record.
  - The specific compliance deficiencies or CAP failures that support the recommendation.
  - The recommended action (which may include contract modification, contract non-renewal, contract termination for cause, or other contractual remedy as applicable).
  - The potential operational impact of the recommended action on County services.
- **IT Director Action**: The IT Director shall review the contract action recommendation and determine the appropriate course of action. Where the IT Director concurs with the recommendation, the IT Director shall refer the matter to the contract administrator and County legal counsel for contract remedies, consistent with the referral pathway established in **Policy 5.01** Section 6.4 (Contractors

and Vendors). The IT Director's authority to revoke or restrict system access under **Policy 5.01** is independent of the contract remedy process and may be exercised at any point.

- **Documentation**: All contract action recommendations, IT Director determinations, and referrals shall be documented in the Vendor Compliance Record and retained in accordance with Section 6.9.

6.8 Vendor Performance Data Feed

This policy serves as a source data provider for the Vendor Performance KPI domain established in **Policy 5.04** Section 6.2. The Assistant IT Director shall ensure that vendor compliance review outcomes, CAP status, assurance evidence currency, and CJIS compliance status are available for incorporation into the Quarterly KPI Review Summary prepared under **Policy 5.04** Section 6.5. This data feed supplements the vendor SLA performance data provided by **Policy 3.02** Section 6.5 and shall not duplicate data already captured in the service level management function.

6.9 Record Retention

Records generated under this policy shall be retained in accordance with NRS 239.125 and the Nevada Local Government Records Retention Schedule.

- **Vendor Compliance Records**: Vendor Compliance Records, including all compliance review records, assurance evidence evaluations, enforcement notification logs, CAP referrals, and contract action recommendations, shall be retained in the System of Engagement (Redmine) for six (6) calendar years after the record is closed, in accordance with LRDA 20071300 (Vendor Performance Case Files). A Vendor Compliance Record is closed when the vendor no longer provides services to the County and all open compliance actions, Corrective Action Plans, and contract action recommendations associated with the vendor have been resolved or formally closed.
- **CJIS Assessment Records**: For vendors with access to CJI, assessment records shall be retained for the greater of the LRDA 20071300 retention period or the CJIS-required retention period applicable at the time of the assessment.
- **Litigation and Legal Holds**: The IT Director shall ensure that retention and disposition actions are suspended during litigation holds, public records preservation requirements, or other legal hold events.
- **Public Records**: All records generated under this policy are subject to NRS 239 and may be subject to public disclosure unless protected by a specific statutory exemption. Disclosure determinations for vendor compliance records containing security findings, assurance evidence, or CJIS-related materials shall be made in coordination with the County's public records process and legal counsel, consistent with applicable exemptions and the data classification requirements of **Policy 1.11**.

5.07 Annual Policy Review and Maturity Scoring

Effective: July 01, 2026 Version: 1.0

1. Purpose

This policy establishes the annual policy review process, maturity scoring methodology, and executive reporting requirements that the Information Operations Department uses to evaluate the implementation effectiveness and operational maturity of the ECIO Policy Manual.

2. Scope

This policy applies to all policies and governed appendices within the ECIO Policy Manual.

- **In Scope**:
  - Annual review of each policy for implementation effectiveness, operational relevance, and regulatory alignment.
  - Maturity scoring of each policy using the NIST Cybersecurity Framework 2.0 Tier model.
  - Annual review of governed appendices for currency and accuracy.
  - Evaluation of audit program effectiveness.
  - Preparation and submission of the Annual Policy Review Report.
  - Executive reporting to the County Manager.
- **Out of Scope**:
  - Policy lifecycle management, version control, and change control workflow: **Policy 1.05**.
  - Internal audit planning, assessment execution, and deficiency classification: **Policy 5.02**.
  - Enforcement actions and formal sanctions: **Policy 5.01**.
  - Corrective Action Plan development, tracking, and closure: **Policy 5.03**.
  - Performance metric governance and KPI catalog maintenance: **Policy 5.04**.
  - Vendor and third-party compliance assessments: **Policy 5.06**.
  - Standard Operating Procedures, playbooks, and operational documentation maintained in the System of Engagement: **Policy 1.04** and **Policy 3.13**.

3. Roles and Responsibilities

- **County Manager**:
  - Shall receive and review the Annual Policy Review Report submitted by the IT Director.
  - Shall provide written acknowledgment of receipt and review within thirty (30) calendar days of submission.
  - Shall direct the IT Director to address specific concerns, conduct additional analysis, or revise maturity tier assignments when the County Manager determines that documented justification warrants such direction.
  - Shall approve exceptions to this policy that would materially affect the annual review, as defined in Section 4.

- **IT Director**:
  - Shall conduct the annual policy review and maturity scoring process defined in this policy.
  - Shall assign a maturity tier to each policy in the ECIO Policy Manual in accordance with the methodology defined in Section 6.3.
  - Shall evaluate the effectiveness of the internal audit program defined in **Policy 5.02** (Internal Audits, Self-Assessment, and Control Testing) in accordance with Section 6.4.
  - Shall prepare and submit the Annual Policy Review Report to the County Manager in accordance with Section 6.5.
  - Shall route findings to the remediation pathways defined in Section 6.7.
  - Shall complete the annual policy review within the timeline defined in Section 6.1.
- **Assistant IT Director**:
  - Shall compile the assessment inputs defined in Section 6.2.
  - Shall present compiled inputs to the IT Director prior to the start of the review.
  - Shall produce the annual improvement summary under **Policy 3.16** (Service Improvement and Continual Improvement Plan) for inclusion as an input to the review process.
  - Shall maintain all review records and scoring documentation in the System of Engagement.
  - Shall update the Policy Matrix (**Appendix 6.02**) to reflect current maturity tier assignments following IT Director approval.
- **All Information Operations Personnel**:
  - Shall provide requested evidence, documentation, or operational context during the annual policy review process when directed by the IT Director or Assistant IT Director.

4. Compliance and Exceptions

Compliance with this policy is mandatory for all Information Operations personnel involved in the annual policy review, maturity scoring, or executive reporting process.

- **Assessment**: Compliance with the review cadence, scoring methodology, report preparation, and submission requirements of this policy shall be assessed through the internal audit process defined in **Policy 5.02**. The County Manager's review of the Annual Policy Review Report, as defined in Section 6.6, provides independent oversight of this policy's execution.
- **Enforcement**: Failure to conduct the annual policy review within the required timeframe, failure to prepare or submit the Annual Policy Review Report, or failure to route findings to the required remediation pathways may result in corrective action in accordance with **Policy 5.01** (Policy Implementation, Enforcement, and Legal Alignment).
- **Exceptions**: Exceptions to this policy shall be documented in writing with a business justification. Exceptions that would materially affect the annual review — including extension or waiver of the submission deadline, suppression or omission of required report content, alteration of the scoring methodology, or omission of the audit program effectiveness evaluation defined in Section 6.4 — shall be approved by the County Manager in accordance with **Policy 1.08** (Delegation of Authority and Decision Rights) and the exception management framework established in **Policy 5.01**. All other exceptions shall be approved by the IT Director in accordance with **Policy 5.01**. Oral exceptions are not valid. No exception shall be granted on an open-ended basis; each exception shall specify a defined remediation timeline.

5. References

Cited References:

- ECIO Policy 1.04: Policy and Documentation Formatting Standards
- ECIO Policy 1.05: Policy Review and Update Procedures
- ECIO Policy 1.08: Delegation of Authority and Decision Rights
- ECIO Policy 1.09: Risk Management Policy
- ECIO Policy 1.11: Data Governance and Classification Policy
- ECIO Policy 1.14: Stakeholder Engagement and Communications Policy
- ECIO Policy 3.13: Knowledge Management Policy
- ECIO Policy 3.16: Service Improvement and Continual Improvement Plan
- ECIO Policy 4.07: (Postmortem Review and Lessons Learned)
- ECIO Policy 5.01: Policy Implementation, Enforcement, and Legal Alignment
- ECIO Policy 5.02: Internal Audits, Self-Assessment, and Control Testing
- ECIO Policy 5.03: Compliance Monitoring and Corrective Action
- ECIO Policy 5.04: Performance Metrics and Operational KPIs
- ECIO Appendix 6.02: Policy Matrix
- NRS 239.125 (Local Government Records Management Program)
- LRDA 20071256 (Quality Assurance Review Audits and Reports)

Framework Alignment:

- CJIS Security Policy v6.0: CA-1 (Assessment, Authorization, and Monitoring Policy and Procedures)
- NIST CSF 2.0: GV.PO-02 (Policy Review)
- NIST CSF 2.0: ID.IM-01 (Improvements Are Identified from Evaluations)
- NIST SP 800-53 Rev. 5: PM-1 (Information Security Program Plan)
- NIST SP 800-53 Rev. 5: PM-6 (Measures of Performance)
- COBIT 2019: MEA01 (Manage Performance and Conformance Monitoring)
- COBIT 2019: MEA03 (Monitor, Evaluate and Assess Compliance with External Requirements)
- ITIL v4: Continual Improvement Practice
- ITIL v4: Measurement and Reporting Practice

6. Policy Statement

The ECIO Policy Manual is a living governance instrument. The policies within it are not static artifacts; they are operational controls that the Department shall evaluate annually for continued relevance, implementation effectiveness, and alignment with the regulatory and operational environment. This policy establishes the structured methodology for that evaluation and the reporting mechanism that delivers accountability to County leadership.

This policy does not govern the policy change control lifecycle — that function belongs to **Policy 1.05**. This policy does not conduct audits, self-assessments, or control tests — those functions belong to **Policy 5.02**. This policy consumes the outputs of both and produces the annual maturity assessment and executive

report that neither can produce independently. The annual policy review conducted under this policy operationalizes the annual internal review referenced in **Policy 1.05** Section 6.1 and does not alter the review cadence, approval chain, or change control workflow established there.

6.1 Review Scope and Cadence

The IT Director shall conduct the annual policy review and maturity scoring process once per fiscal year. The IT Director shall complete the review and submit the Annual Policy Review Report to the County Manager no later than ninety (90) calendar days after the conclusion of each fiscal year.

The review shall encompass every policy in the ECIO Policy Manual. The IT Director shall evaluate each policy for:

- **Implementation status**: whether the policy's directives are implemented and producing the intended outcomes.
- **Control effectiveness**: whether the controls defined in the policy are operating as designed, informed by the assessment results produced under **Policy 5.02**.
- **Operational relevance**: whether the policy's scope, directives, and controls remain appropriate given changes in the regulatory, technological, or operational environment since the prior review.
- **Workforce awareness**: whether personnel subject to the policy demonstrate awareness of and adherence to its requirements, informed by training and acknowledgment records maintained under **Policy 5.01**.
- **Regulatory alignment**: whether the policy's framework mappings and statutory citations remain current and accurate.

The review shall also encompass all appendices within Chapter 6 of the ECIO Policy Manual. The IT Director shall evaluate each appendix for currency and accuracy — whether its content reflects the current state of the policies, roles, frameworks, and operational structures it supports. Appendices do not receive maturity tier assignments; they are reference artifacts, not operational controls.

- **Clarification**: Standard Operating Procedures, playbooks, and other operational documentation maintained in the System of Engagement are not within the scope of this review. The currency of those documents is governed by **Policy 1.04** (Policy and Documentation Formatting Standards) and **Policy 3.13** (Knowledge Management Policy); their adequacy is tested through **Policy 5.02**.

The IT Director may delegate data compilation and preliminary analysis to the Assistant IT Director. The IT Director shall not delegate the maturity tier assignments or the preparation of the final Annual Policy Review Report.

6.2 Assessment Inputs

The IT Director shall base the annual policy review on the following governed set of inputs. The Assistant IT Director shall compile these inputs and present them to the IT Director prior to the commencement of the review.

- **Policy 5.07 Annual Audit Summary Report**: the consolidated results of all internal audits, self-assessments, and control tests conducted during the fiscal year, including conforming findings, observations, and deficiencies classified under Policy 5.02 Section 6.5.
- **Policy 5.04 annual KPI data**: the performance metrics and operational KPI results produced during the fiscal year, including any qualifying underperformance patterns identified under Policy 5.04.
- **Policy 3.16 annual improvement summary**: the summary of Service Improvement Register activity, triage decisions, and completed improvement actions produced under Policy 3.16.

- **Policy 5.03 open Corrective Action Plan status**: the current inventory of open Corrective Action Plans, their milestone status, and any plans that failed to achieve closure within the approved timeframe.
- **Policy 1.09 Risk Register status**: the current risk ratings, risk treatment decisions, and any risk posture changes recorded during the fiscal year.
- **Policy 5.01 enforcement and acknowledgment records**: the summary of enforcement actions taken during the fiscal year and the current status of policy acknowledgment compliance across all population classes.
- **Ad hoc inputs**: **Policy 4.07** (Postmortem Review and Lessons Learned) incident postmortem findings, external audit results, regulatory changes, and any other material that the IT Director determines is relevant to the review.

When an input defined above is not available at the time of review — for example, because a source policy has not yet been operationalized — the IT Director shall document the absence and note the impact on the maturity assessment for affected policies.

6.3 Maturity Scoring Methodology

The IT Director shall assign a maturity tier to each policy in the ECIO Policy Manual using criteria derived from the NIST Cybersecurity Framework (CSF) 2.0 Tier model. NIST CSF 2.0 defines Tiers as a characterization of the rigor of an organization's cybersecurity risk governance and management practices at the organizational level. This policy applies the Tier criteria as an internal scoring rubric for per-policy implementation effectiveness — an operational derivative, not a claim that NIST defines Tiers at individual-policy granularity.

The four (4) tiers, as adapted for per-policy maturity assessment, are:

- **Tier 1 — Partial**: The policy exists but its implementation is ad hoc, inconsistent, or reactive. Controls defined in the policy are not consistently applied. Assessment evidence under **Policy 5.02** is absent, incomplete, or shows material deficiencies. Personnel awareness is limited.
- **Tier 2 — Risk-Informed**: The policy is implemented with management awareness and risk-informed practices, but execution is not standardized across all areas within scope. Assessment evidence exists but reveals observations or inconsistencies. Corrective Action Plans under **Policy 5.03** may be in progress for controls governed by the policy.
- **Tier 3 — Repeatable**: The policy is consistently implemented across all areas within scope. Controls produce reliable, documented outcomes. Assessment evidence under **Policy 5.02** shows predominantly conforming results. The policy is reviewed and updated through the lifecycle process defined in **Policy 1.05**.
- **Tier 4 — Adaptive**: The policy implementation continuously improves based on audit findings, incident lessons learned, KPI data, and operational experience. Practices adapt proactively to changes in the threat environment, regulatory landscape, or operational context. Improvement activity under **Policy 3.16** is linked to the policy. Trend data shows sustained or improving maturity across two (2) or more consecutive review periods.

The IT Director shall document the rationale for each tier assignment. The rationale shall reference specific assessment inputs from Section 6.2 that support the determination.

- **Constraint**: The maturity tier assigned to a policy reflects the assessed state of implementation during the review period. It is not a target, a requirement, or a compliance standard. Tier assignment does not create an obligation to achieve a higher tier in the subsequent period. The IT Director may establish target tiers as a planning tool, but target tiers are advisory and do not carry enforcement consequences.

- **Clarification**: A policy that has been recently adopted or substantially revised may appropriately receive a Tier 1 or Tier 2 assignment in its first review cycle. A lower-tier assignment for a newly adopted policy does not constitute a deficiency.

6.4 Audit Program Effectiveness Review

As part of the annual policy review, the IT Director shall evaluate whether the internal audit program defined in **Policy 5.02** is being executed as designed.

The IT Director shall assess, at minimum:

- Whether the Annual Audit Plan was approved and executed within the cadences and scope requirements defined in **Policy 5.02** Section 6.1.
- Whether every policy in the ECIO Policy Manual received at least one (1) assessment — internal audit, self-assessment, or control test — during the fiscal year, as required by **Policy 5.02**.
- Whether policies governing controls subject to Criminal Justice Information Services (CJIS) Security Policy obligations received assessment through internal audit or control testing — not self-assessment alone — as required by **Policy 5.02**.
- Whether quarterly self-assessments were conducted on the cadence defined in **Policy 5.02** Section 6.2.
- Whether the control testing methodology defined in **Policy 5.02** Section 6.3 was applied consistently and produced documented results.
- Whether audit findings were classified and routed in accordance with **Policy 5.02** Section 6.5.
- Whether the objectivity safeguards defined in **Policy 5.02** Section 6.4 were maintained.

The IT Director shall document the results of this evaluation in the Annual Policy Review Report. The IT Director shall route deficiencies in the audit program in accordance with Section 6.7.

- **Rationale**: **Policy 5.02** cannot serve as its own assessment mechanism. This section provides the independent evaluation of the audit program that **Policy 5.02** Section 4 references through this policy.

6.5 Annual Policy Review Report

The IT Director shall prepare the Annual Policy Review Report as a single consolidated document following the conclusion of the annual review process. The IT Director shall document the report in the System of Engagement and classify it in accordance with **Policy 1.11**.

The Annual Policy Review Report shall contain, at minimum:

- The maturity tier assigned to each policy, with supporting rationale.
- Year-over-year tier comparison identifying policies that improved, maintained their tier, or regressed.
- A summary of the appendix currency and accuracy review, identifying any appendices requiring update.
- A summary of the audit program effectiveness review conducted under Section 6.4.
- The total number and classification of deficiencies identified during the review period, with current remediation status under **Policy 5.03**.
- A summary of open Corrective Action Plans and their impact on affected policy maturity assessments.
- A summary of regulatory, technological, or operational changes that affected or should affect policy content during the next review period.
- Recommendations for policy revisions to be initiated under **Policy 1.05**.
- Recommendations for the next annual audit cycle under **Policy 5.02**.

- Improvement candidates to be routed to the Service Improvement Register under **Policy 3.16**.

6.6 Executive Review

The IT Director shall submit the Annual Policy Review Report to the County Manager through the strategic reporting cadence established in **Policy 1.14** (Stakeholder Engagement and Communications Policy). The IT Director shall present the report during the Monthly Briefing following its completion and shall retain the report as an attachment to the corresponding Monthly Executive Report.

The County Manager shall provide written acknowledgment of receipt and review within thirty (30) calendar days of submission. The County Manager's review provides independent oversight of the annual review process and of the IT Director's execution of this policy. The County Manager may direct the IT Director to address specific concerns, conduct additional analysis, or revise maturity tier assignments with documented justification.

6.7 Findings Routing and Remediation

The IT Director shall route all actionable findings from the annual policy review through existing remediation and improvement pathways. This policy does not establish parallel tracking mechanisms, corrective action processes, or improvement registers.

- The IT Director shall route deficiencies in policy implementation or control effectiveness to **Policy 5.03** for Corrective Action Plan development.
- The IT Director shall initiate policy revisions identified through the review through the change control process defined in **Policy 1.05**.
- The IT Director shall route improvement opportunities that do not constitute deficiencies to the Service Improvement Register under **Policy 3.16**.
- The IT Director shall ensure that risk posture changes identified through the review are reflected in the Risk Register maintained under **Policy 1.09**.
- The IT Director shall route deficiencies in the audit program identified under Section 6.4 to **Policy 5.03** for Corrective Action Plan development and shall communicate those deficiencies to the County Manager in the Annual Policy Review Report.

6.8 Record Retention

The Assistant IT Director shall retain all annual policy review records — including scoring documentation, input summaries, working papers, the Annual Policy Review Report, and County Manager acknowledgment records — in the System of Engagement in accordance with **Policy 1.11** and the applicable Nevada Local Government Records Retention Schedule. Where multiple retention requirements apply, the longest applicable period shall govern.

The Assistant IT Director shall retain annual policy review records for a minimum of three (3) calendar years from the end of the calendar year to which they pertain, where no longer retention period is specified by an applicable schedule.

6. Appendices

6.01 Glossary and Definitions

This appendix defines terms that are coined by the ECIO Policy Manual, terms that carry a specific institutional meaning within the manual, and acronyms whose expansion is not obvious to the intended audience. Terms used in their ordinary, commonly understood sense and external framework terms used in their standard published meaning are excluded. Inclusion criteria and governance rules for this appendix are defined in **Policy 1.04**, Section 6.14.

Terms are listed in alphabetical order. Where a term's definition references a specific policy section, that section is the authoritative source for the complete definition.

A

Authoritative System of Record The designated master repository for governance controls. Within the ECIO framework, the LyX source file of the Information Operations Policy Manual constitutes the Authoritative System of Record. In the event of a discrepancy between the master file and any derivative copy, the master file and its compiled PDF take precedence. Defined in **Policy 1.04**, Section 6.1.

B

Breach Determination The formal finding, rendered exclusively by the IT Director, that a security incident constitutes a breach of personal information requiring notification under NRS 603A.220. The breach determination triggers the statutory notification process. Defined in **Policy 4.06**, Section 6.5.

C

CAP See Corrective Action Plan.

Catch-up RFC A retroactive Request for Change (RFC) record created after an Emergency change has already been implemented. The catch-up RFC documents the change action, captures the justification for Emergency designation, and provides the basis for the mandatory Change Control Authority review. Catch-up RFC documentation shall be completed within twenty-four (24) hours of implementation or by noon on the next business day, whichever is later. Defined in **Policy 3.09**, Section 6.6.

CCA See Change Control Authority.

Change Control Authority (CCA) The governance function that authorizes changes to County IT systems and infrastructure. The IT Director holds CCA authority for all Significant changes; CCA authority for Standard changes may be delegated to the Assistant IT Director. Emergency changes receive provisional CCA authorization for immediate implementation, followed by a mandatory catch-up CCA review. Defined in **Policy 3.09**, Section 6.3.

Child Work Order An operational work order that has been linked to a Parent Problem record under the Parent-Child Linkage mechanic. Child work orders are suppressed from independent troubleshooting while the Parent Problem investigation is active. Upon issuance of the Formal Closure Declaration, child work orders are mass-closed with a disposition status determined by the resolution outcome. Defined in **Policy 3.06**, Section 6.5.

CJI See Criminal Justice Information.

CMDB See Configuration Management Database.

Configuration Baseline The documented, approved configuration state of an information system from which all authorized changes are tracked. Baselines are derived from mandatory frameworks and serve as the reference point for drift detection and compliance assessment. Defined in **Policy 2.10**, Section 6.1.

Configuration Item (CI) A discrete entity — hardware, software, service, or documentation artifact — recorded in the Configuration Management Database (CMDB) and subject to configuration control.

Each CI shall have a defined set of attributes and relationships maintained in accordance with the CI record governance standards. Defined in **Policy 3.08**, Section 6.1.

Configuration Management Database (CMDB) The authoritative repository of Configuration Item records, their attributes, and their relationships. The CMDB is maintained in the System of Engagement and serves as the operational source of truth for the current state of all managed IT assets and services. Defined in **Policy 3.08**, Section 6.1.

Constructive Notice The legal principle by which publication of a policy in the Knowledge Base constitutes notice to all Information Operations personnel, regardless of whether each individual has personally read the document. Used as a compliance label in Section 4 when applicable. Defined in **Policy 1.04**, Section 6.6.

Corrective Action Plan (CAP) A structured remediation instrument that tracks deficiencies from identification through resolution. All remediation tracking instruments across the manual — regardless of originating label — follow the CAP lifecycle governed by **Policy 5.03**. Intake sources include audit deficiencies, sustained SLA non-compliance, risk response remediation, and compliance monitoring findings.

Criminal Justice Information (CJI) Data defined by the FBI Criminal Justice Information Services (CJIS) Security Policy as requiring specific handling, access, and protection controls. Includes Criminal History Record Information (CHRI), National Crime Information Center (NCIC) data, and related law enforcement data accessed through CJIS systems.

D

Deprecated Asset An IT asset that has been designated for replacement and is no longer authorized for new deployments or expanded use. The IT Director establishes a mandatory replacement deadline in the IT Asset Catalog upon Deprecated designation. Support continues within the labor ceiling framework during the replacement window. Defined in **Policy 3.01**, Section 6.4.

Directed Deputization A formal construct by which the IT Director designates Tier L3+ Information Operations Department personnel to exercise specific operational authority on the IT Director's behalf for a defined scope and duration. Directed Deputization is limited to operational functions and excludes a defined set of non-delegable authorities. Defined in **Policy 1.08**, Section 6.2.

E

ECIO Elko County Information Operations. The departmental abbreviation used throughout this manual to refer to the Information Operations Department and its governance framework.

Emergency Change A change that must be implemented immediately to restore service, address a security vulnerability, or prevent imminent harm, without the time to complete the standard Change Control Authority review process. Emergency changes receive provisional CCA authorization and require a catch-up RFC and CCA review within twenty-four (24) hours or by noon on the next business day, whichever is later. Defined in **Policy 3.09**, Section 6.5.

Evidence Artifact Any preserved item — including screenshots, exported logs, camera footage segments, and forensic captures — attached to a work order or incident record as supporting evidence. Evidence artifacts are stored in the Files field of the applicable record in the System of Engagement. Defined in **Policy 4.02**, Section 6.5.

F

Formal Closure Declaration The IT Director's formal closure of a Problem record upon satisfaction of all defined resolution conditions. The Formal Closure Declaration triggers mass-closure of all linked child work orders and deactivation of the associated Known Error record (if applicable) within two (2)

business days. A Problem record shall not be considered resolved by informal agreement or by the cessation of investigation activity. Defined in **Policy 3.07**, Section 6.6.

H

Hard Fork The mandatory, non-discretionary jurisdictional transfer from **Policy 3.06** (operational incident management) to Chapter 4 (cybersecurity incident response) upon discovery of an Indicator of Compromise during an operational response. The Hard Fork suspends **Policy 3.01** SLA obligations for the affected work order. No other SLA suspension mechanism exists within the operational framework. Defined in **Policy 3.06**, Section 6.2.

I

IC See Incident Commander.

Incident Commander (IC) The singular title for the individual exercising command authority during an active incident — operational (**Policy 3.06**) or cybersecurity (Chapter 4). No parallel title (e.g., Major Incident Manager) exists. For operational incidents, the Assistant IT Director serves as default IC. For cybersecurity incidents, the IT Director serves as IC unless a designee is appointed per **Policy 4.01**. Defined in **Policy 3.06**, Section 6.3.

Indicator of Compromise (IoC) An observable artifact or pattern — including but not limited to anomalous network traffic, unauthorized access attempts, malicious code signatures, and known threat intelligence indicators — that provides evidence of a security compromise. IoC definitions are maintained in a two-layer structure under **Policy 4.02**. Discovery of an IoC during an operational incident triggers the mandatory Hard Fork transfer.

IoC See Indicator of Compromise.

K

Knowledge Base The departmental knowledge repository maintained as governed artifacts in the System of Engagement. The Knowledge Base serves as the operational distribution mechanism for policies, SOPs, playbooks, Known Error workaround documentation, and other governed content. Governed by **Policy 3.13**.

Known Error A Problem for which the root cause has been identified and documented but for which a permanent fix has not yet been implemented. Upon Known Error declaration, the Investigator shall document the workaround in the Knowledge Base within two (2) business days. The workaround becomes searchable and feeds the mandatory workaround search step in **Policy 3.06**, Section 6.4. Known Error lifecycle is defined in **Policy 3.07**, Section 6.5.

L

LASO See Local Agency Security Officer.

Legal Hold A directive suspending retention and disposition actions for specified records during litigation, public records preservation requirements, audits, or other legal events. The IT Director shall suspend applicable retention schedules for the duration of the hold. Referenced in **Policy 1.11**.

Local Agency Security Officer (LASO) The individual designated under the CJIS Security Policy to serve as the security point of contact for the local agency's access to CJI systems. Within Elko County, designation currently defaults to the IT Director under **Policy 1.11**, Section 3. The LASO carries non-delegable accountability for CJIS Security Policy incident reporting obligations, though execution of CJIS notifications may be delegated.

M

Maturity Tier The rating assigned to each policy during the annual policy review and maturity scoring process, reflecting the policy's implementation completeness, operational effectiveness, and audit readiness. Maturity tier assignments are rendered by the IT Director and reported to the County Manager. Defined in **Policy 5.07**, Section 6.3.

N

Non-Delegable Authority A defined set of decision rights that the IT Director shall not delegate through the Directed Deputization construct or any other mechanism. Includes policy exception authority, risk acceptance authority, IC declaration, self-access-approval, NRS 603A.220 breach determination authority, and Separation of Duties Matrix functions. Defined in **Policy 1.08**, Section 6.2.

Notification Clock The external reporting obligation timeframe triggered by the declaration of a cybersecurity incident under Chapter 4. The notification window — measured from declaration — continues running during all phases of incident response (containment, eradication, recovery) and is not paused or satisfied by internal response activities. Execution is governed by **Policy 4.06**. Clock parameters established in **Policy 4.02**, Section 6.6.

O

Operational Handback The formal return of jurisdiction from Chapter 4 cybersecurity incident response to normal **Policy 3.06** operational management following completion of recovery operations. The Operational Handback restores SLA obligations and returns the affected assets or services to standard operational governance. Defined in **Policy 4.05**.

P

Parent-Child Linkage The mechanism by which new operational incidents matching an active Problem investigation are linked to the Parent Problem record as child work orders. Linked incidents are suppressed from independent troubleshooting while the investigation is active. Defined in **Policy 3.06**, Section 6.5.

PIR See Post-Implementation Review.

Playbook A scenario-based operational artifact governing decision-making and technical execution during defined incident or operational scenarios. Playbooks present branching decision logic rather than linear procedural steps and are distinct from SOPs. Maintained as governed Knowledge Base artifacts in the System of Engagement. Formatting standards are defined in **Policy 1.04**, Section 6.16. Content requirements are defined in **Policy 4.03**.

Policy Matrix The cross-reference appendix (**Appendix 6.02**) that maps each policy to its applicable framework controls, statutory requirements, and upstream authority alignment. Framework Alignment entries in Section 5 of each policy feed the Policy Matrix.

Post-Implementation Review (PIR) The formal review conducted after implementation of a Significant or Emergency change to verify that the change achieved its objectives, did not introduce unintended effects, and that all documentation obligations have been satisfied. Defined in **Policy 3.09**.

Postmortem The structured after-action review conducted following a cybersecurity incident to identify root causes, evaluate the effectiveness of the response, document lessons learned, and produce actionable recommendations. Postmortem participation is mandatory and shall not be deferred. Governed exclusively by **Policy 4.07**. Distinct from the operational Critical Incident Stakeholder Report governed by **Policy 3.06**.

Problem Record A formal investigation record opened in response to a spawn trigger to determine the root cause of one or more related incidents and to authorize permanent remediation. Problem records

operate under dual-authorization governance (Investigator and IT Director) and are distinct from operational work orders. Governed by **Policy 3.07**.

R

RFC See Request for Change.

Request for Change (RFC) The formal record documenting a proposed or completed change to County IT systems or infrastructure. RFCs are the documentary basis for Change Control Authority review and approval. The RFC record structure and lifecycle are defined in **Policy 3.09**.

Risk Register The centralized record of identified risks, their assessed severity, assigned response strategies, responsible owners, and current status. Maintained under **Policy 1.09** and provided as an input to the annual policy review and maturity scoring process.

S

Separation of Duties Matrix (SoD Matrix) The governance artifact that documents which functions shall not be performed by the same individual and which require independent authorization. Maintained by the IT Director and reviewed at least annually. Defined in **Policy 1.08**.

Service Level Agreement (SLA) The defined response and resolution timeframe commitments established for work orders based on their severity classification and asset lifecycle status. SLA targets are established in **Policy 3.01** and measured under **Policy 3.02**.

Severity Classification The standardized rating assigned to a work order at triage that determines its response and resolution timeframes under the service level commitments. Severity levels and their associated SLA targets are defined in **Policy 3.01**.

Significant Change A change that exceeds the scope of a Standard change and requires full Change Control Authority review and approval before implementation. The IT Director holds CCA authority for all Significant changes. Defined in **Policy 3.09**.

SLA See Service Level Agreement.

SLA Suspension The only condition under which **Policy 3.01** service level obligations are suspended for a work order. SLA Suspension occurs exclusively upon the Hard Fork jurisdictional transfer to Chapter 4. No other suspension mechanism exists for routine operational incidents.

SoD Matrix See Separation of Duties Matrix.

SoE See System of Engagement.

SOP See Standard Operating Procedure.

Spawn Trigger One of two (2) objective conditions that mandate the formal opening of a Problem record: (1) Major Incident — every incident classified as Critical severity; (2) Recurring Incident — five (5) or more incidents in the same category within a rolling thirty (30) day window. Spawn triggers are evaluated at incident closure. Defined in **Policy 3.06**, Section 6.7; received as intake in **Policy 3.07**, Section 6.1.

STAK Matrix The workforce competency mapping framework that categorizes each role's relationship to each policy across four (4) dimensions: Skill (technical competency), Task (operational execution), Awareness (knowledge requirement), and Knowledge (governance understanding). Maintained as **Appendix 6.03** and governed by **Policy 1.07**.

Standard Change A pre-authorized, low-risk change type that follows established procedures and does not require individual CCA review. Standard change authorization is captured within the work order mechanics under **Policy 3.05**. Defined in **Policy 3.09**.

Standard Operating Procedure (SOP) A procedural document maintained in the System of Engagement that provides step-by-step instructions for a defined operational task. SOPs are distinct from policies (which establish governance requirements) and playbooks (which present branching decision logic). SOP formatting standards are defined in **Policy 1.04**, Section 6.15.

System of Engagement (SoE) The accessible operational interface for day-to-day reference, work order management, Knowledge Base access, and procedural documentation. Content published in the System of Engagement shall be sourced from the Authoritative System of Record. In the event of a discrepancy, the Authoritative System of Record takes precedence. Defined in **Policy 1.04**, Section 6.1.

T

Technical Directive An emergency temporary policy amendment issued by the IT Director to address an immediate operational or security need. Technical Directives carry automatic ninety (90) day expiration and include anti-abuse safeguards. Defined in **Policy 1.05**, Section 6.3.

Tier Level The competency classification assigned to Information Operations personnel, ranging from Tier L0 (IT Trainee) through Tier L5 (IT Director). Tier level determines the scope of authorized operational functions, delegation eligibility, and competency maintenance requirements. Tier definitions and advancement criteria are established in **Policy 1.07**.

U

Umbrella RFC A single Request for Change record used to document a coordinated batch action affecting multiple systems — such as domain-wide credential rotation or synchronized malware removal — rather than creating separate RFC records per system. Individual affected systems are documented as line items within the umbrella RFC. Defined in **Policy 4.04**, Section 6.3.

V

Vendor Compliance Record The consolidated compliance summary maintained per-vendor in the System of Engagement, documenting the vendor's compliance posture, review history, and assurance evidence. The Vendor Compliance Record layers over operational data from **Policy 3.02** and enforcement data from **Policy 5.01**. It is the compliance summary layer, not the operational evidence base. Defined in **Policy 5.06**, Section 6.1.

6.02 Policy Matrix

Governance and Strategic Framework						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
1.01						
1.02						
1.03						
1.04						
1.05						
1.06						
1.07						
1.08						
1.09						
1.10						
1.11						
1.12						
1.13						
1.14						

Information Security						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
2.01						
2.02						
2.03						
2.04						
2.05						
2.06						
2.07						
2.08						
2.09						
2.10						
2.11						
2.12						
2.13						
2.14						
2.15						

Service Management and Operations						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
3.01						
3.02						
3.03						
3.04						
3.05						
3.06						
3.07						

Service Management and Operations						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
3.08						
3.09						
3.10						
3.11						
3.12						
3.13						
3.14						
3.15						
3.16						
3.17						

Incident Response						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
4.01						
4.02						
4.03						
4.04						
4.05						
4.06						
4.07						

Compliance and Oversight						
ID	Policy Title	NIST 800-53 r5	NIST CSF 2.0	CJIS v6.0	COBIT 2019	Statutory/Other
5.01						
5.02						
5.03						
5.04						
5.05						
5.06						
5.07						

Table 2 — Policy Dependency and Integration Matrix.

The governance flow map. Rows are ECIO policies, columns are Feeds, Defers To, and Receives From. A policy author asking "if I amend Policy 3.06, what else do I need to review?" scans the row and sees every downstream policy that receives from it. An IT Director asking "what is the full jurisdictional chain for a ransomware event?" traces the Feeds column from 3.12 through to 4.08. This table is an internal instrument — it lives in the document but is clearly labeled as internal governance reference, not the compliance artifact.

Governance and Strategic Framework				
ID	Policy Title	Feeds	Defers To	Receives From
1.01				
1.02				

Governance and Strategic Framework				
ID	Policy Title	Feeds	Defers To	Receives From
1.03				
1.04				
1.05				
1.06				
1.07				
1.08				
1.09				
1.10				
1.11				
1.12				
1.13				
1.14				

Information Security				
ID	Policy Title	Feeds	Defers To	Receives From
2.01				
2.02				
2.03				
2.04				
2.05				
2.06				
2.07				
2.08				
2.09				
2.10				
2.11				
2.12				
2.13				
2.14				
2.15				

Service Management and Operations				
ID	Policy Title	Feeds	Defers To	Receives From
3.01				
3.02				
3.03				
3.04				
3.05				
3.06				
3.07				
3.08				
3.09				
3.10				
3.11				
3.12				

Service Management and Operations				
ID	Policy Title	Feeds	Defers To	Receives From
3.13				
3.14				
3.15				
3.16				
3.17				

Incident Response				
ID	Policy Title	Feeds	Defers To	Receives From
4.01				
4.02				
4.03				
4.04				
4.05				
4.06				
4.07				

Compliance and Oversight				
ID	Policy Title	Feeds	Defers To	Receives From
5.01				
5.02				
5.03				
5.04				
5.05				
5.06				
5.07				

6.03 Workforce Roles STAK Matrix

IT Trainee (Tier L0) *Focus: Learning & Assimilation*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Technical Literacy	Identify basic hardware and software components of IT systems.	Apply foundational IT concepts under supervision.	Computer hardware, operating systems, file systems.	CompTIA A+, SFIA ITOP 1
Troubleshooting	Assist with diagnosing and resolving common user issues.	Follow step-by-step guides and ask clarifying questions.	Basic diagnostic tools, error codes, support documentation.	CompTIA A+, SFIA USUP 1
Ticketing	Log basic user requests and document actions taken.	Use templates and follow format guidelines accurately.	Service desk ticketing systems, terminology standards.	Internal SOP, SFIA USUP 1
Professional Conduct	Demonstrate workplace etiquette, communication, and dress code adherence.	Follow department norms and seek feedback proactively.	Departmental ethos, communication protocols.	Internal Policy, SFIA METL 2
Security Awareness	Identify common security threats and acceptable use violations.	Report suspicious activity and avoid unsafe behavior.	CJIS Security Awareness (Level 2), Phishing, AUP.	CJIS 5.2, SFIA SCTY 2
Workflow	Participate in structured task rotations with Support and Admin teams.	Observe, document, and follow instructions across tasks.	Basic IT operations, workflow diagrams, tool usage norms.	Internal SOP, SFIA USUP 1
Certification	Study for and pass CompTIA A+ and Network+ within 12-month program.	Follow a learning plan, complete practice exams.	A+ exam domains and objectives.	CompTIA Learning Objectives

Administrative Assistant (Tier L1) *Focus: Process & Logistics*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Visitor Mgmt	Greet visitors to the IT department and verify identity as needed.	Follow visitor procedures and validate credentials confidently.	Visitor policy, ID types, physical access protocols.	Internal Policy, SFIA SCTY 2
Communication	Receive, direct, and document incoming calls and messages.	Communicate clearly and route requests to appropriate personnel.	Departmental structure, communication etiquette.	Internal SOP, SFIA CSMG 2
Documentation	Assist with formatting and distributing IT communica-tions.	Use templates and maintain consistent document structure.	Style guides, document handling protocols.	Policy 1.04, SFIA ADMN 2
Scheduling	Coordinate meetings, reserve rooms, and manage calendars.	Use scheduling tools and communicate availability accurately.	Calendar software, internal scheduling policies.	SFIA ADMN 2
Onboarding	Prepare materials and coordinate logistics for new IT staff onboarding.	Assemble packets and liaise with HR and mentors.	Onboarding checklist, training materials.	SFIA ADMN 2
Inventory	Receive and track basic IT inventory deliveries.	Check items against invoices and update inventory records.	Receiving processes, asset tags, inventory system.	SFIA ASMG 2
Credential Support	Assist with basic password resets (Non-Privileged Only).	MUST verify identity per **Policy 2.05** prior to any reset.	Password policy, social engineering indicators.	NIST IA-2, SFIA USUP 2

Support Specialist (Tier L2) *Focus: Service & Resolution*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Endpoint Support	Diagnose and resolve issues with desktops, laptops, and mobile devices.	Apply structured troubleshooting methods.	Windows/macOS, drivers, BIOS, performance tools.	NICE IO-WRL-007, SFIA ITOP 3
Peripheral Config	Install and configure local and networked print-ers/scanners.	Troubleshoot connectivity and driver-related issues.	Print spoolers, network shares, vendor support tools.	NICE IO-WRL-007, SFIA ITOP 3
App Support	Configure and troubleshoot common software (Email, Office, PDF).	Assist users with usage errors and patches.	Outlook, Microsoft Office, Adobe tools, user profiles.	NICE IO-WRL-007, SFIA CSMG 3
User Support	Interact with end-users to understand, resolve, or escalate issues.	Listen actively, communicate clearly, and remain professional.	Service culture, escalation triggers, empathy principles.	NICE IO-WRL-007, SFIA CSMG 3
Identity Mgmt	Reset passwords and verify user identity across systems.	Follow documented verification and reset procedures.	Authentication policies, MFA workflows.	NICE IO-WRL-007, SFIA SCAD 3
Asset Deployment	Provision, label, and deploy new IT assets to users.	Follow imaging checklists and ensure successful deployment.	Imaging tools, inventory control, naming conventions.	NICE IO-WRL-007, SFIA HSIN 3
Ticketing	Log all work performed in the service management system.	Use clear, structured language and document resolution.	Service desk taxonomy, change history recording.	NICE IO-WRL-007, SFIA ASUP 3
Escalation	Escalate issues appropriately when outside Tier 1 authority.	Recognize issue boundaries and route to the correct tier.	Escalation policies, troubleshooting boundaries.	NICE IO-WRL-007, SFIA USUP 3
Security Check	Verify antivirus, patches, and device encryption on devices.	Use tools to check compliance and document findings.	AV software, update tools, Bit-Locker/FileVault.	NICE IO-WRL-007, SFIA SCTY 3

Network Administrator (Tier L3) *Focus: Connectivity & Boundary Defense*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Net Architecture	Design and document LAN, WAN, and wireless topologies.	Develop scalable, fault-tolerant network designs.	IP subnetting, VLANs, routing protocols, topology models.	NICE IO-WRL-004, SFIA NTDS 5
Device Config	Configure routers, switches, firewalls, and wireless controllers.	Apply configurations using CLI and GUI tools per standards.	IOS/CLI, DHCP, DNS, NAT, VLAN tagging.	NICE IO-WRL-004, SFIA ITOP 4
Firewall Mgmt	Implement and audit firewall rule sets and ACLs.	Balance functionality and security based on least privilege.	Firewall zones, rule ordering, logging, VPN passthrough.	NICE PD-WRL-004, SFIA SCTY 5
Monitoring	Monitor traffic, performance, and respond to anomalies.	Use SNMP, syslog, and flow tools to identify root causes.	SNMP, NetFlow, ping/traceroute, log correlation.	NICE IO-WRL-004, SFIA NTAS 4
VPN/Remote	Deploy and manage secure remote access tunnels.	Configure site-to-site and client VPNs with authentication.	IPSec, SSL VPNs, RADIUS, MFA integrations.	NICE IO-WRL-004, SFIA NTAS 5
Security Compliance	Enforce and verify compliance with network security standards.	Audit configurations and isolate insecure behaviors.	NIST 800-53 AC/SC, CJIS encryption standards.	NICE PD-WRL-004, SFIA SCTY 5
Change Mgmt	Submit and execute approved changes to live configurations.	Prepare rollback plans and follow documentation procedures.	CAB process, change forms, outage notification steps.	NICE OG-WRL-002, SFIA CHMG 4
Risk Audit	Conduct self-audits of networking systems and identify risks.	Map risks to controls and support mitigation planning.	CIS Controls, NIST CSF, CJIS 5.9.	NICE OG-WRL-012, SFIA AUDT 4

Systems Administrator (Tier L3) *Focus: Server Infrastructure & Data Integrity*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Server Provisioning	Build and configure physical and virtual servers.	Install OS, configure baseline, and join to directory.	Hyper-V/VMware, Windows/Linux, Active Directory.	NICE IO-WRL-005, SFIA ITOP 4
Database Mgmt	Maintain integrity, backups, and encryption (TDE) of SQL.	Ensure availability and CJIS-compliant storage.	SQL, Oracle, CJIS 5.10, Backup strategies.	NICE IO-WRL-002, SFIA DBAD 4
Identity Mgmt	Create, manage, and audit user accounts and permissions.	Apply RBAC and enforce least-privilege principles.	Active Directory, GPOs, NTFS permissions, LDAP.	NICE IO-WRL-005, SFIA SCAD 4
Patch Mgmt	Apply OS and application patches according to policy.	Use automated tools to deploy and verify patches.	WSUS/SCCM, CVSS scoring, patch windows.	NICE IO-WRL-005, SFIA VUAS 4
System Monitoring	Monitor and optimize system health and performance.	Interpret logs, counters, and alerts to maintain uptime.	Event Viewer, Performance Monitor, SNMP traps.	NICE IO-WRL-005, SFIA ASUP 4
Backup & Recovery	Configure, monitor, and test system backups/DR.	Perform restorations to verify data integrity.	Veeam/Altaro, RTO/RPO, DR planning.	NICE IO-WRL-005, SFIA STMG 4
Config Mgmt	Document and manage baseline configura-tions/changes.	Maintain golden images and enforce approved changes.	CMDB, configuration scripts, version control tools.	NICE IO-WRL-005, SFIA CFMG 4
Security Hardening	Apply security policies and controls to managed systems.	Disable unnecessary services, enforce baselines, audit logs.	CIS Benchmarks, STIGs, NIST AC & SC families.	NICE IO-WRL-006, SFIA SCTY 5
Scripting	Write scripts to automate administration tasks.	Use Power-Shell/Bash to streamline repeatable operations.	PowerShell syntax, Bash scripting, task scheduling.	NICE IO-WRL-005, SFIA PROG 3
Audit Support	Produce system data and evidence during audits.	Export logs, review access, and respond to findings.	CJIS 5.9, NIST 800-53, audit log tools.	NICE OG-WRL-012, SFIA AUDT 4

Assistant IT Director (Tier L4) *Focus: Operations & Governance Execution*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Ops Oversight	Supervise day-to-day operations of support/infra teams.	Coordinate workstreams and monitor SLA adherence.	ITIL service management, workflows, escalation paths.	NICE OG-WRL-010, SFIA ITMG 5
Project Mgmt	Manage the departmental IT project portfolio.	Track milestones, allocate resources, resolve conflicts.	Project lifecycle models, PM tools, resource balancing.	NICE OG-WRL-011, SFIA POMG 5
Vendor Mgmt	Oversee IT vendor contracts and SLAs.	Negotiate terms, assess performance, manage renewals.	Procurement policy, SLA frameworks, vendor scorecards.	NICE OG-WRL-009, SFIA SUPP 5
Policy Enforcement	Ensure compliance with internal IT policies and regulations.	Conduct reviews and implement corrective actions.	Departmental policies, NIST 800-53, CJIS 5.9.	NICE OG-WRL-002, SFIA BURM 5
Staff Dev	Lead performance management and career planning.	Conduct evaluations, set goals, provide feedback.	HR frameworks, coaching methods, performance tracking.	NICE OG-WRL-003, SFIA PDSV 5
Budget Control	Support financial planning and cost monitoring.	Develop budgets, track spend, optimize expenses.	Public budgeting standards, procurement systems.	NICE OG-WRL-010, SFIA FMIT 5
Incident Escalation	Serve as escalation authority for major incidents.	Coordinate response teams and ensure resolution.	Incident response plans, service continuity procedures.	NICE PD-WRL-003, SFIA USUP 5
Change Leadership	Oversee and authorize operational changes.	Evaluate change impact and ensure communication.	Change Advisory Board (CAB) process.	NICE OG-WRL-002, SFIA CHMG 5

IT Director (Tier L5) *Focus: Strategy, Risk & Executive Leadership*

Skill (S)	Task (T)	Ability (A)	Knowledge (K)	Sources
Strategic Planning	Develop and maintain multi-year IT strategy.	Synthesize input from departments into strategic goals.	COBIT, NIST CSF, public sector planning cycles.	NICE OG-WRL-007, SFIA ITSP 6
Governance	Define and oversee implementation of IT governance.	Evaluate frameworks and tailor controls to needs.	COBIT 2019, CJIS Security Policy, NIST 800-53.	NICE OG-WRL-007, SFIA GOVN 6
Executive Mgmt	Represent IT in executive meetings and collaborations.	Communicate IT initiatives in terms of strategic impact.	Government budgeting processes, dependencies.	NICE OG-WRL-007, SFIA RLMT 6
Risk Mgmt	Oversee IT risk management (CISO function).	Evaluate risk posture and approve mitigation strategies.	CJIS 5.9, NIST RMF, risk register maintenance.	NICE OG-WRL-007, SFIA BURM 6
Policy Approval	Approve department-level IT policies.	Authorize and delegate policy enforcement.	Policy development lifecycle, governance standards.	NICE OG-WRL-002, SFIA GOVN 6
Budget Oversight	Develop and manage the annual IT budget.	Balance strategic initiatives with operational needs.	Capital and operational budgeting, procurement.	NICE OG-WRL-007, SFIA FMIT 6
Innovation	Evaluate emerging technologies for strategic adoption.	Facilitate pilot programs and implementation strategies.	Tech scanning, cost-benefit analysis, change leadership.	NICE OG-WRL-007, SFIA INOV 6
Leadership	Provide leadership to the Assistant Director and staff.	Set vision, model expectations, guide culture.	Organizational development, public accountability.	NICE OG-WRL-003, SFIA PEMT 6

6.04 Revision History and Version Control

Effective: July 01, 2026 Version: 1.0

This appendix is the authoritative revision log of the Elko County Information Operations Policy Manual and defines the governance rules that produce its entries. Lifecycle and version control obligations that drive entries into this appendix are defined in **Policy 1.05** (Policy Review and Update Procedures). Records retention timing for archived versions is governed by LRDA 20070057 (Departmental Regulations, Policies and Procedures).

Version numbers and effective dates recorded during pre-publication drafting do not constitute published versions and shall not appear in this appendix. The manual's recorded history begins with the genesis entry dated July 1, 2026, at which point every policy in the manual took effect at Version 1.0.

Entry Schema

Every entry in the revision history shall consist of five (5) fields, recorded in the following order:

- **Date**: The date the change takes effect, recorded in ISO 8601 format (YYYY-MM-DD).
- **Scope**: The policy number (e.g., 1.04), the appendix number (e.g., 6.01), or "ALL" when the entry applies to the entire manual.
- **Version**: The version number assigned to the affected policy, appendix, or manual as a result of the change, following the increment rules defined below. RETIRE entries shall record the Version field as an em-dash ("—"), indicating that no forward version exists.
- **Type**: One of the four (4) controlled values defined in the Entry Types subsection below. No other values shall be used.
- **Note**: A concise description of the change. Cross-references to policies, appendices, or external authorities within the Note field shall follow the formatting conventions defined in **Policy 1.04** (Policy and Documentation Formatting Standards).

Entry Types

The Type field shall use exactly one (1) of the following controlled values. This list is the closed set of entry types; no additional values shall be introduced without approval by the IT Director and incorporation into this appendix.

- **CREATE**: The manual's entry into force. This value applies only to the genesis entry.
- **AMEND**: A minor version increment that does not supersede a prior published version.
- **SUPERSEDE**: A major version increment that replaces a prior published version. The superseded source file shall be archived in accordance with the conventions defined in the Archive and Marking Conventions subsection below.
- **RETIRE**: Permanent removal of a policy or appendix from active circulation.

Version Increment Rules

The IT Director shall determine whether a change warrants a major or minor version increment based on the substantive impact of the change, in accordance with the following rules.

- **Major Version Increment (X.00)**: Structural changes to a policy or appendix, section additions or deletions, directive changes that alter compliance obligations, or role reassignments that change accountability.

- **Minor Version Increment (x.YY)**: Tightening of existing directives without substantive change, clarification of ambiguous language, correction of cross-references, typographical corrections, or stylistic alignment with **Policy 1.04**.

Clarification: Every published change shall receive a version increment. The IT Director shall not apply an unlogged change to a published policy or appendix.

Archive and Marking Conventions

- **Obsolete Marking**: When a policy or appendix is superseded, the IT Director shall append a “Status: Obsolete” notation to the Policy Metadata header of the archived copy. The live, in-force copy of the manual shall reflect only the current version.
- **Supersession Archive**: The IT Director shall archive the superseded source file under the path "/archive/[identifier]_v[major.minor].lyx" (e.g., "/archive/108_v1.3.lyx" for a superseded Policy 1.08 Version 1.3). Retention shall conform to LRDA 20070057.
- **Retirement Archive**: The IT Director shall archive retired policies or appendices under the path "/archive/retired/[identifier]_v[major.minor].lyx", where the recorded version is the final published version prior to retirement. Retention shall conform to LRDA 20070057.

Revision History

Date	Scope	Version	Type	Note
2026-07-01	ALL	1.0	CREATE	Policy manual Version 1.0 in effect.